Tabla de contenidos

- Perfil de Egreso - Plataforma Web Integral CERMAT
  - Proyecto
  - Entregables
    - A. Gestión de Tecnologías de Información (CE01)
    - B. Ingeniería de Software (CE02)
    - C. Infraestructura Tecnológica (CE03)
  - Resumen del sistema (medido el 2026-10-24)
  - Arquitectura
  - Evidencia técnica (repositorio academia-school-platform)
- Brief EPE — Plataforma Web Integral CERMAT
  - 1. Información general
  - 2. Problema
  - 3. Contexto y Stakeholders
    - Organización / entorno
    - Usuarios / actores
    - Mapa de stakeholders
  - 4. Objetivo del sistema
    - Objetivo medible EPE
  - 5. Alcance
    - Incluye
    - No incluye
    - Supuestos
  - 6. Datos
    - Entidades principales

Origen de datos

Restricciones

7. Enfoque de solución

Tipo de sistema

Consideraciones técnicas

Arquitectura básica

Decisiones justificadas EPE

Arquitectura por capas

8. Viabilidad

9. Alineación con competencias

Relación con la guía oficial

Frase clave

A. Área de Gestión de Tecnologías de Información (CE01)

Resumen del área

Competencias de Gestión de TI

Mapa de entregables y evidencias

Cómo se encadenan los entregables

Artefactos del área

Coherencia con las otras líneas

E1 — Diagnóstico Organizacional y Alineamiento Estratégico (CE0111–CE0115)

Portada

Resumen ejecutivo

1.1 Contexto organizacional

Descripción del sector y entorno competitivo

Estructura organizacional

Cadena de valor

Mapa de stakeholders

1.2 Análisis estratégico

Misión, visión y objetivos estratégicos

Análisis FODA sustentado con evidencia

Análisis PESTEL (breve)

Factores críticos de éxito

Alineamiento estratégico (CE0112)

1.3 Diagnóstico digital / TI

Inventario de sistemas de información existentes

Nivel de madurez digital

Brechas tecnológicas

Problemas operativos asociados a TI

1.4 Identificación del problema

Definición estructurada del problema

Causas raíz (árbol de problemas)

Impacto estratégico

Justificación de la intervención

1.5 Roadmap de tecnología (CE0114)

1.6 Matriz de riesgos estratégicos (CE0115)

Referencias

Rúbrica de evaluación

E2 — Business Case del Proyecto (CE0113)

Portada

Resumen ejecutivo

2.1 Justificación del proyecto

Problema que se resuelve

Objetivos del proyecto (SMART)

Beneficios esperados

2.2 Análisis de alternativas

Alternativas tecnológicas consideradas

Criterios de evaluación

Matriz comparativa

2.3 Evaluación de beneficios

Beneficios cuantificables

Beneficios cualitativos

Indicadores de valor

2.4 Estimación de costos

2.4.1 Supuestos del modelo

2.4.2 Inversión inicial

2.4.3 Costos operativos y de mantenimiento

2.4.4 Flujo de caja y evaluación económica a 3 años

2.4.5 Análisis de sensibilidad

2.4.6 Recomendación y criterios del hito de continuidad

2.5 Riesgos iniciales

Referencias

Anexos

Rúbrica de evaluación

E3 — Plan de Gestión del Proyecto (CE0121–CE0125)

Portada

Resumen ejecutivo

3.1 Acta de constitución

3.2 Gestión del alcance

EDT / WBS

Diccionario de la EDT

Control de cambios

3.3 Gestión del cronograma

Lista de actividades

Diagrama de Gantt

Hitos principales

3.4 Gestión de costos

Presupuesto detallado

Línea base de costos

Control presupuestal

3.5 Gestión de riesgos

Identificación y análisis cualitativo

Plan de respuesta y seguimiento

3.6 Gestión ágil

Marco de trabajo

Product backlog

Sprint planning

Incrementos y métricas de seguimiento

Referencias

Rúbrica de evaluación

E4 — Modelado de Procesos AS-IS / TO-BE (CE0131–CE0135)

Portada

Resumen ejecutivo

Identificación y caracterización de procesos (CE0131)

Mapa de procesos

Priorización del proceso a rediseñar

Caracterización del proceso de matrícula

4.1 Proceso actual (AS-IS) (CE0132)

Descripción narrativa

Diagrama BPMN (AS-IS)

Actividades y tiempos (supuestos a validar)

Indicadores actuales

Problemas detectados

4.2 Proceso propuesto (TO-BE) (CE0133 y CE0134)

Rediseño del flujo

Diagrama BPMN (TO-BE)

Automatizaciones propuestas

Actividades y tiempos del TO-BE

Nuevos indicadores

Mejora estimada en eficiencia

4.3 Análisis comparativo (CE0135)

4.3.1 Reducción de tiempos

4.3.2 Reducción de costos

4.3.3 Mejora en calidad

4.3.4 Plan de medición

Referencias

Rúbrica de evaluación

E5 — Propuesta de Solución TIC Integrada al Ecosistema de Sistemas de Información (CE0141–CE0145)

Portada

Resumen ejecutivo

5.1 Arquitectura de la solución (CE0142)

Diagrama de arquitectura (objetivo 2027–2028)

Componentes principales

Integraciones

5.2 Ecosistema de sistemas de información (CE0141 y CE0143)

Mapa de sistemas actuales

Integración propuesta

Flujo de información del caso N2 (propuesto)

Interoperabilidad

5.3 Seguridad y gobernanza

Gestión de accesos

Protección de datos (Ley N.° 29733)

Cumplimiento y hallazgos reales

Gobernanza

5.4 Escalabilidad y sostenibilidad

Capacidad de crecimiento

Costos futuros

Evolución tecnológica

5.5 Plan de implementación y gestión del sistema de información (CE0144)

Fases

Capacitación

Soporte y operación

5.6 Indicadores de uso, valor y mejora (CE0145)

Referencias

Rúbrica de evaluación

E1 - Requerimientos y Diseño del Sistema (CE021)

Portada

Resumen Ejecutivo

Sección 1: Especificación de Requerimientos

1.1 Requerimientos funcionales

1.2 Requerimientos no funcionales

1.3 Reglas de negocio

1.4 Restricciones del sistema

1.5 Historias de usuario y criterios de aceptación

Sección 2: Prototipo Navegable

2.1 Fidelidad y flujo de navegación

2.2 Pantallas principales

2.3 Evidencia de validación con usuarios

Sección 3: Diseño Arquitectónico

3.1 C1 — Contexto del sistema

3.2 C2 — Contenedores (cumple el rol de vista de despliegue)

3.3 C3 — Componentes de la SPA y de la API

3.4 Registro de decisiones arquitectónicas (ADR)

Sección 4: Diseño Detallado

4.1 Diagrama de casos de uso

4.2 Diagrama de clases del dominio

4.3 Diagramas de secuencia

4.4 Diagrama de estados de la matrícula

4.5 Modelo de diseño detallado

Anexos

Anexo A — Acta de validación con stakeholders (plantilla)

Anexo B — Matriz de trazabilidad de requerimientos

Anexo C — Diagramas complementarios

Anexo D — Evidencia de sustentación

Rúbrica de Evaluación

E2 - Plataforma de Datos del Sistema (CE022)

Portada

Resumen Ejecutivo

Sección 1: Modelo de Datos

1.1 Modelo entidad-relación (conceptual)

1.2 Modelo lógico relacional (MySQL)

1.3 Modelo normalizado

1.4 Diccionario de datos

Sección 2: Implementación de Base de Datos

2.1 Scripts DDL

2.2 Scripts DML

2.3 Evidencias de creación

Sección 3: Consultas y Programación en Base de Datos

3.1 Consultas SQL relevantes (91_consultas.sql)

3.2 Procedimientos almacenados

3.3 Funciones

3.4 Triggers

3.5 Planes de ejecución

Sección 4: Seguridad y Administración

4.1 Usuarios y roles

4.2 Auditoría implementada

4.3 Estrategias de respaldo y recuperación

4.4 Evidencias de monitoreo

Pruebas de la capa de datos

Consistencia con el sistema

Anexos

Rúbrica de Evaluación

E3 - Sistema de Software Funcional Integrado (CE023)

Portada

Resumen Ejecutivo

Sección 1: Arquitectura e Integración

1.1 Arquitectura general

1.2 Capas, módulos y servicios

1.3 Integración con la base de datos

1.4 Integración con servicios externos

Sección 2: Funcionalidad del Sistema

2.1 Flujos principales implementados

2.2 Gestión de usuarios, permisos y roles

2.3 Evidencias funcionales

Sección 3: Código y Diseño Técnico

3.1 Estructura del repositorio

3.2 Patrones y buenas prácticas aplicadas

3.3 Modularidad y desacoplamiento

3.4 Manejo de errores y validaciones

Sección 4: Despliegue o Instalación

4.1 Instrucciones de instalación

4.2 Configuración requerida (solo nombres de variables)

4.3 Evidencia de despliegue y ejecución

Anexos

Rúbrica de Evaluación

E4 - Gestión del Proyecto y Calidad de Software (CE024)

Portada

Resumen Ejecutivo

Sección 1: Pruebas

1.1 Estrategia por niveles

1.2 Casos de prueba automatizados

1.3 Reporte de ejecución (2026-10-24)

1.4 Reporte de cobertura

1.5 Evidencia de pruebas sobre flujos críticos

1.6 Las pruebas detectan defectos reales

Sección 2: Integración, Despliegue y Operación Continua

2.1 Pipeline CI/CD

2.2 Configuración de automatización

2.3 Evidencias de integración y despliegue

2.4 Observabilidad en producción

2.5 Estrategia de rollback y respaldos

2.6 Análisis del incidente: reglas sin publicar desde junio

2.7 Cierre en producción (2026-10-24)

Sección 3: Gestión Ágil del Proyecto de Software

3.1 Project Charter

3.2 Historias de usuario

3.3 Product Backlog

3.4 Sprint Backlog — Sprint 1 "Calidad y seguridad"

3.5 Ceremonias y métricas de avance

3.6 Comparación con otros marcos de proceso

Sección 4: Aseguramiento y Auditoría de la Calidad del Software

4.1 Matriz de calidad (ISO/IEC 25010)

4.2 Instrumentos de aseguramiento

4.3 Evaluación de la calidad del código

4.4 Informe de auditoría técnica

4.5 Plan de mejora de la calidad

Anexos

Rúbrica de Evaluación

C. Infraestructura Tecnológica (CE03)

Objeto del proyecto

Codificación de entregables

Distribución por semestre

Reglas comunes de la guía

Equivalencias tecnológicas

Matrices y diagramas

Cifras de la línea

S1-E1 · Análisis y Diseño de Red (CE0311)

Portada

1. Resumen ejecutivo del diseño de red

2. Descripción de la organización y necesidades de red

2.1 Organización

2.2 Usuarios y sedes

2.3 Servicios TI

2.4 Uso previsto de la nube y del entorno local

2.5 Ancho de banda, disponibilidad y crecimiento

2.6 Requisitos técnicos y organizacionales

3. Servicios y procesos críticos dependientes de la red

4. Partes interesadas relevantes

5. Alcance del diseño de red

6. Objetivos medibles del diseño

7. Topología general de infraestructura de red

8. Topología lógica de red

8.1 VLAN, subredes y direccionamiento

8.2 Gateways, DHCP y DNS

8.3 Ruteo

8.4 Comunicación permitida y denegada entre zonas

8.5 Redes inalámbricas

9. Diseño de seguridad perimetral y zonas

10. Diseño de conectividad VPN híbrida

11. Diagrama de flujo de información planeado

12. Matriz de componentes de red

13. Diseño de seguridad perimetral

13.1 Producto propuesto

13.2 Interfaces y zonas

13.3 Política por defecto

13.4 Criterio general de reglas

13.5 Reglas planeadas en OPNsense

13.6 Firewall de host del VPS (equivalente a Security Group)

14. Diseño de detección: IDS/IPS y honeypot

14.1 IDS/IPS (Suricata en OPNsense)

14.2 Honeypot (Cowrie)

14.3 SIEM (Wazuh)

14.4 Eventos esperados

14.5 Plan de validación para el Semestre 2

15. Escalabilidad, conclusiones, hoja de ruta y referencias

15.1 Escalabilidad

15.2 Conclusiones

15.3 Hoja de ruta hacia la implementación

15.4 Referencias

Anexos

Anexo A. Matriz de pruebas de conectividad planeadas

Anexo B. Diagramas editables

Anexo C. Estándares aplicados

Rúbrica de evaluación

Portada

1. Resumen ejecutivo del diseño del centro de datos híbrido

2. Descripción de la organización y necesidades de infraestructura

    2.1 Servicios a alojar

    2.2 Información gestionada

    2.3 Uso previsto de la nube y del entorno local

    2.4 Crecimiento estimado

3. Alcance del diseño

4. Objetivos medibles

5. Arquitectura on-premise

    5.1 Topología física

    5.2 Rack

    5.3 Firewall

    5.4 Switches y puntos de acceso

    5.5 Almacenamiento

    5.6 UPS y energía

    5.7 Host de virtualización

    5.8 Enlaces

    5.9 Nivel de disponibilidad (Uptime Institute)

    5.10 Ambiente y seguridad física

6. Diseño del hipervisor

    6.1 Elección y equivalencia

    6.2 Conmutadores virtuales, port groups y VLAN

    6.3 NIC teaming

    6.4 Máquinas virtuales planeadas

7. Arquitectura en la nube (equivalente a AWS)

    7.1 Región

7.2 Equivalencias de la arquitectura AWS

7.3 Instancia

7.4 Security Group y NACL

7.5 Servicios PaaS

7.6 Alternativa en AWS Academy (no usada)

8. Mecanismo de integración híbrida

9. Matriz de componentes del centro de datos

10. Dimensionamiento y capacidad

10.1 Carga esperada

10.2 Dimensionamiento de las VM

10.3 Capacidad del host y margen

10.4 Margen de crecimiento

10.5 Límite real del VPS

10.6 Supuestos

11. Disponibilidad y continuidad

11.1 Redundancia

11.2 Respaldo previsto (regla 3-2-1)

11.3 RTO y RPO objetivo por servicio

11.4 Validación esperada en el Semestre 2

11.5 Contingencia de la sede

12. Conclusiones, hoja de ruta y referencias

12.1 Conclusiones

12.2 Hoja de ruta

12.3 Referencias

Anexos

Rúbrica de evaluación

Portada

Resumen ejecutivo

1. Índice del expediente

2. Síntesis del diseño de red

3. Síntesis del diseño del centro de datos híbrido

4. Diagramas

5. Matrices

6. Trazabilidad de requerimientos

7. Coherencia entre el diseño de red y el del centro de datos

8. Conclusiones

9. Referencias

10. Anexos cruzados

11. Declaración de responsabilidad ética

Rúbricas aplicables

S2-E1 · Planificación e Implementación del SGSI (CE0321–CE0324)

Portada

1. Resumen ejecutivo del SGSI

2. Contexto de la organización

2.1 Qué protege el SGSI

2.2 Cuestiones externas e internas

2.3 Partes interesadas

3. Alcance del SGSI

4. Liderazgo y objetivos de seguridad

4.1 Política

4.2 Roles y responsabilidades

4.3 Objetivos de seguridad medibles

5. Inventario de activos y clasificación de la información

5.1 Esquema de clasificación

5.2 Criterios de valoración C-I-D

5.3 Inventario

6. Evaluación de riesgos (ISO/IEC 27005)

6.1 Método

6.2 Criterios

6.3 Matriz de evaluación

6.4 Mapa de calor del riesgo inicial

7. Tratamiento de riesgos

8. Declaración de Aplicabilidad (SoA)

8.1 Controles organizacionales (5.1 a 5.37)

8.2 Controles de personas (6.1 a 6.8)

8.3 Controles físicos (7.1 a 7.14)

8.4 Controles tecnológicos (8.1 a 8.34)

9. Políticas y procedimientos

9.1 POL-01 · Política de seguridad de la información

9.2 POL-02 · Política de control de accesos

9.3 PRO-01 · Procedimiento de gestión de incidentes

9.4 POL-03 · Política de proveedores y servicios en la nube

9.5 POL-04 · Política de respaldo y recuperación ante desastres

9.6 POL-05 · Política de uso aceptable

10. Gestión de identidades y accesos

10.1 Principios

10.2 Matriz de accesos por rol

10.3 MFA

10.4 Manejo seguro de credenciales

10.5 Revisión de accesos

10.6 Protección de datos (gobernanza)

11. Gestión de incidentes, continuidad y recuperación

11.1 Roles y escalamiento

11.2 Clasificación

11.3 Registro de incidentes

11.4 Servicios críticos, RTO y RPO

11.5 Continuidad ante escenarios de desastre

12. Ética de la seguridad de la información

12.1 Código de conducta

12.2 Alcance ético de las pruebas

12.3 Consentimiento y autorización

12.4 Confidencialidad y protección de datos

12.5 Divulgación responsable

12.6 Conflictos de interés

12.7 Declaración de ética de seguridad

13. Evaluación del desempeño del SGSI

13.1 Métricas e indicadores

13.2 Auditoría interna del 2026-10-24

13.3 No conformidades y acciones correctivas

13.4 Revisión por la dirección

13.5 Mejora continua

14. Conclusiones y matriz maestra de trazabilidad

14.1 Conclusiones

14.2 Matriz maestra de trazabilidad (riesgo → control → evidencia)

Anexos

Referencias

Rúbrica de evaluación

S2-E2 · Implementación, Testing y Monitoreo de Red (CE0312–CE0313)

Portada

1. Resumen ejecutivo de la implementación de red

2. Trazabilidad con el diseño de red

3. Implementación de la conectividad híbrida (VPN)

4. Implementación de la seguridad perimetral

    4.1 Implementado en la nube (VPS)

    4.2 Pendiente en la sede (OPNsense, switch y Wi-Fi)

    4.3 Endurecimiento pendiente del VPS y del dominio (brechas reales)

5. Pruebas de segmentación

6. IDS/IPS, honeypot y detección

    6.1 Suricata en OPNsense

    6.2 Honeypot Cowrie (VM-HPOT01)

    6.3 Wazuh (VM-SIEM01) y agentes

    6.4 Evidencia de punta a punta

7. Monitoreo y visibilidad de red

    7.1 Implementado hoy

    7.2 Pendiente: centralización, paneles y alertas

8. Plan y resultados de pruebas técnicas

9. Incidencias detectadas

10. Evidencias técnicas

    10.1 Índice de evidencias

    10.2 Repositorio técnico de red

11. Conclusiones, limitaciones, mejoras futuras y referencias

    11.1 Conclusiones

    11.2 Limitaciones

    11.3 Mejoras futuras

    11.4 Referencias

Anexos

Anexo A. Comandos de las pruebas de segmentación y detección

Anexo B. Salidas de las verificaciones externas (2026-10-24)

Rúbrica de evaluación

S2-E3 · Implementación, Gestión y Control de Centro de Datos (CE0332–CE0333)

Portada

1. Resumen ejecutivo de la implementación del centro de datos

2. Trazabilidad con el diseño del centro de datos

3. Implementación del entorno on-premise

3.1 Estado actual (operativo, transitorio)

3.2 Procedimiento de despliegue en Proxmox VE

4. Implementación del entorno de nube

4.1 VPS (equivalente a EC2): implementado

4.2 Equivalencias AWS con su evidencia

4.3 Servicios PaaS: implementados

4.4 Pendiente en la nube

5. Gestión de identidades y accesos

6. Inventario final de activos

7. Continuidad: respaldo, restauración y recuperación

7.1 Respaldo implementado (MySQL)

7.2 Restauración probada (ejercicios reales)

7.3 Recuperación de una VM (REC-07)

7.4 Recuperación de un recurso de nube (REC-06 y REC-08)

7.5 Recuperación de la VPN ante una interrupción simulada (REC-09)

7.6 Firestore y frontend (REC-10 y REC-11)

7.7 Registro de pruebas de recuperación

8. RTO y RPO: objetivos frente a resultados

9. Monitoreo y control operativo

9.1 Implementado

9.2 Métricas y alertas planeadas (equivalente a CloudWatch)

9.3 Línea base de capacidad del VPS

10. Control de cambios y gestión de configuración

10.1 Repositorio y estructura

10.2 Historial de cambios relevantes

10.3 PRO-02 · Procedimiento de gestión de cambios

10.4 Hallazgos del control de cambios

11. Resultados, conclusiones, limitaciones, mejoras futuras y referencias

11.1 Resultados

11.2 Conclusiones

11.3 Limitaciones

11.4 Mejoras futuras

11.5 Referencias

Anexos

Rúbrica de evaluación

Producto Final S2 · Informe de Implementación Integral y Operativa

Portada

Resumen ejecutivo

1. Presentación ejecutiva

2. Evidencias unificadas

3. Análisis de riesgos

4. Declaración de Aplicabilidad

5. Declaración ética

6. Pruebas

7. Monitoreo

8. Respaldo y recuperación

9. Recomendaciones finales

10. Trazabilidad con el diseño técnico consolidado del Semestre 1

11. Guion del recorrido técnico (demo)

12. Evaluación de cierre de la línea

Rúbricas aplicables

Guía de sustentación y defensa técnica

1. Reparto por integrante

2. Guion de demostración (10 minutos)

3. Mensajes clave por entregable

4. Preguntas probables y respuestas preparadas

5. Evidencias a tener abiertas antes de empezar

6. Registro de sustentación por entregable

Perfil de Egreso - Plataforma Web Integral CERMAT

EPE — Sistema desplegado y en operación piloto

Evidencias del proyecto **Plataforma Web Integral de Gestión Académica CERMAT**, organizadas según la guía oficial vigente de evaluación del perfil de egreso (Escuela Profesional de Ingeniería de Sistemas, UPeU, versión de septiembre de 2026). El sistema está publicado en academia-school-platform.vercel.app y opera en piloto en la Academia La Prepa Cermat (Azángaro, Puno).

Repositorio de esta documentación: Perfil-de-egreso-Plataforma-Web-Integral-CERMAT · Versión imprimible: PDF completo (2026-10-24)

Proyecto

Campo	Valor
Nombre	Plataforma Web Integral de Gestión Académica CERMAT
Tipo	EPE (Evaluación de Perfil de Egreso)
Organización	CERMAT — Academia La Prepa Cermat (el colegio CERMAT School tiene su propio sistema de gestión)
Equipo	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Ciclo / semestre	9° ciclo — 2026-2, campus Juliaca
Fecha de esta versión	2026-10-24
Despliegue	https://academia-school-platform.vercel.app

Entregables

A. Gestión de Tecnologías de Información (CE01)

Entregable	Evidencias	Contenido
E1 — Diagnóstico organizacional y alineamiento estratégico	CE0111–CE0115	Contexto, FODA, madurez digital, problema y causas, roadmap y riesgos estratégicos
E2 — Business case	CE0113	Alternativas ponderadas, beneficios, costos y evaluación económica a 3 años
E3 — Plan de gestión del proyecto	CE0121–CE0125	Acta, EDT, cronograma, presupuesto, riesgos y gestión ágil
E4 — Procesos AS-IS / TO-BE	CE0131–CE0135	Proceso de matrícula en BPMN y comparación de tiempo, costo y calidad

Entregable	Evidencias	Contenido
E5 — Propuesta de solución TIC integrada	CE0141–CE0145	Ecosistema colegio + academia, integración, gobierno e indicadores de uso

B. Ingeniería de Software (CE02)

Entregable	Competencia	Contenido
E1 — Requerimientos y diseño del sistema	CE021	22 RF, 10 RNF, reglas de negocio, historias, prototipo, C4, ADR, UML y trazabilidad
E2 — Plataforma de datos	CE022	Modelo, DDL/DML, procedimientos, funciones, triggers, roles, respaldo y 19 pruebas SQL
E3 — Sistema funcional integrado	CE023	Arquitectura, flujos, código, manejo de errores y despliegue
E4 — Gestión del proyecto y calidad	CE024	90 pruebas, CI/CD, observabilidad, gestión ágil, ISO 25010 y CMMI

C. Infraestructura Tecnológica (CE03)

Momento	Entregable	Códigos
Semestre 1	E1 — Análisis y diseño de red	CE0311
Semestre 1	E2 — Análisis y diseño de centro de datos híbrido	CE0331
Semestre 1	Producto final: diseño técnico consolidado	—
Semestre 2	E1 — Planificación e implementación del SGSI	CE0321–CE0324
Semestre 2	E2 — Implementación, testing y monitoreo de red	CE0312–CE0313
Semestre 2	E3 — Implementación, gestión y control de centro de datos	CE0332–CE0333
Semestre 2	Producto final: informe de implementación integral	—

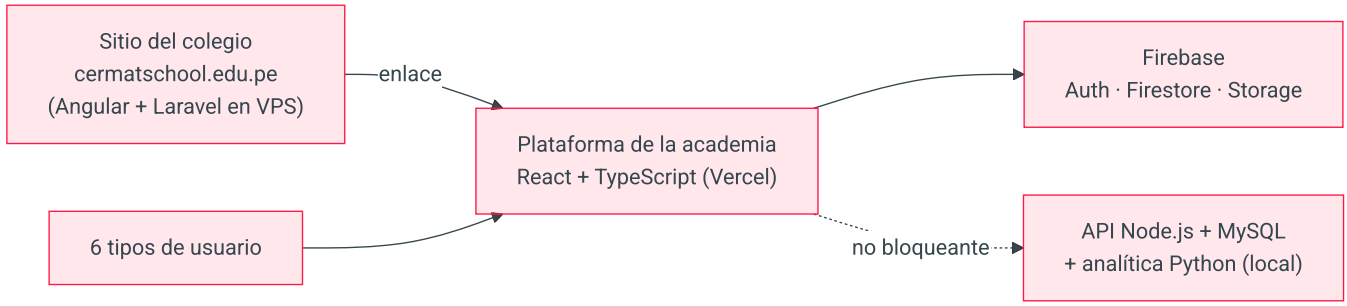
Transversal: Guía de sustentación y defensa técnica.

Resumen del sistema (medido el 2026-10-24)

Indicador	Valor
Módulos de dominio	13 (`src/features/*`)

Indicador	Valor
Portales y guardas de ruta	6 (público, admin, docente, estudiante, auxiliar y padres)
Colecciones de Firestore con reglas	22
Base relacional MySQL	6 tablas de negocio + auditoría; 4 funciones, 5 procedimientos, 6 triggers y 3 vistas
Requerimientos	22 funcionales y 10 no funcionales
Pruebas automáticas	90 (34 unitarias, 18 de API, 19 de reglas de seguridad y 19 de base de datos)
Integración continua	6 trabajos en GitHub Actions
Uso en piloto	8 matrículas, 2 pagos, 7 marcas de asistencia y 8 usuarios con perfil
Estado de producción	Frontend y reglas corregidas publicados el 2026-10-24 y verificados como visitante sin sesión (E4 §2.7)

Arquitectura



Capa	Tecnología	Rol
Presentación	React 18 + TypeScript + Vite en Vercel	Portales por rol
Identidad y datos	Firebase Auth, Firestore y Storage	Fuente de verdad, reglas por rol probadas
Réplica y analítica	Node.js + Express, MySQL 8, Python + FastAPI	Reportes, conciliación, auditoría y riesgo de inasistencia
Infraestructura	Vercel, Firebase, servidor local y VPS del colegio	Base del diseño híbrido de la línea CE03

Evidencia técnica (repositorio `academia-school-platform`)

Evidencia	Ubicación
Rutas y portales	`src/App.tsx`, `src/routes/*`

Evidencia	Ubicación
Reglas de seguridad y sus pruebas	`firestore.rules`, `tests/firestore-rules/reglas.test.ts`
Módulos de dominio	`src/features/*`
Base relacional	`server/src/db/` (migraciones, pruebas y README)
API y sus pruebas	`server/src/`, `server/test/`
Analítica	`analytics/main.py`
Pipeline de CI	`.github/workflows/ci.yml`
Respaldo y restauración	`server/scripts/backup.js`, `server/scripts/restore.js`

Cerrado en producción el 2026-10-24

Frontend y reglas de Firestore corregidas publicados y verificados; pre-matrícula pública operativa; clave de servicio de Firebase rotada y contraseñas expuestas restablecidas. Base MySQL real migrada, con cuentas de mínimo privilegio y restauración probada en 0,23 s (E4 §2.7).

Pendientes que solo puede cerrar el equipo

- Programar el respaldo diario de MySQL y el arranque automático de PM2 con Windows.
- Configurar el secreto `FIREBASE_SERVICE_ACCOUNT` en GitHub para que el CI publique las reglas.
- Firmar las actas de validación con la academia y la declaración de ética de seguridad.
- Ejecutar el laboratorio de infraestructura (Semestre 2) y adjuntar sus evidencias.
- Validar con la Dirección los supuestos del business case.
- Dar acceso al jurado al repositorio.
- Preparar la sustentación individual (guía).

Brief EPE — Plataforma Web Integral CERMAT

Tipo de proyecto

Este documento corresponde a un proyecto de tipo **EPE (Evaluación de Perfil de Egreso)**, el nivel de mayor exigencia académica. El problema es real, los actores son verificables y el sistema está implementado y funcional.

1. Información general

Campo	Detalle
Nombre del proyecto	Plataforma Web Integral de Gestión Académica CERMAT
Tipo	[ ] PS [ ] PI [x] EPE
Curso / Ciclo	Perfil de Egreso - Integración de evidencias profesionales (9° ciclo)
Equipo	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Fecha	2026-06-22 (actualizado el 2026-10-24)

2. Problema

Problema real — evidencia EPE

El problema es real, verificable en el contexto de una institución educativa activa en Azángaro, Perú. El sistema desarrollado responde a necesidades operativas concretas identificadas con los actores involucrados.

La Academia La Prepa Cermat requiere una plataforma digital integral para administrar de forma centralizada su oferta académica, matrículas, alumnos, docentes, auxiliares, asistencia, pagos, recursos, talleres, sedes, contenidos públicos y comunicación con padres.

Antes del sistema, los procesos académicos y administrativos tienden a depender de canales dispersos: formularios no integrados, gestión manual de alumnos, control de asistencia poco trazable, seguimiento de pagos separado de la matrícula, información pública difícil de mantener y ausencia de portales diferenciados por rol. Esto genera duplicidad de datos, baja visibilidad operativa, riesgo de errores en cupos y matrículas, demora en la atención a padres y poca trazabilidad para decisiones administrativas.

Como proyecto **EPE**, el problema es real, verificable en el contexto de una institución educativa y sustentado por los actores, módulos y reglas implementadas en el repositorio:

- Administración de ciclos, sedes, grupos, recursos, docentes, alumnos, pagos, talleres y asistencia.
- Matrícula pública conectada con el flujo interno de aprobación y activación.
- Portales por rol para administradores, docentes, estudiantes, auxiliares y padres.
- Reglas de seguridad en Firestore para proteger operaciones según rol.
- Sincronización opcional hacia MySQL para analítica, reportes y continuidad operativa.

---

3. Contexto y Stakeholders

Organización / entorno

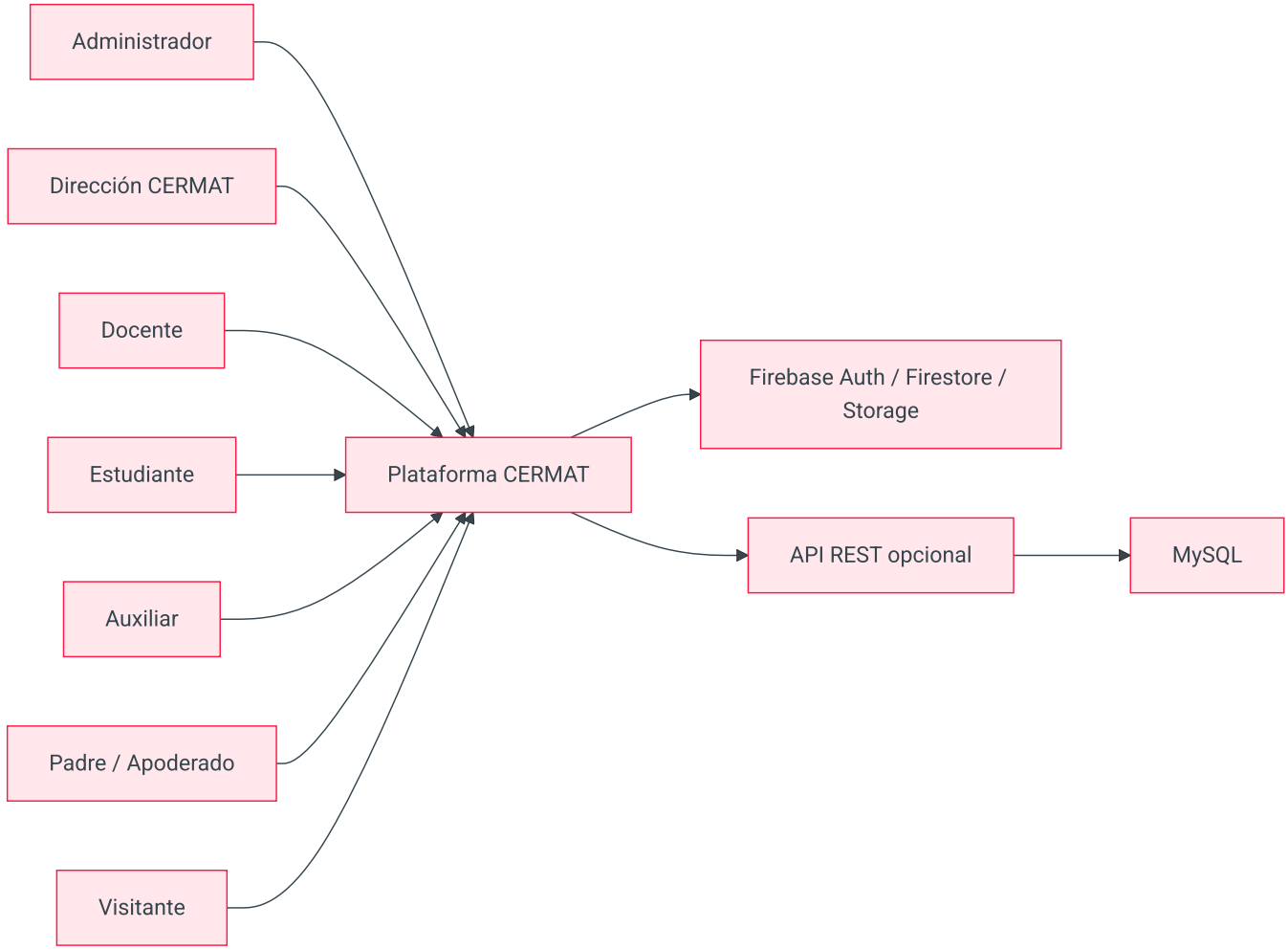
La plataforma opera en el entorno de la **Academia La Prepa Cermat**, una institución educativa que ofrece ciclos académicos, talleres, recursos formativos y servicios de seguimiento a estudiantes y padres.

El sistema funciona como una aplicación web SPA, con datos operativos en Firebase y un backend Node.js + MySQL complementario para integración y reportes.

Usuarios / actores

Stakeholder	Rol	Necesidad principal	Impacto esperado
Dirección / administración CERMAT	Responsable institucional	Controlar ciclos, grupos, matrículas, pagos, sedes, docentes, auxiliares y contenidos.	Mayor trazabilidad, reducción de trabajo manual y mejor visibilidad operativa.
Administrador del sistema	Usuario operativo interno	Gestionar información académica, usuarios, pagos, asistencia y publicaciones.	Operación centralizada con permisos de alto nivel.
Docente	Usuario académico	Consultar cursos, alumnos, recursos y registrar asistencia mediante QR.	Mejor control de clases y seguimiento académico.
Estudiante	Usuario final	Ver cursos, recursos, estado de matrícula, talleres y asistencia.	Experiencia académica personalizada.
Auxiliar	Soporte operativo	Supervisar asistencia y validar QR de estudiantes y docentes.	Control presencial más rápido y trazable.
Padre / apoderado	Consulta externa	Ver asistencia de su hijo mediante código CERMAT.	Transparencia y seguimiento familiar.
Visitante / postulante	Usuario público	Revisar ciclos, sedes, blog, talleres, recursos y registrar matrícula.	Conversión de interesados en matrículas.
Equipo técnico	Desarrollo y mantenimiento	Mantener una arquitectura modular, segura y escalable.	Evolución controlada del sistema.

Mapa de stakeholders



4. Objetivo del sistema

Implementar una plataforma web integral que centralice la gestión académica, administrativa y comunicacional de CERMAT, permitiendo administrar ciclos, grupos, matrículas, pagos, usuarios, asistencia, recursos, talleres, sedes y contenidos públicos con portales diferenciados por rol y reglas de seguridad basadas en permisos.

Objetivo medible EPE

Reducir la fragmentación operativa mediante un sistema único que:

- Centralice los principales procesos académicos y administrativos.
- Permita la matrícula pública y la gestión interna de estados.
- Controle la asistencia de estudiantes y docentes mediante QR.
- Exponga información pública actualizable desde la administración.
- Mantenga la trazabilidad de pagos, usuarios, grupos y recursos.
- Proteja los datos por rol mediante Firebase Authentication y Firestore Rules.

5. Alcance

Incluye

- Sitio público institucional: inicio, ciclos, sedes, blog, recursos, talleres, contacto y matrícula.
- Gestión académica: ciclos, categorías, sedes, grupos, cupos, modalidad, turnos y horarios.
- Matrícula en línea: registro público, validación de ciclo y grupo, seguimiento y estados.
- Gestión de pagos: registro, método de pago, cuotas, comprobantes, cancelación lógica y resumen administrativo.
- Gestión de usuarios: administradores, docentes, estudiantes y auxiliares.
- Activación de cuentas por invitación para estudiantes, docentes y auxiliares.
- Portal administrativo completo.
- Portal docente con cursos, recursos y asistencia.
- Portal estudiante con cursos, recursos, matrícula, talleres y asistencia.
- Portal auxiliar para supervisión de asistencia.
- Consulta de asistencia para padres mediante código CERMAT.
- Gestión de recursos, blog, talleres y contenido del sitio.
- Reglas de seguridad de Firestore por rol y colección.
- Sincronización opcional hacia API REST + MySQL para asistencia, pagos y matrículas.

No incluye

- Aplicación móvil nativa.
- Pasarela de pagos automatizada con bancos o proveedores externos.
- Facturación electrónica integrada.
- Envío masivo de notificaciones push.
- Inteligencia artificial predictiva avanzada.
- Integración directa con sistemas gubernamentales o ERP externos.
- Gestión contable completa fuera del alcance académico.

Supuestos

- Los usuarios administradores poseen credenciales y permisos configurados en Firebase.
- Firestore es la fuente principal para la operación web.
- MySQL funciona como almacenamiento complementario cuando la API REST está habilitada.
- Los procesos de validación institucional, pagos y estados finales dependen de administradores autorizados.

6. Datos

Entidades principales

Entidad	Propósito
`users`	Perfiles, roles, docentes, estudiantes, auxiliares y códigos de padres.
`cycles`	Ciclos académicos publicados o internos.
`cycleCategories`	Niveles y categorías académicas.
`campuses`	Sedes.
`groups`	Grupos por ciclo, sede, turno, horario, docente y cupo.
`enrollments`	Matrículas, estados, pagos esperados y datos del estudiante.
`payments`	Pagos registrados por matrícula.
`attendanceTokens`	Tokens diarios para asistencia QR.
`attendanceLogs`	Registros de entrada y salida de estudiantes y docentes.
`studentQrSignatures`, `attendanceDayState`	Firma del QR permanente y estado diario de asistencia (evitan QR falsificados y dobles marcas).
`parentAttendance`	Vista pública resumida para padres mediante código.
`resources`	Recursos académicos públicos o restringidos.
`posts`	Blog institucional.
`workshops`	Talleres públicos y privados.
`messages`	Mensajes de contacto.
`config`	Configuración dinámica del sitio y servicios.
`invites`, `teacherInvites`, `auxiliarInvites`	Activación e invitaciones por rol.

Origen de datos

- Formularios públicos: matrícula, contacto y consulta.
- Panel administrativo: ciclos, sedes, recursos, blog, talleres, docentes, alumnos, pagos y configuración.
- Portales autenticados: asistencia, recursos, cursos y estado de matrícula.
- Firebase Authentication: identidad y sesión.
- Firestore: datos operativos principales.
- Firebase Storage: imágenes y archivos.
- API REST opcional: sincronización con MySQL.

Restricciones

- Las lecturas y escrituras están restringidas por Firestore Rules.
- La matrícula pública solo permite ciclos publicados y grupos válidos.
- La asistencia requiere usuario autenticado y tokens válidos.
- Los pagos solo pueden ser administrados por usuarios admin.
- La eliminación de pagos y matrículas no es libre; se prioriza la trazabilidad.

7. Enfoque de solución

Arquitectura híbrida — visión de conjunto

El sistema implementa una arquitectura técnica híbrida que combina una capa cloud (Firebase) para la operación web en tiempo real con una capa local (Node.js + MySQL) para analítica, reportes y continuidad operativa.

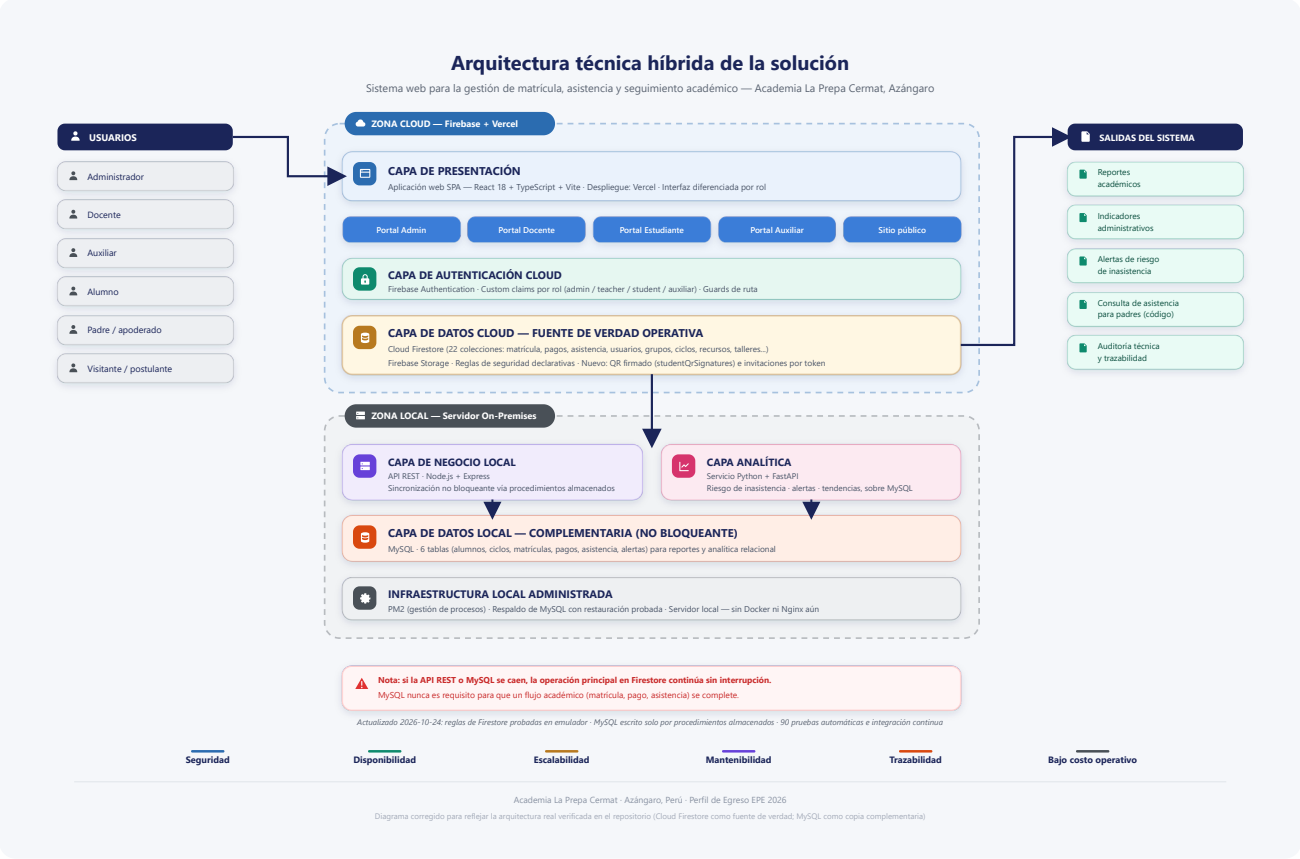


Imagen: Arquitectura técnica híbrida de la solución CERMAT — capas de presentación, autenticación, negocio, analítica, datos e infraestructura local administrada.

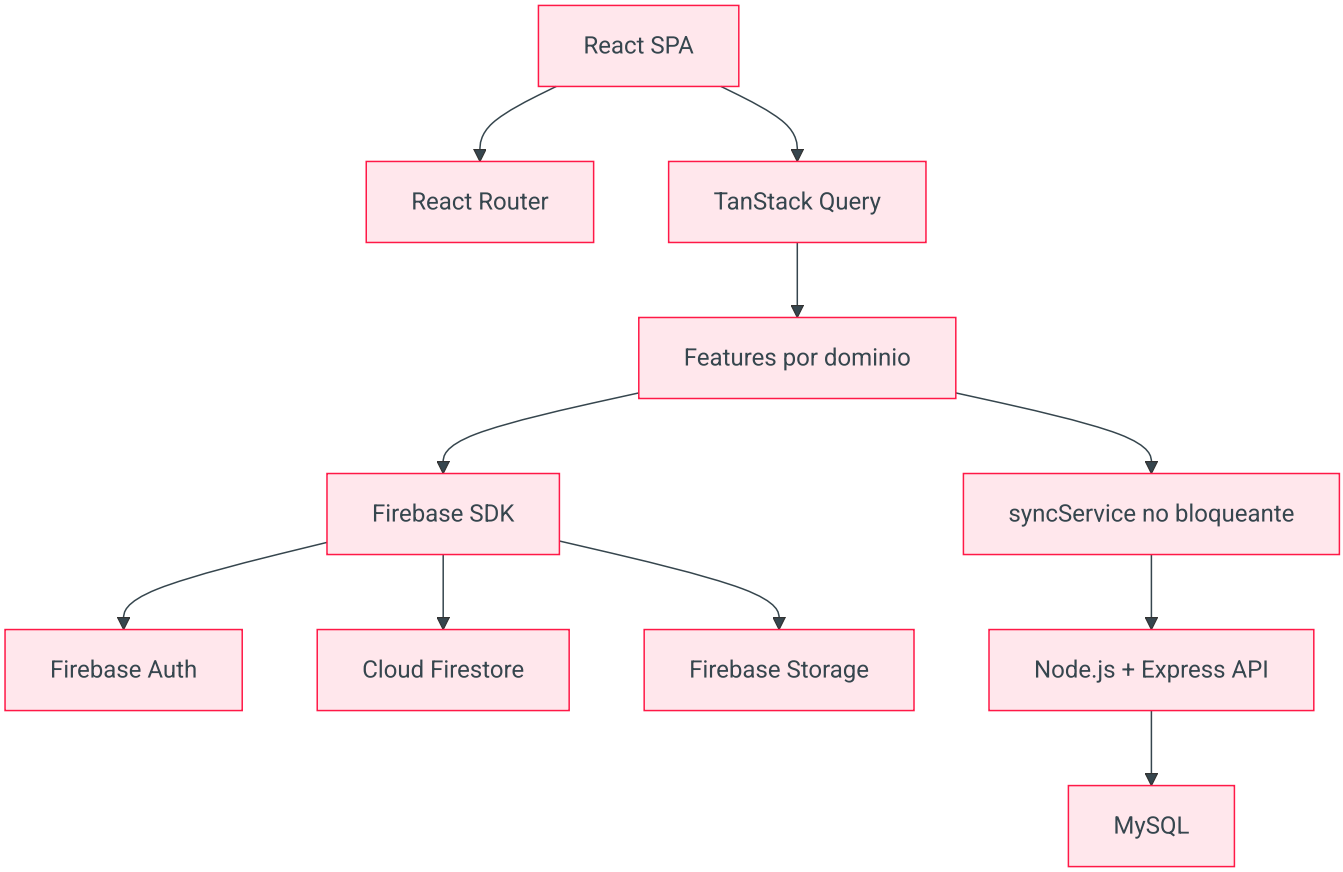
Tipo de sistema

Sistema **transaccional web** con componentes de gestión académica, administración, portal por roles, control de asistencia QR y sincronización complementaria hacia una base de datos relacional.

Consideraciones técnicas

Dimensión	Decisión
Frontend	React 18 + TypeScript + Vite
UI	Tailwind CSS + Radix UI + shadcn/ui + Lucide
Navegación	React Router DOM
Estado remoto	TanStack React Query
Autenticación	Firebase Authentication
Base principal	Cloud Firestore
Archivos	Firebase Storage
Seguridad	Firestore Rules + guards por rol
Backend complementario	Node.js + Express
Base complementaria	MySQL
Despliegue SPA	Vercel: academia-school-platform.vercel.app (separado del sistema del colegio en cermatschool.edu.pe)

Arquitectura básica



Decisiones justificadas EPE

- **Arquitectura modular por dominio:** los módulos viven en `src/features/*`, lo que facilita el mantenimiento y la trazabilidad.
- **Firestore como base operacional:** permite sincronización en tiempo real, reglas de seguridad declarativas y desarrollo ágil.
- **Roles diferenciados:** admin, docente, estudiante y auxiliar tienen rutas y permisos separados.
- **Asistencia QR:** reduce el registro manual y mejora la trazabilidad.
- **MySQL complementario:** habilita reportes, analítica y consultas relacionales sin bloquear la operación principal.

Arquitectura por capas

Capa	Tecnología	Responsabilidad
Presentación	React 18 + TypeScript + Vite	SPA con portales diferenciados por rol
Autenticación cloud	Firebase Authentication	Identidad, sesión y claims por rol
Datos cloud	Cloud Firestore + Firebase Storage	Base de datos operativa en tiempo real
Negocio local	Node.js + Express	API REST, validación, lógica, auditoría
Analítica	Python + FastAPI	Procesamiento de históricos, alertas y tendencias
Datos local	MySQL	Base relacional para reportes y sincronización
Infraestructura	PM2 + respaldo verificado (`backup.js` y `restore.js`)	Gestión de servicios locales y respaldo

---

8. Viabilidad

Dimensión	Evaluación
Técnica	Alta. El sistema ya cuenta con módulos implementados, rutas activas, reglas de Firestore, servicios por dominio y esquema MySQL complementario.
Tiempo	Viable como EPE porque integra evidencias desarrolladas previamente y documenta un sistema funcional con módulos existentes.
Recursos	Viable con un equipo pequeño de desarrollo web, Firebase, Node.js y administradores institucionales para la validación.
Riesgos	Dependencia de la configuración correcta de roles, reglas de Firestore, índices y calidad de los datos migrados.
Mitigación	Validaciones Zod, reglas de seguridad probadas en emulador, separación por rol, 90 pruebas automáticas y pipeline de CI.

9. Alineación con competencias

Competencia	Marcado	Justificación
CE021 - Ingeniería de Requerimientos	X	El sistema cuenta con problema, actores, objetivos, alcance, requerimientos, prototipos, arquitectura y trazabilidad.
CE022 - Ingeniería de la Información	X	Gestiona entidades, colecciones, reglas de seguridad, sincronización SQL, consultas e índices.
CE023 - Programación	X	Implementa módulos React/TypeScript, Firebase SDK, hooks, validaciones, rutas, componentes y servicios.
CE024 - QA	X	Incluye 90 pruebas automáticas en 4 niveles, pipeline de CI, control de estados, reglas de seguridad probadas y restricciones de duplicidad.

Resultado de viabilidad

La viabilidad está **demostrada**: la plataforma está desplegada en academia-school-platform.vercel.app con Firebase, y opera en piloto (8 matrículas, 2 pagos y 7 marcas de asistencia al 2026-10-24). La capa relacional (Node.js, MySQL y analítica) se ejecuta con PM2 en el servidor local cuando está encendido.

Relación con la guía oficial

Este brief es el punto de partida que comparten las tres líneas. La evaluación la hace el jurado con las rúbricas oficiales de cada entregable (Gestión TI, Ingeniería de Software e Infraestructura); el equipo no se autoevalúa.

Frase clave

> El brief del proyecto es el punto de partida de la evaluación por competencias, asegurando que la Plataforma CERMAT responde a un problema pertinente, viable y alineado con el perfil de egreso.

A. Gestión de Tecnologías de Información (CE01)

A. Área de Gestión de Tecnologías de Información (CE01)

Competencia CE01

Diseña y gestiona proyectos de tecnologías e información basándose en la guía del PMBOK y estándares de calidad a fin de lograr la construcción de resultados y el alcance de objetivos de la organización.

Campo	Detalle
Proyecto	Proyecto de Gestión Integral de Tecnologías de Información para Transformación Organizacional: Plataforma Web Integral de Gestión Académica CERMAT
Organización	CERMAT, Azángaro (Puno, Perú): colegio CERMAT School y Academia La Prepa Cermat
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo), UPeU campus Juliaca, sección g1
Fecha	2026-10-24

Resumen del área

Mientras las líneas CE02 y CE03 documentan el sistema y su infraestructura, esta línea documenta **la gestión**: por qué CERMAT necesita la plataforma, cuánto vale, cómo se planifica su cierre y adopción, qué proceso transforma y cómo encaja con el sistema del colegio. El punto de partida es honesto: la plataforma está en producción y tiene buena base técnica, pero opera como **piloto con volumen bajo** (8 matrículas, 2 pagos, 7 marcas de asistencia y 0 consultas de padres al 2026-10-24) y con reglas publicadas que bloquean la matrícula en línea.

Resultado clave	Valor	Dónde
Madurez digital (modelo de 8 dimensiones, escala 1–5)	1,75 hoy; meta 3,0 en 2027	E1, 1.3
VAN para CERMAT a 3 años (vista A, escenario base, 12 %)	S/ 1 247 (pesimista S/ −8 809; optimista S/ 13 245)	E2, 2.4.4
Umbrales de equilibrio	40 matrículas por ciclo o 64,1 % de adopción sostenida	E2, 2.4.5
Presupuesto total del proyecto (BAC)	S/ 21 346, de los cuales CERMAT aporta S/ 1 166	E3, 3.4
Tiempo de personal por matrícula	40 → 10,5 min (−73,8 %, supuestos con plan de medición)	E4, 4.3

Resultado clave	Valor	Dónde
Indicadores de uso, valor y mejora	22, con línea base real	E5, 5.6

Competencias de Gestión de TI

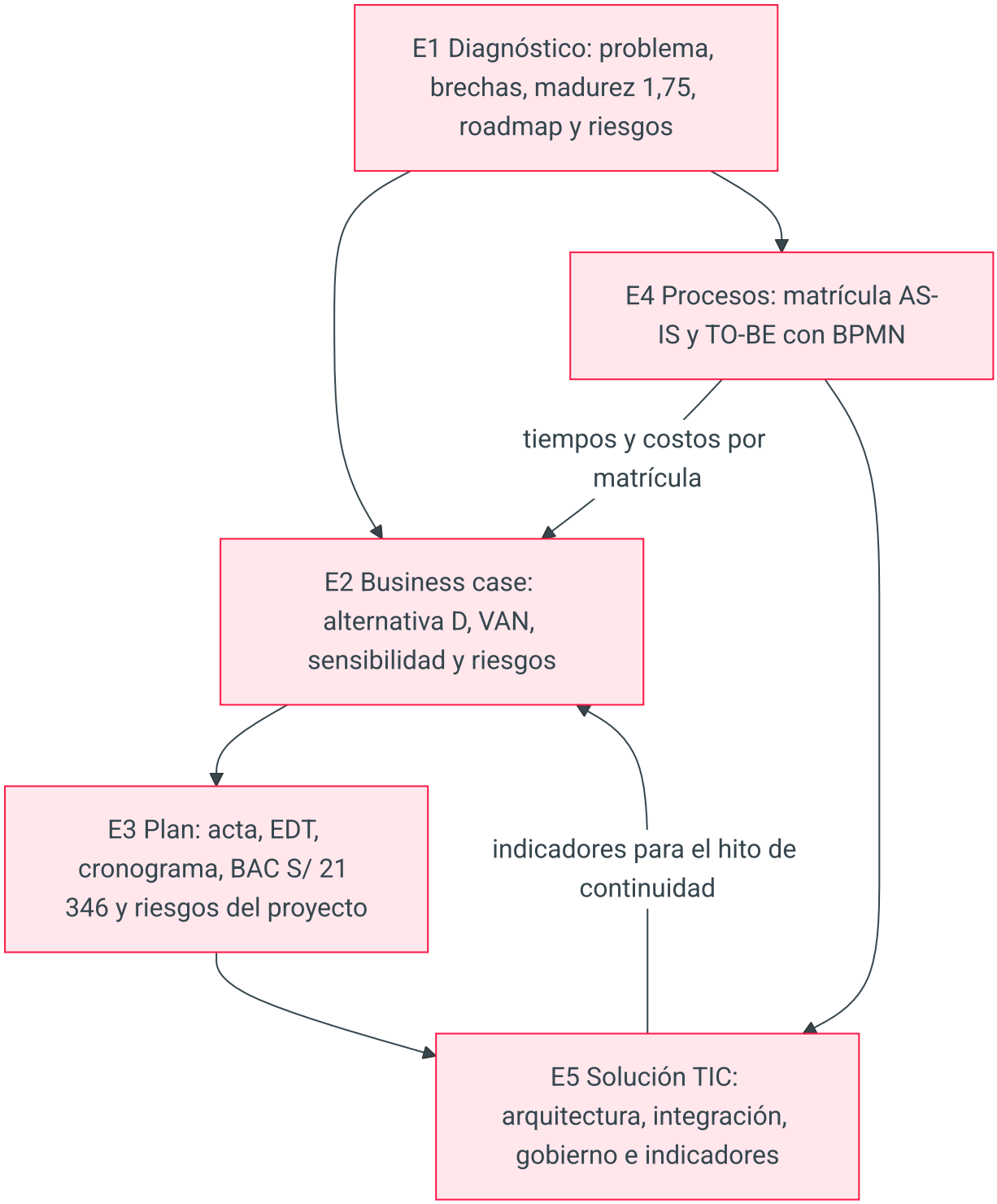
Competencia	Descripción (guía oficial)	Entregable
CE011 — Gestión e Innovación de TI	Administra un Plan Estratégico de TI alineado a la estrategia de negocio. Esta competencia permite diagnosticar brechas, priorizar iniciativas, justificar inversiones y orientar la tecnología hacia resultados organizacionales.	E1 y E2
CE012 — Gestión de Proyectos	Aplica los principios de gestión en computación, las metodologías apropiadas a su campo y la toma de decisiones económicas considerando eventuales riesgos, como individuo y como miembro o líder de equipo, para gestionar proyectos en entornos multidisciplinarios.	E3
CE013 — Gestión de Procesos	Gestiona los procesos de las organizaciones con soluciones TIC. Esta competencia permite modelar procesos actuales, identificar oportunidades de mejora, proponer rediseños y definir indicadores de desempeño.	E4
CE014 — Gestión de Sistemas de Información	Apoya la prestación, el uso y la gestión de sistemas de información dentro de un entorno de sistemas de información. Esta competencia conecta la solución tecnológica con datos, seguridad, integración, operación y toma de decisiones.	E5

Mapa de entregables y evidencias

Evidencia	Contenido	Entregable y sección
CE0111	Diagnóstico organizacional	E1, 1.1 a 1.4
CE0112	Alineamiento estratégico	E1, alineamiento estratégico
CE0113	Caso de negocio	E2 — Business Case
CE0114	Roadmap de tecnología	E1, 1.5
CE0115	Matriz de riesgos estratégicos	E1, 1.6

Evidencia	Contenido	Entregable y sección
CE0121	Acta de constitución del proyecto	E3, 3.1
CE0122	Plan de gestión: alcance, tiempo, costo y recursos	E3, 3.2 a 3.4
CE0123	EDT y cronograma	E3, 3.2 y 3.3
CE0124	Análisis económico y evaluación de viabilidad	E2, 2.4.4 y 2.4.5 y E3, 3.4
CE0125	Plan de gestión de riesgos	E3, 3.5
CE0131	Identificación y caracterización de procesos	E4, identificación y caracterización
CE0132	Modelado AS-IS	E4, 4.1 y matricula-as-is.bpmn
CE0133	Modelado TO-BE	E4, 4.2 y matricula-to-be.bpmn
CE0134	Automatización o mejora mediante TIC	E4, automatizaciones
CE0135	Indicadores de desempeño y evaluación de impacto	E4, nuevos indicadores y 4.3
CE0141	Mapa del ecosistema de sistemas de información	E5, 5.2
CE0142	Arquitectura conceptual del sistema propuesto	E5, 5.1
CE0143	Modelo de integración y flujos de información	E5, integración propuesta
CE0144	Plan de implementación y gestión del sistema de información	E5, 5.5
CE0145	Indicadores de uso, valor y mejora	E5, 5.6

Cómo se encadenan los entregables



Artefactos del área

Artefacto	Ubicación
Modelo financiero con fórmulas (supuestos, proceso, presupuesto, flujo de caja, indicadores, sensibilidad y alternativas)	business-case.xlsx
Proceso de matrícula en BPMN 2.0 editable (bpmn.io o Camunda Modeler)	matricula-as-is.bpmn · matricula-to-be.bpmn

Artefacto	Ubicación
Scripts reproducibles	`perfil-egreso/scripts/generar-business-case.mjs` (genera el libro y verifica sus fórmulas) · `perfil-egreso/scripts/generar-bpmn.mjs` (genera y valida los BPMN)

Coherencia con las otras líneas

- **Ingeniería de Software:** requerimientos y arquitectura en el E1, sistema funcional en el E3, y Project Charter, Product Backlog y Sprint 1 en el E4, que el plan de gestión enlaza en lugar de duplicar.
- **Infraestructura:** el alojamiento de la capa relacional (VM-APP01 o VPS puente) sigue el diseño de centro de datos híbrido; la protección de datos y los incidentes, el SGSI; los respaldos y el RTO, la implementación del centro de datos.
- **Sustentación:** la guía de sustentación reúne las preguntas de defensa de todas las líneas.

Por qué 5 entregables

La tabla resumen de la guía agrupa CE01 en cuatro competencias, pero las plantillas detalladas, con contenido mínimo y rúbrica propios, definen cinco entregables: el Caso de Negocio (CE0113) tiene su propio documento. Se siguen esas plantillas: CE011 se documenta en el E1 y el E2, CE012 en el E3, CE013 en el E4 y CE014 en el E5.

E1 — Diagnóstico Organizacional y Alineamiento Estratégico (CE0111–CE0115)

Evidencias CE011 — Gestión e Innovación de TI

CE0111 Diagnóstico organizacional · CE0112 Alineamiento estratégico · CE0113 Caso de negocio (detallado en el E2) · CE0114 Roadmap de tecnología · CE0115 Matriz de riesgos estratégicos. Los conteos de uso son agregados de Firestore al 2026-10-24, sin datos personales. Toda cifra estimada se marca como supuesto.

Portada

Campo	Detalle
Título	Diagnóstico organizacional y alineamiento estratégico de TI — CERMAT (Academia La Prepa Cermat)
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo), UPeU campus Juliaca, sección g1
Fecha	2026-10-24
Competencia	CE011 — Gestión e Innovación de TI
Organización	CERMAT, Azángaro (Puno, Perú): colegio CERMAT School y academia preuniversitaria La Prepa Cermat

Resumen ejecutivo

CERMAT opera un colegio y una academia preuniversitaria con varias sedes. Su ecosistema digital tiene tres sistemas formales que no se comunican entre sí: la **plataforma de la academia** (React y Firebase, publicada en Vercel), una **capa local** (API, MySQL y analítica en una PC) y el **sistema de gestión del colegio** (Angular, Laravel y PostgreSQL en un VPS). Junto a ellos siguen en uso cuadernos, hojas de cálculo y WhatsApp.

La plataforma está desplegada y tiene buena base técnica (90 pruebas automáticas, CI con 6 trabajos, reglas por rol en 22 colecciones), pero opera como **piloto con volumen bajo**: 8 matrículas, 2 pagos, 7 marcas de asistencia y 0 consultas de padres en diez meses. Hay tres brechas que explican buena parte de ese uso bajo:

- Las reglas publicadas el 22-jun-2026 **bloqueaban la matrícula pública** y **exponían el listado de matrículas pagadas**. Se corrigió en producción el 2026-10-24.
- No existe una disposición institucional de canal único ni capacitación.

- La capa relacional solo sincroniza cuando su PC está encendida.

La madurez digital medida con un modelo de 8 dimensiones es **1,75 de 5** (inicial a gestionado). El problema central y sus causas raíz se analizan en la sección 1.4. El roadmap (1.5) prioriza estabilizar y adoptar antes de integrar con el colegio. La matriz de riesgos (1.6) ubica como críticos la dependencia de una sola persona, la exposición de datos de menores (tratada el 2026-10-24) y la baja adopción.

1.1 Contexto organizacional

Descripción del sector y entorno competitivo

CERMAT compite en la **educación privada de la provincia de Azángaro**: educación básica regular (colegio) y preparación preuniversitaria (academia) para los exámenes de admisión de las universidades de la región. La academia trabaja por **ciclos** con campañas de matrícula cortas, lo que concentra la carga administrativa en pocas semanas.

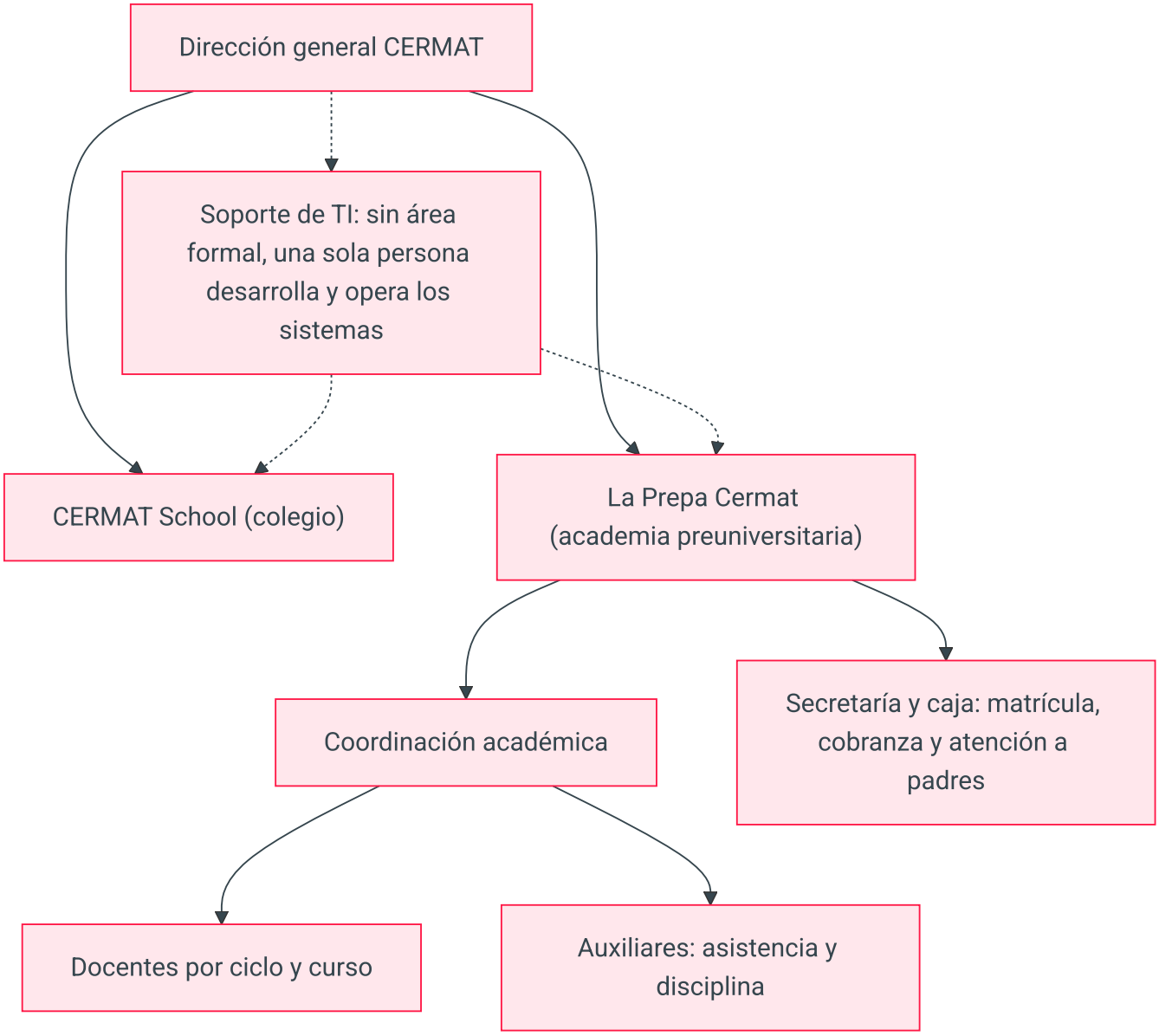
No se cuenta con un estudio de mercado propio. La tabla resume la valoración del equipo con el modelo de cinco fuerzas [1]; debe validarse con la Dirección.

Fuerza	Intensidad	Sustento
Rivalidad entre academias	Alta	Varias academias en la provincia y en Juliaca compiten por los mismos postulantes con precio, horarios y resultados de ingreso.
Amenaza de sustitutos	Media-alta	Centros preuniversitarios de las propias universidades y contenido gratuito en línea.
Poder de negociación de las familias	Media-alta	Alta sensibilidad al precio y decisión influida por la confianza y la comunicación con la academia.
Poder de los proveedores clave (docentes)	Media	Los docentes con buenos resultados son escasos y pueden migrar.
Amenaza de nuevos competidores	Alta	Abrir una academia requiere poca inversión.

Lectura estratégica: con rivalidad alta y bajo costo de entrada, la diferenciación sostenible no es solo académica: también es **servicio** (matrícula sin esperas, información clara a los padres, seguimiento del alumno). Ese es el espacio donde actúa la TI.

Estructura organizacional

Estructura funcional relevada por el equipo (pendiente de validación con la Dirección):



No existe un área de TI. El desarrollo y la operación de la plataforma de la academia y del sistema del colegio dependen del mismo autor (líder de este equipo): el historial de git registra un único autor humano en 49 de 52 commits; los 3 restantes son de herramientas de generación.

Cadena de valor

Cadena de valor adaptada a un servicio educativo [1], con el sistema que soporta cada actividad hoy y su brecha.

Tipo	Actividad	Sistema que la soporta hoy	Evidencia de uso (al 2026-10-24)	Brecha
Primaria	Captación y admisión	Sitio público de la plataforma, redes sociales y WhatsApp	7 mensajes de contacto; 1 post	La pre-matrícula en línea estuvo bloqueada en producción hasta el 2026-10-24; desde entonces funciona

Tipo	Actividad	Sistema que la soporta hoy	Evidencia de uso (al 2026-10-24)	Brecha
Primaria	Matrícula y cobranza	Plataforma (matrículas y pagos) y, sobre todo, cuaderno y hojas de cálculo	8 matrículas (2 pendientes, 5 pagadas, 1 cancelada) y 2 pagos	La mayor parte del proceso sigue siendo manual
Primaria	Planificación académica	Plataforma (ciclos, grupos, sedes, turnos)	1 ciclo, 1 grupo y 1 sede cargados	La oferta real no está cargada
Primaria	Dictado y recursos	Plataforma (recursos y talleres)	6 recursos, 1 taller	Uso marginal
Primaria	Seguimiento del alumno	Asistencia por QR y analítica de riesgo	7 marcas, solo entre el 2026-01-27 y el 2026-04-02	Sin uso desde abril
Primaria	Comunicación con las familias	Código de consulta para padres y WhatsApp	0 consultas registradas	El canal digital no se adoptó
Apoyo	Dirección y planificación	—	No hay tablero de indicadores en uso	Decisiones sin datos consolidados
Apoyo	Gestión de personas	Invitaciones por rol de la plataforma	3 docentes y 1 auxiliar con perfil	—
Apoyo	Finanzas	Pagos en la plataforma y caja manual	2 pagos confirmados, 0 anulados	Sin conciliación sistemática
Apoyo	Tecnología	Plataforma, capa local y sistema del colegio	Ver inventario (1.3)	Sistemas aislados; sin gobierno de TI

Mapa de stakeholders



Stakeholder	Interés principal	Influencia	Estrategia de gestión
Dirección CERMAT (sponsor)	Control, cumplimiento y costo	Decide adopción y presupuesto	Gestionar de cerca: revisión de cada sprint e indicadores mensuales
Product Owner (a designar por la Dirección)	Que la plataforma resuelva la operación diaria	Prioriza el backlog	Gestionar de cerca: participación semanal
Secretaría y caja	Menos trabajo repetitivo y menos errores	Su uso define la adopción	Capacitación y registro rápido en el panel
Docentes y auxiliares	Registro de asistencia simple	Media	Capacitación corta por rol
Padres y apoderados	Saber si su hijo asiste y cuánto debe	Baja individual, alta colectiva	Código de consulta y comunicación clara
Alumnos y postulantes	Matrícula sin esperas y acceso a recursos	Baja	Pre-matrícula en línea y portal del alumno
Equipo técnico (EPE)	Calidad, continuidad y sustentación	Alta en lo técnico	Backlog, CI y revisión por pares
ANPD (Autoridad Nacional de Protección de Datos Personales)	Cumplimiento de la Ley N.° 29733	Puede sancionar	Mantener satisfecha: política, consentimiento e inscripción del banco de datos
Proveedores (Google Firebase, Vercel, RackNerd)	Uso conforme a sus términos	Cambian precios y condiciones	Monitorear términos, cuotas y costos

1.2 Análisis estratégico

Misión, visión y objetivos estratégicos

CERMAT no tiene un plan estratégico escrito que el equipo haya podido revisar. La siguiente es una **formulación de trabajo** construida a partir de la oferta publicada y de las necesidades declaradas en el Brief EPE; debe ser validada y aprobada por la Dirección.

Elemento	Formulación de trabajo
Misión	Preparar a los estudiantes de Azángaro para su ingreso a la universidad con enseñanza exigente y un servicio cercano, ordenado y transparente con las familias.
Visión 2029	Ser la academia de referencia de la provincia por sus resultados de ingreso y por una gestión digital que da a las familias información confiable y oportuna.

ID	Objetivo estratégico	Indicador	Meta propuesta
OE1	Crecer en matrícula y retener a los alumnos durante el ciclo	Matrículas por ciclo y tasa de abandono	Por definir con la línea base 2026
OE2	Hacer eficiente y controlada la gestión administrativa	Minutos de personal por matrícula	≤ 12 min en 2027 (hoy ≈ 40 min, supuesto)
OE3	Fortalecer la confianza de las familias con información oportuna	Alumnos cuyos padres consultan al menos una vez al mes	≥ 50 % en 2027
OE4	Proteger los datos personales de los alumnos y cumplir la normativa	Fallas críticas de seguridad publicadas	0
OE5	Integrar la gestión del colegio y de la academia bajo una visión CERMAT	Procesos con datos compartidos entre ambos sistemas	≥ 2 en 2028

Análisis FODA sustentado con evidencia

Factor	Descripción	Evidencia
F1	Plataforma propia desplegada con portales por rol	6 portales (público, admin, docente, alumno, auxiliar y consulta para padres); 22 colecciones con reglas por rol; E3 de Software
F2	Calidad técnica verificable	90 pruebas automáticas (34 unitarias, 18 de API, 19 de reglas, 19 de base de datos) y CI con 6 trabajos (E4 de Software)
F3	Control de cupos y duplicados por diseño	Matrícula en una transacción con id determinístico `grupo__teléfono` (`src/features/enrollments/api.ts`)

Factor	Descripción	Evidencia
F4	Datos con integridad y recuperación probada	MySQL con 3 FK, 7 CHECK, 6 triggers y 4 roles, aplicados en la base real el 2026-10-24; restauración de la base real con RTO de 0,23 s (E2 de Software)
F5	Infraestructura del colegio ya profesionalizada	VPS con UFW, TLS con renovación automática y PostgreSQL solo local; dominio `.edu.pe`
D1	Adopción muy baja	8 matrículas, 2 pagos, 7 marcas de asistencia y 0 consultas de padres en diez meses
D2	Producción desactualizada sin detección	Las reglas del 22-jun-2026 fallaban 10 de 19 pruebas (auto-asignación de rol, listado público de matrículas pagadas y matrícula pública bloqueada) y nadie lo detectó en 4 meses. Se corrigió en producción el 2026-10-24; la publicación automática por CI sigue pendiente
D3	Conocimiento concentrado en una persona	49 de 52 commits de un único autor; sin revisiones registradas
D4	Capa relacional intermitente y sin respaldo de Firestore	La API y MySQL corren en una PC que solo sincroniza encendida; no hay respaldo programado de Firestore ni monitor con alertas
D5	Gestión sin medición	No hay registro de esfuerzo ni tiempos de proceso; auditoría CMMI en nivel 1 (E4 de Software)
O1	Integración con el sistema del colegio	Mismo autor, API Laravel publicada y dominio institucional con correo en Google
O2	Familias con acceso móvil a internet	La consulta por código y la pre-matrícula funcionan desde el celular sin instalar nada
O3	Crecimiento multi-sede a bajo costo marginal	El modelo de datos ya admite varias sedes, grupos y turnos
O4	Servicios en la nube con cuotas gratuitas suficientes	Firebase sin costo con el uso actual; VPS de US$ 35,99 al año
A1	Exigencias de protección de datos de menores	Ley N.° 29733 y su reglamento [5], [6]; datos alojados fuera del Perú (Firebase, Vercel y VPS en EE. UU.)
A2	Rivalidad alta y estacionalidad	Campañas de matrícula cortas por ciclo
A3	Condiciones y precios de proveedores en dólares	Vercel Hobby es solo para uso personal no comercial [7]; cuotas de Firebase [8]
A4	Exposición del dominio institucional	Sin registros SPF, DMARC, CAA ni DNSSEC; el sitio del colegio no envía cabeceras de seguridad y muestra la versión de nginx (verificado el 2026-10-24)

FODA cruzado (estrategias):

Estrategia	Combinación	Iniciativa del roadmap
FO: usar la plataforma y la experiencia del autor para integrar con el colegio y captar alumnos del colegio	F1, F5, O1, O3	RM-08, RM-11
FA: publicar solo lo que pasa las pruebas y formalizar la privacidad	F2, A1	RM-01, RM-05
DO: llevar la capa relacional a servicio continuo con la infraestructura disponible	D4, O4	RM-02
DA: disposición de canal único, capacitación y transferencia de conocimiento	D1, D3, A2	RM-03, RM-06

Análisis PESTEL (breve)

Factor	Situación	Implicancia para TI
Político	Academias preuniversitarias con menor regulación sectorial que los colegios	Mayor libertad para digitalizar procesos propios
Económico	Familias sensibles al precio; servicios en la nube cobrados en dólares	Priorizar soluciones de bajo costo recurrente y vigilar el tipo de cambio
Social	Comunicación con familias por WhatsApp y celular	Canales móviles sin instalación (web responsiva, código de padres)
Tecnológico	Conectividad y energía variables en la sede	La vía crítica debe estar en la nube; la capa local no debe ser indispensable
Ecológico	Uso de papel en fichas, recibos y listas	La digitalización reduce papel (beneficio cualitativo)
Legal	Ley N.° 29733 y su reglamento (D.S. N.° 016-2024-JUS), datos de menores y transferencia internacional	Política de privacidad, consentimiento, inscripción del banco de datos y medidas de seguridad

Factores críticos de éxito

ID	Factor crítico de éxito	Indicador	Meta
FCE1	Patrocinio activo de la Dirección con una disposición de canal único de matrícula	Disposición emitida y revisiones de sprint con asistencia de la Dirección	Disposición antes del 2026-12-18; 3 de 3 revisiones
FCE2	Matrícula en línea y panel siempre disponibles	Disponibilidad mensual medida por monitor externo	≥ 99 %
FCE3	Datos confiables de cupos y pagos	Incidentes de sobrecupo o duplicados; diferencias de conciliación	0 y 0

ID	Factor crítico de éxito	Indicador	Meta
FCE4	Protección de los datos de menores	Pruebas de reglas contra lo publicado	19 de 19
FCE5	Capacidad técnica que no dependa de una persona	Personas capaces de desplegar y restaurar	≥ 2
FCE6	Personal capacitado y familias informadas	Personal capacitado por rol	100 % antes de la campaña 2027

Alineamiento estratégico (CE0112)

Cada objetivo estratégico se conecta con una brecha, una iniciativa, un objetivo SMART del proyecto (E2) y un indicador del sistema (E5).

Objetivo estratégico	FCE	Brecha que lo impide (1.3)	Iniciativa (1.5)	Objetivo del proyecto (E2)	Indicador (E5)
OE1 Crecer y retener	FCE1, FCE6	BR-01, BR-07	RM-03, RM-08, RM-13	OBJ-1, OBJ-5	IU-01, IV-05
OE2 Eficiencia y control	FCE3	BR-01, BR-03, BR-06	RM-02, RM-03, RM-06	OBJ-2, OBJ-3	IV-01, IV-02
OE3 Confianza de las familias	FCE2, FCE6	BR-01	RM-03, RM-12	OBJ-1	IU-04
OE4 Protección de datos	FCE4, FCE5	BR-02, BR-04, BR-08, BR-09	RM-01, RM-04, RM-05	OBJ-4	IM-01, IM-02
OE5 Integración CERMAT	FCE5	BR-07	RM-08, RM-10, RM-11	— (fase posterior)	IM-06

1.3 Diagnóstico digital / TI

Inventario de sistemas de información existentes

ID	Sistema	Propósito	Usuarios	Tecnología y alojamiento	Datos	Estado	Integración
SI-01	Plataforma de la academia	Oferta, matrícula, pagos, asistencia QR, recursos, talleres y consulta de padres	Admin, docentes, alumnos, auxiliar, padres y visitantes	React 18 + TypeScript + Vite en Vercel (plan Hobby); Firebase Auth, Firestore y Storage	22 colecciones con reglas por rol	En producción, piloto con volumen bajo	Envía eventos a SI-02

ID	Sistema	Propósito	Usuarios	Tecnología y alojamiento	Datos	Estado	Integración
SI-02	Capa local de la academia	Réplica relacional, reportes, auditoría y analítica de riesgo	Admin (vía panel)	API Node.js/Express (3001), MySQL 8 y FastAPI (8000) con PM2 en una PC	Matrículas, pagos, asistencia, alertas y auditoría	Operativa solo con la PC encendida	Recibe de SI-01 (URL en `config/services`)
SI-03	Sistema de gestión del colegio	Gestión escolar del colegio	Personal del colegio	Angular + Laravel (PHP 8.4) + PostgreSQL 16 en VPS RackNerd (Ubuntu 24.04, 2 vCPU, 2 GB)	Base `cermat_produccion` (116 migraciones)	En producción en `cermatschool.edu.pe` y `api.cermatschool.edu.pe`	Ninguna con SI-01
SI-04	Correo del dominio institucional	Correo del colegio	Personal	Google (registros MX del dominio)	Correos	En uso	Ninguna
SI-05	Herramientas informales	Registro manual de matrículas, pagos y asistencia; mensajes a padres	Secretaría, docentes, auxiliares	Cuadernos, hojas de cálculo y WhatsApp	Datos dispersos sin control de acceso	En uso para la mayoría de los trámites	Ninguna (re-digitación)

El mapa visual del ecosistema y la integración propuesta están en el E5, sección 5.2.

Nivel de madurez digital

Modelo usado: modelo de madurez digital de 8 dimensiones con escala de capacidad 1–5 adaptada de CMMI [4] y de los niveles de capacidad de COBIT 2019 [3].

Nivel	Nombre	Descripción
1	Inicial	Prácticas improvisadas que dependen de personas; sin registros.
2	Gestionado	Prácticas repetibles en algunos procesos; herramientas aisladas; controles parciales.
3	Definido	Procesos y herramientas estandarizados, documentados y adoptados por toda la unidad.
4	Medido	Indicadores cuantitativos con metas y control periódico.

Nivel	Nombre	Descripción
5	Optimizado	Mejora continua basada en datos e innovación.

Dimensión	Nivel actual	Justificación con evidencia	Meta 2027
Estrategia y gobierno de TI	1 ■□□□□	Sin plan estratégico de TI ni instancia de decisión; el charter y el backlog existen desde oct-2026	3
Procesos digitalizados	2 ■■□□□	La plataforma cubre matrícula, pagos y asistencia, pero la mayoría de trámites sigue siendo manual (8 matrículas)	3
Datos y analítica	2 ■■□□□	Réplica MySQL con integridad en el motor y analítica de riesgo; sincronización intermitente; sin respaldo de Firestore	3
Aplicaciones y sistemas de información	3 ■■■□□	Plataforma con 6 portales y sistema del colegio en producción, ambos documentados	4
Infraestructura y operación	2 ■■□□□	PaaS y VPS endurecido; capa local en una PC sin UPS; sin monitor con alertas	3
Seguridad y cumplimiento	2 ■■□□□	19 pruebas de reglas y roles de mínimo privilegio. Las 3 fallas de las reglas de producción y la clave expuesta en el historial se corrigieron el 2026-10-24; siguen sin política de privacidad ni registros SPF/DMARC/CAA/DNSSEC	3
Integración e interoperabilidad	1 ■□□□□	Academia y colegio no comparten identidad ni datos; solo existe Firestore → MySQL	2
Personas y cultura digital	1 ■□□□□	Sin capacitación ni disposición de uso; 0 consultas de padres; conocimiento en una persona	3
Promedio	**1,75**	Entre inicial y gestionado	**3,0**

La versión de julio de este documento calificaba la madurez como "medio-alta"; con un modelo explícito y los datos de uso reales, la calificación correcta es 1,75.

Brechas tecnológicas

ID	Brecha	Estado actual (evidencia)	Estado objetivo	Iniciativa	Prioridad
BR-01	Adopción institucional	8 matrículas en la plataforma; trámites mayormente manuales	≥ 60 % de las matrículas de 2027 en la plataforma	RM-03	Crítica
BR-02	Reglas de producción desactualizadas	**Cerrada el 2026-10-24:** versión corregida publicada y verificada como visitante sin sesión (antes fallaban 10 de 19 pruebas)	19 de 19 contra lo publicado	RM-01	Crítica (cerrada)
BR-03	Capa relacional sin servicio continuo	PC que sincroniza solo encendida	Servicio continuo en VM-APP01 (diseño CE03) o VPS puente	RM-02	Alta
BR-04	Respaldo y monitoreo	Sin respaldo programado de Firestore ni alertas	RPO ≤ 24 h y disponibilidad medida	RM-02	Alta
BR-05	Licencia de hosting	Vercel Hobby (uso personal no comercial)	Plan comercial o alternativa evaluada	RM-07	Media
BR-06	Medición y gobierno	Sin indicadores de proceso ni registro de esfuerzo	Tablero mensual de uso, valor y mejora	RM-06	Alta
BR-07	Integración academia–colegio	Ninguna	Enlace desde el sitio del colegio (decisión vigente), subdominio opcional y API REST	RM-08, RM-11	Media
BR-08	Seguridad web y DNS	Sin cabeceras en el colegio; la SPA ya publica sus cabeceras de seguridad (2026-10-24); versión de nginx visible; sin SPF, DMARC, CAA ni DNSSEC	Cabeceras publicadas y registros DNS configurados	RM-04	Alta
BR-09	Cumplimiento de protección de datos	Sin política de privacidad ni consentimiento en `src/` (búsqueda del 2026-10-24); banco de datos sin inscribir	Política, consentimiento e inscripción	RM-05	Alta

ID	Brecha	Estado actual (evidencia)	Estado objetivo	Iniciativa	Prioridad
BR-10	Continuidad del conocimiento	Un único autor; secretos en el historial (revocados el 2026-10-24)	≥ 2 personas capaces; historial limpio	RM-01, RM-03	Crítica

Problemas operativos asociados a TI

Problema	Evidencia	Efecto operativo
La pre-matrícula pública no se completaba en producción (resuelto el 2026-10-24)	Pruebas de reglas contra la versión publicada (E4 de Software, 1.6); cierre en E4 §2.7	Los postulantes debían acudir o llamar; el canal en línea no captaba
Cualquier persona sin sesión podía listar matrículas pagadas con nombre y teléfono (resuelto el 2026-10-24)	Mismo reporte	Exposición de datos de menores y riesgo legal
Reportes de MySQL incompletos	La sincronización ocurre solo con la PC encendida	Decisiones con datos parciales; la conciliación pierde valor
Asistencia sin registros desde abril	7 marcas entre el 2026-01-27 y el 2026-04-02	El cálculo de riesgo de abandono no tiene datos
Re-digitación entre cuaderno, hojas y plataforma	Proceso AS-IS (E4)	Tiempo de personal y errores de transcripción

1.4 Identificación del problema

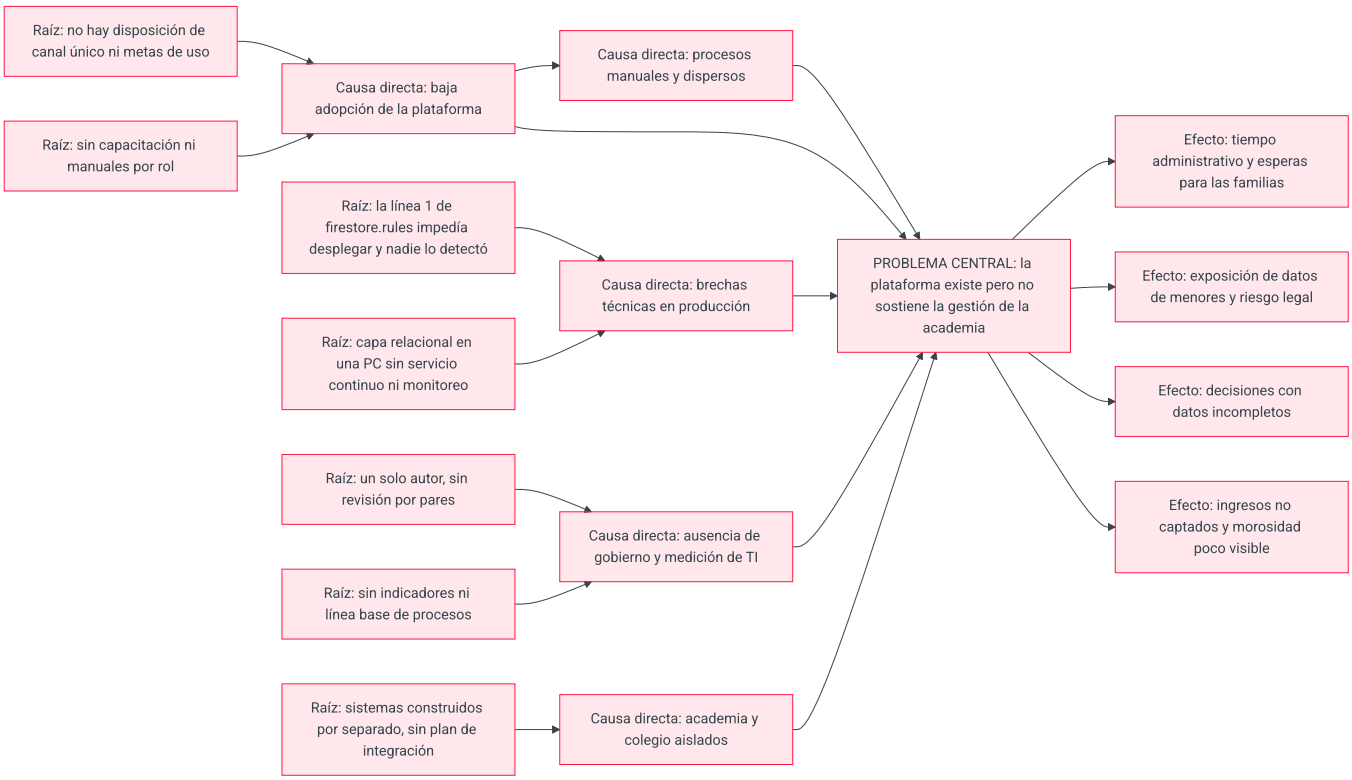
Definición estructurada del problema

Elemento	Descripción
Qué	La matrícula, la cobranza y el seguimiento de asistencia de la academia se gestionan con procesos mayormente manuales, y la plataforma que los digitaliza opera con adopción mínima y brechas técnicas abiertas en producción.
Quién lo sufre	Secretaría y caja (trabajo repetitivo), familias (esperas y poca información), Dirección (sin datos consolidados) y alumnos menores de edad (datos expuestos).
Dónde	Sede principal de la academia en Azángaro y todos los canales de atención.
Desde cuándo	Plataforma en piloto desde enero de 2026; reglas desactualizadas en producción entre el 22-jun-2026 y el 2026-10-24.
Magnitud	8 matrículas y 2 pagos en la plataforma en diez meses; 0 consultas de padres; 3 fallas críticas de seguridad publicadas (corregidas en producción el 2026-10-24).

Elemento	Descripción
Consecuencia	Tiempo administrativo, ingresos no captados, decisiones sin datos y riesgo legal y reputacional.

Enunciado: *CERMAT no aprovecha la plataforma que ya construyó porque no existe una decisión institucional de uso, la versión publicada tiene fallas que bloquean el canal en línea y exponen datos, y no hay medición ni capacidad técnica distribuida para sostenerla.*

Causas raíz (árbol de problemas)



Causa raíz	Evidencia	Cómo se verifica que se eliminó
R1 Sin disposición de canal único	No existe documento de la Dirección; uso de 8 matrículas	Disposición emitida y adopción mensual ≥ 60 %
R2 Sin capacitación	No hay manuales ni registros de capacitación	100 % del personal capacitado (registro de asistencia)
R3 Despliegue de reglas que fallaba sin aviso	Error `L1:1 token recognition error at: '#'` del emulador	Publicación solo vía CI; 19 de 19 pruebas contra lo publicado
R4 Capa relacional intermitente	PC con PM2; sin monitor	Disponibilidad medida y 0 diferencias de conciliación
R5 Un solo autor	49 de 52 commits	100 % de cambios revisados por un segundo integrante
R6 Sin medición	No hay tiempos de proceso ni registro de horas	Línea base AS-IS medida y tablero mensual

Causa raíz	Evidencia	Cómo se verifica que se eliminó
R7 Sin plan de integración	Academia y colegio sin identidad ni datos comunes	Integración N1 publicada (E5)

Impacto estratégico

Objetivo afectado	Impacto actual	Cuantificación
OE1 Crecer y retener	El canal en línea no capta; el riesgo de abandono no se calcula por falta de asistencia	Beneficio de captación y retención del caso base no capturado: S/ 1 800 al año con adopción plena (E2)
OE2 Eficiencia	Cada matrícula manual consume ≈ 40 min de personal (supuesto) frente a ≈ 10,5 min en el proceso TO-BE	Ahorro potencial de S/ 6,42 por matrícula (E4)
OE3 Confianza	0 consultas de padres en la plataforma	—
OE4 Protección de datos	Listado público de matrículas pagadas con nombre y teléfono	Infracciones sancionables con multas de hasta 100 UIT según la Ley N.° 29733 [5]
OE5 Integración	Doble registro y doble identidad entre colegio y academia	—

Justificación de la intervención

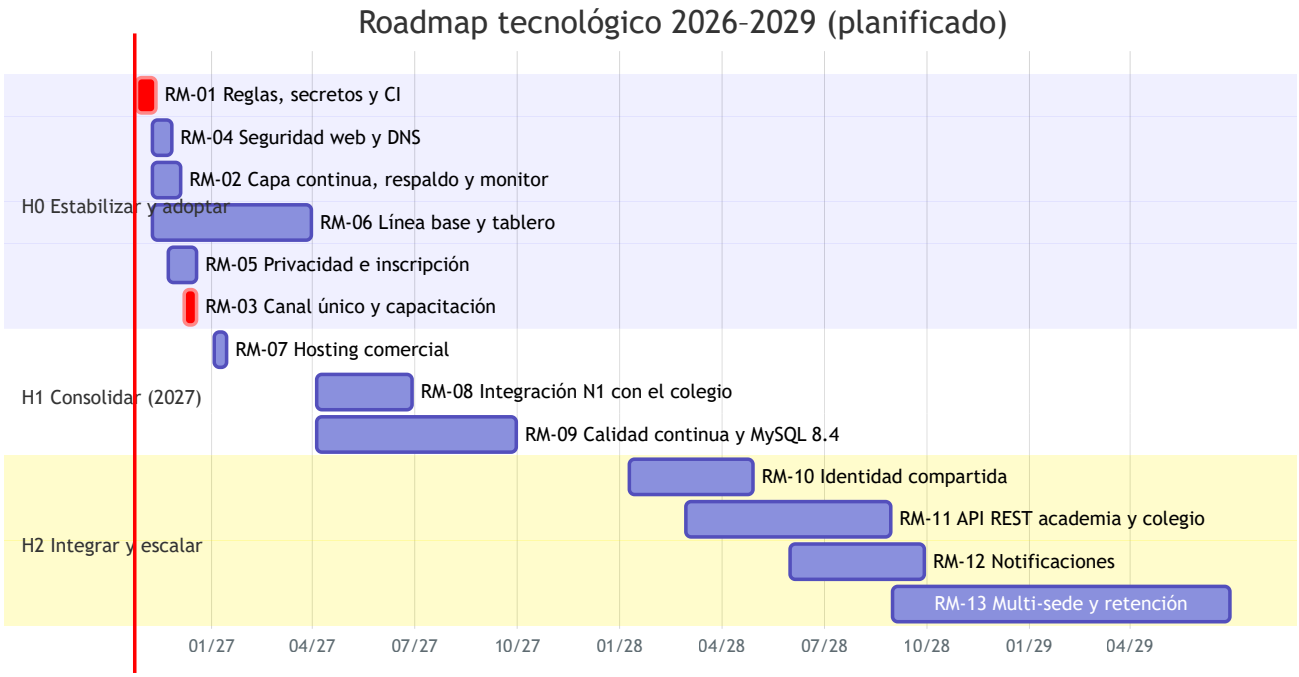
1. **La inversión principal ya está hecha.** El desarrollo de enero a octubre de 2026 es costo hundido: lo que se decide ahora es completar el cierre técnico y la adopción, con una inversión de CERMAT de S/ 1 166 en tiempo de su personal (E2).
2. **Las brechas críticas son corregibles en semanas.** Las reglas corregidas ya pasan 19 de 19 pruebas; falta publicarlas.
3. **El valor depende de la adopción, no de más desarrollo.** El caso base es positivo para CERMAT solo si la adopción sostenida supera el 64,1 % o el volumen supera las 40 matrículas por ciclo.
4. **No intervenir mantiene el riesgo legal.** Mientras las reglas actuales sigan publicadas, los datos de matrículas pagadas son listables sin sesión.

1.5 Roadmap de tecnología (CE0114)

ID	Horizonte	Iniciativa	Objetivo estratégico	Brecha	Responsable	Indicador de logro
RM-01	H0 (nov-2026)	Publicar las reglas corregidas (hecho el 2026-10-24), retirar secretos (clave rotada el 2026-10-24) y obtener el primer CI en verde (PB-04, PB-06)	OE4	BR-02, BR-10	Equipo técnico	19 de 19 pruebas contra lo publicado
RM-02	H0 (nov–dic 2026)	Operación continua de la capa relacional, respaldo de Firestore y monitor con alertas (PB-13, PB-11, PB-08)	OE2, OE4	BR-03, BR-04	Equipo técnico	RPO ≤ 24 h; disponibilidad medida
RM-03	H0 (dic-2026)	Disposición de canal único, manuales y capacitación por rol (PB-15)	OE1, OE2, OE3	BR-01, BR-10	Dirección y Product Owner	100 % del personal capacitado
RM-04	H0 (nov-2026)	Cabeceras de seguridad en Vercel y Nginx, ocultar la versión de nginx, SPF, DMARC y CAA; DNSSEC si el registro lo permite	OE4	BR-08	Responsable técnico	Verificación externa de cabeceras y DNS
RM-05	H0 (dic-2026)	Política de privacidad, aviso de consentimiento e inscripción del banco de datos (PB-16)	OE4	BR-09	Dirección	Política publicada; constancia de inscripción
RM-06	H0 (nov-2026 a mar-2027)	Línea base AS-IS y tablero de indicadores de uso y valor (PB-14)	OE2	BR-06	Product Owner	Tablero mensual publicado

ID	Horizonte	Iniciativa	Objetivo estratégico	Brecha	Responsable	Indicador de logro
RM-07	H1 (ene-2027)	Hosting comercial (Vercel Pro o alternativa evaluada) y revisión anual de proveedores	OE4	BR-05	Dirección	Contrato o plan vigente
RM-08	H1 (2027)	Integración N0–N1 con el colegio: enlace desde su sitio (decisión vigente de la institución), subdominio institucional solo si la Dirección lo aprueba y oferta publicada en JSON	OE5, OE1	BR-07	Responsable técnico	Enlace activo; subdominio según la decisión de la Dirección
RM-09	H1 (2027)	Calidad continua: pruebas de componentes, tipado, carga diferida y migración de MySQL 8.0 a 8.4 LTS	OE4	—	Equipo técnico	JS inicial < 1 MB; MySQL con soporte
RM-10	H2 (2028)	Identidad compartida para el personal con la cuenta institucional de Google en ambos sistemas	OE5	BR-07	Responsable técnico	Inicio de sesión único para el personal
RM-11	H2 (2028)	API REST de intercambio academia–colegio (alumnos del colegio, oferta y matrícula confirmada)	OE5, OE1	BR-07	Responsable técnico	≥ 2 procesos con datos compartidos

ID	Horizonte	Iniciativa	Objetivo estratégico	Brecha	Responsable	Indicador de logro
RM-12	H2 (2028)	Notificaciones por correo institucional (SPF, DKIM y DMARC) y evaluación de WhatsApp	OE3	—	Responsable técnico	Confirmaciones automáticas enviadas
RM-13	H2 (2028–2029)	Todas las sedes y grupos en la plataforma; analítica de retención	OE1	—	Dirección	Sedes cargadas / sedes reales



Regla de secuencia: no se integra con el colegio (H1–H2) mientras la plataforma no supere el hito de continuidad del 2027-03-31 (adopción y beneficios medidos, ver E3). Integrar un sistema que no se usa multiplica el riesgo sin aumentar el valor.

1.6 Matriz de riesgos estratégicos (CE0115)

Escala: probabilidad (P) e impacto (I) de 1 a 5; nivel por P × I: **Bajo** 1–4, **Medio** 5–9, **Alto** 10–14, **Crítico** 15–25. Los riesgos de ejecución del proyecto están en el E3, sección 3.5.

ID	Riesgo estratégico (causa → evento → efecto)	P	I	P×I	Nivel	Respuesta	Responsable	Indicador de alerta
RE-01	Sin disposición institucional → el personal sigue con cuaderno → la plataforma no genera valor	4	4	16	Crítico	Disposición de canal único, capacitación, registro rápido y metas mensuales (RM-03)	Dirección	Adopción mensual < 50 % dos meses seguidos
RE-02	Un solo autor mantiene ambos sistemas → se ausenta → nadie puede desplegar ni restaurar	4	5	20	Crítico	Transferencia de conocimiento, revisión por pares, documentación y contrato de mantenimiento	Dirección	Cambios sin revisión > 0
RE-03	Reglas de producción desactualizadas → listado público de matrículas pagadas → exposición de datos de menores	4	5	20	Crítico	Reglas corregidas publicadas y verificadas el 2026-10-24 (desde la consola); falta la publicación vía CI (RM-01)	Equipo técnico	Pruebas contra lo publicado < 19 de 19
RE-04	Sin política, consentimiento ni inscripción → fiscalización de la ANPD → sanción y daño reputacional	3	4	12	Alto	RM-05; informar la transferencia internacional de datos	Dirección	Política no publicada al 2026-12-18

ID	Riesgo estratégico (causa → evento → efecto)	P	I	P×I	Nivel	Respuesta	Responsable	Indicador de alerta
RE-05	Dominio sin SPF, DMARC, CAA ni DNSSEC y sitios sin cabeceras → suplantación o ataque web → pérdida de confianza	3	3	9	Medio	RM-04	Responsable técnico	Reporte DMARC con fuentes no autorizadas
RE-06	Firestore sin respaldo y capa local en una PC → falla o borrado → pérdida de datos operativos	2	5	10	Alto	Respaldo programado y prueba de restauración (RM-02)	Equipo técnico	Último respaldo verificado > 24 h
RE-07	Proveedores cambian condiciones o precios en dólares → costo mayor o incumplimiento de licencia	3	3	9	Medio	Plan comercial presupuestado, alternativa evaluada y exportación periódica	Dirección	Aviso de cambio de términos o tipo de cambio > S/ 3,74
RE-08	Volumen bajo → beneficios menores a los costos → VAN privado negativo (pesimista: S/ −8 809)	3	4	12	Alto	Hito de continuidad del 2027-03-31 y optimización de costos (E2)	Dirección	Matrículas por ciclo < 40

ID	Riesgo estratégico (causa → evento → efecto)	P	I	P×I	Nivel	Respuesta	Responsable	Indicador de alerta
RE-09	Competidores con mejor experiencia digital → pérdida de postulantes	3	3	9	Medio	Pre-matrícula en línea, código de padres e integración con el colegio	Dirección	Caída de matrículas por ciclo
RE-10	Integración con el colegio mal protegida (API con CORS sin restringir) → acceso indebido entre sistemas	2	4	8	Medio	Diseño de integración con autenticación por servicio, CORS restringido y mínimo privilegio (E5)	Responsable técnico	Endpoint sin autenticación detectado

Mapa de calor (riesgo inherente):

Probabilidad \ Impacto	1	2	3	4	5
5					
4				RE-01	RE-02, RE-03
3			RE-05, RE-07, RE-09	RE-04, RE-08	
2				RE-10	RE-06
1					

Referencias

[1] M. E. Porter, *Competitive Advantage: Creating and Sustaining Superior Performance*. New York, NY, USA: Free Press, 1985.

[2] A. L. Mendelow, "Environmental scanning: The impact of the stakeholder concept," en *Proc. 2nd Int. Conf. Information Systems (ICIS)*, Cambridge, MA, USA, 1981, pp. 407–417.

[3] ISACA, *COBIT 2019 Framework: Governance and Management Objectives*. Schaumburg, IL, USA: ISACA, 2018.

[4] CMMI Institute, *CMMI Model V2.0*. Pittsburgh, PA, USA: CMMI Institute, 2018.

[5] Congreso de la República del Perú, "Ley N.° 29733, Ley de Protección de Datos Personales," *Diario Oficial El Peruano*, 3 de julio de 2011.

[6] Ministerio de Justicia y Derechos Humanos, "Decreto Supremo N.° 016-2024-JUS, que aprueba el Reglamento de la Ley N.° 29733," *Diario Oficial El Peruano*, 2024.

[7] Vercel Inc., "Pricing." [En línea]. Disponible: https://vercel.com/pricing

[8] Google, "Firebase pricing." [En línea]. Disponible: https://firebase.google.com/pricing

Rúbrica de evaluación

Criterio	Excelente	Bueno	Regular	Deficiente
Análisis del contexto organizacional	Analiza profundamente el entorno con evidencia y sustento estratégico.	Analiza el contexto con identificación clara de problemas.	Describe la organización de forma general.	Descripción superficial sin análisis estructurado.
Identificación de brechas estratégicas	Identifica brechas críticas con análisis fundamentado y evidencia objetiva.	Identifica brechas coherentes con objetivos organizacionales.	Identifica brechas generales sin sustento.	No identifica brechas relevantes.
Alineamiento estratégico del proyecto	Evidencia alineamiento claro y coherente entre estrategia, problema y propuesta TI.	Justifica el proyecto en función de objetivos organizacionales.	Relación débil o implícita.	No demuestra relación entre estrategia y proyecto.
Sustentación y defensa técnica	Explica y defiende con dominio las decisiones tomadas.	Explica con solvencia.	Explica con dificultad.	No sustenta.

E2 — Business Case del Proyecto (CE0113)

Evidencia CE0113 — Caso de negocio

Justifica la viabilidad y conveniencia de **institucionalizar** la Plataforma Web Integral CERMAT. El modelo financiero completo, con fórmulas de Excel auditables, está en business-case.xlsx y se genera con `perfil-egreso/scripts/generar-business-case.mjs`. Todas las cifras de este documento salen de ese libro.
Advertencia: el piloto registró solo 8 matrículas, 2 pagos y 7 marcas de asistencia; los beneficios dependen de la adopción institucional y todas las cifras estimadas son supuestos a validar con la Dirección.

Portada

Campo	Detalle
Título	Business case — Institucionalización de la Plataforma Web Integral de Gestión Académica CERMAT
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo), UPeU campus Juliaca, sección g1
Fecha	2026-10-24
Competencia	CE011 — Gestión e Innovación de TI (evidencia CE0113); aporta a CE0124 (análisis económico)
Horizonte	Año 0 = 2026 (inversión) y años 1 a 3 = 2027 a 2029 (operación), en soles constantes y antes de impuestos

Resumen ejecutivo

Decisión que se pide a la Dirección: adoptar la plataforma como canal oficial de matrícula, cobranza y asistencia de la academia en 2027, financiar su operación (S/ 2 438 al año en el escenario base) y aportar el tiempo de su personal para el cierre del proyecto (S/ 1 166). El desarrollo ya ejecutado es costo hundido y el cierre técnico lo realiza el equipo EPE sin desembolso de CERMAT.

Indicador (vista A, perspectiva de CERMAT, tasa 12 %)	Pesimista	Base	Optimista
VAN	S/ −8 809	**S/ 1 247**	S/ 13 245
TIR	No calculable	**53,5 %**	450,7 %
Relación beneficio/costo	0,10	**1,18**	3,23
ROI a 3 años	−89,6 %	**23,6 %**	238,9 %

Indicador (vista A, perspectiva de CERMAT, tasa 12 %)	Pesimista	Base	Optimista
Periodo de recuperación	No se recupera en 3 años	**1,7 años** (descontado: 1,9)	0,2 años

1. **En el escenario base el proyecto conviene a CERMAT**, pero con margen estrecho: el VAN es cero con 40 matrículas por ciclo (el supuesto base es 60) o con una adopción sostenida de 64,1 %.
2. **Si la adopción se queda como en el piloto, el proyecto pierde dinero** (escenario pesimista): los costos fijos de operación superan los ahorros.
3. **Valorizado a precio de mercado**, el proyecto completo (S/ 21 346, incluidas las horas del equipo) no se recupera en 3 años en ningún escenario (vista B). Desarrollar a medida para una sola sede solo se paga a escala multi-sede (≈ 363 matrículas por ciclo) o con un horizonte mayor. La conveniencia actual para CERMAT se apoya en que esa inversión ya la aportó el equipo.
4. Las variables que más mueven el VAN son la **captación y retención** (que hoy dependen de desbloquear la matrícula pública en producción) y la **adopción**; el costo del hosting comercial es la principal palanca de ahorro.

Recomendación: aprobar la alternativa D (plataforma propia) con un **hito de continuidad el 2027-03-31**, al cierre del ciclo de verano, con los criterios de la sección 2.4.6.

2.1 Justificación del proyecto

Problema que se resuelve

CERMAT gestiona la matrícula, la cobranza y la asistencia de la academia con procesos mayormente manuales (cuaderno, hojas de cálculo y WhatsApp), mientras la plataforma construida para digitalizarlos opera con adopción mínima. Hasta el 2026-10-24 sus reglas publicadas bloqueaban la matrícula en línea y exponían el listado de matrículas pagadas; ese día se publicó la versión corregida. El análisis completo del problema, sus causas raíz y su impacto está en el E1, sección 1.4.

Objetivos del proyecto (SMART)

ID	Objetivo	Indicador y fuente	Línea base	Meta	Plazo
OBJ-1	Registrar en la plataforma las matrículas de la academia	Matrículas en `enrollments` ÷ matrículas del registro de secretaría	8 matrículas en el piloto (ene–jul 2026); porcentaje no medido	≥ 60 % en 2027 (promedio anual) y ≥ 80 % en 2028	31-12-2027 y 31-12-2028
OBJ-2	Reducir el tiempo de personal por matrícula	Minutos cronometrados en 10 trámites	≈ 40 min (supuesto; se mide en nov-2026)	≤ 12 min	31-03-2027

ID	Objetivo	Indicador y fuente	Línea base	Meta	Plazo
OBJ-3	Responder rápido a cada pre-matrícula	Percentil 90 de `approvedAt` o `cancelledAt` − `createdAt`	No medible hoy (2 registros de prueba)	≤ 24 h	Campaña 2027
OBJ-4	Publicar solo versiones seguras y sin errores de cupo	Pruebas de reglas contra lo publicado; incidentes de sobrecupo o duplicado	10 de 19 pruebas fallaban contra lo publicado hasta el 2026-10-24; 0 fallas observadas en producción tras publicar la versión corregida	19 de 19 y 0 incidentes	Desde el 06-11-2026
OBJ-5	Confirmar el valor económico con datos reales	VAN de la vista A recalculado con volumen, adopción y tiempos medidos	VAN base proyectado: S/ 1 247	VAN ≥ 0	31-03-2027 y 31-12-2027

Beneficios esperados

Menos tiempo de secretaría y de la Dirección por matrícula, pagos y reportes; asistencia consolidada sin trabajo manual; padres que consultan solos; matrículas captadas fuera del horario de atención; alumnos retenidos gracias a las alertas de inasistencia y menor morosidad. Se cuantifican en la sección 2.3.

2.2 Análisis de alternativas

Alternativas tecnológicas consideradas

Alternativa	Descripción	Principal ventaja	Principal limitación
A. Mantener el proceso manual	Cuaderno, hojas de cálculo y WhatsApp	Sin desembolso	No controla cupos ni duplicados; sin trazabilidad ni datos para decidir
B. Formularios y hojas compartidas	Formularios y hojas de Google Workspace (el dominio del colegio ya usa correo de Google)	Bajo costo y rápida	Sin transacciones de cupo, sin roles por registro, sin QR ni consulta de padres; hojas compartidas por enlace
C. Software SaaS de gestión académica	Suscripción por alumno a un proveedor	Soporte del proveedor	Modelo de colegio genérico (no ciclos, grupos y turnos de academia); datos y reglas fuera del control de CERMAT; costo recurrente en dólares
D. Plataforma propia (elegida)	La plataforma ya construida, con cierre técnico y adopción	Ajuste exacto al proceso; ya probada (90 pruebas)	Depende de mantenimiento propio y de la adopción

Alternativa	Descripción	Principal ventaja	Principal limitación
E. Extender el sistema del colegio	Construir los módulos de la academia en Laravel y Angular	Integración nativa con el colegio	Rehacer ≈ 400 h de trabajo; no estaría lista para la campaña 2027

Criterios de evaluación

Criterio	Peso	Cómo se puntúa (1 a 5)
C1 Ajuste al proceso de CERMAT (ciclos, grupos, sedes, turnos, cuotas, QR, código de padres)	25 %	5 = cubre todo sin adaptación; 1 = no cubre el proceso
C2 Costo incremental para CERMAT a 3 años (valor actual)	20 %	Regla de la hoja Alternativas: ≤ S/ 2 000 = 5; ≤ 5 000 = 4; ≤ 8 000 = 3; ≤ 12 000 = 2; > 12 000 = 1
C3 Control de cupos y calidad de datos	15 %	5 = cupo y duplicados garantizados por transacción; 1 = control manual
C4 Seguridad y protección de datos (roles, Ley N.° 29733)	15 %	5 = control de acceso por rol verificado con pruebas; 1 = sin control
C5 Integración con el ecosistema y escalabilidad multi-sede	15 %	5 = integración nativa; 1 = sistema aislado
C6 Tiempo y riesgo de puesta en marcha para la campaña 2027	10 %	5 = disponible hoy; 1 = más de 6 meses

Matriz comparativa

Costo incremental para CERMAT a 3 años (hoja Alternativas; VA al 12 %):

Alternativa	Inversión inicial	Costo anual	VA del costo a 3 años	Puntaje C2
A. Manual	S/ 0	S/ 0	S/ 0	5
B. Formularios y hojas	S/ 500	S/ 300	S/ 1 221	5
C. SaaS	S/ 500	S/ 4 896	S/ 12 259	1
D. Plataforma propia	S/ 1 166	S/ 2 438	S/ 7 023	3
E. Extender el sistema del colegio	S/ 10 000	S/ 900	S/ 12 162	1

Matriz ponderada:

Alternativa	C1 (25 %)	C2 (20 %)	C3 (15 %)	C4 (15 %)	C5 (15 %)	C6 (10 %)	Total
A. Manual	2	5	1	2	1	5	2,60

Alternativa	C1 (25 %)	C2 (20 %)	C3 (15 %)	C4 (15 %)	C5 (15 %)	C6 (10 %)	Total
B. Formularios y hojas	2	5	2	2	2	5	2,90
C. SaaS	3	1	4	3	2	3	2,60
D. Plataforma propia	**5**	**3**	**5**	**4**	**4**	**4**	**4,20**
E. Extender el sistema del colegio	3	1	4	4	5	1	3,00

Justificación de los puntajes de D y de su competidora más cercana (E): D obtiene 5 en C1 porque modela ciclos, grupos, sedes, turnos, cuotas, QR y código de padres; 5 en C3 porque la matrícula valida cupo y duplicado en una transacción con id determinístico (cubierto por 6 pruebas de reglas); 4 en C4 porque el control por rol está probado (19 pruebas) pero la versión publicada aún no lo aplica; 4 en C5 porque ya replica a MySQL por API y la integración con el colegio está diseñada pero no hecha; 4 en C6 porque existe y solo falta un cierre de 6 semanas. E obtiene 5 en integración, pero 1 en costo y en tiempo.

Robustez: se subió 10 puntos el peso de cada criterio y se reescalaron los demás (6 variantes). D queda primera en **6 de 6**. La decisión no depende de un peso en particular.

Decisión: alternativa D. B es la opción de menor costo, pero no resuelve el control de cupos ni la protección de datos, que son parte del problema.

2.3 Evaluación de beneficios

Beneficios cuantificables

Fórmulas con la adopción α de cada año (supuestos en la sección 2.4.1). Valores del escenario base.

ID	Beneficio	Mecanismo y fórmula	Año 1	Año 2	Año 3
B1	Tiempo de secretaría y de la Dirección en la matrícula	α × matrículas al año × (25 min × S/ 10 por h + 4,5 min × S/ 30 por h); tiempos del E4	S/ 693	S/ 924	S/ 1 040
B2	Registro de pagos y reporte de gestión	α × (matrículas × 2 pagos × 5 min + 3 h al mes) × S/ 10 por h	S/ 396	S/ 528	S/ 594

ID	Beneficio	Mecanismo y fórmula	Año 1	Año 2	Año 3
B3	Consolidación de asistencia y consultas de padres	α × (10 min × 200 días + alumnos × 1 consulta × 10 meses × 5 min × 50 % resueltas con el código) × S/ 10 por h	S/ 350	S/ 467	S/ 525
B4	Matrículas adicionales captadas en línea y alumnos retenidos	α × 3 ciclos × S/ 400 × 60 % de margen × (2 adicionales + 1 retenido × 50 %)	S/ 1 080	S/ 1 440	S/ 1 620
B5	Menor morosidad	α × matrículas × S/ 400 × 0,5 puntos	S/ 216	S/ 288	S/ 324
	Total		**S/ 2 735**	**S/ 3 647**	**S/ 4 103**

B1 a B3 son **ahorros de tiempo**: el personal se reasigna a la atención, no se reduce planilla. B4 y B5 son **ingresos protegidos o adicionales** y dependen de que la matrícula pública vuelva a funcionar en producción y de que se usen las alertas de inasistencia.

Beneficios cualitativos

Beneficio	Destinatario	Cómo se evidencia
Cumplimiento de la Ley N.° 29733 y menor riesgo de sanción	Dirección	Reglas corregidas publicadas; política de privacidad e inscripción del banco de datos
Confianza de las familias	Padres	Consultas por código; confirmación inmediata de la matrícula
Trazabilidad y auditoría	Dirección	Quién aprobó, canceló o anuló y cuándo (`approvedBy` , `approvedAt` y triggers de auditoría en MySQL)
Datos para decidir	Dirección	Vistas de estado de cuenta, asistencia diaria y riesgo de abandono
Imagen institucional moderna	Postulantes	Sitio público con oferta y matrícula en línea
Base para integrar colegio y academia	CERMAT	Roadmap RM-08 a RM-11 (E1)
Menos papel	Todos	Fichas y listas digitales

Indicadores de valor

Indicador	Fórmula	Línea base real	Meta 2027
Adopción	Matrículas en la plataforma ÷ matrículas totales	8 matrículas en la plataforma; total por medir	≥ 60 %

Indicador	Fórmula	Línea base real	Meta 2027
Minutos de personal por matrícula	Cronometraje de 10 trámites	Por medir (supuesto 40 min)	≤ 12 min
Tiempo de respuesta a la pre-matrícula (p90)	`approvedAt` o `cancelledAt` − `createdAt`	No medible (2 registros de prueba)	≤ 24 h
Matrículas originadas en línea por ciclo	Pre-matrículas públicas que pasan a pagadas	Por medir	≥ 2 adicionales por ciclo
Consultas de padres	Alumnos con al menos una consulta por código en el mes ÷ alumnos activos	0	≥ 50 %
Morosidad	Saldo vencido ÷ ingreso del ciclo	Por medir	−0,5 puntos
VAN recalculado (vista A)	Libro con datos reales	S/ 1 247 (proyectado)	≥ 0

2.4 Estimación de costos

2.4.1 Supuestos del modelo

Los costos **reales conocidos** son: VPS RackNerd US$ 35,99 al año; Vercel en plan Hobby US$ 0 (sus términos lo limitan a uso personal no comercial, por lo que el uso institucional corresponde al plan Pro, de pago por miembro, que se toma como **supuesto de costo**); Firebase en plan gratuito con el uso actual. Todo lo demás es supuesto, con su fuente o criterio. Esta tabla es copia de la hoja "Supuestos" del libro; si se cambia un valor allí, todo el modelo se recalcula.

ID	Supuesto	Unidad	Pesimista	Base	Optimista	Fuente o criterio	Estado
S01	Tasa de descuento anual	% anual	12,0 %	12,0 %	12,0 %	Costo de oportunidad del capital para una institución educativa privada pequeña; se usa por encima de la tasa social de descuento del MEF (8 %) por el riesgo privado. Validar con la Dirección o su contador.	Supuesto a validar

ID	Supuesto	Unidad	Pesimista	Base	Optimista	Fuente o criterio	Estado
S02	Tipo de cambio	S/ por US$	3,40	3,40	3,40	Referencia de mercado 2026. Validar con el tipo de cambio venta de la SBS el día de aprobación (ver hoja Sensibilidad: ±10 %).	Supuesto a validar
S03	Matrículas por ciclo (todas las vías)	matrículas	40	60	90	Base: 2 grupos de 30 alumnos en la sede actual. Validar con los registros de matrícula de secretaría. El piloto registró solo 8 matrículas en la plataforma entre el 2026-01-27 y el 2026-07-07.	Supuesto a validar
S04	Ciclos por año	ciclos	3	3	3	Calendario típico de una academia preuniversitaria (verano, ciclo I y ciclo II). Validar con la Dirección.	Supuesto a validar
S05	Adopción en el año 1 (2027)	% de matrículas registradas en la plataforma	30 %	60 %	80 %	Depende de una disposición de la Dirección: toda matrícula se registra en línea o con el registro rápido de secretaría. Hoy la adopción real es baja (8 matrículas).	Supuesto a validar

ID	Supuesto	Unidad	Pesimista	Base	Optimista	Fuente o criterio	Estado
S06	Adopción en el año 2 (2028)	% de matrículas	40 %	80 %	95 %	Curva de adopción con capacitación y acompañamiento.	Supuesto a validar
S07	Adopción en el año 3 (2029)	% de matrículas	50 %	90 %	100 %	Curva de adopción con capacitación y acompañamiento.	Supuesto a validar
S08	Costo hora del personal administrativo y auxiliar	S/ por hora	10	10	10	Remuneración supuesta de S/ 1 300 al mes más cargas sociales (≈ 45 %) entre 192 h al mes.	Supuesto a validar
S09	Costo hora de la Dirección	S/ por hora	30	30	30	Remuneración directiva supuesta de S/ 4 000 al mes más cargas sociales entre 192 h al mes.	Supuesto a validar
S10	Costo hora docente	S/ por hora	20	20	20	Tarifa horaria docente supuesta.	Supuesto a validar
S11	Costo hora técnico (desarrollo, operación y mantenimiento)	S/ por hora	25	25	25	Desarrollador junior con S/ 3 000 al mes más cargas sociales (≈ 45 %) entre 176 h al mes.	Supuesto a validar
S12	Minutos de secretaría ahorrados por matrícula	min	15	25	30	Base calculada en la hoja Proceso (35 → 10 min). Medir con el cronometraje de 10 trámites y las marcas de tiempo del sistema (E4).	Supuesto a validar

ID	Supuesto	Unidad	Pesimista	Base	Optimista	Fuente o criterio	Estado
S13	Minutos de la Dirección ahorrados por matrícula	min	3	4,5	5	Base calculada en la hoja Proceso (5 → 0,5 min).	Supuesto a validar
S14	Pagos registrados por matrícula	pagos	2	2	2	Promedio supuesto entre pago al contado (1) y en cuotas (2 a 3).	Supuesto a validar
S15	Minutos ahorrados por pago registrado	min	3	5	6	Registro y conciliación manual (≈ 8 min) frente a registro en el panel con conciliación automática (≈ 3 min).	Supuesto a validar
S16	Horas ahorradas al mes en el reporte de gestión	h por mes	1,5	3	4	Consolidar cuadernos y hojas (≈ 3,5 h) frente a consultar el panel y las vistas de MySQL (≈ 0,5 h).	Supuesto a validar
S17	Minutos ahorrados por día lectivo al consolidar la asistencia	min por día	5	10	15	Lista en cuaderno y consolidación manual frente a registro por QR.	Supuesto a validar
S18	Días lectivos por año	días	200	200	200	Cinco días por semana durante 40 semanas.	Supuesto a validar
S19	Consultas de padres por alumno al mes	consultas	1	1	1	Llamadas o visitas para preguntar por asistencia o pagos. Hoy hay 0 consultas registradas en la plataforma.	Supuesto a validar

ID	Supuesto	Unidad	Pesimista	Base	Optimista	Fuente o criterio	Estado
S20	Minutos de personal por consulta atendida	min	5	5	5	Atención telefónica o presencial.	Supuesto a validar
S21	Consultas resueltas con el código de padres (autoservicio)	%	25 %	50 %	75 %	Consulta de asistencia por código CERMAT sin llamar a la academia.	Supuesto a validar
S22	Meses con clases por año	meses	10	10	10	Calendario académico supuesto.	Supuesto a validar
S23	Ingreso promedio por matrícula	S/	S/ 400	S/ 400	S/ 400	Supuesto; validar con el tarifario vigente de la academia.	Supuesto a validar
S24	Margen de contribución de una matrícula adicional	%	60 %	60 %	60 %	Docente y aula son costos fijos del grupo; el costo variable son materiales y atención.	Supuesto a validar
S25	Matrículas adicionales por ciclo captadas por el canal en línea	matrículas	0	2	4	Pre-matrícula 24/7 desde el sitio público (desbloqueada en producción el 2026-10-24 al publicar las reglas corregidas). Medir con el origen de cada matrícula.	Supuesto a validar
S26	Alumnos retenidos por ciclo gracias a las alertas de inasistencia	alumnos	0	1	2	Seguimiento con sp_riesgo_inasistencia y la analítica de riesgo.	Supuesto a validar

ID	Supuesto	Unidad	Pesimista	Base	Optimista	Fuente o criterio	Estado
S27	Fracción del ingreso del ciclo que se conserva por alumno retenido	%	50 %	50 %	50 %	El abandono ocurre a mitad de ciclo en promedio (supuesto).	Supuesto a validar
S28	Reducción de la morosidad	puntos del ingreso	0,0 %	0,5 %	1,0 %	Visibilidad del saldo por cuota en el panel. Medir con el saldo vencido mensual.	Supuesto a validar
S29	Vercel Pro por miembro al mes	US$	US$ 20,00	US$ 20,00	US$ 20,00	Precio de lista del plan Pro (pago por miembro). El plan Hobby actual (US$ 0) es solo para uso personal no comercial; el uso institucional corresponde al plan Pro. Validar al contratar.	Supuesto de costo
S30	Miembros del plan Pro	miembros	1	1	1	Un responsable técnico publica los despliegues.	Supuesto a validar

ID	Supuesto	Unidad	Pesimista	Base	Optimista	Fuente o criterio	Estado
S31	VPS institucional imputado a la academia	US$ por año	US$ 35,99	US$ 35,99	US$ 35,99	Costo real del plan RackNerd vigente. Se imputa completo por prudencia: copia externa de respaldos y VPN de la capa relacional (diseño CE03) o VPS puente del mismo plan mientras no exista VM-APP01.	Real (costo); imputación supuesta
S32	Firebase	US$ por año	US$ 60,00	US$ 0,00	US$ 0,00	Plan gratuito con el uso actual (real). El escenario pesimista reserva US$ 5 al mes por exceso de cuota o por pasar al plan Blaze.	Real (US$ 0 hoy); reserva supuesta
S33	Operación: monitoreo, respaldos y usuarios	h por mes	3	2	1,5	Rutina diaria, semanal y mensual de operación (E5).	Supuesto a validar
S34	Mantenimiento correctivo y evolutivo	h por mes	5	3	2	Actualización de dependencias y correcciones; el CI con 90 pruebas reduce el esfuerzo de verificación.	Supuesto a validar
S35	Horas del Product Owner (Dirección)	h	12	12	12	Hoja Presupuesto, fila C.1.	Supuesto a validar

ID	Supuesto	Unidad	Pesimista	Base	Optimista	Fuente o criterio	Estado
S36	Horas de la Dirección en revisiones de sprint	h	3	3	3	Hoja Presupuesto, fila C.2.	Supuesto a validar
S37	Horas de capacitación del personal administrativo y auxiliar	h	9	9	9	Hoja Presupuesto, fila C.3.	Supuesto a validar
S38	Horas de capacitación docente	h	6	6	6	Hoja Presupuesto, fila C.4.	Supuesto a validar
S39	Horas de transferencia de conocimiento al responsable técnico de CERMAT	h	16	16	16	Hoja Presupuesto, fila C.5.	Supuesto a validar
S40	Reserva de contingencia sobre el trabajo planificado	%	20 %	10 %	10 %	Práctica habitual de 10 % para trabajo con alcance conocido; 20 % en el escenario pesimista.	Supuesto a validar
S41	Horas del equipo ya ejecutadas (ene a oct de 2026)	h	640	640	640	Hoja Presupuesto. Estimación por analogía: no hay registro de horas (brecha de estimación del E4 de Software).	Supuesto a validar
S42	Horas del equipo planificadas (oct de 2026 a abr de 2027)	h	152	152	152	Hoja Presupuesto.	Supuesto a validar

ID	Supuesto	Unidad	Pesimista	Base	Optimista	Fuente o criterio	Estado
S43	Suscripción SaaS por alumno activo al mes	US$	US$ 2,00	US$ 2,00	US$ 2,00	Valor de referencia del equipo, sin cotización. Pedir al menos dos cotizaciones.	Supuesto a validar
S44	Horas de configuración y migración al SaaS	h	20	20	20	Carga de oferta, alumnos y usuarios.	Supuesto a validar
S45	Horas para configurar formularios y hojas compartidas	h	20	20	20	Formularios, hoja de cupos y permisos.	Supuesto a validar
S46	Mantenimiento de formularios y hojas	h por mes	1	1	1	Ajustes por ciclo.	Supuesto a validar
S47	Horas para extender el sistema del colegio a la academia	h	400	400	400	Rehacer en Laravel y Angular la oferta, matrícula, pagos, asistencia QR y portales (estimación del equipo).	Supuesto a validar
S48	Mantenimiento del sistema extendido	h por mes	3	3	3	Igual esfuerzo que la plataforma propia.	Supuesto a validar

2.4.2 Inversión inicial

La inversión se presenta en dos vistas. La **vista A** (decisión) contiene solo lo que CERMAT aporta: el tiempo de su personal. La **vista B** (referencia) agrega el trabajo del equipo valorizado a S/ 25 por hora, ejecutado y planificado, y coincide con el presupuesto total del proyecto del E3, sección 3.4.

Rubro	Horas	Tarifa (S/ por h)	Costo	Vista
Product Owner designado por la Dirección	12	30	S/ 360	A

Rubro	Horas	Tarifa (S/ por h)	Costo	Vista
Revisiones de sprint con la Dirección	3	30	S/ 90	A
Capacitación del personal administrativo y auxiliar	9	10	S/ 90	A
Capacitación docente	6	20	S/ 120	A
Transferencia de conocimiento al responsable técnico de CERMAT	16	25	S/ 400	A
Reserva de contingencia (10 %)			S/ 106	A
Inversión de CERMAT (año 0)			**S/ 1 166**	**A**
Trabajo ejecutado del equipo, ene a oct de 2026 (costo hundido)	640	25	S/ 16 000	B
Trabajo planificado del equipo, oct de 2026 a abr de 2027	152	25	S/ 3 800	B
Reserva de contingencia del trabajo planificado (10 %)			S/ 380	B
Inversión del proyecto completo (año 0)			**S/ 21 346**	**B**

Fuera de este caso: el host on-premise del diseño de centro de datos de CE03 (hardware por cotizar, sin presupuesto aprobado, ver S1-E2 de Infraestructura). Sirve a todo CERMAT y a los servicios de seguridad, y la vía crítica de la plataforma está en la nube, por lo que se evalúa en su propio caso.

2.4.3 Costos operativos y de mantenimiento

Rubro	Hoy	Pesimista (año)	Base (año)	Optimista (año)	Tipo
C1 Vercel Pro (1 miembro × US$ 20 × 12 meses)	US$ 0 (Hobby, no comercial)	S/ 816	S/ 816	S/ 816	Operación
C2 VPS institucional imputado (US$ 35,99)	US$ 35,99 al año (pagado por el colegio)	S/ 122	S/ 122	S/ 122	Operación
C3 Firebase	US$ 0	S/ 204	S/ 0	S/ 0	Operación

Rubro	Hoy	Pesimista (año)	Base (año)	Optimista (año)	Tipo
C4 Operación (h por mes × 12 × S/ 25)	No formalizada	S/ 900	S/ 600	S/ 450	Operación
C5 Mantenimiento correctivo y evolutivo (h por mes × 12 × S/ 25)	No formalizado	S/ 1 500	S/ 900	S/ 600	Mantenimiento
Total anual		**S/ 3 542**	**S/ 2 438**	**S/ 1 988**	

El dominio no genera costo: la institución decidió mantener la plataforma en el subdominio de Vercel, enlazado desde el sitio del colegio. Si más adelante la Dirección prefiere un subdominio del dominio `.edu.pe` que ya paga el colegio, tampoco habría costo adicional.

2.4.4 Flujo de caja y evaluación económica a 3 años

Flujo de caja del escenario base (hoja "Flujo de caja", soles):

Concepto	Año 0 (2026)	Año 1 (2027)	Año 2 (2028)	Año 3 (2029)	Total
Adopción	—	60 %	80 %	90 %	
Matrículas registradas en la plataforma	—	108	144	162	414
B1 Matrícula: tiempo de secretaría y de la Dirección	0	693	924	1 040	2 657
B2 Pagos y reporte de gestión	0	396	528	594	1 518
B3 Asistencia y consultas de padres	0	350	467	525	1 342
B4 Matrículas adicionales y alumnos retenidos	0	1 080	1 440	1 620	4 140
B5 Menor morosidad	0	216	288	324	828
Beneficios totales	**0**	**2 735**	**3 647**	**4 103**	**10 484**
C1 Vercel Pro	0	816	816	816	2 448
C2 VPS institucional imputado	0	122	122	122	367
C3 Firebase	0	0	0	0	0

Concepto	Año 0 (2026)	Año 1 (2027)	Año 2 (2028)	Año 3 (2029)	Total
C4 Operación	0	600	600	600	1 800
C5 Mantenimiento	0	900	900	900	2 700
Costos de operación y mantenimiento	0	2 438	2 438	2 438	7 315
Inversión de CERMAT	1 166	0	0	0	1 166
Flujo neto, vista A	**−1 166**	**297**	**1 208**	**1 664**	**2 003**
Flujo neto acumulado, vista A	−1 166	−869	339	2 003	
Flujo descontado al 12 %, vista A	−1 166	265	963	1 184	1 247
Aporte valorizado del equipo (solo vista B)	20 180	0	0	0	20 180
Flujo neto, vista B	**−21 346**	**297**	**1 208**	**1 664**	**−18 177**

Flujos netos de los otros escenarios (vista A):

Escenario	Año 0	Año 1	Año 2	Año 3	Beneficios a 3 años	Costos a 3 años
Pesimista	−1 272	−3 233	−3 130	−3 027	1 236	11 899
Optimista	−1 166	5 042	6 360	6 799	24 166	7 131

Indicadores (hoja "Indicadores"; VAN = flujo del año 0 + `NPV(12 %; años 1 a 3)`, TIR = `IRR`, B/C = VA de beneficios ÷ VA de costos con la inversión, ROI = (beneficios − costos) ÷ costos sin descontar, recuperación por interpolación del flujo acumulado):

Indicador	Vista	Pesimista	Base	Optimista
VAN	A	S/ −8 809	**S/ 1 247**	S/ 13 245
TIR	A	No calculable (todos los flujos netos son negativos)	**53,5 %**	450,7 %
Relación B/C	A	0,10	**1,18**	3,23
ROI a 3 años	A	−89,6 %	**23,6 %**	238,9 %
Recuperación	A	No se recupera en 3 años	**1,7 años**	0,2 años
Recuperación descontada	A	No se recupera en 3 años	**1,9 años**	0,3 años

Indicador	Vista	Pesimista	Base	Optimista
Inversión inicial	A	S/ 1 272	S/ 1 166	S/ 1 166
VAN si CERMAT tuviera que contratar el cierre técnico	A	S/ −13 369	S/ −2 933	S/ 9 065
VAN	B	S/ −29 369	S/ −18 933	S/ −6 935
TIR	B	No calculable	−52,4 %	−7,2 %
Relación B/C	B	0,03	0,30	0,73
ROI a 3 años	B	−96,2 %	−63,4 %	−11,5 %
Recuperación	B	No se recupera en 3 años	No se recupera en 3 años	No se recupera en 3 años
Inversión inicial	B	S/ 21 832	S/ 21 346	S/ 21 346

Lectura de los indicadores:

- La **TIR de la vista A es muy alta** porque el desembolso inicial de CERMAT es pequeño (S/ 1 166). No mide la rentabilidad del desarrollo; para eso está la vista B. Para la decisión se priorizan el VAN y la relación B/C.
- La fila "VAN si CERMAT tuviera que contratar el cierre técnico" muestra la dependencia del aporte del equipo: sin él, el caso base pasa a S/ −2 933. Por eso la transferencia de conocimiento (C.5) es parte de la inversión.
- La **vista B** responde otra pregunta: ¿se paga el proyecto completo a precio de mercado? No en 3 años. Es la razón para escalar a otras sedes y al colegio (roadmap RM-08 a RM-13) en lugar de construir sistemas separados.

2.4.5 Análisis de sensibilidad

Puntos de equilibrio (hoja "Indicadores"; el VAN es lineal en el volumen y en la adopción):

Umbral para VAN = 0 (resto de supuestos en base)	Vista A	Vista B
Matrículas por ciclo	**40,0** (base: 60)	363,3
Adopción constante en los 3 años	**64,1 %** (base: 60 %, 80 % y 90 %)	248,5 % (inalcanzable)

Una variable a la vez (hoja "Sensibilidad"; VAN de la vista A con el resto en base, ordenado por rango):

Variable	Valor bajo → alto	VAN bajo	VAN alto	Rango
Captación en línea y retención (S25 y S26)	0 y 0 → 4 y 2 por ciclo	S/ −2 019	S/ 4 512	S/ 6 531
Adopción años 1 a 3 (S05 a S07)	30/40/50 % → 80/95/100 %	S/ −2 726	S/ 2 930	S/ 5 656

Variable	Valor bajo → alto	VAN bajo	VAN alto	Rango
Hosting de la SPA (S29)	US$ 40 (2 miembros Pro) → US$ 0 (alternativa sin costo)	S/ −713	S/ 3 206	S/ 3 920
Horas de operación y mantenimiento (S33 y S34)	3 + 5 h → 1,5 + 2 h al mes	S/ −915	S/ 2 327	S/ 3 242
Matrículas por ciclo (S03)	40 → 90	S/ −2	S/ 3 120	S/ 3 122
Ahorros en pagos, reportes, asistencia y padres (S15 a S21)	pesimista → optimista	S/ 173	S/ 2 102	S/ 1 929
Reducción de la morosidad (S28)	0 → 1 punto	S/ 594	S/ 1 900	S/ 1 306
Minutos ahorrados por matrícula (S12 y S13)	15 y 3 min → 30 y 5 min	S/ 457	S/ 1 600	S/ 1 143
Tipo de cambio (S02)	3,74 → 3,06 (±10 %)	S/ 1 021	S/ 1 472	S/ 451
Tasa de descuento (S01)	16 % → 8 %	S/ 1 054	S/ 1 466	S/ 412

Conclusiones de la sensibilidad:

1. Las dos variables que más pesan dependen de **gestión, no de tecnología**: la captación en línea y retención, y la adopción. La primera exigía publicar las reglas corregidas, lo que se hizo el 2026-10-24 (la pre-matrícula pública volvió a funcionar), y exige usar las alertas de inasistencia; la segunda, una disposición de la Dirección.
2. El **costo del hosting** es la palanca de ahorro más fuerte: un hosting comercial sin costo de licencia elevaría el VAN base en S/ 1 959 (de S/ 1 247 a S/ 3 206). Se evaluará en el E5 sin cambiar el supuesto de costo del plan Pro.
3. Tipo de cambio y tasa de descuento casi no cambian la decisión.

2.4.6 Recomendación y criterios del hito de continuidad

Se recomienda **aprobar la alternativa D** con estas condiciones:

1. La Dirección emite antes del 2026-12-18 una disposición de canal único: toda matrícula se registra en la plataforma, en línea o con el registro rápido de secretaría.
2. El equipo completa los Sprints 1 a 3 (publicación de reglas, hecha el 2026-10-24; operación continua de la capa relacional, respaldo, monitor y capacitación) según el E3.
3. CERMAT presupuesta S/ 2 438 al año de operación y mantenimiento (escenario base).
4. **Hito de continuidad del 2027-03-31.** Se recalcula el libro con datos reales. Se continúa si se cumplen todos estos criterios: adopción del ciclo de verano ≥ 60 %; minutos de personal por matrícula ≤ 12; 0

incidentes de sobrecupo o duplicado; matrículas por ciclo ≥ 40; VAN de la vista A recalculado ≥ 0. Si no se cumplen, se aplican primero las palancas de costo (hosting y horas de mantenimiento) y se revisa el alcance antes de seguir invirtiendo.

2.5 Riesgos iniciales

Escala 1 a 5 de probabilidad (P) e impacto (I); nivel por P × I: Bajo 1–4, Medio 5–9, Alto 10–14, Crítico 15–25. El impacto económico se calculó en la hoja "Sensibilidad" o con el mismo modelo.

ID	Riesgo estratégico	P	I	P×I	Impacto económico preliminar	Mitigación	Responsable
RB-01	Adopción como la del piloto: el personal sigue con cuaderno	4	4	16 Crítico	VAN base de S/ 1 247 a S/ −2 726 con la adopción pesimista	Disposición de canal único, registro rápido, capacitación y meta mensual	Dirección
RB-02	La matrícula pública vuelve a bloquearse (por ejemplo, por un despliegue que no llega a producción) o no se usan las alertas	3	4	12 Alto	Sin captación ni retención, el VAN base baja a S/ −2 019	Reglas corregidas publicadas y matrícula sin sesión verificada el 2026-10-24; publicar solo tras las 19 pruebas y verificar producción después de cada cambio	Equipo técnico
RB-03	El equipo no completa el cierre técnico y CERMAT lo contrata	2	4	8 Medio	VAN base de S/ 1 247 a S/ −2 933	Cierre dentro de los Sprints 1 a 3 y transferencia de conocimiento (C.5)	Líder del proyecto
RB-04	Mayor esfuerzo de operación y mantenimiento	3	3	9 Medio	Con 3 + 5 h al mes, el VAN base baja a S/ −915	CI con 90 pruebas, monitor con alertas y backlog priorizado	Responsable técnico

ID	Riesgo estratégico	P	I	P×I	Impacto económico preliminar	Mitigación	Responsable
RB-05	Volumen real menor al supuesto	3	4	12 Alto	Con 40 matrículas por ciclo, VAN ≈ S/ 0 (S/ −2)	Validar el volumen con secretaría antes del 2026-12-04	Product Owner
RB-06	Cambio de precio o de plan del hosting	2	3	6 Medio	Con 2 miembros Pro, VAN base S/ −713	Un solo miembro con permiso de despliegue; evaluar alternativa sin costo	Dirección
RB-07	Tipo de cambio desfavorable	2	2	4 Bajo	Con S/ 3,74 por dólar, VAN base S/ 1 021	Pago anual o en soles cuando sea posible	Dirección
RB-08	Incidente de datos personales derivado de la exposición que hubo hasta el 2026-10-24	3	5	15 Crítico	No monetizado: multas de hasta 100 UIT según la Ley N.° 29733 y daño reputacional	Reglas corregidas publicadas el 2026-10-24; política de privacidad y plan de respuesta a incidentes (SGSI)	Dirección y equipo técnico
RB-09	Dependencia de una sola persona	4	5	20 Crítico	Interrupción de la operación; no monetizado	Revisión por pares, documentación y responsable técnico de CERMAT capacitado	Dirección

Referencias

[1] Project Management Institute, *A Guide to the Project Management Body of Knowledge (PMBOK Guide)*, 7th ed. Newtown Square, PA, USA: PMI, 2021.

[2] Ministerio de Economía y Finanzas del Perú, "Anexo N.° 11: Parámetros de evaluación social," Directiva N.° 001-2019-EF/63.01, Directiva General del Sistema Nacional de Programación Multianual y Gestión de Inversiones, Lima, 2019.

[3] Vercel Inc., "Pricing." [En línea]. Disponible: https://vercel.com/pricing

[4] Google, "Firebase pricing." [En línea]. Disponible: https://firebase.google.com/pricing

[5] Congreso de la República del Perú, "Ley N.° 29733, Ley de Protección de Datos Personales," *Diario Oficial El Peruano*, 3 de julio de 2011.

Anexos

Anexo	Ubicación
Modelo financiero con fórmulas (8 hojas: Léame, Supuestos, Proceso, Presupuesto, Flujo de caja, Indicadores, Sensibilidad, Alternativas)	business-case.xlsx
Script reproducible que genera el libro y verifica sus 824 fórmulas contra un cálculo independiente	`perfil-egreso/scripts/generar-business-case.mjs` (`node perfil-egreso/scripts/generar-business-case.mjs` desde la raíz)
Tiempos del proceso usados en B1	E4 — Modelado de procesos
Presupuesto y línea base de costos	E3, sección 3.4

Rúbrica de evaluación

Criterio	Excelente	Bueno	Regular	Deficiente
Análisis de alternativas	Analiza alternativas con matriz comparativa rigurosa y justificación sólida.	Compara alternativas con criterios definidos.	Presenta alternativas sin comparación estructurada.	No evalúa alternativas.
Evaluación económica	Presenta análisis financiero estructurado con indicadores cuantificados.	Estima costos y beneficios razonablemente.	Presenta costos generales sin sustento.	No presenta estimación financiera.
Identificación de riesgos	Analiza riesgos estratégicos con impacto y estrategias de mitigación.	Identifica riesgos con evaluación básica.	Enumera riesgos sin análisis.	No identifica riesgos relevantes.
Sustentación y defensa técnica	Explica y defiende con dominio las decisiones tomadas.	Explica con solvencia.	Explica con dificultad.	No sustenta.

E3 — Plan de Gestión del Proyecto (CE0121–CE0125)

Evidencias CE012 — Gestión de Proyectos

CE0121 Acta de constitución · CE0122 Plan de gestión (alcance, tiempo, costo y recursos) · CE0123 EDT y cronograma · CE0124 Análisis económico (en el E2) · CE0125 Plan de gestión de riesgos. El presupuesto y la línea base están en la hoja "Presupuesto" de business-case.xlsx. El Project Charter de software, el Product Backlog y el Sprint 1 viven en el E4 de Software y aquí se enlazan, no se duplican.

Portada

Campo	Detalle
Título	Plan de gestión del proyecto — Plataforma Web Integral CERMAT: cierre técnico y adopción institucional
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo), UPeU campus Juliaca, sección g1
Fecha	2026-10-24
Competencia	CE012 — Gestión de Proyectos
Enfoque	Híbrido: marco predictivo del PMBOK [1] para el acta, la EDT, la línea base de costos y los hitos; ejecución con Scrum ligero [3] en sprints de 2 semanas

Resumen ejecutivo

El proyecto empezó el **2026-01-02** (primer commit de desarrollo, "Implement Admin & Public MVP") y termina, según este plan, el **2027-04-09**. Lo ejecutado está evidenciado: desarrollo intensivo en enero de 2026 (43 commits), operación piloto entre el 2026-01-27 y el 2026-07-07, auditorías y fases documentadas entre el 2026-06-07 y el 2026-07-07, y el Sprint 1 de calidad desde el 2026-10-24, con 12 de 13 tareas hechas. Lo pendiente es el cierre técnico (Sprints 1 a 3), la capacitación, el acompañamiento en la campaña de matrícula 2027 y un **hito de continuidad el 2027-03-31**.

Cifra del plan	Valor
Presupuesto total del proyecto (BAC, horas valorizadas)	S/ 21 346
Trabajo ya ejecutado (costo hundido valorizado)	S/ 16 000 (640 h)
Trabajo planificado (equipo + CERMAT)	S/ 4 860, más S/ 486 de contingencia

Cifra del plan	Valor
Desembolso de CERMAT en el año 0	S/ 1 166 (tiempo de su personal; el equipo EPE aporta S/ 4 180 de trabajo planificado)
Paquetes de trabajo	35 en 6 entregables más el aporte de CERMAT
Hitos	3 reales y 9 planificados
Riesgos del proyecto	12, de los que 2 se cerraron el 2026-10-24 (exposición total P×I de los abiertos = 89, antes 117; meta al cierre ≤ 40)

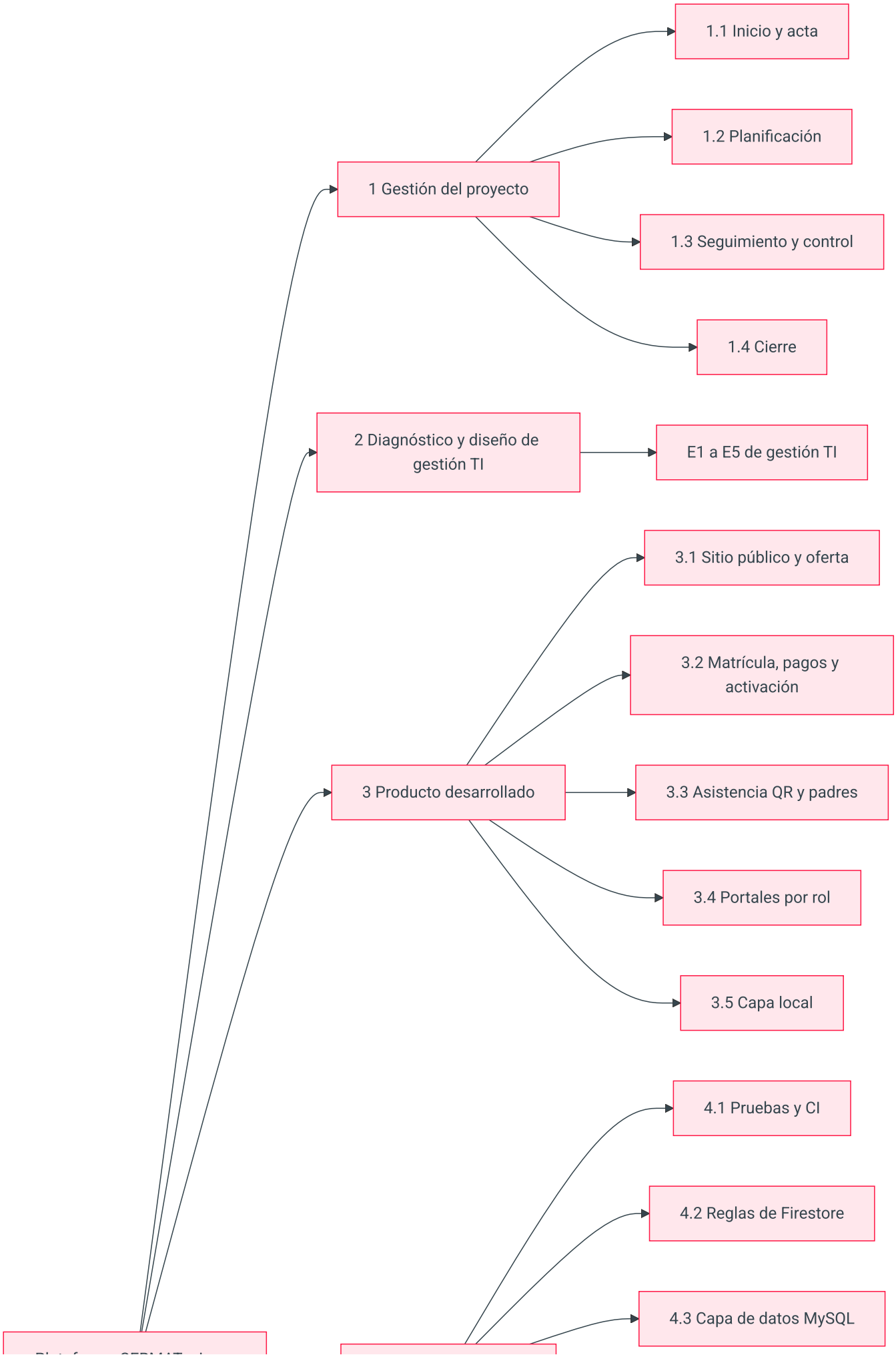
3.1 Acta de constitución

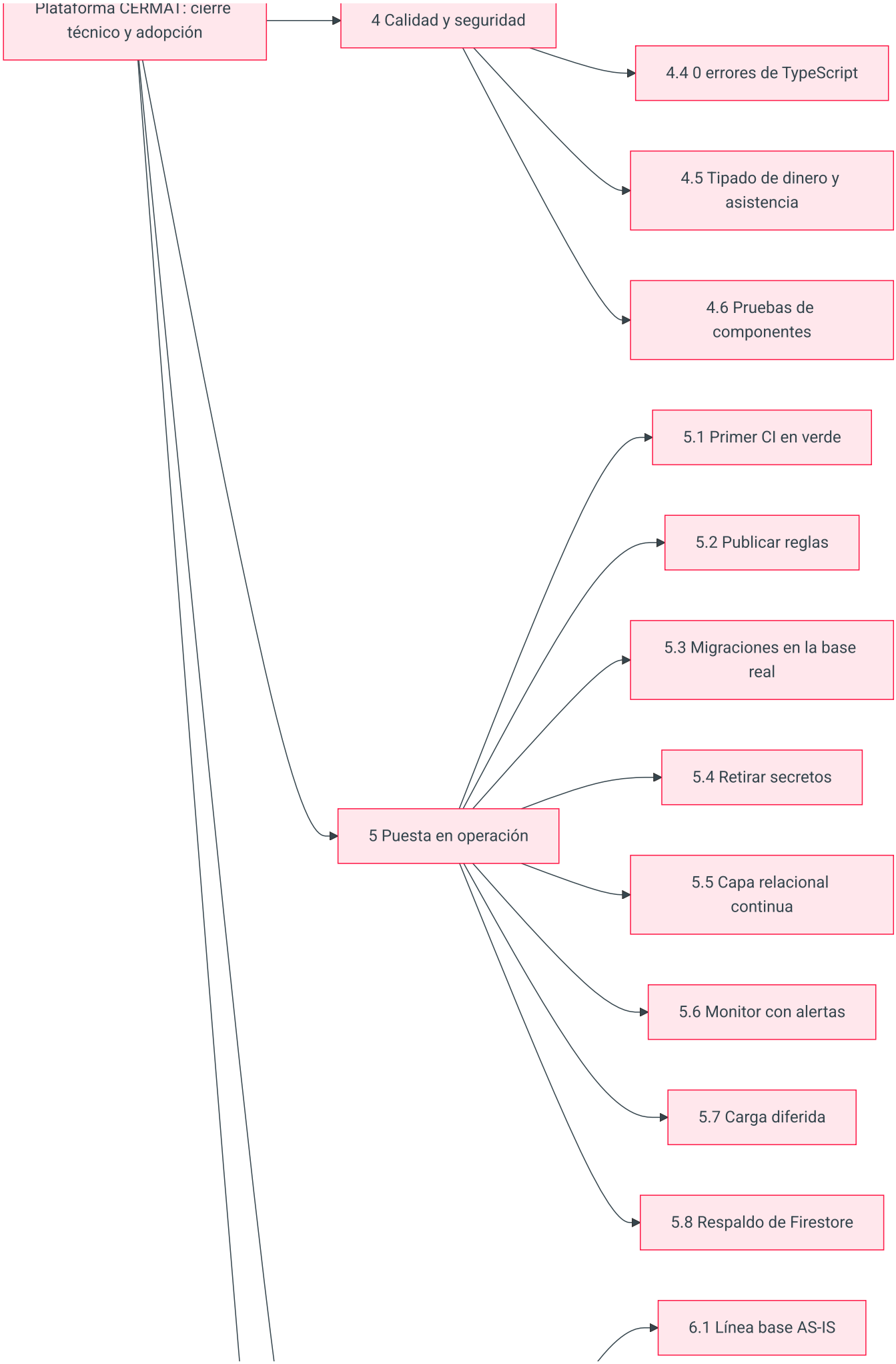
Campo	Detalle
Nombre	Plataforma Web Integral CERMAT — cierre técnico y adopción institucional
Sponsor	Dirección general de CERMAT, en representación de la Academia La Prepa Cermat
Director del proyecto y Scrum Master	David Robert Yucra Mamani
Product Owner	Responsable designado por la Dirección (a confirmar en la revisión del Sprint 1; mientras tanto, el sponsor actúa como Product Owner interino)
Equipo	Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores y Cárdenas Vilca Rennzo (desarrollo, pruebas y documentación)
Justificación estratégica	Responde a los objetivos estratégicos OE1 a OE5 y cierra las brechas BR-01 a BR-10 del E1. El business case muestra un VAN de S/ 1 247 para CERMAT en el escenario base (E2).
Objetivos SMART	OBJ-1 ≥ 60 % de las matrículas de 2027 en la plataforma · OBJ-2 ≤ 12 min de personal por matrícula al 31-03-2027 · OBJ-3 p90 ≤ 24 h de respuesta a la pre-matrícula en la campaña 2027 · OBJ-4 19 de 19 pruebas de reglas contra lo publicado y 0 incidentes de cupo desde el 06-11-2026 · OBJ-5 VAN de la vista A ≥ 0 recalculado el 31-03-2027 (detalle en el E2)
Alcance preliminar: incluye	Cierre técnico (publicación de reglas, migraciones en la base real, retiro de secretos, operación continua de la capa relacional, monitor con alertas, respaldo de Firestore, carga diferida, tipado y pruebas de componentes); adopción (línea base AS-IS, privacidad y consentimiento, oferta 2027, manuales, capacitación y acompañamiento); gestión (seguimiento, hito de continuidad y cierre)
Alcance preliminar: excluye	Aplicación móvil nativa, pasarela de pagos, facturación electrónica, integración con el sistema del colegio (fase posterior, RM-08 a RM-11), hardware del host on-premise de CE03, endurecimiento del servidor y DNS del colegio (tarea operativa RM-04)

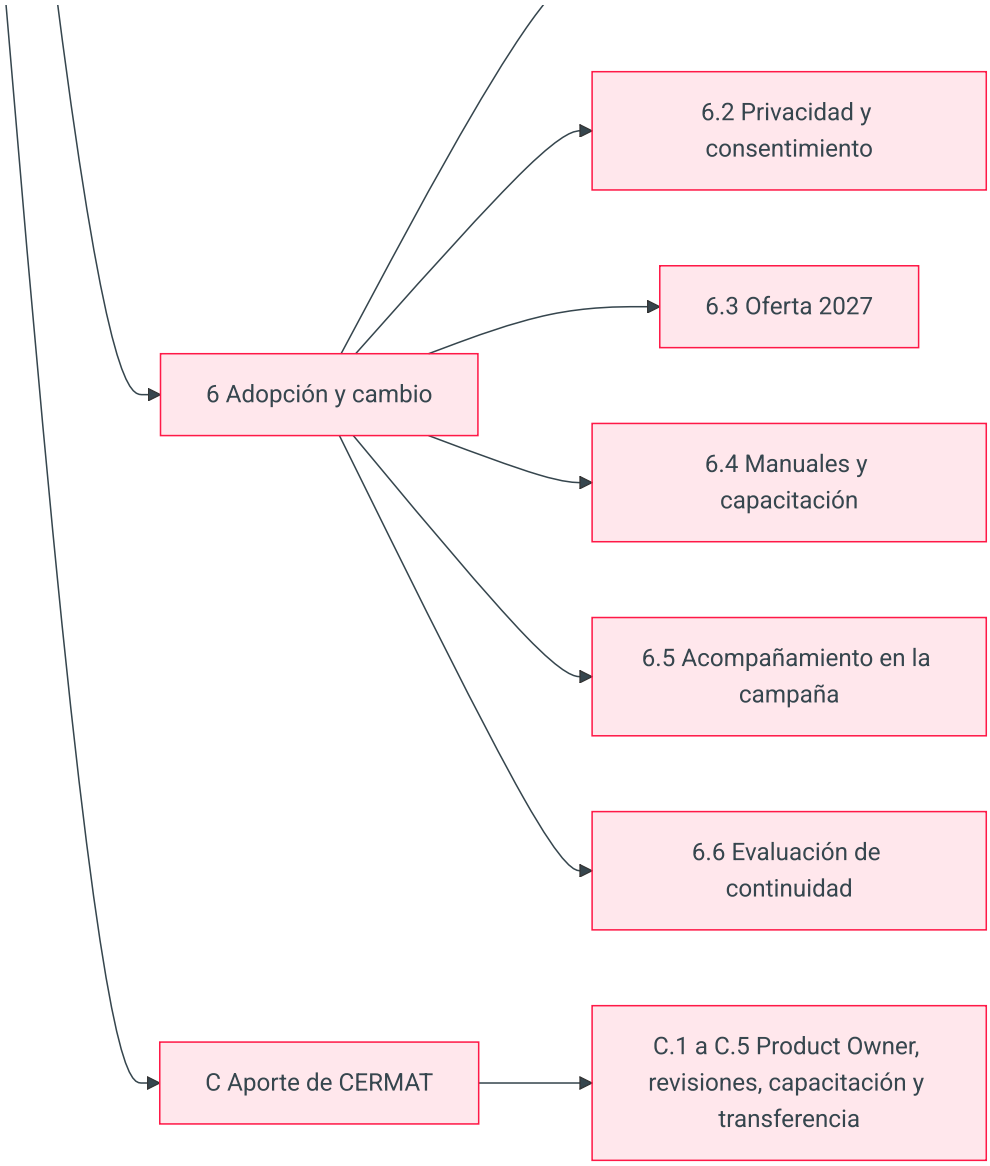
Campo	Detalle
Entregables principales	1 Gestión del proyecto · 2 Diagnóstico y diseño de gestión TI · 3 Producto desarrollado · 4 Calidad y seguridad · 5 Puesta en operación · 6 Adopción y cambio (sección 3.2)
Hitos principales	H2 reglas corregidas publicadas (2026-11-06) · H5 acta de aceptación (2026-12-04) · H6 personal capacitado (2026-12-18) · H7 campaña 2027 en la plataforma (2027-01-04) · H8 hito de continuidad (2027-03-31) · H9 cierre (2027-04-09)
Stakeholders	Dirección, Product Owner, secretaría y caja, docentes, auxiliares, padres, alumnos y postulantes, equipo técnico, ANPD y proveedores (mapa de poder e interés en el E1)
Supuestos	La Dirección designa al Product Owner y emite una disposición de canal único · cada integrante dispone de ≈ 8 h por semana hasta diciembre · la campaña de matrícula del ciclo de verano empieza en enero de 2027 · Firebase sigue sin costo con el volumen previsto · la publicación de reglas se aprueba en el Sprint 1 · supuestos económicos S01 a S48 del E2
Restricciones	Fin del semestre académico en diciembre de 2026 · CERMAT no tiene presupuesto de TI aprobado: su aporte es tiempo del personal y la operación desde 2027 · 4 estudiantes a tiempo parcial y un solo autor que conoce el código · el VPS del colegio (2 GB) queda reservado a componentes ligeros según CE03 · los scripts SQL no se ejecutan desde PowerShell por los falsos positivos del antivirus · cumplimiento de la Ley N.° 29733
Riesgos de alto nivel	Publicación de reglas postergada (R-01), baja disponibilidad del equipo (R-02), Product Owner sin designar (R-03) y resistencia del personal (R-06) (sección 3.5)
Presupuesto resumido	BAC S/ 21 346 valorizado; desembolso de CERMAT en el año 0: S/ 1 166 en tiempo de su personal; operación desde 2027: S/ 2 438 al año (escenario base)
Criterios de éxito	19 de 19 pruebas de reglas contra lo publicado · 6 de 6 trabajos del CI en verde · 30 días con 0 diferencias en `v_conciliacion_pagos` · RPO ≤ 24 h de Firestore probado con una restauración · 100 % del personal capacitado · acta de aceptación de los flujos críticos firmada por la Dirección · criterios del hito de continuidad cumplidos (E2, 2.4.6)
Relación con otros documentos	El Project Charter de software del E4 de Software, 3.1 es el derivado de esta acta para el producto: comparte sponsor, equipo y objetivos
Aprobación	**Pendiente de ejecución.** Procedimiento: presentar el acta en la revisión del Sprint 1 (2026-11-06) y recoger la firma del sponsor y del director del proyecto. Criterio de aceptación: acta firmada sin observaciones abiertas. Evidencia a adjuntar: acta firmada en PDF.

3.2 Gestión del alcance

EDT / WBS


1.1 Inicio y acta
1.2 Planificación
1 Gestión del proyecto
1.3 Seguimiento y control
1.4 Cierre
2 Diagnóstico y diseño de gestión TI
E1 a E5 de gestión TI
3.1 Sitio público y oferta
3.2 Matrícula, pagos y activación
3 Producto desarrollado
3.3 Asistencia QR y padres
3.4 Portales por rol
3.5 Capa local
4.1 Pruebas y CI
4.2 Reglas de Firestore
4.3 Capa de datos MySQL


Plataforma CERMAT: cierre técnico y adopción
4 Calidad y seguridad
4.4 0 errores de TypeScript
4.5 Tipado de dinero y asistencia
4.6 Pruebas de componentes
5 Puesta en operación
5.1 Primer CI en verde
5.2 Publicar reglas
5.3 Migraciones en la base real
5.4 Retirar secretos
5.5 Capa relacional continua
5.6 Monitor con alertas
5.7 Carga diferida
5.8 Respaldo de Firestore
6.1 Línea base AS-IS



Diccionario de la EDT

Horas: reales estimadas por analogía (no hubo registro de horas) y planificadas por paquete. Costo a S/ 25 por hora técnica salvo indicación. Detalle y fórmulas en la hoja "Presupuesto".

Código	Paquete de trabajo	Entregable y criterio de aceptación	Responsable	Horas	Costo	Estado
1.1	Inicio y acta de constitución	Acta de la sección 3.1, firmada por el sponsor	Director del proyecto	4	S/ 100	Real (firma pendiente)
1.2	Planificación	Este plan, el presupuesto y el backlog extendido	Director del proyecto	12	S/ 300	Real
1.3	Seguimiento y control	Informe de cada sprint con valor ganado y riesgos	Scrum Master	20	S/ 500	Planificado

Código	Paquete de trabajo	Entregable y criterio de aceptación	Responsable	Horas	Costo	Estado
1.4	Cierre	Acta de cierre y lecciones aprendidas	Director del proyecto	4	S/ 100	Planificado
2	Diagnóstico y diseño de gestión TI	E1 a E5 de gestión TI con sus artefactos	Equipo	56	S/ 1 400	Real
3.1	Sitio público y oferta académica	Páginas públicas en producción	Equipo	80	S/ 2 000	Real
3.2	Matrícula, pagos y activación	Matrícula transaccional, pagos con cuotas y activación por invitación	Equipo	140	S/ 3 500	Real
3.3	Asistencia QR y consulta de padres	QR firmado, registro diario y consulta por código	Equipo	90	S/ 2 250	Real
3.4	Portales por rol	Admin, docente, alumno y auxiliar con rutas protegidas	Equipo	110	S/ 2 750	Real
3.5	Capa local	API, MySQL y analítica con PM2	Equipo	60	S/ 1 500	Real
4.1	Pruebas automáticas y CI (PB-01)	90 pruebas y 6 trabajos de CI	Equipo	40	S/ 1 000	Real
4.2	Corrección de reglas (PB-02)	19 de 19 pruebas en el emulador	Equipo	12	S/ 300	Real
4.3	Capa de datos MySQL (PB-03)	Integridad, roles, respaldo y restauración probada	Equipo	24	S/ 600	Real

Código	Paquete de trabajo	Entregable y criterio de aceptación	Responsable	Horas	Costo	Estado
4.4	0 errores de TypeScript (PB-07)	`npm run typecheck` sin errores y 7 defectos corregidos	Equipo	12	S/ 300	Real
4.5	Tipado de dinero y asistencia (PB-09)	Usos de `any` < 120	Equipo	8	S/ 200	Planificado
4.6	Pruebas de componentes (PB-12)	≥ 20 casos de matrícula y pagos	Equipo	12	S/ 300	Planificado
5.1	Primer CI en verde	6 de 6 trabajos en verde en GitHub	Líder	2	S/ 50	Planificado
5.2	Publicar reglas (PB-04)	19 de 19 pruebas contra lo publicado y una matrícula sin sesión verificada	Líder	4	S/ 100	Planificado; ejecutado el 2026-10-24
5.3	Migraciones en la base real (PB-05)	Migraciones aplicadas y 19 pruebas de BD en verde	Equipo	4	S/ 100	Planificado; ejecutado el 2026-10-24 (migraciones 02–04 en `cermat_db`, cuentas de mínimo privilegio y restauración REC-05 verificadas)
5.4	Retirar secretos (PB-06)	0 archivos sensibles en el historial; clave rotada	Líder	6	S/ 150	Planificado; clave rotada el 2026-10-24 (los `.env`, sin contraseñas, siguen versionados por decisión del equipo)

Código	Paquete de trabajo	Entregable y criterio de aceptación	Responsable	Horas	Costo	Estado
5.5	Capa relacional continua (PB-13)	Servicio continuo en VM-APP01 o VPS puente; 30 días sin diferencias de conciliación	Equipo	16	S/ 400	Planificado
5.6	Monitor con alertas (PB-08)	Alertas sobre la URL y `/health`	Equipo	4	S/ 100	Planificado
5.7	Carga diferida (PB-10)	JS inicial < 1 MB	Equipo	8	S/ 200	Planificado
5.8	Respaldo de Firestore (PB-11)	Exportación programada y restauración probada (RPO ≤ 24 h)	Equipo	12	S/ 300	Planificado
6.1	Línea base AS-IS (PB-14)	10 trámites cronometrados con hoja de registro (E4)	Equipo y Product Owner	8	S/ 200	Planificado
6.2	Privacidad y consentimiento (PB-16)	Política publicada y aviso de consentimiento en la matrícula	Equipo y Dirección	6	S/ 150	Planificado
6.3	Oferta 2027 (PB-17)	Ciclos, grupos y sedes 2027 cargados y revisados por el Product Owner	Equipo	4	S/ 100	Planificado
6.4	Manuales y capacitación (PB-15)	Manual de una página por rol y sesiones con registro de asistencia	Equipo	18	S/ 450	Planificado
6.5	Acompañamiento en la campaña 2027	Soporte en sede durante las primeras semanas	Equipo	12	S/ 300	Planificado
6.6	Evaluación de continuidad	Libro recalculado con datos reales e informe a la Dirección	Director del proyecto	4	S/ 100	Planificado

Código	Paquete de trabajo	Entregable y criterio de aceptación	Responsable	Horas	Costo	Estado
C.1	Product Owner	Backlog priorizado y aceptación de historias (S/ 30 por h)	Dirección	12	S/ 360	Planificado
C.2	Revisiones de sprint	Asistencia a 3 revisiones (S/ 30 por h)	Dirección	3	S/ 90	Planificado
C.3	Capacitación administrativa y auxiliar	3 personas × 3 h (S/ 10 por h)	Secretaría y auxiliar	9	S/ 90	Planificado
C.4	Capacitación docente	3 docentes × 2 h (S/ 20 por h)	Docentes	6	S/ 120	Planificado
C.5	Transferencia de conocimiento	El responsable técnico de CERMAT despliega y restaura solo	Responsable técnico	16	S/ 400	Planificado

Control de cambios

1. **Solicitud:** issue en el repositorio con descripción, motivo, horas estimadas y riesgo.
2. **Análisis de impacto (máximo 2 días):** alcance, cronograma, costo, riesgo y pruebas afectadas.
3. **Decisión:** el Product Owner aprueba cambios de hasta 8 h que no muevan un hito; el sponsor aprueba los mayores, los que mueven un hito o los que consumen la reserva de contingencia.
4. **Registro:** el cambio entra al backlog con su identificador y se anota en el registro de cambios.
5. **Implementación:** pull request con la lista de revisión obligatoria, revisión de un segundo integrante y CI en verde.
6. **Verificación:** el Product Owner lo acepta en la revisión del sprint.

ID	Fecha	Cambio	Motivo	Decisión
CR-01	2026-10-24	La capa relacional se aloja en VM-APP01 o en un VPS puente, no en el VPS del colegio (PB-13)	El diseño de CE03 reserva el VPS de 2 GB para componentes ligeros	Incorporado en este plan
CR-02	2026-10-24	La integración con el sistema del colegio pasa a una fase posterior	Integrar antes de lograr adopción multiplica el riesgo sin valor (E1, 1.5)	Incorporado en este plan

3.3 Gestión del cronograma

Lista de actividades

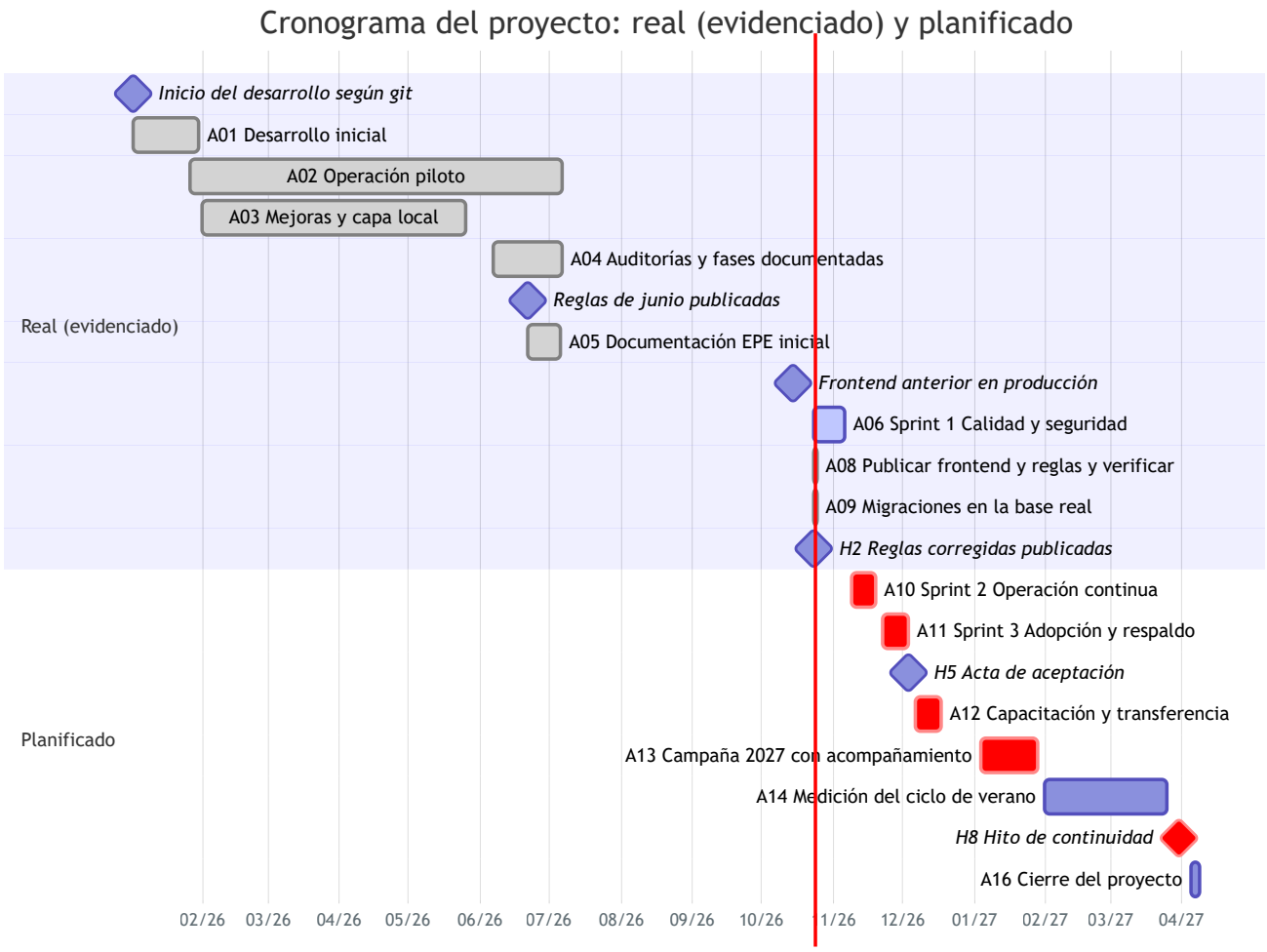
ID	Actividad (EDT)	Predecesoras	Inicio	Fin	Tipo	Responsable
A01	Desarrollo inicial: MVP público y administrativo, portales y talleres (3.1 a 3.4)	—	2026-01-02	2026-01-30	Real: 43 commits en enero	Líder
A02	Operación piloto con registros reales (3.2, 3.3)	A01	2026-01-27	2026-07-07	Real: fechas de Firestore	Dirección y líder
A03	Mejoras incrementales y capa local (3.5)	A01	2026-02-01	2026-05-26	Real: commits de feb, abr y may	Líder
A04	Auditorías y fases documentadas (3)	A03	2026-06-07	2026-07-07	Real: fechas en `docs/AUDITORIA_*` y `docs/FASE_*`	Líder
A05	Documentación EPE inicial (2)	A04	2026-06-22	2026-07-06	Real	Equipo
A06	Sprint 1 Calidad y seguridad (4.1 a 4.4, 5.1 a 5.4)	A04	2026-10-24	2026-11-06	En curso: 12 de 13 tareas	Equipo
A07	Actualización de diagnóstico, business case y plan (1.1, 1.2, 2)	A05	2026-10-24	2026-10-24	Real	Equipo
A08	Publicar reglas y verificar la matrícula sin sesión (5.1, 5.2)	A06 (pruebas en verde)	2026-10-26	2026-11-06	Real: ejecutada el 2026-10-24, antes de lo planificado	Líder y sponsor
A09	Migraciones en la base real y retiro de secretos (5.3, 5.4)	A08	2026-11-02	2026-11-06	Real: ejecutada el 2026-10-24, antes de lo planificado (los `.env`, sin contraseñas, siguen versionados por decisión del equipo)	Equipo

ID	Actividad (EDT)	Predecesoras	Inicio	Fin	Tipo	Responsable
A10	Sprint 2 Operación continua (5.5, 5.6, 5.7, 4.5, 6.1)	A08	2026-11-09	2026-11-20	Planificado (crítica)	Equipo
A11	Sprint 3 Adopción y respaldo (5.8, 4.6, 4.5, 6.2, 6.3, 6.4)	A10	2026-11-23	2026-12-04	Planificado (crítica)	Equipo
A12	Capacitación por rol y transferencia de conocimiento (6.4, C.3 a C.5)	A11	2026-12-07	2026-12-18	Planificado (crítica)	Equipo y CERMAT
A13	Acompañamiento en la campaña de matrícula 2027 (6.5)	A12	2027-01-04	2027-01-29	Planificado (crítica)	Equipo
A14	Medición de indicadores del ciclo de verano (6.6)	A13	2027-02-01	2027-03-26	Planificado	Product Owner
A15	Evaluación de continuidad (6.6)	A14	2027-03-29	2027-03-31	Planificado (crítica)	Director del proyecto y sponsor
A16	Cierre del proyecto (1.4)	A15	2027-04-05	2027-04-09	Planificado	Director del proyecto
A17	Seguimiento y control (1.3)	—	2026-10-24	2027-03-31	Planificado (continuo)	Scrum Master

Las fechas de A13 a A16 dependen del calendario de la academia (supuesto: campaña del ciclo de verano en enero de 2027) y se confirman con la Dirección en el Sprint 1.

Diagrama de Gantt

En la sección "Real" solo hay fechas evidenciadas por git, Firestore, los documentos fechados y el panel de Vercel. Lo planificado empieza el 2026-10-24; la ruta crítica se muestra en rojo.



Hitos principales

ID	Hito	Fecha	Tipo	Criterio o evidencia
H0	Inicio del desarrollo	2026-01-02	Real	Commit "Implement Admin & Public MVP"
H0b	Publicación de las reglas vigentes (con 3 fallas)	2026-06-22	Real	Ruleset de producción identificado en el E4 de Software
H0c	Última publicación del frontend	2026-10-15	Real	Historial de despliegues de Vercel
H1	Acta de constitución firmada	2026-11-06	Planificado	Firma del sponsor
H2	Reglas corregidas publicadas y matrícula sin sesión verificada	2026-11-06 (cumplido el 2026-10-24)	Real	Consulta sin sesión denegada (403) y pre-matrícula de prueba exitosa (E4 de Software, 2.7)
H3	Capa relacional en servicio continuo con monitor	2026-11-20	Planificado	Alertas activas y 0 diferencias de conciliación

ID	Hito	Fecha	Tipo	Criterio o evidencia
H4	Línea base AS-IS medida	2026-11-20	Planificado	10 trámites cronometrados
H5	Acta de aceptación de los flujos críticos	2026-12-04	Planificado	Firma de la Dirección
H6	Personal capacitado y disposición de canal único	2026-12-18	Planificado, crítico	100 % de asistencia y disposición emitida
H7	Inicio de la campaña 2027 en la plataforma	2027-01-04	Planificado, crítico	Primera matrícula del ciclo de verano registrada
H8	Hito de continuidad	2027-03-31	Planificado, crítico	Criterios del E2, 2.4.6
H9	Cierre del proyecto	2027-04-09	Planificado	Acta de cierre y lecciones aprendidas

Ruta crítica: A06 → A08 → A10 → A11 → A12 → A13 → A14 → A15 → A16. A09 también se ejecutó el 2026-10-24, y la tarea operativa RM-04 tiene holgura dentro de su sprint. A08 (publicar las reglas) era el punto más sensible, porque sin matrícula pública no hay campaña en línea que acompañar, y se cumplió el 2026-10-24, antes de lo planificado.

3.4 Gestión de costos

Presupuesto detallado

Entregable de la EDT	Horas reales	Horas planificadas	Costo real (hundido)	Costo planificado	Financia
1 Gestión del proyecto	16	24	S/ 400	S/ 600	Equipo EPE
2 Diagnóstico y diseño de gestión TI	56	0	S/ 1 400	S/ 0	Equipo EPE
3 Producto desarrollado	480	0	S/ 12 000	S/ 0	Equipo EPE
4 Calidad y seguridad	88	20	S/ 2 200	S/ 500	Equipo EPE
5 Puesta en operación	0	56	S/ 0	S/ 1 400	Equipo EPE
6 Adopción y cambio	0	52	S/ 0	S/ 1 300	Equipo EPE
C Aporte de CERMAT	0	46	S/ 0	S/ 1 060	CERMAT

Entregable de la EDT	Horas reales	Horas planificadas	Costo real (hundido)	Costo planificado	Financia
Subtotal	**640**	**198**	**S/ 16 000**	**S/ 4 860**	
Reserva de contingencia (10 % del trabajo planificado)				S/ 486	Equipo EPE S/ 380 y CERMAT S/ 106
Presupuesto total del proyecto (BAC)				**S/ 21 346**	

Estimaciones justificadas: las horas reales se estimaron por analogía con el tamaño del producto (41 748 líneas en `src/`, 13 módulos de dominio y 104 documentos de auditoría), porque no hubo registro de horas; las planificadas, por juicio experto del equipo para cada paquete con su criterio de aceptación. Las tarifas son los supuestos S08 a S11 del E2. La reserva de contingencia (S40) cubre riesgos identificados; no se define reserva de gestión porque CERMAT no tiene presupuesto de TI aprobado.

Coherencia con el E2: el BAC (S/ 21 346) es la inversión del año 0 de la vista B, y la parte de CERMAT con su contingencia (S/ 1 166) es la inversión de la vista A.

Línea base de costos

Trabajo planificado por mes (equipo y CERMAT), en soles:

Mes	oct-26	nov-26	dic-26	ene-27	feb-27	mar-27	abr-27
Valor planificado del mes	155	2 200	1 655	575	25	150	100
Línea base acumulada	155	2 355	4 010	4 585	4 610	4 760	4 860
Acumulada con contingencia	171	2 591	4 411	5 044	5 071	5 236	5 346

Noviembre concentra el 45 % del valor planificado (Sprints 1 a 3). Sumando el costo hundido de S/ 16 000, la línea base termina en el BAC de S/ 21 346.

Control presupuestal

Elemento	Definición
Registro de esfuerzo	Desde el Sprint 2, cada integrante registra sus horas por paquete en una hoja compartida (cierra la brecha de estimación del E4 de Software)

Elemento	Definición
Medición	Al cierre de cada sprint: PV = línea base acumulada; EV = % completado × costo planificado del paquete; AC = horas registradas × tarifa
Índices	CPI = EV ÷ AC; SPI = EV ÷ PV; estimación al cierre (EAC) = S/ 16 000 + costo planificado ÷ CPI
Umbrales	CPI o SPI entre 0,90 y 0,95: alerta en la revisión del sprint. Menor que 0,90: plan de acción y, si hace falta, uso de la contingencia con aprobación del sponsor
Registro de la contingencia	Cada uso se anota con fecha, riesgo que lo motiva, monto y aprobador
Primer informe	**Pendiente de ejecución:** al cierre del Sprint 2 (2026-11-20). Criterio de aceptación: PV, EV, AC, CPI y SPI calculados. Evidencia a adjuntar: hoja de horas y cálculo

3.5 Gestión de riesgos

Identificación y análisis cualitativo

Escala de 1 a 5; nivel por P × I: Bajo 1–4, Medio 5–9, Alto 10–14, Crítico 15–25. Los riesgos estratégicos de la organización están en el E1, 1.6.

ID	Riesgo (causa → evento → efecto)	P	I	P×I	Prioridad	Estrategia	Respuesta	Responsable	Disparador	Estado
R-01	Decisión postergada → las reglas corregidas no se publican → matrícula pública bloqueada y datos expuestos	4	5	20	Crítico	Evitar	Publicar en el Sprint 1 vía CI (entorno `production`, aprobación del sponsor) y verificar una matrícula sin sesión	Líder y sponsor	Sin aprobación al 2026-11-04	Cerrado (2026-10-24): reglas publicadas desde la consola y verificadas en producción

ID	Riesgo (causa → evento → efecto)	P	I	P×I	Prioridad	Estrategia	Respuesta	Responsable	Disparador	Estado
R-02	Fin de semestre → poca disponibilidad del equipo → tareas de los Sprints 2 y 3 incompletas	4	3	12	Alto	Mitigar	Capacidad fija de ≈ 40 h por sprint, orden por prioridad; PB-09 y PB-10 pasan a mantenimiento si hace falta	Scrum Master	Más de 25 % pendiente a mitad de sprint	Abierto
R-03	Product Owner sin designar o sin tiempo → aceptación y priorización demoradas	3	4	12	Alto	Mitigar	Solicitar la designación en la revisión del Sprint 1; el sponsor actúa como interino	Sponsor	Sin Product Owner al 2026-11-06	Abierto
R-04	Sin alojamiento continuo para la capa relacional (host sin presupuesto, VPS reservado) → la sincronización sigue intermitente	3	3	9	Medio	Mitigar	VPS puente del mismo plan (US$ 35,99 al año) hasta que exista VM-APP01	Líder	Sin decisión al 2026-11-13	Abierto

ID	Riesgo (causa → evento → efecto)	P	I	P×I	Prioridad	Estrategia	Respuesta	Responsable	Disparador	Estado
R-05	La rotación de la clave de servicio rompe la sincronización o el CI	2	4	8	Medio	Mitigar	Rotación en ventana acordada, prueba en CI y procedimiento de reversión	Líder	`/health` falla tras la rotación	Cerrado (2026-10-24): clave rotada y la nueva comprobada como válida; la API local la toma al reiniciarse
R-06	Resistencia del personal o capacitación insuficiente → baja adopción en la campaña	3	4	12	Alto	Mitigar	Manual de una página por rol, práctica guiada, registro rápido y acompañamiento en enero	Product Owner	Menos de 50 % de matrículas en la plataforma en la segunda semana de enero	Abierto
R-07	Pedidos nuevos durante los sprints → crecimiento del alcance	3	3	9	Medio	Mitigar	Control de cambios (3.2); los pedidos van al backlog	Product Owner	Más de 8 h de cambios no planificados en un sprint	Abierto
R-08	Falsos positivos del antivirus → scripts SQL en cuarentena → retraso de migraciones	3	2	6	Medio	Mitigar	Ejecutar desde Git Bash y excepción para `server/src/db`	Equipo	Archivo en cuarentena	Abierto

ID	Riesgo (causa → evento → efecto)	P	I	P×I	Prioridad	Estrategia	Respuesta	Responsable	Disparador	Estado
R-09	Registros manuales incompletos → no se puede medir la línea base → beneficios no verificables	3	3	9	Medio	Mitigar	Cronometraje prospectivo de 10 trámites con hoja de registro	Product Owner	Menos de 10 trámites medidos al 2026-12-04	Abierto
R-10	La campaña 2027 empieza antes de lo supuesto → capacitación desfasada	2	3	6	Medio	Mitigar	Confirmar el calendario con la Dirección en el Sprint 1	Director del proyecto	Campaña antes del 2026-12-18	Abierto
R-11	Cambio de condiciones de Vercel o Firebase durante el proyecto	2	2	4	Bajo	Aceptar	Monitorear avisos de los proveedores; usar contingencia	Líder	Aviso del proveedor	Abierto
R-12	Cuenta de administrador comprometida durante la transición → exposición de datos	2	5	10	Alto	Mitigar	MFA en cuentas admin, revisión de claims y procedimiento de incidentes del SGSI	Líder	Inicio de sesión anómalo	Abierto

Mapa de calor de los riesgos del proyecto:

Probabilidad \ Impacto	1	2	3	4	5
5					
4			R-02		R-01
3		R-08	R-04, R-07, R-09	R-03, R-06	
2		R-11	R-10	R-05	R-12
1					

Plan de respuesta y seguimiento

Prioridad	Tratamiento	Frecuencia de revisión
Crítico	Respuesta inmediata con responsable y fecha dentro del sprint en curso	Seguimiento diario asíncrono
Alto	Plan de respuesta en el sprint en curso	Revisión de cada sprint
Medio	Respuesta planificada y vigilancia del disparador	Quincenal
Bajo	Aceptación y monitoreo	Mensual

Métrica de seguimiento: exposición total (suma de P × I de los riesgos abiertos) = **89** al 2026-10-24 (era 117 antes de cerrar ese día R-01 y R-05); meta al cierre ≤ 40. Se recalcula en cada revisión de sprint y se informa junto con el valor ganado.

3.6 Gestión ágil

Marco de trabajo

Scrum ligero con sprints de 2 semanas, Product Owner designado por la Dirección y Scrum Master del equipo. La comparación con RUP y Cascada y la justificación de la adaptación están en el E4 de Software, 3.6.

Product backlog

El backlog del producto (PB-01 a PB-12, con prioridad y estado) está en el E4 de Software, 3.3. Este plan lo extiende con los ítems de gestión TI:

ID	Ítem	Prioridad	Criterio de aceptación	EDT
PB-13	Operación continua de la capa relacional (VM-APP01 o VPS puente)	Alta	30 días sin diferencias en `v_conciliacion_pagos` y `/health` bajo monitoreo	5.5
PB-14	Medición de la línea base AS-IS	Alta	10 trámites cronometrados con hoja de registro firmada por quien midió	6.1
PB-15	Manuales por rol y capacitación	Alta	Manual de una página por rol; 100 % de asistencia; ejercicio práctico aprobado	6.4
PB-16	Política de privacidad y consentimiento	Alta	Política publicada en el sitio y aviso de consentimiento en la matrícula	6.2
PB-17	Configuración de la oferta 2027	Media	Ciclos, grupos y sedes 2027 cargados y revisados por el Product Owner	6.3

Sprint planning

Sprint	Fechas	Objetivo	Ítems	Capacidad	Incremento esperado
Sprint 1	2026-10-24 a 2026-11-06	Que ningún defecto crítico llegue a producción sin ser detectado	PB-01 a PB-07 (hechos)	12 de 13 tareas hechas (E4 de Software, 3.4)	Reglas corregidas publicadas y CI en verde
Sprint 2	2026-11-09 a 2026-11-20	Operación continua y observable	PB-13, PB-08, PB-10, PB-09 (parte) y PB-14	40 h	Capa relacional continua, monitor con alertas, carga diferida y línea base medida
Sprint 3	2026-11-23 a 2026-12-04	Lista para la campaña 2027	PB-11, PB-12, PB-09 (resto), PB-16, PB-17 y PB-15 (manuales)	≈ 42 h	Respaldo de Firestore, pruebas de componentes, privacidad, oferta 2027 y manuales
Transición	2026-12-07 a 2026-12-18	Personal capacitado	PB-15 (sesiones) y C.3 a C.5	14 h del equipo y 23 h de CERMAT (la transferencia continúa 8 h en enero)	Personal capacitado y responsable técnico autónomo

Definición de terminado: la del E4 de Software, 4.2 (prueba, CI en verde y reversión documentada), más dos condiciones de gestión: el cambio queda en el manual de operación y actualiza su indicador del E5.

Incrementos y métricas de seguimiento

Métrica	Fórmula	Valor al 2026-10-24	Meta
Avance del sprint	Tareas hechas ÷ tareas del sprint	12 de 13 (92 %) en el Sprint 1	100 % al cierre de cada sprint
Velocidad	Horas de ítems terminados por sprint	Sin registro (empieza en el Sprint 2)	Estable ±15 %
Desvío de estimación	Horas reales ÷ horas estimadas por ítem	Sin registro	Entre 0,85 y 1,15
Defectos escapados a producción	Defectos encontrados en producción por sprint	3 críticos heredados de junio	0
Pruebas automáticas	Total en CI	90	En aumento cada sprint
Exposición de riesgo	Suma de P × I abiertos	89 (117 antes de cerrar R-01 y R-05 el 2026-10-24)	≤ 40 al cierre

Las ceremonias (planificación, seguimiento diario asíncrono, revisión con la Dirección y retrospectiva) y la retrospectiva del Sprint 1 están en el E4 de Software, 3.5.

Referencias

[1] Project Management Institute, *A Guide to the Project Management Body of Knowledge (PMBOK Guide)*, 7th ed. Newtown Square, PA, USA: PMI, 2021.

[2] Project Management Institute, *Process Groups: A Practice Guide*. Newtown Square, PA, USA: PMI, 2022.

[3] K. Schwaber y J. Sutherland, *The Scrum Guide*, nov. 2020. [En línea]. Disponible: https://scrumguides.org

[4] Project Management Institute y Agile Alliance, *Agile Practice Guide*. Newtown Square, PA, USA: PMI, 2017.

Rúbrica de evaluación

Criterio	Excelente	Bueno	Regular	Deficiente
Acta de Constitución	Formula acta completa con objetivos SMART, justificación estratégica, stakeholders identificados y criterios de éxito definidos.	Define objetivos, alcance preliminar y stakeholders de forma clara.	Presenta acta con información general y poco precisa.	No define formalmente el proyecto ni sus objetivos.

Criterio	Excelente	Bueno	Regular	Deficiente
Gestión del Alcance	Define alcance detallado con EDT estructurada, diccionario de trabajo y control de cambios establecido.	Presenta EDT/WBS coherente con entregables definidos.	Define alcance general sin desglose estructurado.	No delimita entregables ni estructura de trabajo.
Gestión del Cronograma	Presenta cronograma detallado, secuenciado, con dependencias, hitos críticos y coherencia total con el alcance.	Presenta cronograma estructurado con actividades y hitos definidos.	Presenta cronograma básico sin coherencia total con el alcance.	No presenta planificación temporal clara.
Gestión de Costos	Desarrolla presupuesto detallado con línea base de costos, estimaciones justificadas y control presupuestal definido.	Presenta presupuesto coherente alineado al alcance y cronograma.	Presenta estimación general sin estructura presupuestal clara.	No estima costos o lo hace de manera informal.
Gestión de Riesgos	Desarrolla matriz completa con evaluación cualitativa, priorización y plan formal de respuesta y seguimiento.	Presenta matriz de riesgos con análisis básico de probabilidad e impacto.	Enumera riesgos sin análisis estructurado.	No identifica riesgos relevantes.
Gestión Ágil (si aplica)	Integra marco ágil coherente (backlog priorizado, sprints definidos, criterios de aceptación y métricas de seguimiento).	Define backlog, iteraciones y entregables incrementales.	Menciona prácticas ágiles sin estructura clara.	No aplica prácticas ágiles cuando corresponden.
Sustentación y defensa técnica	Explica y defiende con dominio las decisiones tomadas.	Explica con solvencia.	Explica con dificultad.	No sustenta.

E4 — Modelado de Procesos AS-IS / TO-BE (CE0131–CE0135)

Evidencias CE013 — Gestión de Procesos

CE0131 Identificación y caracterización · CE0132 Modelado AS-IS · CE0133 Modelado TO-BE · CE0134 Automatización con TIC · CE0135 Indicadores y evaluación de impacto. Diagramas BPMN 2.0 editables (abren en bpmn.io y Camunda Modeler): matricula-as-is.bpmn y matricula-to-be.bpmn. Los tiempos del proceso manual son **supuestos a validar** con el plan de medición de la sección 4.3.4; los cálculos están en la hoja "Proceso" de business-case.xlsx.

Portada

Campo	Detalle
Título	Modelado y rediseño del proceso de matrícula — Academia La Prepa Cermat
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo), UPeU campus Juliaca, sección g1
Fecha	2026-10-24
Competencia	CE013 — Gestión de Procesos
Proceso analizado	Matrícula de un alumno en un ciclo y grupo, desde la consulta hasta la activación de su acceso

Resumen ejecutivo

El proceso de matrícula se eligió con una matriz de priorización (4,80 de 5) porque es la puerta de entrada de los datos del alumno, del grupo y del pago, y allí nacen los duplicados, los errores de cupo y las esperas. En el AS-IS cada matrícula consume **40 minutos de personal** (35 de secretaría y 5 de la Dirección) con 7 actividades manuales y una espera de autorización presencial. El TO-BE, que ya está implementado en la plataforma, la reduce a **10,5 minutos** con 4 actividades manuales y 4 automatizaciones verificadas por pruebas.

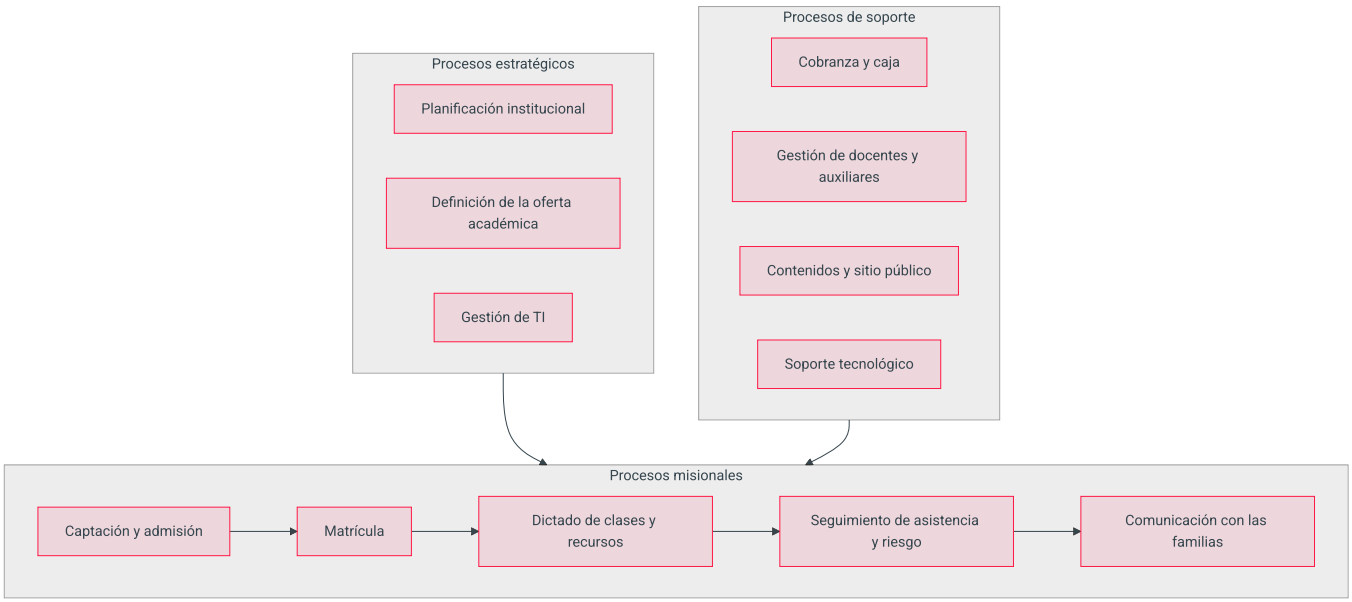
Dimensión	AS-IS	TO-BE	Mejora
Tiempo de personal por matrícula	40 min	10,5 min	−73,8 %

Dimensión	AS-IS	TO-BE	Mejora
Costo de personal por matrícula	S/ 8,33	S/ 1,92	−77,0 %
Costo total por matrícula (con la plataforma imputada)	S/ 8,33	S/ 5,73	−31,2 %
Tiempo de ciclo (consulta → confirmación)	1 a 3 días (supuesto)	≤ 24 h (meta medida con marcas de tiempo)	—
Sobrecupo y duplicados	Posibles y no medidos	0 por diseño (transacción e id determinístico)	Calidad

Condición: las mejoras de calidad y de captación solo se materializan cuando se publiquen las reglas corregidas: con las reglas vigentes del 22-jun-2026 la pre-matrícula pública no se completa.

Identificación y caracterización de procesos (CE0131)

Mapa de procesos



Priorización del proceso a rediseñar

Puntajes de 1 a 5 asignados por el equipo con la evidencia del E1; pesos: impacto en el problema 35 %, frecuencia 20 %, dolor actual 25 %, viabilidad con las TIC existentes 20 %.

Proceso	Impacto en el problema	Frecuencia	Dolor actual	Viabilidad con TIC	Total
Matrícula	5	4	5	5	**4,80**
Cobranza y cuotas	4	4	4	4	4,00

Proceso	Impacto en el problema	Frecuencia	Dolor actual	Viabilidad con TIC	Total
Seguimiento de asistencia	3	5	3	4	3,60
Captación y admisión	4	3	4	3	3,60
Comunicación con las familias	3	4	3	4	3,40

Caracterización del proceso de matrícula

Elemento	Descripción
Objetivo	Matricular al postulante en el ciclo y grupo elegidos, con cupo garantizado, pago registrado y acceso activo, en el menor tiempo posible
Dueño	Secretaría y caja (operación), con supervisión de la Dirección
Alcance	Desde la consulta del postulante hasta la activación de la cuenta del alumno y la entrega del código de consulta al padre
Disparador	Interés de un postulante durante la campaña de un ciclo
Reglas de negocio	Solo ciclos publicados y abiertos; el grupo debe pertenecer al ciclo y a la sede; un teléfono por grupo; cupo no superable; pago mayor que cero; un pago no se borra, se anula con auditoría (E1 de Software)
Recursos	Personal de secretaría, Dirección, plataforma (TO-BE) o cuaderno y hojas (AS-IS)
Requisito legal	Ley N.° 29733: datos de menores con consentimiento de padres o tutores y finalidad declarada

SIPOC:

Proveedores	Entradas	Proceso	Salidas	Clientes
Postulante y padre; Dirección (oferta)	Datos del alumno y del apoderado, ciclo, grupo, turno, modalidad de pago	Consultar → registrar → validar cupo → aprobar → cobrar → confirmar → activar	Matrícula pagada, recibo, cupo descontado, acceso del alumno, código de padres	Alumno, padre, docentes (listas del grupo), Dirección (reportes)

4.1 Proceso actual (AS-IS) (CE0132)

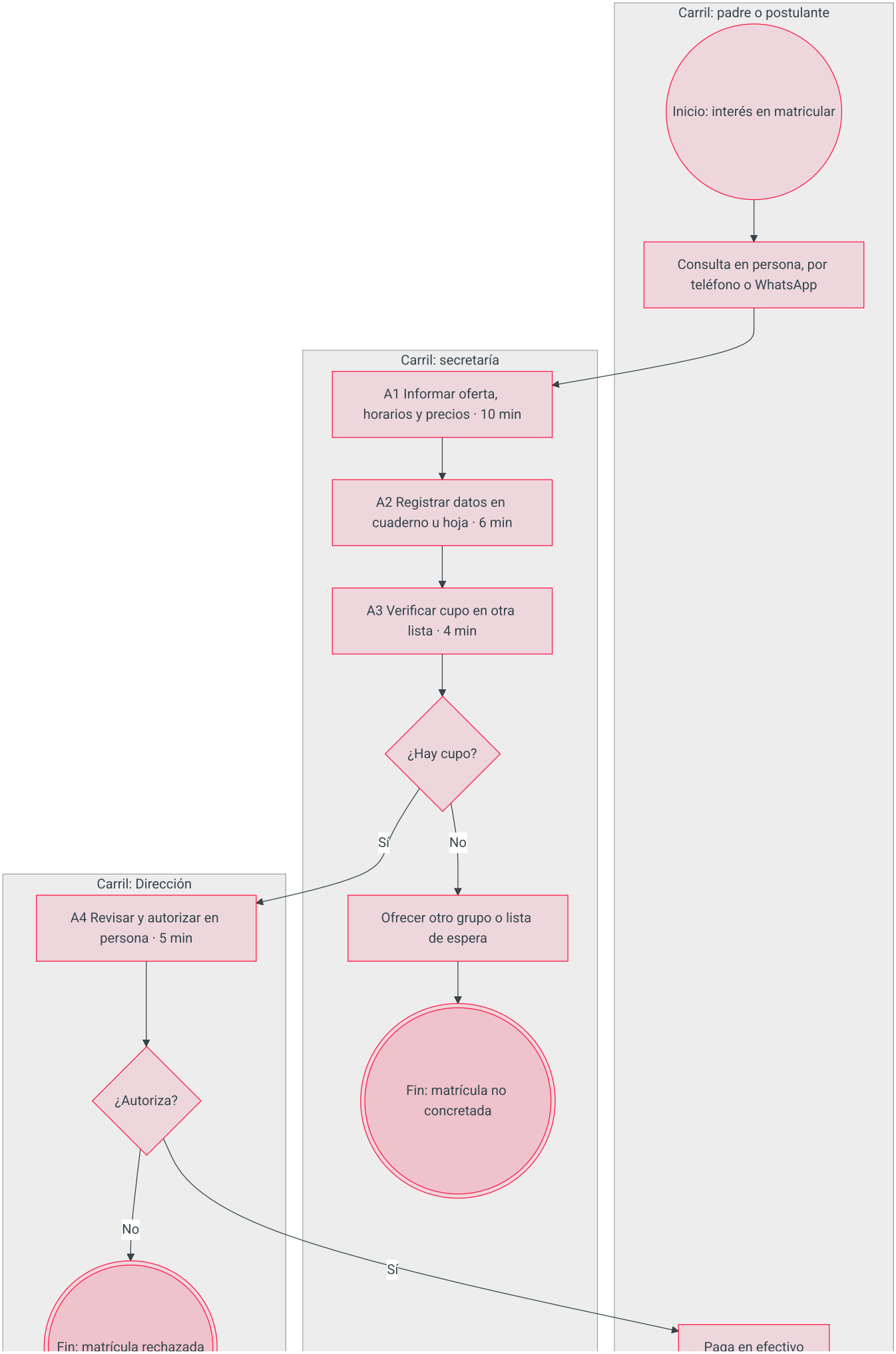
Descripción narrativa

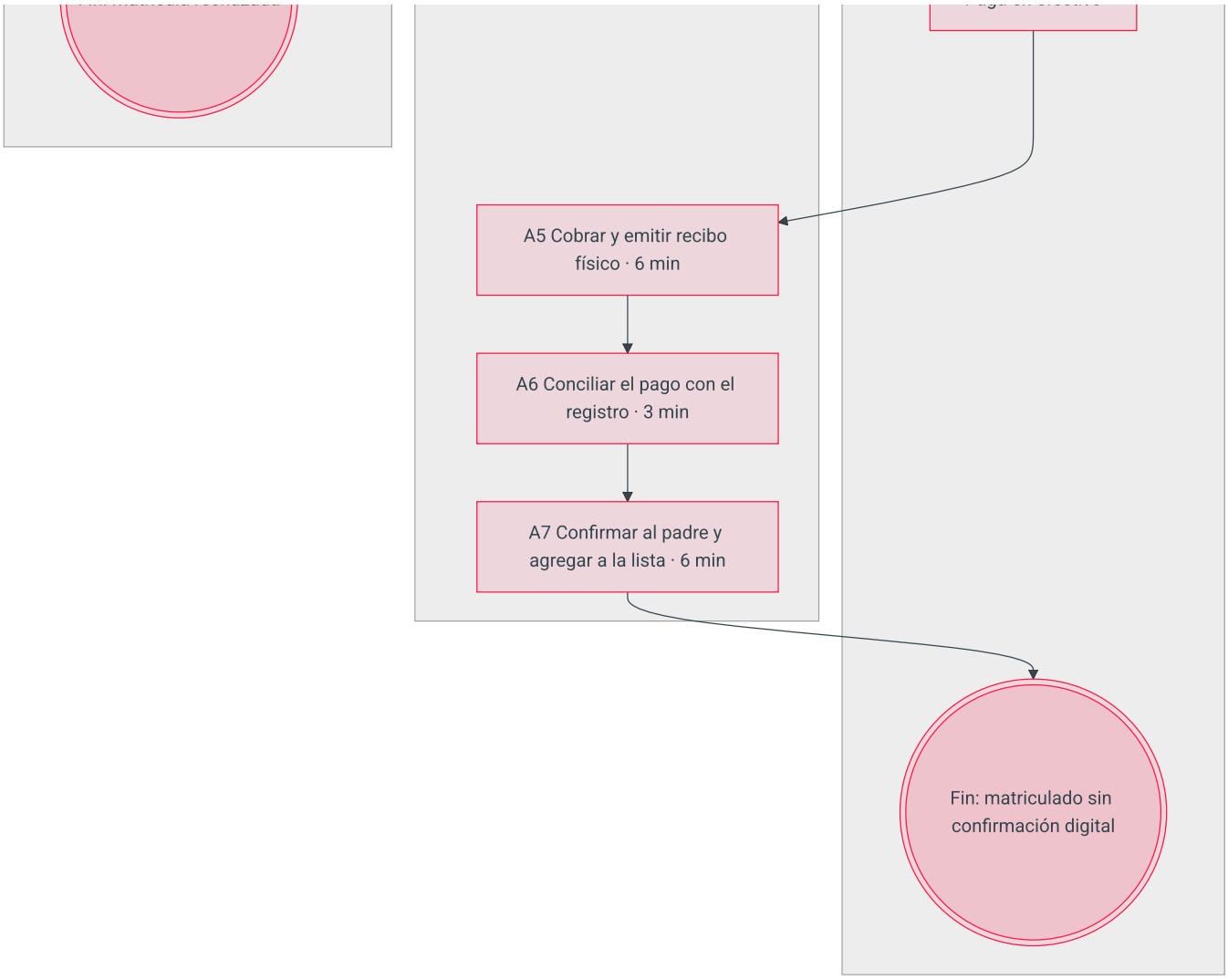
Descripción elaborada por el equipo a partir del Brief EPE y de la operación de la sede. **No hay entrevistas formales registradas**; la descripción se validará con la secretaría durante la medición del Sprint 2 (sección 4.3.4).

1. El padre o postulante consulta en la sede, por teléfono o por WhatsApp.
2. Secretaría informa la oferta, horarios y precios (A1) y anota los datos en un cuaderno o una hoja de cálculo (A2).
3. Secretaría revisa en otra lista si el grupo tiene cupo (A3). Si no lo tiene, ofrece otro grupo o una lista de espera.
4. La Dirección revisa el caso en persona y autoriza (A4). Si no está disponible, el trámite espera.
5. El padre paga en efectivo; secretaría emite un recibo físico y anota el pago en caja (A5).
6. Al cierre del día, secretaría concilia el pago con el registro de matrícula (A6).
7. Secretaría confirma verbalmente al padre y agrega al alumno a la lista del grupo (A7). No hay confirmación digital ni acceso para el alumno.

Diagrama BPMN (AS-IS)

Carriles representados con `subgraph`. El modelo BPMN 2.0 formal, con carriles, compuertas, anotaciones de problemas y diagrama editable, está en matricula-as-is.bpmn.


Carril: padre o postulante
Inicio: interés en matricular
Consulta en persona, por teléfono o WhatsApp
Carril: secretaría
A1 Informar oferta, horarios y precios · 10 min
A2 Registrar datos en cuaderno u hoja · 6 min
A3 Verificar cupo en otra lista · 4 min
¿Hay cupo?
Sí
No
Carril: Dirección
A4 Revisar y autorizar en persona · 5 min
Ofrecer otro grupo o lista de espera
Fin: matrícula no concretada
¿Autoriza?
No
Sí
Fin: matrícula rechazada
Paga en efectivo



Actividades y tiempos (supuestos a validar)

ID	Actividad	Rol	Minutos de personal	Costo (S/)
A1	Atender la consulta e informar oferta, horarios y precios	Secretaría	10	1,67
A2	Registrar los datos del postulante en cuaderno u hoja de cálculo	Secretaría	6	1,00
A3	Verificar el cupo en la lista del grupo (otro registro)	Secretaría	4	0,67
A4	Revisar y autorizar la matrícula en persona	Dirección	5	2,50
A5	Cobrar, emitir el recibo físico y anotar en caja	Secretaría	6	1,00
A6	Conciliar el pago con el registro de matrícula	Secretaría	3	0,50

ID	Actividad	Rol	Minutos de personal	Costo (S/)
A7	Confirmar al padre y agregar al alumno a la lista del grupo	Secretaría	6	1,00
	Total por matrícula		**40** (35 + 5)	**8,33**

Costo hora supuesto: secretaría S/ 10 y Dirección S/ 30 (supuestos S08 y S09 del E2).

Indicadores actuales

Indicador	Valor AS-IS	Origen
Tiempo de personal por matrícula	40 min	Supuesto (tabla anterior)
Costo de personal por matrícula	S/ 8,33	Derivado del supuesto
Tiempo de ciclo (primera consulta → confirmación)	1 a 3 días; mediana supuesta de 2 días hábiles	Supuesto: depende de la disponibilidad de la Dirección y del pago
Costo anual de personal del proceso (162 matrículas, año 3 del caso base)	S/ 1 350	Derivado (hoja "Proceso")
Incidentes de sobrecupo o de matrícula duplicada	No registrados: no existe control que los detecte	No medible hoy
Autorizaciones con autor y fecha registrados	No sistemático	Registro en papel
Matrículas con confirmación verificable al padre	0 % (confirmación verbal)	Descripción del proceso
Matrículas registradas en la plataforma	8 (2 pendientes, 5 pagadas, 1 cancelada) entre el 2026-01-27 y el 2026-07-07	Firestore, conteo real
Tiempo pre-matrícula → aprobación en la plataforma	Solo 2 registros con ambas fechas y ≈ 1 min; parecen pruebas del administrador	**No se usa como indicador**

Problemas detectados

Problema	Actividad	Tipo de desperdicio (Lean)	Efecto
Re-digitación de los mismos datos en cuaderno, hojas y listas	A2, A7	Sobreprocesamiento	Tiempo y errores de transcripción
Cupo verificado en un registro distinto al de la matrícula	A3	Defecto potencial	Sobrecupo o matrícula perdida por listas desincronizadas

Problema	Actividad	Tipo de desperdicio (Lean)	Efecto
Autorización presencial de la Dirección	A4	Espera	1 a 3 días de ciclo; el postulante puede matricularse en otra academia
Pago desconectado de la matrícula	A5, A6	Sobreprocesamiento y defecto	Conciliación manual; morosidad poco visible
Sin control de duplicados	A2	Defecto	Un alumno registrado dos veces
Confirmación verbal	A7	Defecto	Llamadas repetidas del padre; sin acceso para el alumno
Datos personales en papel sin control de acceso	A2, A5	Riesgo	Incumplimiento potencial de la Ley N.° 29733
Sin datos del proceso	Todas	—	No se puede medir ni mejorar

4.2 Proceso propuesto (TO-BE) (CE0133 y CE0134)

Rediseño del flujo

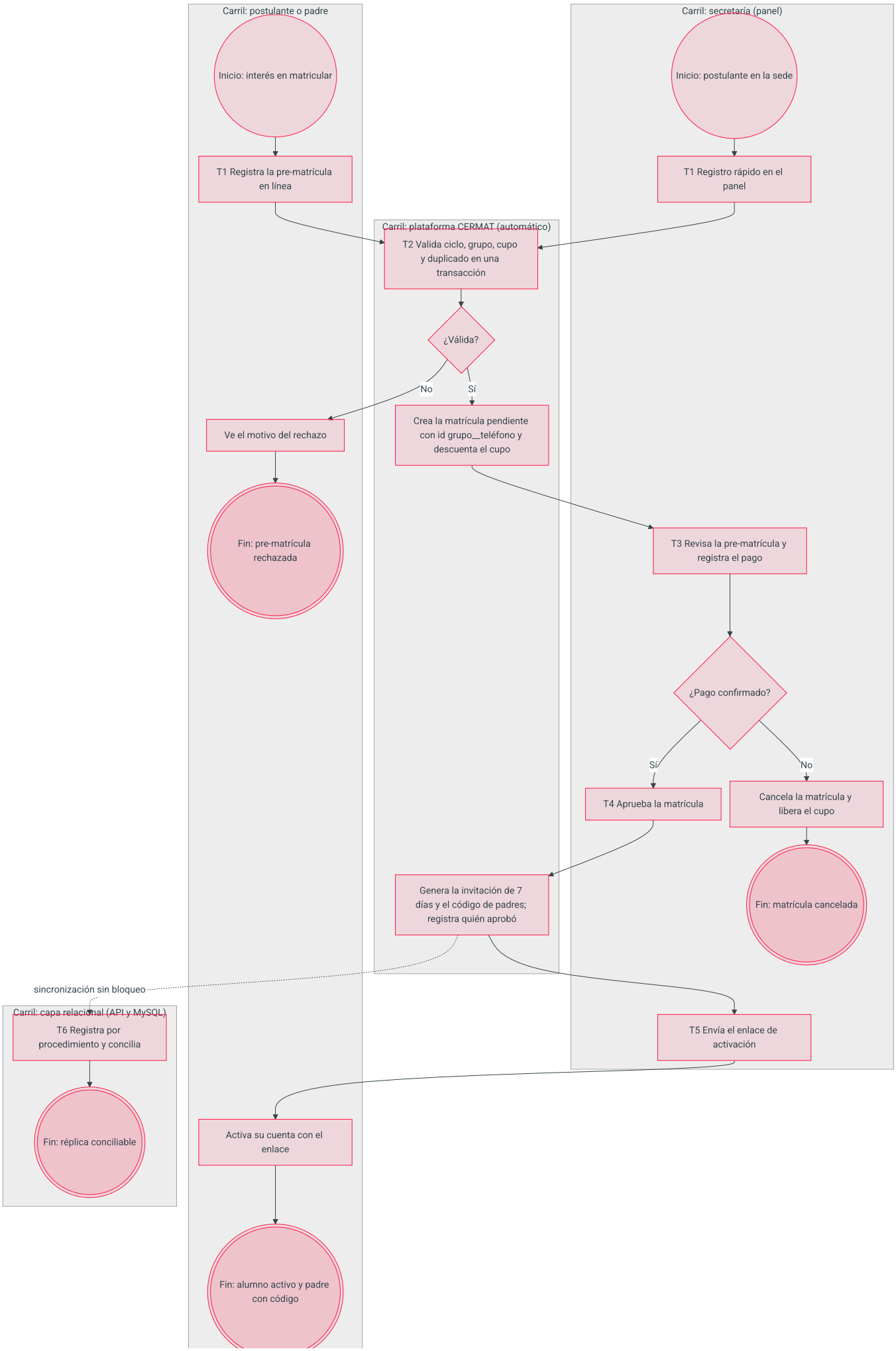
El TO-BE ya está implementado en la plataforma; falta su adopción y la publicación de las reglas corregidas.

1. **Dos canales de entrada con las mismas reglas.** El postulante registra la pre-matrícula en línea desde el sitio público, o secretaría la registra con el registro rápido del panel cuando acude a la sede.
2. **Validación automática en una transacción:** ciclo abierto, grupo del ciclo y de la sede, cupo disponible y teléfono no repetido en el grupo. Si algo falla, el postulante ve el motivo.
3. La matrícula queda **pendiente** con id determinístico `grupo__teléfono` y el cupo se descuenta en la misma transacción.
4. Secretaría revisa la pre-matrícula y registra el pago en el panel. Si no hay pago, cancela y el cupo se libera.
5. Al **aprobar**, el sistema genera la invitación de activación (vigencia de 7 días) y el código de consulta para el padre, y registra quién aprobó y cuándo.
6. Secretaría envía el enlace; el alumno activa su cuenta; el padre consulta la asistencia con su código.
7. En paralelo, la matrícula y el pago se replican en MySQL por procedimientos almacenados y la vista de conciliación detecta cualquier evento perdido.

La autorización de la Dirección deja de ser un paso del flujo: la Dirección define las reglas (cupos, precios, ciclos abiertos) y revisa indicadores en el panel.

Diagrama BPMN (TO-BE)

Modelo formal: matricula-to-be.bpmn.


Carril: postulante o padre
Inicio: interés en matricular
T1 Registra la pre-matrícula en línea
Carril: secretaría (panel)
Inicio: postulante en la sede
T1 Registro rápido en el panel
Carril: plataforma CERMAT (automático)
T2 Valida ciclo, grupo, cupo y duplicado en una transacción
¿Válida?
No
Sí
Ve el motivo del rechazo
Fin: pre-matrícula rechazada
Crea la matrícula pendiente con id grupo__teléfono y descuenta el cupo
T3 Revisa la pre-matrícula y registra el pago
¿Pago confirmado?
Sí
No
T4 Aprueba la matrícula
Cancela la matrícula y libera el cupo
Fin: matrícula cancelada
Genera la invitación de 7 días y el código de padres; registra quién aprobó
sincronización sin bloqueo
Carril: capa relacional (API y MySQL)
T6 Registra por procedimiento y concilia
Fin: réplica conciliable
T5 Envía el enlace de activación
Activa su cuenta con el enlace
Fin: alumno activo y padre con código

Automatizaciones propuestas

Automatización	Cómo funciona (evidencia en el código)	Problema AS-IS que elimina	Pruebas que la respaldan
Validación transaccional de cupo	`createEnrollment` lee el grupo dentro de `runTransaction`, rechaza si `enrolledCount >= capacity` y suma el cupo en la misma transacción; `updateEnrollmentStatus` lo libera al cancelar (`src/features/enrollments/api.ts`)	Sobrecupo por listas desincronizadas (A3)	6 pruebas de reglas de matrícula pública: sobrecupo, cupo sin matrícula y manipulación del contador, entre otras
Deduplicación por id determinístico	El id de la matrícula es `groupId__teléfonoNormalizado`; si ya existe, la transacción falla con un mensaje claro	Alumno registrado dos veces (A2)	Prueba de reglas "duplicado"
Ciclo abierto y grupo válido	Funciones `isEnrollmentCycleOpen`, `isEnrollmentGroupInCycle` e `isEnrollmentGroupCampusValid` en `firestore.rules`	Matrículas en ciclos cerrados o grupos ajenos	Prueba de reglas "ciclo cerrado"
Activación por invitación	`markPaidAndCreateStudentInvite` crea, en una transacción, una invitación con token aleatorio de 24 caracteres cuyo hash SHA-256 es el id, con vencimiento de 7 días; reutiliza la vigente si existe	Confirmación verbal sin acceso (A7)	3 pruebas unitarias de tokens; 8 pruebas de reglas de roles
Código de consulta para padres	Se genera al aprobar, sin caracteres ambiguos (0/O, 1/I)	Llamadas del padre para conocer la asistencia	4 pruebas unitarias del código de padres
Trazabilidad de decisiones	`approvedBy`, `approvedAt`, `cancelledBy`, `cancelledAt` y `statusUpdatedAt` en cada matrícula; auditoría por triggers en MySQL	Autorización sin registro (A4)	Pruebas de BD de auditoría de anulación

Automatización	Cómo funciona (evidencia en el código)	Problema AS-IS que elimina	Pruebas que la respaldan
Sincronización conciliable	`syncService` envía matrícula y pago a la API sin bloquear la operación; la API escribe solo por procedimientos y `v_conciliacion_pagos` lista los pagos sin matrícula (0 filas = sin eventos perdidos)	Conciliación manual del pago (A6)	8 pruebas de API de sincronización; 2 de BD de conciliación
Registro rápido por secretaría	`useQuickEnrollmentSubmit` registra en el panel a quien acude a la sede con las mismas validaciones	Canal presencial sin control	4 pruebas unitarias del formulario de matrícula

Actividades y tiempos del TO-BE

ID	Actividad	Rol	Minutos de personal	Costo (S/)
T1	Pre-matrícula en línea (autoservicio) o registro rápido de secretaría (promedio ponderado)	Postulante o secretaría	4	0,67
T2	Validar ciclo, grupo, cupo y duplicado en una transacción	Sistema	0	0,00
T3	Revisar la pre-matrícula y registrar el pago en el panel	Secretaría	4	0,67
T4	Aprobar: el sistema genera la invitación y el código de padres	Secretaría	1	0,17
T5	Enviar el enlace de activación	Secretaría	1	0,17
T6	Sincronizar con MySQL y conciliar	Sistema	0	0,00
T7	Revisar indicadores de matrícula en el panel (prorrateo por matrícula)	Dirección	0,5	0,25
	Total por matrícula		**10,5** (10 + 0,5)	**1,92**

Nuevos indicadores

ID	Indicador	Fórmula	Fuente de datos	Meta	Frecuencia
IV-01	Minutos de personal por matrícula	Promedio de 10 trámites cronometrados	Hoja de cronometraje	≤ 12 min	Por ciclo
IV-02	Tiempo de respuesta a la pre-matrícula	p50 y p90 de (`approvedAt` o `cancelledAt`) − `createdAt`	Firestore `enrollments`	p90 ≤ 24 h	Semanal en campaña
IV-03	Costo de personal por matrícula	Σ (minutos × costo hora del rol)	Cronometraje y supuestos S08 y S09	≤ S/ 2,50	Por ciclo
IV-04	Incidentes de sobrecupo o duplicado	Grupos con matrículas activas > `capacity` ; duplicados detectados después del registro	Firestore `groups` y `enrollments`	0	Por ciclo
IU-01	Adopción	Matrículas en la plataforma ÷ matrículas totales	Firestore y registro de secretaría	≥ 60 % en 2027	Mensual
IP-01	Activación oportuna	Invitaciones usadas en 7 días ÷ invitaciones emitidas	Firestore `invites` (`used` , `usedAt`)	≥ 90 %	Por ciclo
IP-02	Conciliación	Filas en `v_conciliacion_pagos`	MySQL	0	Mensual
IP-03	Confirmación verificable	Matrículas pagadas con código de padres ÷ matrículas pagadas	Firestore `enrollments`	100 %	Por ciclo

Mejora estimada en eficiencia

Medida	AS-IS	TO-BE	Variación
Actividades manuales	7	4	−3
Actividades automáticas	0	4 (validación, alta con cupo, invitación y código, réplica)	+4
Decisiones que requieren a la Dirección	1 por matrícula	0 (la Dirección fija reglas)	−1
Minutos de personal por matrícula	40	10,5	−73,8 %

Medida	AS-IS	TO-BE	Variación
Horas de personal al año (162 matrículas)	108 h	28,4 h	−79,7 h

4.3 Análisis comparativo (CE0135)

4.3.1 Reducción de tiempos

Medida	AS-IS	TO-BE	Reducción	Cómo se verifica
Tiempo de personal por matrícula	40 min	10,5 min	29,5 min (−73,8 %)	Cronometraje de 10 trámites en cada situación
Secretaría por matrícula	35 min	10 min	25 min	Ídem
Dirección por matrícula	5 min	0,5 min	4,5 min	Ídem
Tiempo de ciclo (consulta → confirmación)	1 a 3 días (supuesto)	≤ 24 h en el p90 (meta)	Al menos 1 día	Marcas de tiempo de Firestore
Horas de personal al año (162 matrículas)	108 h	28,4 h	79,7 h	Volumen real × tiempos medidos

4.3.2 Reducción de costos

Medida	AS-IS	TO-BE	Reducción
Costo de personal por matrícula	S/ 8,33	S/ 1,92	S/ 6,42 (−77,0 %)
Costo anual de personal del proceso (162 matrículas, año 3 base)	S/ 1 350	S/ 311	S/ 1 040 (= beneficio B1 del año 3 en el E2)
Costo de plataforma imputado por matrícula	—	S/ 3,81	—
Costo total por matrícula	**S/ 8,33**	**S/ 5,73**	**S/ 2,60 (−31,2 %)**

Criterio de imputación: la plataforma soporta varios procesos (matrícula, pagos, asistencia, comunicación). A la matrícula se le imputa la parte de los costos anuales de operación (S/ 2 438) proporcional a su participación en los beneficios (25,3 %), repartida entre las 162 matrículas del año 3. Incluso cargando ese costo, el proceso TO-BE es 31,2 % más barato por matrícula.

4.3.3 Mejora en calidad

Dimensión de calidad	AS-IS	TO-BE	Evidencia
Sobrecupo	Posible; no se detecta	0 por diseño: el cupo se valida y descuenta en una transacción	Pruebas de reglas de sobrecupo y de manipulación del contador
Matrícula duplicada	Posible	0 por diseño: id determinístico `grupo__teléfono`	Prueba de reglas "duplicado"
Matrícula en ciclo cerrado	Posible	Bloqueada por las reglas	Prueba de reglas "ciclo cerrado"
Trazabilidad de la aprobación	No sistemática	100 %: autor y fecha en cada matrícula	Campos `approvedBy` y `approvedAt`
Conciliación de pagos	Manual	Automática; meta de 0 filas en la vista	Pruebas de BD de conciliación
Confirmación al padre	Verbal	100 % de las pagadas con enlace de activación y código de padres	Indicador IP-03
Protección de datos	Papel sin control de acceso	Acceso por rol verificado con 19 pruebas y publicado en producción el 2026-10-24	E4 de Software, 1.6

4.3.4 Plan de medición

Pendiente de ejecución. Los tiempos del AS-IS son supuestos; este plan los convierte en mediciones antes de la campaña 2027 (paquete 6.1 del E3, PB-14).

Paso	Procedimiento	Cuándo	Criterio de aceptación	Evidencia a adjuntar
1. Línea base AS-IS	Cronometrar N = 10 matrículas manuales reales (al menos 3 presenciales y 3 telefónicas), con hora de inicio y fin de cada actividad A1 a A7, sin intervenir. Registrar también la fecha de la primera consulta y la de confirmación.	Sprint 2 (2026-11-09 a 2026-11-20)	10 trámites completos. Con un coeficiente de variación supuesto de 0,3, 10 observaciones estiman la media con ±21 % al 95 % (t_9 = 2,26); si el coeficiente medido supera 0,4, se amplía a 20 trámites	Hojas de cronometraje firmadas por el observador
2. Validación del modelo	Revisar con la secretaría las actividades A1 a A7 y corregir el diagrama si difiere	Sprint 2	Diagrama AS-IS aprobado por la secretaría	Versión corregida del `.bpmn`

Paso	Procedimiento	Cuándo	Criterio de aceptación	Evidencia a adjuntar
3. Medición TO-BE en el sistema	Exportar de `enrollments` solo `createdAt`, `approvedAt`, `cancelledAt` y `status`, sin nombres ni teléfonos; calcular p50 y p90 del tiempo de respuesta. Excluir registros de prueba (creados y aprobados por una cuenta de administrador en menos de 2 minutos se revisan uno por uno)	Campaña 2027 (enero)	p90 ≤ 24 h (OBJ-3)	CSV agregado y cálculo
4. Medición TO-BE de personal	Cronometrar 10 trámites en el panel (registro rápido, revisión, pago, aprobación y envío del enlace)	Campaña 2027	Promedio ≤ 12 min (OBJ-2)	Hojas de cronometraje
5. Actualización del modelo	Reemplazar los supuestos S12 y S13 del libro por los valores medidos y recalcular	Antes del 2027-03-31	Libro recalculado para el hito de continuidad	`business-case.xlsx` actualizado

Referencias

[1] Object Management Group, *Business Process Model and Notation (BPMN), Version 2.0*, formal/2011-01-03, ene. 2011.

[2] ISO/IEC 19510:2013, *Information technology — Object Management Group Business Process Model and Notation*. Ginebra, Suiza: ISO, 2013.

[3] M. Dumas, M. La Rosa, J. Mendling y H. A. Reijers, *Fundamentals of Business Process Management*, 2nd ed. Berlín, Alemania: Springer, 2018.

[4] J. P. Womack y D. T. Jones, *Lean Thinking*. New York, NY, USA: Simon & Schuster, 1996.

Rúbrica de evaluación

Criterio	Excelente	Bueno	Regular	Deficiente
Modelado AS-IS	Modelado detallado con identificación clara de ineficiencias.	Modelado correcto del proceso actual.	Representación básica sin análisis crítico.	Incorrecto o incompleto.

Criterio	Excelente	Bueno	Regular	Deficiente
Propuesta TO-BE	Rediseño innovador con mejora cuantificada en eficiencia y calidad.	Rediseño coherente apoyado en TIC.	Propone mejoras generales.	No responde al problema.
Análisis comparativo	Cuantifica mejoras en tiempo, costo y calidad.	Evidencia mejoras esperadas.	Comparación descriptiva básica.	No presenta comparación.
Sustentación y defensa técnica	Explica y defiende con dominio las decisiones tomadas.	Explica con solvencia.	Explica con dificultad.	No sustenta.

E5 — Propuesta de Solución TIC Integrada al Ecosistema de Sistemas de Información (CE0141–CE0145)

Evidencias CE014 — Gestión de Sistemas de Información

CE0141 Mapa del ecosistema · CE0142 Arquitectura conceptual · CE0143 Integración y flujos de información · CE0144 Plan de implementación y gestión · CE0145 Indicadores de uso, valor y mejora. Lo implementado se distingue de lo propuesto en cada tabla. La infraestructura de soporte se diseña en la línea CE03 (S1-E2 y S2-E3) y la seguridad en el SGSI.

Portada

Campo	Detalle
Título	Solución TIC integrada: la Plataforma CERMAT en el ecosistema de sistemas de información de CERMAT
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo), UPeU campus Juliaca, sección g1
Fecha	2026-10-24
Competencia	CE014 — Gestión de Sistemas de Información
Producción	https://academia-school-platform.vercel.app (academia) · `cermatschool.edu.pe` y `api.cermatschool.edu.pe` (colegio)

Resumen ejecutivo

La solución es la **Plataforma Web Integral CERMAT**: una SPA en Vercel con Firebase como capa operativa y una capa relacional (API, MySQL y analítica) para réplica, auditoría y reportes. Hoy convive, sin integración, con el **sistema de gestión del colegio** (Angular, Laravel y PostgreSQL en un VPS) y con herramientas informales. La propuesta tiene tres ejes:

1. **Estabilizar y adoptar** (2026–2027): publicar las reglas corregidas (hecho el 2026-10-24), dar servicio continuo a la capa relacional, respaldar Firestore, monitorear y medir.
2. **Integrar por niveles** (2027–2028): enlace desde el sitio del colegio, que es la decisión vigente de la institución (N0), y un subdominio institucional solo si la Dirección lo aprueba (N1), intercambio de datos

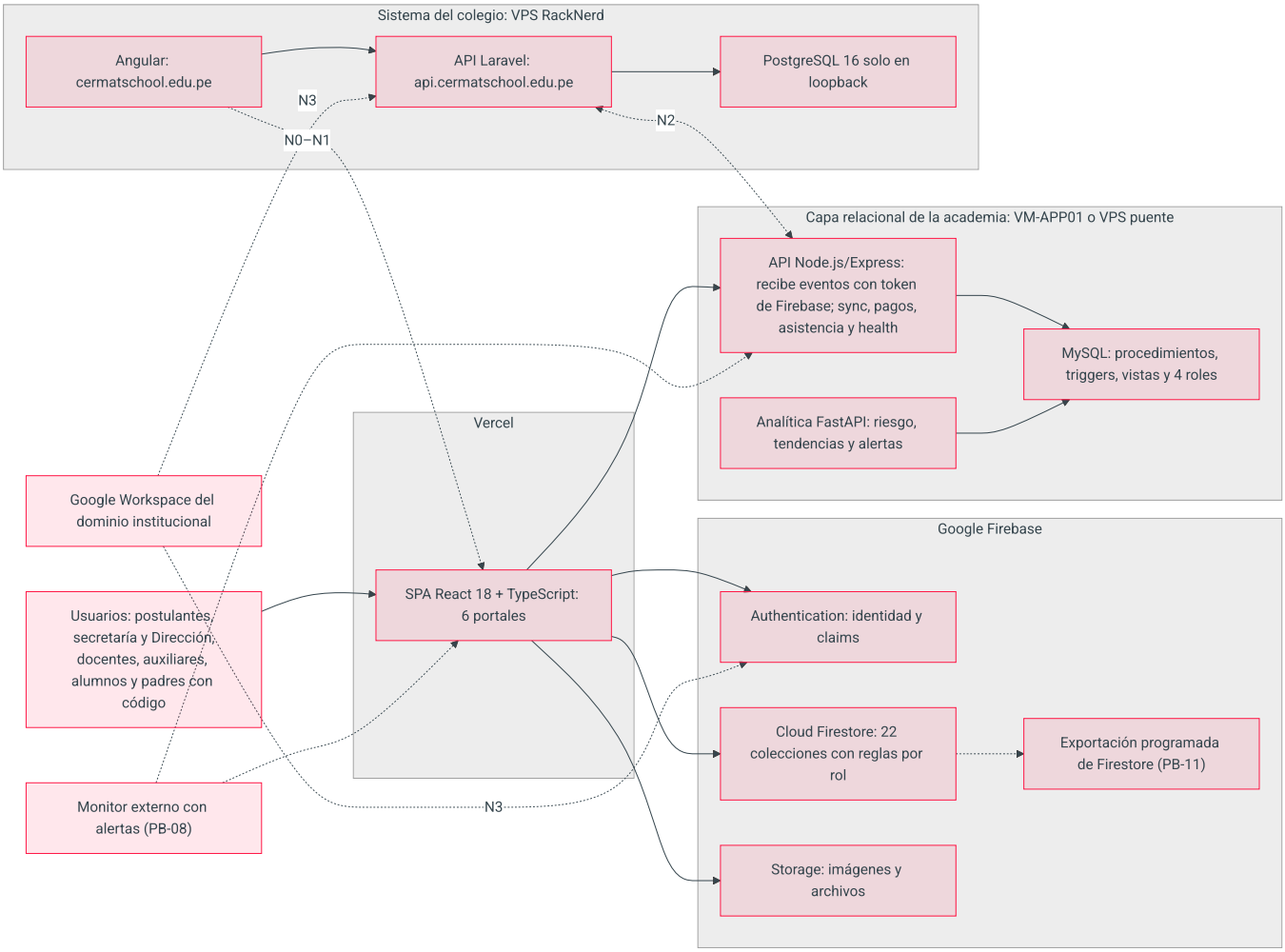
por API REST/JSON con la API Laravel del colegio (N2), identidad compartida para el personal con la cuenta institucional de Google (N3) y notificaciones desde el dominio institucional (N4).

3. **Gobernar y sostener**: accesos por rol, cumplimiento de la Ley N.° 29733, corrección de hallazgos reales (reglas, cabeceras, DNS), costos de S/ 2 438 al año coherentes con el E2 y 22 indicadores de uso, valor y mejora con línea base real.

5.1 Arquitectura de la solución (CE0142)

Diagrama de arquitectura (objetivo 2027–2028)

Líneas continuas: implementado. Líneas punteadas: propuesto. N0 a N3 son los niveles de integración de la tabla «Integraciones»; PB-08 y PB-11 son elementos del Product Backlog.



Componentes principales

Componente	Tecnología	Responsabilidad	Alojamiento	Estado
SPA multi-portal	React 18, TypeScript, Vite, TanStack Query, Tailwind	Sitio público y portales admin, docente, alumno, auxiliar y consulta de padres	Vercel (plan Hobby; plan comercial presupuestado)	Implementado

Componente	Tecnología	Responsabilidad	Alojamiento	Estado
Identidad	Firebase Authentication con claims de administrador	Sesión y rol	Google Cloud	Implementado
Datos operativos	Cloud Firestore, 22 colecciones	Fuente de verdad de la operación	Google Cloud	Implementado; reglas corregidas publicadas el 2026-10-24
Archivos	Firebase Storage	Imágenes y recursos	Google Cloud	Implementado
API de sincronización	Node.js/Express con helmet, CORS por lista y morgan	Recibe eventos y escribe en MySQL solo por procedimientos	PC con PM2 (transitorio) → VM-APP01 o VPS puente	Implementado; servicio continuo propuesto (PB-13)
Base relacional	MySQL 8 con 3 FK, 7 CHECK, 6 triggers, 4 funciones, 5 procedimientos, 3 vistas y 4 roles	Réplica auditable, conciliación y reportes	Ídem	Implementado (E2 de Software)
Analítica	Python/FastAPI	Riesgo de inasistencia, tendencias, pagos y alertas	Ídem	Implementado
Respaldo de Firestore	Exportación programada con prueba de restauración	RPO ≤ 24 h	Google Cloud	Propuesto (PB-11)
Monitor	Servicio externo de chequeo HTTP con alertas	Disponibilidad medida de la SPA y de `/health`	Externo o VM-MON01 de CE03	Propuesto (PB-08)
Sistema del colegio	Angular, Laravel (PHP 8.4), PostgreSQL 16	Gestión escolar	VPS RackNerd (2 vCPU, 2 GB, Ubuntu 24.04)	Implementado (otro proyecto del mismo autor)

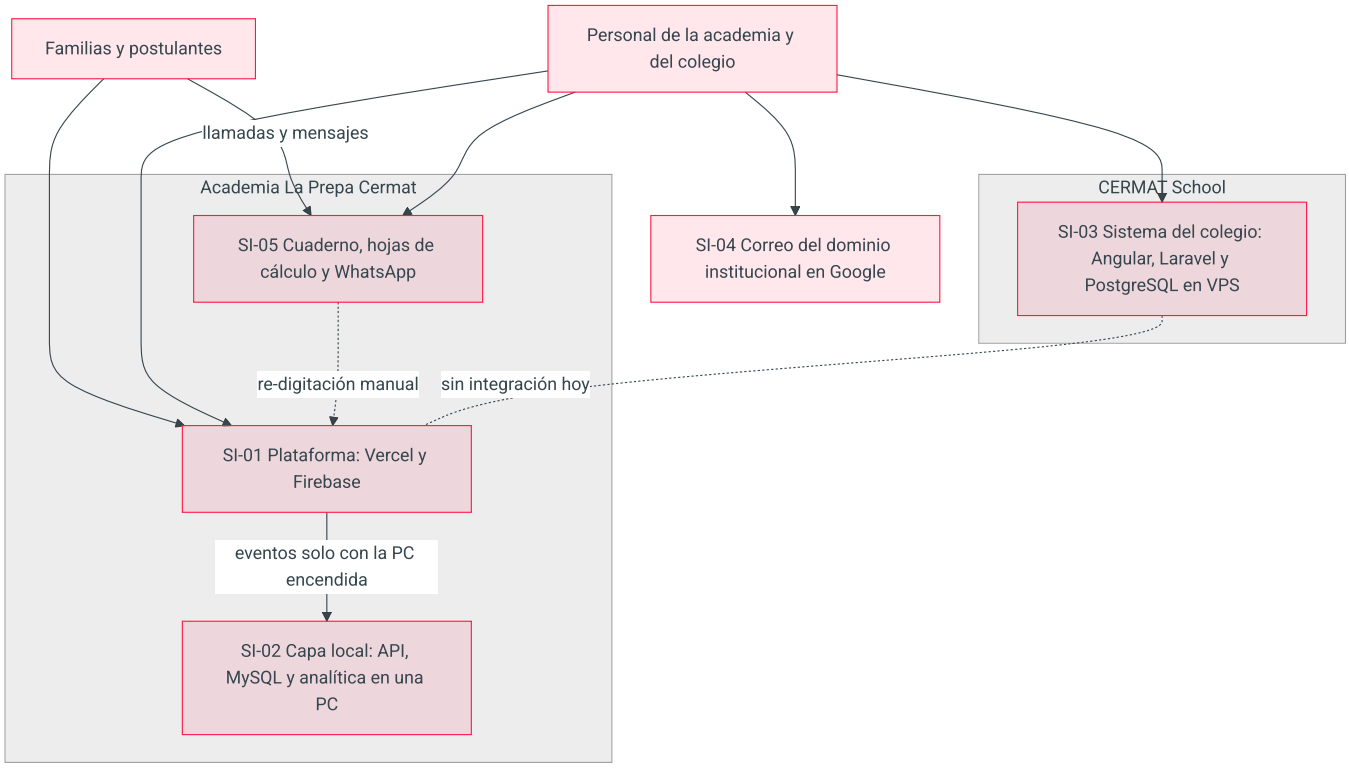
Integraciones

Origen → destino	Mecanismo	Datos	Seguridad	Estado
SPA → Firebase	SDK de Firebase	Toda la operación	Reglas por rol y claims; 19 pruebas en el emulador	Implementado
SPA → API local	HTTPS POST sin bloqueo (fire-and-forget), URL en `config/services` con caché de 5 min	Matrícula, pago y marca de asistencia	Token de Firebase; `requireAuth`, `requireAdmin` y titularidad; 18 pruebas	Implementado; solo opera con la PC encendida
API → MySQL	Procedimientos almacenados	Ídem	Cuenta `cermat_api` sin `INSERT`, `UPDATE` ni `DELETE` directos	Implementado

Origen → destino	Mecanismo	Datos	Seguridad	Estado
Analítica → MySQL	Lectura de vistas y procedimientos	Asistencia, pagos y alertas	Cuenta de lectura	Implementado
Panel admin → `/health`	HTTP	Estado de API y MySQL	Solo administradores	Implementado
Firestore → respaldo	Exportación programada	Todas las colecciones	Cuenta de servicio con mínimo privilegio	Propuesto
Sitio del colegio → SPA	Enlace e inserción controlada (`frame-ancestors` limitado al dominio del colegio, ya definido en `vercel.json` como cambio local)	Ninguno	CSP	Previsto (N0–N1)
API de la academia ↔ API Laravel	REST/JSON versionado	Verificación de alumno del colegio, oferta pública	Credencial de servicio, TLS, CORS restringido	Propuesto (N2)
Google Workspace → Firebase Auth y Laravel	OpenID Connect con la cuenta del dominio	Identidad del personal	Restricción al dominio institucional	Propuesto (N3)
Plataforma → correo institucional	Envío autenticado desde el dominio	Confirmaciones y alertas	SPF, DKIM y DMARC	Propuesto (N4)

5.2 Ecosistema de sistemas de información (CE0141 y CE0143)

Mapa de sistemas actuales



Proceso	SI-01 Plataforma	SI-02 Capa local	SI-03 Colegio	SI-04 Correo	SI-05 Informales
Captación y admisión	◐ sitio y pre-matrícula (operativa desde el 2026-10-24)	—	—	—	● llamadas y WhatsApp
Matrícula	◐ 8 matrículas	◐ réplica	—	—	● cuaderno y hojas
Cobranza	◐ 2 pagos	◐ estado de cuenta	—	—	● caja manual
Asistencia	◐ 7 marcas (ene–abr)	◐ riesgo	—	—	● listas
Comunicación con familias	◐ código (0 consultas)	—	—	—	● WhatsApp
Gestión escolar del colegio	—	—	●	—	◐
Comunicación interna	—	—	—	●	● WhatsApp

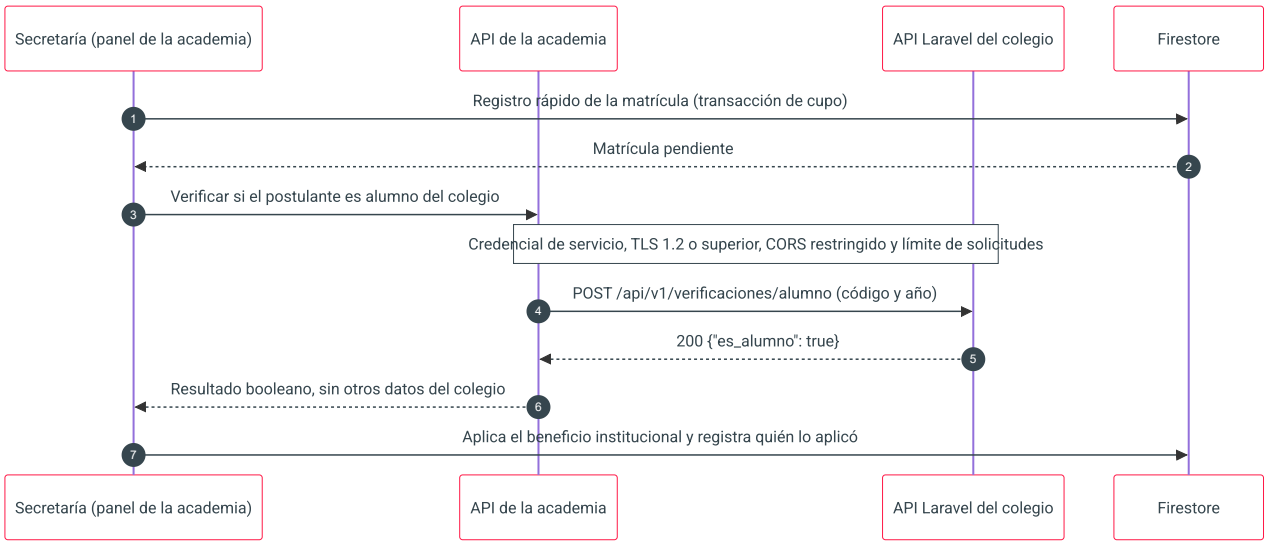
● soporte principal · ◐ soporte parcial · — sin soporte.

Integración propuesta

Nivel	Qué integra	Mecanismo	Datos que cruzan	Requisitos previos	Fase
N0 Enlace	El sitio del colegio enlaza a la academia	Hipervínculo o inserción controlada	Ninguno	Publicar la plataforma estable	RM-08 (2027)
N1 Dominio institucional	`academia.cermatschool.edu.pe` como dominio de la plataforma	Registro CNAME en Punto.pe hacia Vercel; TLS automático	Ninguno	Plan comercial de hosting; registros CAA	RM-08 (2027)
N2 Intercambio de datos	API de la academia ↔ API Laravel del colegio	REST/JSON con contrato OpenAPI 3.1	Verificación booleana de alumno del colegio; oferta pública de la academia	CORS del colegio restringido; credencial de servicio; consentimiento	RM-11 (2028)
N3 Identidad compartida	Personal (administración y docentes) inicia sesión con su cuenta institucional en ambos sistemas	OpenID Connect con Google: Firebase Authentication y Laravel (Socialite) restringidos al dominio	Identidad del personal; el rol sigue en cada sistema	Cuentas institucionales para todo el personal	RM-10 (2028)
N4 Notificaciones	Confirmación de matrícula, enlace de activación y alertas de inasistencia	Correo autenticado desde el dominio; WhatsApp como opción evaluada por costo	Correo del apoderado y mensaje mínimo	SPF, DKIM y DMARC configurados	RM-12 (2028)

Decisiones de diseño: alumnos y padres no entran a la identidad compartida (son menores o externos y el código de padres ya resuelve su necesidad). Cada sistema conserva su base y sus roles; solo se intercambia lo mínimo necesario.

Flujo de información del caso N2 (propuesto)



Contrato de ejemplo (fragmento; la versión completa se publicará como OpenAPI 3.1):

```
{
  "solicitud": { "codigo_alumno": "texto", "anio": 2027 },
  "respuesta": { "es_alumno": true, "verificado_en": "2027-01-04T09:15:00-05:00" },
  "errores": { "401": "credencial inválida", "404": "sin coincidencia", "429": "límite de solicitudes"
}
}
```

Interoperabilidad

Aspecto	Estándar adoptado
Estilo y formato	REST con JSON (RFC 8259) y UTF-8
Contrato	OpenAPI 3.1, versionado en la ruta (`/api/v1`)
Fechas	ISO 8601 con zona `America/Lima` (la plataforma ya corrigió el uso de UTC en asistencia)
Autenticación entre sistemas	Credencial de servicio (OAuth 2.0 *client credentials* [5] o token de servicio de Laravel) rotada cada 6 meses
Identidad del personal	OpenID Connect con Google [6]
Errores	Códigos HTTP y cuerpo JSON sin detalles internos (como ya hace la API: 400, 422 y 500 tipados)
Idempotencia	Clave de idempotencia por evento, como `firestore_log_id` en la réplica de asistencia
Trazabilidad	Identificador de correlación por solicitud en los registros de ambas APIs

5.3 Seguridad y gobernanza

Gestión de accesos

Rol	Cómo obtiene acceso	Qué puede hacer	Control técnico	Evidencia
Administrador	Claim `admin` asignado por el responsable técnico	Gestión completa de oferta, matrículas, pagos, usuarios y contenidos	`isAdmin()` en reglas; `requireAdmin` en la API	Pruebas de reglas y de API
Docente	Invitación vigente (`teacherInvites`)	Portal docente, recursos y su asistencia	Reglas de roles con invitación	8 pruebas de roles
Auxiliar	Invitación vigente (`auxiliarInvites`)	Registro de asistencia por QR	Reglas de roles y titularidad en `/api/sync`	Pruebas de reglas y de API
Alumno	Invitación de activación tras la matrícula pagada (hash SHA-256, 7 días)	Sus cursos, recursos, matrícula y asistencia	Reglas por titularidad	3 pruebas de tokens
Padre	Código CERMAT, sin cuenta	Lectura de la asistencia resumida de su hijo	Colección `parentAttendance` de solo lectura por código	4 pruebas del código
Visitante	Sin sesión	Oferta pública y pre-matrícula con reglas de cupo	Reglas de matrícula pública	6 pruebas
Servicio (API)	Cuenta MySQL `cermat_api` ; clave de servicio de Firebase	Solo ejecutar procedimientos; verificar tokens	Mínimo privilegio en MySQL; clave rotada el 2026-10-24 (PB-06)	19 pruebas de BD
Servidor del colegio	Usuario Linux no root con sudo; usuario de BD sin superusuario	Administración del VPS	UFW (22, 80 y 443), PostgreSQL solo en loopback	Manual del propietario

Ciclo de vida de accesos: alta solo por invitación o claim; baja al cerrar el ciclo o al cesar el personal; revisión trimestral de los claims de administrador; evaluar MFA para cuentas de administrador en Firebase.

Protección de datos (Ley N.° 29733)

Obligación	Estado al 2026-10-24	Acción	Responsable
Consentimiento de padres o tutores para datos de menores	Sin aviso de consentimiento en los formularios (búsqueda en `src/` sin resultados)	Aviso y casilla en la pre-matrícula y el registro rápido, con versión aceptada registrada (PB-16)	Dirección y equipo
Información de la finalidad (política de privacidad)	No publicada	Publicar finalidad, plazo de conservación, derechos y canal de atención	Dirección

Obligación	Estado al 2026-10-24	Acción	Responsable
Inscripción de los bancos de datos	No realizada	Inscribir los bancos "alumnos y apoderados" y "pagos" en el Registro Nacional de Protección de Datos Personales	Dirección
Medidas de seguridad	Parciales: reglas probadas y publicadas (2026-10-24), cabeceras de la SPA, roles de BD, TLS	Respaldo, monitoreo y cabeceras del sitio del colegio (sección siguiente)	Equipo técnico
Transferencia internacional	Datos en Firebase, Vercel y VPS en EE. UU., sin informar	Declararla en la política y en el consentimiento	Dirección
Derechos de acceso, rectificación, cancelación y oposición	Sin procedimiento	Canal y plazo de respuesta	Dirección
Conservación y minimización	Sin regla	Eliminar pre-matrículas no concretadas al cierre de cada ciclo; conservar matrículas y pagos durante el plazo contable	Dirección

El análisis de riesgos, la declaración de aplicabilidad y los procedimientos de incidentes están en el SGSI de Infraestructura.

Cumplimiento y hallazgos reales

Hallazgo (fecha de verificación)	Riesgo	Corrección	Estado
Reglas publicadas el 22-jun-2026: cualquier cuenta se asigna rol de auxiliar o docente, cualquiera lista matrículas pagadas sin sesión y la matrícula pública está bloqueada; 10 de 19 pruebas fallan (2026-10-24)	Escalamiento de privilegios, exposición de datos de menores y pérdida del canal en línea	Reglas corregidas (19 de 19 en el emulador) y publicación solo vía CI tras las pruebas	**Corregido en producción (2026-10-24):** publicado desde la consola; listar matrículas pagadas sin sesión → 403 y pre-matrícula de prueba exitosa (hito H2 cumplido)
Causa raíz: la línea 1 de `firestore.rules` (`#`) impedía compilar y cada despliegue fallaba sin aviso	Versiones probadas que nunca llegan a producción	Comentario válido y trabajo de CI `desplegar-reglas` condicionado	Corregido y publicado (2026-10-24); falta el secreto del CI

Hallazgo (fecha de verificación)	Riesgo	Corrección	Estado
Secretos (ZIP y `.env`) en el historial del repositorio	Exposición de credenciales	Retirar del historial y rotar la clave de servicio (PB-06)	**Tratado (2026-10-24):** clave revocada y reemplazada; contraseñas de `teachers.json` restablecidas; los `.env`, sin contraseñas, siguen versionados por decisión del equipo
La SPA de la academia solo envía HSTS (2026-10-24)	Clickjacking y otros ataques de navegador	`vercel.json` con `X-Content-Type-Options`, `Referrer-Policy`, `Permissions-Policy` y `frame-ancestors` limitado al colegio; falta añadir una política de contenido completa	**Publicado y verificado (2026-10-24)**
El sitio del colegio no envía cabeceras de seguridad y muestra la versión de nginx (2026-10-24)	Clickjacking, detección de tipos y reconocimiento de versión	`server_tokens off` y cabeceras equivalentes en Nginx	Pendiente (RM-04)
El dominio no tiene CAA, SPF, DMARC ni DNSSEC (2026-10-24)	Suplantación del correo institucional y emisión de certificados no autorizada	SPF con el remitente de Google, DKIM, DMARC en modo de monitoreo y luego cuarentena, CAA para la autoridad de los certificados; DNSSEC si el registro lo permite	Pendiente (RM-04)
API del colegio con CORS sin restringir, correo saliente en modo registro y respaldos sin implantar	Acceso entre orígenes y pérdida de datos	Restringir CORS antes de N2; respaldos con `pg_dump` y restauración probada (S2-E3)	Pendiente

Gobernanza

Responsabilidades (RACI): R = responsable, A = rinde cuentas, C = consultado, I = informado.

Actividad	Dirección	Product Owner	Responsable técnico	Equipo EPE	Secretaría
Aprobar alcance, presupuesto y proveedores	A	R	C	I	I
Priorizar el backlog	I	A/R	C	C	C
Publicar cambios en producción	I	C	A/R	R	I
Altas, bajas y claims de acceso	A	C	R	I	I

Actividad	Dirección	Product Owner	Responsable técnico	Equipo EPE	Secretaría
Respaldo y restauración	I	I	A/R	C	—
Protección de datos (política, derechos, inscripción)	A/R	C	C	C	I
Revisión mensual de indicadores	A	R	C	I	I

Objetivos de COBIT 2019 [2] aplicados: EDM01 (marco de gobierno: comité mensual Dirección–Product Owner–técnico) · APO02 (estrategia: roadmap del E1) · APO12 (riesgo: matrices del E1 y E3) · APO13 y DSS05 (seguridad: SGSI y reglas probadas) · BAI06 (cambios: PR con revisión y CI) · BAI08 (conocimiento: transferencia C.5 y documentación) · DSS01 (operación: rutinas de la sección 5.5) · DSS04 (continuidad: respaldos y RTO) · MEA01 (desempeño: indicadores de 5.6) · MEA03 (cumplimiento: Ley N.° 29733).

Políticas mínimas: ningún cambio llega a producción sin revisión de un segundo integrante y CI en verde; mínimo privilegio en todos los roles; respaldo 3-2-1 según CE03; revisión trimestral de accesos; revisión anual de términos y costos de proveedores.

5.4 Escalabilidad y sostenibilidad

Capacidad de crecimiento

Componente	Límite o cuota	Uso estimado 2027 (1 sede)	Uso estimado con 3 sedes	Acción
Firestore: lecturas por día	50 000 gratuitas	≈ 10 500 (21 %)	≈ 31 500 (63 %)	Medir en la consola; pasar al plan de pago por uso si supera el 80 %
Firestore: escrituras por día	20 000 gratuitas	< 500	< 1 500	Ninguna
Firestore: almacenamiento	1 GiB gratuito	Decenas de MB (supuesto)	< 1 GiB	Medir en la consola
Modelo de datos	Sedes, grupos, turnos y horarios	1 sede cargada	Varias sedes sin cambio de modelo	Cargar la oferta real (PB-17)
Capa relacional (VM-APP01 del diseño CE03)	2 vCPU, 4 GB y 60 GB	MySQL < 100 MB en 3 años (supuesto SUP-07 de CE03)	Igual orden	Ninguna
VPS del colegio	2 vCPU y 2 GB	≈ 845 MB proyectados (41 %) con componentes ligeros	—	Prueba de capacidad pendiente; la capa de la academia no se aloja aquí

Estimación de lecturas (supuesto a validar con la pestaña de uso de Firebase): administración 10 sesiones × 400 lecturas + alumnos 60 × 40 + docentes y auxiliar 4 × 200 + padres 30 consultas × 10 + visitantes 200 × 15 ≈ 10 500 al día; con 3 sedes se triplican las sesiones.

Costos futuros

Rubro anual (escenario base del E2)	2027	2028	2029
Hosting comercial de la SPA (Vercel Pro, 1 miembro)	S/ 816	S/ 816	S/ 816
VPS institucional imputado	S/ 122	S/ 122	S/ 122
Firebase	S/ 0	S/ 0	S/ 0
Operación (2 h al mes)	S/ 600	S/ 600	S/ 600
Mantenimiento (3 h al mes)	S/ 900	S/ 900	S/ 900
Total	**S/ 2 438**	**S/ 2 438**	**S/ 2 438**

Fuera del caso base: con 3 sedes, Firebase podría pasar al plan de pago por uso; la reserva del escenario pesimista del E2 (US$ 60 al año) cubre el primer tramo. El host on-premise de CE03 es una inversión institucional aparte. **Palanca de ahorro:** un hosting estático comercial sin costo de licencia elevaría el VAN base en S/ 1 959 (E2, 2.4.5); se evaluará verificando términos y cuotas antes de migrar.

Evolución tecnológica

Componente	Versión actual	Horizonte de soporte	Acción	Cuándo
MySQL 8.0 (imagen del CI)	8.0	Fin de vida en abril de 2026 (vencido)	Migrar a MySQL 8.4 LTS	RM-09 (2027)
Node.js (CI y API)	22 LTS	Hasta abril de 2027	Migrar a Node 24 LTS (soporte hasta abril de 2028)	Primer trimestre de 2027
Python (analítica, CI)	3.11	Seguridad hasta octubre de 2027	Migrar a 3.12 o superior	2027
React y Vite	React 18, Vite 5	React 19 estable desde diciembre de 2024	Actualizar después de tener pruebas de componentes (PB-12)	2027
PHP (colegio)	8.4	Soporte activo hasta dic-2026 y de seguridad hasta dic-2028	Planificar la siguiente versión	2028
PostgreSQL (colegio)	16	Hasta noviembre de 2028	Migrar a una versión mayor	2028
Ubuntu (VPS)	24.04 LTS	Soporte estándar hasta 2029	—	2029

Sostenibilidad organizacional: transferencia de conocimiento al responsable técnico de CERMAT (C.5), revisión por pares, documentación de este perfil de egreso, CI con 90 pruebas que permite cambiar sin miedo y un presupuesto anual de mantenimiento aprobado.

5.5 Plan de implementación y gestión del sistema de información (CE0144)

Fases

Fase	Periodo	Contenido	Responsable	Criterio de salida
F0 Estabilización	2026-10-24 a 2026-11-20	Sprints 1 y 2: reglas publicadas, migraciones, secretos, capa relacional continua, monitor	Equipo EPE	H2 y H3 del E3 cumplidos
F1 Adopción en la sede principal	2026-11-23 a 2027-03-31	Sprint 3, capacitación, campaña 2027 y medición	Product Owner y equipo	Hito de continuidad aprobado (H8)
F2 Integración N0–N1	2027-04 a 2027-06	Enlace, subdominio institucional (si la Dirección lo aprueba) y oferta pública	Responsable técnico	Enlace activo; subdominio con TLS si se aprueba
F3 Integración N2–N3	2028	API REST con el colegio e identidad compartida del personal	Responsable técnico	Contrato OpenAPI publicado y pruebas de integración en verde
F4 Notificaciones y multi-sede	2028–2029	Correo autenticado, todas las sedes y analítica de retención	Dirección y responsable técnico	Sedes cargadas = sedes reales

Capacitación

Rol	Contenido	Duración	Modalidad y material	Evaluación
Secretaría (2 personas)	Registro rápido, revisión de pre-matrículas, pagos y cuotas, aprobación, envío del enlace, cancelación y reportes	3 h	Práctica guiada con datos de prueba; manual de una página	Matricular, cobrar y aprobar un caso sin ayuda
Auxiliar (1 persona)	Escaneo de QR, registro excepcional y día de asistencia	3 h	Práctica en la puerta de ingreso; manual de una página	Registrar 10 ingresos sin errores
Docentes (3 personas)	Portal docente, recursos y asistencia	2 h	Taller corto; manual de una página	Publicar un recurso y revisar asistencia

Rol	Contenido	Duración	Modalidad y material	Evaluación
Dirección	Lectura de indicadores y decisiones del hito de continuidad	Dentro de las revisiones de sprint	Tablero mensual	—
Responsable técnico de CERMAT	Despliegue, reglas, respaldo y restauración, monitor e incidentes	16 h	Transferencia con el líder del equipo	Desplegar y restaurar solo
Padres	Consulta de asistencia por código	—	Guía breve entregada al matricular	Consultas registradas (IU-04)

Soporte y operación

Nivel	Quién	Atiende	Tiempo objetivo de respuesta (propuesto)
N1	Administrador de la academia (secretaría)	Dudas de uso, altas y bajas, reenvío de enlaces	Mismo día
N2	Responsable técnico de CERMAT	Incidentes, despliegues, respaldos y accesos	Severidad 1 (matrícula o pagos caídos, exposición de datos): 1 h para responder y 4 h para resolver o revertir; severidad 2: 4 h y 2 días
N3	Equipo desarrollador y proveedores (Firebase, Vercel, RackNerd)	Defectos de código y fallas de plataforma	Según el canal de soporte del proveedor

Rutina	Tareas
Diaria	Revisar alertas del monitor y `/health`; atender pre-matrículas pendientes de más de 24 h
Semanal	Revisar la conciliación (`v_conciliacion_pagos` = 0 filas), verificar el último respaldo y aplicar actualizaciones de seguridad
Mensual	Restauración de prueba, revisión de claims de administrador, tablero de indicadores y costos de proveedores
Por ciclo	Configurar la oferta, cerrar el ciclo anterior y depurar pre-matrículas no concretadas

Continuidad: SPA RTO de 15 min promoviendo el despliegue anterior en Vercel; MySQL RTO de 1 h y RPO de 24 h (diseño CE03; restauración ya medida en 0,23 s en la base real y en 0,27–0,38 s en la base de prueba; el respaldo diario falta programarlo); Firestore RPO ≤ 24 h cuando exista la exportación programada (PB-11).

5.6 Indicadores de uso, valor y mejora (CE0145)

Línea base real: conteos agregados de Firestore al 2026-10-24, sin datos personales. Lo no medido se indica como tal; no se presenta el piloto como adopción masiva.

ID	Indicador	Fórmula	Línea base real	Meta 2027	Fuente	Frecuencia
Uso						
IU-01	Adopción	Matrículas en la plataforma ÷ matrículas totales	8 matrículas (2 pendientes, 5 pagadas, 1 cancelada) del 2026-01-27 al 2026-07-07; total por medir	≥ 60 %	Firestore y registro de secretaría	Mensual
IU-02	Usuarios con perfil	Perfiles por rol	8 (4 alumnos, 3 docentes, 1 auxiliar; administradores por claim)	100 % de los alumnos matriculados con cuenta activa	`users`	Mensual
IU-03	Asistencia digital	Días lectivos con marcas QR ÷ días lectivos	7 registros, solo del 2026-01-27 al 2026-04-02	≥ 95 %	`attendanceLogs`	Mensual
IU-04	Familias que consultan	Alumnos con al menos una consulta de su padre en el mes ÷ alumnos activos	0 consultas registradas	≥ 50 %	Consultas por código	Mensual
IU-05	Captación en línea	Pre-matrículas públicas que pasan a pagadas por ciclo	Por medir (canal bloqueado en producción)	≥ 2 adicionales por ciclo	`enrollments`	Por ciclo
IU-06	Oferta cargada	Ciclos, grupos y sedes reales cargados ÷ existentes	1 ciclo, 1 grupo y 1 sede	100 % de la oferta 2027	`cycles`, `groups`, `campuses`	Por ciclo
IU-07	Contenidos y contacto	Publicaciones al mes; mensajes de contacto atendidos en ≤ 24 h	6 recursos, 1 post, 1 taller; 7 mensajes de contacto (atención no medida)	≥ 2 publicaciones al mes; 100 % atendidos en ≤ 24 h	`resources`, `posts`, `workshops`, `messages`	Mensual
Valor						
IV-01	Minutos de personal por matrícula	Promedio de 10 trámites cronometrados	≈ 40 min (supuesto; se mide en nov-2026)	≤ 12 min	Cronometraje	Por ciclo

ID	Indicador	Fórmula	Línea base real	Meta 2027	Fuente	Frecuencia
IV-02	Tiempo de respuesta a la pre-matrícula	p90 de (`approvedAt` o `cancelledAt`) − `createdAt`	No medible (2 registros de prueba de ≈ 1 min)	≤ 24 h	`enrollments`	Semanal en campaña
IV-03	Costo de personal por matrícula	Σ minutos × costo hora	S/ 8,33 (supuesto)	≤ S/ 2,50	Cronometraje y supuestos	Por ciclo
IV-04	Incidentes de sobrecupo o duplicado	Conteo por ciclo	No medible en el proceso manual	0	`groups` y `enrollments`	Por ciclo
IV-05	Retención	Alumnos en riesgo contactados que terminan el ciclo	Por medir (sin marcas de asistencia desde abril)	≥ 1 retenido por ciclo	`sp_riesgo_inasistencia` y seguimiento	Por ciclo
IV-06	Morosidad	Saldo vencido ÷ ingreso del ciclo	Por medir; 2 pagos confirmados y 0 anulados en la plataforma	−0,5 puntos	`v_estado_cuenta`	Mensual
IV-07	VAN recalculado (vista A)	Libro del E2 con datos reales	S/ 1 247 (proyectado)	≥ 0	`business-case.xlsx`	31-03-2027 y anual
Mejora						
IM-01	Seguridad de las reglas publicadas	Pruebas de reglas que pasan contra la versión publicada	9 de 19 con las reglas de junio; tras publicar la versión corregida (2026-10-24), 0 fallas observadas en producción	19 de 19	CI y emulador	Cada publicación
IM-02	Cumplimiento de privacidad	Ítems cumplidos: política, consentimiento, inscripción, transferencia informada y procedimiento de derechos	0 de 5	5 de 5	Lista de verificación	Trimestral
IM-03	Disponibilidad	Minutos disponibles ÷ minutos del mes	No medida	≥ 99 %	Monitor externo	Mensual

ID	Indicador	Fórmula	Línea base real	Meta 2027	Fuente	Frecuencia
IM-04	Recuperabilidad	Restauraciones de prueba exitosas; RPO de Firestore	MySQL: base real restaurada en 0,23 s (REC-05, 2026-10-24) y base de prueba en 0,27–0,38 s; Firestore sin respaldo	1 restauración al mes; RPO ≤ 24 h	Registro de restauraciones	Mensual
IM-05	Integridad de la réplica	Filas en `v_conciliacion_pagos`	Vista disponible; sincronización intermitente	0	MySQL	Semanal
IM-06	Integración con el colegio	Niveles de integración activos y procesos con datos compartidos	0	N0 y N1 activos en 2027; ≥ 2 procesos en 2028	Inventario de integraciones	Semestral
IM-07	Calidad del cambio	Pruebas automáticas; cambios revisados por un segundo integrante	90 pruebas; 0 revisiones registradas	En aumento; 100 % revisados	CI y repositorio	Por sprint
IM-08	Seguridad web y DNS	Cabeceras de seguridad publicadas en ambos sitios; registros CAA, SPF, DMARC y DNSSEC	SPA con cabeceras publicadas el 2026-10-24 (antes solo HSTS); colegio sin cabeceras; 0 de 4 registros	Cabeceras completas; 4 de 4 (DNSSEC si el registro lo permite)	Verificación externa	Trimestral

Ciclo de revisión: el Product Owner prepara el tablero mensual con conteos agregados de Firestore y las vistas de MySQL (`v_estado_cuenta`, `v_asistencia_diaria`, `v_conciliacion_pagos`); la Dirección lo revisa en el comité mensual; cada trimestre se revisan costos y proveedores y cada año se recalcula el business case. Los indicadores de proceso IP-01 a IP-03 del E4 complementan esta tabla.

Referencias

[1] ISO/IEC 27001:2022, *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. Ginebra, Suiza: ISO, 2022.

[2] ISACA, *COBIT 2019 Framework: Governance and Management Objectives*. Schaumburg, IL, USA: ISACA, 2018.

[3] Congreso de la República del Perú, "Ley N.° 29733, Ley de Protección de Datos Personales," *Diario Oficial El Peruano*, 3 de julio de 2011.

[4] OpenAPI Initiative, *OpenAPI Specification v3.1.0*, feb. 2021. [En línea]. Disponible: https://spec.openapis.org/oas/v3.1.0

[5] D. Hardt, Ed., "The OAuth 2.0 Authorization Framework," RFC 6749, IETF, oct. 2012.

[6] N. Sakimura, J. Bradley, M. Jones, B. de Medeiros y C. Mortimore, "OpenID Connect Core 1.0," OpenID Foundation, 2014.

[7] M. Kucherawy y E. Zwicky, Eds., "Domain-based Message Authentication, Reporting, and Conformance (DMARC)," RFC 7489, IETF, mar. 2015.

[8] OWASP Foundation, "OWASP Secure Headers Project." [En línea]. Disponible: https://owasp.org/www-project-secure-headers/

Rúbrica de evaluación

Criterio	Excelente	Bueno	Regular	Deficiente
Diseño de arquitectura	Arquitectura estructurada, integrada y alineada al ecosistema SI.	Arquitectura coherente con integración definida.	Arquitectura básica sin integración clara.	No presenta arquitectura clara.
Integración con sistemas existentes	Diseña integración completa considerando interoperabilidad y seguridad.	Define integración básica con sistemas existentes.	Integración mencionada sin detalle técnico.	No considera integración.
Sustento técnico y escalabilidad	Justifica solución considerando seguridad, escalabilidad y sostenibilidad.	Sustenta técnicamente la solución.	Justificación limitada.	Sin justificación técnica.
Sustentación y defensa técnica	Explica y defiende con dominio las decisiones tomadas.	Explica con solvencia.	Explica con dificultad.	No sustenta.

B. Ingeniería de Software (CE02)

E1 - Requerimientos y Diseño del Sistema (CE021)

Evidencia CE021 — Ingeniería de Requerimientos

Define, valida y diseña la solución de software: especificación de requerimientos, prototipo navegable, arquitectura C4 con registro de decisiones y diseño detallado en UML, con trazabilidad desde cada requerimiento hasta el código y las pruebas automáticas.

Portada

Campo	Detalle
Título del sistema	Plataforma Web Integral de Gestión Académica CERMAT
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo)
Fecha	2026-10-24
Despliegue	https://academia-school-platform.vercel.app

Resumen Ejecutivo

Problema. La Academia La Prepa Cermat (Azángaro, Puno) gestionaba la oferta de ciclos, las matrículas, los pagos y la asistencia con registros dispersos. Eso producía duplicados, riesgo de sobrepasar los cupos, pagos desvinculados de la matrícula y ningún canal de consulta para los padres.

Usuarios. Visitantes y postulantes, administradores, docentes, estudiantes, auxiliares y padres o apoderados. Tienen 6 portales con permisos diferenciados.

Alcance. 22 requerimientos funcionales y 10 no funcionales: sitio público, matrícula en línea, gestión académica, pagos, asistencia por QR, consulta para padres, contenidos y sincronización a una base relacional. Quedan fuera la app móvil nativa, la pasarela de pagos y la facturación electrónica.

Solución. Una aplicación web (SPA en React y TypeScript) publicada en Vercel, con Firebase como identidad y base operativa protegida por reglas por rol. Una capa relacional complementaria (API Node.js, MySQL y analítica en Python) cubre reportes y continuidad. El diseño se documenta con vistas C4, 7 decisiones arquitectónicas y diagramas UML. Cada requerimiento se traza hasta su código y, cuando existe, hasta su prueba automática (90 pruebas en el proyecto).

Sección 1: Especificación de Requerimientos

1.1 Requerimientos funcionales

ID	Descripción
RF01	El sistema debe mostrar una página pública de inicio con información institucional y acceso a la oferta académica.
RF02	El sistema debe listar los ciclos académicos publicados y permitir ver su detalle.
RF03	El sistema debe permitir la pre-matrícula pública seleccionando ciclo, grupo, sede, turno y modalidad de pago.
RF04	El sistema debe impedir pre-matrículas en ciclos no publicados o cerrados, en grupos que no pertenecen al ciclo y en grupos sin cupo.
RF05	El administrador debe gestionar ciclos académicos, categorías, sedes y grupos con capacidad, turno y horario.
RF06	El administrador debe gestionar matrículas y sus estados (pendiente, pagado, cancelado) con trazabilidad del autor.
RF07	El administrador debe registrar pagos asociados a matrículas (método, monto, cuota y comprobante) y anularlos sin borrarlos.
RF08	El administrador debe gestionar alumnos, docentes y auxiliares, de forma individual o masiva por Excel.
RF09	El sistema debe activar cuentas de estudiantes, docentes y auxiliares mediante invitaciones de un solo uso.
RF10	El docente debe acceder a sus cursos y consultar los alumnos asociados.
RF11	El docente debe acceder a los recursos académicos asignados o creados por él.
RF12	El sistema debe registrar la asistencia de estudiantes con su QR permanente firmado.
RF13	El sistema debe registrar la asistencia de docentes con un QR diario validado por token y ventana horaria.
RF14	El auxiliar debe operar los paneles de asistencia según sus permisos.
RF15	El estudiante debe ver su panel, cursos, recursos, matrícula, talleres y asistencia.
RF16	El padre debe consultar la asistencia de su hijo con un código CERMAT, sin acceso administrativo.
RF17	El administrador debe publicar y administrar recursos académicos.
RF18	El administrador debe publicar y administrar entradas del blog.

ID	Descripción
RF19	El administrador debe administrar talleres y su visibilidad pública.
RF20	El sistema debe registrar los mensajes de contacto del sitio público.
RF21	El sistema debe sincronizar matrículas, pagos y asistencia a la base relacional cuando el servicio esté habilitado.
RF22	El sistema debe proteger las rutas por rol: admin, docente, estudiante, auxiliar y padre.

1.2 Requerimientos no funcionales

ID	Tipo (ISO/IEC 25010)	Descripción	Verificación
RNF01	Seguridad	Toda lectura y escritura se autoriza con Firebase Auth, claims, documento de rol y reglas de Firestore.	19 pruebas de reglas en emulador
RNF02	Usabilidad	La interfaz es adaptable a móvil y separa los flujos público, administrativo y privado.	Capturas de escritorio y móvil (Sección 2)
RNF03	Eficiencia	Las consultas usan filtros compatibles con los índices de Firestore.	Revisión de consultas
RNF04	Mantenibilidad	El código se organiza por dominio en `src/features/*` (`api.ts`, `hooks.ts`, `schemas.ts`, `types.ts`).	Estructura del repositorio
RNF05	Disponibilidad	La operación depende de Firebase; si la capa relacional falla, el flujo principal continúa.	Sincronización no bloqueante
RNF06	Integridad	Matrículas, pagos y asistencia conservan estados, fechas y responsables, y no se borran físicamente.	Reglas y triggers con pruebas
RNF07	Escalabilidad	Se agregan módulos sin reestructurar la aplicación.	13 módulos de dominio independientes
RNF08	Compatibilidad	SPA con build Vite y rutas de React Router en navegadores modernos.	Build en el pipeline de CI
RNF09	Validación	Los formularios se validan con esquemas Zod antes de escribir.	Pruebas unitarias de esquemas

ID	Tipo (ISO/IEC 25010)	Descripción	Verificación
RNF10	Auditoría	Las acciones críticas registran responsable, fecha y estado.	Tabla `auditoria` y campos `*By`

1.3 Reglas de negocio

Cada regla está aplicada en el código o en las reglas de seguridad, no solo descrita.

ID	Regla	Dónde se aplica
RN01	Solo se admite pre-matrícula en ciclos publicados con estado "activo" o "nuevo".	`firestore.rules` (`isEnrollmentCycleOpen`)
RN02	El grupo debe pertenecer al ciclo, y la sede, su identificador y el turno deben coincidir con los del grupo.	`firestore.rules` (`isEnrollmentGroupInCycle` , `isEnrollmentGroupCampusValid`)
RN03	Un mismo teléfono solo puede tener una pre-matrícula por grupo.	Id determinístico `grupo__teléfono` en `createEnrollment`
RN04	Cada pre-matrícula descuenta un cupo y el cupo nunca supera la capacidad del grupo.	Transacción en `createEnrollment` y regla `isPublicEnrollmentSeatIncrement`
RN05	Los estados de la matrícula solo cambian por las transiciones permitidas (Sección 4.4). La activación la hace el propio alumno con una invitación válida.	`isAdminEnrollmentUpdateAllowed` y regla de activación
RN06	Solo un administrador registra pagos; el monto es mayor que 0; un pago no se elimina, solo se anula indicando quién lo hizo.	Reglas de `payments` y trigger `trg_pagos_bd`
RN07	El número de cuota no puede superar las cuotas pactadas en la matrícula.	Trigger `trg_pagos_bi` (réplica relacional)
RN08	Las cuentas de auxiliar y docente solo se crean con una invitación vigente de un solo uso.	`firestore.rules` (`hasUsableInvite`)
RN09	La marca de un alumno exige su QR firmado y la registra un auxiliar o administrador. Entrada y salida alternan en el día. El docente marca con el QR diario dentro de su ventana y no puede marcar salida sin entrada.	`isStudentAttendanceCreate` , `isTeacherAttendanceCreate` , `attendanceDayState`
RN10	El código de los padres tiene formato `CERMAT-XXXX-XXXX` , sin caracteres ambiguos (0, O, 1, I), y puede revocarse.	`src/lib/parentAccess.ts`
RN11	Matrículas y pagos no se borran físicamente: se cancelan o anulan.	`allow delete: if false` en las reglas

1.4 Restricciones del sistema

Tipo	Restricción
Tecnológica	La operación principal depende de Firebase (cuotas del plan del proveedor) y las consultas están sujetas a los índices de Firestore.
Tecnológica	Requiere un navegador moderno con JavaScript y conexión a Internet; no hay modo sin conexión.
Operativa	Las fechas de asistencia usan la zona horaria de Perú (America/Lima).
Operativa	La capa relacional (API, MySQL y analítica) es complementaria: su caída no detiene matrícula, pagos ni asistencia.
Legal	El sistema trata datos personales de menores de edad: aplica la Ley N.° 29733 de Protección de Datos Personales.
Alcance	Sin app móvil nativa, pasarela de pagos, facturación electrónica ni integración con ERP.
Despliegue	La academia usa su propio dominio en Vercel, separado del sistema de gestión del colegio (cermatschool.edu.pe).

1.5 Historias de usuario y criterios de aceptación

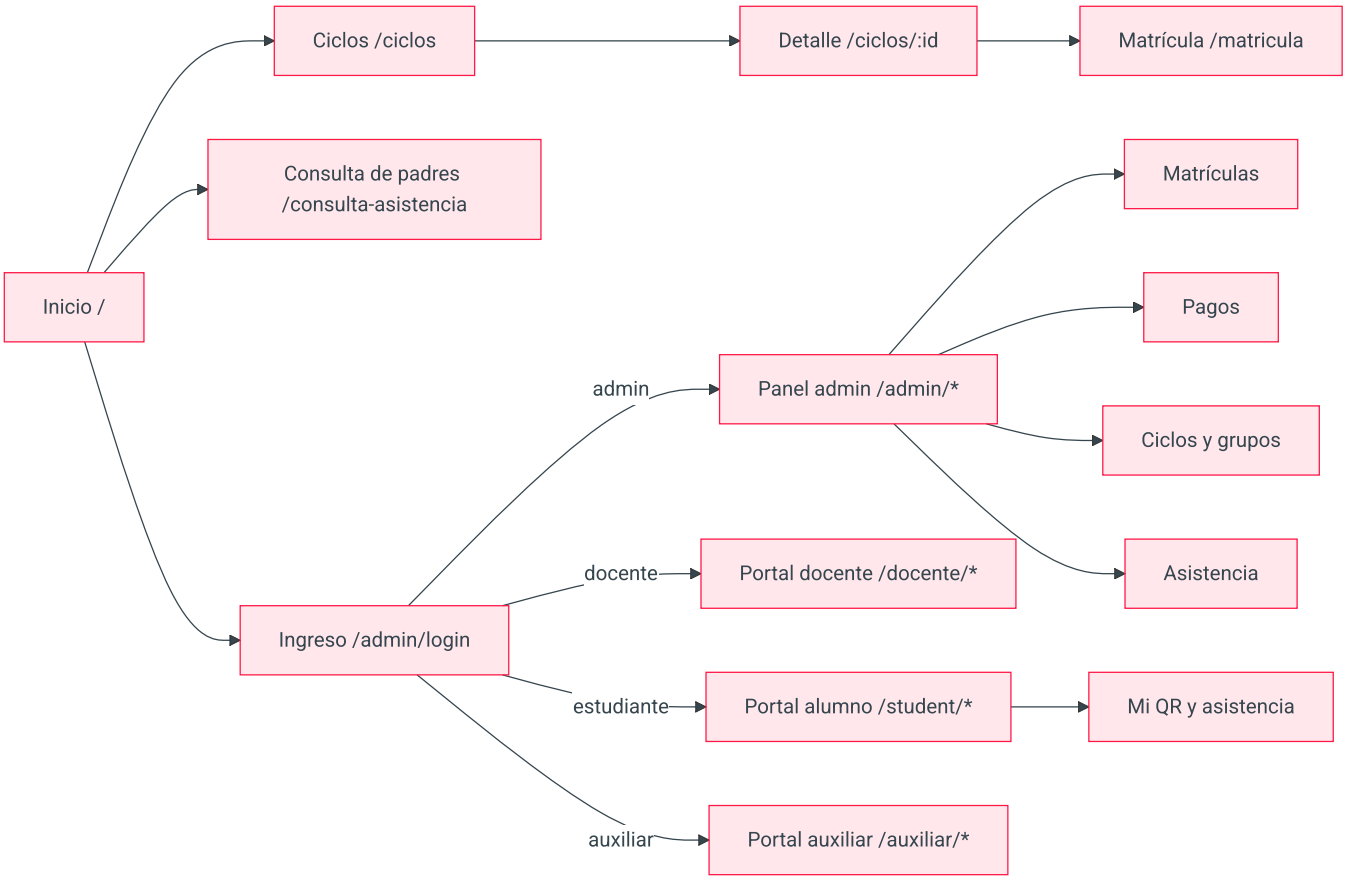
ID	Historia	Criterios de aceptación	RF
HU01	Como **postulante** quiero pre-matricularme sin crear cuenta para reservar mi cupo.	**Dado** un ciclo abierto con cupo, **cuando** envío el formulario, **entonces** queda en "pendiente" y se descuenta 1 cupo. Mismo teléfono en el grupo: mensaje de duplicado. Ciclo cerrado o grupo lleno: rechazo.	RF03, RF04
HU02	Como **administrador** quiero aprobar, cancelar o reabrir matrículas para controlar el proceso.	Solo se aceptan las transiciones de la Sección 4.4. Cada cambio registra quién lo hizo.	RF06
HU03	Como **administrador** quiero registrar y anular pagos para llevar la caja.	Solo admin. Monto mayor que 0. No se borra. La anulación registra el autor.	RF07
HU04	Como **estudiante** quiero activar mi cuenta con el enlace recibido al pagar.	El enlace es de un solo uso y vence. Al activarse, la matrícula pasa a "activo".	RF09
HU05	Como **auxiliar o docente invitado** quiero activar mi cuenta.	Sin invitación, o con una vencida o de otra persona, no se crea el perfil. Reintentar con la propia sí funciona.	RF09, RF22

ID	Historia	Criterios de aceptación	RF
HU06	Como **auxiliar** quiero registrar la asistencia escaneando el QR del alumno.	El QR firmado se acepta. El formato antiguo se detecta. Entrada y salida alternan. Un reenvío no duplica.	RF12, RF14
HU07	Como **docente** quiero marcar mi asistencia con el QR del día.	Solo dentro de la ventana del token. No hay salida sin entrada previa.	RF13
HU08	Como **padre** quiero consultar la asistencia con un código fácil de dictar.	Acepta minúsculas, espacios y el código sin prefijo. Un código revocado no muestra datos.	RF16
HU09	Como **administrador** quiero dar de alta alumnos o docentes desde un Excel.	Una fila con error no detiene el lote. El error indica la fila real del archivo.	RF08
HU10	Como **Dirección** quiero ver los alumnos en riesgo de abandono.	Calcula sobre días lectivos, incluye a quien nunca asistió y excluye a los docentes.	RF21

Sección 2: Prototipo Navegable

2.1 Fidelidad y flujo de navegación

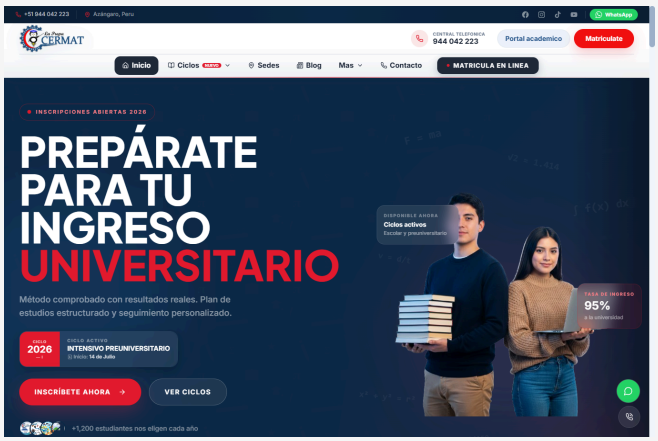
El prototipo es de **alta fidelidad**: es el propio sistema desplegado y navegable en academia-school-platform.vercel.app, con 55 rutas protegidas por 6 guardas de rol.



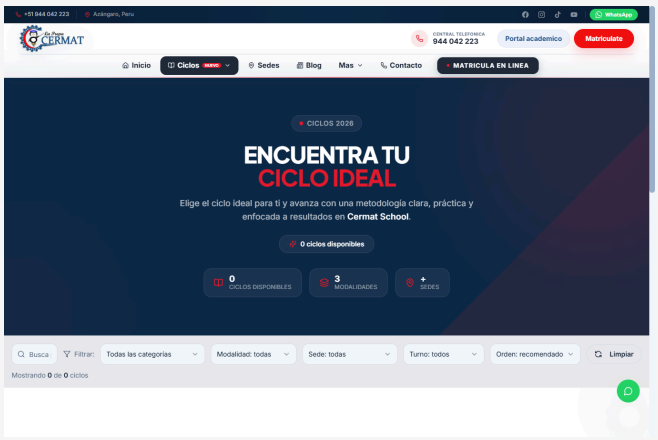
2.2 Pantallas principales

Capturas del sitio desplegado tomadas el 2026-10-24:

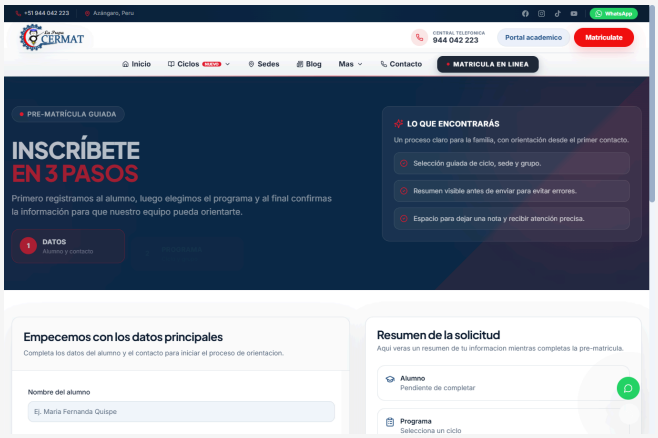
Inicio



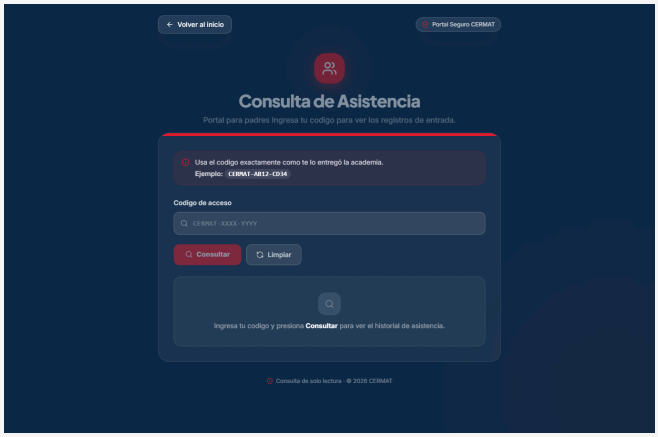
Ciclos

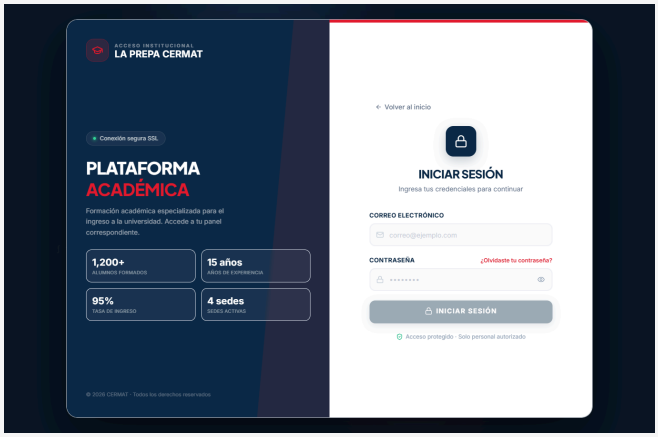
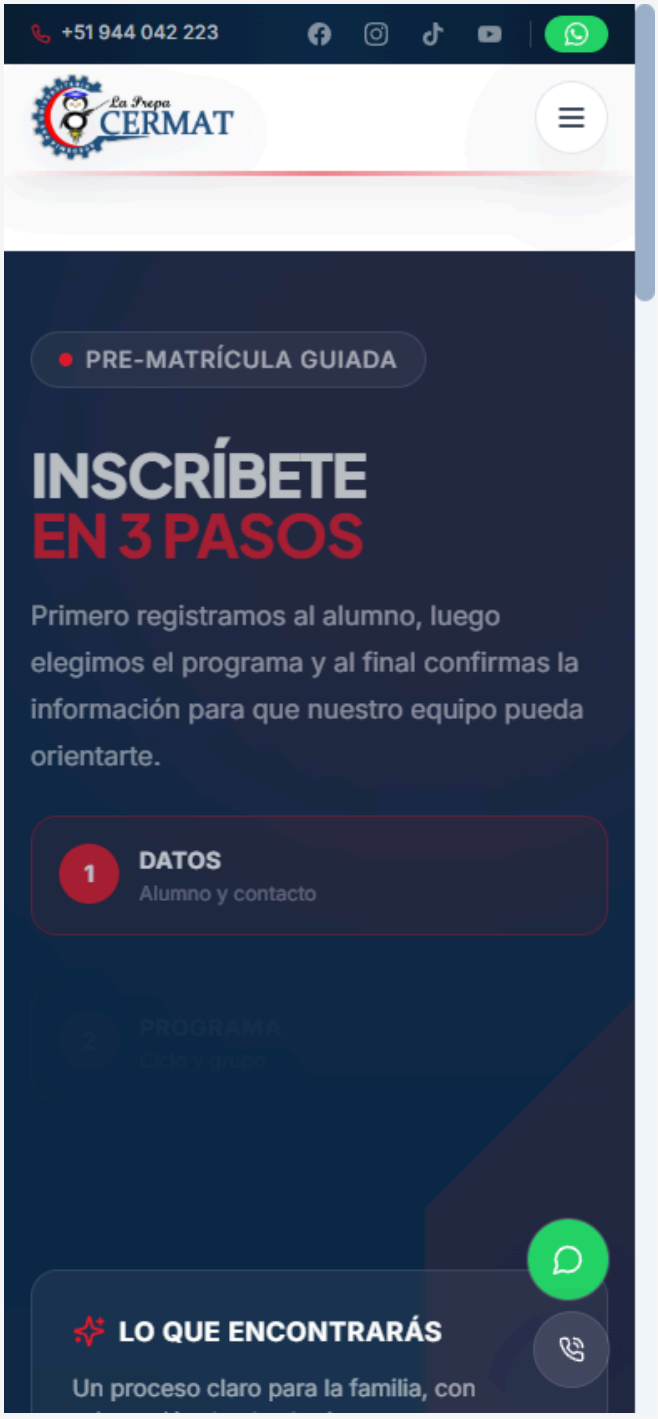


Matrícula en línea



Consulta de asistencia para padres



Ingreso a los portales	Matrícula en móvil (RNF02)
	

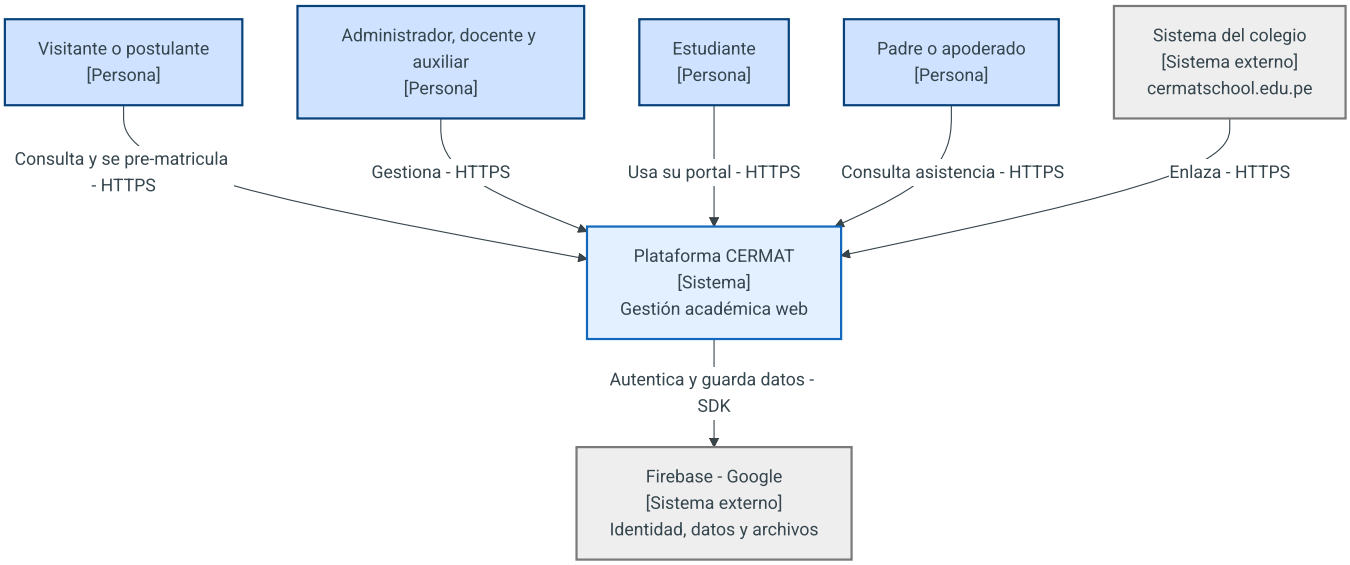
2.3 Evidencia de validación con usuarios

Aspecto	Estado
Validación funcional con el equipo	Recorridos de los flujos críticos y 90 pruebas automáticas (ver E4)
Uso real en piloto	Conteos de Firestore al 2026-10-24: 8 matrículas, 2 pagos, 7 marcas de asistencia, 8 usuarios con perfil
Validación con la Dirección y usuarios finales	**Pendiente de acta firmada.** Protocolo propuesto: recorrido guiado de HU01–HU08 con la Dirección, un docente y un auxiliar; registro de observaciones y conformidad en el acta del Anexo A.

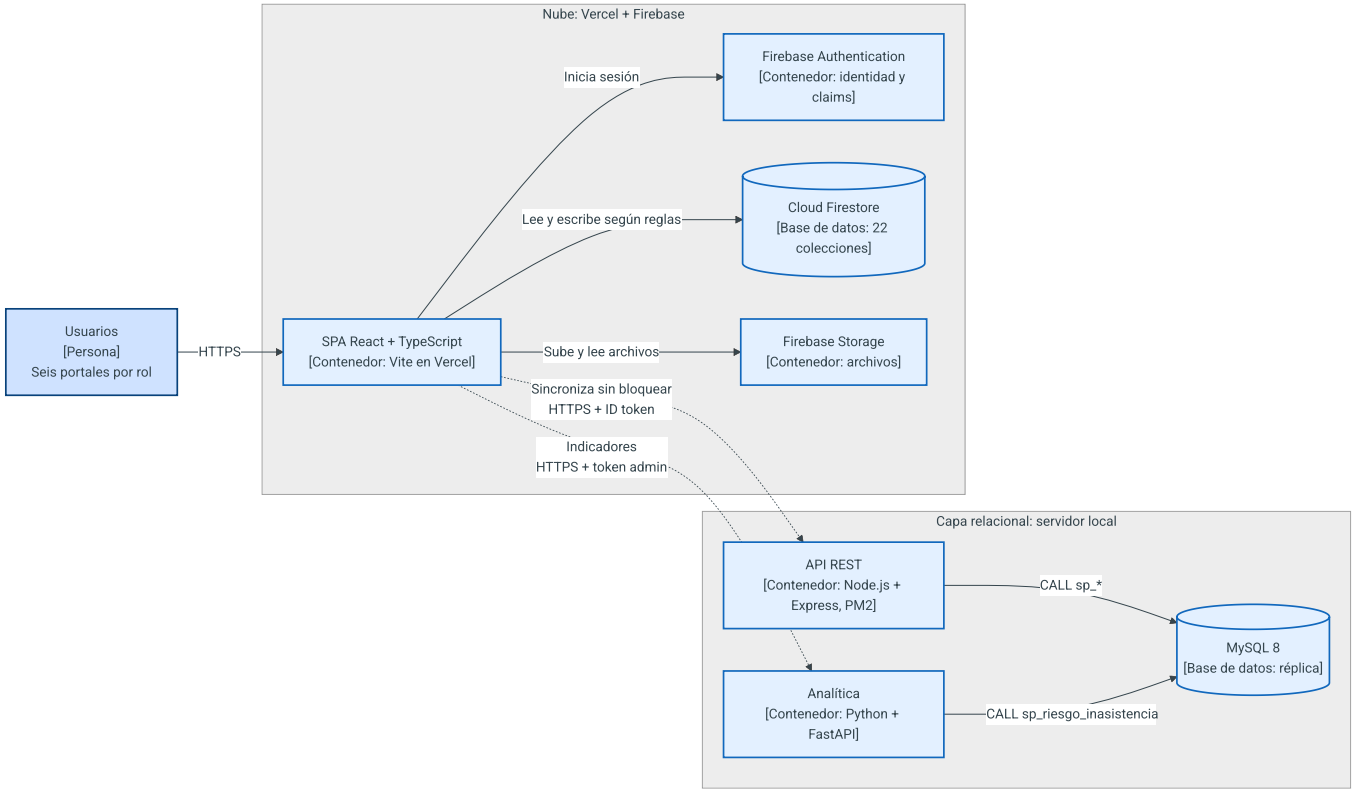
Sección 3: Diseño Arquitectónico

3.1 C1 — Contexto del sistema

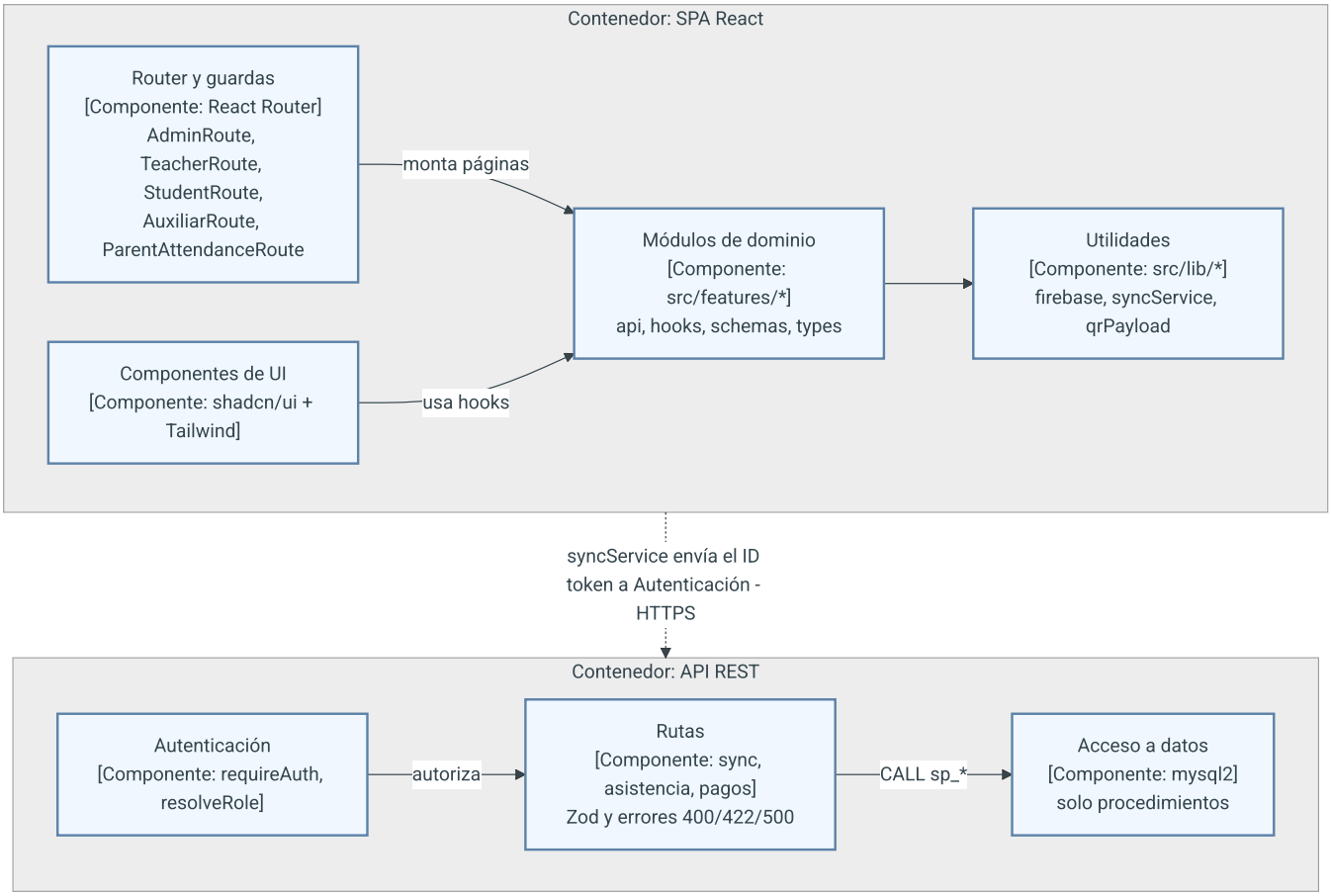
Notación C4 en todas las vistas: persona (borde azul oscuro), sistema o contenedor propio (borde azul), sistema externo (gris) y base de datos (cilindro).



3.2 C2 — Contenedores (cumple el rol de vista de despliegue)



3.3 C3 — Componentes de la SPA y de la API



3.4 Registro de decisiones arquitectónicas (ADR)

ADR	Contexto	Decisión	Consecuencias	Estado
ADR-01	Equipo pequeño, sin servidor propio permanente, con necesidad de tiempo real y control de acceso por rol	Firebase como backend principal (Auth, Firestore, Storage) con reglas declarativas	Sin servidor que mantener para la operación diaria. La seguridad depende de reglas que deben probarse y publicarse (ver ADR-07).	Aceptada
ADR-02	Firestore no resuelve bien reportes agregados ni conciliaciones	Réplica relacional en MySQL, escrita solo mediante procedimientos almacenados	Reportes SQL, integridad por FK y CHECK, y auditoría. La cuenta de la API no puede escribir tablas directamente.	Aceptada
ADR-03	La réplica no debe detener la operación si falla	Sincronización no bloqueante, idempotente y con vista de conciliación	Un fallo de la API no afecta al usuario. Los eventos perdidos se detectan en `v_conciliacion_pagos`.	Aceptada

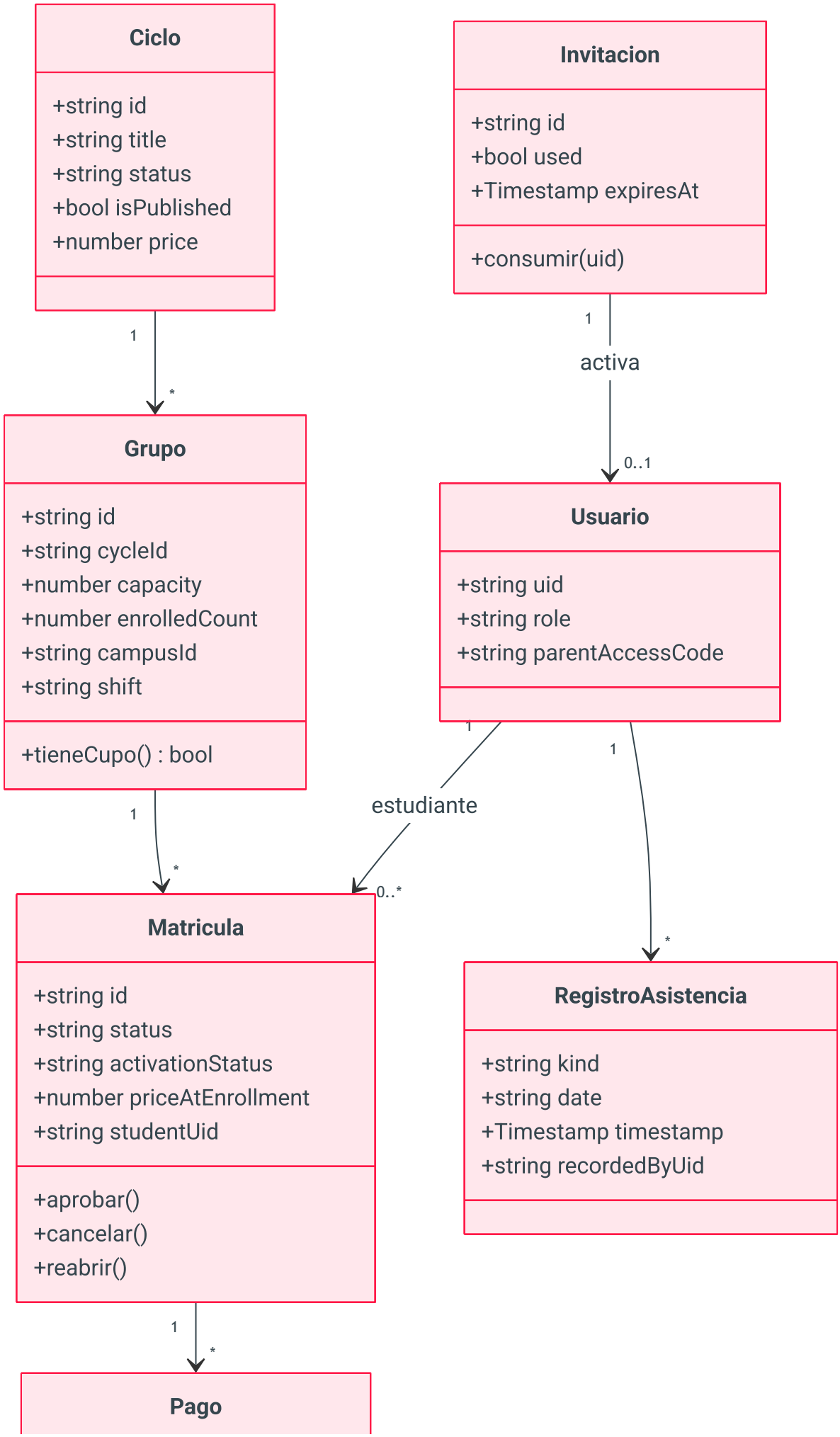
ADR	Contexto	Decisión	Consecuencias	Estado
ADR-04	Muchos dominios que crecen en paralelo	Arquitectura modular por dominio en `src/features/*`	Módulos predecibles y probables por separado. Algunas páginas siguen siendo grandes (deuda registrada en E4).	Aceptada
ADR-05	Riesgo de sobrecupo y duplicados en la matrícula pública sin sesión	Transacción con id determinístico `grupo__teléfono` y regla que solo permite sumar un cupo junto con la nueva pre-matrícula	Sin sobrecupo aun con solicitudes simultáneas. Para el visitante, un duplicado se ve como permiso denegado (mensaje explicado).	Aceptada
ADR-06	Un QR con solo el id del alumno puede falsificarse	QR permanente firmado (firma en `studentQrSignatures`) más estado diario transaccional (`attendanceDayState`)	No se aceptan QR reconstruidos ni dobles marcas simultáneas. Requiere regenerar los QR del formato antiguo.	Aceptada
ADR-07	Las reglas publicadas quedaron 4 meses desactualizadas	Las reglas se prueban en un emulador y se publican solo desde el pipeline de CI	Ninguna regla sin probar llega a producción. Requiere configurar el secreto de despliegue; mientras falte, la versión corregida se publicó desde la consola el 2026-10-24, después de pasar las 19 pruebas.	Aceptada (2026-10-24)

Sección 4: Diseño Detallado

4.1 Diagrama de casos de uso



4.2 Diagrama de clases del dominio


Ciclo
+string id
+string title
+string status
+bool isPublished
+number price
1
*
Grupo
+string id
+string cycleId
+number capacity
+number enrolledCount
+string campusId
+string shift
+tieneCupo() : bool
1
*
Invitacion
+string id
+bool used
+Timestamp expiresAt
+consumir(uid)
1
activa
0..1
Usuario
+string uid
+string role
+string parentAccessCode
1
estudiante
0..*
1
*
Matricula
+string id
+string status
+string activationStatus
+number priceAtEnrollment
+string studentUid
+aprobar()
+cancelar()
+reabrir()
1
*
Pago
RegistroAsistencia
+string kind
+string date
+Timestamp timestamp
+string recordedByUid

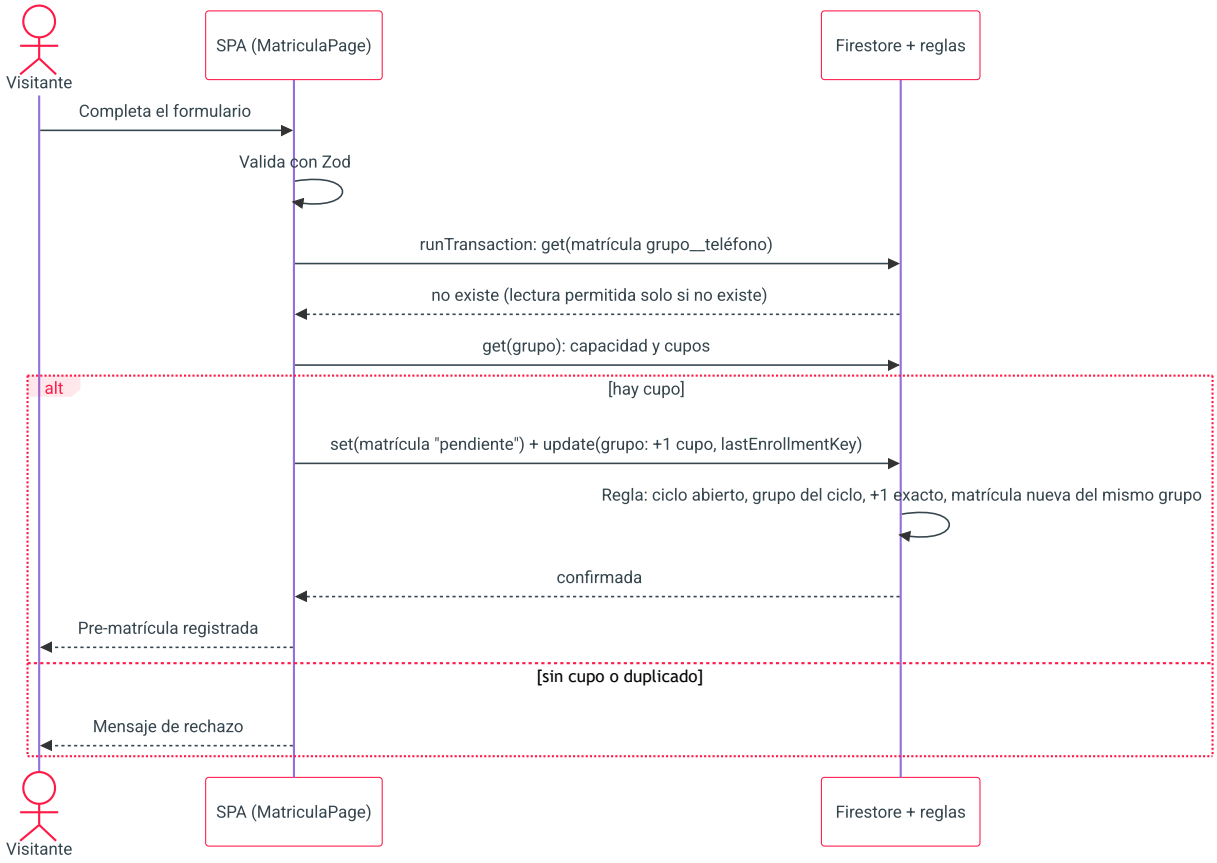
+string id
+number amount
+string method
+number installmentNumber
+string status

+anular(autor)

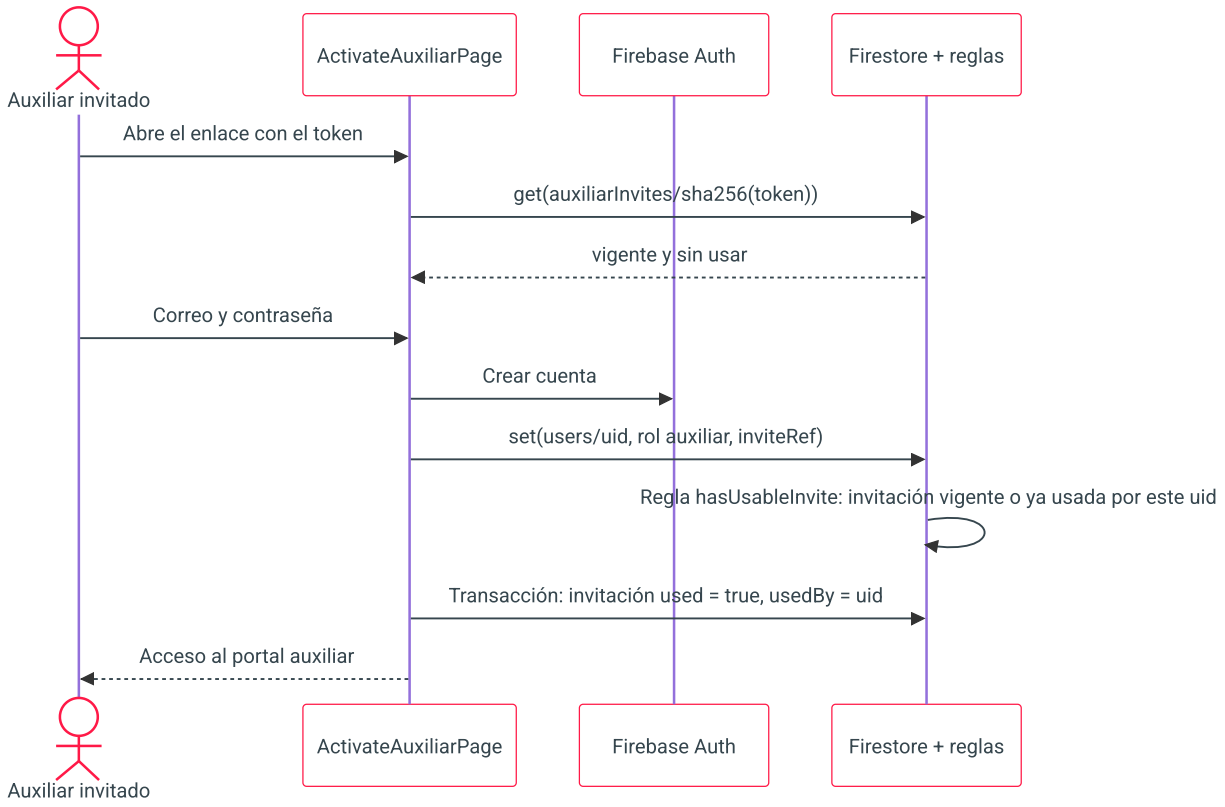
El id de `Matricula` es determinístico (`grupo__teléfono`, RN03) y el de `Invitacion` es el SHA-256 del token enviado por enlace: el token nunca se guarda.

4.3 Diagramas de secuencia

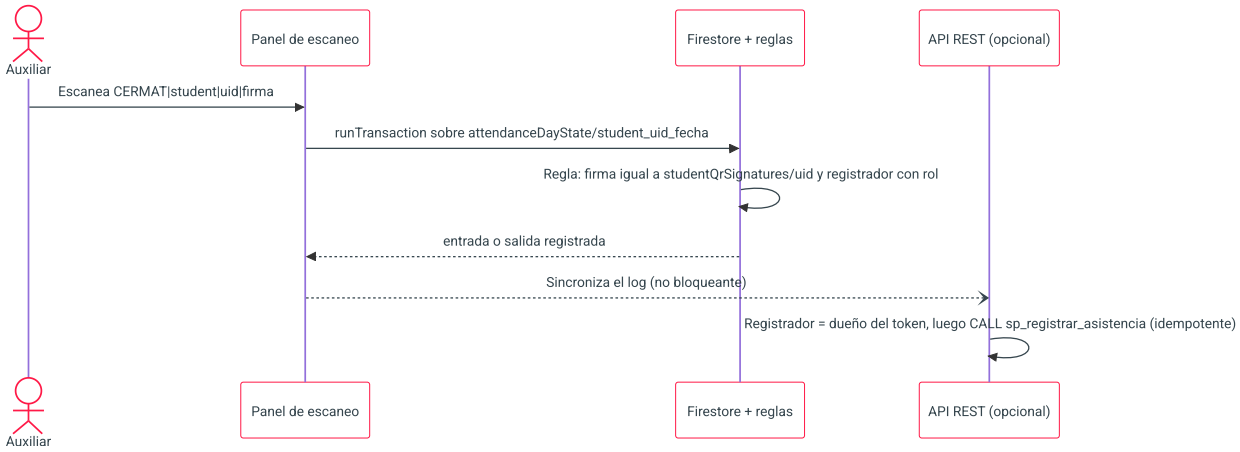
Pre-matrícula pública con control de cupo (HU01, ADR-05):



Activación por invitación (HU05, RN08):

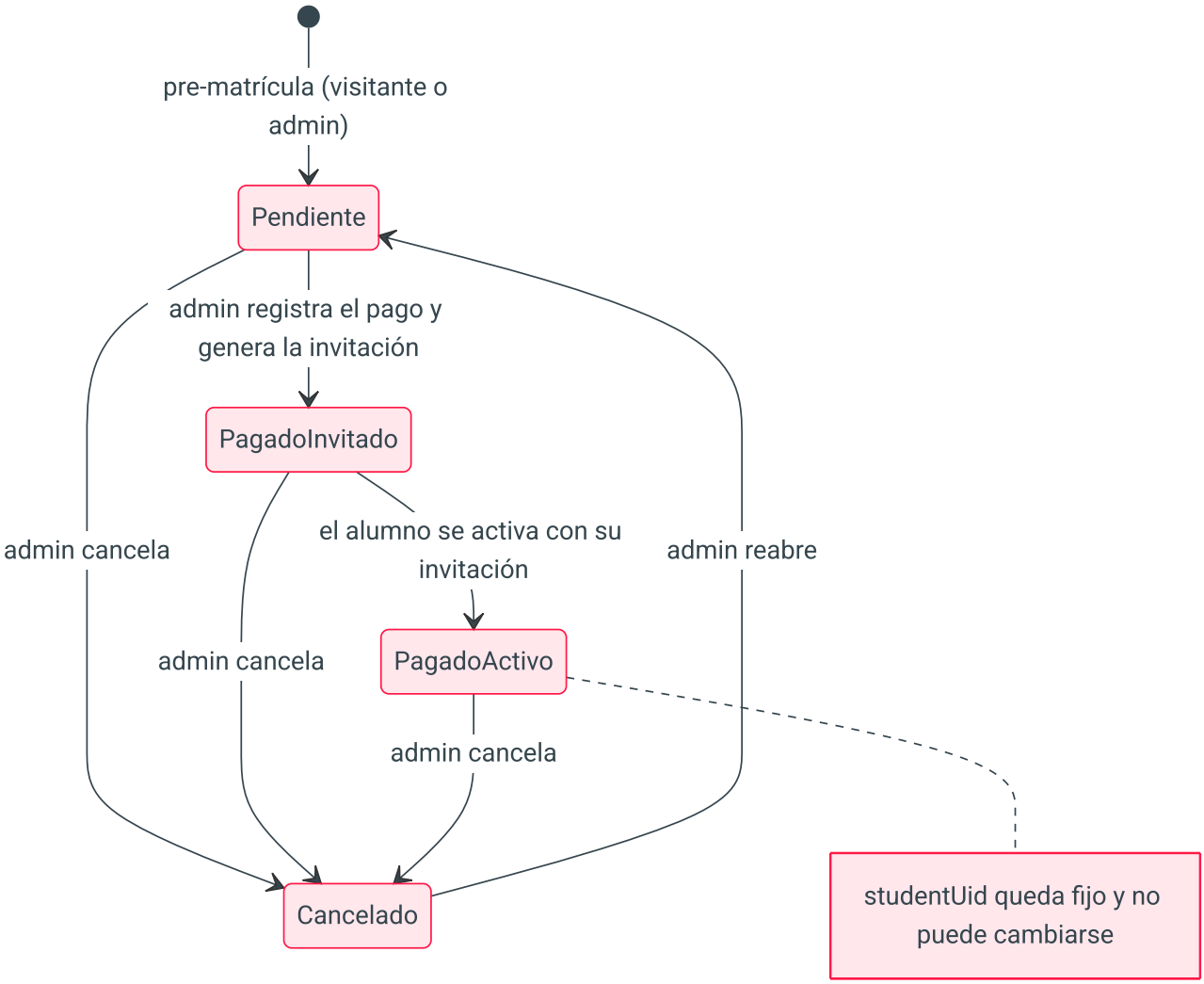


Registro de asistencia con QR firmado (HU06, ADR-06):

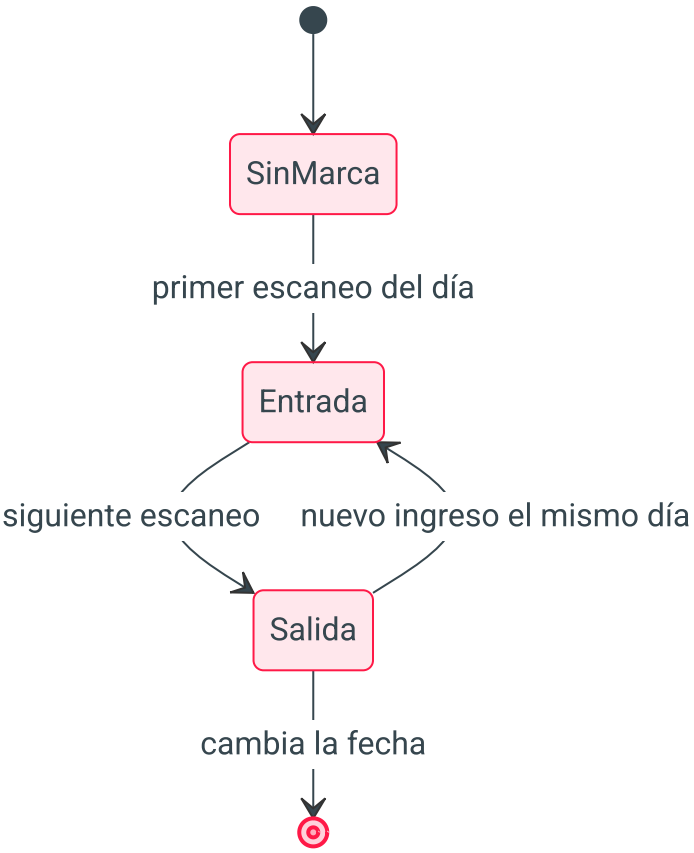


4.4 Diagrama de estados de la matrícula

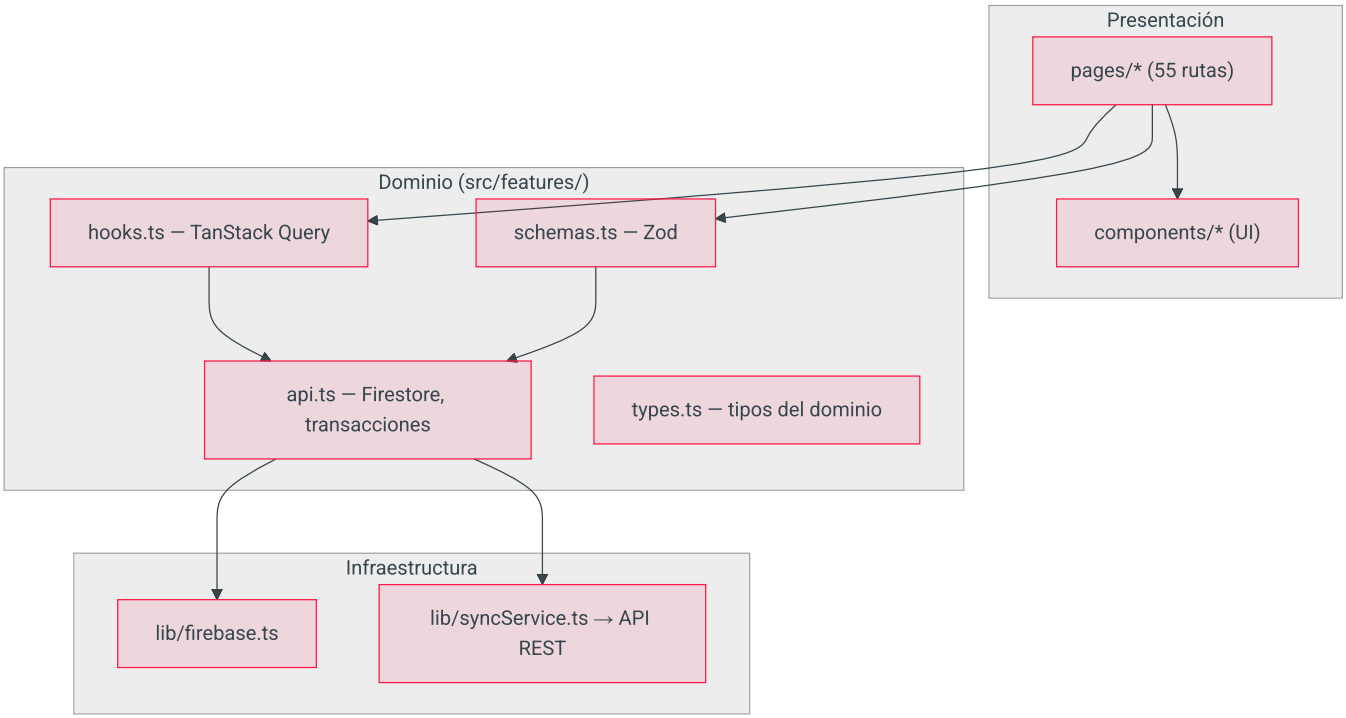
Corresponde a `isAdminEnrollmentUpdateAllowed` y a la regla de activación de `firestore.rules`.



Estado diario de la asistencia del alumno (`attendanceDayState`):



4.5 Modelo de diseño detallado



Capa	Responsabilidad	Regla de dependencia
Presentación	Pantallas y formularios	Solo usa hooks y esquemas del dominio
Dominio	Casos de uso, validación y acceso a datos	No depende de la UI
Infraestructura	SDK de Firebase y sincronización	Encapsulada en `src/lib`

Anexos

Anexo A — Acta de validación con stakeholders (plantilla)

Campo	Contenido
Fecha y lugar	(completar)
Participantes	Dirección de la academia, un docente, un auxiliar y el equipo de desarrollo
Historias validadas	HU01–HU10 (marcar conformidad u observación por historia)
Observaciones	(completar)
Conformidad	Firma de la Dirección y del líder del equipo
Estado	**Pendiente de realizar y firmar**

Anexo B — Matriz de trazabilidad de requerimientos

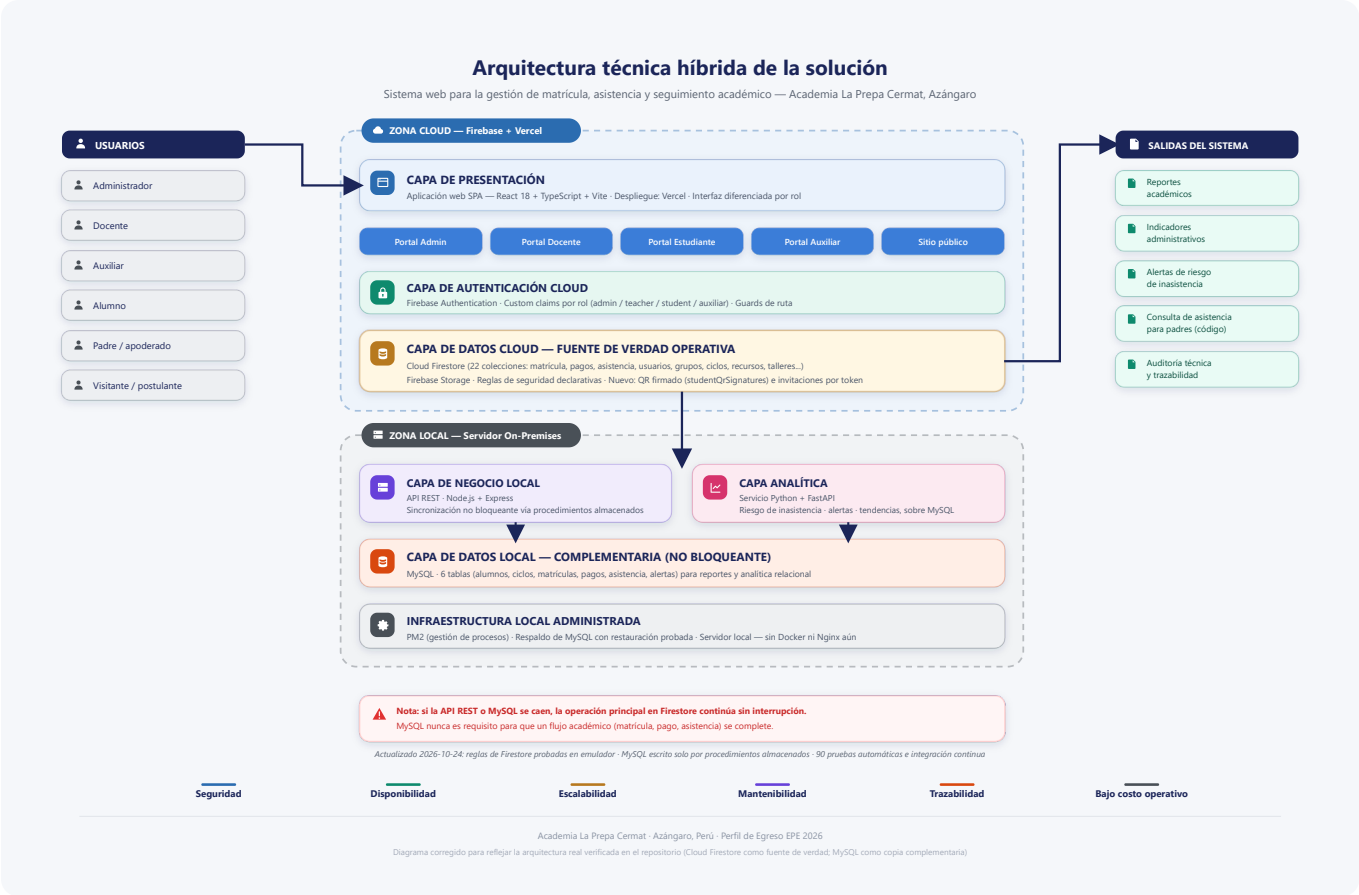
RF	Historia	Componente	Prueba automática
RF01	—	`pages/Index.tsx`, `components/home/*`	— (captura 01)
RF02	—	`pages/CiclosPage.tsx`, `features/cycles/*`	— (captura 02)
RF03	HU01	`pages/MatriculaPage.tsx`, `features/enrollments/api.ts`	Reglas › matrícula pública; esquemas de matrícula
RF04	HU01	`firestore.rules`, `features/enrollments/schemas.ts`	Reglas › ciclo cerrado, sobrecupo y cupo sin matrícula
RF05	—	`pages/admin/AdminCiclosPage.tsx`, `features/groups/*`	Reglas › manipulación del contador
RF06	HU02	`pages/admin/AdminEnrollmentsPage.tsx`, `features/enrollments/*`	Pendiente: pruebas de transiciones de estado
RF07	HU03	`pages/admin/AdminPaymentsPage.tsx`, `features/payments/*`	Reglas › pagos; API › payment (5); BD (10)
RF08	HU09	`features/users/*`, `lib/excelImport.ts`	Unitarias › excelImport (3)
RF09	HU04, HU05	`pages/Activate*Page.tsx`, `features/teacherInvites/*`	Reglas › roles (8); unitarias › invite (3)

RF	Historia	Componente	Prueba automática
RF10	—	`pages/teacher/TeacherCursosPage.tsx`	—
RF11	—	`pages/teacher/TeacherRecursosPage.tsx`, `features/resources/*`	—
RF12	HU06	`features/attendance/api.ts`, `lib/qrPayload.ts`	Unitarias › QR (5); API › attendance (6); BD 12
RF13	HU07	`pages/teacher/TeacherAttendanceScanPage.tsx`	API › asistencia diaria del docente
RF14	HU06	`pages/auxiliar/*`, `pages/admin/AuxiliarDashboard.tsx`	API › auxiliar sin claim
RF15	—	`pages/student/*`	Reglas › lectura del alumno con sesión
RF16	HU08	`pages/ConsultaAsistenciaPadrePage.tsx`, `lib/parentAccess.ts`	Unitarias › parentAccess (4)
RF17	—	`features/resources/*`, `pages/admin/AdminRecursosPage.tsx`	—
RF18	—	`features/posts/*`, `pages/admin/AdminPostsPage.tsx`	Unitarias › conversión de fechas (3)
RF19	—	`features/workshops/*`	—
RF20	—	`pages/ContactoPage.tsx`, `firestore.rules`	—
RF21	HU10	`lib/syncService.ts`, `server/src/routes/sync.ts`, `server/src/db/*`	API › sync (15); BD (19)
RF22	HU05	`routes/*Route.tsx`, `firestore.rules`, `server/src/middleware/auth.ts`	Reglas › roles; API › autenticación

Cobertura de trazabilidad: 22 de 22 RF con componente identificado; 15 de 22 con al menos una prueba automática. Las 7 restantes se cubren con capturas o están en el plan de mejora del E4.

Anexo C — Diagramas complementarios

Arquitectura técnica híbrida:



Anexo D — Evidencia de sustentación

Exposición breve ante el docente: pendiente (ver Guía de sustentación).

Rúbrica de Evaluación

Criterio	Excelente (18-20)	Bueno (15-17)	Regular (13-14)	Deficiente (<13)
Completitud y claridad de requerimientos	SRS completo, claro y estructurado (RF, RNF, reglas, restricciones)	SRS mayormente completo	Requerimientos incompletos o ambiguos	Requerimientos deficientes
Coherencia entre requerimientos, prototipos y diseño del sistema	Prototipos y diseño reflejan fielmente los requerimientos	Coherencia general	Varias inconsistencias	No hay coherencia
Definición de arquitectura del sistema	Arquitectura clara, documentada y alineada al problema	Arquitectura funcional	Arquitectura parcial	No hay arquitectura
Modelado del sistema (UML)	Diagramas completos y coherentes	Modelado adecuado	Modelado incompleto	No hay modelado

Criterio	Excelente (18-20)	Bueno (15-17)	Regular (13-14)	Deficiente (<13)
Trazabilidad de requerimientos	Componentes rastreables a requerimientos	Trazabilidad parcial	Trazabilidad limitada	No hay trazabilidad
Validación con stakeholders	Evidencia clara de validación	Validación parcial	Validación limitada	No hay validación
Sustentación y defensa técnica	Explica y defiende con dominio las decisiones tomadas	Explica con solvencia	Explica con dificultad	No sustenta

E2 - Plataforma de Datos del Sistema (CE022)

> **Evidencia CE022 — Ingeniería de la Información**
>
> Modelado, implementación, consulta, programación, seguridad y administración de la base de datos que sostiene la Plataforma CERMAT. El modelo es **híbrido**: Cloud Firestore es la fuente de verdad operativa y MySQL es la capa relacional para reportes, analítica, auditoría y continuidad.

Portada

Campo	Detalle
Título del sistema	Plataforma Web Integral de Gestión Académica CERMAT
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo)
Fecha	2026-10-24
Scripts	`server/src/db/` del repositorio `academia-school-platform`

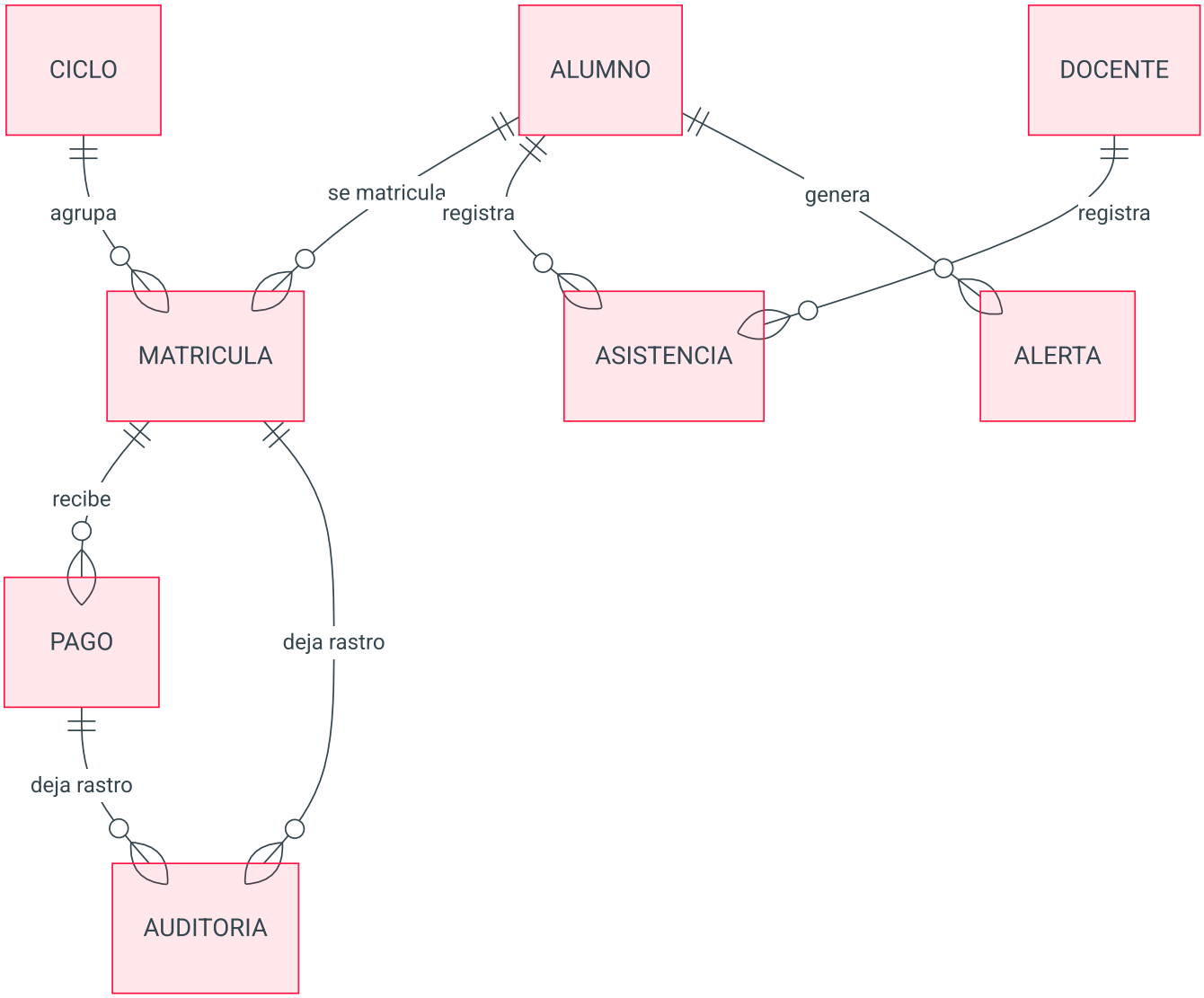
Resumen Ejecutivo

Los datos sostienen tres decisiones de la academia: quién está matriculado y cuánto debe, quién asiste y quién está en riesgo de abandonar, y qué se cobró y por qué medio. La operación diaria escribe en **Firestore** (22 colecciones protegidas por reglas por rol). Cada matrícula, pago y marca de asistencia se replica en **MySQL 8.0** mediante una API que **solo escribe a través de procedimientos almacenados**.

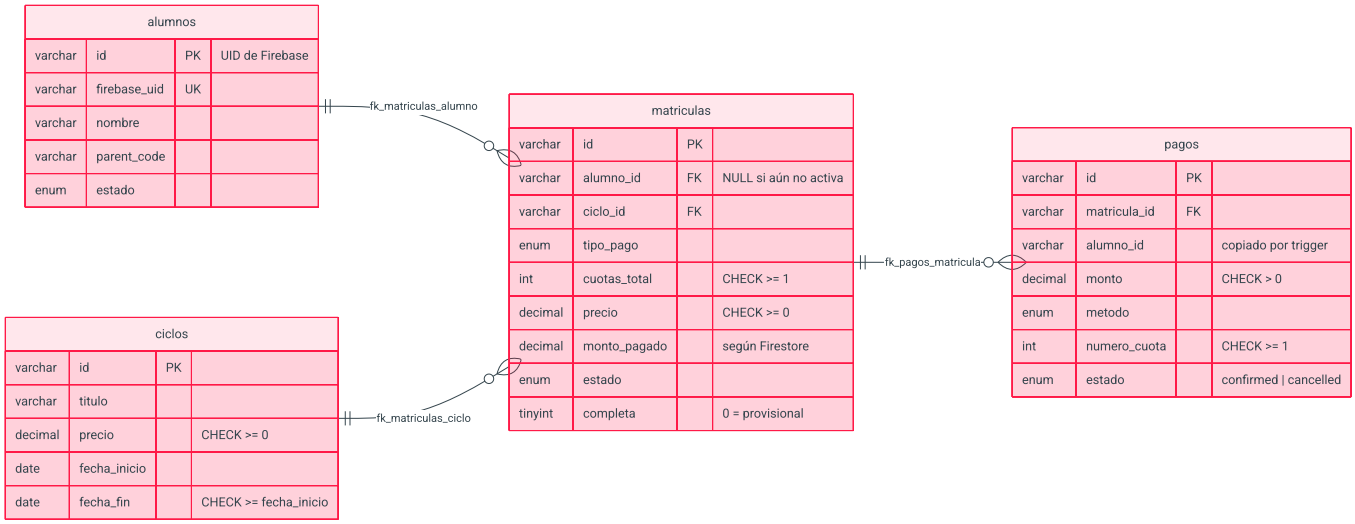
En MySQL la integridad se asegura en el motor, no solo en la aplicación: 3 claves foráneas, 7 restricciones CHECK, 6 triggers (validación, auditoría y consistencia), 4 funciones, 5 procedimientos transaccionales y 3 vistas de reporte. La seguridad usa 4 roles de mínimo privilegio. La cuenta de la API no puede ejecutar `INSERT`, `UPDATE`, `DELETE` ni `DROP` directos. Los respaldos incluyen rutinas y triggers, se verifican con SHA-256 y se restauran con medición del RTO. Una batería de **19 pruebas automáticas** sobre la base valida funciones, triggers y restricciones. Desde el 2026-10-24 la base real `cermat_db` tiene estas migraciones y sus cuentas de servicio, con el mínimo privilegio verificado en ella (secciones 2.3 y 4.1).

Sección 1: Modelo de Datos

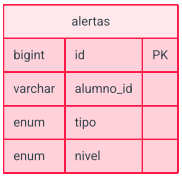
1.1 Modelo entidad-relación (conceptual)



1.2 Modelo lógico relacional (MySQL)









1.3 Modelo normalizado

Forma normal	Verificación
1FN	Todos los atributos son atómicos. Los horarios y las categorías multivaluados viven solo en Firestore, no en la réplica.
2FN	Todas las tablas tienen clave primaria simple, así que no hay dependencias parciales.
3FN	`matriculas` depende solo de su id. El saldo **no se almacena**: se calcula con `fn_saldo_matricula` o `v_estado_cuenta`.

Forma normal	Verificación
Desnormalización deliberada	`pagos.alumno_nombre` y `pagos.ciclo_titulo` guardan el valor vigente al momento del pago, como un comprobante. `pagos.alumno_id` es una copia que mantiene el trigger `trg_matriculas_au`.
Excepción justificada	`asistencia.alumno_id` guarda alumnos **y** docentes (fuente `teacher-daily-qr`), por eso no tiene FK. La columna generada `sujeto_tipo` los separa en todas las consultas.

1.4 Diccionario de datos

MySQL (`server/src/db/schema.sql` + `02_integridad.sql`)

Tabla	Columna	Tipo	Restricción	Descripción
alumnos	id	VARCHAR(64)	PK	UID de Firebase Auth
alumnos	firebase_uid	VARCHAR(64)	UNIQUE, NOT NULL	Igual a `id`, por compatibilidad
alumnos	parent_code	VARCHAR(50)	índice	Código CERMAT para la consulta de padres
alumnos	estado	ENUM	activo/inactivo/egresado	Vigencia del alumno
ciclos	id	VARCHAR(64)	PK	Id del documento en Firestore
ciclos	precio	DECIMAL(10,2)	CHECK ≥ 0	Precio de lista
matriculas	id	VARCHAR(128)	PK	Id de la matrícula en Firestore
matriculas	alumno_id	VARCHAR(64)	FK → alumnos, NULL	NULL mientras la cuenta no se activa
matriculas	ciclo_id	VARCHAR(64)	FK → ciclos	Ciclo matriculado
matriculas	cuotas_total	INT	CHECK ≥ 1	Cuotas pactadas
matriculas	precio	DECIMAL(10,2)	CHECK ≥ 0	Precio congelado al matricular
matriculas	monto_pagado	DECIMAL(10,2)	CHECK ≥ 0	Valor reportado por Firestore (se concilia)
matriculas	completa	TINYINT(1)	—	0 = creada por un pago adelantado
pagos	matricula_id	VARCHAR(128)	FK → matriculas	Matrícula pagada
pagos	monto	DECIMAL(10,2)	CHECK > 0	Importe
pagos	numero_cuota	INT	CHECK ≥ 1 o NULL; ≤ cuotas pactadas (trigger)	NULL = pago único

Tabla	Columna	Tipo	Restricción	Descripción
pagos	estado	ENUM	confirmed/cancelled	Anulación lógica: no se borra
asistencia	firestore_log_id	VARCHAR(64)	UNIQUE	Evita duplicados por reintentos
asistencia	sujeto_tipo	VARCHAR(10)	generada (STORED)	`alumno` o `docente` según la fuente
auditoria	detalle	JSON	NOT NULL	Valores antes/después
auditoria	usuario_app	VARCHAR(64)	—	UID de Firebase que originó el cambio

Firestore (fuente de verdad, protegida por `firestore.rules`)

Colección	Descripción	Relaciones
`users`	Perfiles y rol (admin, teacher, student, auxiliar)	asistencia, grupos, invitaciones, código de padres
`cycles`, `cycleCategories`, `campuses`	Oferta académica, niveles y sedes	grupos, matrículas, recursos
`groups`	Grupo por ciclo, sede, turno, horario, docente y cupo	`enrolledCount` controlado por transacción
`enrollments`	Matrículas y su máquina de estados	pagos, `studentGroupLinks`
`payments`	Pagos; eliminación bloqueada por reglas	`enrollmentId`
`attendanceTokens`, `attendanceLogs`, `attendanceDayState`	QR diario, marcas y estado transaccional del día	usuario, fecha
`studentQrSignatures`	Firma opaca del QR permanente	validada por reglas con `get()`
`parentAttendance`	Vista resumida por código para padres	estudiante
`resources`, `posts`, `workshops`, `messages`, `config`	Contenido y configuración	—
`invites`, `teacherInvites`, `auxiliarInvites`, `studentGroupLinks`, `students`	Activación por rol y vínculos	—

Sección 2: Implementación de Base de Datos

2.1 Scripts DDL

Archivo	Contenido
`schema.sql`	6 tablas base con PK, 15 índices y ENUM

Archivo	Contenido
`02_integridad.sql`	3 FK, 7 CHECK, columnas `completa`, `firestore_log_id` y `sujeto_tipo`, índices compuestos `idx_ciclo_estado`, `idx_estado_fecha`, `idx_sujeto_fecha` y `idx_alumno_tipo_resuelta`. Convierte `''` en `NULL` y crea las filas padre faltantes de datos ya replicados, para que las FK se puedan aplicar sobre una base en uso.
`03_programacion.sql`	Tabla `auditoria`, funciones, procedimientos, triggers y vistas
`04_seguridad.sql`	Roles y privilegios

Fragmento de `02_integridad.sql`:

```
ALTER TABLE pagos
  ADD CONSTRAINT fk_pagos_matricula FOREIGN KEY (matricula_id) REFERENCES matriculas (id)
    ON UPDATE CASCADE ON DELETE RESTRICT,
  ADD CONSTRAINT chk_pagos_monto CHECK (monto > 0),
  ADD CONSTRAINT chk_pagos_cuota CHECK (numero_cuota IS NULL OR numero_cuota >= 1),
  ADD INDEX idx_estado_fecha (estado, pagado_en);

ALTER TABLE asistencia
  ADD COLUMN firestore_log_id VARCHAR(64) NULL AFTER id,
  ADD COLUMN sujeto_tipo VARCHAR(10)
    GENERATED ALWAYS AS (IF(fuente = 'teacher-daily-qr', 'docente', 'alumno')) STORED,
  ADD UNIQUE KEY uq_asistencia_log (firestore_log_id);
```

2.2 Scripts DML

`90_datos_prueba.sql` carga **datos ficticios** (nombres "Prueba", correos `example.com`):

- 2 ciclos y 4 alumnos con `INSERT` directos.
- 4 matrículas y 6 operaciones de pago mediante los procedimientos, incluidas una anulación y un pago que llega antes que su matrícula.
- 30 días de asistencia generados con `INSERT … SELECT` y tabla derivada (solo días hábiles).

El script se niega a ejecutarse si la base contiene matrículas reales: una tabla temporal con CHECK aborta la carga sin dejar residuos.

2.3 Evidencias de creación

Migración aplicada sobre una base que ya tenía datos replicados con la versión anterior de la API (pagos sin alumno, ciclos inexistentes y un pago huérfano). Resultado: las 3 migraciones se registran en `schema_migraciones`, los vacíos pasan a `NULL`, se crean las filas padre faltantes y el pago huérfano queda en una matrícula provisional visible en `v_conciliacion_pagos`.

Base real (`cermat_db`, 2026-10-24, de 16:29 a 16:40 UTC−5):

1. Respaldo previo `cermat_db_2026-10-24T16-29-23_antes-migracion.sql`, con su SHA-256.

2. Revisión previa sin conflictos: estaban todas las columnas que usan las migraciones y el único pago cumple los CHECK.
3. Migraciones 02, 03 y 04 aplicadas: 3 FK, 7 CHECK, 4 funciones, 5 procedimientos, 6 triggers, 3 vistas y 4 roles; `schema_migraciones` con 3 filas.
4. La matrícula del único pago no existía, así que la migración creó una provisional (`completa = 0`). `v_conciliacion_pagos` la muestra hasta que llegue la real, como está diseñado.

> **Capturas a adjuntar**
>
> `SHOW CREATE TABLE pagos;` · `SELECT * FROM information_schema.TABLE_CONSTRAINTS WHERE TABLE_SCHEMA='cermat_db';` · `SELECT * FROM schema_migraciones;` (comandos en `server/src/db/README.md`).

Sección 3: Consultas y Programación en Base de Datos

3.1 Consultas SQL relevantes (`91_consultas.sql`)

ID	Pregunta de negocio	Implementación
Q1	¿Qué matrículas de un ciclo siguen pendientes?	`JOIN` matrículas–alumnos filtrado por `(ciclo_id, estado)`
Q2	¿Cuánto se cobró por día y medio de pago?	Agregación sobre `(estado, pagado_en)`
Q3	¿Qué alumnos están en riesgo de abandono?	`CALL sp_riesgo_inasistencia(30, 75)`
Q4	¿A qué hora entró y salió un alumno cada día?	Vista `v_asistencia_diaria`
Q5	¿Quién tiene saldo pendiente?	Vista `v_estado_cuenta` (pagos agregados una sola vez)
Q6	¿Se perdió algún evento de sincronización?	Vista `v_conciliacion_pagos`

```
-- Q5. Estado de cuenta con saldo pendiente
SELECT matricula_id, alumno_nombre, ciclo_titulo, precio, total_pagado, saldo, cuotas_pagadas,
cuotas_total
  FROM v_estado_cuenta
 WHERE estado <> 'cancelado' AND saldo > 0
 ORDER BY saldo DESC;
```

3.2 Procedimientos almacenados

Procedimiento	Tipo	Qué garantiza
`sp_sync_matricula`	Escritura transaccional	Crea o actualiza ciclo, alumno y matrícula en una transacción con `ROLLBACK` + `RESIGNAL`. Completa una matrícula provisional cuando llega la real.
`sp_sync_pago`	Escritura transaccional	No pierde pagos que llegan antes que su matrícula. En una anulación conserva al registrador original y deja en auditoría quién anuló.
`sp_registrar_asistencia`	Escritura idempotente	Reenviar el mismo log no duplica filas y responde si la marca era nueva. No depende de `ROW_COUNT()`, que con `CLIENT_FOUND_ROWS` de mysql2 cuenta los duplicados.
`sp_estado_cuenta`	Consulta	Estado de cuenta por ciclo o general
`sp_riesgo_inasistencia`	Consulta	Parte de los alumnos con matrícula vigente, así que **incluye a quienes nunca asistieron**. Excluye docentes y usa días lectivos reales.

Fragmento de `sp_sync_pago`:

```
  DECLARE EXIT HANDLER FOR SQLEXCEPTION
  BEGIN
    SET @app_uid = NULL;
    ROLLBACK;
    RESIGNAL;
  END;
  SET @app_uid = p_registrado_por;          -- lo leen los triggers de auditoría
  START TRANSACTION;
  INSERT IGNORE INTO matriculas (id, completa) VALUES (p_matricula_id, 0);
  INSERT INTO pagos (...) VALUES (...)
  ON DUPLICATE KEY UPDATE estado = p_estado, monto = p_monto;
  COMMIT;
```

3.3 Funciones

Función	Retorna	Uso
`fn_total_pagado(matricula)`	DECIMAL	Suma de pagos `confirmed` (los anulados no cuentan)
`fn_saldo_matricula(matricula)`	DECIMAL	`precio - pagado`, nunca negativo
`fn_dias_lectivos(desde, hasta)`	INT	Días con al menos una entrada de alumno, sin fines de semana ni feriados
`fn_porcentaje_asistencia(alumno, desde, hasta)`	DECIMAL(5,1)	Asistencia sobre días lectivos

Corrección de lógica: la analítica anterior dividía entre 30 días calendario. Un alumno que asistía todos los días hábiles obtenía ≈ 73 % y quedaba marcado "en riesgo". Además, no veía a los alumnos con cero asistencias y contaba a los docentes como alumnos. Con `fn_dias_lectivos` y `sp_riesgo_inasistencia` los tres problemas quedan resueltos. `analytics/main.py` y `GET /api/asistencia/riesgo` ya usan el procedimiento.

3.4 Triggers

Trigger	Momento	Función
`trg_pagos_bi`	BEFORE INSERT	Copia `alumno_id` desde la matrícula y rechaza una cuota mayor a las pactadas (`SIGNAL 45000`)
`trg_pagos_ai`	AFTER INSERT	Audita el pago
`trg_pagos_au`	AFTER UPDATE	Audita cambios de estado o monto (antes/después)
`trg_pagos_bd`	BEFORE DELETE	Impide borrar pagos, igual que la regla de Firestore
`trg_matriculas_ai`	AFTER INSERT	Audita la matrícula
`trg_matriculas_au`	AFTER UPDATE	Audita cambios de estado o de completitud; propaga `alumno_id` a los pagos cuando la cuenta se activa

3.5 Planes de ejecución

Obtenidos con `EXPLAIN FORMAT=TREE` en MySQL 8.0.30:

```
Q1 -> Nested loop left join  (cost=0.70 rows=1)
    -> Sort: m.created_at DESC
        -> Index lookup on m using idx_ciclo_estado (ciclo_id=(@ciclo), estado='pendiente')
    -> Single-row index lookup on a using PRIMARY (id=m.alumno_id)

Q4 -> Group aggregate: min(...), max(...)
    -> Index lookup on asistencia using idx_alumno_fecha (alumno_id='UID-PRUEBA-A1')
```

Q1 y Q4 resuelven por índice, sin recorrer la tabla completa. En Q2, con pocos datos de prueba, el optimizador eligió `idx_estado`. El índice compuesto `idx_estado_fecha` está pensado para el volumen real, donde el rango de fechas descarta la mayoría de filas. Esto debe confirmarse con `EXPLAIN` sobre la base productiva.

Sección 4: Seguridad y Administración

4.1 Usuarios y roles

Cuenta	Rol	Puede	No puede
cermat_api	cermat_rol_api	SELECT; EXECUTE de los procedimientos y funciones	INSERT, UPDATE, DELETE, DROP directos (verificado: error 1142)
cermat_analitica	cermat_rol_analitica	SELECT; escribir en alertas; sp_riesgo_inasistencia	Modificar matrículas, pagos o asistencia
cermat_respaldo	cermat_rol_respaldo	SELECT, SHOW VIEW, TRIGGER, LOCK TABLES, EVENT, SHOW_ROUTINE	Escribir
cermat_reportes	cermat_rol_reportes	Leer las 3 vistas	Leer tablas con datos crudos

Las cuentas se crean con `server/scripts/db-crear-usuarios.js`, que lee las contraseñas solo de variables de entorno (mínimo 12 caracteres). **Ninguna contraseña queda escrita en el repositorio.**

En la base real (2026-10-24):

- Se crearon `cermat_api`, `cermat_analitica` y `cermat_respaldo`, cada una con su rol por defecto. `cermat_reportes` queda opcional.
- Las contraseñas son aleatorias, de 32 caracteres, y están solo en `server/.env.local` y `analytics/.env.local`. Esos archivos no se versionan (regla `*.local`) y tienen prioridad sobre los `.env`, que siguen versionados y sin contraseñas.
- Mínimo privilegio verificado en la base real: `cermat_api` usa funciones y procedimientos, pero `INSERT` en `pagos` y `DELETE` en `matriculas` dan error 1142; `cermat_analitica` lee `v_asistencia_diaria`, pero `UPDATE` en `alumnos` da error 1142.
- La API y la analítica se conectan cada una con su cuenta, según `performance_schema`; `root` queda solo para administración.

La capa de aplicación aplica además estas reglas en la API:

Ruta	Regla
POST /api/sync/payment	Solo administradores, igual que `firestore.rules`
POST /api/sync/enrollment	Un no-administrador solo sincroniza su propia matrícula recién creada
POST /api/sync/attendance-log	El registrador es siempre el dueño del token (nunca el cuerpo de la petición) y el rol se valida por fuente

4.2 Auditoría implementada

La tabla `auditoria` registra cada alta, cambio de estado o monto y anulación de pagos y matrículas. Guarda el detalle en JSON (antes/después), el UID de Firebase que originó el cambio (`@app_uid`, fijado por el procedimiento) y la cuenta MySQL (`CURRENT_USER()`).

4.3 Estrategias de respaldo y recuperación

Elemento	Implementación
Respaldo	`server/scripts/backup.js` : `mysqldump --single-transaction --routines --triggers --events` con la cuenta de solo lectura. La contraseña viaja por `MYSQL_PWD` , no por la línea de comandos. Genera `.sha256` y conserva 7.
Programación	**Pendiente de activar** (RPO objetivo ≤ 24 h): `pm2 start scripts/backup.js --name cermat-backup --cron "0 2 * * *" --no-autorestart` , más `pm2 save` y el inicio automático de PM2 con Windows
Recuperación	`server/scripts/restore.js` : verifica el hash, restaura en `cermat_db_verificacion` , mide el RTO y compara filas, rutinas, triggers y vistas. Restaurar sobre producción exige `--confirmar-produccion` .
Registro	Cada prueba se anota en `backups/registro-restauraciones.jsonl`

En el ambiente de prueba (MySQL 8.0.30, 2026-10-24) el respaldo pasó la verificación SHA-256 y se restauró en `cermat_db_verificacion` con un RTO medido de 0,38 s. Las filas, rutinas, triggers y vistas restaurados coincidieron con el origen. También se verificó que la restauración rechaza un archivo alterado ("no coincide con su .sha256") y que se niega a escribir sobre la base productiva sin confirmación.

En la base real (REC-05, 2026-10-24): `backup.js` generó el respaldo con la cuenta de solo lectura `cermat_respaldo` y su SHA-256. `restore.js` lo restauró en `cermat_db_verificacion` con un **RTO de 0,23 s**; las tablas y filas coincidieron con el origen y las 9 rutinas, 6 triggers y 3 vistas quedaron completos. La prueba quedó anotada en `backups/registro-restauraciones.jsonl`. Los respaldos tienen datos personales, por eso `backups/` está en `.gitignore` .

Captura a adjuntar

Salida de `node scripts/restore.js` de la prueba REC-05 (base real, 2026-10-24), junto con su línea de `backups/registro-restauraciones.jsonl` .

4.4 Evidencias de monitoreo

Indicador	Fuente
Disponibilidad de MySQL	`GET /health` de la API y de la analítica (ping a MySQL), mostrado en el panel admin "Infraestructura"
Integridad de la réplica	`SELECT * FROM v_conciliacion_pagos;` , que debe devolver 0 filas. Hoy devuelve 1: el pago que espera su matrícula real
Trazabilidad	`SELECT … FROM auditoria ORDER BY id DESC`

Indicador	Fuente
Recuperabilidad	`backups/registro-restauraciones.jsonl` (RTO y objetos completos por prueba)

Pruebas de la capa de datos

`92_pruebas_bd.sql` ejecuta 19 pruebas y muestra una tabla OK/FALLÓ.

Resultado: 19/19 OK en MySQL 8.0.30, con modo estricto y binlog activo.

#	Prueba	Resultado
1–3	`fn_total_pagado` y `fn_saldo_matricula` ; los pagos anulados no cuentan	OK
4–7	Asistencia sobre días lectivos; alumno con 0 asistencias visible; docentes excluidos	OK
8–9	El trigger copia `alumno_id` ; la anulación conserva al registrador y audita a quien anuló	OK
10–11	El pago adelantado crea una matrícula provisional y la conciliación queda limpia al llegar la real	OK
12	Reenviar un log no duplica filas	OK
13–18	Rechazos: borrar pago, cuota excedida, monto negativo, FK alumno, borrar matrícula con pagos, 0 cuotas	OK
19	Las operaciones rechazadas no dejan filas a medias (`ROLLBACK`)	OK

Consistencia con el sistema

Requerimiento (E1)	Soporte de datos
RF03–RF06 Matrícula y estados	`enrollments` + reglas; `matriculas` + `sp_sync_matricula`
RF07 Pagos	`payments` ; `pagos` + `sp_sync_pago` + triggers + `v_estado_cuenta`
RF12–RF14 Asistencia QR	`attendanceLogs` , `attendanceDayState` ; `asistencia` idempotente
RF16 Padres	`parentAttendance` , `alumnos.parent_code`

Requerimiento (E1)	Soporte de datos
RF21 Sincronización	`syncService` → API → procedimientos; conciliación con `v_conciliacion_pagos`
RNF06 Integridad y RNF10 Auditoría	FK, CHECK, triggers, `auditoria`

Anexos

Anexo	Ubicación
Scripts completos	`server/src/db/schema.sql`, `02_integridad.sql`, `03_programacion.sql`, `04_seguridad.sql`, `90_datos_prueba.sql`, `91_consultas.sql`, `92_pruebas_bd.sql`
Capturas de ejecución	Resultado de `92_pruebas_bd.sql` (19/19), de `91_consultas.sql` (consultas + `EXPLAIN`) y de `restore.js`
Resultados de consultas	Salida de `91_consultas.sql` sobre la base de prueba
Documentación técnica de administración	`server/src/db/README.md` (orden de migración, cuentas, respaldo y recuperación)
Evidencia de sustentación	Exposición breve ante el docente (pendiente)

Rúbrica de Evaluación

Criterio	Excelente	Bueno	Regular	Deficiente
Modelado de datos	Modelo consistente, normalizado y alineado	Modelo adecuado	Modelo incompleto	Modelo incorrecto
Integridad y consistencia de datos	Integridad referencial completa	Integridad funcional	Problemas de consistencia	Datos inconsistentes
Implementación y consultas SQL	Consultas correctas y eficientes	Consultas funcionales	Consultas deficientes	Sin consultas
Programación de base de datos	Uso adecuado de lógica en BD	Uso funcional	Uso limitado	No hay programación
Seguridad y administración	Control de accesos y seguridad definidos	Seguridad básica	Seguridad parcial	Sin seguridad
Rendimiento y optimización	Índices y consultas optimizadas	Rendimiento aceptable	Problemas de rendimiento	Sistema ineficiente
Sustentación y defensa técnica	Explica y defiende con dominio las decisiones tomadas	Explica con solvencia	Explica con dificultad	No sustenta

E3 - Sistema de Software Funcional Integrado (CE023)

> **Evidencia CE023 — Programación**
>
> Sistema funcional y desplegado que implementa los requerimientos del E1 sobre la plataforma de datos del E2: una aplicación web React + TypeScript integrada con Firebase, una API REST Node.js y un servicio de analítica en Python.

Portada

Campo	Detalle
Título del sistema	Plataforma Web Integral de Gestión Académica CERMAT
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo)
Fecha	2026-10-24
Despliegue	https://academia-school-platform.vercel.app (Vercel)
Repositorio	`github.com/yucradavid/academia-school-platform` (privado; acceso para el jurado a solicitud)

Resumen Ejecutivo

Qué resuelve. La plataforma centraliza la operación de la academia en un solo sistema con portales por rol: oferta de ciclos, pre-matrícula en línea, aprobación y pagos, asistencia por QR y consulta de los padres. Antes había registros dispersos, duplicados y riesgo de sobrepasar los cupos.

Cómo se usa.

1. El visitante elige un ciclo y se pre-matricula en `/matricula`.
2. El administrador aprueba la matrícula y registra el pago en `/admin/matriculas` y `/admin/pagos`. El alumno recibe un enlace de activación.
3. El auxiliar registra la entrada y salida escaneando el QR firmado del alumno.
4. El docente marca su asistencia con el QR del día.
5. El padre consulta la asistencia con un código `CERMAT-XXXX-XXXX` en `/consulta-asistencia`.

Estado. El sistema está desplegado y en operación piloto. Al 2026-10-24 tiene 8 matrículas, 2 pagos, 7 marcas de asistencia y 8 usuarios con perfil.

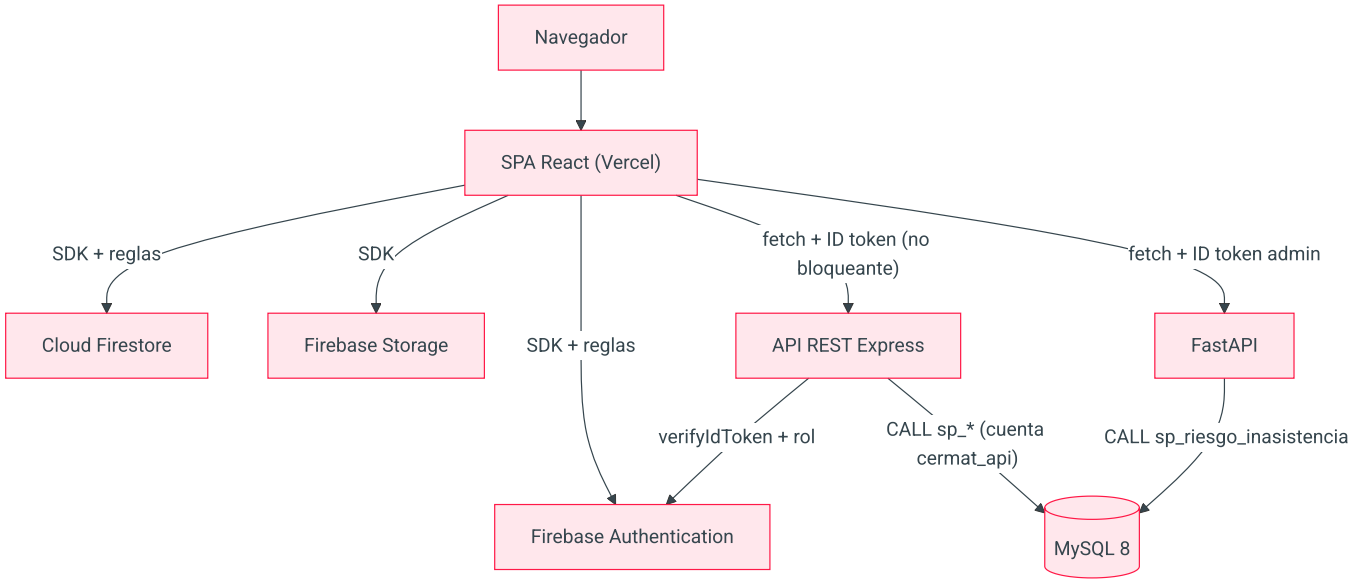
La verificación de esa fecha da:

- **TypeScript:** 0 errores (`tsc --noEmit`).
- **Build:** de producción correcto.
- **Pruebas:** 90 automáticas, todas en verde.
- **Calidad:** pipeline de CI con 6 trabajos (ver E4).

Sección 1: Arquitectura e Integración

1.1 Arquitectura general

Proceso	Tecnología	Ubicación en el repositorio	Rol
Frontend SPA	React 18 + TypeScript + Vite	`src/`	Portales público y privados (55 rutas, 6 guardas)
Identidad y datos	Firebase Auth, Cloud Firestore, Storage	`src/lib/firebase.ts` , `firestore.rules`	Fuente de verdad, protegida por reglas probadas
API REST	Node.js + Express + TypeScript	`server/src/`	Sincronización a MySQL con autorización por rol
Analítica	Python + FastAPI	`analytics/main.py`	Riesgo de inasistencia y resúmenes (solo admin)
Base relacional	MySQL 8	`server/src/db/`	Réplica con procedimientos, triggers y auditoría



1.2 Capas, módulos y servicios

Capa	Contenido	Ejemplos
Presentación	Páginas por portal y componentes de UI	`pages/admin/*`, `pages/student/*`, `components/ui/*` (shadcn/ui)
Dominio	13 módulos con el mismo patrón de 4 archivos	`features/enrollments`, `payments`, `attendance`, `cycles`, `groups`, `users`, `teacherInvites`, `resources`, `posts`, `workshops`, `analytics`, `students`, `site`
Infraestructura	Acceso a Firebase y sincronización	`lib/firebase.ts`, `lib/syncService.ts`
Seguridad	Guardas de ruta y reglas del servidor	`routes/*Route.tsx`, `firestore.rules`, `server/src/middleware/auth.ts`

1.3 Integración con la base de datos

- **Firestore** es la base operativa. Las escrituras críticas usan transacciones, como la matrícula con su cupo y el estado diario de la asistencia.
- **MySQL** recibe una copia de cada matrícula, pago y marca de asistencia mediante `syncService` → API → procedimiento almacenado. La cuenta de la API solo puede ejecutar procedimientos; no tiene INSERT, UPDATE ni DELETE directos.
- La sincronización es **idempotente**: reenviar un log no lo duplica. Además, **no bloquea**: si la API está apagada, el usuario no lo nota. La vista `v_conciliacion_pagos` detecta los eventos perdidos.

1.4 Integración con servicios externos

Servicio	Uso	Autenticación
Firebase Authentication	Identidad de los 5 roles	Correo y contraseña; claims `admin` y `role`
Firebase Admin SDK (API y analítica)	Verificar el ID token y leer el rol	Cuenta de servicio
Vercel	Publicación del frontend	Panel del equipo
Sitio del colegio (cermatschool.edu.pe)	Enlaza a la plataforma de la academia	— (enlace público)

Sección 2: Funcionalidad del Sistema

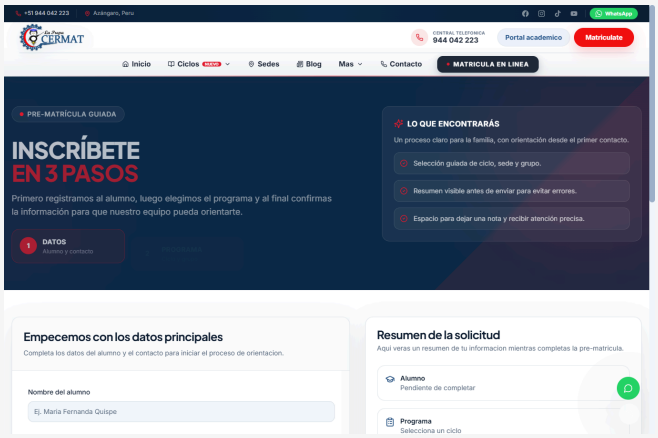
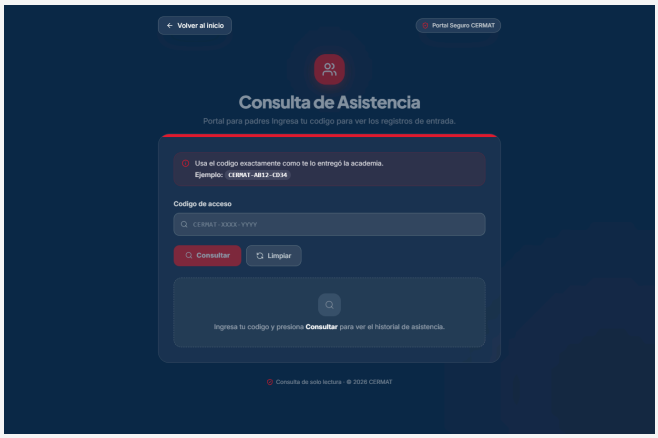
2.1 Flujos principales implementados

Flujo	Descripción	Evidencia
Pre-matrícula pública con cupo	Transacción con id determinístico, validación del ciclo, el grupo y el cupo, y mensaje claro ante un duplicado	`features/enrollments/api.ts` (`createEnrollment`); 6 pruebas de reglas con el código real
Máquina de estados de la matrícula	Pendiente → pagado (invitado) → pagado (activo); cancelación y reapertura con autor	`updateEnrollmentStatus` , `isAdminEnrollmentUpdateAllowed`
Pagos con cuotas	Registro solo admin, anulación lógica y saldo calculado	`features/payments/*` ; reglas y triggers con pruebas
Activación por invitación	Token de un solo uso con vencimiento para estudiantes, docentes y auxiliares	`pages/Activate*Page.tsx` ; 8 pruebas de roles
Asistencia con QR firmado	QR permanente del alumno con firma opaca y estado diario transaccional	`features/attendance/api.ts` , `studentQr.ts`
Asistencia del docente	QR diario con token de entrada y salida y ventana de validez; no se acepta salida sin entrada	`logTeacherAttendanceScan`
Consulta de padres	Código normalizado, sin caracteres ambiguos y revocable	`pages/ConsultaAsistenciaPadrePage.tsx` , `lib/parentAccess.ts`
Carga masiva por Excel	Alta de alumnos, docentes y auxiliares; los errores se reportan por fila sin detener el lote	`lib/excelImport.ts`
Analítica protegida	Riesgo de inasistencia sobre días lectivos, solo para administradores	`analytics/main.py` , `sp_riesgo_inasistencia`

2.2 Gestión de usuarios, permisos y roles

Rol	Cómo se identifica	Guarda de ruta	Alcance
Administrador	Claim `admin`	`AdminRoute`	Gestión completa, pagos y estados
Docente	Claim `teacher` o rol en `users`	`TeacherRoute`	Sus grupos, alumnos, recursos y asistencia propia
Auxiliar	Claim `auxiliar` o rol en `users` , creado solo con invitación	`AuxiliarRoute`	Paneles de escaneo de asistencia
Estudiante	Rol `student`	`StudentRoute`	Sus cursos, recursos, matrícula y asistencia
Padre	Código de acceso, sin cuenta	`ParentAttendanceRoute`	Asistencia de su hijo, solo lectura
Visitante	Sin sesión	—	Oferta pública y pre-matrícula

2.3 Evidencias funcionales

Pre-matrícula	Consulta de padres
	

Más capturas (inicio, ciclos, ingreso y vista móvil) en la Sección 2 del E1.

> **Capturas a adjuntar por el equipo**
>
> Portales con sesión: panel admin (matrículas y pagos), escaneo de QR por el auxiliar y portal del alumno. Requieren cuentas reales y no se capturaron de forma automatizada.

Sección 3: Código y Diseño Técnico

3.1 Estructura del repositorio

```
academia-school-platform/
├─ src/
│  ├─ features/<dominio>/   api.ts · hooks.ts · schemas.ts · types.ts · components/
│  ├─ pages/                55 rutas (público, admin, teacher, student, auxiliar)
│  ├─ components/           UI compartida (shadcn/ui) y layout
│  ├─ lib/                  firebase, syncService, qrPayload, parentAccess, date, excelImport
│  └─ routes/               guardas por rol
├─ server/                  API REST (src/routes, src/middleware, src/db, scripts, test)
├─ analytics/               servicio FastAPI
├─ tests/firestore-rules/   pruebas de reglas con emulador
├─ firestore.rules · firebase.json
└─ .github/workflows/ci.yml · .github/pull_request_template.md
```

3.2 Patrones y buenas prácticas aplicadas

Patrón	Propósito	Ejemplo
Módulo por dominio (4 archivos)	Navegación predecible y aislamiento	`features/enrollments/*`
Hooks de TanStack Query	Caché, estados de carga y error	`useCreatePost`, `useQuickEnrollmentSubmit`
Validación en la frontera (doble)	El cliente valida con Zod; el servidor revalida con reglas y Zod	`schemas.ts` + `firestore.rules` + `server/src/routes/sync.ts`

Patrón	Propósito	Ejemplo
Id determinístico y transacciones	Evitar duplicados y condiciones de carrera sin bloqueos externos	`grupo__teléfono`, `attendanceDayState/{tipo}_{id}_{fecha}`
Escritura solo por procedimientos	Integridad y auditoría centralizadas en la base	`CALL sp_sync_pago(...)`
Idempotencia	Reintentos seguros de la sincronización	`sp_registrar_asistencia`
Invitación por token hasheado	Activar sin contraseñas compartidas; el token no se guarda	`sha256Hex(token)` como id
Utilidades genéricas	Un solo parser de Excel para 3 roles	`excelImport.ts`, `runBulkRows`

3.3 Modularidad y desacoplamiento

- Las páginas no llaman directamente a Firebase: usan los hooks y la API de su dominio.
- La sincronización está aislada en `syncService` y se activa por configuración (`config/services`), sin recompilar.
- La API depende de una interfaz mínima de base de datos (procedimientos), no del esquema de tablas.

3.4 Manejo de errores y validaciones

Situación	Tratamiento
Formulario inválido	Zod + react-hook-form muestran el error por campo antes de cualquier escritura
Operación remota fallida	Las mutaciones exponen `isError` y la UI notifica con un toast
Duplicado en la pre-matrícula pública	El permiso denegado se traduce a un mensaje comprensible (`createEnrollment`)
API: datos inválidos, rechazo de la base o error inesperado	400 con detalle de Zod / 422 con el mensaje del trigger / 500 sin filtrar detalles internos
Carga masiva	Continúa ante errores por fila e informa la fila real del Excel
Fechas de Firestore	`toDateSafe` convierte `Timestamp`, `Date` o texto, sin "Invalid Date"

Correcciones de esta iteración (2026-10-24):

Defecto	Corrección
66 errores de TypeScript	Tipos corregidos sin cambiar el JavaScript generado (verificado archivo por archivo); 0 errores
Fechas del blog como "Invalid Date"	`toDateSafe` con 3 pruebas
Guardar un post sin imagen fallaba (`undefined` en Firestore)	Se guarda una cadena vacía

Defecto	Corrección
Editar un post reiniciaba su fecha de publicación	La API fija la fecha solo en la primera publicación
Posts sin autor	Se registra `createdBy` con el UID del administrador
Sincronización con `alumnoId` vacío	Se usa `studentUid`, que es el vínculo real
Animación de entrada de la galería que nunca corría	Entrada y hover separados en dos elementos (verificado en el navegador)
Ejemplo de código de padres inválido (`…AB12…` contiene "1")	Ejemplo válido `CERMAT-AB2C-D3EF`

Sección 4: Despliegue o Instalación

4.1 Instrucciones de instalación

Componente	Pasos
Frontend	`npm install` · `npm run dev` (desarrollo) · `npm run build` (genera `dist/`)
Calidad	`npm run typecheck` · `npm test` · `npm run test:rules` (emulador de Firestore; requiere Java y Firebase CLI)
Reglas de Firestore	`firebase deploy --only firestore:rules` (o automático desde el CI)
API REST	`cd server && npm install && npm run build && npm run pm2:start` · pruebas: `npm test`
Base MySQL	Migraciones `02` – `04` y cuentas de mínimo privilegio según `server/src/db/README.md`
Analítica	`pip install -r requirements.txt` · `uvicorn main:app`

Orden obligatorio al actualizar:

1. Publicar el frontend.
2. Publicar las reglas: las nuevas exigen la invitación que solo envía el frontend nuevo.
3. Aplicar las migraciones de MySQL.
4. Reiniciar la API y la analítica, que ya llaman a los procedimientos almacenados.

Los cuatro pasos se cumplieron en este orden el 2026-10-24. Los pasos 1 y 2 se verificaron en producción (E4 §2.7). Los pasos 3 y 4 se hicieron entre las 16:29 y las 16:40 (UTC−5): migraciones en la base real con respaldo previo, y la API y la analítica en línea con PM2, cada una con su cuenta de mínimo privilegio (E2 §2.3). Después de cada publicación se verifica la versión en producción (bundle y cabeceras), porque Vercel puede bloquear un despliegue sin que el push lo muestre.

4.2 Configuración requerida (solo nombres de variables)

Componente	Variables
Frontend	`VITE_FIREBASE_API_KEY`, `VITE_FIREBASE_AUTH_DOMAIN`, `VITE_FIREBASE_PROJECT_ID`, `VITE_FIREBASE_STORAGE_BUCKET`, `VITE_FIREBASE_MESSAGING_SENDER_ID`, `VITE_FIREBASE_APP_ID`
API	`MYSQL_HOST`, `MYSQL_PORT`, `MYSQL_USER` (`cermat_api`), `MYSQL_PASSWORD`, `MYSQL_DATABASE`, `FIREBASE_PROJECT_ID`, `GOOGLE_APPLICATION_CREDENTIALS`, `CORS_ORIGINS` (incluye el dominio de Vercel)
Analítica	`MYSQL_*` (`cermat_analitica`), `ALLOWED_ORIGINS`, `FIREBASE_SERVICE_ACCOUNT_PATH`
Respaldo	`BACKUP_MYSQL_USER` (`cermat_respaldo`), `BACKUP_MYSQL_PASSWORD`, `RESTORE_MYSQL_USER`, `MYSQLDUMP_PATH`, `MYSQL_PATH`

Las contraseñas de MySQL van en `server/.env.local` y `analytics/.env.local`. No se versionan (regla `*.local`) y tienen prioridad sobre los `.env`, que siguen versionados sin contraseñas.

4.3 Evidencia de despliegue y ejecución

Evidencia	Resultado
Frontend publicado	academia-school-platform.vercel.app responde 200 (capturas del 2026-10-24). Desde el 2026-10-24 producción corre la versión de esta iteración, con las cabeceras de seguridad (E4 §2.7).
Build de producción	`vite build` correcto (aviso de chunk mayor de 500 kB, registrado en el plan de mejora del E4)
Tipos	`tsc --noEmit` sin errores
Pruebas	34 unitarias, 18 de API, 19 de reglas y 19 de base de datos: 90 en verde
Respaldo y restauración	Restauración verificada con SHA-256: RTO de 0,23 s en la base real (REC-05) y de 0,27 s en la base de prueba (E2)

Anexos

Anexo	Ubicación
Repositorio fuente	`github.com/yucradavid/academia-school-platform`
Manual técnico breve	Sección 4 de este documento y `server/src/db/README.md`
Capturas de funcionamiento	`docs/assets/capturas/` (6 capturas del sitio desplegado)

Anexo	Ubicación
Evidencia de despliegue	URL de Vercel, `vercel.json`, `firebase.json`, `.github/workflows/ci.yml`
Evidencia de sustentación	Pendiente (ver Guía de sustentación)

Rúbrica de Evaluación

Criterio	Excelente	Bueno	Regular	Deficiente
Arquitectura e integración del sistema	Arquitectura clara e integración completa	Integración funcional	Integración parcial	Sin integración
Funcionalidad del sistema	Sistema completamente operativo	Funcionalidad mayormente correcta	Funcionalidad incompleta	No cumple requerimientos
Integración entre capas y servicios	Comunicación fluida entre componentes	Integración funcional	Integración parcial	Componentes aislados
Calidad del código	Código limpio y modular	Código estructurado	Código poco organizado	Código deficiente
Desempeño y comportamiento del sistema	Sistema eficiente	Rendimiento aceptable	Problemas de rendimiento	Sistema inestable
Escalabilidad y diseño técnico	Diseño preparado para escalar	Escalabilidad parcial	Diseño rígido	No escalable
Sustentación y defensa técnica	Explica y defiende con dominio las decisiones tomadas	Explica con solvencia	Explica con dificultad	No sustenta

E4 - Gestión del Proyecto y Calidad de Software (CE024)

> **Evidencia CE024 — Calidad de Software**
>
> Calidad del **producto**, con pruebas automatizadas e integración, despliegue y operación continuas, y calidad del **proceso**, con gestión ágil del proyecto, aseguramiento y auditoría. Todas las cifras de este documento se midieron el 2026-10-24 sobre el repositorio `academia-school-platform`.

Portada

Campo	Detalle
Título del sistema	Plataforma Web Integral de Gestión Académica CERMAT
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo)
Fecha	2026-10-24
Despliegue	https://academia-school-platform.vercel.app

Resumen Ejecutivo

Calidad del producto. El sistema cuenta con **90 pruebas automáticas en cuatro niveles**, y las 90 pasan:

- 34 pruebas unitarias del frontend.
- 18 de integración de la API.
- 19 de reglas de seguridad de Firestore, ejecutadas en el emulador.
- 19 de la base de datos MySQL.

La cobertura de los módulos de lógica probados es de 91 % de líneas y 94 % de ramas.

Las pruebas encontraron **tres fallas activas en producción**. Las reglas publicadas, del 22-jun-2026, permitían que cualquier usuario se asignara el rol de auxiliar o docente, permitían listar sin sesión las matrículas pagadas (nombres y teléfonos) y bloqueaban la matrícula pública de visitantes. La causa raíz fue que la primera línea de `firestore.rules` (`#`) impedía compilar el archivo, así que las versiones posteriores nunca llegaron a producción. Las tres fallas quedaron corregidas en el código: con las reglas de junio fallan 10 pruebas, y con las corregidas pasan las 19. El 2026-10-24 se publicaron el frontend y las reglas corregidas, y se verificó en producción que las tres fallas quedaron cerradas (sección 2.7).

Operación continua. Un pipeline de GitHub Actions con 6 trabajos verifica tipos, pruebas y build en cada cambio. También ejecuta las migraciones y pruebas de la base en un MySQL 8 real, y publica las reglas de Firestore solo si todo lo anterior pasó. La operación se observa con endpoints `/health`, la vista de conciliación Firestore ↔ MySQL y el registro de pruebas de restauración. Cada componente tiene una ruta de reversión documentada. Desde el 2026-10-24 la base real `cermat_db` tiene las migraciones aplicadas, y la API y la analítica se conectan con cuentas de mínimo privilegio (sección 2.7).

Calidad del proceso.

- **Gestión ágil:** Project Charter, historias de usuario con criterios de aceptación ligados a pruebas, Product Backlog priorizado y Sprint 1 en curso, con su retrospectiva.
- **Aseguramiento:** matriz de calidad ISO/IEC 25010 con métricas reales, lista de revisión obligatoria para cada cambio e inventario de defectos de código.
- **Auditoría CMMI-DEV 2.0 (estilo SCAMPI C):** ubica al proyecto en **nivel 1**, con prácticas de nivel 2 parcialmente implementadas. El plan de mejora prioriza las brechas para alcanzar el nivel 2.

Sección 1: Pruebas

1.1 Estrategia por niveles

Nivel	Herramienta	Qué valida	Ubicación
Unitarias (frontend)	Vitest 3.2	Lógica pura: códigos de padres, payload del QR, fechas locales, montos en soles, importación Excel, tokens de invitación y esquemas Zod	`src/**/*.test.ts`
Integración de la API	Vitest + Supertest; Firebase Admin y MySQL simulados	Autenticación, autorización por rol y titularidad, validación, manejo de errores y fecha local	`server/test/*.test.ts`
Seguridad (reglas)	Vitest + `@firebase/rules-unit-testing` + emulador de Firestore	Reglas por rol, privacidad, control de cupos y **el código real de `createEnrollment`** ejecutado como visitante	`tests/firestore-rules/reglas.test.ts`
Base de datos	Procedimientos de aserción SQL sobre MySQL 8.0	Funciones, triggers, restricciones, idempotencia y `ROLLBACK`	`server/src/db/92_pruebas_bd.sql`

1.2 Casos de prueba automatizados

Suite	Grupo de casos	N°
Unitarias	Código de acceso para padres: formato, normalización y caracteres ambiguos	4

Suite	Grupo de casos	N°
Unitarias	QR permanente firmado, QR diario y rechazo de QR ajenos	5
Unitarias	Fechas locales (no UTC), cambio de mes y últimos N días	5
Unitarias	Conversión segura de fechas de Firestore (Timestamp, texto, valores inválidos)	3
Unitarias	Formato en soles y valores inválidos	3
Unitarias	Importación Excel: celdas, listas y lote que no se detiene por un error	3
Unitarias	Tokens de invitación: SHA-256 y unicidad	3
Unitarias	Formulario de matrícula: turno, cuotas, nombre, teléfono, correo y precio	4
Unitarias	Registro de pagos: monto, cuota y método	4
API	Autenticación (sin token / token inválido)	1
API	`/sync/payment` : solo admin, registrador del token, validación, 422 del trigger, 500 sin filtrar detalles	5
API	`/sync/enrollment` : titularidad, no auto-marcar pagado, admin	3
API	`/sync/attendance-log` : titularidad, auxiliar sin claim, docente, manual solo admin, duplicados	6
API	`/asistencia/log` con fecha local y solo admin; `/asistencia/riesgo` por procedimiento	3
Reglas	Matrícula pública: registro con cupo, duplicado, ciclo cerrado, sobrecupo, cupo sin matrícula, manipulación del contador	6
Reglas	Privacidad: listar pagadas, leer existentes, verificar inexistencia, lectura del alumno con sesión	4
Reglas	Roles: sin invitación, invitación vigente, ajena, vencida, reintento, docentes, alumno, cambio de rol	8
Reglas	Pagos: solo admin, monto > 0, no se borran, anulación	1
BD	Funciones de saldo, pago y asistencia (días lectivos, cero asistencias, docentes)	7
BD	Triggers de copia de alumno y auditoría de anulación	2

Suite	Grupo de casos	N°
BD	Pago que llega antes que su matrícula y conciliación	2
BD	Idempotencia de asistencia	1
BD	Rechazos: borrar pago, cuota excedida, monto negativo, FK, borrar con pagos, 0 cuotas	6
BD	Sin filas a medias tras un rechazo	1
	Total	**90**

1.3 Reporte de ejecución (2026-10-24)

Suite	Comando	Resultado	Duración
Unitarias frontend	`npm run test:coverage`	**34/34 OK**	1,9 s
API REST	`cd server && npm test`	**18/18 OK**	1,2 s
Reglas de Firestore	`npm run test:rules`	**19/19 OK**	5,8 s + arranque del emulador
Base de datos	`mysql -t cermat_prueba < server/src/db/92_pruebas_bd.sql`	**19/19 OK**	< 1 s
Total		**90/90 OK**	

1.4 Reporte de cobertura

Cobertura de líneas y ramas (V8) de los módulos de lógica de negocio:

Módulo	Líneas	Ramas	Funciones
`lib/parentAccess.ts`	100 %	100 %	100 %
`lib/date.ts`	95,0 %	96,0 %	100 %
`lib/money.ts`	100 %	100 %	100 %
`lib/qrPayload.ts`	87,1 %	82,6 %	100 %
`lib/excelImport.ts`	63,3 %	92,3 %	66,7 %
`features/enrollments/invite.ts`	100 %	100 %	100 %
`features/enrollments/schemas.ts`	100 %	100 %	100 %
`features/payments/schemas.ts`	100 %	100 %	100 %

Módulo	Líneas	Ramas	Funciones
Total	**91,0 %**	**94,3 %**	**91,7 %**

> ⚠ **Alcance real de la cobertura**
>
> Los porcentajes corresponden a los módulos de lógica, no a las 41 748 líneas del frontend. Las pantallas React no tienen pruebas de componentes; la capa de acceso a Firebase se cubre con la suite de reglas, que ejecuta el código real de matrícula. Las pruebas de componentes están en el plan de mejora (sección 4.5).

1.5 Evidencia de pruebas sobre flujos críticos

Flujo crítico	Riesgo	Pruebas que lo cubren
Matrícula pública	Sobreventa de cupos, duplicados, bloqueo del visitante	6 de reglas (con `createEnrollment` real), 4 unitarias del formulario, 3 de API
Pagos	Dinero mal registrado, borrado o anulado sin rastro	1 de reglas, 4 unitarias, 5 de API, 10 de BD
Asistencia por QR	Suplantación, duplicados, fecha incorrecta	10 unitarias (QR y fechas), 9 de API, 5 de BD
Roles y privacidad	Escalamiento de privilegios, exposición de datos de menores	12 de reglas, 1 de API de autenticación y controles de titularidad en todas las rutas

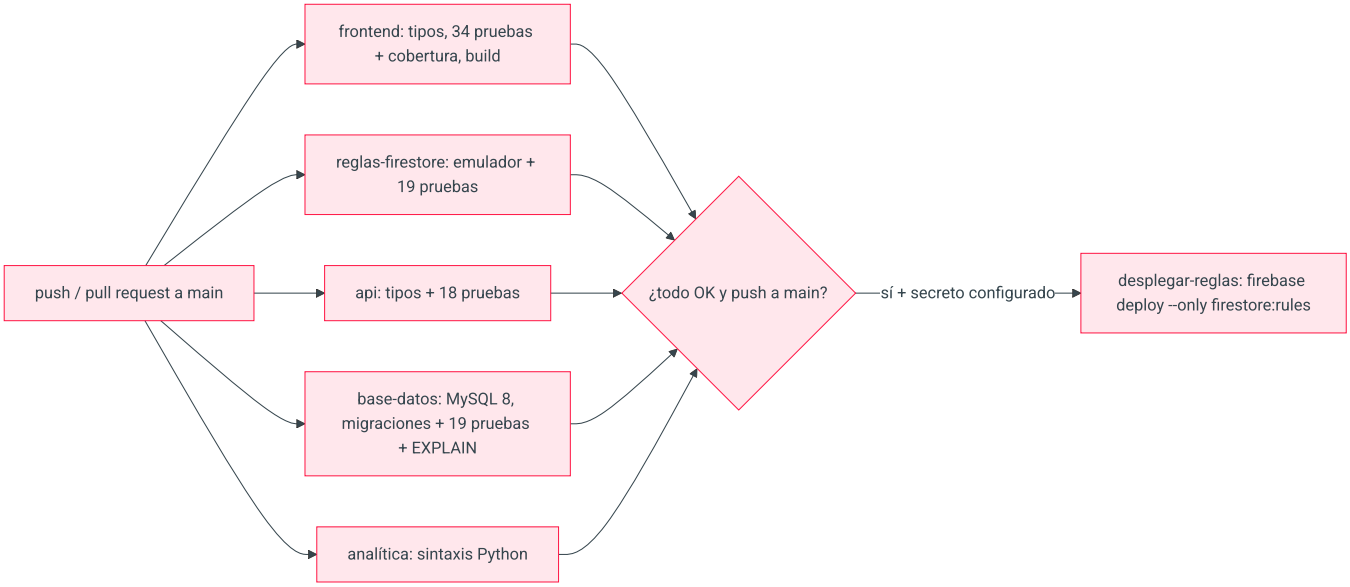
1.6 Las pruebas detectan defectos reales

La misma suite de reglas se ejecutó contra la versión **que estaba publicada en producción** hasta el 2026-10-24 (ruleset `3743ae00…`, 22-jun-2026), descargada en modo solo lectura. Esa versión ya fue reemplazada por la corregida (sección 2.7).

Grupo	Con las reglas del 22-jun	Con reglas corregidas	Defecto que revela
Matrícula pública	2 fallan	OK	El visitante no puede leer el id de matrícula inexistente ni sumar el cupo: la matrícula pública no se completa
Privacidad	4 fallan	OK	Cualquiera, sin sesión, puede listar matrículas pagadas con nombre y teléfono
Roles	4 fallan	OK	Cualquier cuenta puede crearse un perfil de auxiliar o docente sin invitación
Resto	9 pasan	OK	—
Total	**10 fallan / 9 pasan**	**19/19**	

Sección 2: Integración, Despliegue y Operación Continua

2.1 Pipeline CI/CD



2.2 Configuración de automatización

Elemento	Detalle
Archivo	`.github/workflows/ci.yml`
Disparadores	`push` y `pull_request` a `main`, y ejecución manual
Puertas de calidad	El build y la publicación solo ocurren si pasan tipos y pruebas. El trabajo de base de datos falla si alguna prueba devuelve `FALLÓ`.
Artefactos	Reporte de cobertura, métricas de lint (JSON), resultado de las pruebas de BD y planes de ejecución
Despliegue de reglas	Solo en `push` a `main`, después de los 5 trabajos de verificación. Usa el entorno `produccion` (permite exigir aprobación manual) y el secreto `FIREBASE_SERVICE_ACCOUNT`; sin el secreto, se omite con un aviso.
Frontend	Vercel publica `main`. Para que solo se publique lo verificado, se recomienda activar en Vercel la espera de los checks de GitHub.

2.3 Evidencias de integración y despliegue

Cada paso del pipeline se ejecutó en local el 2026-10-24 con los mismos comandos y versiones (Node 22/24, MySQL 8.0.30, Java 21, Firebase CLI 14.15). La primera ejecución en GitHub ocurrirá al subir los cambios.

> **Capturas a adjuntar**
>
> Pestaña *Actions* con los 6 trabajos en verde y el detalle del trabajo `base-datos` (tabla de 19 pruebas).

2.4 Observabilidad en producción

Señal	Mecanismo	Estado
Disponibilidad de API y MySQL	`GET /health` de la API y de la analítica; panel admin "Infraestructura"	Implementado
Registro de accesos de la API	`morgan` (formato combined)	Implementado, sin centralizar
Integridad de la réplica	`v_conciliacion_pagos` (0 filas = sin eventos perdidos)	Implementado
Recuperabilidad	`backups/registro-restauraciones.jsonl` (RTO medido por prueba)	Implementado
Historial de despliegues del frontend	Panel de Vercel (en producción: commit `c06f5a2` , 2026-10-24)	Disponible
Alertas automáticas de caída	—	**Brecha**: plan de mejora 4.5
Errores en el navegador	105 llamadas `console.*` sin centralizar	**Brecha**: plan de mejora 4.5

2.5 Estrategia de rollback y respaldos

Componente	Cómo se revierte	Evidencia
Frontend (Vercel)	Promover el despliegue anterior desde el panel (inmediato) o revertir el commit	Historial de despliegues de Vercel
Reglas de Firestore	Revertir el commit; el pipeline publica la versión anterior ya probada. La consola de Firebase conserva el historial de rulesets.	Ruleset de producción identificado por id y fecha
API local	`git checkout <versión>` , `npm run build` , `pm2 restart cermat-api`	`server/package.json`
Base MySQL	`scripts/backup.js` (con `--routines` , SHA-256) y `scripts/restore.js` (verificación, RTO)	RTO medido: 0,23 s en la base real (REC-05, 2026-10-24) y 0,27–0,38 s en la base de prueba
Datos de Firestore	—	**Brecha**: respaldo programado en el plan de mejora

2.6 Análisis del incidente: reglas sin publicar desde junio

Aspecto	Detalle
Detección	2026-10-24, al ejecutar la suite de reglas contra la versión publicada

Aspecto	Detalle
Impacto	Auto-asignación de rol auxiliar o docente, listado público de matrículas pagadas, matrícula pública bloqueada y colecciones de julio (`attendanceDayState` , `studentQrSignatures`) sin reglas en producción. La app publicada en Vercel (15-oct) ya usa esas colecciones.
Causa raíz	La línea 1 de `firestore.rules` (`# // firestore.rules`) no es sintaxis válida: el emulador responde `L1:1 token recognition error at: '#'` . Cualquier `firebase deploy` fallaba, y no había un proceso que lo hiciera visible.
Corrección	Comentario válido en la línea 1. Regla de rol con invitación vigente, cupo público ligado a la creación de la pre-matrícula y lectura de matrículas pagadas restringida a lecturas individuales con sesión.
Prevención	Ninguna regla se publica sin pasar las 19 pruebas (CI), y la publicación es automática tras el CI, no un paso manual que se olvida.
Cierre	2026-10-24: se publicó primero el frontend y después las reglas corregidas, desde la consola de Firebase. Verificado en producción (sección 2.7).

2.7 Cierre en producción (2026-10-24)

Verificación	Resultado
Versión del frontend en producción	Commit `c06f5a2` (bundle `index-BmprsKxb.js`). Las páginas cargan los datos de Firestore sin errores en la consola
Cabeceras de seguridad	`X-Content-Type-Options` , `Referrer-Policy` , `Content-Security-Policy: frame-ancestors` (solo el dominio del colegio), `Permissions-Policy` y HSTS
Reglas de Firestore	Publicadas desde la consola, después del frontend
Visitante sin sesión: listar matrículas pagadas	Denegado (403)
Visitante sin sesión: listar matrículas, usuarios o pagos	Denegado (403)
Visitante: comprobar que una matrícula no existe (antiduplicados)	Permitido (404)
Visitante: leer ciclos publicados	Permitido (200)
Pre-matrícula pública de prueba	"Solicitud enviada"; el equipo cancela el registro de prueba
Clave de servicio de Firebase	Rotada: nueva `ddf50bfe…` . La de enero (`283b43c3…`), que estuvo en los ZIP versionados, fue eliminada y ya no figura en la lista pública de claves de Google
Cuentas de `scripts/teachers.json`	Contraseñas restablecidas o cuentas inhabilitadas

Verificación	Resultado
Archivos `.env`	Siguen versionados por decisión del equipo: solo contienen la configuración web pública de Firebase y contraseñas de MySQL vacías. Condición: ninguna contraseña en un `.env` versionado
Dominio	`www.cermatschool.edu.pe` se retiró del proyecto de Vercel; la academia queda solo en `academia-school-platform.vercel.app`
Base MySQL real (`cermat_db`)	Respaldo previo con SHA-256 y revisión de restricciones sin conflictos. Migraciones 02–04 aplicadas: 3 FK, 7 CHECK, 4 funciones, 5 procedimientos, 6 triggers, 3 vistas y 4 roles. El único pago sin matrícula quedó con una matrícula provisional, visible en `v_conciliacion_pagos`
Cuentas de mínimo privilegio	`cermat_api` , `cermat_analitica` y `cermat_respaldo` , con contraseñas aleatorias de 32 caracteres solo en `server/.env.local` y `analytics/.env.local` (no versionados). INSERT y DELETE directos de la API, y UPDATE de la analítica → error 1142
Respaldo y restauración en la base real (REC-05)	`backup.js` con `cermat_respaldo` ; `restore.js` en `cermat_db_verificacion` : RTO 0,23 s, filas, 9 rutinas, 6 triggers y 3 vistas completos
API y analítica	En línea con PM2; ambos `/health` responden con MySQL conectado, cada uno con su cuenta. Se corrigió el arranque de la analítica, que fallaba por una inicialización doble de Firebase

Las pruebas como visitante se hicieron con consultas REST sin credenciales que solo informan si la operación fue permitida o denegada, sin mostrar datos. Las de la base real se ejecutaron entre las 16:29 y las 16:40 (UTC−5), sin mostrar contraseñas.

Lección aprendida. Los despliegues de `05fbe9e` y `e96eea1` quedaron en estado *Blocked* en Vercel (plan Hobby), y el push no lo mostraba; el propietario lo resolvió desde su cuenta. Desde ahora un cambio se da por terminado solo cuando la versión en producción se verifica (bundle y cabeceras), no al hacer push.

Sección 3: Gestión Ágil del Proyecto de Software

3.1 Project Charter

Campo	Detalle
Proyecto	Plataforma Web Integral de Gestión Académica CERMAT
Sponsor	Dirección de Academia La Prepa Cermat
Objetivo general	Centralizar oferta, matrícula, pagos, asistencia y comunicación con padres en una plataforma con portales por rol

Campo	Detalle
Objetivos medibles	Matrícula pública operativa sin intervención manual. Cero fallas críticas en reglas de seguridad (verificado por CI). 100 % de pruebas en verde antes de cada publicación. RTO de la base relacional < 1 h.
Alcance	22 requerimientos funcionales y 10 no funcionales del E1. Fuera de alcance: app móvil nativa, pasarela de pagos, facturación electrónica.
EDT	Sitio público · Gestión académica · Matrícula y pagos · Usuarios y roles · Asistencia QR · Contenidos · Infraestructura y sincronización (detalle en Gestión TI E3)
Equipo	Líder técnico y Scrum Master: David Robert Yucra Mamani. Equipo de desarrollo: Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores y Cárdenas Vilca Rennzo. Product Owner: responsable designado por la Dirección (a confirmar).
Riesgos principales	Reglas publicadas distintas de las probadas (mitigado con CI) · Secretos en el historial del repositorio · Conocimiento concentrado en una persona · Falsos positivos del antivirus al ejecutar scripts SQL
Criterio de éxito	Pipeline en verde, reglas corregidas publicadas y aceptación de los flujos críticos por la Dirección

3.2 Historias de usuario

ID	Historia	Criterios de aceptación	Pruebas
HU-01	Como **postulante** quiero pre-matricularme sin crear una cuenta para reservar mi cupo.	Ciclo abierto con cupo: se registra y descuenta 1 cupo. Mismo teléfono en el grupo: se rechaza con mensaje claro. Ciclo cerrado o grupo lleno: se rechaza.	Reglas › matrícula pública (6)
HU-02	Como **administrador** quiero registrar y anular pagos para llevar la caja.	Solo un administrador. Monto > 0. Un pago nunca se borra. La anulación queda auditada con su autor.	Reglas › pagos, API › payment (5), BD 1–3, 9, 13–15
HU-03	Como **auxiliar invitado** quiero activar mi cuenta con el enlace recibido.	Sin invitación, o con una vencida o de otro, no se crea el perfil. Un reintento del mismo usuario sí funciona.	Reglas › roles (8)
HU-04	Como **padre** quiero consultar la asistencia con un código fácil de dictar.	Acepta minúsculas, espacios y el código sin prefijo. Excluye 0/O y 1/I.	Unitarias › parentAccess (4)
HU-05	Como **auxiliar** quiero registrar asistencia escaneando el QR del alumno.	El QR firmado se acepta. El formato antiguo se detecta. Un reenvío no duplica. Solo registra quien tiene el rol.	Unitarias › qrPayload (5), API › attendance (6), BD 12

ID	Historia	Criterios de aceptación	Pruebas
HU-06	Como **Dirección** quiero ver qué alumnos están en riesgo de abandonar.	Calcula sobre días lectivos. Incluye a quien nunca asistió. Excluye docentes.	BD 4–7, API › riesgo
HU-07	Como **administrador** quiero importar alumnos desde Excel.	Una fila con error no detiene el lote. El error indica la fila real del archivo.	Unitarias › excelImport (3)
HU-08	Como **equipo técnico** quiero que las reglas solo se publiquen si pasan sus pruebas.	El pipeline bloquea la publicación si una prueba falla.	CI › desplegar-reglas

3.3 Product Backlog

ID	Ítem	Prioridad	Estado
PB-01	Suites de pruebas automáticas (4 niveles) y pipeline CI	Alta	Hecho (Sprint 1)
PB-02	Corregir reglas: rol con invitación, privacidad de matrículas, cupo público, compilación	Alta	Hecho (Sprint 1; publicado el 2026-10-24)
PB-03	Capa de datos MySQL: integridad, procedimientos, triggers, roles, respaldo y restauración	Alta	Hecho (Sprint 1)
PB-04	Publicar reglas corregidas y verificar la matrícula pública en producción	Alta	Hecho (2026-10-24)
PB-05	Aplicar las migraciones MySQL en la base real	Alta	Hecho (2026-10-24): migraciones 02–04 con respaldo previo y cuentas de mínimo privilegio verificadas
PB-06	Retirar secretos del historial y rotar la clave de servicio	Alta	Hecho en lo esencial (2026-10-24): clave rotada y contraseñas de docentes restablecidas; los `.env`, sin contraseñas, siguen versionados por decisión del equipo
PB-07	0 errores de TypeScript	Alta	Hecho (Sprint 1)
PB-08	Monitor externo con alertas sobre la URL y `/health`	Media	Pendiente
PB-09	Reducir `any` en módulos de dinero y asistencia	Media	Pendiente

ID	Ítem	Prioridad	Estado
PB-10	Carga diferida de páginas (bundle inicial de 2,8 MB)	Media	Pendiente
PB-11	Respaldo programado de Firestore con prueba de restauración	Media	Pendiente
PB-12	Pruebas de componentes de matrícula y pagos	Media	Pendiente

3.4 Sprint Backlog — Sprint 1 "Calidad y seguridad"

Duración: 2 semanas, desde el 2026-10-24. Objetivo: que ningún defecto crítico llegue a producción sin ser detectado.

Tarea	PB	Estado	Evidencia
Migraciones de integridad y programación MySQL	PB-03	Hecho	`server/src/db/02` – `04`, 19 pruebas OK
Respaldo con rutinas y verificación; restauración con RTO	PB-03	Hecho	`scripts/backup.js`, `scripts/restore.js`
Autorización por rol y titularidad en `/api/sync`	PB-01	Hecho	15 pruebas de API
Pruebas unitarias del frontend con cobertura	PB-01	Hecho	34 pruebas, 91 %
Corrección y pruebas de `firestore.rules`	PB-02	Hecho	19 pruebas en el emulador
Pipeline CI con publicación condicionada	PB-01	Hecho	`.github/workflows/ci.yml`
Corregir dominio (Vercel) en CORS y SEO	—	Hecho	`analytics/main.py`, `index.html`, `sitemap.xml`
0 errores de TypeScript (66 al inicio) sin cambiar el JavaScript generado	PB-07	Hecho	`npm run typecheck`
Corrección de 7 defectos funcionales hallados al tipar	—	Hecho	3 pruebas nuevas y verificación en el navegador
Subir cambios y primera ejecución del CI	PB-01	Pendiente	Pestaña *Actions*
Publicar reglas y verificarlas en producción	PB-04	Hecho	Sección 2.7
Rotar la clave de servicio y las contraseñas expuestas	PB-06	Hecho	Sección 2.7

Tarea	PB	Estado	Evidencia
Aplicar las migraciones MySQL en la base real	PB-05	Hecho	Sección 2.7; REC-05

3.5 Ceremonias y métricas de avance

Ceremonia	Cadencia	Registro
Planificación	Inicio de cada sprint	Sprint Backlog (sección 3.4)
Seguimiento diario	Asíncrono, en el grupo del equipo	Estado de las tareas del sprint
Revisión	Fin de sprint, con la Dirección	Acta con la aceptación de las historias
Retrospectiva	Fin de sprint	Acciones de mejora (abajo)

Métricas del Sprint 1 (al 2026-10-24): 12 de 13 tareas hechas. Pruebas automáticas: de 0 a 90. Errores de TypeScript: de 66 a 0. Defectos corregidos en código: 15.

- **3 críticos de seguridad en producción**, cerrados en producción el 2026-10-24.
- **4 de lógica de datos:** riesgo calculado sobre 30 días calendario, alumnos sin asistencias que no aparecían en el cálculo de riesgo, docentes contados como alumnos y fecha UTC en el registro manual de asistencia.
- **7 funcionales hallados al eliminar los errores de tipos:** fechas del blog como "Invalid Date", post sin imagen que no se podía guardar, fecha de publicación reiniciada al editar, post sin autor, vínculo del alumno vacío en la réplica, animación de la galería que no corría y un ejemplo inválido de código de padres.
- **1 de operación, hallado al levantar la capa local:** la analítica no arrancaba con `python main.py` porque `uvicorn.run("main:app")` reimportaba el módulo y Firebase se inicializaba dos veces, lo que dejaba a PM2 en un ciclo de reinicios. Se corrigió pasando el objeto `app`; el defecto venía del commit `e574500` (19-ago).

Retrospectiva del Sprint 1:

Qué funcionó	Qué mejorar	Acción
Probar contra lo publicado reveló fallas que la lectura del código no mostraba	Las reglas estuvieron 4 meses sin publicarse sin que nadie lo notara	Publicación solo vía CI (HU-08)
Verificar producción después de publicar mostró que Vercel había bloqueado dos despliegues	Los push `05fbe9e` y `e96eea1` quedaron *Blocked* sin que el equipo lo notara	Dar un cambio por terminado solo al verificar la versión en producción (bundle y cabeceras)
Las pruebas de BD en un MySQL aislado no tocaron datos reales	Ejecutar SQL con `cmd /c` desde PowerShell provocó una cuarentena del antivirus (falso positivo)	Ejecutar scripts desde Git Bash; excepción en el antivirus para `server/src/db`
Los hallazgos quedaron documentados con su evidencia	El historial de git muestra un solo autor y commits genéricos ("mejoras")	Commits descriptivos y cambios revisados por un segundo integrante (sección 4.2)

3.6 Comparación con otros marcos de proceso

Aspecto	Scrum (adaptado, usado)	RUP	Cascada (predictivo PMBOK)
Ciclo de vida	Iterativo e incremental en sprints de 2 semanas	Iterativo dentro de 4 fases	Lineal, una sola entrega
Fases	Sin fases formales; cada sprint entrega un incremento	Inicio, elaboración, construcción, transición	Requisitos, diseño, construcción, pruebas, despliegue
Disciplinas	Integradas en cada sprint	9 disciplinas (modelado de negocio, requisitos, análisis y diseño, implementación, pruebas, despliegue, configuración, gestión, entorno)	Una por fase
Roles	Product Owner, Scrum Master, equipo	Más de 30 roles (analista, arquitecto, tester…)	Jefe de proyecto y especialistas por fase
Artefactos	Backlogs, incremento, definición de terminado	Modelos UML, documento de arquitectura, casos de uso	Documentos firmados por fase
Cuándo conviene	Requisitos cambiantes y cliente cercano	Sistemas grandes que exigen arquitectura temprana	Requisitos estables y contratos cerrados

Adaptación elegida. Se usa Scrum ligero porque el equipo es pequeño, la Dirección está cerca y los requisitos cambiaron durante la construcción: grupos, sedes y turnos se agregaron después del inicio. Se toman de **RUP** los artefactos de análisis y diseño que el proyecto ya produjo (casos de uso, UML y vistas de arquitectura del E1) y su disciplina de **gestión de configuración** (migraciones numeradas y entornos separados). No se adopta Cascada: el sistema ya está en operación y recibe cambios continuos.

Sección 4: Aseguramiento y Auditoría de la Calidad del Software

4.1 Matriz de calidad (ISO/IEC 25010)

Característica	Atributo	Métrica	Valor actual	Meta	Riesgo
Adecuación funcional	Corrección	Flujos críticos con pruebas automáticas	4 de 4	4 de 4	Bajo
Seguridad	Confidencialidad / autorización	Fallas de reglas detectadas por la suite	0 en producción desde el 2026-10-24 (3 con las reglas de junio)	0 publicadas	Bajo
Seguridad	Integridad	Restricciones de BD que rechazan datos inválidos	6 de 6	100 %	Bajo

Característica	Atributo	Métrica	Valor actual	Meta	Riesgo
Seguridad	Responsabilidad	Cambios de pagos y matrículas auditados	100 % (triggers)	100 %	Bajo
Fiabilidad	Recuperabilidad	RTO de MySQL medido	0,23 s en la base real (REC-05); 0,27–0,38 s en la base de prueba	< 1 h	Medio (falta programar el respaldo diario: RPO ≤ 24 h)
Fiabilidad	Disponibilidad	Disponibilidad medida por monitor externo	No medida	99 % mensual	**Alto**
Mantenibilidad	Analizabilidad	Errores de TypeScript (`tsc --noEmit`)	0 (66 al inicio del sprint)	0	Bajo
Mantenibilidad	Modificabilidad	Usos de `any` (ESLint: src, server, scripts)	233 (240 al inicio del sprint)	< 120	Medio
Mantenibilidad	Capacidad de prueba	Pruebas automáticas	90	En aumento cada sprint	Bajo
Mantenibilidad	Modularidad	Archivos de más de 800 líneas	8	≤ 3	Medio
Eficiencia de desempeño	Comportamiento temporal	JS inicial	2,84 MB (781 KB gzip)	< 1 MB	Medio
Compatibilidad	Interoperabilidad	Diferencias Firestore ↔ MySQL	Vista de conciliación disponible	0 filas	Bajo

4.2 Instrumentos de aseguramiento

Instrumento	Uso	Ubicación
Lista de revisión de cambios	Obligatoria en cada pull request: tipos, pruebas, reglas, secretos, migraciones y reversión	`.github/pull_request_template.md`
Definición de terminado	Una tarea está terminada si tiene prueba, el CI está en verde y queda documentada su forma de reversión	Esta sección
Inspección automatizada de reglas	Cada cambio de `firestore.rules` se valida con 19 casos en el emulador	`tests/firestore-rules/`
Inspección de migraciones	Cada migración se ejecuta en un MySQL limpio en CI antes de llegar a la base real	Trabajo `base-datos`
Auditorías por fase	104 documentos de hallazgo, riesgo y decisión antes de cambiar código	`docs/AUDITORIA_*.md` , `docs/FASE_*.md`

4.3 Evaluación de la calidad del código

Atributos internos (medidos): 41 748 líneas en `src/`, organizadas en 13 módulos de dominio; TypeScript sin modo estricto pero con 0 errores; 233 usos de `any`; 8 archivos de más de 800 líneas.

Atributos externos: 15 defectos corregidos en este sprint, encontrados por las pruebas, por la revisión de tipos y al poner en marcha la capa local (sección 3.5).

Code smell	Evidencia	Impacto	Acción
Componentes gigantes	`AdminEnrollmentsPage.tsx` (1 261 líneas), `AdminConfigPage.tsx` (1 193), `AuxiliarDashboard.tsx` (1 099)	Difíciles de probar y revisar	Extraer hooks y subcomponentes
Código duplicado	`normalizePhone` definida 4 veces	Reglas de normalización divergentes entre módulos	Unificar en `src/lib/phone.ts`
Tipado débil	233 `any` (ESLint `no-explicit-any`)	Errores que el compilador no detecta (así se ocultaban 7 defectos)	Tipos de dominio en `types.ts`
Carga anticipada	51 páginas importadas sin `lazy()` en `App.tsx`	Bundle inicial de 2,8 MB	Carga diferida por ruta
Registro de depuración	105 llamadas `console.*`	Ruido y posible exposición de datos personales en la consola	Logger con niveles

Deuda técnica pagada mediante refactorización (Sprint 1):

Antes	Después
SQL embebido en las rutas de la API y escrito con root sin contraseña	Escritura solo por procedimientos almacenados con la cuenta `cermat_api` de mínimo privilegio
La misma consulta de riesgo copiada en dos endpoints y con un cálculo erróneo	Un solo procedimiento, `sp_riesgo_inasistencia`, probado
`backup.js` **armaba un comando de shell con la contraseña visible**	`execFileSync` con `MYSQL_PWD`, rutinas incluidas y hash de verificación
Fecha de asistencia en UTC y hora local en la misma fila	Fecha y hora en la misma zona horaria, con prueba de regresión
Errores de la API devolvían el mensaje interno	Respuestas 400/422/500 tipadas, sin filtrar detalles
66 errores de TypeScript que ocultaban 7 defectos funcionales	0 errores. En 19 de 20 archivos el JavaScript generado es idéntico (verificado con el compilador de Vite); los defectos se corrigieron aparte, con pruebas
Conversión de fechas repetida con `new Date(...)` **sobre un** `Timestamp`	Un solo helper probado, `toDateSafe`
`any` **en la sincronización de matrículas**	Tipos de dominio `SyncEnrollment`

4.4 Informe de auditoría técnica

Listas de verificación (2026-10-24):

Área	Ítem	Resultado
Gestión de proyecto	Project Charter, backlog priorizado y sprint con objetivo	Cumple
Gestión de proyecto	Registro de riesgos y decisiones	Cumple (Gestión TI y `docs/AUDITORIA_*`)
Gestión de proyecto	Estimación de esfuerzo registrada	**No cumple**
Ingeniería	Requisitos trazables a código y pruebas	Cumple (E1 §12 y sección 3.2)
Ingeniería	Arquitectura documentada	Cumple (E1 y E3)
Ingeniería	Validación con usuarios mediante acta	**No cumple**
Software	Build reproducible y pruebas automáticas	Cumple
Software	Cero errores de compilación de tipos	Cumple (puerta del CI)
Software	Repositorio sin secretos	Cumple parcialmente: la clave de los ZIP fue revocada y las contraseñas de docentes restablecidas (2026-10-24); los `.env`, sin contraseñas, siguen versionados por decisión del equipo
Software	Cambios revisados por un segundo integrante	**No cumple** (plantilla creada, sin revisiones registradas)

Madurez del proceso (CMMI-DEV 2.0, valoración estilo SCAMPI C):

Área de práctica	Evidencia principal	Valoración
Desarrollo y gestión de requisitos (RDM)	RF01–RF22, RNF01–RNF10 y trazabilidad	Ampliamente implementada
Solución técnica (TS)	Arquitectura y decisiones documentadas	Ampliamente implementada
Verificación y validación (VV)	90 pruebas automáticas; validación sin acta	Ampliamente implementada (verificación) / parcial (validación)
Aseguramiento de calidad del proceso (PQA)	104 auditorías por fase	Ampliamente implementada
Integración de producto (PI)	Pipeline que integra 4 componentes	Parcialmente implementada (falta la primera ejecución)
Planificación (PLAN)	Charter y backlog recientes	Parcialmente implementada
Monitoreo y control (MC)	Estado del sprint y métricas	Parcialmente implementada
Revisiones entre pares (PR)	Plantilla creada, sin registros	Parcialmente implementada
Gestión de configuración (CM)	Git y migraciones numeradas; secretos del historial revocados el 2026-10-24	Parcialmente implementada
Gestión de riesgos (RSK)	Matrices de riesgo	Parcialmente implementada

Área de práctica	Evidencia principal	Valoración
Estimación (EST)	—	No implementada

Conclusión: nivel de madurez 1 (Inicial). Las prácticas técnicas (requisitos, solución, verificación) superan ese nivel. Las de gestión (estimación, revisiones registradas, configuración sin secretos, seguimiento por métricas) aún no sostienen el **nivel 2 (Gestionado)**.

4.5 Plan de mejora de la calidad

#	Acción	Métrica	Meta	Plazo
1	Publicar las reglas corregidas y probar una matrícula sin sesión en producción	Fallas críticas publicadas	0	Hecho (2026-10-24)
2	Subir los cambios y obtener el primer pipeline en verde	Trabajos en verde	6 de 6	Sprint 1
3	Retirar secretos del historial y rotar la clave de servicio	Secretos vigentes en git	0	Hecho en lo esencial (2026-10-24)
4	Revisión obligatoria de cada cambio por un segundo integrante	Cambios revisados	100 %	Desde Sprint 2
5	Estimar cada ítem del backlog y medir la velocidad	Sprints con estimación	100 %	Desde Sprint 2
6	Monitor externo con alertas sobre la URL y `/health`	Disponibilidad medida	99 % mensual	Sprint 2
7	Carga diferida de páginas	JS inicial	< 1 MB	Sprint 2
8	Tipar los módulos de dinero y asistencia	Usos de `any`	< 120	Sprints 2–3
9	Pruebas de componentes de matrícula y pagos	Casos de componentes	≥ 20	Sprint 3
10	Respaldo programado de Firestore con prueba de restauración	RPO	≤ 24 h	Sprint 3
11	Programar el respaldo diario de MySQL y el arranque automático de PM2 (`pm2 save` e inicio con Windows)	RPO de MySQL	≤ 24 h	Sprint 2

Cumplir las acciones 2 a 5 lleva las áreas PLAN, MC, PR y CM al nivel 2 (Gestionado).

Anexos

Anexo	Ubicación
Reportes de pruebas	Salida de `npm run test:coverage`, `npm run test:rules`, `cd server && npm test` y `92_pruebas_bd.sql`; reporte HTML de cobertura en `coverage/index.html`
Capturas del pipeline y de observabilidad	Pestaña *Actions* tras la primera ejecución; panel admin "Infraestructura" (`/health`)
Artefactos ágiles	Secciones 3.1 a 3.5 (Charter, historias, Product Backlog, Sprint Backlog, retrospectiva)
Matriz de calidad y checklists de auditoría	Secciones 4.1 y 4.4; `.github/pull_request_template.md`
Evidencia de sustentación	Exposición breve ante el docente (pendiente)

Rúbrica de Evaluación

Criterio	Excelente	Bueno	Regular	Deficiente
Cobertura y calidad de pruebas	Pruebas efectivas cubren componentes críticos	Pruebas funcionales	Pruebas limitadas	Sin pruebas
Automatización (CI/CD)	Pipeline automatizado completo	Pipeline funcional	Automatización parcial	Sin automatización
Operación y observabilidad en producción	Monitoreo, alertas y rollback evidenciados en producción	Observabilidad funcional	Observabilidad parcial	Sin observabilidad
Gestión ágil del proyecto	Project Charter y artefactos ágiles completos y coherentes entre sí	Gestión ágil funcional	Gestión ágil parcial	Sin gestión ágil
Adaptación o comparación de marcos de proceso	Compara y adapta marcos de proceso con criterio fundamentado	Comparación básica	Comparación superficial	Sin comparación
Aseguramiento de la calidad del proceso	Matriz de calidad e instrumentos de aseguramiento completos	Aseguramiento funcional	Aseguramiento parcial	Sin aseguramiento
Auditoría de madurez del proceso (CMMI/SCAMPI)	Auditoría estructurada con deuda técnica gestionada y plan de mejora documentado	Auditoría general	Auditoría superficial	Sin auditoría

Criterio	Excelente	Bueno	Regular	Deficiente
Sustentación y defensa técnica	Explica y defiende con dominio las decisiones tomadas	Explica con solvencia	Explica con dificultad	No sustenta

C. Infraestructura Tecnológica (CE03)

C. Infraestructura Tecnológica (CE03)

Competencia CE03

Diseña y ejecuta proyectos de infraestructura tecnológica para contribuir en la solución de problemas de la organización siguiendo estándares internacionales y presenta formalmente sus resultados demostrando una actitud ética de la ACM.

Objeto del proyecto

La línea de infraestructura diseña, implementa, valida y opera una **arquitectura de seguridad híbrida on-premise + nube** para CERMAT (Azángaro, Puno), que reúne a la Academia La Prepa Cermat y a CERMAT School:

Dominio	Qué contiene	Estado al 2026-10-24
On-premise (sede principal, Azángaro)	Host de virtualización con OPNsense, servidor de aplicaciones (API Node.js, MySQL y analítica), Wazuh, monitoreo, respaldo, bastión y honeypot, segmentados en 6 VLAN	**Diseñado.** Hoy la capa local corre en una PC con PM2, sin firewall perimetral ni segmentación
Nube IaaS (VPS RackNerd, New York)	Sistema de gestión del colegio con Nginx, TLS, UFW y PostgreSQL local; extremo de la VPN	**En producción** desde el 2026-10-17; VPN y respaldos externos pendientes
Nube PaaS	Plataforma de la academia en Vercel; identidad y datos en Firebase	**En producción**; frontend con cabeceras de seguridad y reglas de Firestore corregidas publicados y verificados el 2026-10-24

La guía oficial toma como referencia VMware ESXi y AWS y permite ajustar la tecnología "siempre que se mantenga la equivalencia técnica". La tabla de equivalencias de esta página explica cada sustitución.

Implementado frente a diseñado

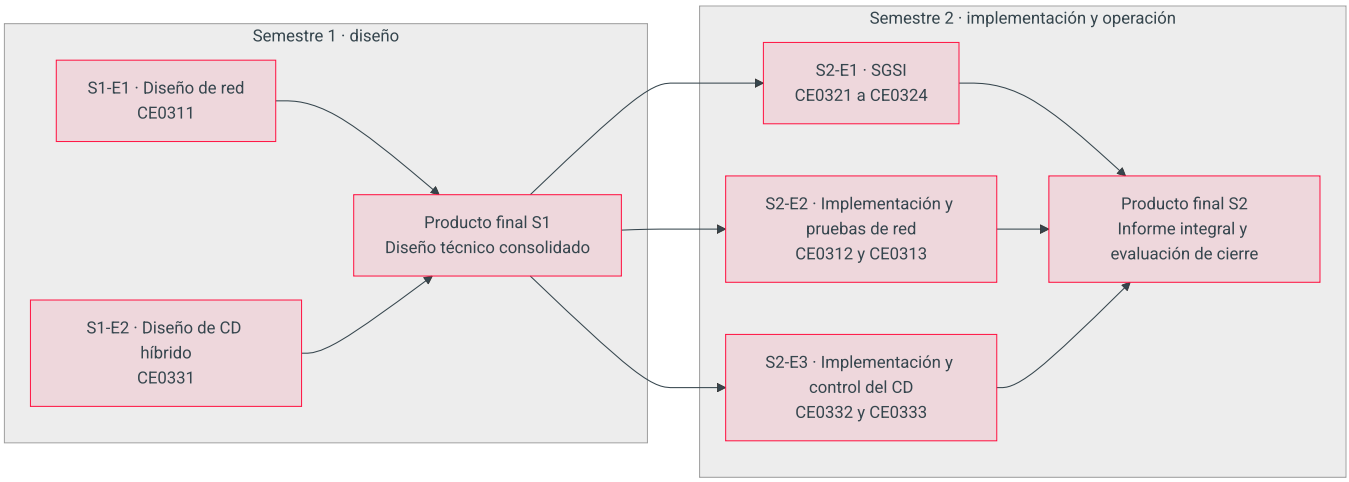
Cada documento separa lo **implementado con evidencia** (VPS, PaaS, base MySQL, pruebas y CI) de lo **pendiente de ejecución** (hipervisor, OPNsense, VPN, IDS/IPS, honeypot, SIEM y monitor externo). Lo pendiente incluye el procedimiento, el criterio de aceptación y la evidencia que se adjuntará. No se presentan resultados que no se hayan obtenido.

Codificación de entregables

Competencia	Código(s)	Momento	Entregable	Documento	Rúbrica
CE031: Conectividad	CE0311	S1	E1: Análisis y Diseño de Red	S1-E1	8 criterios (100 %)
CE033: Implementación de Centro de Datos	CE0331	S1	E2: Análisis y Diseño de Centro de Datos Híbrido	S1-E2	8 criterios (100 %)
—	CE0311 + CE0331	S1	Producto final: Diseño Técnico Consolidado	Producto final S1	Rúbricas de S1-E1 y S1-E2
CE032: Gestión de la Seguridad de la Información	CE0321, CE0322, CE0323, CE0324	S2	E1: Planificación e Implementación del SGSI	S2-E1	10 criterios (100 %)
CE031: Conectividad	CE0312, CE0313	S2	E2: Implementación, Testing y Monitoreo de Red	S2-E2	8 criterios (100 %)
CE033: Implementación de Centro de Datos	CE0332, CE0333	S2	E3: Implementación, Gestión y Control de Centro de Datos	S2-E3	8 criterios (100 %)
—	CE031 + CE032 + CE033	S2	Producto final: Informe de Implementación Integral y Operativa	Producto final S2	Rúbricas de S2 y evaluación de cierre

Nota interpretativa de la guía: CE031 primero diseña la red (S1) y luego la implementa, prueba y controla (S2); CE033 primero diseña la arquitectura (S1) y luego la despliega, opera y controla (S2); CE032 se evalúa como SGSI integral en S2.

Distribución por semestre



Reglas comunes de la guía

Todos los entregables se califican sobre **100 puntos** y se convierten a **nota sobre 20**.

Nivel	Valor
Excelente	4
Logrado	3
En proceso	2
Insuficiente	1
No evidenciado	0

Puntaje = peso × (nivel / 4).

- La evidencia debe ser verificable y reproducible: no se evalúa como diseñado, implementado o probado lo que solo se describe de forma genérica.
- Ningún informe, captura, configuración o repositorio contiene contraseñas, llaves privadas, tokens, secretos ni datos personales reales. En esta documentación tampoco se publican IP públicas ni correos.
- La sustentación individual puede complementar la nota del equipo para verificar autoría, dominio técnico y capacidad de defensa.

Equivalencias tecnológicas

Referencia de la guía	Equivalente adoptado	Justificación	Estado
VMware ESXi	**Proxmox VE** (ESXi como alternativa si la institución dispone de licencia)	Sin costo de licencia; bridges con VLAN, bonds, ZFS, firewall y respaldo integrados. Tras la compra de VMware por Broadcom, la disponibilidad de una edición gratuita de ESXi es incierta	Diseñado
vSwitch	Linux bridge VLAN-aware (`vmbr0`)	Mismo papel: conmutador virtual con uplinks físicos	Diseñado
Port group con VLAN	Etiqueta `tag` en la NIC virtual de la VM	Asigna la VM a una VLAN sin configurar el sistema invitado	Diseñado
NIC teaming	Bond Linux 802.3ad (LACP) `bond0`	Agregación y redundancia de enlaces	Diseñado
Snapshots y respaldo de vSphere	vzdump + Proxmox Backup Server	Respaldo deduplicado, verificado y restaurable por VM	Diseñado
AWS VPC y CIDR	Espacio 10.20.0.0/16; red interna del VPS 10.20.0.0/24 en la interfaz `dum0`	Red privada de nube alcanzable solo por el túnel	Diseñado

Referencia de la guía	Equivalente adoptado	Justificación	Estado
Subred pública + Internet Gateway	Interfaz pública del VPS y enrutamiento del proveedor	El VPS recibe una IP pública propia	Implementado (provisto)
Route tables	Tabla `main` y tabla 220 de strongSwan	strongSwan instala las rutas de los selectores de tráfico	Diseñado
NAT Gateway	NAT saliente de OPNsense en la sede; no se requiere en el VPS	El VPS ya tiene IP pública	Diseñado
EC2	VPS KVM de RackNerd (2 vCPU, 2 GB, 35 GB SSD, Ubuntu 24.04)	Ya contratado (US$ 35,99 al año) y en producción	**Implementado**
Security Group	UFW (nftables con estado) en el VPS	Entrada denegada por defecto; 22, 80 y 443/tcp permitidos	**Implementado**
NACL	Reglas nftables sin estado o filtro de red del proveedor	Segunda capa a nivel de red; disponibilidad del filtro del proveedor por confirmar	Pendiente
VPN Gateway (Site-to-Site IPsec)	strongSwan IKEv2 en el VPS ↔ OPNsense en la sede	Túnel IPsec equivalente con AES-256-GCM y PFS	Diseñado
IAM	Usuarios Linux con sudo y llaves SSH; roles de PostgreSQL y MySQL; claims de Firebase; cuentas de servicio	Mínimo privilegio por plataforma	Parcial
CloudWatch	Uptime Kuma (disponibilidad), Netdata (métricas) y Wazuh (eventos)	Monitoreo y alertas sin costo de licencia	Pendiente
Route 53	DNS autoritativo de Punto.pe (servidores de RCP)	Dominio institucional `.edu.pe`	**Implementado**
ACM	Let's Encrypt con Certbot; certificados gestionados por Vercel	TLS 1.2/1.3 verificado el 2026-10-24	**Implementado**
PaaS (Amplify/Elastic Beanstalk)	Vercel (frontend) y Firebase (Auth, Firestore, Storage)	Plataforma de la academia ya en producción	**Implementado**
GuardDuty o IDS	Suricata en OPNsense y Wazuh	IDS/IPS y correlación de eventos	Pendiente

AWS Academy como alternativa

Si el jurado requiere evidencia sobre AWS, el mismo diseño puede reproducirse en AWS Academy (VPC 10.20.0.0/16, EC2, Security Groups, NACL y Site-to-Site VPN hacia OPNsense), sujeto a los servicios habilitados en esa cuenta educativa. **No se usó en este proyecto.**

Matrices y diagramas

Entregable	Matriz (XLSX)	Diagrama editable (draw.io)
S1-E1	Componentes de red, VLAN, zonas, reglas, flujos y requisitos · Pruebas de conectividad planeadas	Topología general híbrida · Topología lógica · Zonas de seguridad y VPN
S1-E2	Componentes y dimensionamiento del CD	Arquitectura del CD híbrido (rack, hipervisor y nube)
S2-E1	Inventario de activos · Riesgos · Declaración de Aplicabilidad	—
S2-E2	Plan y resultados de pruebas de red	Diagramas de S1-E1
S2-E3	Registro de pruebas de recuperación · Inventario final de activos	Diagrama de S1-E2

Las matrices se generan con `perfil-egreso/scripts/generar-matrices-infra.mjs`, que contiene los mismos datos que las tablas de los informes. Para regenerarlas: `cd perfil-egreso && node scripts/generar-matrices-infra.mjs`.

Cifras de la línea

Indicador	Valor
Componentes de red en la matriz	31
Flujos de información definidos	22
Reglas de firewall planeadas (OPNsense)	35
Componentes del centro de datos	36
Activos del SGSI	33
Riesgos evaluados (ISO/IEC 27005)	29
Controles del Anexo A en la SoA	93 (92 aplicables)
Pruebas de red con resultado real / pendientes	11 conformes y 2 no conformes / 24 pendientes
Pruebas de recuperación ejecutadas / pendientes	5 / 7 (REC-05 en la base real: RTO de 0,23 s)

Semestre 1

S1-E1 · Análisis y Diseño de Red (CE0311)

CE0311 — Diseño de red

Levantamiento de requerimientos, topología lógica y física, segmentación VLAN/DMZ, direccionamiento, ruteo, seguridad perimetral, conectividad híbrida y diseño de detección para la infraestructura **on-premise + nube** de CERMAT. Es un documento de **análisis y diseño, sin implementación**: la ejecución y las pruebas se documentan en S2-E2.

Portada

Campo	Detalle
Título	Análisis y diseño de red de la infraestructura híbrida de CERMAT
Entregable	Semestre 1 · Entregable 1 · CE0311
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo), UPeU campus Juliaca, sección g1
Fecha	2026-10-24
Versión	2.0
Organización	CERMAT, Azángaro (Puno, Perú): Academia La Prepa Cermat y CERMAT School

Control de versiones

Versión	Fecha	Cambio
1.0	2026-07-06	Diseño de red de la sede con 4 VLAN, según la estructura anterior de la guía
2.0	2026-10-24	Reescrito según la guía vigente (2026-09-09): arquitectura híbrida, DMZ, VPN IPsec, detección, matrices y diagramas editables

Productos obligatorios

Producto	Formato entregado	Ubicación	Criterio de aceptación (guía)
Informe de análisis y diseño de red	Página versionada en Git; PDF desde la vista de impresión del sitio	Este documento	Completo, versionado y coherente con la organización descrita

Producto	Formato entregado	Ubicación	Criterio de aceptación (guía)
Diagramas de red	draw.io editable y Mermaid; PNG/PDF se exportan desde draw.io	Topología general · Topología lógica · Zonas de seguridad y VPN	Topología general, lógica, seguridad por zonas y VPN híbrida
Matriz de componentes de red	XLSX y sección 12	s1-e1-matriz-componentes-red.xlsx	Cubre el 100 % de los componentes dibujados (31 componentes)
Matriz de pruebas de conectividad planeadas	XLSX y Anexo A	s1-e1-matriz-pruebas-conectividad.xlsx	Coherente con el diseño de VPN y segmentación (22 pruebas)

1. Resumen ejecutivo del diseño de red

Proyecto y organización. CERMAT opera dos sistemas de información: la plataforma web de la academia (React en Vercel, con Firebase para identidad y datos) y el sistema de gestión del colegio (Angular + Laravel + PostgreSQL en un VPS de RackNerd). La academia tiene además una capa local (API Node.js, MySQL y analítica en Python) para reportes, auditoría y continuidad.

Problema de conectividad y seguridad.

- La capa local corre en una PC con PM2, **sin firewall perimetral, sin segmentación y sin DMZ**. La aplicación la llama en `http://localhost:3001` (valor por defecto de `config/services`), así que solo sincroniza desde el navegador de esa misma PC y cuando está encendida.
- El VPS del colegio expone SSH a Internet y **no tiene un canal privado** con la sede para respaldos externos, administración ni monitoreo.
- No existen IDS/IPS, honeypot ni registro centralizado de eventos.
- La sede depende de un solo enlace de Internet y no tiene UPS (supuestos SUP-02 y SUP-10).

Solución propuesta.

- **Topología híbrida en tres dominios:** sede virtualizada (Proxmox VE, equivalente a ESXi), nube IaaS (VPS, equivalente a EC2 en una VPC) y PaaS (Vercel y Firebase).
- **Seguridad perimetral:** OPNsense como firewall de la sede, con política por defecto de denegar y 35 reglas planeadas. El VPS mantiene UFW como Security Group.
- **Zonas de seguridad:** 6 VLAN (ADMIN 10, ACAD 20, GUEST 30, SRV 40, DMZ 50 y MGMT 99) y la red de nube 10.20.0.0/24, con una matriz permitido/denegado y 22 flujos definidos.
- **VPN híbrida:** IPsec IKEv2 sitio a sitio OPNsense ↔ strongSwan con AES-256-GCM, PRF SHA-256, grupo DH 20 (alterno 19) y PFS. Se anuncian 10.10.40.0/24 y 10.10.99.0/27 en la sede, y 10.20.0.0/24 en la nube.
- **Detección:** Suricata como IPS en las WAN e IDS en la troncal, honeypot Cowrie en la DMZ y Wazuh como SIEM.

Riesgos preliminares.

Riesgo	Tratamiento en el diseño
La sede podría no tener IP pública (CGNAT)	La sede siempre inicia el túnel con NAT-T; el honeypot solo se expone si hay IP pública
2 GB de RAM del VPS compartidos	Solo componentes ligeros en el VPS; la capa de la academia va on-premise
Firewall virtualizado en el host único	NIC dedicadas para WAN; contingencia con el router del ISP; los servicios críticos siguen en la nube
SSH del VPS expuesto	Cierre de 22/tcp a Internet una vez validada la administración por VPN

Siguientes pasos. Confirmar con el ISP el tipo de IP y el ancho de banda (SUP-02, SUP-03). Implementar y probar en S2-E2 las pruebas PR-14 a PR-35, que corresponden a PC-01 a PC-22. Cerrar SSH público del VPS tras validar la VPN.

Cifra del diseño	Valor
Componentes de red	31
VLAN de la sede / redes de nube	6 / 1
Reglas OPNsense / reglas UFW del VPS	35 / 10
Flujos de información	22
Pruebas de conectividad planeadas	22

2. Descripción de la organización y necesidades de red

2.1 Organización

CERMAT tiene un colegio (CERMAT School) y una academia preuniversitaria (La Prepa Cermat), con varias sedes. La plataforma de la academia está en **operación piloto con volumen bajo**: los conteos agregados de Firestore al 2026-10-24 (sin datos personales) son los siguientes.

Indicador	Valor
Matrículas	8 (2 pendientes, 5 pagadas, 1 cancelada), creadas entre 2026-01-27 y 2026-07-07
Pagos	2 confirmados, 0 anulados
Registros de asistencia	7 (2026-01-27 a 2026-04-02)
Usuarios con perfil	8 (4 alumnos, 3 docentes, 1 auxiliar); los administradores se identifican por claim
Oferta	1 ciclo, 1 grupo y 1 sede; 6 recursos, 1 post, 1 taller y 7 mensajes de contacto

Indicador	Valor
Consultas de padres registradas	0

El diseño no presenta estas cifras como adopción masiva: dimensiona para el crecimiento esperado con supuestos explícitos (sección 2.5).

2.2 Usuarios y sedes

Grupo	Dónde se conecta	Zona asignada	Necesidad
Dirección, secretaría/admisión y caja	Sede principal	VLAN 10 ADMIN	Matrícula, pagos y reportes con prioridad y aislamiento
Encargado de TI	Sede (estación ADMIN_TI)	VLAN 10 + acceso a VLAN 99	Administrar red, hipervisor y servidores
Docentes y auxiliares	Sede (cableado y Wi-Fi)	VLAN 20 ACAD	Portales docente y auxiliar; lectura de QR de asistencia
Alumnos, padres y visitantes	Sede (Wi-Fi) o Internet	VLAN 30 GUEST / Internet	Solo navegación; nunca acceso a redes internas
Postulantes y padres	Internet	—	Matrícula pública y consulta de asistencia (servicios en la nube)
Equipo técnico	Internet y sede	Bastión por VPN	Despliegue y operación

La sede principal está en Azángaro. Otras sedes quedan fuera del alcance, con un bloque de direcciones reservado (sección 8).

2.3 Servicios TI

Servicio	Ubicación actual	Ubicación de diseño	Usuarios
Plataforma de la academia (SPA)	Vercel	Vercel	Todos los roles
Identidad y datos operativos	Firebase (Auth, 22 colecciones de Firestore, Storage)	Firebase	Todos los roles
API de sincronización, MySQL y analítica	PC local con PM2	VM-APP01 en VLAN 40, publicada por el VPS	Administración y dirección
Sistema de gestión del colegio	VPS (Nginx, PHP-FPM, PostgreSQL)	VPS	Colegio
DNS del dominio institucional	Punto.pe (servidores de RCP)	Igual	Todos
Correo institucional	Google (registros MX)	Igual	Personal
Control de versiones y CI	GitHub	Igual	Equipo técnico

2.4 Uso previsto de la nube y del entorno local

Criterio	Nube	Local (sede)
Disponibilidad para usuarios externos	Matrícula, pagos, asistencia y consulta de padres (PaaS)	—
Datos relacionales para reportes y auditoría	—	MySQL en VM-APP01
Detección y registro de eventos	Agentes en el VPS	Wazuh, Suricata y honeypot
Respaldo externo	Copia cifrada de la sede en el VPS	Copias del VPS en la sede
Costo	VPS de US$ 35,99 al año; PaaS en su plan actual	Hardware propio; software libre

2.5 Ancho de banda, disponibilidad y crecimiento

ID	Supuesto	Valor	Estado	Fuente
SUP-01	Equipos simultáneos en la sede principal	12–18	Supuesto a validar	Levantamiento preliminar del equipo (jun-2026), sin medición
SUP-02	Ancho de banda del enlace principal	≥ 50 Mb/s	Supuesto a validar	Confirmar con el contrato del ISP y una prueba de velocidad
SUP-03	Tipo de IP pública de la sede	Desconocido (fija, dinámica o CGNAT)	Dato a confirmar	Consultar al ISP
SUP-04	Latencia sede ↔ VPS (New York)	90–150 ms	Supuesto a validar	Medir con `mtr` desde la sede
SUP-08	Crecimiento de usuarios	Piloto con 8 perfiles; cada VLAN /24 admite hasta 253 equipos	Supuesto a validar	Conteos agregados de Firestore

- **Disponibilidad:** la red de la sede apunta a 99 % mensual. Ante su caída, matrícula, pagos y consulta de padres siguen operando desde cualquier conexión porque residen en la nube.
- **Crecimiento:** cada VLAN /24 deja más de 200 direcciones libres; el bloque 10.10.0.0/16 reserva 10.10.60.0–10.10.98.255 para nuevas zonas y se reservan 10.11.0.0/16 y 10.12.0.0/16 para otras sedes.

2.6 Requisitos técnicos y organizacionales

ID	Tipo	Requisito	Elemento de diseño	Sección	Verificación (S2)
RQ-01	Organizacional	Datos de alumnos y pagos accesibles solo por roles autorizados	Zonas SRV y MGMT aisladas; reglas por rol en la capa PaaS	S1-E1 §8, §9	PC-03, PC-04

ID	Tipo	Requisito	Elemento de diseño	Sección	Verificación (S2)
RQ-02	Técnico	Separar el tráfico de invitados del administrativo y de los servidores	VLAN 30, FW-02 y aislamiento de clientes	S1-E1 §8	PC-06, PC-08
RQ-03	Técnico	Gestión de la infraestructura solo desde estaciones autorizadas	VLAN 99, alias ADMIN_TI y bastión	S1-E1 §8, §13	PC-04, PC-05
RQ-04	Técnico	Ningún servicio interno expuesto a Internet, salvo el señuelo	FW-61; NAT solo al honeypot; API publicada por el VPS	S1-E1 §9, §13	PC-02, PC-14
RQ-05	Organizacional	Matrícula y pagos continúan ante una falla de la sede	Servicios críticos en PaaS; enlace WAN2	S1-E2 §11	PC-16, REC-10
RQ-06	Técnico	Canal cifrado sede ↔ nube para respaldos y administración	IPsec IKEv2, AES-256-GCM, PFS	S1-E1 §10	PC-11, PC-12, PC-13
RQ-07	Técnico	Respaldos 3-2-1 con restauración verificada	PBS, VPS y disco externo; restore.js	S1-E2 §11	REC-01 a REC-12
RQ-08	Técnico	Detección de ataques y trazabilidad de eventos	Suricata, Cowrie y Wazuh	S1-E1 §14	PC-17, PC-18, PC-19
RQ-09	Técnico	Alertas de disponibilidad de los servicios	Uptime Kuma con latido externo	S1-E2 §11	PC-20
RQ-10	Técnico	Capacidad con margen ≥ 30 % para crecimiento	Host de 64 GB (47 % comprometido); presupuesto de RAM del VPS	S1-E2 §10	Medición en S2-E3 §9
RQ-11	Organizacional	Cumplimiento de la Ley N.° 29733 (datos de menores)	Clasificación, cifrado en tránsito, mínimo privilegio	S2-E1	Auditoría interna
RQ-12	Técnico	Administración del VPS solo por canal cifrado y restringido	UFW-08, UFW-09 y bastión	S1-E1 §13	PC-15
RQ-13	Organizacional	Costo de licencias mínimo	Software libre: Proxmox VE, OPNsense, Wazuh, Suricata, Cowrie y strongSwan	S1-E2 §4, §7	Revisión de licencias

ID	Tipo	Requisito	Elemento de diseño	Sección	Verificación (S2)
RQ-14	Técnico	Escalable a nuevas sedes	Bloque 10.x.0.0/16 por sede; el VPS como concentrador VPN	S1-E1 §15	—
RQ-15	Técnico	Réplica relacional disponible 24/7	VM-APP01 y proxy en el VPS	S1-E2 §8	PC-14, PC-20

3. Servicios y procesos críticos dependientes de la red

Proceso	Servicio TI	Dependencia de red	Criticidad	Efecto si cae la red de la sede
Matrícula pública	SPA en Vercel + Firestore	Internet del postulante	Crítica	Ninguno: opera en la nube
Registro y anulación de pagos	SPA + Firestore (claim de administrador)	Internet de la sede (ADMIN)	Crítica	Se registra desde otra conexión (4G); WAN2 mitiga
Asistencia por QR	SPA + Firestore (auxiliares)	Internet en la sede (ACAD, Wi-Fi)	Alta	Se interrumpe en la sede; WAN2 mitiga
Consulta de asistencia de padres	SPA + `parentAttendance`	Internet del padre	Media	Ninguno
Sincronización, reportes y analítica	API + MySQL + analítica	SRV y túnel hacia el proxy del VPS	Media	Reportes desactualizados; Firestore sigue siendo la fuente de verdad
Sistema del colegio	VPS	Internet	Alta	Ninguno por la sede
Respaldo externo del VPS	Túnel IPsec	Sede ↔ VPS	Alta	Las copias se posponen hasta restablecer el túnel
Administración de infraestructura	Bastión y VPN	MGMT y túnel	Media	Acceso de emergencia por la consola del proveedor
Monitoreo y detección	Wazuh, Uptime Kuma, Suricata	SRV y túnel	Media	Pérdida temporal de visibilidad

4. Partes interesadas relevantes

Parte interesada	Categoría de la guía	Interés o necesidad de red	Influencia
Alumnos, postulantes y padres	Clientes	Acceso web confiable; protección de sus datos personales y de menores	Media
Personal administrativo, docentes y auxiliares	Empleados	Conectividad estable en la sede; separación de su tráfico	Media
Dirección de la academia y del colegio	Dirección	Continuidad del servicio, costo y cumplimiento legal	Alta
Encargado de TI y equipo técnico	Administradores	Gestión segura, trazabilidad y acceso remoto controlado	Alta
RackNerd (VPS), Vercel, Google/Firebase, GitHub, Punto.pe/RCP y Let's Encrypt	Proveedores	Uso conforme a sus términos; responsabilidad compartida	Media
ISP de fibra y operador móvil (4G)	ISP	Contrato de ancho de banda, tipo de IP y soporte	Alta
Proveedor IaaS (referencia AWS en la guía)	Nube	En este proyecto el rol lo cumple RackNerd; AWS Academy queda como alternativa no usada	Media
ANPD (MINJUSDH), MINEDU/UGEL Azángaro y OSIPTEL	Organismos reguladores	Protección de datos personales (Ley N.° 29733), normativa educativa y supervisión de los servicios de telecomunicaciones	Alta

5. Alcance del diseño de red

Declaración de alcance. Diseño de la red de la sede principal de Azángaro, de su conexión segura con el VPS de RackNerd y de su relación con los servicios PaaS, incluidos segmentación, direccionamiento, ruteo, perímetro, VPN y detección.

Límite	Incluye
Físico	Sede principal (cuarto de equipos, cableado, Wi-Fi) y VPS en New York
Tecnológico	LAN y Wi-Fi por VLAN, firewall OPNsense, Suricata, honeypot, VPN IPsec, firewall de host del VPS, DNS del dominio y flujos hacia PaaS
Organizacional	Infraestructura compartida por la academia y el colegio

Exclusión	Justificación
Otras sedes	Solo se reserva su direccionamiento; se integran con el mismo patrón de VPN

Exclusión	Justificación
Red interna de Vercel, Firebase y GitHub	La gestiona cada proveedor (responsabilidad compartida)
Red física del colegio	Su sistema se usa por Internet; no comparte red con la sede
VPN de acceso remoto para usuarios	Los portales son web; para administradores se propone OpenVPN con certificado y TOTP en una fase posterior
Firewall redundante (CARP)	Costo de un segundo host; se documenta como mejora futura
Telefonía IP y videovigilancia IP	Fuera del objeto del proyecto

6. Objetivos medibles del diseño

ID	Objetivo	Indicador	Meta	Verificación (S2-E2)
OBJ-R1	Segmentar los servidores críticos	VM ubicadas en VLAN 40, 50 o 99	7 de 7 (100 %)	Inventario de Proxmox
OBJ-R2	Aislar la gestión	Interfaces de gestión en VLAN 99 alcanzables solo desde ADMIN_TI y el bastión	100 %	PR-17 y PR-18
OBJ-R3	No exponer servicios internos	Puertos abiertos en la WAN de la sede	Solo 22/tcp del honeypot	PR-15
OBJ-R4	Considerar rutas alternas	Tiempo de conmutación a WAN2	≤ 60 s	PR-29
OBJ-R5	Cifrar el enlace híbrido	Túnel con AES-256-GCM, PFS y reconexión automática	≤ 2 min tras una caída	PR-24 y REC-09
OBJ-R6	Controlar el tráfico entre zonas	Flujos documentados con política por defecto de denegar	22 de 22	Matriz de zonas
OBJ-R7	Centralizar la detección	Dispositivos de seguridad que envían eventos al SIEM	100 % (OPNsense, Suricata, Cowrie, VPS y VM)	PR-30 a PR-32
OBJ-R8	Administrar el VPS solo por VPN	SSH del VPS alcanzable desde Internet	No	PR-28

7. Topología general de infraestructura de red

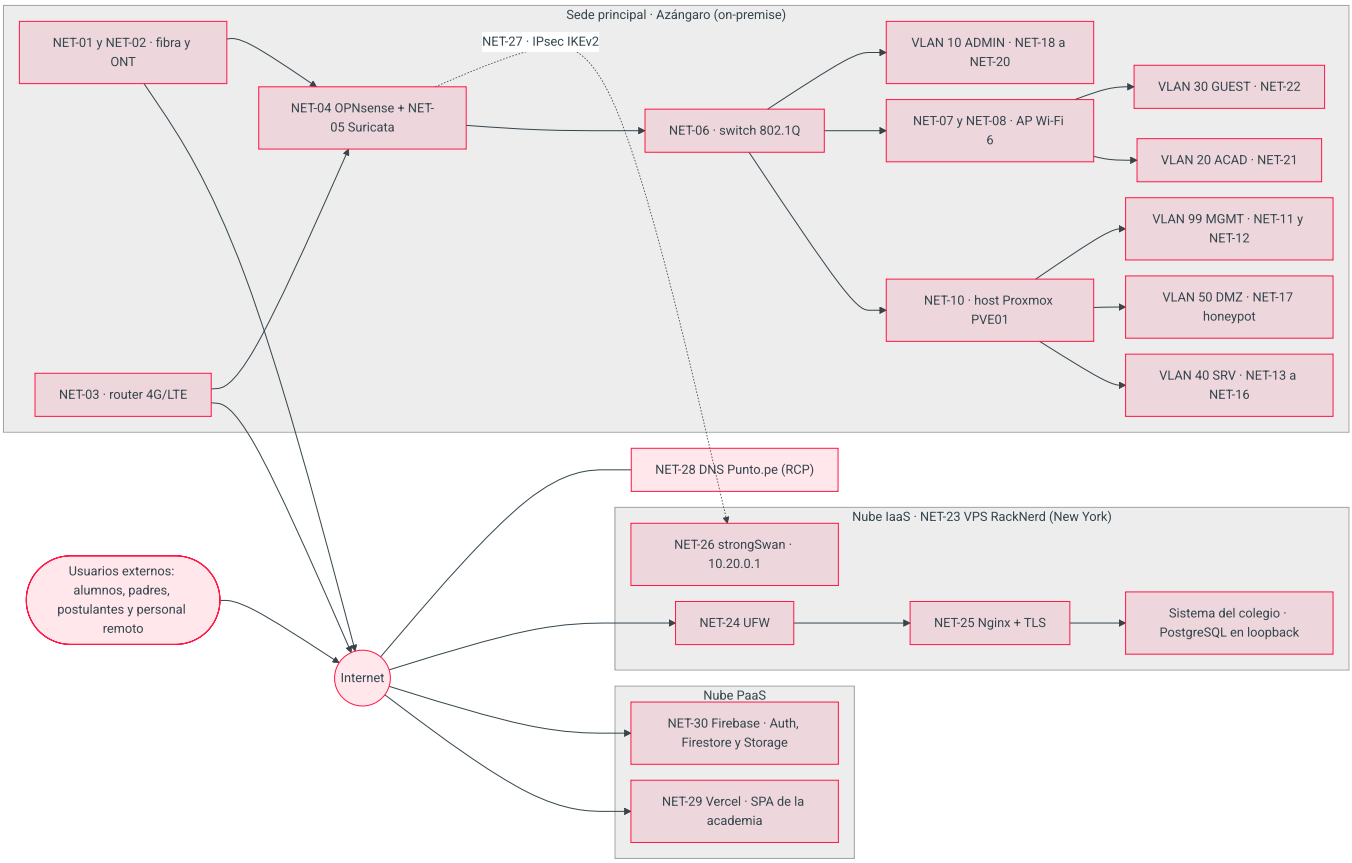


Diagrama editable: topologia-general-hibrida.drawio.

Elemento de la guía	En este diseño
Usuarios	Personal en la sede (ADMIN, ACAD), invitados (GUEST) y usuarios externos por Internet
Internet	Enlace de fibra (WAN1) y 4G/LTE (WAN2)
Firewall perimetral	OPNsense (VM-FW01) con Suricata
On-premise	Host Proxmox PVE01 con 7 VM
DMZ	VLAN 50 con el honeypot Cowrie
LAN	VLAN 10 ADMIN, 20 ACAD y 30 GUEST
Gestión	VLAN 99 con switch, AP, UPS, hipervisor, IPMI y bastión
Nube (AWS en la guía)	VPS RackNerd (IaaS) y Vercel/Firebase (PaaS)
VPN	Túnel IPsec NET-27 entre OPNsense y strongSwan

Situación actual (AS-IS). La sede no tiene firewall perimetral, DMZ, segmentación documentada ni UPS. La capa local corre en una PC con PM2 (NET-31). El inventario de equipos de red existentes (router del ISP, switch y puntos de acceso) está pendiente de levantamiento.

8. Topología lógica de red

8.1 VLAN, subredes y direccionamiento

VLAN	Zona	Nombre	Subred	Gateway	DHCP	Direcciones fijas	Uso	Confianza
10	ADMIN	Administrativa	10.10.10.0/24	10.10.10.1	10.10.10.100–10.10.10.199	.10 estación ADMIN_TI (reserva DHCP); .20 impresora	Dirección, secretaría/admisión y caja	Media
20	ACAD	Académica	10.10.20.0/24	10.10.20.1	10.10.20.100–10.10.20.250	—	Docentes y equipos de auxiliares para asistencia QR	Media
30	GUEST	Invitados	10.10.30.0/24	10.10.30.1	10.10.30.50 – 10.10.30.250	—	Wi-Fi de visitantes, padres y alumnos, con aislamiento de clientes	Baja
40	SRV	Servidores	10.10.40.0/24	10.10.40.1	Sin DHCP	.10 VM-APP01; .20 VM-SIEM01; .30 VM-MON01; .40 VM-BKP01	Servicios internos	Alta
50	DMZ	Zona desmilitarizada	10.10.50.0/24	10.10.50.1	Sin DHCP	.10 VM-HPOT01	Servicios expuestos y señuelo	Baja (expuesta)
99	MGMT	Gestión	10.10.99.0/27	10.10.99.1	Sin DHCP	.2 switch; .3 y .4 AP; .5 UPS; .10 PVE01; .11 IPMI; .20 bastión	Administración de la infraestructura	Máxima
—	NUBE	Red interna del VPS	10.20.0.0/24	Enrutada por el túnel	Sin DHCP	.1 VPS (interfaz dum0)	Extremo de nube del túnel IPsec	Alta
—	WAN1	Internet por fibra	Asignada por el ISP	Gateway del ISP	DHCP o PPPoE del ISP	IP pública de la sede (por confirmar: fija, dinámica o CGNAT)	Salida principal	No confiable

VLAN	Zona	Nombre	Subred	Gateway	DHCP	Direcciones fijas	Uso	Confianza
—	WAN2	Internet 4G/LTE	Red privada del router LTE	Router LTE	DHCP del router	—	Salida alterna con conmutación	No confiable

Plan de direccionamiento jerárquico (RFC 1918): 10.10.0.0/16 para la sede principal, 10.11.0.0/16 y 10.12.0.0/16 reservadas para otras sedes y 10.20.0.0/16 para la nube. Se pueden resumir rutas por sede y no hay solapamiento con las redes domésticas típicas (192.168.0.0/16). La VLAN 99 usa /27 porque solo aloja equipos de infraestructura con direcciones fijas.

8.2 Gateways, DHCP y DNS

- **Gateways:** la dirección .1 de cada VLAN pertenece a OPNsense (subinterfaces VLAN sobre la troncal).
- **DHCP:** rangos por VLAN; reservas para ADMIN_TI e impresora. SRV, DMZ y MGMT solo usan direcciones fijas.
- **DNS:** Unbound en OPNsense resuelve para todas las VLAN, con listas de bloqueo de dominios maliciosos para GUEST y ACAD (control 8.23). La salida DNS directa de invitados se bloquea (prueba PC-21).
- **NTP:** OPNsense sirve hora a todas las zonas para que los registros sean correlacionables (control 8.17).

8.3 Ruteo

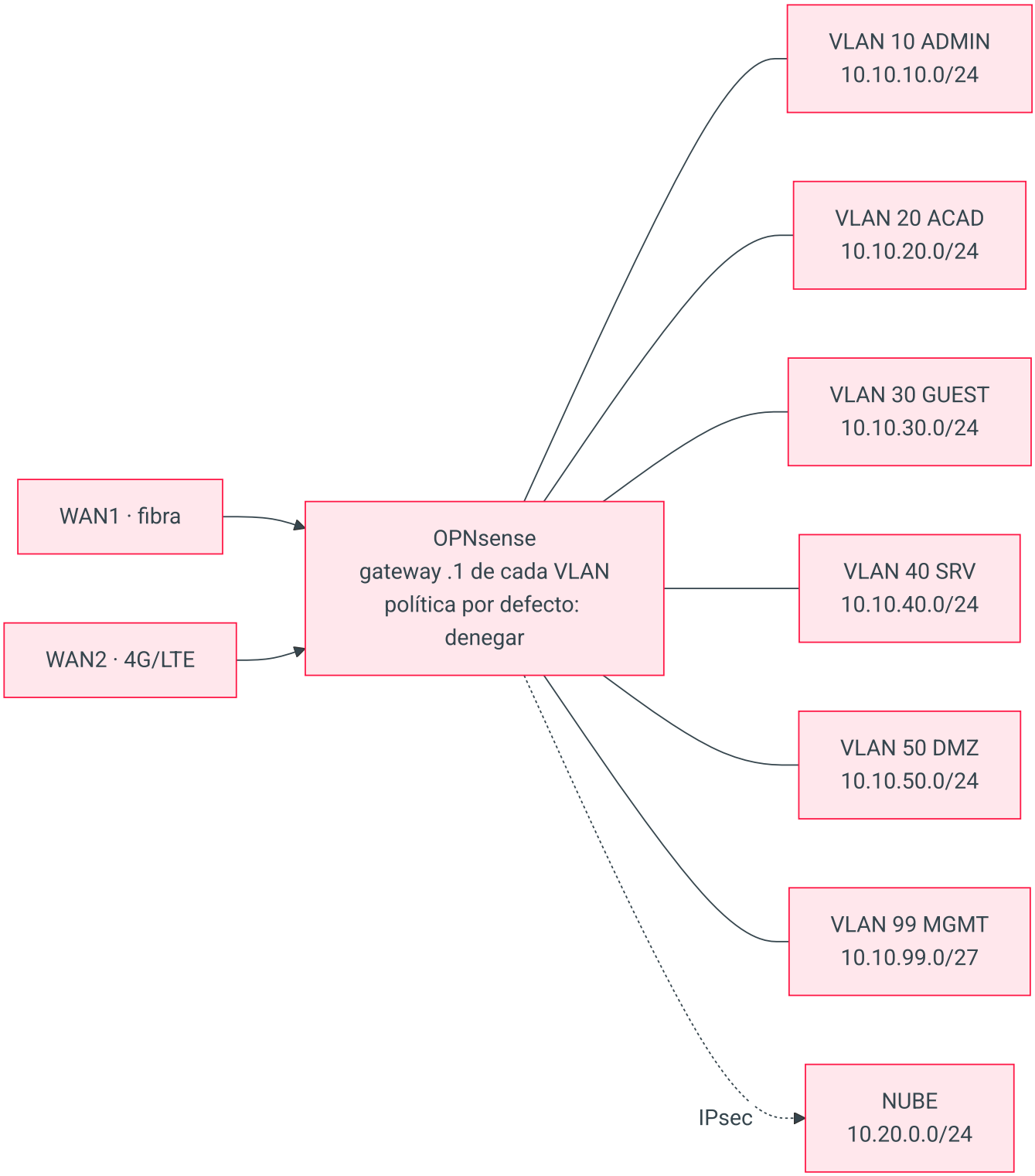


Diagrama editable: topologia-logica-vlan.drawio.

- **Router-on-a-stick:** OPNsense es el único equipo que enruta entre VLAN, de modo que todo el tráfico entre zonas pasa por el firewall. No se usa ruteo en el switch porque saltaría la política.
- **Ruta por defecto:** grupo de gateways con WAN1 en nivel 1 y WAN2 en nivel 2; conmuta por pérdida de paquetes o latencia alta.
- **Red de nube:** 10.20.0.0/24 se alcanza por la política IPsec, sin rutas estáticas manuales. En el VPS, strongSwan instala la ruta de vuelta en la tabla 220 usando 10.20.0.1 como origen.

- **Sin protocolo dinámico:** la red es pequeña y estable; OSPF añadiría complejidad sin beneficio. Se reconsidera al integrar más sedes.

8.4 Comunicación permitida y denegada entre zonas

Origen → destino	Internet	ADMIN	ACAD	GUEST	SRV	DMZ	MGMT	NUBE
Internet	—	D	D	D	D	L (FW-60)	D	D
ADMIN (10)	P (FW-24)	P (misma VLAN)	D	D	L (FW-21, solo ADMIN_TI)	D	L (FW-20, solo ADMIN_TI)	D
ACAD (20)	P (FW-13)	L (FW-11, impresora)	P (misma VLAN)	D	D	D	D	D
GUEST (30)	L (FW-03)	D	D	D (aislamiento en AP)	D	D	D	D
SRV (40)	L (FW-30, FW-33)	D	D	D	L (microsegmentación en Proxmox)	D	D	L (FW-32)
DMZ (50)	D (FW-41)	D	D	D	L (FW-40, solo agente Wazuh)	—	D	D
MGMT (99)	L (FW-56)	D	D	D	L (FW-50 a FW-53)	L (FW-55)	P (misma VLAN)	L (FW-54)
NUBE (10.20.0.0/24)	— (salida propia del VPS)	D	D	D	L (FW-70 a FW-72)	D	D	—

P = permitido; L = limitado a las reglas indicadas (sección 13.5); D = denegado por la política por defecto, con registro. El tráfico dentro de SRV se filtra además con el firewall de Proxmox (solo puertos de agentes y respaldo).

8.5 Redes inalámbricas

SSID	VLAN	Seguridad	Controles
CERMAT-ADMIN	10	WPA3-Personal (WPA2/WPA3 en transición si hay equipos antiguos)	Clave rotada cada semestre; WPA3-Enterprise con RADIUS como mejora futura
CERMAT-DOCENTES	20	WPA3-Personal	Clave distinta a la de ADMIN
CERMAT-INVITADOS	30	WPA3-Personal con clave publicada en la sede, o portal cautivo de OPNsense	Aislamiento de clientes, limitador de ancho de banda y aceptación de la política de uso

9. Diseño de seguridad perimetral y zonas

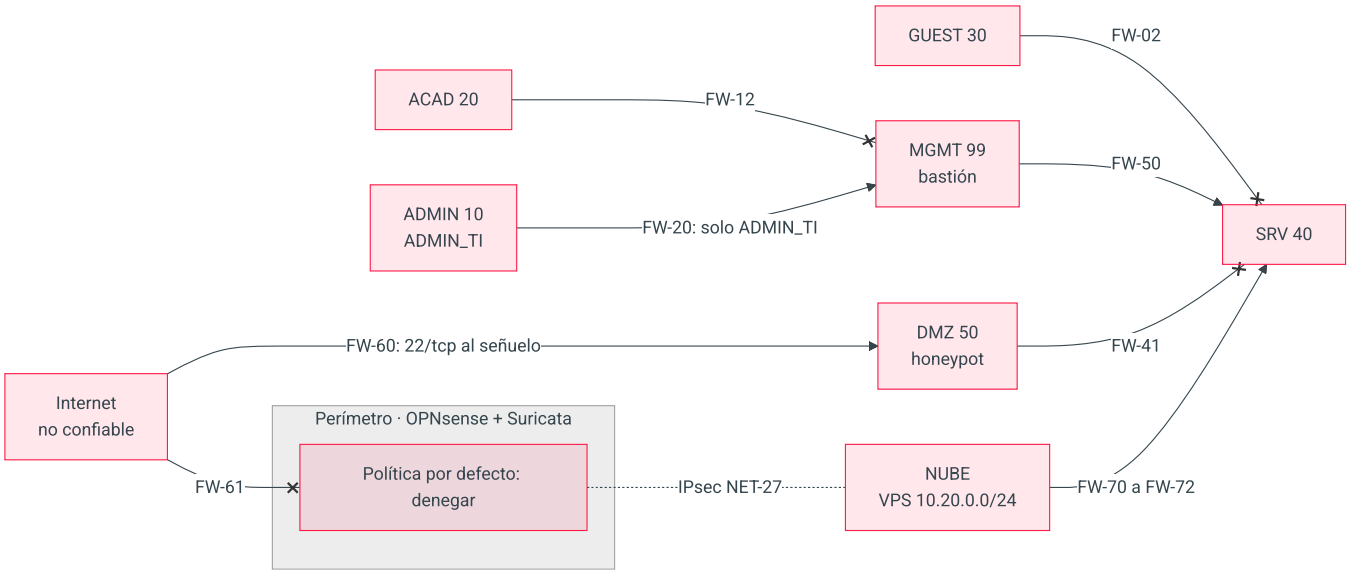


Diagrama editable: zonas-seguridad-vpn.drawio.

Zona	Confianza	Qué protege	Regla clave
Internet	No confiable	—	Ninguna entrada salvo FW-60
DMZ (50)	Baja (expuesta)	Aloja solo el señuelo	Sin salida (FW-41)
GUEST (30)	Baja	—	Solo Internet (FW-02, FW-03)
ACAD (20)	Media	Equipos de docentes y auxiliares	Internet e impresora (FW-11 a FW-13)
ADMIN (10)	Media	Equipos con acceso a pagos y datos personales	Solo ADMIN_TI llega a MGMT y SRV
SRV (40)	Alta	API, MySQL, SIEM, monitoreo y respaldos	Accesible solo desde el bastión, ADMIN_TI y el VPS por el túnel
MGMT (99)	Máxima	Hipervisor, switch, AP, UPS y bastión	Accesible solo desde ADMIN_TI
NUBE	Alta	Extremo VPN y proxy	Solo puertos definidos hacia SRV (FW-70 a FW-72)

Defensa en profundidad.

Capa	Control
Perímetro	OPNsense con filtrado con estado, NAT y Suricata
Segmentación	VLAN con política por defecto de denegar y DMZ sin salida
Host	UFW en el VPS; firewall de Proxmox en las VM; SSH solo con llaves desde el bastión

Capa	Control
Aplicación	Reglas de Firestore por rol y titularidad; API que verifica tokens de Firebase; roles MySQL de mínimo privilegio
Detección	Suricata, Cowrie y Wazuh; Uptime Kuma para disponibilidad

Riesgo del firewall virtualizado. OPNsense corre como VM en el mismo host que los servidores, lo que es aceptado en la arquitectura de referencia de la guía (firewall virtual sobre ESXi). Se mitiga así:

- Las WAN llegan por NIC físicas dedicadas (`vmbr1` , `vmbr2`) sin IP del host.
- La gestión del hipervisor solo existe en la VLAN 99.
- Si el host falla, el router del ISP se pasa a modo router para dar Internet a una estación administrativa. Como los servicios críticos están en la nube, la academia sigue operando.

10. Diseño de conectividad VPN híbrida

Parámetro	Extremo on-premise	Extremo nube
Equipo	OPNsense (VM-FW01), interfaz WAN	strongSwan (swanctl) en el VPS
Rol	Iniciador (la sede puede tener IP dinámica o CGNAT)	Respondedor (IP pública fija del VPS)
Redes anunciadas	10.10.40.0/24 (SRV) y 10.10.99.0/27 (MGMT)	10.20.0.0/24 (interfaz `dum0` , 10.20.0.1)
Redes no anunciadas	10.10.10.0/24, 10.10.20.0/24, 10.10.30.0/24 y 10.10.50.0/24	—
Tipo de túnel	IPsec sitio a sitio basado en políticas, IKEv2 (RFC 7296)	Igual
Autenticación	Certificados X.509 de una CA propia (ECDSA P-384)	Igual
Propuesta IKE	`aes256gcm16-prfsha256-ecp384` (alterna `…-ecp256`)	Igual
Propuesta ESP	`aes256gcm16-ecp384` con PFS (alterna `…-ecp256`)	Igual
Grupos DH	20 (ECP-384) y 19 (ECP-256)	Igual
Vida de las SA	Renegociación IKE cada 4 h; CHILD cada 1 h	Igual
NAT-T y DPD	Encapsulación UDP 4500 forzada; DPD cada 30 s con reinicio	DPD cada 30 s con limpieza
MTU	MSS máximo de 1360 en la interfaz IPsec	Igual

Justificación de los algoritmos. AES-GCM es un cifrado autenticado (RFC 4106), así que no requiere un algoritmo de integridad separado. SHA-256 se usa como función pseudoaleatoria de IKE. Los grupos de curva elíptica 19 y 20 están entre los recomendados por NIST SP 800-77r1. PFS asegura que una llave comprometida no descifre tráfico pasado. Con el encapsulado UDP forzado, ESP atraviesa NAT y CGNAT y en el VPS basta abrir UDP 500 y 4500.

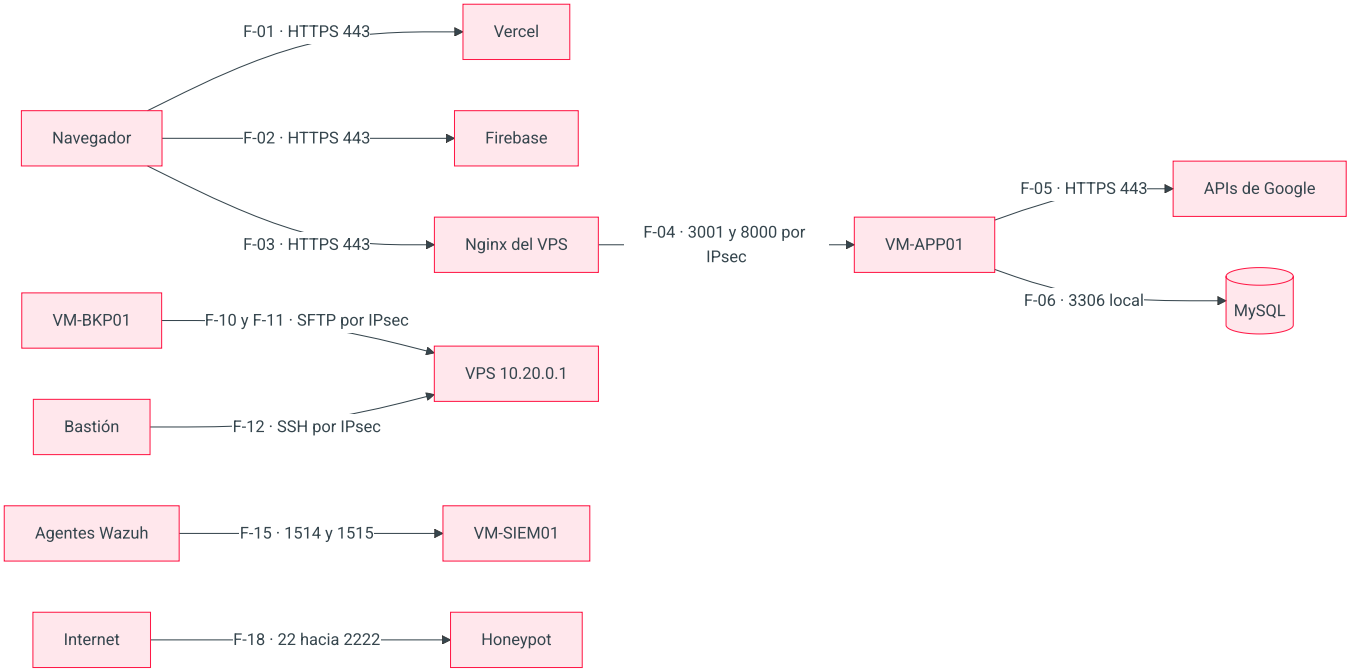
Sin secretos. Las llaves privadas se generan en cada extremo y nunca salen de él: en OPNsense, en su almacén de certificados; en el VPS, en `/etc/swanctl/private` con permisos 600. Ninguna llave, certificado privado ni clave compartida se versiona.



Uso del túnel	Flujo	Beneficio
Respaldo 3-2-1 del VPS en la sede (modelo pull)	F-10	Copia fuera del VPS sin dar al VPS credenciales de la sede
Copia externa cifrada de la sede en el VPS	F-11	Tercera copia fuera de la sede (restic cifrado)
Administración SSH del VPS solo por VPN	F-12	Permite cerrar 22/tcp a Internet (UFW-08, UFW-09)
Monitoreo y SIEM	F-15, F-16	Agente Wazuh y métricas del VPS sin exponer puertos
Publicación de la API de la academia	F-03, F-04	El VPS publica la API con TLS aunque la sede no tenga IP pública

Equivalencia con AWS. En AWS Site-to-Site VPN, el extremo de nube sería un Virtual Private Gateway con dos túneles, la VPC 10.20.0.0/16 y una ruta propagada hacia 10.10.40.0/24 y 10.10.99.0/27. Los parámetros de cifrado elegidos son compatibles con ese servicio.

11. Diagrama de flujo de información planeado



ID	Origen	Destino	Protocolo y puerto	Propósito	Ruta	Estado
F-01	Usuarios (Internet o sede)	SPA en Vercel	HTTPS 443/tcp	Uso de la plataforma académica	Internet	Implementado
F-02	Navegador	Firebase Auth, Firestore y Storage	HTTPS 443/tcp	Identidad y datos operativos	Internet	Implementado
F-03	Navegador (admin, docente, auxiliar)	Proxy del VPS (subdominio propuesto api-academia)	HTTPS 443/tcp	Sincronización hacia MySQL, no bloqueante	Internet	Pendiente (hoy http://localhost:3001 en la PC local)
F-04	VPS 10.20.0.1 (Nginx)	VM-APP01 10.10.40.10	HTTP 3001/tcp y 8000/tcp dentro de IPsec	Proxy inverso hacia la API y la analítica	Túnel IPsec	Pendiente
F-05	VM-APP01	APIs de Google (Firebase Admin)	HTTPS 443/tcp	Verificar tokens de identidad	Internet (NAT de OPNsense)	Implementado en la PC local
F-06	API y analítica	MySQL 8	3306/tcp en loopback	Persistencia relacional	Local	Implementado en la PC local
F-07	Visitantes	Sitio y API del colegio (VPS)	HTTP 80/tcp → 301; HTTPS 443/tcp	Sistema de gestión del colegio	Internet	Implementado
F-08	Laravel (PHP-FPM)	PostgreSQL 16	5432/tcp en loopback	Datos del colegio	Local	Implementado
F-09	OPNsense (WAN)	VPS (IP pública)	UDP 500 y 4500 (IKEv2, NAT-T)	Establecer el túnel	Internet	Pendiente

ID	Origen	Destino	Protocolo y puerto	Propósito	Ruta	Estado
F-10	VM-BKP01 10.10.40.40	VPS 10.20.0.1	SSH/SFTP 22/tcp dentro de IPsec	Extraer el pg_dump diario (modelo pull)	Túnel IPsec	Pendiente
F-11	VM-BKP01 10.10.40.40	VPS 10.20.0.1	SFTP 22/tcp dentro de IPsec	Copia externa cifrada (restic) de los respaldos de MySQL	Túnel IPsec	Pendiente
F-12	Bastión 10.10.99.20	VPS 10.20.0.1	SSH 22/tcp dentro de IPsec	Administración del VPS	Túnel IPsec	Pendiente
F-13	Bastión 10.10.99.20	VM de SRV y DMZ	SSH 22/tcp y 22022/tcp	Administración de servidores	LAN (OPNsense)	Pendiente
F-14	ADMIN_TI 10.10.10.10	PVE01, switch, AP, UPS y OPNsense	HTTPS 443/tcp y 8006/tcp; SSH 22/tcp	Gestión de la infraestructura	LAN (OPNsense)	Pendiente
F-15	Agentes Wazuh (VM, host, VPS, honeypot, OPNsense)	VM-SIEM01 10.10.40.20	1514/tcp (eventos), 1515/tcp (registro)	Centralización de eventos	LAN y túnel	Pendiente
F-16	Netdata (host, VM-APP01, VPS)	VM-MON01 10.10.40.30	19999/tcp	Métricas de capacidad	LAN y túnel	Pendiente
F-17	Uptime Kuma (VM-MON01)	Vercel, VPS, API y túnel	HTTPS 443/tcp, ICMP	Disponibilidad y vigencia de certificados	Internet y túnel	Pendiente
F-18	Internet	Honeypot 10.10.50.10	22/tcp → 2222/tcp (NAT)	Captura de intentos de intrusión	Internet → DMZ	Pendiente (requiere IP pública en la sede)
F-19	PVE01 10.10.99.10	VM-BKP01 10.10.40.40	8007/tcp	Respaldo de VM	LAN (OPNsense)	Pendiente
F-20	GitHub Actions	Firebase (reglas)	HTTPS 443/tcp	Publicación de reglas tras el CI	Internet	Implementado en código (requiere el secreto)
F-21	Equipos ACAD	Impresora 10.10.10.20	9100/tcp, 631/tcp	Impresión	LAN (OPNsense)	Pendiente
F-22	Equipos de la sede	OPNsense (Unbound y NTP)	DNS 53, NTP 123	Resolución de nombres y hora	LAN	Pendiente

12. Matriz de componentes de red

ID	Componente	IP planeada	Zona	Función	Criticidad	Estado al 2026-10-24	Diagramas
NET-01	Enlace de Internet por fibra (ISP principal)	IP asignada por el ISP	WAN1	Salida principal a Internet y terminación del túnel	Alta	Existente (tipo de IP por confirmar)	General, Lógica
NET-02	ONT o módem del ISP en modo puente	Sin gestión expuesta	WAN1	Entrega el enlace de fibra al firewall	Alta	Existente (modo por confirmar)	General, Física
NET-03	Router 4G/LTE de respaldo	Red privada del router LTE	WAN2	Salida alterna con conmutación automática	Media	Diseñado	General, Lógica, Física
NET-04	Firewall perimetral OPNsense (VM-FW01)	WAN1 y WAN2 por DHCP/PPPoE; .1 en cada VLAN	Perímetro	Filtrado con estado, ruteo entre VLAN, NAT, DHCP, DNS, NTP e IPsec	Crítica	Diseñado	General, Lógica, Zonas, Hipervisor
NET-05	Suricata (IDS/IPS en OPNsense)	IPS en WAN1/WAN2; IDS en la troncal interna	Perímetro	Detección y bloqueo de tráfico malicioso	Alta	Diseñado	General, Zonas
NET-06	Switch gestionable de 24 puertos PoE+ (802.1Q, LACP)	10.10.99.2	MGMT	Conmutación, VLAN y agregación de enlaces con el host	Crítica	Diseñado	General, Lógica, Física
NET-07	Punto de acceso Wi-Fi 6 n.° 1	10.10.99.3	MGMT	SSID por VLAN (10, 20 y 30)	Media	Diseñado	General, Lógica
NET-08	Punto de acceso Wi-Fi 6 n.° 2	10.10.99.4	MGMT	SSID por VLAN (10, 20 y 30)	Media	Diseñado	General, Lógica
NET-09	UPS con interfaz de red (NUT)	10.10.99.5	MGMT	Respaldo eléctrico y apagado ordenado	Alta	Diseñado	General, Física
NET-10	Host hipervisor PVE01 (gestión)	10.10.99.10	MGMT	Virtualización de las VM de red y de servidores	Crítica	Diseñado	General, Lógica, Física, Hipervisor
NET-11	Gestión fuera de banda del host (IPMI)	10.10.99.11	MGMT	Consola remota del servidor físico	Media	Diseñado	Lógica, Física

ID	Componente	IP planeada	Zona	Función	Criticidad	Estado al 2026-10-24	Diagramas
NET-12	Bastión SSH (VM-BAS01)	10.10.99.20	MGMT	Punto único de administración por SSH, incluida la VPN	Alta	Diseñado	General, Lógica, Zonas, Hipervisor
NET-13	Servidor de aplicaciones (VM-APP01)	10.10.40.10	SRV	API Node.js (3001), MySQL 8 (3306 local) y analítica FastAPI (8000)	Alta	Diseñado (hoy en la PC local)	General, Lógica, Zonas, Hipervisor
NET-14	SIEM Wazuh (VM-SIEM01)	10.10.40.20	SRV	Correlación de eventos, alertas e inventario de agentes	Alta	Diseñado	General, Lógica, Zonas, Hipervisor
NET-15	Monitoreo (VM-MON01)	10.10.40.30	SRV	Uptime Kuma (disponibilidad) y Netdata (métricas)	Media	Diseñado	General, Lógica, Zonas, Hipervisor
NET-16	Respaldo (VM-BKP01, Proxmox Backup Server)	10.10.40.40	SRV	Respaldo de VM y repositorio de copias del VPS	Alta	Diseñado	General, Lógica, Zonas, Hipervisor
NET-17	Honeypot Cowrie (VM-HPOT01)	10.10.50.10	DMZ	Señuelo SSH/Telnet para detectar ataques	Media	Diseñado	General, Lógica, Zonas, Hipervisor
NET-18	Estación de administración TI (ADMIN_TI)	10.10.10.10 (reserva DHCP)	ADMIN	Única estación de usuario con acceso a gestión	Alta	Diseñado	General, Lógica, Zonas
NET-19	Equipos administrativos	10.10.10.100 – 10.10.10.199	ADMIN	Operación de matrícula, pagos y reportes	Alta	Existentes (por inventariar)	General, Lógica
NET-20	Impresora de red	10.10.10.20	ADMIN	Impresión para ADMIN y ACAD	Baja	Por confirmar	General, Lógica

ID	Componente	IP planeada	Zona	Función	Criticidad	Estado al 2026-10-24	Diagramas
NET-21	Equipos académicos (docentes y auxiliares)	10.10.20.100 – 10.10.20.250	ACAD	Portales docente y auxiliar; lectura de QR	Media	Existentes (por inventariar)	General, Lógica
NET-22	Clientes Wi-Fi de invitados	10.10.30.50– 10.10.30.250	GUEST	Acceso a Internet aislado	Baja	Diseñado	General, Lógica
NET-23	VPS RackNerd (KVM, Ubuntu 24.04)	IP pública del VPS; 10.20.0.1 en dum0 (planificada)	NUBE	Sistema del colegio, extremo VPN y proxy inverso	Crítica	Implementado (dum0 pendiente)	General, Zonas, Nube
NET-24	Firewall de host UFW del VPS	—	NUBE	Entrada denegada por defecto; 22, 80 y 443/tcp permitidos	Alta	Implementado	General, Zonas, Nube
NET-25	Nginx con TLS (Let's Encrypt) en el VPS	IP pública del VPS: 80 → 301 y 443	NUBE	Servidor web, API del colegio y proxy inverso hacia la sede	Crítica	Implementado (proxy hacia la sede pendiente)	General, Zonas, Nube
NET-26	strongSwan IKEv2 en el VPS	IP pública del VPS (UDP 500/4500); 10.20.0.1	NUBE	Extremo de nube del túnel IPsec	Alta	Diseñado	General, Zonas, Nube
NET-27	Túnel IPsec sitio a sitio	10.10.40.0/24 y 10.10.99.0/27 ↔ 10.20.0.0/24	VPN	Respaldo, administración, monitoreo y proxy entre sede y nube	Alta	Diseñado	General, Lógica, Zonas
NET-28	DNS autoritativo (Punto.pe, servidores RCP)	Servicio del proveedor	Internet	Registros A, CNAME, MX y TXT del dominio	Alta	Implementado	General, Nube
NET-29	Vercel (SPA de la academia)	Dominio *.vercel.app	PaaS	Entrega de la plataforma por HTTPS	Crítica	Implementado	General, Nube
NET-30	Firebase (Auth, Firestore y Storage)	Servicio de Google	PaaS	Identidad y datos operativos	Crítica	Implementado	General, Nube

ID	Componente	IP planeada	Zona	Función	Criticidad	Estado al 2026-10-24	Diagramas
NET-31	PC local actual (API, MySQL y analítica con PM2)	Red actual de la sede, sin segmentar	Actual	Réplica relacional y analítica hasta migrar a VM-APP01	Media	Implementado (transitorio)	General

La matriz incluye los 31 componentes de los diagramas de topología general, lógica y de zonas; la columna "Diagramas" indica dónde aparece cada uno. Los usuarios externos e Internet son actores, no componentes.

---

13. Diseño de seguridad perimetral

13.1 Producto propuesto

OPNsense (licencia BSD de 2 cláusulas, sin costo). Integra filtrado con estado, NAT, IPsec, Unbound, DHCP, Suricata con conjuntos de reglas descargables, portal cautivo y exportación de registros por syslog o con el plugin de agente Wazuh. Corre como VM en Proxmox o en ESXi. pfSense CE es una alternativa equivalente; se prefiere OPNsense por su ciclo de actualizaciones y su interfaz IPsec basada en swanctl.

13.2 Interfaces y zonas

Interfaz de OPNsense	Dispositivo virtual	Zona	Dirección
WAN	vtnet0 sobre `vmbr1` (NIC3)	WAN1	DHCP o PPPoE del ISP
WAN2	vtnet1 sobre `vmbr2` (NIC4)	WAN2	DHCP del router LTE
ADMIN	VLAN 10 sobre vtnet2 (troncal en `vmbr0`)	ADMIN	10.10.10.1/24
ACAD	VLAN 20 sobre vtnet2	ACAD	10.10.20.1/24
GUEST	VLAN 30 sobre vtnet2	GUEST	10.10.30.1/24
SRV	VLAN 40 sobre vtnet2	SRV	10.10.40.1/24
DMZ	VLAN 50 sobre vtnet2	DMZ	10.10.50.1/24
MGMT	VLAN 99 sobre vtnet2	MGMT	10.10.99.1/27
IPsec	enc0	VPN	Políticas hacia 10.20.0.0/24

13.3 Política por defecto

- Denegar todo lo entrante por las WAN; el único reenvío de puertos es el del honeypot (FW-60), y solo si hay IP pública.
- Denegar el tráfico entre VLAN salvo reglas explícitas; registrar los bloqueos en SRV, DMZ, MGMT e IPsec.

- Interfaz web y SSH del firewall solo en MGMT; regla anti-bloqueo desactivada en las demás interfaces.
- Usuario administrador nominativo con TOTP; respaldo cifrado de `config.xml` después de cada cambio.

13.4 Criterio general de reglas

1. **Mínimo privilegio:** origen, destino y puerto concretos; no se usa "any → any" salvo como bloqueo final.
2. **Orden de evaluación:** permisos específicos → bloqueo de `PRIVADAS` → salida a Internet → bloqueo por defecto (primera coincidencia).
3. **Alias** para redes y equipos (`PRIVADAS`, `ADMIN_TI`, `BASTION`, `VPS_INTERNO`), para que una dirección se cambie en un solo lugar.
4. **Trazabilidad:** la descripción de cada regla lleva su ID (FW-xx) y el flujo (F-xx) que habilita.
5. **Gestión de cambios:** toda regla nueva pasa por el procedimiento de cambios (S2-E3) y se revisa cada trimestre.

13.5 Reglas planeadas en OPNsense

ID	Interfaz	Origen	Destino	Servicio	Acción	Registro	Propósito
FW-01	GUEST	Red GUEST	Firewall (10.10.30.1)	DNS 53/tcp-udp	Permitir	No	Resolución DNS con Unbound y listas de bloqueo
FW-02	GUEST	Red GUEST	Alias PRIVADAS (RFC 1918)	Cualquiera	Bloquear	Sí	Aislar a los invitados de las redes internas y de la VPN
FW-03	GUEST	Red GUEST	Internet (no PRIVADAS)	80/tcp, 443/tcp, 443/udp	Permitir con limitador de ancho de banda	No	Navegación
FW-04	GUEST	Cualquiera	Cualquiera	Cualquiera	Bloquear	Sí	Política por defecto
FW-10	ACAD	Red ACAD	Firewall (10.10.20.1)	DNS 53, NTP 123	Permitir	No	Servicios de infraestructura
FW-11	ACAD	Red ACAD	Impresora 10.10.10.20	9100/tcp, 631/tcp	Permitir	No	Impresión
FW-12	ACAD	Red ACAD	Alias PRIVADAS	Cualquiera	Bloquear	Sí	Sin acceso a ADMIN, SRV, DMZ, MGMT ni VPN

ID	Interfaz	Origen	Destino	Servicio	Acción	Registro	Propósito
FW-13	ACAD	Red ACAD	Internet	80/tcp, 443/tcp, 443/udp	Permitir	No	Plataforma (Vercel y Firebase) y navegación
FW-20	ADMIN	ADMIN_TI (10.10.10.10)	Red MGMT	22/tcp, 443/tcp, 8006/tcp	Permitir	Sí	Administración de switch, AP, UPS, firewall e hipervisor
FW-21	ADMIN	ADMIN_TI (10.10.10.10)	Red SRV	22/tcp, 443/tcp, 3001/tcp, 8007/tcp, 19999/tcp	Permitir	Sí	Consolas de Wazuh, Uptime Kuma, PBS y Netdata
FW-22	ADMIN	Red ADMIN	Firewall (10.10.10.1)	DNS 53, NTP 123	Permitir	No	Servicios de infraestructura
FW-23	ADMIN	Red ADMIN	Alias PRIVADAS	Cualquiera	Bloquear	Sí	Usuarios administrativos sin acceso a gestión ni a servidores
FW-24	ADMIN	Red ADMIN	Internet	80/tcp, 443/tcp, 443/udp	Permitir	No	Plataforma y servicios en la nube
FW-30	SRV	VM-APP01 (10.10.40.10)	Internet	443/tcp	Permitir	Sí	Verificación de tokens de Firebase (APIs de Google)
FW-31	SRV	Red SRV	Firewall (10.10.40.1)	DNS 53, NTP 123	Permitir	No	Servicios de infraestructura
FW-32	SRV	VM-BKP01 (10.10.40.40)	VPS 10.20.0.1	22/tcp (SFTP)	Permitir	Sí	Extraer respaldos del VPS y guardar la copia externa cifrada
FW-33	SRV	Red SRV	Internet	80/tcp, 443/tcp	Permitir	No	Actualizaciones de paquetes

ID	Interfaz	Origen	Destino	Servicio	Acción	Registro	Propósito
FW-34	SRV	Red SRV	Cualquiera	Cualquiera	Bloquear	Sí	Política por defecto (ADMIN, ACAD, GUEST, DMZ y MGMT)
FW-40	DMZ	VM-HPOT01 (10.10.50.10)	VM-SIEM01 (10.10.40.20)	1514/tcp, 1515/tcp	Permitir	Sí	Enviar los eventos del honeypot al SIEM
FW-41	DMZ	Red DMZ	Cualquiera	Cualquiera	Bloquear	Sí	Contención: el honeypot no inicia conexiones (prueba DMZ → DB)
FW-50	MGMT	Bastión (10.10.99.20)	Red SRV	22/tcp, 443/tcp	Permitir	Sí	Administración de servidores
FW-51	MGMT	PVE01 (10.10.99.10)	VM-BKP01 (10.10.40.40)	8007/tcp	Permitir	No	Respaldo de VM hacia Proxmox Backup Server
FW-52	MGMT	Red MGMT	VM-SIEM01 (10.10.40.20)	1514/tcp, 1515/tcp	Permitir	No	Agentes Wazuh del host y del bastión
FW-53	MGMT	Red MGMT	VM-MON01 (10.10.40.30)	19999/tcp	Permitir	No	Métricas Netdata del host
FW-54	MGMT	Bastión (10.10.99.20)	VPS 10.20.0.1	22/tcp	Permitir	Sí	Administración del VPS solo por la VPN
FW-55	MGMT	Bastión (10.10.99.20)	VM-HPOT01 (10.10.50.10)	22022/tcp	Permitir	Sí	Administración del honeypot (SSH real en puerto alterno)
FW-56	MGMT	Red MGMT	Internet	80/tcp, 443/tcp	Permitir	No	Actualizaciones de firmware y del hipervisor

ID	Interfaz	Origen	Destino	Servicio	Acción	Registro	Propósito
FW-57	MGMT	Red MGMT	Firewall (10.10.99.1)	DNS 53, NTP 123, 443/tcp	Permitir	No	Servicios de infraestructura e interfaz web del firewall
FW-58	MGMT	Cualquiera	Cualquiera	Cualquiera	Bloquear	Sí	Política por defecto
FW-60	WAN1/WAN2	Internet	IP de WAN, 22/tcp → NAT a 10.10.50.10:2222	22/tcp	Permitir (reenvío)	Sí	Exposición del honeypot, solo si la sede tiene IP pública
FW-61	WAN1/WAN2	Internet	Cualquiera	Cualquiera	Bloquear	Sí (muestreo)	Política por defecto; ningún otro reenvío de puertos
FW-70	IPsec	VPS 10.20.0.1	VM-APP01 (10.10.40.10)	3001/tcp, 8000/tcp	Permitir	Sí	Proxy inverso del VPS hacia la API y la analítica
FW-71	IPsec	VPS 10.20.0.1	VM-SIEM01 (10.10.40.20)	1514/tcp, 1515/tcp	Permitir	No	Agente Wazuh del VPS
FW-72	IPsec	VPS 10.20.0.1	VM-MON01 (10.10.40.30)	19999/tcp	Permitir	No	Métricas Netdata del VPS
FW-73	IPsec	Cualquiera	Cualquiera	Cualquiera	Bloquear	Sí	Política por defecto del túnel

13.6 Firewall de host del VPS (equivalente a Security Group)

ID	Regla	Estado al 2026-10-24	Propósito
UFW-01	default deny incoming	Implementado	Entrada denegada por defecto
UFW-02	default allow outgoing	Implementado	Salida para actualizaciones y renovación de certificados
UFW-03	allow 80/tcp	Implementado	Desafío HTTP-01 de Let's Encrypt y redirección a HTTPS
UFW-04	allow 443/tcp	Implementado	Sitio y API del colegio; proxy hacia la sede (futuro)
UFW-05	allow 22/tcp	Implementado (transitorio)	Administración; se reemplaza por UFW-08 cuando la VPN esté validada

ID	Regla	Estado al 2026-10-24	Propósito
UFW-06	allow 500,4500/udp	Pendiente	IKEv2 y NAT-T del túnel
UFW-07	allow in from 10.10.40.40 to 10.20.0.1 port 22 proto tcp	Pendiente	Extracción de respaldos (usuario SFTP restringido)
UFW-08	allow in from 10.10.99.20 to 10.20.0.1 port 22 proto tcp	Pendiente	SSH solo desde el bastión por la VPN
UFW-09	delete allow 22/tcp	Pendiente	Cierre de SSH a Internet; la consola del proveedor queda como acceso de emergencia
UFW-10	limit 22/tcp + fail2ban	Pendiente	Mitigar fuerza bruta mientras SSH siga expuesto

14. Diseño de detección: IDS/IPS y honeypot

14.1 IDS/IPS (Suricata en OPNsense)

Aspecto	Diseño
Ubicación	Modo IPS (en línea, netmap) en WAN1 y WAN2; modo IDS (solo alerta) sobre la troncal interna para ver el tráfico entre zonas
Conjuntos de reglas	ET Open (Emerging Threats), abuse.ch SSL Blacklist y Feodo Tracker; reglas locales para la DMZ y la gestión
Política	Descartar en categorías de explotación, escaneo y malware conocidas; solo alertar en el resto durante el primer mes para afinar falsos positivos
Requisito técnico	Desactivar en OPNsense la descarga de CRC, TSO y LRO por hardware, necesario para netmap sobre NIC virtio
Registro	Alertas EVE en syslog hacia Wazuh (o agente Wazuh en OPNsense) con 90 días de retención

14.2 Honeypot (Cowrie)

Aspecto	Diseño
Ubicación	VM-HPOT01 en la DMZ (10.10.50.10), aislada: sin salida (FW-41)
Exposición	Si la sede tiene IP pública, NAT de WAN 22/tcp a Cowrie 2222/tcp (FW-60). Si hay CGNAT, opera como señuelo interno: cualquier conexión desde la LAN es sospechosa por definición
Interacción	Media: emula SSH y Telnet y registra credenciales y comandos sin dar un shell real
Administración	SSH real en el puerto 22022, solo desde el bastión (FW-55)

Aspecto	Diseño
Registro	`cowrie.json` leído por el agente Wazuh con reglas locales

14.3 SIEM (Wazuh)

Wazuh (VM-SIEM01) recibe los eventos del firewall, Suricata, Cowrie, el VPS, el hipervisor y las VM. Su panel concentra la correlación, las alertas y el inventario de agentes.

14.4 Eventos esperados

Evento	Fuente	Regla o firma	Severidad	Respuesta
Escaneo de puertos desde la LAN o Internet	Suricata	Categoría ET SCAN	Media	Revisar el origen; bloquear si es externo y persistente
Intento de acceso a la gestión desde usuarios	OPNsense	Bloqueo de FW-12 o FW-23	Media	Verificar el equipo; posible equipo comprometido
Conexión al honeypot	Cowrie	`cowrie.session.connect` (regla local 100100)	Baja (Internet) o alta (LAN)	Desde la LAN: tratar como incidente
Inicio de sesión o comandos en el honeypot	Cowrie	`cowrie.login.*` y `cowrie.command.input` (reglas 100101 y 100102)	Alta	Registrar credenciales usadas; revisar exposición de cuentas reales
Fuerza bruta SSH contra el VPS	Wazuh (sshd)	Reglas 5710, 5712, 5716 y 5720	Alta	Confirmar el bloqueo de fail2ban; acelerar el cierre de 22/tcp
Respuesta sospechosa (`uid=0`) en HTTP	Suricata	SID 2100498	Alta	Prueba de validación; en producción, investigar
Caída del túnel IPsec	Uptime Kuma y registro de IPsec	Sin respuesta de 10.20.0.1 por 3 minutos	Media	Procedimiento REC-09

14.5 Plan de validación para el Semestre 2

Prueba	Qué valida	Criterio de aceptación
PC-17 / PR-30	Cadena Suricata → Wazuh con una firma inocua	Alerta SID 2100498 en Wazuh en menos de 1 minuto, con IP de origen y fecha
PC-18 / PR-31	Detección de escaneo interno	Al menos una alerta ET SCAN correlacionada con el origen GUEST
PC-19 / PR-32	Honeypot de punta a punta	Evento de Cowrie con usuario y contraseña intentados, visible en Wazuh con nivel ≥ 10

Prueba	Qué valida	Criterio de aceptación
PR-37	Detección sobre el servicio expuesto real	Alertas de sshd del VPS en Wazuh con conteo diario

15. Escalabilidad, conclusiones, hoja de ruta y referencias

15.1 Escalabilidad

- **Nuevas sedes:** cada sede recibe un bloque 10.x.0.0/16 con las mismas VLAN y un túnel IPsec hacia el VPS, que actúa como concentrador.
- **Capacidad:** VLAN /24 con más de 200 direcciones libres; switch de 24 puertos con PoE+ ampliable por apilamiento; Suricata dimensionado con holgura en VM-FW01.
- **Alta disponibilidad futura:** segundo OPNsense con CARP y sincronización de estados cuando se justifique un segundo host.
- **Wi-Fi corporativo:** WPA3-Enterprise con RADIUS cuando crezca el número de usuarios de ADMIN.

15.2 Conclusiones

1. El diseño sustituye una red plana y sin perímetro por 6 zonas con política por defecto de denegar, 35 reglas trazables y 22 flujos documentados.
2. La VPN IPsec IKEv2 resuelve tres necesidades con un solo túnel: respaldo externo cruzado, administración del VPS sin exponer SSH y publicación de la API aunque la sede no tenga IP pública.
3. La detección combina prevención en el perímetro (Suricata), un señuelo de alta señal (Cowrie) y correlación central (Wazuh), con un plan de validación medible.
4. Las sustituciones tecnológicas (Proxmox, VPS y PaaS) conservan la equivalencia con ESXi y AWS, y bajan el costo de licencias a cero.

15.3 Hoja de ruta hacia la implementación

Fase	Plazo	Actividades
0. Correcciones en la nube	Hasta 2026-10-31	Reglas de Firestore corregidas publicadas (hecho el 2026-10-24); MFA en cuentas de proveedores
1. Endurecimiento de lo existente	Hasta 2026-11-21	Cabeceras de seguridad y DNS (CAA, SPF, DMARC); verificación de SSH y fail2ban en el VPS
1b. Laboratorio de validación (opcional)	Hasta 2026-11-21	Reproducir la sede en un Proxmox de laboratorio para ejecutar PR-14 a PR-35; las evidencias se rotulan como de laboratorio

Fase	Plazo	Actividades
2. Implementación en la sede	Sujeta a la adquisición del hardware (2027-I)	Switch, AP, host, OPNsense, VLAN, VPN, Suricata, honeypot y Wazuh
3. Operación	Continuo	Revisión trimestral de reglas; pruebas de detección mensuales

15.4 Referencias

[1] C. Kaufman, P. Hoffman, Y. Nir, P. Eronen y T. Kivinen, "Internet Key Exchange Protocol Version 2 (IKEv2)," RFC 7296, IETF, oct. 2014.

[2] J. Viega y D. McGrew, "The Use of Galois/Counter Mode (GCM) in IPsec Encapsulating Security Payload (ESP)," RFC 4106, IETF, jun. 2005.

[3] A. Huttunen, B. Swander, V. Volpe, L. DiBurro y M. Stenberg, "UDP Encapsulation of IPsec ESP Packets," RFC 3948, IETF, ene. 2005.

[4] Y. Rekhter, B. Moskowitz, D. Karrenberg, G. J. de Groot y E. Lear, "Address Allocation for Private Internets," RFC 1918, IETF, feb. 1996.

[5] E. Barker, Q. Dang, S. Frankel, K. Scarfone y P. Wouters, "Guide to IPsec VPNs," NIST SP 800-77 Rev. 1, jun. 2020.

[6] K. Scarfone y P. Hoffman, "Guidelines on Firewalls and Firewall Policy," NIST SP 800-41 Rev. 1, sep. 2009.

[7] K. Scarfone y P. Mell, "Guide to Intrusion Detection and Prevention Systems (IDPS)," NIST SP 800-94, feb. 2007.

[8] *IEEE Standard for Local and Metropolitan Area Networks—Bridges and Bridged Networks*, IEEE Std 802.1Q-2022, 2022.

[9] *IEEE Standard for Local and Metropolitan Area Networks—Link Aggregation*, IEEE Std 802.1AX-2020, 2020.

[10] *Balanced Twisted-Pair Telecommunications Cabling and Components Standard*, ANSI/TIA-568.2-D, 2018.

[11] Deciso B.V., "OPNsense Documentation." [En línea]. Disponible en: https://docs.opnsense.org/

[12] strongSwan Project, "swanctl.conf Reference." [En línea]. Disponible en: https://docs.strongswan.org/

[13] Open Information Security Foundation, "Suricata User Guide." [En línea]. Disponible en: https://docs.suricata.io/

[14] Cowrie Project, "Cowrie SSH/Telnet Honeypot." [En línea]. Disponible en: https://github.com/cowrie/cowrie

[15] Wazuh Inc., "Wazuh Documentation." [En línea]. Disponible en: https://documentation.wazuh.com/

[16] Amazon Web Services, "AWS Site-to-Site VPN User Guide." [En línea]. Disponible en: https://docs.aws.amazon.com/vpn/

Anexos

Anexo A. Matriz de pruebas de conectividad planeadas

ID	Prueba	Origen	Destino o servicio	Herramienta	Resultado esperado	Regla o requisito
PC-01	Internet → DMZ	Equipo externo (datos móviles)	IP de WAN, 22/tcp (honeypot)	ssh; nmap -Pn -p 22	Sesión simulada de Cowrie y alerta en Wazuh; ningún otro puerto abierto	FW-60, FW-61
PC-02	Internet → LAN	Equipo externo	IP de WAN, 1000 puertos más comunes	nmap -Pn -sS --top-ports 1000	Solo responde 22/tcp (honeypot); el resto filtrado	FW-61
PC-03	DMZ → DB	VM-HPOT01 (10.10.50.10)	10.10.40.10:3306	nc -vz -w 3	Bloqueado y registrado por el firewall	FW-41
PC-04	Usuarios → MGMT	Equipo ADMIN (10.10.10.150) y equipo ACAD (10.10.20.120)	10.10.99.10:8006 y 10.10.99.2:443	curl -k -m 5; nc -vz	Bloqueado y registrado	FW-12, FW-23
PC-05	ADMIN → MGMT	ADMIN_TI (10.10.10.10)	10.10.99.10:8006	Navegador; curl -k	Permitido (interfaz de Proxmox)	FW-20
PC-06	Invitados → redes internas	Cliente GUEST	10.10.10.0/24, 10.10.40.0/24 y 10.10.99.0/27	ping; nmap -sn	Sin respuesta; bloqueos registrados	FW-02
PC-07	Invitados → Internet	Cliente GUEST	https://academia-school-platform.vercel.app	Navegador; curl -I	Permitido; DNS resuelto por el firewall	FW-01, FW-03
PC-08	Aislamiento de clientes Wi-Fi	Cliente GUEST A	Cliente GUEST B	ping	Sin respuesta (aislamiento en el AP)	Configuración del AP
PC-09	ACAD → impresora y ADMIN	Equipo ACAD	10.10.10.20:9100 y 10.10.10.150	nc -vz	Impresora permitida; equipo ADMIN bloqueado	FW-11, FW-12
PC-10	SRV → Internet	VM-APP01	APIs de Google 443/tcp; servidor SMTP 25/tcp	curl -I; nc -vz	443 permitido; 25 bloqueado	FW-30, FW-34

ID	Prueba	Origen	Destino o servicio	Herramienta	Resultado esperado	Regla o requisito
PC-11	Establecimiento del túnel	OPNsense ↔ VPS	IKEv2	swanctl --list-sas; estado IPsec en OPNsense	IKE_SA ESTABLISHED y CHILD_SA INSTALLED con AES_GCM_16_256 y ECP_384	Diseño VPN
PC-12	VPN bidireccional	Bastión ↔ VPS	10.20.0.1:22; desde el VPS, 10.10.40.10:3001/health	ssh; curl	Ambos sentidos responden dentro del túnel	FW-54, FW-70
PC-13	Selectores de tráfico	VPS 10.20.0.1	10.10.10.0/24 y 10.10.20.0/24	ping; nc -vz	Sin ruta por el túnel (redes no anunciadas)	Diseño VPN
PC-14	Publicación de la API por el VPS	Internet	https://api-academia…/health y otra ruta	curl -I	/health responde 200 a través del túnel; otras rutas 404	Nginx (proxy)
PC-15	SSH del VPS tras el endurecimiento	Internet y bastión	IP pública del VPS:22 y 10.20.0.1:22	nc -vz; ssh	Bloqueado desde Internet; permitido desde el bastión	UFW-08, UFW-09
PC-16	Conmutación de enlaces	Equipo ADMIN	Internet	ping continuo; desconectar WAN1	Recuperación en ≤ 60 s por WAN2; el túnel se restablece	Grupo de gateways
PC-17	Detección IDS con firma de prueba	Equipo ACAD	http://testmynids.org/uid/index.html	curl	Alerta de Suricata SID 2100498 visible en Wazuh	Suricata
PC-18	Detección de escaneo	Cliente GUEST	10.10.30.1 (firewall)	nmap -sS -T4	Alertas ET SCAN en Suricata y en Wazuh	Suricata
PC-19	Inicio de sesión en el honeypot	Equipo externo	Honeypot Cowrie	ssh root@	Evento cowrie.login en Wazuh con regla local de nivel ≥ 10	Cowrie y Wazuh
PC-20	Caída de la API	VM-APP01	Uptime Kuma	pm2 stop cermat-api	Alerta en ≤ 2 min y recuperación registrada	Uptime Kuma
PC-21	DNS forzado en invitados	Cliente GUEST	8.8.8.8:53	nslookup	Bloqueado; solo resuelve el firewall	FW-01, FW-04

ID	Prueba	Origen	Destino o servicio	Herramienta	Resultado esperado	Regla o requisito
PC-22	MTU por el túnel	VM-BKP01 → VPS	Transferencia SFTP de 100 MB	sftp; ping -M do -s 1332	Sin fragmentación ni cortes (MSS 1360)	Diseño VPN

Estas pruebas se ejecutan en S2-E2 como PR-14 a PR-35, con resultado obtenido y evidencia.

Anexo B. Diagramas editables

Diagrama	Archivo	Contenido
Topología general híbrida	topologia-general-hibrida.drawio	Usuarios, Internet, sede, nube IaaS, PaaS y túnel
Topología lógica	topologia-logica-vlan.drawio	VLAN, subredes, gateways, DHCP y ruteo
Zonas de seguridad y VPN	zonas-seguridad-vpn.drawio	Niveles de confianza, reglas clave, pruebas de segmentación y parámetros del túnel

Los archivos se abren en diagrams.net o en draw.io Desktop; desde ahí se exportan a PNG o PDF.

Anexo C. Estándares aplicados

Estándar	Aplicación en el diseño
IEEE 802.1Q	VLAN y troncales entre switch, host y AP
IEEE 802.1AX (LACP)	Agregación de enlaces entre el host y el switch
IEEE 802.3 / 802.3at	Ethernet cableado y PoE+ para los AP
IEEE 802.11ax (Wi-Fi 6)	SSID por VLAN con WPA3
ANSI/TIA-568.2-D y TIA-606	Cableado Cat 6 y etiquetado
RFC 1918	Direccionamiento privado
RFC 7296, RFC 4106 y RFC 3948	IKEv2, ESP con AES-GCM y NAT-T
NIST SP 800-41r1, 800-77r1 y 800-94	Política de firewall, VPN IPsec e IDPS
ISO/IEC 27001:2022, controles 8.20 a 8.22	Seguridad, servicios y segregación de redes (vínculo con el SGSI de S2-E1)

Rúbrica de evaluación

N°	Criterio de evaluación	Peso
1	Contexto y alcance del diseño de red	10%

N°	Criterio de evaluación	Peso
2	Arquitectura lógica de red: VLAN, subredes y direccionamiento	20%
3	Diseño de conectividad híbrida (VPN)	15%
4	Diseño de seguridad perimetral: firewall, DMZ y segmentación	20%
5	Diseño de detección: IDS/IPS y honeypot (planificación)	10%
6	Diagrama de flujo de información y matriz de componentes	10%
7	Calidad documental y trazabilidad del diseño	8%
8	Sustentación del diseño	7%
	Total	**100%**

Escala: Excelente 4, Logrado 3, En proceso 2, Insuficiente 1 y No evidenciado 0. Puntaje = peso × (nivel / 4).

Dónde se evidencia cada criterio

Criterio	Secciones
1	2 a 6
2	8
3	10
4	9 y 13
5	14
6	11 y 12
7	Portada (versiones), anexos, matrices y diagramas
8	Exposición ante el jurado (pendiente)

S1-E2 · Análisis y Diseño de Centro de Datos Híbrido (CE0331)

CE0331 — Diseño de centro de datos

Arquitectura on-premise virtualizada (Proxmox VE, equivalente a VMware ESXi), arquitectura de nube (VPS de RackNerd equivalente a EC2 en una VPC, más PaaS), integración híbrida, dimensionamiento, disponibilidad y continuidad. Documento de **análisis y diseño, sin implementación**: el despliegue y el control se documentan en S2-E3. El diseño de red asociado está en S1-E1.

Portada

Campo	Detalle
Título	Análisis y diseño del centro de datos híbrido de CERMAT
Entregable	Semestre 1 · Entregable 2 · CE0331
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo), UPeU campus Juliaca, sección g1
Fecha	2026-10-24
Versión	2.0
Organización	CERMAT, Azángaro (Puno, Perú)

Control de versiones

Versión	Fecha	Cambio
1.0	2026-07-06	Diseño de rack, Tier y dimensionamiento de un servidor local con contenedores (estructura anterior de la guía)
2.0	2026-10-24	Reescrito según la guía vigente: hipervisor, VM, nube con equivalencias AWS, integración híbrida, RTO/RPO por servicio y matriz de componentes

Productos obligatorios

Producto	Formato entregado	Ubicación	Criterio de aceptación (guía)
Informe de análisis y diseño de centro de datos híbrido	Página versionada en Git; PDF desde la vista de impresión	Este documento	Completo, versionado y coherente con la organización

Producto	Formato entregado	Ubicación	Criterio de aceptación (guía)
Diagramas de arquitectura	draw.io editable de 3 páginas y Mermaid	arquitectura-centro-datos-hibrido.drawio	Topología física on-premise, hipervisor y nube (VPC/AWS equivalente)
Matriz de componentes y dimensionamiento	XLSX y secciones 9 y 10	s1-e2-matriz-componentes-dimensionamiento.xlsx	100 % de los elementos dibujados (36) y sustento del dimensionamiento

1. Resumen ejecutivo del diseño del centro de datos híbrido

Problema. La capa relacional de la academia (API Node.js, MySQL 8 y analítica FastAPI) corre en una PC con PM2. Ese equipo no está pensado para servicio continuo: sin redundancia de disco, sin UPS y con respaldos en el mismo disco que la base. Además, solo sincroniza cuando está encendido. El sistema del colegio está en un VPS de 2 GB de RAM sin respaldo externo. No hay dónde alojar los servicios de seguridad que pide la línea (firewall, SIEM, honeypot, monitoreo y respaldo).

Solución.

- **On-premise:** un rack de 12U en la sede principal con un host **Proxmox VE** (equivalente a ESXi) de 8 núcleos, 64 GB ECC, espejo ZFS de 2×1 TB y un HDD de 4 TB para respaldos. Corre 7 VM: OPNsense con Suricata, servidor de aplicaciones, Wazuh, monitoreo, Proxmox Backup Server, honeypot y bastión. UPS con apagado ordenado y doble enlace de Internet.
- **Nube IaaS:** se reutiliza el **VPS de RackNerd** ya contratado (US$ 35,99 al año), equivalente a una instancia EC2 en una VPC: UFW como Security Group, una red interna 10.20.0.0/24 como subred privada y strongSwan como VPN Gateway.
- **Nube PaaS:** Vercel para la plataforma y Firebase para identidad y datos; siguen siendo la vía crítica de la operación.

Dimensionamiento. Las VM suman 14 vCPU, 24 GB de RAM y 344 GB de disco. Con el sistema, el host compromete 30 de 64 GB (47 %) y 38 % del espejo, con margen para una VM de pruebas y para absorber el sistema del colegio si los 2 GB del VPS no alcanzan.

Disponibilidad. Tier I con elementos de Tier II. Si la sede falla, la matrícula, los pagos y la asistencia siguen en la nube. RTO de 1 h y RPO de 24 h para la base relacional.

Siguientes pasos. Cotizar y adquirir el hardware; mientras tanto, implantar en S2-E3 los respaldos del VPS y de Firestore y validar el diseño en un laboratorio.

Cifra del diseño	Valor
Componentes del centro de datos	36
VM planeadas	7
vCPU / RAM / disco de VM	14 / 24 GB / 344 GB

Cifra del diseño	Valor
RAM del host comprometida	30 de 64 GB (47 %)
Costo de licencias de software on-premise	US$ 0 (software libre)

2. Descripción de la organización y necesidades de infraestructura

2.1 Servicios a alojar

Servicio	Hoy	Destino del diseño	Motivo
Plataforma de la academia (SPA)	Vercel	Vercel	HTTPS y reversión de despliegues gestionados; sin servidor que mantener
Identidad y datos operativos	Firebase	Firebase	Fuente de verdad con reglas por rol; tiempo real
API de sincronización, MySQL y analítica	PC local con PM2	VM-APP01 (sede), publicada por el VPS	Servicio 24/7, respaldos 3-2-1 y aislamiento en la VLAN 40
Sistema del colegio	VPS	VPS	Ya en producción con TLS y firewall
Firewall, IDS/IPS y VPN	No existe	VM-FW01 (sede)	Perímetro y segmentación de la sede
SIEM	No existe	VM-SIEM01 (sede)	Registros centralizados y correlación
Monitoreo	No existe	VM-MON01 (sede)	Disponibilidad, certificados y capacidad
Respaldo	Script en la PC local	VM-BKP01 (sede) + copias cruzadas	Regla 3-2-1
Honeypot	No existe	VM-HPOT01 (sede, DMZ)	Detección de ataques
Bastión	No existe	VM-BAS01 (sede, gestión)	Único punto de administración por SSH

2.2 Información gestionada

Información	Clasificación	Dónde reside
Datos personales de alumnos (incluidos menores) y apoderados	Restringida	Firestore; réplica en MySQL
Pagos y matrículas	Restringida	Firestore; réplica en MySQL con auditoría
Asistencia	Confidencial	Firestore; réplica en MySQL
Datos del colegio	Restringida	PostgreSQL en el VPS

Información	Clasificación	Dónde reside
Registros de eventos y alertas	Confidencial	VPS, VM y Wazuh
Respaldos	Restringida	VM-BKP01, VPS y disco externo cifrado

2.3 Uso previsto de la nube y del entorno local

Va a la **nube** lo que debe estar disponible para usuarios externos sin depender de la sede (portales, identidad y datos operativos) y lo que ya opera allí (el sistema del colegio). Queda en el **entorno local** lo que maneja copias completas de datos personales para reportes y auditoría (MySQL), lo que necesita ver el tráfico de la sede (firewall, IDS, honeypot) y lo que conviene tener cerca del personal técnico (SIEM, monitoreo y respaldo). La capa de la academia no se lleva al VPS porque compartiría 2 GB de RAM con el sistema del colegio (sección 10.5).

2.4 Crecimiento estimado

La plataforma está en piloto (8 matrículas y 8 perfiles al 2026-10-24). El dimensionamiento no extrapola esas cifras: reserva capacidad para crecer en usuarios, en agentes de seguridad y en una sede adicional (sección 10.4), con los supuestos de la sección 10.6.

3. Alcance del diseño

Límite	Incluye
Físico	Cuarto de equipos y rack de la sede principal de Azángaro; VPS en el centro de datos del proveedor (New York)
Tecnológico	Hipervisor, VM, almacenamiento, respaldo, energía, enlaces, VPS y su integración con los servicios PaaS
Organizacional	Servicios de la academia y la infraestructura que comparte con el colegio

Exclusión	Justificación
Clúster de hipervisores y almacenamiento compartido (SAN)	Costo y escala; el host único se acepta con mitigaciones (riesgo R-18)
Segundo centro de datos propio para recuperación	La nube (VPS y PaaS) cumple el papel de sitio externo para copias y servicios críticos
Migración del sistema del colegio	Es otro proyecto; el diseño solo deja capacidad para hacerla
Cuenta de AWS	No se dispone de ella; se usa la equivalencia técnica con el VPS (AWS Academy como alternativa no usada)

4. Objetivos medibles

ID	Objetivo	Meta	Verificación
OBJ-C1	Dimensionar el host con margen	≤ 50 % de RAM comprometida y ≤ 1 vCPU por hilo en el año 1 (47 % y 0,88)	Capacidad del host (sección 10.3) y Netdata en S2
OBJ-C2	Arquitectura de nube costo-eficiente	Reutilizar el VPS (US$ 35,99 al año), PaaS en el plan actual y US$ 0 en licencias on-premise	Inventario de proveedores
OBJ-C3	Disponibilidad mínima	99 % mensual en servicios internos (máximo ≈ 7,3 h de caída al mes); PaaS según el SLA del proveedor	Uptime Kuma (S2-E3)
OBJ-C4	RTO/RPO preliminar	MySQL: RTO 1 h y RPO 24 h; colegio: RTO 8 h y RPO 24 h; Firestore: RTO 4 h y RPO 24 h; SPA: RTO 15 min	Registro de recuperación (S2-E3)
OBJ-C5	No saturar el VPS	MemAvailable ≥ 25 % en hora pico tras agregar los componentes de integración	`free -m` y Netdata
OBJ-C6	Recuperar una VM	Restaurar VM-APP01 desde PBS en ≤ 2 h	REC-07

5. Arquitectura on-premise

5.1 Topología física

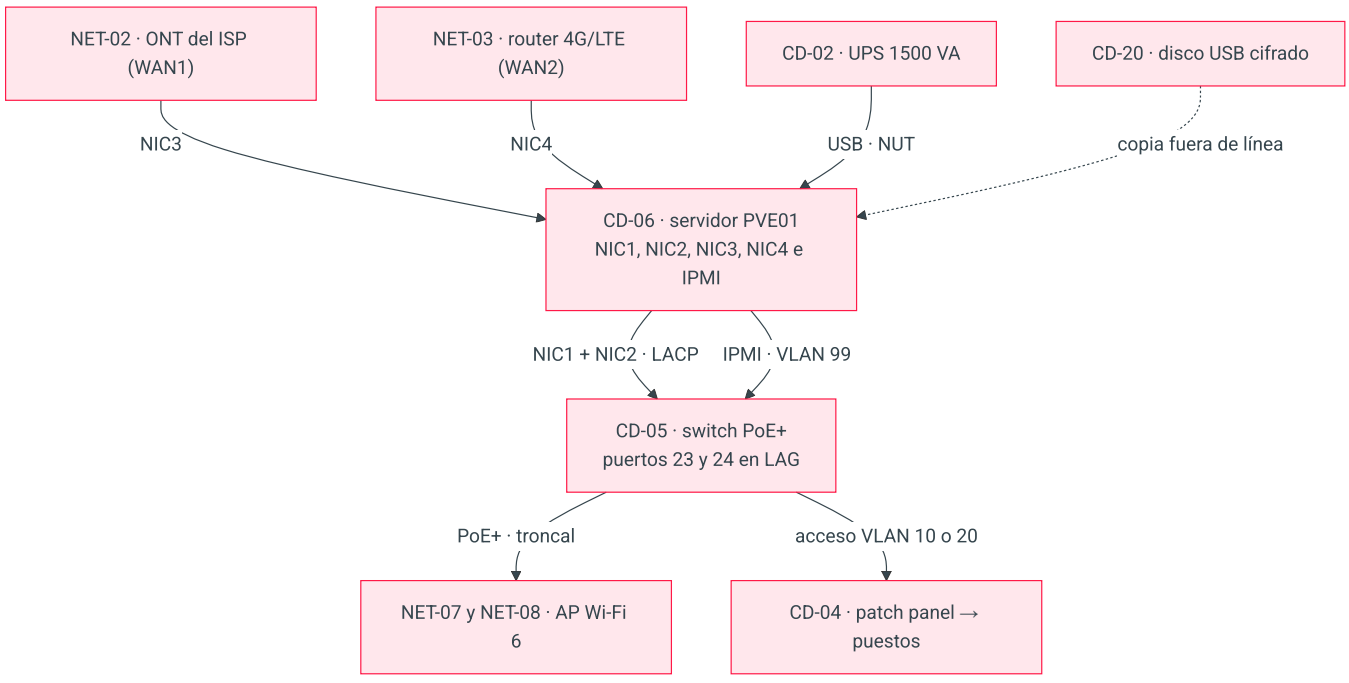


Diagrama editable: arquitectura-centro-datos-hibrido.drawio, página "Rack y topología física".

5.2 Rack

Unidad	Equipo
U12	CD-04 · patch panel Cat 6 de 24 puertos
U11	Organizador horizontal
U10	CD-05 · switch de 24 puertos PoE+
U9	Organizador horizontal
U8	Bandeja con la ONT del ISP y el router 4G/LTE
U6–U7	Libres para crecimiento
U4–U5	CD-06 · servidor PVE01 (2U)
U3	Bandeja para el disco USB cuando está en la sede
U1–U2	CD-02 · UPS de 1500 VA (2U)
Posterior	CD-03 · regleta o PDU

5.3 Firewall

El firewall perimetral es la VM **VM-FW01 (OPNsense con Suricata)**, con NIC físicas dedicadas para WAN1 (NIC3 → `vmbr1`) y WAN2 (NIC4 → `vmbr2`). Esos bridges no tienen IP del host, así que el hipervisor no queda expuesto a Internet. Arranca primero (orden 1). La contingencia ante una falla del host se describe en la sección 11.5.

5.4 Switches y puntos de acceso

Equipo	Requisitos
Switch	24 puertos GbE, al menos 4 con PoE+ (802.3at), 802.1Q, LACP (802.1AX), gestión web/SSH en VLAN 99, SNMPv3, protección de bucles y DHCP snooping
Puntos de acceso (2)	Wi-Fi 6 (802.11ax), varios SSID con VLAN, WPA3, aislamiento de clientes y alimentación PoE

5.5 Almacenamiento

Almacenamiento	Medio	Uso	Protección
`local-zfs`	2×1 TB SSD en espejo	Discos de las 7 VM	Tolera la falla de un disco; verificación mensual (`zpool scrub`)

Almacenamiento	Medio	Uso	Protección
Datastore de PBS	HDD de 4 TB en paso directo a VM-BKP01	Respaldos de VM y copias del VPS	Medio distinto del de las VM; verificación de respaldos programada
Disco externo	USB cifrado, rotación mensual	Copia fuera de línea y fuera de la sede	Cifrado completo; registro de custodia

5.6 UPS y energía

Equipo	Consumo típico (W)	Estado	Fuente
Servidor PVE01 (carga media)	90–150	Supuesto a validar	Hoja de datos del modelo elegido
Switch PoE+ con 2 AP	30–60	Supuesto a validar	Hoja de datos
ONT y router LTE	10–20	Supuesto a validar	Hoja de datos
Total	**130–230**	Supuesto a validar (SUP-06)	Suma

Con un UPS de 1500 VA y unos 200 W de carga se estiman 20–30 minutos de autonomía (SUP-05). NUT, por USB, ordena el apagado cuando quedan 10 minutos o el 50 % de batería: primero el honeypot, el monitoreo y la VM de aplicaciones; luego Wazuh, PBS y el bastión; al final el firewall y el host.

5.7 Host de virtualización

Elemento	Especificación	Justificación
CPU	8 núcleos / 16 hilos con VT-x/AMD-V y VT-d/AMD-Vi	14 vCPU planeadas; paso directo del HDD a PBS
RAM	64 GB ECC (2×32 GB)	30 GB comprometidos; ECC evita corrupción silenciosa con ZFS
Disco de VM	2×1 TB SSD, de preferencia con protección ante pérdida de energía	Espejo ZFS con 38 % de uso inicial
Disco de respaldo	1×4 TB HDD	Segundo medio de la regla 3-2-1
Red	4×1 GbE + puerto IPMI	2 para el bond LACP; 1 por cada WAN
Formato	Torre o rack de 2U	Cabe en el rack de 12U

5.8 Enlaces

Enlace	Medio	Función
WAN1	Fibra del ISP → ONT en modo puente → NIC3	Salida principal; ancho de banda por confirmar (SUP-02)

Enlace	Medio	Función
WAN2	Router 4G/LTE → NIC4	Salida alterna con conmutación automática
Host ↔ switch	2×1 GbE en LACP (NIC1 y NIC2)	Troncal de las 6 VLAN con redundancia
IPMI ↔ switch	1 GbE en acceso VLAN 99	Gestión fuera de banda

5.9 Nivel de disponibilidad (Uptime Institute)

Nivel	Disponibilidad de referencia	¿Aplica a CERMAT?
Tier I	99,671 % (≈ 28,8 h al año)	Base del diseño
Tier II	99,741 % (≈ 22,7 h al año)	Se adoptan sus elementos de redundancia de componentes: UPS, doble WAN y espejo de discos
Tier III	99,982 %	No: exige doble ruta de energía y mantenimiento concurrente
Tier IV	99,995 %	No: tolerancia total a fallas, fuera de escala

No se busca certificación. La sede es un cuarto de equipos (alineado con ANSI/TIA-942 Rated-1 con elementos de Rated-2), porque la disponibilidad de los servicios críticos la aportan los proveedores en la nube.

5.10 Ambiente y seguridad física

- Cuarto cerrado con llave, bitácora de ingreso y cámara orientada al rack, con aviso de videovigilancia (controles 7.1, 7.2 y 7.4).
- Temperatura de entrada entre 18 y 27 °C (rango recomendado por ASHRAE), con extracción o aire acondicionado dedicado y un sensor leído por Netdata.
- Extintor de CO2 cercano; el rack lejos de tuberías y ventanas (7.5).
- Cableado Cat 6 en canaletas y etiquetado (TIA-568 y TIA-606).

6. Diseño del hipervisor

6.1 Elección y equivalencia

Criterio	VMware ESXi (referencia de la guía)	Proxmox VE (adoptado)
Licencia	Comercial; edición gratuita incierta tras la adquisición por Broadcom	Libre (AGPLv3); suscripción de soporte opcional
Conmutación virtual	vSwitch estándar con port groups	Linux bridge VLAN-aware
Agregación de enlaces	NIC teaming	bond 802.3ad

Criterio	VMware ESXi (referencia de la guía)	Proxmox VE (adoptado)
Almacenamiento	VMFS, NFS, vSAN	ZFS, LVM-thin, Ceph
Respaldo	Herramientas de terceros	vzdump y Proxmox Backup Server integrados
Firewall por VM	Requiere NSX (licencia aparte)	Integrado
Gestión	vSphere Client o vCenter	Interfaz web (8006) y CLI `qm`

Proxmox VE cumple las mismas funciones que exige la guía (conmutadores virtuales, VLAN por VM, teaming y VM) sin costo de licencia. Si la institución obtiene una licencia de ESXi, el diseño se traslada uno a uno con la tabla de la sección 6.2.

6.2 Conmutadores virtuales, port groups y VLAN

Red virtual (Proxmox)	Equivalente en ESXi	Uplink	VLAN	Uso
`vmbr0` **(VLAN-aware)**	vSwitch0 con port groups ADMIN, ACAD, GUEST, SRV, DMZ y MGMT	bond0 (NIC1 + NIC2)	10, 20, 30, 40, 50, 99	Troncal interna
`vmbr0.99`	Puerto VMkernel de gestión	bond0	99	Gestión del host (10.10.99.10/27)
`vmbr1`	vSwitch1 "WAN1"	NIC3	Sin VLAN	Solo VM-FW01
`vmbr2`	vSwitch2 "WAN2"	NIC4	Sin VLAN	Solo VM-FW01
NIC virtual sin etiqueta con `trunks=10;20;30;40;50;99`	Port group troncal (VLAN 4095)	`vmbr0`	Todas	Interfaz interna de VM-FW01

6.3 NIC teaming

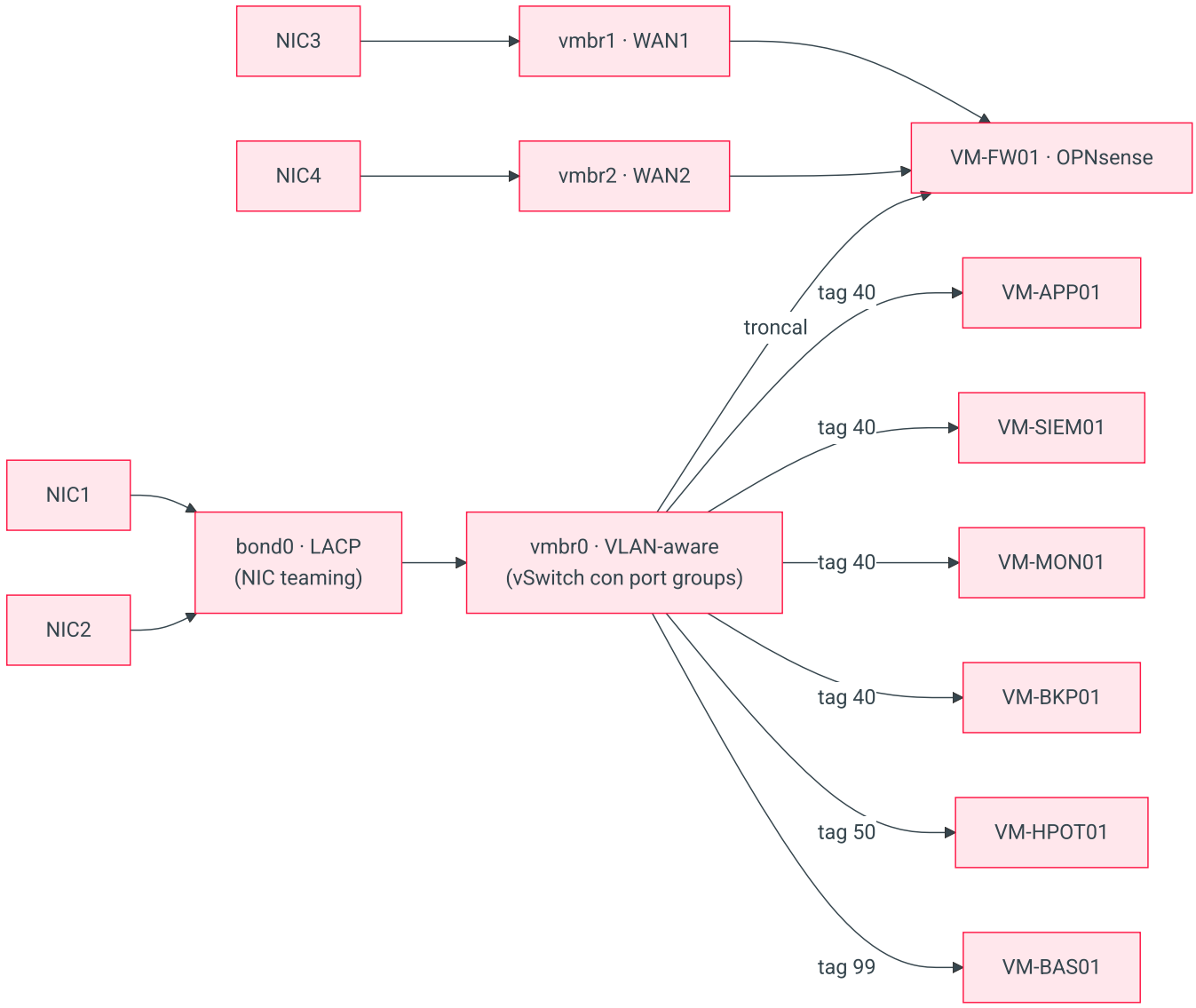
`bond0` agrupa NIC1 y NIC2 en modo 802.3ad (LACP) con hash `layer2+3` y supervisión de enlace cada 100 ms. En el switch, los puertos 23 y 24 forman un LAG con LACP activo. Si el switch elegido no soporta LACP, se usa `active-backup` (modo 1), que da redundancia sin agregación.

6.4 Máquinas virtuales planeadas

VM	Rol	Red virtual	Orden de arranque
VM-FW01	Firewall perimetral, IDS/IPS y VPN (OPNsense + Suricata)	`vmbr1`, `vmbr2` y troncal en `vmbr0`	1
VM-BAS01	Bastión SSH	`vmbr0`, tag 99	2
VM-SIEM01	SIEM (Wazuh)	`vmbr0`, tag 40	3

VM	Rol	Red virtual	Orden de arranque
VM-APP01	API Node.js, MySQL 8 y analítica FastAPI	`vmbr0` , tag 40	4
VM-BKP01	Proxmox Backup Server	`vmbr0` , tag 40	5
VM-MON01	Uptime Kuma y Netdata	`vmbr0` , tag 40	5
VM-HPOT01	Honeypot Cowrie	`vmbr0` , tag 50	6

Los recursos de cada VM (vCPU, RAM y disco) y su justificación están en la sección 10.2. Todas se inician solas al encender el host, en el orden indicado.



7. Arquitectura en la nube (equivalente a AWS)

7.1 Región

El VPS está en **New York (EE. UU.)**. Ya está contratado y en producción, cuesta US$ 35,99 al año y su latencia desde Perú es aceptable para aplicaciones web (supuesto a validar con `mtr`, SUP-04). Una región sudamericana reduciría la latencia a mayor costo y no es necesaria con el volumen actual. Los datos personales se alojan fuera del Perú (VPS, Firebase y Vercel), lo que el SGSI trata como transferencia internacional según la Ley N.° 29733 (riesgo R-24).

7.2 Equivalencias de la arquitectura AWS

Elemento AWS (guía)	Implementación equivalente	Valor	Estado
VPC y CIDR	Espacio de nube 10.20.0.0/16	10.20.0.0/16	Diseñado
Subred pública	Interfaz `eth0` del VPS con IP pública	IP pública del VPS	Implementado (provisto)
Subred privada	Interfaz `dum0` alcanzable solo por el túnel	10.20.0.0/24 (10.20.0.1)	Diseñado
Route tables	Tabla `main` (salida por el gateway del proveedor) y tabla 220 (rutas IPsec)	—	Diseñado
Internet Gateway	Enrutamiento público del proveedor	—	Implementado (provisto)
NAT Gateway	No requerido: el VPS tiene IP pública; la sede usa NAT de OPNsense	—	No aplica
VPN Gateway	strongSwan IKEv2	UDP 500/4500	Diseñado
Instancia EC2	VPS KVM	2 vCPU, 2 GB, 35 GB SSD, Ubuntu 24.04	Implementado
Security Group	UFW con estado	Entrada denegada; 22, 80 y 443/tcp	Implementado
NACL	Reglas nftables sin estado o filtro del proveedor	Ver sección 7.4	Pendiente

7.3 Instancia

El VPS aloja el sistema del colegio: Nginx sirve Angular y hace de proxy hacia PHP 8.4-FPM (Laravel), y PostgreSQL 16 escucha solo en loopback con un usuario de aplicación sin superusuario. La administración se hace con un usuario Linux no-root con sudo. El diseño le agrega la interfaz `dum0`, strongSwan, el proxy hacia la API de la academia, el agente Wazuh y un Netdata hijo.

7.4 Security Group y NACL

- **Security Group (UFW, con estado):** reglas UFW-01 a UFW-10 de S1-E1 §13.6. Se mantienen 80 y 443; se agregan UDP 500 y 4500 para la VPN; SSH pasa a permitirse solo desde el bastión por el túnel.

- **NACL (sin estado):** reglas nftables previas al filtrado con estado que descartan orígenes falsificados (redes de documentación y reservadas) y paquetes TCP con banderas inválidas. Si el panel de RackNerd ofrece un filtro de red, se usa como capa adicional (dato por confirmar). Antes de activarlas se valida que no afecten al tráfico IPsec desencapsulado.

7.5 Servicios PaaS

Servicio	Uso	Controles	Por confirmar
Vercel	SPA de la academia	HTTPS con HSTS (verificado), reversión de despliegues, variables de entorno fuera del repositorio	Plan contratado (SUP-13)
Firebase Authentication	Identidad y claims de rol	Invitaciones de un solo uso; MFA para administradores (recomendado)	—
Cloud Firestore	22 colecciones con reglas por rol	Reglas probadas con 19 casos; publicación por CI	Ubicación de la base y plan (SUP-11, SUP-12)
Firebase Storage	Imágenes y archivos	Reglas de acceso	—

7.6 Alternativa en AWS Academy (no usada)

Elemento	Configuración equivalente
VPC	10.20.0.0/16
Subred pública	10.20.1.0/24 con Internet Gateway, instancia EC2 t3.small para Nginx y proxy
Subred privada	10.20.0.0/24 para servicios internos
Site-to-Site VPN	Virtual Private Gateway ↔ OPNsense con los parámetros de S1-E1 §10
Security Groups y NACL	Las reglas UFW y nftables de la sección 7.4

Su uso depende de los servicios habilitados en la cuenta educativa. No se ejecutó.

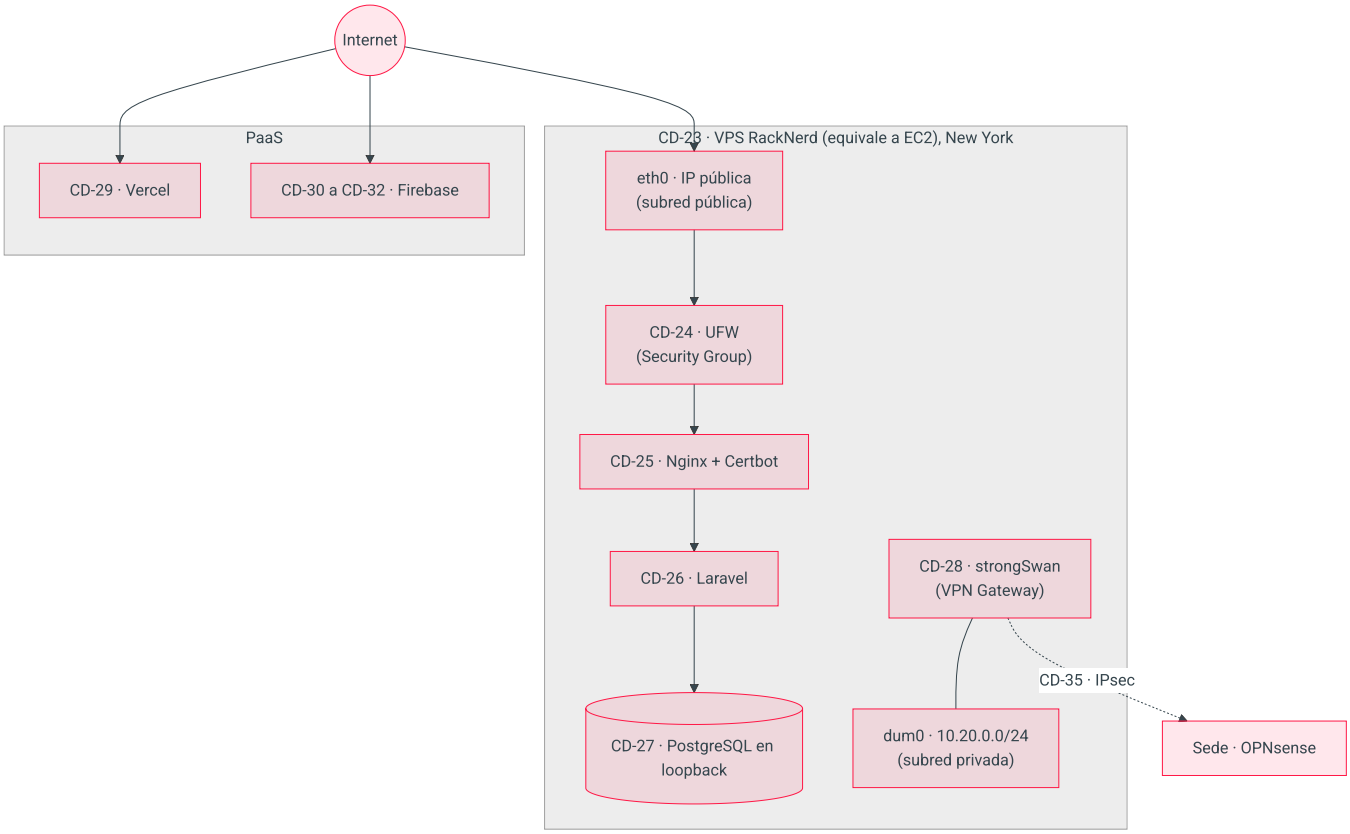
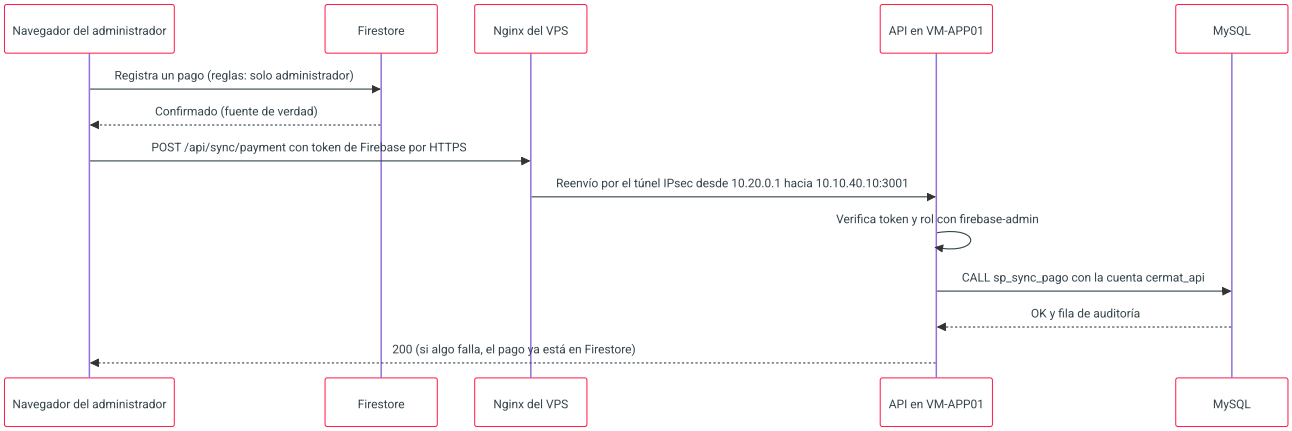


Diagrama editable: página "Nube IaaS y PaaS" de arquitectura-centro-datos-hibrido.drawio.

8. Mecanismo de integración híbrida

Integración	Mecanismo	Seguridad	Coherencia con S1-E1
Red sede ↔ nube	Túnel IPsec IKEv2 OPNsense ↔ strongSwan	AES-256-GCM, PFS y certificados	§10, NET-27
Publicación de la API de la academia	Nginx del VPS como proxy inverso hacia VM-APP01 por el túnel	TLS público, límite de peticiones, solo `/health` y `/api/`	Flujos F-03 y F-04, regla FW-70
Identidad común	La API verifica los tokens de Firebase con `firebase-admin`	Sin segundo sistema de usuarios	Flujo F-05
Réplica relacional	Sincronización no bloqueante desde el navegador; Firestore sigue siendo la fuente de verdad	Autorización por rol y titularidad en la API	Flujos F-02 y F-03
Respaldos cruzados	La sede extrae los respaldos del VPS; el VPS guarda la copia cifrada de la sede	Modelo pull y cifrado con restic	Flujos F-10 y F-11
Telemetría	Agente Wazuh y Netdata del VPS hacia la sede	Por el túnel, sin puertos públicos	Flujos F-15 y F-16



La aplicación ya permite cambiar la URL de la API y de la analítica desde el panel de administración (`config/services`); al implementar el proxy se apunta a los subdominios propuestos en lugar de `localhost`.

---

9. Matriz de componentes del centro de datos

ID	Componente	Entorno	Tipo	Función	Criticidad	Estado al 2026-10-24
CD-01	Rack de 12U con puerta y cerradura	On-premise	Físico	Alojar equipos de red y cómputo	Alta	Diseñado
CD-02	UPS de 1500 VA con interfaz de red o USB (NUT)	On-premise	Energía	Autonomía y apagado ordenado	Alta	Diseñado
CD-03	Regleta o PDU de rack	On-premise	Energía	Distribución eléctrica	Media	Diseñado
CD-04	Patch panel Cat 6 de 24 puertos y organizador	On-premise	Cableado	Terminación del cableado horizontal	Media	Diseñado
CD-05	Switch gestionable de 24 puertos PoE+ (NET-06)	On-premise	Red	VLAN 802.1Q, LACP y PoE para los AP	Crítica	Diseñado
CD-06	Servidor físico PVE01: 8 núcleos/16 hilos, 64 GB ECC, 2×1 TB SSD, 1×4 TB HDD, 4×1 GbE e IPMI	On-premise	Cómputo	Host de virtualización	Crítica	Diseñado
CD-07	Proxmox VE (equivalente a VMware ESXi)	On-premise	Hipervisor	Ejecutar y aislar las VM	Crítica	Diseñado

ID	Componente	Entorno	Tipo	Función	Criticidad	Estado al 2026-10-24
CD-08	bond0: LACP 802.3ad sobre NIC1 y NIC2 (equivale a NIC teaming)	On-premise	Red virtual	Agregación y redundancia de enlaces	Alta	Diseñado
CD-09	vmbr0: bridge VLAN-aware sobre bond0 con VLAN 10, 20, 30, 40, 50 y 99 (equivale a vSwitch con port groups)	On-premise	Red virtual	Conmutador virtual troncal	Crítica	Diseñado
CD-10	vmbr1 (NIC3, WAN1) y vmbr2 (NIC4, WAN2), sin IP del host	On-premise	Red virtual	Entregar los enlaces de Internet solo al firewall virtual	Alta	Diseñado
CD-11	VM-FW01: OPNsense con Suricata	On-premise	VM	Firewall perimetral virtual, IDS/IPS y VPN	Crítica	Diseñado
CD-12	VM-APP01: API Node.js, MySQL 8 y analítica FastAPI con PM2	On-premise	VM	Réplica relacional, reportes y analítica	Alta	Diseñado (hoy en la PC local)
CD-13	VM-SIEM01: Wazuh (indexador, servidor y panel)	On-premise	VM	SIEM	Alta	Diseñado
CD-14	VM-MON01: Uptime Kuma y Netdata (padre)	On-premise	VM	Disponibilidad y métricas	Media	Diseñado
CD-15	VM-BKP01: Proxmox Backup Server	On-premise	VM	Respaldos deduplicados y verificados	Alta	Diseñado
CD-16	VM-HPOT01: Cowrie	On-premise	VM	Honeypot en la DMZ	Media	Diseñado
CD-17	VM-BAS01: bastión SSH	On-premise	VM	Administración centralizada	Alta	Diseñado
CD-18	Almacenamiento local-zfs (espejo de 2×1 TB SSD)	On-premise	Almacenamiento	Discos de las VM; tolera la falla de un disco	Crítica	Diseñado

ID	Componente	Entorno	Tipo	Función	Criticidad	Estado al 2026-10-24
CD-19	Datastore de respaldos (HDD de 4 TB)	On-premise	Almacenamiento	Segunda copia en un medio distinto	Alta	Diseñado
CD-20	Disco externo USB cifrado (rotación mensual)	On-premise / fuera de la sede	Almacenamiento	Copia fuera de línea (regla 3-2-1)	Media	Diseñado
CD-21	Enlace de fibra (NET-01)	On-premise	Conectividad	Salida principal	Alta	Existente (por confirmar)
CD-22	Enlace 4G/LTE (NET-03)	On-premise	Conectividad	Salida alterna	Media	Diseñado
CD-23	VPS RackNerd KVM: 2 vCPU, 2 GB RAM, 35 GB SSD, New York (equivale a EC2)	Nube IaaS	Cómputo	Servidor del colegio y extremo VPN	Crítica	Implementado
CD-24	Ubuntu 24.04 LTS con UFW (equivale a Security Group)	Nube IaaS	SO y seguridad	Base con firewall de host	Crítica	Implementado
CD-25	Nginx con Certbot (Let's Encrypt)	Nube IaaS	Servicio web	HTTPS, redirección y proxy inverso	Crítica	Implementado
CD-26	Sistema del colegio: Angular y Laravel (PHP 8.4-FPM)	Nube IaaS	Aplicación	Gestión escolar	Alta	Implementado
CD-27	PostgreSQL 16 solo en loopback, usuario de aplicación sin superusuario	Nube IaaS	Base de datos	Datos del colegio	Crítica	Implementado
CD-28	strongSwan e interfaz dum0 10.20.0.1 (equivale a VPN Gateway y subred privada)	Nube IaaS	Red	Extremo del túnel IPsec	Alta	Diseñado
CD-29	Vercel: SPA de la academia	Nube PaaS	Hosting	Entrega web con HTTPS y reversión de despliegues	Crítica	Implementado

ID	Componente	Entorno	Tipo	Función	Criticidad	Estado al 2026-10-24
CD-30	Firebase Authentication con claims por rol	Nube PaaS	Identidad	Autenticación y roles	Crítica	Implementado
CD-31	Cloud Firestore (22 colecciones con reglas por rol)	Nube PaaS	Base de datos	Fuente de verdad operativa	Crítica	Implementado (reglas corregidas publicadas el 2026-10-24)
CD-32	Firebase Storage	Nube PaaS	Archivos	Imágenes y archivos	Media	Implementado
CD-33	GitHub: repositorios y Actions (CI de 6 trabajos)	Nube SaaS	Código y CI	Control de versiones y verificación	Media	Implementado (primera ejecución en GitHub pendiente)
CD-34	DNS autoritativo Punto.pe/RCP (equivale a Route 53)	Proveedor	DNS	Resolución del dominio	Alta	Implementado
CD-35	Túnel IPsec sede ↔ VPS (NET-27)	Híbrido	Integración	Respaldo, administración, monitoreo y proxy	Alta	Diseñado
CD-36	PC local actual con PM2 (API, MySQL y analítica)	On-premise (actual)	Cómputo	Servicio transitorio hasta VM-APP01	Media	Implementado (transitorio)

10. Dimensionamiento y capacidad

10.1 Carga esperada

La carga actual es baja: 8 matrículas, 2 pagos y 7 registros de asistencia en Firestore, y un respaldo de MySQL de 47 KB con datos de prueba. La capacidad la definen los servicios de seguridad, no la aplicación: Wazuh es la VM más exigente según los requisitos publicados por su fabricante.

10.2 Dimensionamiento de las VM

VM	Rol	Sistema	vCPU	RAM (GB)	Disco (GB)	Red	Justificación
VM-FW01	Firewall, IDS/IPS y VPN	OPNsense (serie estable vigente)	2	4	40	vmbr1, vmbr2 y vmbr0 (troncal)	Suricata en modo IPS sobre dos WAN y tabla de estados; holgura para las reglas ET Open
VM-APP01	API, MySQL y analítica	Ubuntu Server 24.04 LTS	2	4	60	VLAN 40	Carga actual baja (8 matrículas y 7 registros de asistencia); buffer pool de MySQL de 1 GB; Node y Python
VM-SIEM01	SIEM	Wazuh 4.x todo en uno sobre Ubuntu 24.04	4	8	150	VLAN 40	Requisito publicado por Wazuh para 1–25 agentes (4 vCPU, 8 GB, 50 GB por 90 días) más margen de retención
VM-MON01	Monitoreo	Ubuntu 24.04 con Docker	2	2	30	VLAN 40	Uptime Kuma y Netdata padre con retención corta
VM-BKP01	Respaldo	Proxmox Backup Server	2	4	32	VLAN 40 (+ HDD de 4 TB)	Deduplicación, verificación y restauración de VM
VM-HPOT01	Honeypot	Debian 12 mínimo con Cowrie	1	1	16	VLAN 50	Interacción media, sin servicios reales
VM-BAS01	Bastión	Debian 12 mínimo	1	1	16	VLAN 99	Solo SSH con llaves y registro de sesiones
Total VM			14	24	344 (+ 4 TB de respaldo)		

10.3 Capacidad del host y margen

Recurso	Capacidad del host	Comprometido (año 1)	Utilización	Margen	Criterio de diseño
CPU	16 hilos (8 núcleos)	14 vCPU	0,88 vCPU por hilo	Admite sobresuscripción hasta 2:1 en cargas ligeras	≤ 2 vCPU por hilo
RAM	64 GB ECC	30 GB (24 de VM + 6 de sistema y ARC de ZFS)	47 %	53 %	≤ 70 % comprometido; sin sobresuscripción de RAM
Disco de VM	~900 GB útiles (espejo 2×1 TB)	344 GB (aprovisionamiento delgado)	38 %	62 %	≤ 70 % (ZFS pierde rendimiento sobre el 80 %)
Respaldo	4 TB (HDD dedicado)	~0,5 TB (supuesto: 7 diarios, 4 semanales y 6 mensuales deduplicados)	~13 % (supuesto)	~87 %	Verificar con el informe de deduplicación de PBS
Red	2 Gb/s (bond LACP) + 2 WAN	< 100 Mb/s (supuesto)	< 5 %	> 95 %	Medir con Netdata en S2

10.4 Margen de crecimiento

Escenario	Recursos adicionales	RAM comprometida resultante	¿Cabe en el host?
VM de pruebas (staging) de la plataforma	2 vCPU, 4 GB, 60 GB	34 GB (53 %)	Sí
Migrar el sistema del colegio desde el VPS si 2 GB no alcanzan	2 vCPU, 4 GB, 60 GB	38 GB (59 %), sumado al anterior	Sí
Wazuh con 26–50 agentes (otras sedes)	+4 vCPU, +100 GB de disco	Sin cambio de RAM	Sí (CPU sobresuscrita 1,5:1)
Segunda sede conectada por VPN al VPS	Sin VM nuevas (bloque 10.11.0.0/16)	Sin cambio	Sí

Con todos los escenarios, el host llega al 59 % de RAM comprometida, por debajo del límite de diseño del 70 %. Comprar 32 GB dejaría el año 1 en 94 % sin margen; por eso se eligen 64 GB.

10.5 Límite real del VPS

Componente	RAM estimada (MB)	Estado	Fuente o forma de validar
Ubuntu 24.04 base (systemd, sshd, journald, cron)	250	Supuesto a validar	Estimación del equipo; medir con free -m y ps -eo rss,comm --sort=-rss

Componente	RAM estimada (MB)	Estado	Fuente o forma de validar
Nginx (maestro y 2 workers)	20	Supuesto a validar	ps -C nginx -o rss=
PHP 8.4-FPM (pm dinámico, ~5 procesos)	200	Supuesto a validar	ps -C php-fpm8.4 -o rss=
PostgreSQL 16 (shared_buffers de 128 MB por defecto y conexiones)	250	Supuesto a validar	ps -u postgres -o rss=; SHOW shared_buffers;
Subtotal actual estimado	720	Supuesto a validar	Línea base que se mide antes de agregar componentes
strongSwan (charon)	15	Supuesto a validar	Medir tras instalar
Agente Wazuh	50	Supuesto a validar	Medir tras instalar
Netdata hijo sin base local (streaming)	60	Supuesto a validar	Alternativa más ligera: node_exporter (~15 MB)
Total proyectado	845 de 2048 (≈ 41 %)	Supuesto a validar	Aceptación: MemAvailable ≥ 25 % en hora pico
Capa de la academia (API Node, MySQL 8 y FastAPI)	≈ 600 (supuesto)	Excluida del VPS	Se aloja on-premise en VM-APP01 (riesgo R-08)

Decisión: el VPS solo recibe componentes ligeros (strongSwan, agente Wazuh y Netdata en modo streaming). La capa de la academia, que con MySQL 8, Node y FastAPI necesitaría unos 600 MB adicionales (supuesto), va a VM-APP01. Si la línea base medida deja menos del 25 % de memoria disponible en hora pico, se retira Netdata del VPS y se evalúa ampliar el plan o mover el sistema del colegio al host (escenario de crecimiento).

10.6 Supuestos

ID	Supuesto	Valor	Estado	Fuente
SUP-01	Equipos simultáneos en la sede principal	12–18	Supuesto a validar	Levantamiento preliminar del equipo (jun-2026), sin medición
SUP-02	Ancho de banda del enlace principal	≥ 50 Mb/s	Supuesto a validar	Diseño de junio; confirmar con el contrato del ISP y una prueba de velocidad
SUP-03	Tipo de IP pública de la sede	Desconocido (fija, dinámica o CGNAT)	Dato a confirmar	Consultar al ISP; condiciona la exposición del honeypot. El túnel siempre lo inicia la sede
SUP-04	Latencia sede ↔ VPS (New York)	90–150 ms	Supuesto a validar	Estimación; medir con mtr desde la sede

ID	Supuesto	Valor	Estado	Fuente
SUP-05	Autonomía del UPS con la carga del rack (~200 W)	20–30 min	Supuesto a validar	Hoja de datos del modelo elegido
SUP-06	Consumo eléctrico del rack	150–250 W	Supuesto a validar	Suma de consumos típicos de host, switch PoE, ONT y router LTE
SUP-07	Volumen de datos de MySQL	< 100 MB en 3 años	Supuesto a validar	Respaldo actual de 47 KB con datos de prueba; 8 matrículas reales
SUP-08	Crecimiento de usuarios	Piloto con 8 perfiles; cada VLAN /24 admite hasta 253 equipos	Supuesto a validar	Conteos agregados de Firestore al 2026-10-24
SUP-09	Retención de eventos en Wazuh	90 días	Supuesto a validar	Requisito de Wazuh (50 GB por 90 días para 1–25 agentes)
SUP-10	Frecuencia de cortes eléctricos en la sede	Frecuentes (no medido)	Supuesto a validar	Percepción del personal; registrar los eventos del UPS durante 3 meses
SUP-11	Ubicación de los datos de Firestore	Desconocida	Dato a confirmar	Consola de Firebase (ubicación de la base)
SUP-12	Plan de facturación de Firebase	Desconocido (Spark o Blaze)	Dato a confirmar	Condiciona la exportación programada gestionada
SUP-13	Plan de Vercel	Desconocido	Dato a confirmar	El plan Hobby está limitado a uso personal no comercial según los términos del proveedor
SUP-14	Uso real de RAM y disco del VPS	Ver presupuesto de RAM	Supuesto a validar	free -m y df -h en el VPS

11. Disponibilidad y continuidad

11.1 Redundancia

Componente	Redundancia	Falla tolerada
Discos de las VM	Espejo ZFS	Un disco
Enlace host ↔ switch	bond LACP	Un cable o un puerto
Internet de la sede	WAN1 y WAN2 con conmutación	Caída de un proveedor
Energía	UPS con NUT	Cortes de hasta 20–30 min (supuesto) con apagado ordenado

Componente	Redundancia	Falla tolerada
Host	Sin redundancia (aceptado, R-18)	Los servicios críticos siguen en la nube; se restaura desde PBS en hardware de reemplazo
VPS	Sin redundancia; respaldo diario en la sede	Reconstrucción en ≤ 8 h
PaaS	Redundancia del proveedor	Según el SLA del plan contratado

11.2 Respaldo previsto (regla 3-2-1)

Datos	Copia 1	Copia 2 (otro medio)	Copia 3 (fuera del sitio)	Frecuencia	Retención
MySQL (VM-APP01)	`backup.js` en la VM (7 copias con SHA-256)	PBS en el HDD de 4 TB	VPS por el túnel, cifrada con restic	Diaria, 02:00	7 diarias, 4 semanales y 6 mensuales
PostgreSQL del colegio	`pg_dump -Fc` en el VPS (7 copias)	VM-BKP01 en la sede (extracción por el túnel)	Disco externo cifrado, rotación mensual	Diaria, 01:30	7 diarias, 4 semanales y 6 mensuales
Firestore y usuarios de Auth	Exportación diaria	VM-BKP01	Disco externo cifrado	Diaria	30 días
VM completas	vzdump hacia PBS	Datastore en el HDD dedicado	Disco externo cifrado (semanal)	Diaria	7 diarias, 4 semanales y 3 mensuales
Configuraciones (OPNsense, swanctl, Nginx, Proxmox)	Repositorio Git sanitizado	PBS	Disco externo	En cada cambio	Historial completo

11.3 RTO y RPO objetivo por servicio

Servicio	Ubicación	Criticidad	RTO objetivo	RPO objetivo	Mecanismo de recuperación	Validación (S2)
Plataforma web (SPA)	Vercel	Crítica	15 min	0 (código en Git)	Promover el despliegue anterior en Vercel o revertir el commit	REC-10
Identidad (Firebase Auth)	Firebase	Crítica	Según el proveedor	Según el proveedor	Exportación semanal de usuarios (firebase auth:export), cifrada	REC-11

Servicio	Ubicación	Criticidad	RTO objetivo	RPO objetivo	Mecanismo de recuperación	Validación (S2)
Datos operativos (Firestore)	Firebase	Crítica	4 h	24 h	Exportación diaria programada y restauración en un proyecto de prueba	REC-11
API de sincronización y MySQL	VM-APP01 (hoy PC local)	Alta	1 h	24 h	backup.js diario y restore.js; resincronización desde Firestore	REC-01 a REC-05
Analítica	VM-APP01	Baja	24 h	24 h	Redespliegue desde Git	REC-07
Sistema del colegio (web, API y PostgreSQL)	VPS	Alta	8 h (reconstrucción completa); 2 h (solo base)	24 h	pg_dump -Fc diario con SHA256SUMS y copia en la sede	REC-06, REC-08
VPN sitio a sitio	OPNsense ↔ VPS	Media	1 h (reconexión automática ≤ 2 min)	No aplica	DPD y reintento; configuración versionada	REC-09
Firewall perimetral	VM-FW01	Crítica para la sede	2 h	Último config.xml	Restaurar config.xml en una VM nueva; contingencia con el router del ISP	REC-12
SIEM (Wazuh)	VM-SIEM01	Media	24 h	24 h	Restaurar la VM desde PBS	REC-07
Monitoreo (Uptime Kuma y Netdata)	VM-MON01	Media	8 h	24 h	Restaurar la VM desde PBS	REC-07

El RTO de 1 h de la base relacional coincide con el objetivo del Project Charter del E4 de Ingeniería de Software.

11.4 Validación esperada en el Semestre 2

Prueba	Qué demuestra	Criterio de aceptación
REC-01 a REC-05	Restauración de MySQL con verificación de integridad	RTO < 1 h; filas, rutinas, triggers y vistas completos
REC-06	Restauración de PostgreSQL del colegio	Base de verificación con las 116 migraciones registradas
REC-07	Recuperación de una VM desde PBS	VM-APP01 responde `/health` en ≤ 2 h

Prueba	Qué demuestra	Criterio de aceptación
REC-08	Reconstrucción del VPS	Web y API del colegio en ≤ 8 h en un entorno de prueba
REC-09	Recuperación del túnel	Reconexión automática en ≤ 2 min
REC-10 a REC-12	Reversión del frontend, Firestore y firewall	Dentro de los RTO de la tabla 11.3

11.5 Contingencia de la sede

Si el host PVE01 falla:

1. El personal sigue operando matrícula, pagos y asistencia desde la nube con cualquier conexión; puede usar el router 4G/LTE como punto de acceso.
2. El encargado de TI pasa el router del ISP a modo router para dar Internet a las estaciones administrativas, sin acceso a servidores.
3. Las VM se restauran desde PBS o desde el disco externo en hardware de reemplazo, en este orden: VM-FW01, VM-APP01 y las demás.
4. La réplica MySQL se reconcilia con Firestore usando `v_conciliacion_pagos` y una resincronización.

---

12. Conclusiones, hoja de ruta y referencias

12.1 Conclusiones

1. El reparto on-premise/nube sigue un criterio explícito: lo que debe estar siempre disponible para usuarios externos queda en la nube; lo que maneja copias completas de datos personales o necesita ver la red de la sede queda on-premise.
2. Un solo host de 64 GB aloja las 7 VM con 47 % de RAM comprometida y deja margen para pruebas, más agentes y la eventual migración del sistema del colegio.
3. La nube reutiliza un VPS existente con equivalencia directa a EC2, Security Group y VPN Gateway, y mantiene el costo de licencias on-premise en cero.
4. Cada servicio tiene RTO y RPO con un mecanismo y una prueba de validación asignados para el Semestre 2.

12.2 Hoja de ruta

Fase	Plazo	Actividades
Continuidad inmediata	Hasta 2026-11-21	Respaldos del VPS y de Firestore, línea base de RAM del VPS, monitoreo transitorio
Laboratorio (opcional)	Hasta 2026-11-21	Proxmox de laboratorio con las 7 VM para ensayar el despliegue y las pruebas REC

Fase	Plazo	Actividades
Adquisición	2027-I	Cotizar y comprar host, switch, AP, UPS y discos
Despliegue	Tras la adquisición	Instalar Proxmox, crear las VM, migrar la API a VM-APP01 y activar el túnel
Operación	Continuo	Restauraciones de prueba mensuales y revisión de capacidad trimestral

12.3 Referencias

[1] Uptime Institute, "Tier Standard: Topology," Uptime Institute, 2018.

[2] *Telecommunications Infrastructure Standard for Data Centers*, ANSI/TIA-942-B, 2017.

[3] ASHRAE TC 9.9, *Thermal Guidelines for Data Processing Environments*, 5.ª ed. Atlanta, GA, EE. UU.: ASHRAE, 2021.

[4] Proxmox Server Solutions GmbH, "Proxmox VE Administration Guide." [En línea]. Disponible en: https://pve.proxmox.com/pve-docs/

[5] Proxmox Server Solutions GmbH, "Proxmox Backup Server Documentation." [En línea]. Disponible en: https://pbs.proxmox.com/docs/

[6] VMware by Broadcom, "vSphere Networking." [En línea]. Disponible en: https://techdocs.broadcom.com/

[7] Amazon Web Services, "Amazon VPC User Guide." [En línea]. Disponible en: https://docs.aws.amazon.com/vpc/

[8] Wazuh Inc., "Wazuh Quickstart: requirements." [En línea]. Disponible en: https://documentation.wazuh.com/

[9] M. Swanson, P. Bowen, A. W. Phillips, D. Gallup y D. Lynes, "Contingency Planning Guide for Federal Information Systems," NIST SP 800-34 Rev. 1, may. 2010.

[10] E. Barker, Q. Dang, S. Frankel, K. Scarfone y P. Wouters, "Guide to IPsec VPNs," NIST SP 800-77 Rev. 1, jun. 2020.

[11] restic authors, "restic Documentation." [En línea]. Disponible en: https://restic.readthedocs.io/

[12] Google, "Export and import data — Cloud Firestore." [En línea]. Disponible en: https://firebase.google.com/docs/firestore/manage-data/export-import

Anexos

Anexo	Contenido	Ubicación
A	Diagrama editable de 3 páginas: rack y topología física, hipervisor y nube	arquitectura-centro-datos-hibrido.drawio
B	Matriz de componentes, dimensionamiento, capacidad, crecimiento, RAM del VPS, supuestos y RTO/RPO	s1-e2-matriz-componentes-dimensionamiento.xlsx
C	Equivalencias tecnológicas de la línea	Resumen del área
D	Costos: el único costo real conocido es el VPS (US$ 35,99 al año); las licencias de software on-premise cuestan US$ 0; el hardware está por cotizar y no hay presupuesto aprobado	—

Rúbrica de evaluación

N°	Criterio de evaluación	Peso
1	Contexto y alcance del diseño de infraestructura	8%
2	Diseño de arquitectura on-premise (VMware ESXi)	22%
3	Diseño de arquitectura AWS	22%
4	Mecanismo de integración híbrida	10%
5	Dimensionamiento, capacidad y justificación técnica	12%
6	Matriz de componentes y trazabilidad	10%
7	Disponibilidad y continuidad en el diseño	8%
8	Calidad documental y sustentación	8%
	Total	**100%**

Escala: Excelente 4, Logrado 3, En proceso 2, Insuficiente 1 y No evidenciado 0. Puntaje = peso × (nivel / 4).

Dónde se evidencia cada criterio

Criterio	Secciones
1	2 a 4
2	5 y 6 (Proxmox VE como equivalente de ESXi)
3	7 (VPS y PaaS como equivalentes de AWS)
4	8

Criterio	Secciones
5	10
6	9 y matriz XLSX
7	11
8	Portada, anexos y exposición ante el jurado (pendiente)

Producto Final S1 · Diseño Técnico Consolidado de Infraestructura Híbrida

Expediente único del Semestre 1

Integra los dos entregables del semestre: el diseño de red (S1-E1, CE0311) y el diseño del centro de datos híbrido (S1-E2, CE0331). Reúne diagramas, matrices, trazabilidad de requerimientos, conclusiones, referencias IEEE, anexos cruzados y la declaración de responsabilidad ética.

Portada

Campo	Detalle
Título	Diseño técnico consolidado de la infraestructura híbrida de CERMAT
Entregable	Producto final del Semestre 1 (CE0311 + CE0331)
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo), UPeU campus Juliaca, sección g1
Fecha	2026-10-24
Versión	2.0

Productos

Producto	Formato sugerido por la guía	Entregado	Estado
Expediente consolidado	PDF consolidado	Este documento y los dos entregables enlazados; el PDF se genera desde la vista de impresión del sitio (*Documentación completa*)	Contenido entregado; exportación a PDF a cargo del equipo
Diagramas	Draw.io y PDF/PNG	4 archivos draw.io (6 páginas) y diagramas Mermaid	Entregado
Matrices	XLSX	3 libros con 31 componentes de red, 36 del centro de datos y 22 pruebas planeadas	Entregado

Resumen ejecutivo

CERMAT tiene sus servicios críticos en la nube (la plataforma de la academia en Vercel y Firebase, y el sistema del colegio en un VPS), pero la capa local de la academia corre en una PC sin perímetro ni segmentación, y el VPS no tiene un canal privado con la sede. El diseño consolidado propone:

1. **Una sede segmentada y virtualizada.** Seis VLAN con política por defecto de denegar, OPNsense con Suricata como perímetro, honeypot en la DMZ y un host Proxmox VE (equivalente a ESXi) con 7 VM: 14 vCPU, 24 GB de RAM y 47 % de la memoria del host comprometida.
2. **Una nube equivalente a AWS sin costo adicional.** El VPS existente cumple el papel de EC2, UFW el de Security Group, una red interna 10.20.0.0/24 el de subred privada y strongSwan el de VPN Gateway.
3. **Una integración híbrida cifrada.** Un túnel IPsec IKEv2 con AES-256-GCM y PFS da respaldo cruzado 3-2-1, administración sin exponer SSH, telemetría hacia Wazuh y publicación de la API de la academia.
4. **Continuidad definida.** Cada servicio tiene RTO/RPO, mecanismo de recuperación y prueba asignada para el Semestre 2.

El diseño es **verificable**: cada componente tiene un ID (NET-xx, CD-xx) que aparece en las matrices y en los diagramas, y cada requisito se traza a un elemento de diseño y a una prueba (sección 6).

1. Índice del expediente

Parte	Documento	Secciones principales
Diseño de red	S1-E1 · CE0311	Organización y requisitos (2 a 6), topología general y lógica (7 y 8), zonas y perímetro (9 y 13), VPN (10), flujos (11), componentes (12), detección (14)
Diseño del centro de datos híbrido	S1-E2 · CE0331	On-premise (5), hipervisor (6), nube y equivalencias AWS (7), integración (8), componentes (9), dimensionamiento (10), continuidad (11)
Equivalencias y reglas comunes	Resumen del área	Codificación, reglas comunes y tabla de equivalencias
Este expediente	Producto final S1	Trazabilidad, coherencia, referencias, anexos cruzados y declaración ética

2. Síntesis del diseño de red

Aspecto	Decisión	Detalle
Segmentación	6 VLAN y una red de nube	ADMIN 10, ACAD 20, GUEST 30, SRV 40, DMZ 50, MGMT 99 y NUBE 10.20.0.0/24
Direccionamiento	Jerárquico por sede (RFC 1918)	10.10.0.0/16 para la sede principal; 10.11 y 10.12 reservadas; 10.20.0.0/16 para la nube

Aspecto	Decisión	Detalle
Ruteo	Router-on-a-stick en OPNsense	Grupo de gateways WAN1 → WAN2; rutas IPsec por política
Perímetro	OPNsense con política por defecto de denegar	35 reglas con ID; NAT solo hacia el honeypot
VPN	IPsec IKEv2 sitio a sitio	AES-256-GCM, PRF SHA-256, DH 20/19, PFS, certificados y NAT-T
Detección	Suricata, Cowrie y Wazuh	IPS en las WAN, IDS interno, señuelo en la DMZ y correlación central
Flujos	22 flujos documentados	Origen, destino, protocolo, puerto, ruta y estado

3. Síntesis del diseño del centro de datos híbrido

Aspecto	Decisión	Detalle
Sitio on-premise	Rack de 12U, Tier I con elementos de Tier II	UPS con NUT, doble WAN y espejo de discos
Hipervisor	Proxmox VE (equivalente a ESXi)	`vmbr0` VLAN-aware sobre `bond0` LACP; `vmbr1` y `vmbr2` para las WAN
VM	7 VM	Firewall, aplicaciones, SIEM, monitoreo, respaldo, honeypot y bastión
Capacidad	64 GB ECC, 2×1 TB SSD en espejo y 4 TB HDD	47 % de RAM y 38 % de disco comprometidos
Nube IaaS	VPS de RackNerd (equivalente a EC2)	UFW como Security Group; NACL con nftables; `dum0` como subred privada
Nube PaaS	Vercel y Firebase	Vía crítica de la operación académica
Continuidad	Regla 3-2-1 con copias cruzadas sede ↔ nube	RTO/RPO por servicio; 12 pruebas de recuperación previstas

4. Diagramas

Diagrama	Archivo editable	Páginas	Secciones donde se explica
Topología general híbrida	topologia-general-hibrida.drawio	1	S1-E1 §7
Topología lógica (VLAN y subredes)	topologia-logica-vlan.drawio	1	S1-E1 §8
Zonas de seguridad y VPN	zonas-seguridad-vpn.drawio	1	S1-E1 §9 y §10

Diagrama	Archivo editable	Páginas	Secciones donde se explica
Arquitectura del centro de datos híbrido	arquitectura-centro-datos-hibrido.drawio	3 (rack y física, hipervisor, nube)	S1-E2 §5 a §7

5. Matrices

Matriz	Archivo	Hojas
Componentes de red	s1-e1-matriz-componentes-red.xlsx	Componentes, VLAN y subredes, matriz de zonas, reglas OPNsense, reglas UFW, flujos y requisitos
Pruebas de conectividad planeadas	s1-e1-matriz-pruebas-conectividad.xlsx	22 pruebas con resultado esperado y regla asociada
Componentes y dimensionamiento del CD	s1-e2-matriz-componentes-dimensionamiento.xlsx	Componentes, VM, capacidad, crecimiento, RAM del VPS, supuestos y RTO/RPO

Las tres se generan con `perfil-egreso/scripts/generar-matrices-infra.mjs`, que contiene los mismos datos que las tablas de los informes.

6. Trazabilidad de requerimientos

ID	Tipo	Requisito	Elemento de diseño	Sección	Verificación (S2)
RQ-01	Organizacional	Datos de alumnos y pagos accesibles solo por roles autorizados	Zonas SRV y MGMT aisladas; reglas por rol en la capa PaaS	S1-E1 §8, §9	PC-03, PC-04
RQ-02	Técnico	Separar el tráfico de invitados del administrativo y de los servidores	VLAN 30, FW-02 y aislamiento de clientes	S1-E1 §8	PC-06, PC-08
RQ-03	Técnico	Gestión de la infraestructura solo desde estaciones autorizadas	VLAN 99, alias ADMIN_TI y bastión	S1-E1 §8, §13	PC-04, PC-05
RQ-04	Técnico	Ningún servicio interno expuesto a Internet, salvo el señuelo	FW-61; NAT solo al honeypot; API publicada por el VPS	S1-E1 §9, §13	PC-02, PC-14
RQ-05	Organizacional	Matrícula y pagos continúan ante una falla de la sede	Servicios críticos en PaaS; enlace WAN2	S1-E2 §11	PC-16, REC-10

ID	Tipo	Requisito	Elemento de diseño	Sección	Verificación (S2)
RQ-06	Técnico	Canal cifrado sede ↔ nube para respaldos y administración	IPsec IKEv2, AES-256-GCM, PFS	S1-E1 §10	PC-11, PC-12, PC-13
RQ-07	Técnico	Respaldos 3-2-1 con restauración verificada	PBS, VPS y disco externo; restore.js	S1-E2 §11	REC-01 a REC-12
RQ-08	Técnico	Detección de ataques y trazabilidad de eventos	Suricata, Cowrie y Wazuh	S1-E1 §14	PC-17, PC-18, PC-19
RQ-09	Técnico	Alertas de disponibilidad de los servicios	Uptime Kuma con latido externo	S1-E2 §11	PC-20
RQ-10	Técnico	Capacidad con margen ≥ 30 % para crecimiento	Host de 64 GB (47 % comprometido); presupuesto de RAM del VPS	S1-E2 §10	Medición en S2-E3 §9
RQ-11	Organizacional	Cumplimiento de la Ley N.° 29733 (datos de menores)	Clasificación, cifrado en tránsito, mínimo privilegio	S2-E1	Auditoría interna
RQ-12	Técnico	Administración del VPS solo por canal cifrado y restringido	UFW-08, UFW-09 y bastión	S1-E1 §13	PC-15
RQ-13	Organizacional	Costo de licencias mínimo	Software libre: Proxmox VE, OPNsense, Wazuh, Suricata, Cowrie y strongSwan	S1-E2 §4, §7	Revisión de licencias
RQ-14	Técnico	Escalable a nuevas sedes	Bloque 10.x.0.0/16 por sede; el VPS como concentrador VPN	S1-E1 §15	—
RQ-15	Técnico	Réplica relacional disponible 24/7	VM-APP01 y proxy en el VPS	S1-E2 §8	PC-14, PC-20

Cada requisito (RQ-xx) se origina en las necesidades de la organización (S1-E1 §2), se resuelve en un elemento de diseño y se verifica con una prueba que se ejecuta en el Semestre 2 (S2-E2 y S2-E3).

7. Coherencia entre el diseño de red y el del centro de datos

Elemento de red (S1-E1)	Elemento del centro de datos (S1-E2)	Comprobación
NET-04 OPNsense	CD-11 VM-FW01 con `vmbr1`, `vmbr2` y troncal en `vmbr0`	Las interfaces de §13.2 coinciden con las redes virtuales de §6.2
VLAN 10, 20, 30, 40, 50 y 99	`bridge-vids` de `vmbr0` y etiquetas de las VM	Cada VM tiene la etiqueta de su zona
NET-13 a NET-17 y NET-12	CD-12 a CD-17	Mismas direcciones y roles
NET-27 túnel IPsec	CD-28 strongSwan + `dum0` y CD-35	Mismas redes anunciadas (10.10.40.0/24 y 10.10.99.0/27 ↔ 10.20.0.0/24)
Reglas UFW-01 a UFW-10	CD-24 UFW (Security Group)	El Security Group equivalente aplica las reglas del diseño de red
Flujos F-10 y F-11 (respaldo)	Regla 3-2-1 de S1-E2 §11.2	Copias cruzadas por el túnel
Flujos F-03 y F-04 (API)	Integración por proxy inverso (S1-E2 §8)	La API se publica por el VPS sin exponer la sede

8. Conclusiones

1. El diseño responde al problema real de CERMAT: servicios críticos en la nube sin perímetro en la sede y sin canal privado entre la sede y el VPS.
2. La equivalencia técnica con VMware ESXi y AWS se mantiene elemento por elemento, con costo de licencias cero y reutilizando el VPS existente.
3. La trazabilidad RQ → diseño → prueba permite que el jurado verifique en el Semestre 2 si cada decisión se cumplió.
4. Las limitaciones están declaradas: el hardware on-premise está por adquirir, el tipo de IP de la sede está por confirmar y las cifras de carga son supuestos a validar.

9. Referencias

[1] ISO/IEC 27001:2022, *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. Ginebra, Suiza: ISO, 2022.

[2] C. Kaufman, P. Hoffman, Y. Nir, P. Eronen y T. Kivinen, "Internet Key Exchange Protocol Version 2 (IKEv2)," RFC 7296, IETF, oct. 2014.

[3] J. Viega y D. McGrew, "The Use of Galois/Counter Mode (GCM) in IPsec Encapsulating Security Payload (ESP)," RFC 4106, IETF, jun. 2005.

[4] A. Huttunen, B. Swander, V. Volpe, L. DiBurro y M. Stenberg, "UDP Encapsulation of IPsec ESP Packets," RFC 3948, IETF, ene. 2005.

[5] Y. Rekhter, B. Moskowitz, D. Karrenberg, G. J. de Groot y E. Lear, "Address Allocation for Private Internets," RFC 1918, IETF, feb. 1996.

[6] E. Barker, Q. Dang, S. Frankel, K. Scarfone y P. Wouters, "Guide to IPsec VPNs," NIST SP 800-77 Rev. 1, jun. 2020.

[7] K. Scarfone y P. Hoffman, "Guidelines on Firewalls and Firewall Policy," NIST SP 800-41 Rev. 1, sep. 2009.

[8] K. Scarfone y P. Mell, "Guide to Intrusion Detection and Prevention Systems (IDPS)," NIST SP 800-94, feb. 2007.

[9] M. Swanson, P. Bowen, A. W. Phillips, D. Gallup y D. Lynes, "Contingency Planning Guide for Federal Information Systems," NIST SP 800-34 Rev. 1, may. 2010.

[10] *IEEE Standard for Local and Metropolitan Area Networks—Bridges and Bridged Networks*, IEEE Std 802.1Q-2022, 2022.

[11] *IEEE Standard for Local and Metropolitan Area Networks—Link Aggregation*, IEEE Std 802.1AX-2020, 2020.

[12] *Balanced Twisted-Pair Telecommunications Cabling and Components Standard*, ANSI/TIA-568.2-D, 2018.

[13] *Telecommunications Infrastructure Standard for Data Centers*, ANSI/TIA-942-B, 2017.

[14] Uptime Institute, "Tier Standard: Topology," Uptime Institute, 2018.

[15] ASHRAE TC 9.9, *Thermal Guidelines for Data Processing Environments*, 5.ª ed. Atlanta, GA, EE. UU.: ASHRAE, 2021.

[16] Proxmox Server Solutions GmbH, "Proxmox VE Administration Guide." [En línea]. Disponible en: https://pve.proxmox.com/pve-docs/

[17] Deciso B.V., "OPNsense Documentation." [En línea]. Disponible en: https://docs.opnsense.org/

[18] strongSwan Project, "swanctl.conf Reference." [En línea]. Disponible en: https://docs.strongswan.org/

[19] Wazuh Inc., "Wazuh Documentation." [En línea]. Disponible en: https://documentation.wazuh.com/

[20] Amazon Web Services, "Amazon VPC User Guide." [En línea]. Disponible en: https://docs.aws.amazon.com/vpc/

[21] Association for Computing Machinery, "ACM Code of Ethics and Professional Conduct," 2018. [En línea]. Disponible en: https://www.acm.org/code-of-ethics

10. Anexos cruzados

Anexo	Contenido	Ubicación
A	Matriz de pruebas de conectividad planeadas	S1-E1, Anexo A, y XLSX

Anexo	Contenido	Ubicación
B	Diagramas editables de red	S1-E1, Anexo B
C	Estándares aplicados a la red	S1-E1, Anexo C
D	Diagrama editable del centro de datos (3 páginas)	S1-E2, Anexo A
E	Matriz de componentes y dimensionamiento	S1-E2, Anexo B, y XLSX
F	Supuestos con estado y fuente	S1-E2 §10.6
G	Equivalencias tecnológicas	Resumen del área
H	Continuidad en la implementación	S2-E3

11. Declaración de responsabilidad ética

Los integrantes del equipo declaramos, conforme al Código de Ética y Conducta Profesional de la ACM:

1. **Veracidad (ACM 1.3).** Este diseño distingue lo existente de lo propuesto. Las cifras no medidas figuran como supuestos a validar, con su fuente, y no se presentan resultados que no se hayan obtenido.
2. **Evitar daño y proteger la privacidad (ACM 1.2 y 1.6).** El diseño prioriza la protección de los datos de menores y apoderados: segmentación, cifrado y mínimo privilegio.
3. **Confidencialidad (ACM 1.7).** La documentación no contiene contraseñas, llaves, tokens, IP públicas, correos ni datos personales; los indicadores de uso son conteos agregados.
4. **Acceso autorizado (ACM 2.8).** Las pruebas previstas se ejecutarán solo sobre infraestructura propia de CERMAT y con autorización escrita de la Dirección.
5. **Sistemas robustos y seguros (ACM 2.9).** Las decisiones de diseño se justificaron con estándares (ISO/IEC 27001, NIST, IEEE, TIA) y se declararon sus riesgos residuales.
6. **Autoría.** El contenido es trabajo del equipo; las fuentes externas se citan en formato IEEE.

Integrante	Firma	Fecha
David Robert Yucra Mamani	Pendiente de firma	—
Gladys Rosaura Yana Pari	Pendiente de firma	—
Denilson Leeke Mamani Flores	Pendiente de firma	—
Cárdenas Vilca Rennzo	Pendiente de firma	—

La declaración ampliada de ética de seguridad del Semestre 2 está en S2-E1 §12.

Rúbricas aplicables

La guía no define una rúbrica propia para el producto final del Semestre 1; se evalúa con las rúbricas de los entregables que integra.

S1-E1 · CE0311 — Análisis y Diseño de Red

N°	Criterio de evaluación	Peso
1	Contexto y alcance del diseño de red	10%
2	Arquitectura lógica de red: VLAN, subredes y direccionamiento	20%
3	Diseño de conectividad híbrida (VPN)	15%
4	Diseño de seguridad perimetral: firewall, DMZ y segmentación	20%
5	Diseño de detección: IDS/IPS y honeypot (planificación)	10%
6	Diagrama de flujo de información y matriz de componentes	10%
7	Calidad documental y trazabilidad del diseño	8%
8	Sustentación del diseño	7%
	Total	**100%**

S1-E2 · CE0331 — Análisis y Diseño de Centro de Datos Híbrido

N°	Criterio de evaluación	Peso
1	Contexto y alcance del diseño de infraestructura	8%
2	Diseño de arquitectura on-premise (VMware ESXi)	22%
3	Diseño de arquitectura AWS	22%
4	Mecanismo de integración híbrida	10%
5	Dimensionamiento, capacidad y justificación técnica	12%
6	Matriz de componentes y trazabilidad	10%
7	Disponibilidad y continuidad en el diseño	8%
8	Calidad documental y sustentación	8%
	Total	**100%**

Escala: Excelente 4, Logrado 3, En proceso 2, Insuficiente 1 y No evidenciado 0. Puntaje = peso × (nivel / 4).

Semestre 2

S2-E1 · Planificación e Implementación del SGSI (CE0321–CE0324)

CE032 — Gestión de la Seguridad de la Información

Sistema de Gestión de Seguridad de la Información (ISO/IEC 27001:2022) aplicado a la arquitectura híbrida diseñada en el Semestre 1: planificación (CE0321), implementación de controles (CE0322), monitoreo y mejora (CE0323) y ética ACM (CE0324). Se apoya en el diseño de red y en el diseño del centro de datos.

Portada

Campo	Detalle
Título	Sistema de Gestión de Seguridad de la Información de la infraestructura híbrida de CERMAT
Entregable	Semestre 2 · Entregable 1 · CE0321, CE0322, CE0323 y CE0324
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo), UPeU campus Juliaca, sección g1
Fecha	2026-10-24
Versión	2.0
Marco	ISO/IEC 27001:2022, ISO/IEC 27002:2022, ISO/IEC 27005:2022 y NIST CSF 2.0

Control de versiones

Versión	Fecha	Cambio
1.0	2026-07-06	Planificación de seguridad (activos, riesgos, políticas y roles) y entregable de controles, monitoreo y ética, según la estructura anterior de la guía
2.0	2026-10-24	SGSI integral según la guía vigente: alcance híbrido, inventario C-I-D, ISO/IEC 27005, SoA de 93 controles, 6 políticas, auditoría interna real y matriz maestra de trazabilidad

Productos obligatorios

Producto	Formato entregado	Ubicación	Criterio de aceptación (guía)	Estado
Informe del SGSI	Página versionada; PDF desde la vista de impresión	Este documento	Completo, versionado y trazable con los diseños del Semestre 1	Entregado
Inventario de activos	XLSX y sección 5	s2-e1-inventario-activos.xlsx	Cubre todo el alcance del SGSI	Entregado (33 activos)
Matriz de evaluación y tratamiento de riesgos	XLSX y secciones 6 y 7	s2-e1-matriz-riesgos.xlsx	Criterios definidos y resultados consistentes	Entregado (29 riesgos)
Declaración de Aplicabilidad (SoA)	XLSX y sección 8	s2-e1-declaracion-aplicabilidad.xlsx	Trazabilidad riesgo → control → evidencia	Entregado (93 controles)
Políticas y procedimientos del SGSI	Sección 9 (6 documentos)	Este documento	Adaptados al proyecto; no plantillas genéricas	Redactados; aprobación de la Dirección pendiente
Declaración de ética de seguridad	Sección 12.7	Este documento	Firmada por el equipo y coherente con el comportamiento observado	**Pendiente de firma**

1. Resumen ejecutivo del SGSI

Alcance. La seguridad de la información de los procesos de matrícula, pagos, asistencia, comunicación con padres y gestión escolar de CERMAT, soportados por la sede on-premise (diseñada), el VPS y los servicios PaaS en producción, la VPN entre ambos y los procesos de administración, respaldo, monitoreo e incidentes.

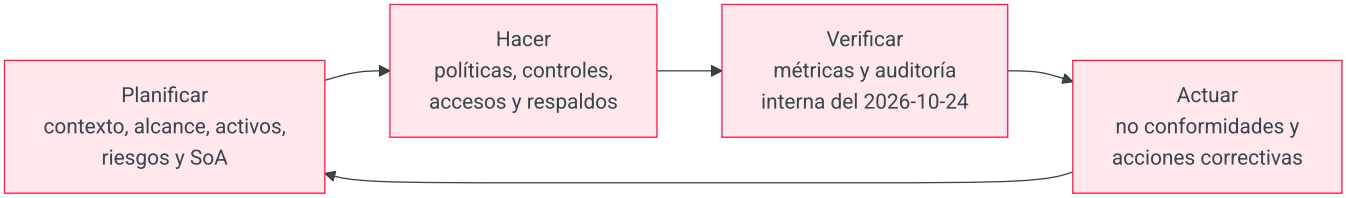
Riesgos principales. Se evaluaron 29 riesgos con ISO/IEC 27005: 7 críticos, 10 altos y 12 medios. **16 provienen de hallazgos reales**, no de supuestos:

- Reglas de Firestore publicadas que permiten listar matrículas pagadas sin sesión, auto-asignarse roles y que bloquean la matrícula pública (R-01 a R-03).
- Correcciones de seguridad que no llegan a producción porque el despliegue fallaba en silencio (R-04).
- Una clave de cuenta de servicio en copias ZIP versionadas: retiro iniciado, rotación pendiente (R-05).
- Respaldos del VPS sin implantar (R-07) y 2 GB de RAM compartidos en el VPS (R-08).
- Dominio sin SPF ni DMARC y MFA no verificado (R-11).
- Un falso positivo del antivirus que interrumpió pruebas (R-22).

Con el tratamiento, el riesgo residual queda en 18 bajos y 11 medios, que requieren aceptación de la Dirección.

Controles y SoA. De los 93 controles del Anexo A de ISO/IEC 27001:2022, 92 son aplicables y 1 se excluye (8.30, sin desarrollo externalizado). Hoy hay 9 implementados con evidencia, 46 parciales y 37 planificados.

Ciclo PHVA.



Etapa	Estado
Planificar	Completo (secciones 2 a 8)
Hacer	Parcial: controles en la nube y en la capa de datos; la sede está pendiente de hardware
Verificar	Auditoría interna real del 2026-10-24 con 11 hallazgos; 12 indicadores definidos
Actuar	8 no conformidades con acción correctiva, responsable y plazo (NC-01 a NC-03 cerradas el 2026-10-24); revisión por la dirección pendiente

Conclusión. El SGSI está establecido y opera parcialmente. El 2026-10-24 se cerraron dos acciones críticas: se publicaron las reglas corregidas, verificadas en producción, y se rotó la clave expuesta. Antes de la sustentación deben cerrarse las restantes: activar MFA e implantar los respaldos del VPS.

2. Contexto de la organización

2.1 Qué protege el SGSI

- Datos personales de alumnos (incluidos menores de edad) y apoderados.
- Registros de pagos y matrículas.
- Registros de asistencia y la consulta de los padres.
- Datos del sistema de gestión del colegio.
- La continuidad de la matrícula, los pagos y la asistencia.
- Credenciales, llaves y configuraciones de seguridad (reglas, firewall y VPN).

2.2 Cuestiones externas e internas

Tipo	Cuestión	Efecto en el SGSI
Externa	Ley N.° 29733 y su reglamento (D.S. N.° 016-2024-JUS)	Requisitos de tratamiento, seguridad, transferencia internacional y notificación de incidentes
Externa	Proveedores en el extranjero (Google, Vercel, RackNerd y GitHub)	Responsabilidad compartida; datos fuera del Perú
Externa	Amenazas comunes: phishing, fuerza bruta SSH, ransomware y escaneo automatizado	Controles de identidad, perímetro y respaldo

Tipo	Cuestión	Efecto en el SGSI
Externa	Conectividad y energía en Azángaro (supuestos a validar)	Doble enlace, UPS y servicios críticos en la nube
Interna	Equipo pequeño con conocimiento concentrado en una persona	Segregación limitada; necesidad de documentar y delegar
Interna	Presupuesto limitado	Software libre; hardware on-premise sujeto a adquisición
Interna	Operación piloto con volumen bajo	Riesgo real aunque el número de registros sea pequeño: son datos de menores
Interna	Secretos en el historial del repositorio	No conformidad abierta (NC-03)

2.3 Partes interesadas

Parte interesada	Necesidades y expectativas	Requisito que adopta el SGSI
Alumnos y apoderados	Confidencialidad de sus datos; consulta de asistencia disponible	Reglas por rol, cifrado en tránsito y aviso de privacidad
Dirección de la academia y del colegio	Continuidad, cumplimiento legal y costo controlado	RTO/RPO, SoA y uso de software libre
Personal administrativo, docentes y auxiliares	Acceso simple y seguro	Identidad única en Firebase y MFA para cuentas privilegiadas
Equipo técnico	Procedimientos claros	Políticas y procedimientos de la sección 9
Proveedores en la nube	Uso conforme a sus términos	Política de proveedores (POL-03)
ANPD	Cumplimiento de la Ley N.° 29733	Inscripción del banco de datos y notificación de incidentes
MINEDU y UGEL Azángaro	Custodia de registros académicos	Protección de los registros (control 5.33)
UPeU (jurado)	Evidencia verificable	Este SGSI con trazabilidad completa

3. Alcance del SGSI

Declaración. El SGSI comprende la seguridad de la información de los procesos de matrícula, pagos, asistencia, comunicación con padres y gestión escolar de CERMAT, soportados por los elementos de la tabla siguiente.

Elemento del alcance (guía)	En este proyecto	Estado al 2026-10-24
Infraestructura virtualizada (VMware ESXi)	Host Proxmox VE con 7 VM en la sede principal; PC local transitoria con PM2	Diseñado; la PC local está operativa
Recursos de nube (AWS)	VPS RackNerd (IaaS); Vercel y Firebase (PaaS); GitHub (SaaS)	Operativos

Elemento del alcance (guía)	En este proyecto	Estado al 2026-10-24
Redes	VLAN 10, 20, 30, 40, 50 y 99; red de nube 10.20.0.0/24	Diseñadas
Servidores	VM-APP01, VM-SIEM01, VM-MON01, VM-BKP01, VM-BAS01 y VPS	VPS operativo; VM diseñadas
Dispositivos de seguridad	OPNsense, Suricata, Cowrie, UFW y firewall de Proxmox	UFW operativo; el resto diseñado
VPN	Túnel IPsec IKEv2 OPNsense ↔ strongSwan	Diseñado
Monitoreo	Wazuh, Uptime Kuma y Netdata; `/health` y panel de infraestructura	`/health` operativo; el resto diseñado
Procesos asociados	Administración de accesos, respaldo, gestión de cambios, gestión de incidentes y monitoreo	Definidos en las secciones 9 a 11

Interfaces y dependencias. Proveedores en la nube (responsabilidad compartida), ISP de la sede, correo de Google Workspace (cuentas usadas para recuperar accesos) y personal de la institución.

Exclusión	Justificación
Red física del colegio	Su sistema se usa por Internet; la infraestructura del VPS sí está en el alcance
Dispositivos personales de alumnos y visitantes	Solo se conectan a la VLAN de invitados, aislada
Desarrollo externalizado	No existe (control 8.30 excluido)
Contabilidad fuera del ámbito académico	No es tratada por estos sistemas

4. Liderazgo y objetivos de seguridad

4.1 Política

La política de seguridad de la información (POL-01, sección 9.1) compromete a CERMAT a cumplir la Ley N.° 29733, proteger los datos según su clasificación, conceder acceso por rol con MFA en cuentas privilegiadas, cifrar en tránsito, publicar cambios de seguridad solo con pruebas en verde, mantener respaldos 3-2-1 probados, gestionar incidentes y mejorar de forma continua. **Estado: redactada; aprobación y firma de la Dirección pendientes.**

4.2 Roles y responsabilidades

Actividad	Dirección	Responsable de seguridad	Líder técnico	Encargado de TI	Responsable de respaldos	Usuarios
Aprobar políticas y aceptar riesgos residuales	A	R	C	I	I	I
Evaluar riesgos y mantener la SoA	I	A/R	C	C	C	—
Gestionar identidades y accesos	I	A	R	R	—	I
Operar respaldos y pruebas de restauración	I	A	C	C	R	—
Responder incidentes	I (S1/S2: A)	A/R	R	R	C	I
Gestionar cambios de seguridad	I	A	R	C	—	—
Auditoría interna	I	A	C	C	C	—
Revisión por la dirección	A/R	R	C	C	C	—

R = responsable de ejecutar, A = rinde cuentas, C = consultado, I = informado. La Dirección debe designar formalmente a las personas en cada rol. Mientras tanto, el líder técnico concentra funciones, lo que se trata como riesgo R-23.

4.3 Objetivos de seguridad medibles

ID	Objetivo	Indicador	Meta	Plazo
OBJ-S1	Ninguna falla crítica de autorización en producción	KPI-01	0	2026-10-31
OBJ-S2	Cuentas privilegiadas protegidas	KPI-03	100 % con MFA	2026-10-31
OBJ-S3	Repositorios sin secretos	KPI-04	0 hallazgos	2026-11-07
OBJ-S4	Recuperabilidad demostrada	KPI-05	≥ 1 restauración verificada por sistema y mes	Desde 2026-11
OBJ-S5	Disponibilidad medida	KPI-07	≥ 99 % mensual	Desde 2026-12

ID	Objetivo	Indicador	Meta	Plazo
OBJ-S6	Respuesta oportuna a incidentes	KPI-09	100 % de S1/S2 contenidos en plazo	Continuo
OBJ-S7	Avance de controles	KPI-10	≥ 60 % de los aplicables implementados	Cierre de la fase 2
OBJ-S8	Riesgos críticos tratados	KPI-11	0 abiertos	2026-11-30

5. Inventario de activos y clasificación de la información

5.1 Esquema de clasificación

Nivel	Definición	Manejo
Pública	Puede divulgarse sin daño	Sin restricciones; se controla su integridad
Interna	Uso del personal y del equipo técnico	No se publica; acceso con cuenta institucional
Confidencial	Su divulgación causa daño limitado	Acceso por rol; cifrado en tránsito; registros de acceso
Restringida	Datos personales, de menores, financieros o credenciales	Acceso mínimo y nominativo; cifrado en tránsito y en las copias externas; nunca en repositorios ni chats

5.2 Criterios de valoración C-I-D

Dimensión	Nivel 1	Nivel 2	Nivel 3
Confidencialidad (C)	Pública: su divulgación no causa daño	Interna o confidencial: uso interno; su divulgación causa daño limitado	Restringida: datos personales, de menores, financieros o credenciales
Integridad (I)	Un error no tiene consecuencias	Un error afecta la operación y se corrige	Un error tiene consecuencias económicas, legales o de seguridad
Disponibilidad (D)	Tolera más de 1 semana sin servicio	Tolera hasta 1 día sin servicio	Se requiere de forma continua (máximo 4 h sin servicio)
Criticidad (C+I+D)	3–4: Baja	5–6: Media; 7–8: Alta	9: Crítica

5.3 Inventario

ID	Activo	Tipo	Propietario	Custodio	Ubicación	Clasificación	C	I	D	Valor (C+I+D)	Criticidad	Estado
ACT-01	Datos personales de alumnos y apoderados (users, enrollments, students; réplica alumnos)	Información	Dirección de la academia	Equipo técnico	Firestore (Google) y réplica MySQL	Restringida	3	3	2	8	Alta	Operativo
ACT-02	Datos de pagos (payments; tabla pagos)	Información	Dirección de la academia	Administrador del sistema	Firestore y MySQL	Restringida	3	3	2	8	Alta	Operativo
ACT-03	Registros de asistencia (attendanceLogs, attendanceDayState, parentAttendance; tabla asistencia)	Información	Dirección de la academia	Auxiliares y equipo técnico	Firestore y MySQL	Confidencial	2	3	2	7	Alta	Operativo
ACT-04	Contenido público (ciclos, sedes, posts, recursos y talleres)	Información	Dirección de la academia	Administrador del sistema	Firestore y Storage	Pública	1	2	2	5	Media	Operativo

ID	Activo	Tipo	Propietario	Custodio	Ubicación	Clasificación	C	I	D	Valor (C+I+D)	Criticidad	Estado
ACT-05	Configuración de servicios (config/services)	Información	Líder técnico	Administrador del sistema	Firestore	Interna	2	3	2	7	Alta	Operativo
ACT-06	Reglas de seguridad de Firestore	Software y configuración	Líder técnico	Equipo técnico	Repositorio Git y Firebase	Interna	1	3	3	7	Alta	Operativo (publicada 2026-10-24)
ACT-07	Código fuente, pruebas y pipeline CI	Software	Líder técnico	Equipo técnico	GitHub (repositorio privado)	Interna	2	3	2	7	Alta	Operativo
ACT-08	Secretos y credenciales (cuenta de servicio, contraseñas de BD, llaves SSH, credenciales de VPN)	Información	Líder técnico	Responsable de seguridad	Gestor de contraseñas y servidores	Restringida	3	3	2	8	Alta	Operativo (clave rotada 2026-10-24)
ACT-09	Respaldos (MySQL, PostgreSQL, Firestore y VM)	Información	Responsable de respaldos	Encargado de TI	PC local, VPS, PBS y disco externo	Restringida	3	3	3	9	Crítica	Parcial (solo MySQL)

ID	Activo	Tipo	Propietario	Custodio	Ubicación	Clasificación	C	I	D	Valor (C+I+D)	Criticidad	Estado
ACT-10	Datos del sistema del colegio (PostgreSQL cermat_produccion)	Información	Dirección del colegio	Líder técnico	VPS (New York)	Restringida	3	3	3	9	Crítica	Operativo
ACT-11	Registros de eventos (API, Nginx, autenticación, firewall, IDS y SIEM)	Información	Responsable de seguridad	Encargado de TI	VPS, PC local y VM-SIEM01	Confidencial	2	3	2	7	Alta	Parcial (sin centralizar)
ACT-12	Documentación técnica y del SGSI	Información	Líder técnico	Equipo técnico	Repositorio público de documentación	Pública e interna	1	2	1	4	Baja	Operativo
ACT-13	Plataforma web de la academia (SPA en Vercel)	Servicio	Dirección de la academia	Líder técnico	Vercel	Pública	1	3	3	7	Alta	Operativo
ACT-14	Firebase Authentication (cuentas y claims)	Servicio	Dirección de la academia	Líder técnico	Google Cloud	Restringida	3	3	3	9	Crítica	Operativo
ACT-15	Cloud Firestore y Storage	Servicio	Dirección de la academia	Líder técnico	Google Cloud	Restringida	3	3	3	9	Crítica	Operativo

ID	Activo	Tipo	Propietario	Custodio	Ubicación	Clasificación	C	I	D	Valor (C+I+D)	Criticidad	Estado
ACT-16	API de sincronización y servicio de analítica	Software	Líder técnico	Equipo técnico	PC local (destino: VM-APP01)	Interna	2	3	2	7	Alta	Transitorio
ACT-17	Base MySQL 8 (réplica relacional)	Software e información	Líder técnico	Equipo técnico	PC local (destino: VM-APP01)	Restringida	3	3	2	8	Alta	Transitorio
ACT-18	Sistema de gestión del colegio (Angular y Laravel)	Software	Dirección del colegio	Líder técnico	VPS	Interna	2	3	3	8	Alta	Operativo
ACT-19	VPS RackNerd (Ubuntu 24.04, UFW, Nginx y Certbot)	Infraestructura	Dirección del colegio	Líder técnico	New York (proveedor)	Restringida	3	3	3	9	Crítica	Operativo
ACT-20	PC local con PM2 (servicios transitorios)	Infraestructura	Dirección de la academia	Líder técnico	PC local (ubicación por confirmar)	Restringida	3	2	2	7	Alta	Transitorio
ACT-21	Host hipervisor PVE01 y sus VM	Infraestructura	Dirección de la academia	Encargado de TI	Rack de la sede	Restringida	3	3	3	9	Crítica	Planificado

ID	Activo	Tipo	Propietario	Custodio	Ubicación	Clasificación	C	I	D	Valor (C+I+D)	Criticidad	Estado
ACT-22	Firewall OPNsense con Suricata	Infraestructura	Dirección de la academia	Encargado de TI	VM-FW01	Confidencial	2	3	3	8	Alta	Planificado
ACT-23	Red local: switch, AP y cableado	Infraestructura	Dirección de la academia	Encargado de TI	Sede principal	Interna	2	2	3	7	Alta	Planificado
ACT-24	Túnel IPsec sede ↔ VPS	Infraestructura	Líder técnico	Encargado de TI	OPNsense y VPS	Confidencial	3	3	2	8	Alta	Planificado
ACT-25	SIEM Wazuh	Infraestructura	Responsable de seguridad	Encargado de TI	VM-SIEM01	Confidencial	2	3	2	7	Alta	Planificado
ACT-26	Monitoreo (Uptime Kuma y Netdata)	Infraestructura	Encargado de TI	Encargado de TI	VM-MON01	Interna	1	2	2	5	Media	Planificado
ACT-27	Repositorio de respaldos (PBS) y disco externo	Infraestructura	Responsable de respaldos	Encargado de TI	Sede y custodia externa	Restringida	3	3	3	9	Crítica	Planificado
ACT-28	Honeypot Cowrie	Infraestructura	Responsable de seguridad	Encargado de TI	VM-HPOT01 en la DMZ	Interna	1	2	1	4	Baja	Planificado
ACT-29	Dominio y DNS (cermatschool.edu.pe en Punto.pe)	Servicio	Dirección del colegio	Líder técnico	Punto.pe / RCP	Interna	1	3	3	7	Alta	Operativo

ID	Activo	Tipo	Propietario	Custodio	Ubicación	Clasificación	C	I	D	Valor (C+I+D)	Criticidad	Estado
ACT-30	Cuentas administrativas de proveedores (Google/Firebase, GitHub, Vercel, RackNerd y Punto.pe)	Información y acceso	Dirección	Líder técnico	Proveedores en la nube	Restringida	3	3	2	8	Alta	Operativo (MFA no verificado)
ACT-31	Equipos de usuario (PC administrativas, laptops y dispositivos de auxiliares)	Infraestructura	Dirección de la academia	Usuarios	Sede principal	Interna	2	2	2	6	Media	Operativo (por inventariar)
ACT-32	Personal clave (administrador del sistema, encargado de TI y equipo técnico)	Personas	Dirección	—	Sede y trabajo remoto	No aplica	2	2	3	7	Alta	Operativo
ACT-33	Cuarto de equipos, rack y UPS	Físico	Dirección de la academia	Encargado de TI	Sede principal, Azángaro	Interna	1	2	3	6	Media	Planificado

El inventario cubre información, software y servicios, infraestructura en la nube y on-premise, personas y el espacio físico. Resultado: 7 activos críticos, 20 altos, 4 medios y 2 bajos.

---

6. Evaluación de riesgos (ISO/IEC 27005)

6.1 Método

Se aplicó el enfoque basado en activos de ISO/IEC 27005:2022:

1. Para cada activo del inventario se identificaron amenazas y vulnerabilidades.
2. Se estimaron probabilidad e impacto con escalas de 1 a 5.
3. El nivel se calculó como P × I y se comparó con los criterios de aceptación.

Las fuentes fueron los hallazgos de la auditoría interna del 2026-10-24, el manual de despliegue del VPS, las verificaciones externas y el análisis del diseño.

6.2 Criterios

Escala	Valor	Nombre	Descripción
Probabilidad	1	Rara	No se espera en 5 años
Probabilidad	2	Improbable	Podría ocurrir una vez en 2 a 5 años
Probabilidad	3	Posible	Una vez al año
Probabilidad	4	Probable	Varias veces al año
Probabilidad	5	Casi segura	Mensual, o la vulnerabilidad está activa y se explota sin conocimientos especiales
Impacto	1	Insignificante	Sin efecto en datos ni servicios
Impacto	2	Menor	Molestia operativa menor a 4 h; sin datos personales
Impacto	3	Moderado	Interrupción de un servicio crítico hasta 1 día o pérdida recuperable de hasta 24 h de datos
Impacto	4	Mayor	Exposición de datos personales de un grupo, interrupción mayor a 1 día o posible sanción
Impacto	5	Catastrófico	Exposición masiva de datos de menores, compromiso total de la plataforma o pérdida irrecuperable

Escala	Valor	Nombre	Descripción
Nivel (P×I)	1–4	Bajo	Aceptable; se revisa una vez al año
Nivel (P×I)	5–9	Medio	Aceptable con monitoreo y aprobación de la Dirección
Nivel (P×I)	10–14	Alto	Tratamiento en 30 días como máximo
Nivel (P×I)	15–25	Crítico	Tratamiento inmediato (7 días como máximo)

6.3 Matriz de evaluación

ID	Activos	Amenaza	Vulnerabilidad	Impacto	P	I	Nivel (P×I)	Clasificación	Origen
R-01	ACT-01, ACT-15	Recolección no autorizada de datos personales	Las reglas publicadas el 22-jun-2026 permitían, hasta el 2026-10-24, listar sin sesión las matrículas pagadas (nombres y teléfonos)	Exposición de datos de menores y apoderados; incumplimiento de la Ley N.° 29733	5	4	20	Crítico	Hallazgo H-01 (auditoría 2026-10-24)
R-02	ACT-14, ACT-15	Escalamiento de privilegios por un usuario registrado	Las reglas publicadas hasta el 2026-10-24 permitían crear un perfil de auxiliar o docente sin invitación	Acceso a funciones de asistencia y a datos de alumnos	4	4	16	Crítico	Hallazgo H-01

ID	Activos	Amenaza	Vulnerabilidad	Impacto	P	I	Nivel (P×I)	Clasificación	Origen
R-03	ACT-13, ACT-15	Interrupción de la matrícula pública	Las reglas publicadas hasta el 2026-10-24 bloqueaban la lectura y el cupo que necesita la matrícula sin sesión	Pérdida de pre-matrículas e ingresos	5	3	15	Crítico	Hallazgo H-01
R-04	ACT-06	Cambios de seguridad que no llegan a producción	El despliegue de reglas fallaba en silencio por una línea inválida y nadie verificaba lo publicado	Controles corregidos sin efecto durante meses	4	4	16	Crítico	Hallazgo H-02
R-05	ACT-08, ACT-14, ACT-15	Uso indebido de una credencial de administrador del proyecto Firebase	La clave de la cuenta de servicio estuvo en copias ZIP versionadas en el repositorio privado (revocada el 2026-10-24)	Lectura y escritura total de datos y cuentas	2	5	10	Alto	Hallazgo H-03
R-06	ACT-08, ACT-17	Acceso no autorizado a MySQL	Archivos de entorno versionados (hoy sin contraseñas; el equipo decidió mantenerlos en Git)	Lectura o alteración de la réplica	2	3	6	Medio	Hallazgo H-03

ID	Activos	Amenaza	Vulnerabilidad	Impacto	P	I	Nivel (P×I)	Clasificación	Origen
R-07	ACT-09, ACT-10, ACT-19	Pérdida de datos del colegio (falla del VPS, error humano o ransomware)	Respaldos externos diseñados pero no implantados; sin prueba de restauración	Pérdida irrecuperable de información escolar	3	5	15	Crítico	Hallazgo H-04 (manual del VPS)
R-08	ACT-19	Agotamiento de memoria del VPS	2 GB compartidos por Nginx, PHP-FPM y PostgreSQL, sin línea base ni alertas	Caída del sitio y de la API del colegio	3	3	9	Medio	Hallazgo H-05
R-09	ACT-13, ACT-16, ACT-18, ACT-19	Indisponibilidad no detectada	Sin monitor externo ni alertas	Las fallas las descubren los usuarios	4	3	12	Alto	Hallazgo H-06
R-10	ACT-01, ACT-02, ACT-03, ACT-15	Pérdida de datos operativos	Firestore sin respaldo programado ni prueba de restauración	Pérdida de matrículas, pagos y asistencia	2	5	10	Alto	Hallazgo H-07
R-11	ACT-30	Toma de cuentas administrativas por phishing	MFA no verificado; el dominio sin SPF ni DMARC facilita la suplantación	Control total de los servicios en la nube	3	5	15	Crítico	Hallazgo H-08 (verificación DNS 2026-10-24)
R-12	ACT-19	Acceso no autorizado por SSH	22/tcp abierto a Internet; configuración de autenticación SSH no verificada	Compromiso del servidor y de PostgreSQL	3	5	15	Crítico	Análisis (manual del VPS)

ID	Activos	Amenaza	Vulnerabilidad	Impacto	P	I	Nivel (P×I)	Clasificación	Origen
R-13	ACT-13, ACT-18, ACT-19	Reconocimiento y ataques del lado del cliente	Nginx revela su versión; el sitio del colegio no envía HSTS ni cabeceras de seguridad y la SPA solo envía HSTS	Facilita ataques dirigidos, clickjacking y degradación a HTTP	3	2	6	Medio	Hallazgo H-09 (verificación 2026-10-24)
R-14	ACT-29	Emisión indebida de certificados o suplantación DNS	Sin registros CAA ni DNSSEC	Suplantación del sitio institucional	2	3	6	Medio	Hallazgo H-09
R-15	ACT-16, ACT-17, ACT-21	Movimiento lateral desde la red local	La sede no tiene firewall perimetral ni segmentación implantada	Acceso a servidores desde equipos infectados o de invitados	3	4	12	Alto	Análisis
R-16	ACT-11, ACT-22, ACT-25	Intrusión no detectada	Sin IDS/IPS, SIEM ni honeypot	Ataques sin detección ni evidencia	3	4	12	Alto	Análisis
R-17	ACT-33, ACT-21	Cortes eléctricos	Sin UPS en la sede	Apagado abrupto y corrupción de datos locales	4	3	12	Alto	Análisis (SUP-10)
R-18	ACT-21	Falla del host único	Un solo servidor físico, sin clúster	Interrupción de los servicios locales	2	4	8	Medio	Análisis
R-19	ACT-23	Caída del enlace de Internet de la sede	Un solo enlace	La sede pierde acceso a la plataforma	3	3	9	Medio	Análisis

ID	Activos	Amenaza	Vulnerabilidad	Impacto	P	I	Nivel (P×I)	Clasificación	Origen
R-20	ACT-24	Interrupción del túnel	Dependencia del enlace de la sede	Sin respaldos externos, administración ni sincronización mientras dure	3	2	6	Medio	Análisis
R-21	ACT-31, ACT-01	Ransomware o malware	Equipos de usuario sin control centralizado	Cifrado o robo de información	3	4	12	Alto	Análisis
R-22	ACT-07, ACT-31	Interrupción de tareas por un falso positivo del antivirus	Ejecutar scripts SQL desde PowerShell con cmd se detectó como amenaza	Scripts en cuarentena y demora de pruebas	3	2	6	Medio	Incidente INC-03
R-23	ACT-32	Pérdida de capacidad operativa por concentración de conocimiento y accesos	Un solo integrante administra los servicios y figura como único autor del historial	Dependencia crítica de una persona	3	4	12	Alto	Hallazgo H-10
R-24	ACT-01	Sanción o reclamo por incumplimiento normativo	Formalidades de la Ley N.° 29733 no verificadas (banco de datos, aviso de privacidad, consentimiento de apoderados, transferencia internacional)	Multas y daño reputacional	3	4	12	Alto	Análisis (dato a confirmar)

ID	Activos	Amenaza	Vulnerabilidad	Impacto	P	I	Nivel (P×I)	Clasificación	Origen
R-25	ACT-28	Uso del honeypot como plataforma de ataque	Servicio expuesto a Internet	Responsabilidad por ataques a terceros	2	3	6	Medio	Análisis
R-26	ACT-33	Acceso físico no autorizado	Sin cuarto de equipos cerrado	Robo o manipulación de equipos	2	4	8	Medio	Análisis
R-27	ACT-09, ACT-17	Pérdida de los respaldos de MySQL junto con la base	Respaldos en el mismo equipo que la base; programación diaria no verificada	Sin recuperación ante una falla del equipo	3	4	12	Alto	Análisis
R-28	ACT-17	Réplica relacional incompleta	Sincroniza solo con la PC local encendida y sin reintentos	Reportes con datos faltantes	4	2	8	Medio	Hecho verificado
R-29	ACT-13, ACT-15, ACT-19	Dependencia de proveedores	Cambio de condiciones, falta de pago o suspensión de la cuenta	Interrupción prolongada	2	4	8	Medio	Análisis

6.4 Mapa de calor del riesgo inicial

Probabilidad / Impacto	1 Insignificante	2 Menor	3 Moderado	4 Mayor	5 Catastrófico
5 Casi segura	—	—	R-03	R-01	—
4 Probable	—	R-28	R-09, R-17	R-02, R-04	—
3 Posible	—	R-13, R-20, R-22	R-08, R-19	R-15, R-16, R-21, R-23, R-24, R-27	R-07, R-11, R-12
2 Improbable	—	—	R-06, R-14, R-25	R-18, R-26, R-29	R-05, R-10
1 Rara	—	—	—	—	—

7. Tratamiento de riesgos

ID	Opción	Controles (Anexo A)	Acciones	Responsable	Plazo	Residual (P×I)	Nivel residual	Estado
R-01	Mitigar	5.15, 8.3, 5.34, 8.29, 8.32	Publicar las reglas corregidas mediante el CI (19/19); verificar en producción que el listado sin sesión falla	Líder técnico	2026-10-31	1×4 = 4	Bajo	Tratado (2026-10-24): publicadas desde la consola; listar matrículas pagadas sin sesión → 403
R-02	Mitigar	5.15, 5.18, 8.2, 8.29	Publicar las reglas; revisar los 4 perfiles con rol docente o auxiliar contra sus invitaciones	Líder técnico	2026-10-31	1×4 = 4	Bajo	Tratado (2026-10-24): reglas publicadas; falta revisar los 4 perfiles existentes
R-03	Mitigar	8.32, 8.29, 5.30	Publicar las reglas y registrar una matrícula de prueba sin sesión en producción, anulándola después	Líder técnico	2026-10-31	1×3 = 3	Bajo	Tratado (2026-10-24): pre-matrícula de prueba sin sesión exitosa en producción
R-04	Mitigar	8.32, 8.9, 8.25	Publicar solo por CI tras las 19 pruebas; configurar el secreto; comparar cada mes el ruleset publicado con el repositorio	Líder técnico	2026-11-07	1×4 = 4	Bajo	En curso: reglas publicadas desde la consola el 2026-10-24; falta el secreto del CI y la comparación mensual

ID	Opción	Controles (Anexo A)	Acciones	Responsable	Plazo	Residual (P×I)	Nivel residual	Estado
R-05	Mitigar	5.17, 8.12, 8.4, 5.26	Revocar y rotar la clave en IAM; retirar todas las copias y depurar el historial; revisar los registros de auditoría de IAM; escaneo de secretos en el CI	Líder técnico	2026-10-26	1×5 = 5	Medio	Tratado (2026-10-24): clave `283b43c3` … eliminada y reemplazada por `ddf50bfe` … ; falta el escaneo de secretos en el CI
R-06	Mitigar	5.17, 8.12	Retirar los archivos del índice de Git, rotar las contraseñas y usar las cuentas de mínimo privilegio	Líder técnico	2026-11-07	1×3 = 3	Bajo	Tratado con riesgo aceptado (2026-10-24): los `.env` no tienen contraseñas y siguen versionados por decisión del equipo; las contraseñas MySQL irán fuera de ellos
R-07	Mitigar	8.13, 5.30, 8.14	pg_dump -Fc diario con SHA256SUMS; copia semanal cifrada fuera del VPS por SCP (transitoria) y luego extracción diaria por el túnel; restauración mensual de prueba	Líder técnico	2026-11-07	3×2 = 6	Medio	Pendiente

ID	Opción	Controles (Anexo A)	Acciones	Responsable	Plazo	Residual (P×I)	Nivel residual	Estado
R-08	Mitigar	8.6, 8.16	Medir la línea base; no alojar la capa de la academia en el VPS; swap de 1–2 GB; alerta al 80 %; ampliar el plan si MemAvailable < 25 %	Encargado de TI	2026-11-14	2×3 = 6	Medio	Pendiente
R-09	Mitigar	8.16, 5.24	Uptime Kuma con alertas y latido externo	Encargado de TI	2026-11-14	4×2 = 8	Medio	Pendiente
R-10	Mitigar	8.13, 5.23	Exportación diaria (gestionada si el plan lo permite, o script con firebase-admin) y restauración en un proyecto de prueba	Líder técnico	2026-11-21	2×2 = 4	Bajo	Pendiente
R-11	Mitigar	5.17, 8.5, 6.3, 5.14	MFA en las 5 cuentas (de preferencia llave FIDO2); SPF, DKIM y DMARC; capacitación	Dirección y líder técnico	2026-10-31	1×5 = 5	Medio	Pendiente
R-12	Mitigar	8.5, 8.20, 8.2	Verificar autenticación solo con llaves y sin root; fail2ban; SSH solo por la VPN desde el bastión	Líder técnico	2026-11-07	1×5 = 5	Medio	Pendiente

ID	Opción	Controles (Anexo A)	Acciones	Responsable	Plazo	Residual (P×I)	Nivel residual	Estado
R-13	Mitigar	8.21, 8.9	server_tokens off; HSTS, nosniff, frame-ancestors y Referrer-Policy en Nginx y en vercel.json	Líder técnico	2026-11-07	1×2 = 2	Bajo	Pendiente
R-14	Mitigar	8.21, 8.24	Registro CAA para Let's Encrypt; DNSSEC si el registro .pe y el proveedor lo permiten	Líder técnico	2026-11-14	1×3 = 3	Bajo	Pendiente
R-15	Mitigar	8.22, 8.20	VLAN y reglas de OPNsense según S1-E1	Encargado de TI	Fase 2 (sujeta al hardware)	1×4 = 4	Bajo	Planificado
R-16	Mitigar	8.16, 8.15, 5.7	Suricata, Wazuh y Cowrie	Responsable de seguridad	Fase 2	2×3 = 6	Medio	Planificado
R-17	Mitigar	7.11, 8.14	UPS con NUT y apagado ordenado	Encargado de TI	Fase 2	4×1 = 4	Bajo	Planificado
R-18	Aceptar con mitigación parcial	8.14, 8.13	Espejo ZFS, respaldos en PBS y disco externo; los servicios críticos siguen en la nube	Dirección	Fase 2	2×3 = 6	Medio	Planificado (aceptación pendiente)
R-19	Mitigar	8.14, 5.30	WAN2 4G/LTE con conmutación automática	Encargado de TI	Fase 2	3×1 = 3	Bajo	Planificado

ID	Opción	Controles (Anexo A)	Acciones	Responsable	Plazo	Residual (P×I)	Nivel residual	Estado
R-20	Mitigar	8.14, 8.16	DPD y reintento, alerta y consola del proveedor como acceso de emergencia	Encargado de TI	Fase 2	3×1 = 3	Bajo	Planificado
R-21	Mitigar	8.7, 8.1, 6.3, 8.13	Antivirus, actualizaciones, cuentas sin privilegios de administrador y respaldos fuera de línea	Encargado de TI	2026-12-15	2×3 = 6	Medio	Planificado
R-22	Mitigar	8.7, 5.37	Ejecutar desde Git Bash; exclusión acotada a la carpeta; verificar el hash al restaurar desde cuarentena; reportar al fabricante	Líder técnico	Cumplido (procedimiento)	1×2 = 2	Bajo	Implementado
R-23	Mitigar	5.2, 5.3, 5.37	Manuales, cuentas nominativas para otro integrante, credenciales de emergencia custodiadas y revisión por un segundo integrante	Dirección y líder técnico	2026-11-30	2×3 = 6	Medio	Pendiente

ID	Opción	Controles (Anexo A)	Acciones	Responsable	Plazo	Residual (P×I)	Nivel residual	Estado
R-24	Mitigar	5.31, 5.34, 5.20	Verificar la inscripción del banco de datos ante la ANPD, el aviso de privacidad y el consentimiento en la matrícula; revisar las condiciones de tratamiento de los proveedores	Dirección	2026-12-15	1×4 = 4	Bajo	Pendiente
R-25	Mitigar	8.22, 8.20	DMZ sin salida (FW-41), Cowrie de interacción media, snapshots y revisión semanal	Responsable de seguridad	Fase 2	1×3 = 3	Bajo	Planificado
R-26	Mitigar	7.1, 7.2, 7.4	Cuarto cerrado con llave, bitácora y cámara	Dirección	Fase 2	1×4 = 4	Bajo	Planificado
R-27	Mitigar	8.13	Programar con PM2 y copiar a PBS y fuera de la sede (3-2-1)	Líder técnico	2026-11-14	1×3 = 3	Bajo	Pendiente
R-28	Mitigar	8.14, 8.16	Servicio 24/7 en VM-APP01; conciliación con v_conciliacion_pagos; resincronización desde Firestore	Líder técnico	Fase 2	2×2 = 4	Bajo	Planificado

ID	Opción	Controles (Anexo A)	Acciones	Responsable	Plazo	Residual (P×I)	Nivel residual	Estado
R-29	Aceptar con controles	5.19, 5.22, 5.23	Recordatorios de renovación, exportaciones periódicas y documentación para migrar	Dirección	Continuo	2×3 = 6	Medio	Aceptación pendiente

Resultado. El tratamiento deja 18 riesgos residuales bajos y 11 medios: R-05, R-07, R-08, R-09, R-11, R-12, R-16, R-18, R-21, R-23 y R-29. Según el criterio de aceptación, los residuales medios necesitan aprobación de la Dirección, que se solicitará en la revisión por la dirección (sección 13.4). R-18 y R-29 se aceptan con controles porque eliminarlos exigiría un segundo host o un segundo proveedor, desproporcionados para la escala de la institución.

---

8. Declaración de Aplicabilidad (SoA)

La SoA cubre los 93 controles del Anexo A de ISO/IEC 27001:2022. La columna "Riesgos tratados" se calcula automáticamente desde la matriz de tratamiento: cada control seleccionado en un tratamiento aparece vinculado a su riesgo. La hoja "Trazabilidad" del XLSX y la sección 14 completan la cadena riesgo → control → evidencia.

Estados: Implementado = existe y hay evidencia verificable; Parcial = existe en una parte del alcance (por ejemplo, en la nube) y falta en otra; Planificado = diseñado, con procedimiento, sin ejecutar; No aplicable = excluido con justificación.

Tema	Controles	Implementado	Parcial	Planificado	No aplicable
5. Organizacionales	37	4	22	11	0
6. De personas	8	0	2	6	0
7. Físicos	14	0	0	14	0
8. Tecnológicos	34	5	22	6	1
Total	93	9	46	37	1

Exclusión justificada: 8.30 Desarrollo externalizado. El software lo desarrolla el propio equipo; si en el futuro se contrata desarrollo a terceros, se aplicarán los requisitos de 5.20 y se reincorporará el control.

8.1 Controles organizacionales (5.1 a 5.37)

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
5.1	Políticas de seguridad de la información	Sí	Requisito de la cláusula 5.2; marco de todo el SGSI	—	Parcial	Política POL-01 redactada (§9.1); aprobación de la Dirección pendiente
5.2	Roles y responsabilidades de seguridad de la información	Sí	Equipo pequeño con funciones concentradas	R-23	Parcial	Matriz RACI (§4.2); designación formal pendiente
5.3	Segregación de funciones	Sí	Un mismo integrante desarrolla y publica	R-23	Planificado	Revisión por un segundo integrante con .github/pull_request_template.md
5.4	Responsabilidades de la dirección	Sí	La Dirección aprueba la política y acepta riesgos residuales	—	Planificado	Revisión por la dirección (§13.4) pendiente
5.5	Contacto con las autoridades	Sí	Incidentes con datos personales y delitos informáticos	—	Planificado	Directorio de contactos en PRO-01 (ANPD, PNP-DIVINDAT, CSIRT nacional)
5.6	Contacto con grupos de interés especial	Sí	Avisos de seguridad de los productos usados	—	Planificado	Suscripción a avisos de Ubuntu, OPNsense, Proxmox, Wazuh, Firebase y GitHub
5.7	Inteligencia de amenazas	Sí	Detección basada en firmas y reputación	R-16	Planificado	Reglas ET Open y listas abuse.ch en Suricata; CTI de Wazuh
5.8	Seguridad de la información en la gestión de proyectos	Sí	Los riesgos de seguridad deben entrar al backlog	—	Parcial	Ítems PB-04, PB-06, PB-08 y PB-11 del backlog (E4 §3.3)
5.9	Inventario de información y otros activos asociados	Sí	Base de la evaluación de riesgos	—	Implementado	s2-e1-inventario-activos.xlsx (33 activos); revisión trimestral

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
5.10	Uso aceptable de la información y otros activos asociados	Sí	Personal, docentes e invitados usan la red y los datos	—	Parcial	POL-05 redactada (§9.6); difusión y aceptación pendientes
5.11	Devolución de activos	Sí	Rotación de personal con accesos	—	Planificado	Lista de baja: retirar claims, llaves SSH y equipos el mismo día
5.12	Clasificación de la información	Sí	Datos de menores y financieros	—	Implementado	Esquema de 4 niveles aplicado al inventario (§5)
5.13	Etiquetado de la información	Sí	Respaldos y exportaciones con datos restringidos	—	Planificado	Prefijo de clasificación en nombres de respaldos y documentos
5.14	Transferencia de información	Sí	Datos entre navegador, nube y sede	R-11	Parcial	TLS 1.2/1.3 verificado (PR-06, PR-13); túnel IPsec pendiente; correo sin SPF ni DMARC
5.15	Control de acceso	Sí	Portales por rol y datos de menores	R-01, R-02	Parcial	Reglas por rol probadas 19/19 y publicadas el 2026-10-24; roles MySQL; UFW
5.16	Gestión de identidades	Sí	Identidad única en Firebase y cuentas en servidores	—	Parcial	Invitaciones de un solo uso; usuario nominativo en el VPS; revisión de cuentas pendiente
5.17	Información de autenticación	Sí	Contraseñas, llaves y cuentas de servicio	R-05, R-06, R-11	Parcial	Contraseñas de BD por variables de entorno; no conformidad NC-03 abierta

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
5.18	Derechos de acceso	Sí	Altas, cambios y bajas de roles	R-02	Parcial	Claims de administrador y matriz de accesos (§10.2); revisión trimestral pendiente
5.19	Seguridad de la información en las relaciones con los proveedores	Sí	Dependencia de 6 proveedores	R-29	Parcial	Proveedores identificados (§9.4); evaluación formal pendiente
5.20	Tratamiento de la seguridad de la información en los acuerdos con proveedores	Sí	Tratamiento de datos personales por terceros	R-24	Planificado	Revisar términos y anexos de tratamiento de datos de Google, Vercel, RackNerd y Punto.pe
5.21	Gestión de la seguridad de la información en la cadena de suministro de las TIC	Sí	Dependencias npm y pip	—	Parcial	package-lock.json y npm ci en el CI; auditoría de dependencias pendiente
5.22	Seguimiento, revisión y gestión del cambio de los servicios de proveedores	Sí	Cambios de planes y condiciones	R-29	Planificado	Suscripción a páginas de estado y avisos de cambios de plan
5.23	Seguridad de la información para el uso de servicios en la nube	Sí	Arquitectura con IaaS, PaaS y SaaS	R-10, R-29	Parcial	POL-03 (§9.4); respaldo de Firestore pendiente
5.24	Planificación y preparación de la gestión de incidentes de seguridad de la información	Sí	Incidentes reales registrados	R-09	Parcial	PRO-01 (§9.3) y registro de incidentes; simulacro pendiente
5.25	Evaluación y decisión sobre los eventos de seguridad de la información	Sí	Diferenciar eventos e incidentes	—	Parcial	Criterios de severidad (§11.2) aplicados a INC-01 a INC-05

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
5.26	Respuesta a incidentes de seguridad de la información	Sí	INC-01 e INC-02 abiertos	R-05	Parcial	INC-01 contenido en código; publicación y rotación pendientes
5.27	Aprendizaje de los incidentes de seguridad de la información	Sí	Evitar recurrencia	—	Implementado	Lecciones aprendidas aplicadas: publicación por CI y ejecución desde Git Bash (E4 §2.6 y §3.5)
5.28	Recopilación de evidencias	Sí	Evidencia de hallazgos y de incidentes	—	Parcial	Ruleset de producción descargado en modo solo lectura; cadena de custodia por formalizar
5.29	Seguridad de la información durante una interrupción	Sí	Operación en contingencia sin la sede	—	Planificado	Modo de contingencia: la operación sigue en la nube con los mismos controles
5.30	Preparación de las TIC para la continuidad de negocio	Sí	RTO y RPO por servicio	R-03, R-07, R-19	Parcial	RTO/RPO definidos; restauración de MySQL probada; VPS, VM y Firestore pendientes
5.31	Requisitos legales, estatutarios, reglamentarios y contractuales	Sí	Ley N.° 29733 y su reglamento	R-24	Parcial	Requisitos identificados; formalidades ante la ANPD por verificar
5.32	Derechos de propiedad intelectual	Sí	Uso de software libre y dependencias	—	Parcial	Licencias libres (AGPL, BSD, GPL) identificadas; inventario de licencias pendiente

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
5.33	Protección de los registros	Sí	Trazabilidad de pagos y cambios	—	Parcial	Tabla auditoria con triggers; historial de Git; retención centralizada pendiente
5.34	Privacidad y protección de datos personales	Sí	Datos de menores y apoderados	R-01, R-24	Parcial	Reglas corregidas restringen lecturas; indicadores con conteos agregados; datos ficticios en pruebas
5.35	Revisión independiente de la seguridad de la información	Sí	La auditoría interna la hizo el propio equipo	—	Planificado	Revisión por el jurado y por un integrante no autor; auditoría externa no prevista por costo
5.36	Cumplimiento de las políticas, reglas y normas de seguridad de la información	Sí	Verificar que los controles se aplican	—	Parcial	Auditoría interna del 2026-10-24 con lista de verificación
5.37	Procedimientos de operación documentados	Sí	Operación por pocas personas	R-22, R-23	Implementado	Manual del VPS (diario, semanal, mensual, diagnóstico y comandos prohibidos); server/src/db/README.md

8.2 Controles de personas (6.1 a 6.8)

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
6.1	Investigación de antecedentes	Sí	Personal con acceso privilegiado	—	Planificado	Verificación de referencias proporcional al cargo

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
6.2	Términos y condiciones del empleo	Sí	Responsabilidades de seguridad del personal	—	Planificado	Cláusula de confidencialidad y uso aceptable en los contratos
6.3	Concienciación, educación y formación en seguridad de la información	Sí	Phishing y manejo de datos personales	R-11, R-21	Planificado	Sesión anual sobre phishing, contraseñas, MFA y uso aceptable
6.4	Proceso disciplinario	Sí	Consecuencias de incumplir las políticas	—	Planificado	Referencia al reglamento interno de la institución
6.5	Responsabilidades ante la finalización o cambio de empleo	Sí	Retiro oportuno de accesos	—	Planificado	Retiro de claims, roles y llaves el mismo día
6.6	Acuerdos de confidencialidad o no divulgación	Sí	Acceso a datos personales	—	Parcial	Declaración de ética del equipo (§12.7) pendiente de firma; acuerdo para el personal pendiente
6.7	Trabajo remoto	Sí	La plataforma se administra por Internet	—	Parcial	Administración web por HTTPS; administración de infraestructura solo por VPN y bastión (planificado)
6.8	Notificación de eventos de seguridad de la información	Sí	Detección temprana por usuarios	—	Planificado	Canal de reporte (grupo del equipo y correo del administrador) y formulario de incidente

8.3 Controles físicos (7.1 a 7.14)

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
7.1	Perímetros de seguridad física	Sí	Rack on-premise; en la nube lo asume el proveedor	R-26	Planificado	Cuarto de equipos cerrado (S1-E2 §5)
7.2	Controles físicos de entrada	Sí	Acceso al cuarto de equipos	R-26	Planificado	Llave y bitácora de ingreso
7.3	Seguridad de oficinas, despachos e instalaciones	Sí	Secretaría y caja atienden público	—	Planificado	Acceso restringido a oficinas con equipos administrativos
7.4	Monitoreo de la seguridad física	Sí	Rack sin vigilancia	R-26	Planificado	Cámara orientada al rack, con aviso de videovigilancia
7.5	Protección contra amenazas físicas y ambientales	Sí	Incendio, agua y temperatura	—	Planificado	Extintor de CO2, ubicación lejos de tuberías, sensor de temperatura
7.6	Trabajo en áreas seguras	Sí	Visitas técnicas al cuarto de equipos	—	Planificado	Acompañamiento de terceros; prohibido comer o beber junto al rack
7.7	Puesto de trabajo despejado y pantalla limpia	Sí	Datos personales en pantallas de atención	—	Planificado	Bloqueo automático de sesión a los 5 minutos
7.8	Ubicación y protección de equipos	Sí	Equipos de red y cómputo	—	Planificado	Rack cerrado, UPS y ventilación
7.9	Seguridad de los activos fuera de las instalaciones	Sí	Disco de respaldo externo y laptops	—	Planificado	Disco cifrado con custodia registrada fuera de la sede
7.10	Soportes de almacenamiento	Sí	Respaldos con datos restringidos	—	Planificado	Cifrado del disco externo y registro de custodia
7.11	Servicios de suministro	Sí	Cortes eléctricos	R-17	Planificado	UPS con NUT (Tier I con elementos de Tier II)

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
7.12	Seguridad del cableado	Sí	Cableado estructurado de la sede	—	Planificado	Cat 6 en canaletas; patch panel etiquetado (TIA-568 y TIA-606)
7.13	Mantenimiento de los equipos	Sí	Baterías del UPS y ventilación	—	Planificado	Mantenimiento semestral del UPS y limpieza del rack
7.14	Eliminación o reutilización segura de los equipos	Sí	Discos con datos restringidos	—	Planificado	Borrado seguro según NIST SP 800-88 antes de reutilizar o desechar

En la nube, la seguridad física la asume cada proveedor (modelo de responsabilidad compartida). Los controles físicos aplican al cuarto de equipos de la sede, que aún no existe.

8.4 Controles tecnológicos (8.1 a 8.34)

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
8.1	Dispositivos de punto final de usuario	Sí	Equipos administrativos y de auxiliares	R-21	Parcial	Antivirus activo en la PC local (INC-03); estándar de equipos pendiente
8.2	Derechos de acceso privilegiado	Sí	Administradores de nube y servidores	R-02, R-12	Parcial	Usuario no-root con sudo en el VPS; claim admin acotado; MFA no verificado
8.3	Restricción del acceso a la información	Sí	Datos de menores	R-01	Parcial	Reglas corregidas publicadas el 2026-10-24; vistas MySQL para reportes
8.4	Acceso al código fuente	Sí	Repositorio con configuración de seguridad	R-05	Parcial	Repositorio privado en GitHub; secretos en el historial (NC-03)

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
8.5	Autenticación segura	Sí	Cuentas privilegiadas y servidores	R-11, R-12	Parcial	Firebase Auth y SSH; MFA no verificado; IKEv2 con certificados planificado
8.6	Gestión de la capacidad	Sí	VPS de 2 GB compartido	R-08	Planificado	Presupuesto de RAM del VPS; alertas de capacidad al 80 %
8.7	Protección contra el malware	Sí	Ransomware en equipos de usuario	R-21, R-22	Parcial	Antivirus en la PC local; FIM y rootcheck de Wazuh planificados
8.8	Gestión de las vulnerabilidades técnicas	Sí	Servidores expuestos y dependencias	—	Planificado	Auditoría de dependencias en el CI, actualizaciones automáticas de seguridad y detección de vulnerabilidades de Wazuh
8.9	Gestión de la configuración	Sí	Reglas, migraciones y configuraciones de red	R-04, R-13	Parcial	Git, migraciones numeradas y reglas versionadas; configuraciones de red y CD por versionar en infra/
8.10	Eliminación de la información	Sí	Retención de datos personales	—	Parcial	backup.js conserva 7 copias; política de retención de datos de exalumnos pendiente
8.11	Enmascaramiento de datos	Sí	Pruebas e indicadores	—	Implementado	Datos ficticios en 90_datos_prueba.sql; indicadores solo con conteos agregados

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
8.12	Prevención de la fuga de datos	Sí	Secretos en el repositorio	R-05, R-06	Planificado	gitleaks en el CI y escaneo de secretos de GitHub
8.13	Copias de seguridad de la información	Sí	Pérdida de datos	R-07, R-10, R-18, R-21, R-27	Parcial	MySQL: backup.js y restore.js probados, también sobre la base real (REC-05); falta programarlos. VPS, Firestore y VM pendientes
8.14	Redundancia de las instalaciones de procesamiento de la información	Sí	Falla de disco, enlace o host	R-07, R-17, R-18, R-19, R-20, R-28	Planificado	Espejo ZFS, bond LACP y WAN2 LTE; PaaS con redundancia del proveedor
8.15	Registro de eventos	Sí	Trazabilidad e investigación	R-16	Parcial	morgan en la API, registros de Nginx y autenticación en el VPS, auditoría MySQL; centralización en Wazuh pendiente
8.16	Actividades de monitoreo	Sí	Detección de fallas y ataques	R-08, R-09, R-16, R-20, R-28	Parcial	/health y panel admin Infraestructura; Uptime Kuma y Wazuh pendientes
8.17	Sincronización del reloj	Sí	Correlación de eventos	—	Parcial	Fechas locales corregidas en la app; NTP del VPS por verificar (timedatectl); NTP de OPNsense planificado

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
8.18	Uso de programas utilitarios privilegiados	Sí	Comandos destructivos en producción	—	Parcial	Lista de comandos prohibidos en el manual del VPS; sudo con registro
8.19	Instalación del software en sistemas en producción	Sí	Cambios en servidores productivos	—	Parcial	Despliegue por CI y Vercel; procedimiento de actualización sin pérdida del manual
8.20	Seguridad de las redes	Sí	Perímetro de la sede y del VPS	R-12, R-15, R-25	Parcial	UFW en el VPS implementado; OPNsense planificado
8.21	Seguridad de los servicios de red	Sí	HTTPS, DNS y correo	R-13, R-14	Parcial	TLS 1.2/1.3 y HSTS en Vercel; cabeceras, CAA, SPF y DMARC pendientes
8.22	Segregación de las redes	Sí	Red plana en la sede	R-15, R-25	Planificado	VLAN 10, 20, 30, 40, 50 y 99 (S1-E1 §8)
8.23	Filtrado web	Sí	Malware en la navegación de invitados	—	Planificado	Listas de bloqueo DNS en Unbound para GUEST y ACAD
8.24	Uso de la criptografía	Sí	Datos en tránsito y respaldos	R-14	Parcial	TLS verificado; SHA-256 en respaldos; IPsec AES-256-GCM y restic cifrado planificados
8.25	Ciclo de vida de desarrollo seguro	Sí	Reglas y API con controles de acceso	R-04	Parcial	CI con pruebas; revisión entre pares pendiente
8.26	Requisitos de seguridad de las aplicaciones	Sí	Autorización por rol y titularidad	—	Implementado	Requisitos de autorización probados (19 reglas, 18 API); validación con Zod

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
8.27	Principios de ingeniería y arquitectura de sistemas seguros	Sí	Defensa en profundidad	—	Parcial	Mínimo privilegio en BD, sincronización no bloqueante y zonas del diseño
8.28	Codificación segura	Sí	Inyección y fuga de errores	—	Parcial	execFileSync sin shell, errores sin detalles internos y helmet; 240 usos de any pendientes
8.29	Pruebas de seguridad en el desarrollo y la aceptación	Sí	Fallas de autorización	R-01, R-02, R-03	Implementado	19 pruebas de reglas, 18 de API y 19 de BD; suite ejecutada contra producción en solo lectura
8.30	Desarrollo externalizado	No	No aplica: el desarrollo lo realiza el equipo; si se contrata a terceros se aplicará 5.20	—	No aplicable	—
8.31	Separación de los entornos de desarrollo, prueba y producción	Sí	Pruebas sin tocar datos reales	—	Parcial	Emulador de Firestore y bases cermat_prueba y cermat_db_verificacion; sin proyecto Firebase de staging
8.32	Gestión de cambios	Sí	Reglas que nunca llegaron a producción	R-01, R-03, R-04	Parcial	Publicación condicionada en el CI; procedimiento de actualización del VPS; NC-02 abierta
8.33	Información de prueba	Sí	Datos personales en pruebas	—	Implementado	Datos ficticios; el script de datos se niega a correr con datos reales

Control	Nombre	Aplicable	Justificación	Riesgos tratados	Estado	Evidencia o plan
8.34	Protección de los sistemas de información durante las pruebas de auditoría	Sí	Auditar sin afectar producción	—	Implementado	Ruleset descargado en solo lectura; restauraciones en base de verificación; restore.js se niega a escribir en producción

9. Políticas y procedimientos

Los seis documentos que exige la guía están adaptados a esta infraestructura. Cada uno tiene versión 1.0 del 2026-10-24, revisión anual o ante cambios significativos y **aprobación de la Dirección pendiente**. El procedimiento de gestión de cambios (PRO-02) está en S2-E3 §10.

9.1 POL-01 · Política de seguridad de la información

Propósito. Proteger la confidencialidad, integridad y disponibilidad de la información de alumnos, apoderados y personal, y de las operaciones académicas y administrativas de CERMAT.

Alcance. El del SGSI (sección 3).

Compromisos.

1. Cumplir la Ley N.° 29733, su reglamento y las condiciones contractuales de los proveedores.
2. Clasificar la información (sección 5.1) y protegerla según su nivel; los datos de menores son siempre Restringidos.
3. Conceder acceso por rol y con mínimo privilegio (POL-02), con MFA obligatorio en las cuentas privilegiadas.
4. Cifrar la información en tránsito (TLS 1.2 o superior; IPsec entre la sede y la nube) y las copias que salgan del sitio.
5. Publicar cambios de seguridad (reglas de Firestore, firewall, VPN) solo después de pasar sus pruebas automáticas, y verificar lo publicado.
6. Mantener respaldos 3-2-1 con al menos una restauración probada al mes por sistema (POL-04).
7. Registrar, clasificar y responder los incidentes (PRO-01), y notificar a los afectados y a la ANPD cuando corresponda.
8. No guardar secretos en repositorios ni documentos.
9. Medir el desempeño del SGSI (sección 13) y mejorar de forma continua.

Responsabilidades. La Dirección aprueba y asigna recursos. El responsable de seguridad mantiene el SGSI. El líder técnico y el encargado de TI implementan los controles. Todo el personal cumple y reporta. El incumplimiento se trata según el reglamento interno.

Controles relacionados: 5.1, 5.2, 5.4, 5.31 y 5.34.

9.2 POL-02 · Política de control de accesos

1. **Identidad única.** Cada persona usa su propia cuenta de Firebase y, si administra servidores, su propio usuario Linux. No se comparten cuentas. Las cuentas de servicio están inventariadas, con propietario (sección 10.4).
2. **Altas por invitación.** Docentes, auxiliares y alumnos se activan con una invitación de un solo uso y con vencimiento. Las reglas de Firestore solo asignan los roles de docente y auxiliar con una invitación vigente (lo cubren 8 pruebas automáticas) y solo vinculan al alumno con su matrícula mediante su propia invitación.
3. **Claim de administrador.** Lo otorga el líder técnico con aprobación de la Dirección. La lista de administradores se revisa cada trimestre.
4. **Bajas.** El mismo día del cese se retiran el claim y el rol, se revocan las sesiones activas y las llaves SSH, y se deja registro.
5. **MFA obligatorio** en Google (consola de Firebase y Google Cloud), GitHub, Vercel, el panel de RackNerd y el de Punto.pe; TOTP en Proxmox, OPNsense y Wazuh.
6. **SSH** solo con llaves ed25519, sin root ni contraseñas. Una vez validada la VPN, solo desde el bastión (reglas UFW-08 y UFW-09).
7. **Bases de datos** con cuentas de mínimo privilegio: `cermat_api` sin `INSERT`, `UPDATE` ni `DELETE` directos; `cermat_respaldo` de solo lectura; usuario de PostgreSQL sin superusuario. Las cuentas root y postgres se usan solo en mantenimientos planificados.
8. **Red.** La gestión (VLAN 99) solo se alcanza desde ADMIN_TI y el bastión; los invitados están aislados.
9. **Contraseñas** de al menos 12 caracteres (el mínimo que exige `db-crear-usuarios.js`), únicas y guardadas en un gestor de contraseñas; nunca en código, chats ni documentos.
10. **Revisión trimestral** de accesos, con registro (sección 10.5).

Controles relacionados: 5.15 a 5.18, 8.2, 8.3 y 8.5.

9.3 PRO-01 · Procedimiento de gestión de incidentes

Definiciones. *Evento:* ocurrencia observable relevante para la seguridad. *Incidente:* evento que compromete o puede comprometer la confidencialidad, integridad o disponibilidad. *Brecha de datos personales:* incidente que afecta datos personales.

Roles. Coordinador de incidentes (responsable de seguridad; suplente, el líder técnico), encargado de TI, Dirección (decide la comunicación externa) y proveedores (soporte).

Severidad	Ejemplos	Escalamiento	Contención
S1 · Crítica	Exposición de datos personales; credencial privilegiada comprometida; caída total mayor a 4 h	Dirección en 2 h	4 h
S2 · Alta	Servicio crítico caído por 1 h o más; malware en un servidor	Dirección en 8 h	8 h
S3 · Media	Intento relevante bloqueado; falla parcial	Líder técnico	3 días
S4 · Baja	Falso positivo u observación	Registro	7 días

Etapas.

1. **Detectar y registrar:** fecha, quién detecta, sistema, descripción y evidencia inicial; se asigna un ID (INC-xx).
2. **Evaluar y clasificar** la severidad con la tabla anterior (control 5.25).
3. **Contener:** aislar la VM o la red, deshabilitar la cuenta, revocar la clave, bloquear la IP de origen o publicar la corrección.
4. **Preservar la evidencia:** copiar los registros en solo lectura, calcular su SHA-256 y anotar la cadena de custodia (control 5.28).
5. **Erradicar y recuperar:** restaurar desde un respaldo verificado y rotar los secretos afectados.
6. **Notificar:** a la Dirección; a los titulares afectados y a la ANPD si hay datos personales, conforme al reglamento de la Ley N.° 29733; a los proveedores implicados; a la PNP (DIVINDAT) si hay delito.
7. **Lecciones aprendidas** en 10 días como máximo, con acción correctiva registrada en la sección 13.3.

Contactos (el directorio con datos de contacto se guarda fuera de este documento): Dirección, líder técnico, encargado de TI, soporte de RackNerd, Vercel y Google Cloud, ANPD, PNP-DIVINDAT y Centro Nacional de Seguridad Digital (PCM).

Registro: sección 11.3 y hoja "Incidencias" de s2-e2-plan-resultados-pruebas-red.xlsx.

Controles relacionados: 5.24 a 5.28 y 6.8.

9.4 POL-03 · Política de proveedores y servicios en la nube

Proveedor	Servicio	Datos que trata	Controles exigidos	Plan de salida
Google (Firebase y Google Cloud)	Auth, Firestore y Storage	Personales (Restringida)	MFA del propietario, roles IAM mínimos, reglas probadas y exportación periódica	Exportación de Firestore y de usuarios

Proveedor	Servicio	Datos que trata	Controles exigidos	Plan de salida
Vercel	Hosting de la SPA	Registros de acceso	MFA, variables de entorno fuera del repositorio, plan acorde al uso institucional (SUP-13)	Publicar el build estático en otro hosting
RackNerd	VPS	Datos del colegio (Restringida)	MFA del panel, renovación a tiempo y respaldos fuera del VPS	Reconstrucción con el manual y los respaldos
GitHub	Código y CI	Código y secretos de CI	MFA, repositorio privado, secretos con rol mínimo y escaneo de secretos	Clon local completo
Punto.pe / RCP	Dominio y DNS	Ninguno	Credenciales robustas o MFA; registros CAA, SPF y DMARC	Cambio de servidores DNS
ISP y operador móvil	Internet	Tráfico cifrado	Condiciones del contrato	Segundo enlace

1. La responsabilidad compartida se documenta por servicio: el proveedor protege la infraestructura; CERMAT protege cuentas, configuración y datos.
2. Los datos personales solo se confían a proveedores con condiciones de tratamiento publicadas y con ubicación conocida (dato por confirmar en Firestore, SUP-11).
3. Las copias de los datos pertenecen a CERMAT y se guardan fuera del proveedor (POL-04).
4. Las cuentas en los proveedores son nominativas, con MFA y sin compartir.
5. Los secretos se guardan solo en los almacenes del proveedor (GitHub Secrets, variables de Vercel), nunca en Git.
6. Las cuentas de servicio tienen el rol mínimo (por ejemplo, *Firebase Rules Admin* para el CI) y se rotan cada 90 días o de inmediato si se exponen.
7. Cada año se revisan términos, incidentes y costos de cada proveedor, y se sigue su página de estado.

Controles relacionados: 5.19 a 5.23.

9.5 POL-04 · Política de respaldo y recuperación ante desastres

1. **Regla 3-2-1** para cada conjunto de datos (MySQL, PostgreSQL del colegio, Firestore y usuarios, VM y configuraciones), según el esquema de S1-E2 §11.2.
2. **Integridad:** cada respaldo lleva su SHA-256, como ya hace `backup.js` para MySQL; para PostgreSQL, un archivo `SHA256SUMS`.
3. **Cifrado** de toda copia fuera del sitio: restic, cifrado del cliente en PBS o disco externo cifrado.
4. **Cuentas de solo lectura** para respaldar (`cermat_respaldo`). El VPS no guarda credenciales de la sede: la sede extrae las copias (modelo pull).

5. **Retención:** 7 copias diarias, 4 semanales y 6 mensuales; los datos personales no se conservan más de lo necesario.
6. **Pruebas de restauración** mensuales por sistema, en una base o VM de verificación y nunca sobre producción sin confirmación explícita (`--confirmar-produccion`). El RTO medido se anota en el registro de recuperación.
7. **RTO y RPO** por servicio según la sección 11.4.
8. **Desastres:** la respuesta a pérdida de la sede, del VPS o de los datos de Firestore está en la sección 11.5.
9. **Verificación diaria** del éxito de los trabajos de respaldo, como prevé la rutina diaria del manual del VPS.

Controles relacionados: 8.13, 8.14, 5.29 y 5.30.

9.6 POL-05 · Política de uso aceptable

Alcance: personal, docentes, auxiliares, alumnos y visitantes que usan la red, los equipos o la plataforma de CERMAT.

1. Las cuentas institucionales son personales e intransferibles; no se comparten contraseñas ni códigos de acceso.
2. Los datos de alumnos y apoderados se usan solo con fines académicos y administrativos; no se copian a dispositivos personales ni se envían por canales no institucionales.
3. Se bloquea la sesión al dejar el puesto; los equipos administrativos se bloquean solos a los 5 minutos.
4. No se instala software no autorizado en los equipos administrativos; el antivirus y las actualizaciones se mantienen activos.
5. En la red de invitados se exige uso lícito; se prohíbe escanear, atacar o intentar acceder a otras redes, y se limita el ancho de banda.
6. Correos sospechosos, pérdida de equipos o accesos indebidos se reportan de inmediato al canal de incidentes.
7. **Aviso de monitoreo:** se registran eventos de red y de acceso con fines de seguridad durante 90 días.
8. El incumplimiento se trata según el reglamento interno.

Aceptación: registro de aceptación del personal (firma o aceptación digital), **pendiente**.

Controles relacionados: 5.10, 6.3, 7.7, 8.1 y 8.23.

---

10. Gestión de identidades y accesos

10.1 Principios

Identidad única por persona, acceso por rol con mínimo privilegio, separación entre quien desarrolla y quien aprueba cambios de seguridad, MFA en toda cuenta privilegiada y ningún secreto fuera de un almacén seguro.

10.2 Matriz de accesos por rol

Rol	Plataforma (Firebase)	API y MySQL	VPS y PostgreSQL	Proxmox, OPNsense y Wazuh	Consolas de proveedores	MFA
Visitante o postulante	Contenido público; crear pre-matrícula si hay cupo	—	—	—	—	No aplica
Padre o apoderado	Consulta de asistencia por código	—	—	—	—	No aplica (código de acceso)
Alumno	Su perfil, cursos, recursos y asistencia	—	—	—	—	Recomendado
Docente	Sus grupos, alumnos y asistencia por QR	Sincroniza su propia asistencia	—	—	—	Recomendado
Auxiliar	Escaneo QR y supervisión de asistencia	Sincroniza asistencia como registrador del token	—	—	—	Recomendado
Administrador del sistema (claim admin)	Gestión completa de matrículas, pagos, usuarios y contenido	Sincroniza pagos y matrículas	—	—	—	Obligatorio (se evalúa MFA en Firebase Authentication)
Encargado de TI	—	Mantenimiento con cuenta nominativa	Usuario sudo nominativo	Administrador con TOTP	Panel de RackNerd, si se delega	Obligatorio
Líder técnico	Administrador, si se requiere	Administrador de BD	Usuario sudo nominativo	Administrador con TOTP	Propietario de Firebase, GitHub, Vercel y Punto.pe	Obligatorio
Responsable de respaldos	—	`cermat_respaldo` (solo lectura)	Usuario SFTP de solo lectura	Operador de PBS	—	Obligatorio en PBS
Cuentas de servicio	—	`cermat_api` (SELECT y EXECUTE), `cermat_analitica` y `cermat_reportes`	Usuario de aplicación de PostgreSQL sin superusuario	Agentes Wazuh	CI de GitHub con rol *Firebase Rules Admin*	No aplica (llaves rotadas)

10.3 MFA

Cuenta	Factor recomendado	Estado al 2026-10-24	Acción
Cuenta de Google propietaria del proyecto Firebase	Llave FIDO2 o app de autenticación	No verificado	Activar y registrar (2026-10-31)
GitHub (propietario y colaboradores)	Llave FIDO2 o TOTP	No verificado	Activar y exigirlo en el repositorio
Vercel	TOTP o llave	No verificado	Activar
Panel de RackNerd	TOTP	No verificado	Activar si el panel lo ofrece
Panel de Punto.pe	TOTP o contraseña robusta	No verificado	Activar si el panel lo ofrece
Proxmox, OPNsense y Wazuh	TOTP	Planificado	Al implementar la sede
Administradores de la plataforma (claim admin)	MFA de Firebase Authentication	No implementado	Evaluar la activación de MFA en Firebase Authentication (requiere cambios en la aplicación)

10.4 Manejo seguro de credenciales

Credencial	Dónde se guarda	Rotación	Estado
Contraseñas de las cuentas MySQL	Variables de entorno del servidor; gestor de contraseñas	Cada 6 meses o al cambiar de personal	Implementado en los scripts; los archivos de entorno versionados deben retirarse (NC-03)
Clave de la cuenta de servicio de Firebase	Solo en el servidor que la necesita; en el CI, como secreto de GitHub con rol mínimo	Cada 90 días e **inmediatamente**, por la exposición en copias ZIP	**Rotación pendiente**
Llaves SSH	Una llave ed25519 por persona y por equipo	Anual; revocación inmediata ante pérdida	Por verificar en el VPS
Certificados de la VPN	CA guardada fuera de línea; llaves privadas en cada extremo	Certificados cada 2 años; CA cada 10	Planificado
Tokens de GitHub y Vercel	Almacén del proveedor, con alcance mínimo y vencimiento	Al vencer o ante exposición	Por revisar
Claves Wi-Fi	Gestor de contraseñas	Cada semestre	Planificado

10.5 Revisión de accesos

Cada trimestre, el responsable de seguridad y el líder técnico revisan: administradores con claim, perfiles de docente y auxiliar con su invitación, colaboradores de GitHub, miembros de Vercel, usuarios Linux con sudo, cuentas de MySQL y PostgreSQL, y cuentas de Proxmox, OPNsense y Wazuh. Retiran lo innecesario y dejan registro con fecha. La primera revisión debe incluir los 4 perfiles de docente y auxiliar creados mientras estaba publicada la regla defectuosa (R-02).

10.6 Protección de datos (gobernanza)

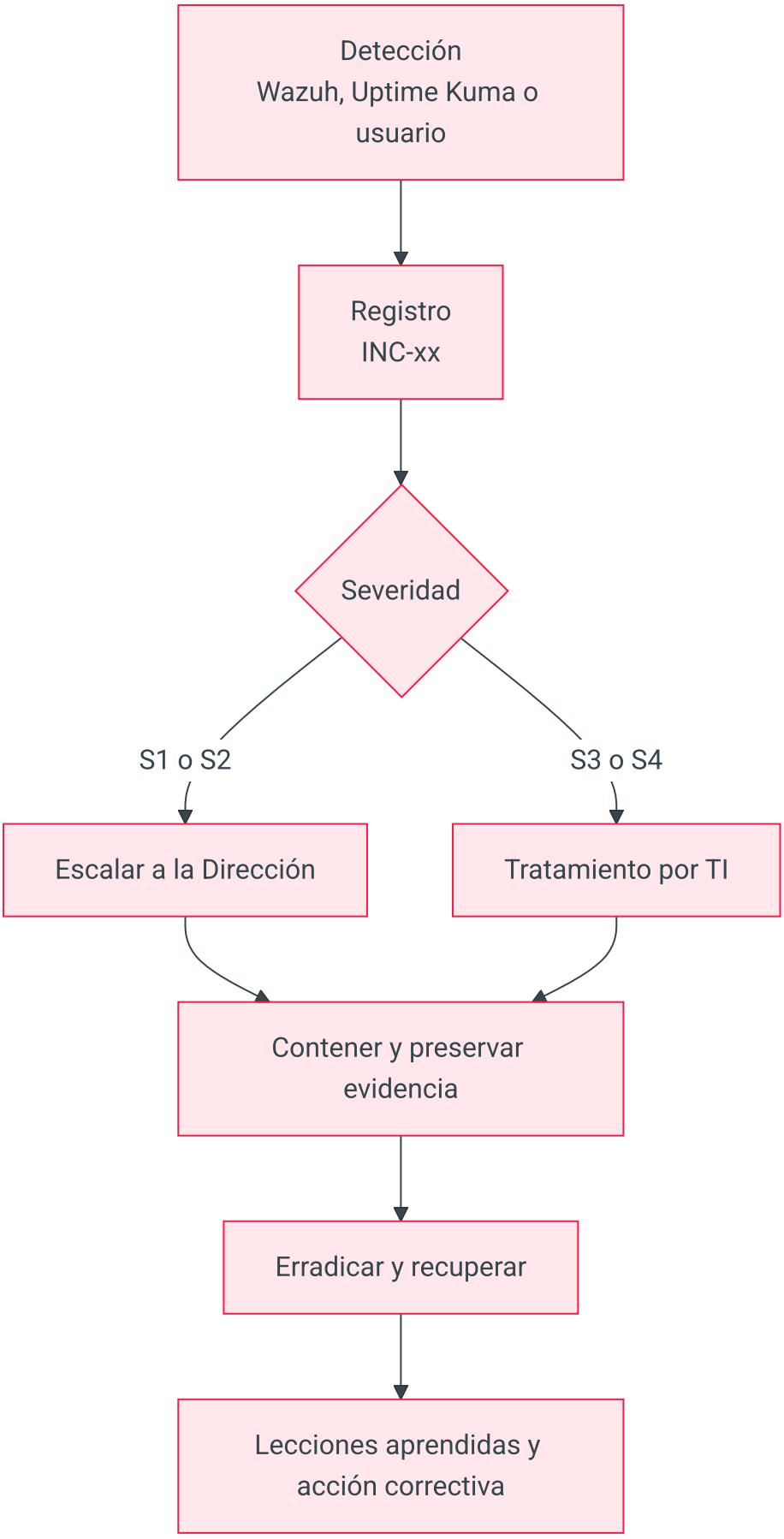
- **Minimización:** los indicadores del proyecto usan conteos agregados; la réplica MySQL guarda solo lo necesario para reportes y auditoría.
- **Datos de prueba ficticios:** `90_datos_prueba.sql` se niega a correr si hay matrículas reales (control 8.33).
- **Retención:** definir con la Dirección el plazo de conservación de los datos de exalumnos (control 8.10).
- **Transferencia internacional:** los datos están en proveedores de EE. UU. (VPS, Vercel y, según su ubicación, Firestore). Se debe cumplir el régimen de flujo transfronterizo de la Ley N.° 29733 (R-24).
- **Derechos de los titulares:** canal para solicitudes de acceso, rectificación, cancelación y oposición, a cargo de la Dirección.

---

11. Gestión de incidentes, continuidad y recuperación

11.1 Roles y escalamiento

Los roles, la clasificación por severidad y el escalamiento se definen en PRO-01 (sección 9.3).



11.2 Clasificación

Ver la tabla de severidades de PRO-01. Los incidentes con datos personales son S1 por defecto hasta que se demuestre lo contrario.

11.3 Registro de incidentes

ID	Detección	Descripción	Clasificación	Severidad	Contención	Causa raíz	Lección aprendida	Estado	Vínculo SGSI
INC-01	2026-10-24	Reglas de Firestore publicadas el 22-jun-2026 con 3 fallas: listado público de matrículas pagadas, auto-asignación de rol y matrícula pública bloqueada	Incidente de seguridad: exposición potencial de datos personales y escalamiento de privilegios	S1 (alta)	Corrección con 19 pruebas; frontend y reglas publicados el 2026-10-24 y verificados como visitante sin sesión (listar matrículas pagadas → 403)	Una línea inválida impedía compilar y nadie verificaba el despliegue	Publicar solo por CI y verificar el ruleset publicado	Cerrado (2026-10-24)	R-01 a R-04; NC-01 y NC-02
INC-02	2026-10-24	Clave de cuenta de servicio y archivos de entorno en el repositorio privado (copias ZIP y archivos versionados)	Incidente de seguridad: credencial expuesta	S1 (alta)	Clave de enero (`283b43c3…`) eliminada y reemplazada por `ddf50bfe…`; contraseñas de las cuentas de `teachers.json` restablecidas; los `.env` (sin contraseñas) siguen versionados por decisión del equipo	Copias del proyecto subidas con secretos; control preventivo ausente	Escaneo de secretos en el CI y lista de revisión de cambios	Cerrado con riesgo residual aceptado (2026-10-24)	R-05 y R-06; NC-03

ID	Detección	Descripción	Clasificación	Severidad	Contención	Causa raíz	Lección aprendida	Estado	Vínculo SGSI
INC-03	2026-10-24	El antivirus puso en cuarentena scripts SQL al ejecutarlos desde PowerShell con cmd (IDP.Generic)	Evento de seguridad: falso positivo	S4 (baja)	Restaurar desde cuarentena, ejecutar desde Git Bash y exclusión acotada	Heurística del antivirus ante la cadena PowerShell → cmd	Procedimiento documentado en server/src/db/README.md	Cerrado	R-22
INC-04	2026-10-24	Sitio del colegio sin cabeceras de seguridad y con la versión de Nginx expuesta; SPA de la academia solo con HSTS	Observación de seguridad (no es incidente)	S4 (baja)	No requiere	Configuración por defecto	Academia: cabeceras publicadas con `vercel.json` y verificadas el 2026-10-24. Colegio: plantilla de Nginx de S2-E2 §4.3	Cerrado para la academia; abierto para el colegio	R-13
INC-05	2026-10-24	Dominio sin SPF, DMARC, CAA ni DNSSEC	Observación de seguridad (no es incidente)	S3 (media)	No requiere	Configuración DNS inicial sin controles de correo	Lista de verificación de dominio	Abierto	R-11 y R-14

11.4 Servicios críticos, RTO y RPO

Servicio	Ubicación	Criticidad	RTO objetivo	RPO objetivo	Mecanismo de recuperación	Validación (S2)
Plataforma web (SPA)	Vercel	Crítica	15 min	0 (código en Git)	Promover el despliegue anterior en Vercel o revertir el commit	REC-10
Identidad (Firebase Auth)	Firebase	Crítica	Según el proveedor	Según el proveedor	Exportación semanal de usuarios (firebase auth:export), cifrada	REC-11

Servicio	Ubicación	Criticidad	RTO objetivo	RPO objetivo	Mecanismo de recuperación	Validación (S2)
Datos operativos (Firestore)	Firebase	Crítica	4 h	24 h	Exportación diaria programada y restauración en un proyecto de prueba	REC-11
API de sincronización y MySQL	VM-APP01 (hoy PC local)	Alta	1 h	24 h	backup.js diario y restore.js; resincronización desde Firestore	REC-01 a REC-05
Analítica	VM-APP01	Baja	24 h	24 h	Redespliegue desde Git	REC-07
Sistema del colegio (web, API y PostgreSQL)	VPS	Alta	8 h (reconstrucción completa); 2 h (solo base)	24 h	pg_dump -Fc diario con SHA256SUMS y copia en la sede	REC-06, REC-08
VPN sitio a sitio	OPNsense ↔ VPS	Media	1 h (reconexión automática ≤ 2 min)	No aplica	DPD y reintento; configuración versionada	REC-09
Firewall perimetral	VM-FW01	Crítica para la sede	2 h	Último config.xml	Restaurar config.xml en una VM nueva; contingencia con el router del ISP	REC-12
SIEM (Wazuh)	VM-SIEM01	Media	24 h	24 h	Restaurar la VM desde PBS	REC-07
Monitoreo (Uptime Kuma y Netdata)	VM-MON01	Media	8 h	24 h	Restaurar la VM desde PBS	REC-07

11.5 Continuidad ante escenarios de desastre

Escenario	Respuesta	Objetivo
Pérdida de la sede (falla del host, incendio o corte prolongado)	La operación sigue en la nube; Internet de contingencia por el router del ISP o 4G; restauración de las VM desde PBS o el disco externo en hardware de reemplazo	Matrícula y pagos sin interrupción; servicios locales en ≤ 24 h
Pérdida del VPS	Reconstrucción con el manual y el último `pg_dump` guardado en la sede	≤ 8 h (REC-08)
Pérdida o corrupción de datos de Firestore	Importación de la última exportación en un proyecto de verificación y luego en producción	RTO 4 h; RPO 24 h (REC-11)

Escenario	Respuesta	Objetivo
Credencial privilegiada comprometida	PRO-01 (S1): revocar, rotar, revisar registros de auditoría y notificar	Contención en ≤ 4 h
Ransomware en equipos de la sede	Aislar la VLAN, reinstalar y restaurar desde una copia fuera de línea	Según el sistema afectado

12. Ética de la seguridad de la información

12.1 Código de conducta

Principio ACM	Compromiso del equipo
1.2 Evitar daño	Las pruebas que pueden afectar la operación se hacen en el emulador, en bases de prueba o en laboratorio
1.3 Ser honesto y confiable	Lo no ejecutado se reporta como pendiente; las cifras estimadas se rotulan como supuestos
1.6 Respetar la privacidad	Los indicadores usan conteos agregados; no se consultan registros personales innecesarios
1.7 Honrar la confidencialidad	Sin secretos, IP públicas ni datos personales en la documentación
2.5 Evaluar riesgos de forma exhaustiva	Riesgos evaluados con ISO/IEC 27005 y tratados con responsable y plazo
2.8 Acceder solo con autorización	Pruebas solo sobre sistemas de CERMAT, con autorización escrita
2.9 Diseñar sistemas robustos y seguros	Defensa en profundidad y mínimo privilegio en todo el diseño

12.2 Alcance ético de las pruebas

Permitido	No permitido
Pruebas de reglas en el emulador de Firestore y pruebas SQL en bases de prueba con datos ficticios	Probar reglas o escrituras contra datos reales de producción
Descargar en solo lectura el ruleset publicado para auditarlo	Modificar producción durante una auditoría
Consultas HTTP, TLS y DNS no intrusivas sobre los dominios propios, como las del 2026-10-24	Escanear puertos o ejecutar ataques contra sistemas de terceros
Pruebas de segmentación, IDS y honeypot en la red de la sede con autorización y ventana acordada	Usar las credenciales capturadas por el honeypot fuera del análisis de seguridad
Restaurar respaldos en bases o VM de verificación	Restaurar sobre producción sin confirmación explícita

12.3 Consentimiento y autorización

Antes de las pruebas de segmentación, detección y recuperación de S2-E2 y S2-E3, la Dirección de la academia (para la sede y la plataforma) y la del colegio (para el VPS) deben firmar una **autorización de pruebas de seguridad**. Esa autorización debe indicar:

- Sistemas y redes incluidos y excluidos.
- Ventanas horarias.
- Pruebas permitidas (PR-14 a PR-37 y REC-05 a REC-12).
- Responsables.
- Criterio para detener una prueba si afecta la operación.
- Tratamiento de los datos capturados.

Estado: pendiente de firma. Las verificaciones del 2026-10-24 se limitaron a consultas públicas no intrusivas sobre dominios propios.

12.4 Confidencialidad y protección de datos

Los integrantes tratan como Restringidos los datos personales, las credenciales y los hallazgos aún no corregidos. Los registros del honeypot contienen IP de origen, que pueden ser datos personales, y se usan solo con fines de seguridad durante 90 días.

12.5 Divulgación responsable

1. Los hallazgos de secretos se documentan **sin rutas exactas** hasta que la credencial se rote.
2. El repositorio de esta documentación es **público**. Las fallas de reglas descritas aquí y en el E4 de Ingeniería de Software siguen activas en producción, así que **las reglas corregidas deben publicarse antes de difundir el sitio actualizado**.
3. Las vulnerabilidades que se encuentren en productos de terceros se reportan primero al fabricante.
4. Las observaciones sobre el sistema del colegio (cabeceras y DNS) se comunican a su Dirección junto con el plan de corrección.

12.6 Conflictos de interés

El líder técnico es autor de ambos sistemas y administrador del VPS. Para que no audite ni apruebe solo su propio trabajo: los cambios de seguridad requieren la revisión de un segundo integrante; la Dirección aprueba la aceptación de riesgos; y la auditoría interna siguiente la conduce otro integrante, con revisión independiente del jurado (control 5.35).

12.7 Declaración de ética de seguridad

> **Declaración de ética de seguridad de la información — Equipo CERMAT, EPE 2026-2**
>
> Los integrantes del equipo declaramos que:
>
> 1. Realizamos y realizaremos pruebas de seguridad solo sobre sistemas de CERMAT, dentro del alcance autorizado por escrito por la Dirección, y en entornos de prueba cuando el ensayo pueda afectar la operación.
> 2. No accedemos a datos personales reales más allá de lo necesario; para los indicadores usamos conteos agregados.
> 3. Mantenemos la confidencialidad de credenciales, configuraciones y hallazgos; no publicamos secretos, IP públicas ni datos personales.
> 4. Reportamos de inmediato toda vulnerabilidad o incidente al responsable de seguridad y a la Dirección, y lo divulgamos de forma responsable después de corregirlo o mitigarlo.
> 5. No usamos el acceso privilegiado para fines distintos de los asignados y declaramos cualquier conflicto de interés.
> 6. Presentamos resultados veraces: lo no ejecutado se reporta como pendiente.

Integrante	Firma	Fecha
David Robert Yucra Mamani	Pendiente de firma	—
Gladys Rosaura Yana Pari	Pendiente de firma	—
Denilson Leeke Mamani Flores	Pendiente de firma	—
Cárdenas Vilca Rennzo	Pendiente de firma	—

Coherencia con el comportamiento observado

Compromiso	Evidencia observable
Pruebas en entornos controlados	19 pruebas de reglas en el emulador; base `cermat_prueba` con datos ficticios
Auditar sin afectar producción	Ruleset descargado en solo lectura; `restore.js` se niega a escribir en producción
Datos mínimos	Indicadores de uso con conteos agregados
Sin secretos	Documentación sin IP públicas, correos ni contraseñas; secretos reportados sin rutas exactas
Veracidad	Pendientes rotulados en todos los entregables
Verificación no intrusiva	Solo consultas HTTP, TLS y DNS a dominios propios el 2026-10-24; sin escaneo de puertos

13. Evaluación del desempeño del SGSI

13.1 Métricas e indicadores

ID	Indicador	Fórmula	Meta	Valor al 2026-10-24	Fuente	Frecuencia
KPI-01	Fallas de reglas en producción	Pruebas de la suite que fallan contra el ruleset publicado	0	0 fallas observadas en producción tras publicar la versión corregida (verificación como visitante sin sesión del 2026-10-24); con las reglas de junio: 10 de 19	Suite de reglas y consultas sin sesión	Cada cambio y mensual
KPI-02	Publicaciones con pruebas en verde	Despliegues con CI en verde / despliegues	100 %	90 de 90 pruebas en local; CI en GitHub sin primera ejecución	GitHub Actions	Cada cambio
KPI-03	Cuentas privilegiadas con MFA	Con MFA / privilegiadas	100 %	No verificado	Revisión de cuentas	Trimestral
KPI-04	Secretos en repositorios	Hallazgos de escaneo de secretos	0	0 secretos vigentes: la clave de los ZIP fue revocada y las contraseñas de `teachers.json` restablecidas (2026-10-24); escaneo con gitleaks pendiente	gitleaks	Cada cambio
KPI-05	Restauraciones verificadas	Pruebas exitosas por sistema y mes	≥ 1	MySQL: 3 (2 en la base de prueba y 1 en la base real, REC-05 del 2026-10-24); PostgreSQL, Firestore y VM: 0	Registro de recuperación	Mensual
KPI-06	RTO medido de MySQL	Tiempo de `restore.js`	< 1 h	0,23 s en la base real (REC-05); 0,27–0,38 s en la base de prueba	`restore.js`	Mensual

ID	Indicador	Fórmula	Meta	Valor al 2026-10-24	Fuente	Frecuencia
KPI-07	Disponibilidad de servicios públicos	Tiempo en línea / total	≥ 99 %	No medida	Uptime Kuma	Mensual
KPI-08	Tiempo de detección de caídas	Minutos hasta la alerta	≤ 5	No medido	Uptime Kuma	Por evento
KPI-09	Incidentes S1 y S2 contenidos en plazo	Contenidos a tiempo / total	100 %	INC-01 e INC-02 cerrados el día de la detección (2026-10-24); la contención superó el objetivo de 4 h porque la publicación de las reglas esperó el despliegue del frontend	Registro de incidentes	Mensual
KPI-10	Controles aplicables implementados	Implementados / aplicables	≥ 60 % al cierre de la fase 2	9 de 92, más 46 parciales	SoA	Trimestral
KPI-11	Riesgos críticos abiertos	Riesgos con nivel ≥ 15 sin tratar	0	4 (R-04, R-07, R-11 y R-12); R-01 a R-03 tratados el 2026-10-24	Matriz de riesgos	Mensual
KPI-12	Sitios con TLS ≥ 1.2 y HSTS	Sitios conformes / sitios	4 de 4	TLS: 4 de 4; HSTS: 1 de 4	`curl` y `openssl` (PR-06, PR-10, PR-13)	Trimestral

13.2 Auditoría interna del 2026-10-24

Aspecto	Detalle
Objetivo	Verificar el estado de los controles en la parte implementada (nube, capa de datos y repositorio) y su conformidad con ISO/IEC 27001:2022 en lo aplicable
Alcance	VPS del colegio, Vercel, reglas de Firestore, repositorio y capa local de la academia. La sede on-premise no se auditó porque no está implementada
Criterios	Controles del Anexo A seleccionados (5.15, 5.17, 8.3, 8.5, 8.9, 8.12, 8.13, 8.16, 8.21, 8.29 y 8.32); lista de verificación del E4 §4.4; manual del propietario del VPS

Aspecto	Detalle
Método	Revisión documental; suite de reglas contra el ruleset publicado, descargado en solo lectura; revisión del índice de Git sin abrir el contenido de los secretos; consultas externas no intrusivas (HTTP, TLS y DNS) sobre los dominios propios
Equipo auditor	Equipo del proyecto. **Limitación:** no es independiente; se compensa con la revisión del jurado (control 5.35)

Hallazgos

ID	Hallazgo	Evidencia	Control	Tipo	NC
H-01	Tres fallas activas en las reglas publicadas el 22-jun-2026: listado sin sesión de matrículas pagadas, auto-asignación de rol y matrícula pública bloqueada (corregido en producción el 2026-10-24)	10 de 19 pruebas fallan contra el ruleset publicado	5.15, 8.3, 8.29	No conformidad mayor	NC-01
H-02	Las correcciones de reglas no se publican desde junio: la línea 1 (`#`) impedía compilar y nadie verificaba el despliegue (corregido el 2026-10-24)	Error del emulador `token recognition error at: '#'`	8.32, 8.9	No conformidad mayor	NC-02
H-03	Secretos en el repositorio privado: clave de cuenta de servicio en copias ZIP versionadas y archivos de entorno versionados (corregido el 2026-10-24: clave revocada y contraseñas restablecidas)	Revisión del índice de Git, sin abrir los secretos	5.17, 8.12, 8.4	No conformidad mayor	NC-03
H-04	Respaldos del VPS diseñados y no implantados; sin prueba de restauración	Manual del propietario	8.13, 5.30	No conformidad mayor	NC-04

ID	Hallazgo	Evidencia	Control	Tipo	NC
H-05	Capacidad del VPS (2 GB) no validada para carga real; sin línea base	Manual del propietario	8.6	Observación	—
H-06	Sin monitor externo ni alertas de disponibilidad	E4 §2.4	8.16	No conformidad menor	NC-05
H-07	Firestore sin respaldo programado	E4 §2.5	8.13	No conformidad mayor	NC-06
H-08	MFA de cuentas privilegiadas no verificado; dominio sin SPF ni DMARC	Verificación DNS del 2026-10-24 (PR-12)	5.17, 8.5, 5.14	No conformidad menor	NC-07
H-09	Sin cabeceras de seguridad, con la versión de Nginx expuesta y sin CAA ni DNSSEC	Verificación externa del 2026-10-24 (PR-10, PR-12)	8.21, 8.9	Observación	—
H-10	Cambios sin revisión de un segundo integrante; un solo autor y mensajes de commit genéricos	Historial de Git; plantilla de PR sin uso registrado	5.3, 8.32, 8.25	No conformidad menor	NC-08
H-11	Falso positivo del antivirus al ejecutar scripts SQL desde PowerShell	Cuarentena registrada; procedimiento en `server/src/db/README.md`	8.7, 5.37	Observación cerrada con procedimiento	—

Fortalezas

ID	Fortaleza	Evidencia
F-01	Cuentas MySQL de mínimo privilegio	`cermat_api` recibe el error 1142 ante DML directo, verificado también en la base real (2026-10-24)
F-02	Pruebas automáticas que detectan fallas reales	90 pruebas; la suite de reglas reveló las 3 fallas de producción
F-03	Cifrado en tránsito correcto en todos los sitios	TLS 1.0 y 1.1 rechazados; TLS 1.2 y 1.3 con AEAD; redirección a HTTPS (PR-03 a PR-07, PR-13)
F-04	Base del colegio no expuesta	PostgreSQL solo en loopback y usuario sin superusuario

ID	Fortaleza	Evidencia
F-05	Recuperación verificable	Restauración con SHA-256 y RTO medido (REC-01 a REC-05; en la base real, 0,23 s)
F-06	Operación documentada	Procedimientos diarios, semanales y mensuales del manual del VPS

13.3 No conformidades y acciones correctivas

NC	Hallazgo	Corrección inmediata	Causa raíz	Acción correctiva	Responsable	Plazo	Verificación de eficacia	Estado
NC-01	H-01	Publicar las reglas corregidas	Reglas publicadas sin pruebas y despliegue fallido sin detección	Suite de 19 pruebas obligatoria en el CI	Líder técnico	2026-10-31	Suite contra el ruleset publicado: 19/19	Cerrada (2026-10-24): reglas publicadas desde la consola y verificadas como visitante sin sesión (matrículas pagadas → 403; pre-matrícula de prueba exitosa)
NC-02	H-02	Línea 1 corregida en código	Despliegue manual sin verificación posterior	Publicación automática solo por CI; alerta si falla; comparación mensual del ruleset	Líder técnico	2026-11-07	Ruleset publicado igual al del repositorio	Cerrada (2026-10-24): versión corregida publicada; la publicación automática por CI sigue en R-04 (falta el secreto)

NC	Hallazgo	Corrección inmediata	Causa raíz	Acción correctiva	Responsable	Plazo	Verificación de eficacia	Estado
NC-03	H-03	Retirar las copias y rotar la clave	Sin control preventivo de secretos	Escaneo de secretos (gitleaks) en el CI, plantilla de PR y `.gitignore`	Líder técnico	Rotación 2026-10-26; CI 2026-11-07	Clave anterior revocada; escaneo sin hallazgos	Cerrada con riesgo residual aceptado (2026-10-24): clave `283b43c3` … revocada, contraseñas de `teachers.json` restablecidas; los `.env`, sin contraseñas, siguen versionados por decisión del equipo; escaneo en el CI pendiente
NC-04	H-04	Copia manual inmediata con `pg_dump`	Se priorizó el despliegue sobre la operación	Respaldos automáticos y restauración mensual	Líder técnico	2026-11-07	REC-06 conforme	Abierta
NC-05	H-06	—	No había herramienta de monitoreo	Uptime Kuma con latido externo	Encargado de TI	2026-11-14	PR-33 conforme	Abierta
NC-06	H-07	Exportación manual inicial	Confianza exclusiva en la durabilidad del proveedor	Exportación programada y prueba de restauración	Líder técnico	2026-11-21	REC-11 conforme	Abierta
NC-07	H-08	Activar MFA en las cuentas	Configuración por defecto de las cuentas	Revisión trimestral de MFA; SPF, DKIM y DMARC	Dirección y líder técnico	2026-10-31	KPI-03 = 100 %; PR-12 conforme	Abierta
NC-08	H-10	—	Equipo pequeño sin flujo de revisión	Revisión obligatoria por un segundo integrante	Líder técnico	Desde el Sprint 2	100 % de los cambios revisados	Abierta

13.4 Revisión por la dirección

Entrada (ISO/IEC 27001:2022, 9.3)	Contenido preparado
a) Estado de las acciones de revisiones anteriores	Primera revisión: no hay acciones previas
b) Cambios en cuestiones externas e internas	Reglamento de la Ley N.° 29733; VPS del colegio en producción desde el 2026-10-17
c) Cambios en necesidades de las partes interesadas	Enlace del sitio del colegio hacia la plataforma de la academia
d) Desempeño: no conformidades, seguimiento, auditoría y objetivos	Secciones 13.1 a 13.3
e) Retroalimentación de partes interesadas	Pendiente de recoger de la Dirección y del personal
f) Resultados de la evaluación de riesgos y del plan de tratamiento	Secciones 6 y 7
g) Oportunidades de mejora	Sección 13.5
Salidas esperadas	Aprobar POL-01 a POL-05; designar roles; aceptar los riesgos residuales medios; decidir el presupuesto del hardware

Fecha propuesta: semana del 2026-11-23. **Resultado obtenido: pendiente de ejecución. Evidencia a adjuntar:** acta firmada por la Dirección con las decisiones tomadas.

13.5 Mejora continua

- Revisión mensual de los indicadores KPI-01 a KPI-12.
- Seguimiento quincenal de NC-04 a NC-08 hasta su cierre (NC-01 a NC-03 se cerraron el 2026-10-24).
- Auditoría interna semestral; la próxima, en 2027-I, incluirá la sede si ya está implementada y la conducirá un integrante distinto del líder técnico.
- Actualización de la matriz de riesgos ante cada incidente o cambio significativo.

14. Conclusiones y matriz maestra de trazabilidad

14.1 Conclusiones

1. El SGSI está establecido con contexto, alcance, 33 activos valorados, 29 riesgos evaluados, una SoA de 93 controles y seis políticas y procedimientos propios.
2. La auditoría interna encontró fallas reales y activas (reglas, secretos y respaldos). El SGSI las convierte en no conformidades con causa raíz, responsable, plazo y verificación de eficacia.
3. 9 de los 92 controles aplicables están implementados y 46 parcialmente. El avance depende de cerrar NC-04 a NC-08 (NC-01 a NC-03 se cerraron el 2026-10-24) y de implementar la sede (fase 2).
4. El alcance ético de las pruebas ya se practica; falta firmar la declaración y obtener la autorización escrita de la Dirección.

14.2 Matriz maestra de trazabilidad (riesgo → control → evidencia)

Riesgo	Descripción	Nivel inicial	Controles (SoA)	Política o procedimiento	Evidencia	Verificación	Nivel residual	Estado
R-01	Recolección no autorizada de datos personales	20 (Crítico)	5.15, 8.3, 5.34, 8.29, 8.32	POL-02, PRO-02	tests/firestore-rules/reglas.test.ts: 19/19 con las reglas corregidas; 10 fallaban con las de junio. Producción: listar matrículas pagadas sin sesión → 403 (2026-10-24)	Suite de reglas contra el ruleset publicado (KPI-01 = 0)	4 (Bajo)	Tratado (2026-10-24)
R-02	Escalamiento de privilegios por un usuario registrado	16 (Crítico)	5.15, 5.18, 8.2, 8.29	POL-02	Grupo de 8 pruebas de roles en la suite de reglas; reglas publicadas el 2026-10-24	Revisión de perfiles y KPI-01	4 (Bajo)	Tratado (2026-10-24); falta revisar los 4 perfiles existentes
R-03	Interrupción de la matrícula pública	15 (Crítico)	8.32, 8.29, 5.30	PRO-02	Grupo de 6 pruebas de matrícula pública con el código real de la app; pre-matrícula de prueba exitosa en producción (2026-10-24)	Matrícula de prueba sin sesión en producción	3 (Bajo)	Tratado (2026-10-24)
R-04	Cambios de seguridad que no llegan a producción	16 (Crítico)	8.32, 8.9, 8.25	PRO-02	.github/workflows/ci.yml (trabajo desplegar-reglas condicionado)	Primera ejecución del CI en GitHub; comparación mensual	4 (Bajo)	En curso (reglas publicadas desde la consola; falta el secreto del CI)

Riesgo	Descripción	Nivel inicial	Controles (SoA)	Política o procedimiento	Evidencia	Verificación	Nivel residual	Estado
R-05	Uso indebido de una credencial de administrador del proyecto Firebase	10 (Alto)	5.17, 8.12, 8.4, 5.26	POL-02, PRO-01	Clave `283b43c3…` eliminada y reemplazada por `ddf50bfe…` (INC-02); fuera de la lista pública de claves de Google	Clave anterior revocada en IAM; gitleaks sin hallazgos (KPI-04)	5 (Medio)	Tratado (2026-10-24); falta el escaneo de secretos en el CI
R-06	Acceso no autorizado a MySQL	6 (Medio)	5.17, 8.12	POL-02	server/scripts/db-crear-usuarios.js (contraseñas por variables de entorno); `.env` versionados sin contraseñas	Ninguna contraseña en `.env` versionados (KPI-04)	3 (Bajo)	Tratado con riesgo aceptado (2026-10-24)
R-07	Pérdida de datos del colegio (falla del VPS, error humano o ransomware)	15 (Crítico)	8.13, 5.30, 8.14	POL-04	Procedimiento diseñado en el manual del VPS	REC-06 conforme	6 (Medio)	Pendiente
R-08	Agotamiento de memoria del VPS	9 (Medio)	8.6, 8.16	POL-03	Presupuesto de RAM (S1-E2 §10)	Línea base con free -m; alerta de MemAvailable	6 (Medio)	Pendiente
R-09	Indisponibilidad no detectada	12 (Alto)	8.16, 5.24	PRO-01	/health de la API y panel admin Infraestructura	PR-33 (alerta ≤ 2 min); KPI-07 y KPI-08	8 (Medio)	Pendiente
R-10	Pérdida de datos operativos	10 (Alto)	8.13, 5.23	POL-04	Brecha registrada en E4 §2.5	REC-11	4 (Bajo)	Pendiente

Riesgo	Descripción	Nivel inicial	Controles (SoA)	Política o procedimiento	Evidencia	Verificación	Nivel residual	Estado
R-11	Toma de cuentas administrativas por phishing	15 (Crítico)	5.17, 8.5, 6.3, 5.14	POL-02, POL-05	PR-12 (sin SPF ni DMARC)	KPI-03 = 100 %; PR-12 conforme	5 (Medio)	Pendiente
R-12	Acceso no autorizado por SSH	15 (Crítico)	8.5, 8.20, 8.2	POL-02	UFW activo (PR-01)	PR-28; sshd -T	5 (Medio)	Pendiente
R-13	Reconocimiento y ataques del lado del cliente	6 (Medio)	8.21, 8.9	POL-01	PR-10	PR-10 conforme	2 (Bajo)	Pendiente
R-14	Emisión indebida de certificados o suplantación DNS	6 (Medio)	8.21, 8.24	POL-03	PR-12	PR-12 conforme	3 (Bajo)	Pendiente
R-15	Movimiento lateral desde la red local	12 (Alto)	8.22, 8.20	POL-01	Diseño S1-E1 §8 a §13	PR-14 a PR-23	4 (Bajo)	Planificado
R-16	Intrusión no detectada	12 (Alto)	8.16, 8.15, 5.7	PRO-01	Diseño S1-E1 §14	PR-30 a PR-32 y PR-37	6 (Medio)	Planificado
R-17	Cortes eléctricos	12 (Alto)	7.11, 8.14	POL-04	Diseño S1-E2 §5	Prueba de apagado ordenado con NUT	4 (Bajo)	Planificado
R-18	Falla del host único	8 (Medio)	8.14, 8.13	POL-04	Diseño S1-E2 §6 y §11	REC-07	6 (Medio)	Planificado (aceptación pendiente)
R-19	Caída del enlace de Internet de la sede	9 (Medio)	8.14, 5.30	POL-04	Diseño S1-E1 §7	PR-29	3 (Bajo)	Planificado
R-20	Interrupción del túnel	6 (Medio)	8.14, 8.16	POL-04	Diseño S1-E1 §10	REC-09	3 (Bajo)	Planificado
R-21	Ransomware o malware	12 (Alto)	8.7, 8.1, 6.3, 8.13	POL-05	Antivirus activo en la PC local	Revisión trimestral de equipos	6 (Medio)	Planificado

Riesgo	Descripción	Nivel inicial	Controles (SoA)	Política o procedimiento	Evidencia	Verificación	Nivel residual	Estado
R-22	Interrupción de tareas por un falso positivo del antivirus	6 (Medio)	8.7, 5.37	PRO-01	server/src/db/README.md	Sin nuevas cuarentenas al ejecutar desde Git Bash	2 (Bajo)	Implementado
R-23	Pérdida de capacidad operativa por concentración de conocimiento y accesos	12 (Alto)	5.2, 5.3, 5.37	POL-01	Matriz RACI (§4.2)	Segundo integrante con accesos nominativos; 100 % de cambios revisados	6 (Medio)	Pendiente
R-24	Sanción o reclamo por incumplimiento normativo	12 (Alto)	5.31, 5.34, 5.20	POL-01	Clasificación de activos (§5)	Constancia de inscripción y aviso de privacidad publicado	4 (Bajo)	Pendiente
R-25	Uso del honeypot como plataforma de ataque	6 (Medio)	8.22, 8.20	POL-01	Regla FW-41 (diseño)	PR-16 (DMZ → DB bloqueado)	3 (Bajo)	Planificado
R-26	Acceso físico no autorizado	8 (Medio)	7.1, 7.2, 7.4	POL-01	Diseño de rack (S1-E2 §5)	Bitácora de acceso	4 (Bajo)	Planificado
R-27	Pérdida de los respaldos de MySQL junto con la base	12 (Alto)	8.13	POL-04	server/scripts/backup.js	REC-05; copias en 3 ubicaciones	3 (Bajo)	Pendiente
R-28	Réplica relacional incompleta	8 (Medio)	8.14, 8.16	POL-04	Vista v_conciliacion_pagos	Conciliación con 0 filas	4 (Bajo)	Planificado
R-29	Dependencia de proveedores	8 (Medio)	5.19, 5.22, 5.23	POL-03	Inventario de proveedores (§9.4)	Revisión anual de proveedores	6 (Medio)	Aceptación pendiente

Anexos

Anexo	Contenido	Ubicación
A	Inventario de activos con criterios C-I-D	s2-e1-inventario-activos.xlsx
B	Criterios, evaluación y tratamiento de riesgos	s2-e1-matriz-riesgos.xlsx
C	Declaración de Aplicabilidad, resumen y trazabilidad	s2-e1-declaracion-aplicabilidad.xlsx
D	Registro de incidentes	Sección 11.3 y s2-e2-plan-resultados-pruebas-red.xlsx
E	Evidencia de las verificaciones externas del 2026-10-24	S2-E2, Anexo B
F	Registro de pruebas de recuperación	s2-e3-registro-prueba-recuperacion.xlsx
G	Autorización de pruebas y acta de revisión por la dirección	Pendientes de firma

Referencias

[1] ISO/IEC 27001:2022, *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. Ginebra, Suiza: ISO, 2022.

[2] ISO/IEC 27002:2022, *Information security, cybersecurity and privacy protection — Information security controls*. Ginebra, Suiza: ISO, 2022.

[3] ISO/IEC 27005:2022, *Information security, cybersecurity and privacy protection — Guidance on managing information security risks*. Ginebra, Suiza: ISO, 2022.

[4] National Institute of Standards and Technology, "The NIST Cybersecurity Framework (CSF) 2.0," NIST CSWP 29, feb. 2024.

[5] A. Nelson, S. Rekhi, M. Souppaya y K. Scarfone, "Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile," NIST SP 800-61 Rev. 3, abr. 2025.

[6] M. Swanson, P. Bowen, A. W. Phillips, D. Gallup y D. Lynes, "Contingency Planning Guide for Federal Information Systems," NIST SP 800-34 Rev. 1, may. 2010.

[7] R. Kissel, A. Regenscheid, M. Scholl y K. Stine, "Guidelines for Media Sanitization," NIST SP 800-88 Rev. 1, dic. 2014.

[8] Congreso de la República del Perú, "Ley N.° 29733, Ley de Protección de Datos Personales," *Diario Oficial El Peruano*, jul. 2011.

[9] Ministerio de Justicia y Derechos Humanos, "Decreto Supremo N.° 016-2024-JUS que aprueba el Reglamento de la Ley N.° 29733," *Diario Oficial El Peruano*, nov. 2024.

[10] Association for Computing Machinery, "ACM Code of Ethics and Professional Conduct," 2018. [En línea]. Disponible en: https://www.acm.org/code-of-ethics

[11] M. Kucherawy y E. Zwicky, "Domain-based Message Authentication, Reporting, and Conformance (DMARC)," RFC 7489, IETF, mar. 2015.

[12] S. Kitterman, "Sender Policy Framework (SPF) for Authorizing Use of Domains in Email, Version 1," RFC 7208, IETF, abr. 2014.

Rúbrica de evaluación

N°	Criterio de evaluación	Peso
1	Contexto, alcance y liderazgo del SGSI	10%
2	Inventario de activos y clasificación de información	10%
3	Evaluación y tratamiento de riesgos (ISO/IEC 27005)	18%
4	Declaración de Aplicabilidad (SoA) y selección de controles	12%
5	Políticas y procedimientos del SGSI	10%
6	Gestión de identidades, accesos y protección de datos (gobernanza)	8%
7	Gestión de incidentes, continuidad y recuperación (planificación)	8%
8	Ética de la seguridad de la información	8%
9	Monitoreo, medición y auditoría interna del SGSI	9%
10	Calidad documental y sustentación	7%
	Total	**100%**

Escala: Excelente 4, Logrado 3, En proceso 2, Insuficiente 1 y No evidenciado 0. Puntaje = peso × (nivel / 4).

Dónde se evidencia cada criterio

Criterio	Secciones
1	2, 3 y 4
2	5
3	6 y 7
4	8
5	9
6	10
7	11

Criterio	Secciones
8	12
9	13
10	Portada, anexos, matriz de trazabilidad (14.2) y exposición ante el jurado (pendiente)

S2-E2 · Implementación, Testing y Monitoreo de Red (CE0312–CE0313)

CE0312 y CE0313 — Implementación, pruebas y control de red

Ejecución del diseño de red del Semestre 1: VPN, firewall, DMZ, segmentación, IDS/IPS, honeypot, monitoreo y pruebas reproducibles. Este documento separa lo **implementado con evidencia** (perímetro y TLS del VPS, DNS y HTTPS de la plataforma) de lo **pendiente de ejecución** (equipos de la sede, VPN, detección y monitoreo), que incluye procedimiento, criterio de aceptación y evidencia por adjuntar.

Portada

Campo	Detalle
Título	Implementación, pruebas y monitoreo de la red híbrida de CERMAT
Entregable	Semestre 2 · Entregable 2 · CE0312 y CE0313
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo), UPeU campus Juliaca, sección g1
Fecha	2026-10-24
Versión	2.0

Control de versiones

Versión	Fecha	Cambio
1.0	2026-07-06	Plantillas de configuración de VLAN y protocolo de pruebas (estructura anterior de la guía)
2.0	2026-10-24	Reescrito según la guía vigente: evidencia real del VPS y de las verificaciones externas, procedimientos de VPN, perímetro y detección, plan de 37 pruebas e incidencias

Productos obligatorios

Producto	Formato entregado	Ubicación	Criterio de aceptación (guía)	Estado
Informe de implementación, testing y monitoreo de red	Página versionada; PDF desde la vista de impresión	Este documento	Completo, versionado y coherente con el diseño de S1	Entregado
Evidencias técnicas de configuración	Salidas de comandos, configuraciones sanitizadas y explicación de cada evidencia	Secciones 4 y 10 y Anexo B	Capturas legibles, configuraciones exportadas y propósito de cada evidencia	Parcial: evidencia real del VPS y externa; lo de la sede, pendiente
Plan y resultados de pruebas	XLSX y sección 8	s2-e2-plan-resultados-pruebas-red.xlsx	Pruebas positivas y negativas: permitido/denegado y detección	11 conformes y 2 no conformes con resultado real; 24 pendientes
Repositorio técnico de red	Git	Sección 10.2	Permite revisar o reconstruir la configuración sin credenciales	Parcial: estructura definida; configuraciones de la sede pendientes

1. Resumen ejecutivo de la implementación de red

Elemento del diseño	Estado	Evidencia
Perímetro de la nube (UFW: entrada denegada; 22, 80 y 443/tcp)	**Implementado**	Manual del VPS (2026-10-17), PR-01
Base de datos de la nube no expuesta (PostgreSQL solo en loopback)	**Implementado**	PR-02
HTTPS con redirección, TLS 1.2/1.3 y certificados vigentes en los 3 sitios del VPS	**Implementado y verificado**	PR-03 a PR-07 (2026-10-24); renovación PR-08 (manual)
HTTPS, HSTS y TLS de la plataforma de la academia (Vercel)	**Implementado y verificado**	PR-13 (2026-10-24)
Bloqueo de archivos ocultos en Nginx	**Implementado y verificado**	PR-09
DNS del dominio (NS, MX y CNAME)	**Implementado y verificado**	PR-11
Cabeceras de seguridad HTTP y protección del dominio (CAA, SPF, DMARC y DNSSEC)	**No conforme**	PR-10 y PR-12: acciones en la sección 4.3
OPNsense, VLAN, DMZ y Wi-Fi de la sede	Pendiente de ejecución	Procedimiento en la sección 4.2
VPN IPsec sede ↔ VPS	Pendiente de ejecución	Procedimiento en la sección 3
Suricata, Cowrie y Wazuh	Pendiente de ejecución	Procedimiento en la sección 6
Monitoreo con Uptime Kuma y Netdata	Pendiente de ejecución	Procedimiento en la sección 7.2

Hallazgos. Las verificaciones del 2026-10-24 confirman que el cifrado en tránsito es correcto en todos los sitios: TLS 1.0 y 1.1 se rechazan y TLS 1.2 y 1.3 usan cifrados AEAD. También revelan dos brechas reales: el sitio del colegio no envía cabeceras de seguridad y expone la versión de Nginx, y el dominio no publica CAA, SPF, DMARC ni DNSSEC. Se registraron 5 incidencias: 2 incidentes abiertos, 1 falso positivo cerrado y 2 observaciones.

Cumplimiento del diseño. De los 31 componentes de red del diseño, los de la nube (NET-23 a NET-25, NET-28 a NET-30) están operativos. Los de la sede y el túnel dependen del hardware (fase 2) o del laboratorio de validación propuesto (fase 1b).

2. Trazabilidad con el diseño de red

Elemento de S1-E1	Implementación	Cambio respecto del diseño	Justificación
UFW-01 a UFW-05 (Security Group del VPS)	Implementado	Ninguno	—
UFW-06 a UFW-10 (VPN, SSH solo por VPN y fail2ban)	Pendiente	El cierre de SSH a Internet espera a la validación de la VPN	Evitar quedar sin acceso; la consola del proveedor es el acceso de emergencia
NET-25 Nginx con TLS	Implementado	Se agregan cabeceras de seguridad y `server_tokens off`	Hallazgo PR-10
NET-28 DNS	Implementado	Se agregan CAA, SPF, DKIM y DMARC	Hallazgo PR-12
NET-04 OPNsense, VLAN y reglas FW-01 a FW-73	Pendiente	Ninguno	Requiere el host (fase 2) o un laboratorio (fase 1b)
NET-27 túnel IPsec	Pendiente	Ninguno	Requiere OPNsense
NET-05, NET-14 y NET-17 (detección)	Pendiente	Ninguno	Requiere el host
NET-31 PC local	Operativa (transitoria)	Se mantiene hasta migrar a VM-APP01	Continuidad de la réplica

3. Implementación de la conectividad híbrida (VPN)

Estado: pendiente de ejecución. Requiere VM-FW01 (OPNsense). Los parámetros son los de S1-E1 §10.

Paso 1. Red interna del VPS (`dum0` , equivalente a la subred privada).

```
# /etc/systemd/network/10-dum0.netdev
[NetDev]
Name=dum0
Kind=dummy

# /etc/systemd/network/10-dum0.network
[Match]
Name=dum0

[Network]
Address=10.20.0.1/24
```

```
sudo networkctl reload
ip -br addr show dum0        # esperado: dum0 ... 10.20.0.1/24
```

Paso 2. strongSwan y llave privada del VPS. La llave se genera en el VPS y nunca sale de él.

```
sudo apt install strongswan-swanctl charon-systemd strongswan-pki
sudo sh -c 'pki --gen --type ecdsa --size 384 --outform pem > /etc/swanctl/private/vps.key.pem'
sudo chmod 600 /etc/swanctl/private/vps.key.pem
sudo pki --req --type priv --in /etc/swanctl/private/vps.key.pem \
     --dn "CN=vps.cermat.vpn" --san vps.cermat.vpn --outform pem > vps.csr.pem
```

Paso 3. CA y certificados en OPNsense. Crear la CA interna en *System → Trust → Authorities*: `CA-CERMAT-VPN`, ECDSA secp384r1, SHA-384, 10 años. Firmar `vps.csr.pem` como certificado de servidor por 2 años y emitir el certificado propio `fw-sede.cermat.vpn`. Solo se copian al VPS los certificados **públicos**: el del VPS a `/etc/swanctl/x509/` y el de la CA a `/etc/swanctl/x509ca/`.

Paso 4. Configuración de strongSwan. Archivo sin secretos:

```
# /etc/swanctl/conf.d/sede.conf
connections {
  sede-azangaro {
    version = 2
    local_addrs = %any
    remote_addrs = %any              # la sede puede tener IP dinámica o CGNAT
    proposals = aes256gcm16-prfsha256-ecp384,aes256gcm16-prfsha256-ecp256
    encap = yes                      # NAT-T forzado (UDP 4500)
    dpd_delay = 30s
    rekey_time = 4h
    local {
      auth = pubkey
      certs = vps.crt.pem
      id = vps.cermat.vpn
    }
    remote {
      auth = pubkey
      id = fw-sede.cermat.vpn
      cacerts = ca-cermat-vpn.crt.pem
    }
    children {
      sede-net {
        local_ts = 10.20.0.0/24
        remote_ts = 10.10.40.0/24,10.10.99.0/27
        esp_proposals = aes256gcm16-ecp384,aes256gcm16-ecp256
        rekey_time = 1h
        dpd_action = clear
        start_action = none
      }
    }
  }
}
```

```
sudo systemctl enable --now strongswan
sudo swanctl --load-all
```

Paso 5. Firewall del VPS.

```
sudo ufw allow 500,4500/udp comment 'IKEv2 y NAT-T (UFW-06)'
sudo ufw allow in from 10.10.40.40 to 10.20.0.1 port 22 proto tcp comment 'Respaldo (UFW-07)'
sudo ufw allow in from 10.10.99.20 to 10.20.0.1 port 22 proto tcp comment 'Bastion por VPN (UFW-08)'
sudo ufw status numbered
```

Paso 6. Conexión en OPNsense (*VPN → IPsec → Connections*).

Campo	Valor
Versión	IKEv2
Direcciones locales y remotas	Interfaz WAN / IP pública del VPS
Propuestas	`aes256gcm16-prfsha256-ecp384` y `aes256gcm16-prfsha256-ecp256`
Encapsulación UDP y DPD	Activada; 30 s
Autenticación local	Llave pública, certificado `fw-sede.cermat.vpn`
Autenticación remota	Llave pública, CA `CA-CERMAT-VPN`, id `vps.cermat.vpn`
Child SA	Local 10.10.40.0/24 y 10.10.99.0/27; remota 10.20.0.0/24; ESP `aes256gcm16-ecp384` ; acción de inicio *start*; DPD *restart*

Después: reglas FW-70 a FW-73 en la pestaña IPsec y normalización con MSS máximo de 1360 en la interfaz IPsec.

Paso 7. Verificación bidireccional.

```
# En el VPS
sudo swanctl --list-sas          # esperado: sede-azangaro ESTABLISHED; sede-net INSTALLED,
AES_GCM_16-256, ECP_384
ping -c 3 -I 10.20.0.1 10.10.40.10
curl -s --interface 10.20.0.1 http://10.10.40.10:3001/health    # esperado: {"status":"ok",...}
# En el bastión (10.10.99.20)
ssh <usuario>@10.20.0.1          # SSH al VPS por la VPN
ping -c 3 10.20.0.1
```

Criterio de aceptación	Resultado obtenido	Evidencia a adjuntar
IKE_SA establecida y CHILD_SA instalada con AES-GCM-256 y ECP-384; respuesta en ambos sentidos; redes no anunciadas sin ruta (PR-24 a PR-26)	Pendiente de ejecución	Salida de `swanctl --list-sas`, captura del estado IPsec en OPNsense, salidas de `ping` y `curl` y registro de las reglas FW-70 a FW-73

4. Implementación de la seguridad perimetral

4.1 Implementado en la nube (VPS)

Control	Configuración	Verificación	Resultado	Fuente
Firewall de host (equivalente a Security Group)	UFW con entrada denegada por defecto; 22, 80 y 443/tcp permitidos; salida permitida	`sudo ufw status verbose`	Conforme	Manual del propietario (2026-10-17), PR-01
Segmentación por servicio (la base no es alcanzable)	PostgreSQL escucha solo en loopback	`sudo ss -tlnp`	Conforme	Manual, PR-02
Cifrado en tránsito	Let's Encrypt en dominio, www y api; redirección 301; TLS 1.2/1.3	`curl` y `openssl`	Conforme	Verificación del 2026-10-24, PR-03 a PR-07
Renovación de certificados	Certbot con renovación automática	`certbot renew --dry-run`	Conforme	Manual, PR-08
Superficie web mínima	Raíz pública solo en `backend/public`; bloqueo de archivos ocultos; `client_max_body_size 20M`	`curl https://<host>/.env`	403 (conforme)	PR-09

Control	Configuración	Verificación	Resultado	Fuente
Permisos de la aplicación	Grupo `www-data`, sin 777; `.env` con permisos 640	Revisión del manual	Conforme	Manual

En la nube, el VPS cumple el papel de un servidor en DMZ: expone solo 80 y 443, la base escucha en loopback y la administración se cerrará al túnel.

4.2 Pendiente en la sede (OPNsense, switch y Wi-Fi)

Estado: pendiente de ejecución (fase 2, o laboratorio en la fase 1b).

1. **OPNsense (VM-FW01).** Instalar desde la imagen oficial en la VM 101 (sección 3 de S2-E3). Asignar WAN = vtnet0, WAN2 = vtnet1 y la troncal vtnet2 con las VLAN 10, 20, 30, 40, 50 y 99 (*Interfaces → Other Types → VLAN*), cada una con su dirección .1.
2. **Servicios.** DHCP por VLAN con los rangos y reservas de S1-E1 §8.1; Unbound con listas de bloqueo para GUEST y ACAD; NTP en todas las interfaces internas.
3. **Gateways.** Grupo con WAN1 en nivel 1 y WAN2 en nivel 2, con disparador por pérdida de paquetes o latencia alta; regla de salida a Internet usando el grupo.
4. **Alias.** `PRIVADAS` (10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16), `ADMIN_TI` (10.10.10.10), `BASTION` (10.10.99.20) y `VPS_INTERNO` (10.20.0.1).
5. **Reglas FW-01 a FW-73** en el orden de S1-E1 §13.5, con el ID en la descripción. Reenvío FW-60 solo si el ISP entrega IP pública.
6. **Endurecimiento.** Interfaz web y SSH solo en MGMT; administrador nominativo con TOTP; regla anti-bloqueo desactivada fuera de MGMT; respaldo cifrado de `config.xml` después de cada cambio.
7. **Switch.** Crear las VLAN; LAG LACP en los puertos 23 y 24 (troncal hacia PVE01); puertos 1 y 2 como troncal para los AP con VLAN nativa 99; puertos de acceso en VLAN 10 o 20; puerto 22 en VLAN 99 para IPMI; desactivar los puertos sin uso; gestión solo en VLAN 99.
8. **AP.** SSID CERMAT-ADMIN (VLAN 10), CERMAT-DOCENTES (VLAN 20) y CERMAT-INVITADOS (VLAN 30) con aislamiento de clientes; WPA3; gestión en VLAN 99.

Criterio de aceptación	Resultado obtenido	Evidencia a adjuntar
PR-14 a PR-23 y PR-34 conformes; reglas exportadas iguales a S1-E1 §13.5	Pendiente de ejecución	Captura de las reglas por interfaz, `config.xml` sanitizado (sin hashes ni llaves), configuración exportada del switch y capturas de los SSID

4.3 Endurecimiento pendiente del VPS y del dominio (brechas reales)

Cabeceras y versión del servidor (PR-10). Archivo `/etc/nginx/conf.d/seguridad.conf`:

```
server_tokens off;
```

En cada bloque `server` con TLS, probando primero que la aplicación Angular no se rompa:

```
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;
add_header X-Content-Type-Options "nosniff" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;
add_header Content-Security-Policy "frame-ancestors 'self'" always;
```

```
sudo nginx -t && sudo systemctl reload nginx
curl -sI https://cermatschool.edu.pe/ | grep -iE 'strict-transport|x-content|referrer|content-security|^server'
```

Para la plataforma de la academia, el mismo conjunto (salvo HSTS, que Vercel ya envía) se declara en la sección `headers` de `vercel.json` del repositorio de la aplicación.

SSH (R-12).

```
sudo sshd -T | grep -Ei '^(passwordauthentication|permitrootlogin|pubkeyauthentication)'
# esperado: passwordauthentication no · permitrootlogin no · pubkeyauthentication yes
sudo apt install fail2ban && sudo fail2ban-client status sshd
```

Dominio (PR-12), en el panel DNS de Punto.pe:

Registro	Valor
`CAA` en el dominio	`0 issue "letsencrypt.org"`
`TXT` SPF en el dominio	`v=spf1 include:_spf.google.com ~all`
`TXT` DKIM en `google._domainkey`	Llave generada en la consola de Google Workspace
`TXT` DMARC en `_dmarc`	`v=DMARC1; p=none; rua=mailto:<buzón de reportes>`; pasar a `p=quarantine` tras 2–4 semanas sin rechazos legítimos
DNSSEC	Activar si el registro `.pe` y el proveedor DNS lo permiten

Criterio de aceptación	Resultado obtenido	Evidencia a adjuntar
PR-10 y PR-12 repetidas con resultado conforme; `sshd -T` con los valores esperados; fail2ban activo	Pendiente de ejecución	Salidas de `curl -sI`, `sshd -T`, `fail2ban-client` y de las consultas DNS

5. Pruebas de segmentación

Prueba de la guía	Caso	Resultado esperado	Resultado obtenido	Estado
Internet → DMZ	PR-14	Solo 22/tcp hacia el honeypot; ningún otro puerto	Pendiente de ejecución	Pendiente
Internet → LAN	PR-15	Todo filtrado, sin reenvíos	Pendiente de ejecución	Pendiente

Prueba de la guía	Caso	Resultado esperado	Resultado obtenido	Estado
DMZ → DB	PR-16	10.10.50.10 → 10.10.40.10:3306 bloqueado y registrado por FW-41	Pendiente de ejecución	Pendiente
Usuarios → MGMT	PR-17	Equipos ADMIN sin rol TI y ACAD → 10.10.99.10:8006 bloqueados y registrados	Pendiente de ejecución	Pendiente
ADMIN → MGMT	PR-18	ADMIN_TI → 10.10.99.10:8006 permitido	Pendiente de ejecución	Pendiente

Equivalentes ya verificados en la nube.

- Internet → base de datos del colegio: PostgreSQL solo escucha en loopback (PR-02) y UFW deniega la entrada (PR-01). La comprobación desde afuera con `nc -vz` está pendiente (PR-36).
- Internet → archivos internos del servidor web: `/.env` responde 403 (PR-09).

Los comandos de cada prueba están en el Anexo A.

---

6. IDS/IPS, honeypot y detección

Estado: pendiente de ejecución (requiere VM-FW01, VM-HPOT01 y VM-SIEM01).

6.1 Suricata en OPNsense

1. En *Interfaces → Settings*, desactivar la descarga de CRC, TSO y LRO por hardware (requisito de netmap sobre virtio) y reiniciar.
2. En *Services → Intrusion Detection → Administration*: activar, modo IPS, *pattern matcher* Hyperscan si la CPU lo soporta, interfaces WAN y WAN2.
3. Descargar ET Open (categorías scan, exploit, malware, trojan y policy), abuse.ch SSL Blacklist y Feodo Tracker; programar la actualización diaria.
4. Política: descartar en exploit, malware y scan sobre las WAN; solo alertar en el resto durante el primer mes para afinar falsos positivos. Para ver el tráfico interno, agregar SRV y DMZ con reglas en modo alerta.
5. Enviar las alertas y el registro del firewall por syslog TCP a Wazuh (10.10.40.20:514).

6.2 Honeypot Cowrie (VM-HPOT01)

```
# SSH real en el puerto 22022, alcanzable solo desde el bastión (FW-55)
sudo sed -i 's/^#\?Port .*/Port 22022/' /etc/ssh/sshd_config && sudo systemctl restart ssh
sudo adduser --disabled-password --gecos "" cowrie
sudo -iu cowrie
git clone https://github.com/cowrie/cowrie && cd cowrie
python3 -m venv cowrie-env && . cowrie-env/bin/activate
python -m pip install --upgrade pip
python -m pip install -e .        # según la versión de Cowrie: pip install -r requirements.txt
cowrie start                      # escucha en 2222 (SSH) y 2223 (Telnet)
```

En OPNsense, el reenvío FW-60 (WAN 22/tcp → 10.10.50.10:2222) solo se activa si la sede tiene IP pública. Sin IP pública, el honeypot funciona como señuelo interno.

6.3 Wazuh (VM-SIEM01) y agentes

```
# Instalación todo en uno con el asistente oficial (versión vigente de la guía de inicio rápido)
curl -sO https://packages.wazuh.com/<versión>/wazuh-install.sh && sudo bash ./wazuh-install.sh -a
# La contraseña de administrador que muestra el asistente se guarda en el gestor de contraseñas, nunca en documentos.

# Agentes en Ubuntu o Debian (VM, host, VPS y honeypot), con el repositorio de Wazuh configurado
sudo WAZUH_MANAGER="10.10.40.20" apt-get install wazuh-agent
sudo systemctl enable --now wazuh-agent
```

Recepción de syslog de OPNsense en `/var/ossec/etc/ossec.conf` del servidor:

```
<remote>
  <connection>syslog</connection>
  <port>514</port>
  <protocol>tcp</protocol>
  <allowed-ips>10.10.40.1/32</allowed-ips>
  <local_ip>10.10.40.20</local_ip>
</remote>
```

Lectura de Cowrie en el agente del honeypot y reglas locales en el servidor (`/var/ossec/etc/rules/local_rules.xml`):

```
<!-- agente de VM-HPOT01 -->
<localfile>
  <log_format>json</log_format>
  <location>/home/cowrie/cowrie/var/log/cowrie/cowrie.json</location>
</localfile>

<!-- servidor Wazuh -->
<group name="cowrie,honeypot,">
  <rule id="100100" level="5">
    <decoded_as>json</decoded_as>
    <field name="eventid">^cowrie.session.connect$</field>
    <description>Honeypot: conexión desde $(src_ip)</description>
  </rule>
  <rule id="100101" level="10">
    <decoded_as>json</decoded_as>
    <field name="eventid">^cowrie.login</field>
    <description>Honeypot: intento de inicio de sesión con el usuario $(username) desde $(src_ip)
</description>
  </rule>
  <rule id="100102" level="12">
    <decoded_as>json</decoded_as>
    <field name="eventid">^cowrie.command.input$</field>
    <description>Honeypot: comando ejecutado $(input)</description>
  </rule>
</group>
```

6.4 Evidencia de punta a punta

Paso	Evidencia esperada
1. Generar el evento controlado (PR-30, PR-31 o PR-32)	Comando ejecutado con hora
2. Detección en el sensor	Alerta de Suricata (SID 2100498 o ET SCAN) o evento de Cowrie
3. Ingesta en el SIEM	Alerta en Wazuh con la regla, el nivel y la IP de origen
4. Notificación	Correo o mensaje del canal de alertas
5. Registro	Fila del plan de pruebas con la hora de cada paso (relojes sincronizados por NTP)

Criterio de aceptación	Resultado obtenido	Evidencia a adjuntar
PR-30, PR-31, PR-32 y PR-37 conformes, con la cadena completa en menos de 1 minuto	Pendiente de ejecución	Capturas del panel de Wazuh, extracto de `eve.json` y de `cowrie.json`

7. Monitoreo y visibilidad de red

7.1 Implementado hoy

Señal	Mecanismo	Dónde	Estado
Disponibilidad de la API y de MySQL	`GET /health` con el estado de MySQL y el tiempo en línea	API y analítica	Implementado

Señal	Mecanismo	Dónde	Estado
Verificación manual de servicios	Panel admin "Infraestructura": prueba `/health` y activa o desactiva la sincronización	Plataforma	Implementado
Accesos HTTP a la API	`morgan` en formato *combined*	PC local	Implementado, sin centralizar
Registros del VPS	Nginx (acceso y error), `auth.log` y journald	VPS	Implementado, sin centralizar
Historial de despliegues	Panel de Vercel	Vercel	Disponible
Rutinas de operación	Revisión diaria, semanal y mensual del manual del VPS	VPS	Documentado

7.2 Pendiente: centralización, paneles y alertas

- **Centralización de registros:** Wazuh recibe OPNsense, Suricata, Cowrie, el VPS, el host y las VM; retención de 90 días (SUP-09).
- **Paneles:** panel de Wazuh (alertas por nivel y origen), página de estado de Uptime Kuma y Netdata (CPU, RAM, disco y red por equipo).
- **Correlación:** reglas de Wazuh para fuerza bruta SSH (5710, 5712, 5716 y 5720), alertas de Suricata con su origen y eventos del honeypot (100100 a 100102).
- **Conservación de evidencias:** exportación semanal de alertas con su SHA-256, guardada en PBS en modo solo lectura.

Monitores de Uptime Kuma (VM-MON01).

Monitor	Tipo	Objetivo	Intervalo	Alerta
Plataforma de la academia	HTTP(s)	https://academia-school-platform.vercel.app	60 s	2 fallas seguidas
Sitio del colegio	HTTP(s)	https://cermatschool.edu.pe	60 s	2 fallas seguidas
API del colegio	HTTP(s)	https://api.cermatschool.edu.pe/up	60 s	2 fallas seguidas
API de la academia	HTTP(s) con JSON	`/health` a través del proxy	60 s	2 fallas seguidas
Certificados	Vencimiento TLS	Los 3 dominios del VPS	Diario	Menos de 14 días
Túnel IPsec	Ping	10.20.0.1	60 s	3 fallas seguidas
Latido del VPS	Push	`cron` del VPS cada minuto	60 s	Sin latido en 3 min
Latido del propio monitor	Servicio externo gratuito de latidos	Uptime Kuma	5 min	Sin latido

```
docker run -d --restart=unless-stopped -p 3001:3001 -v uptime-kuma:/app/data --name uptime-kuma
louislam/uptime-kuma:1
```

Mientras no exista el host, Uptime Kuma puede correr de forma transitoria en la PC local con Docker para vigilar los servicios públicos y cerrar la no conformidad NC-05 antes del 2026-11-14.

Criterio de aceptación	Resultado obtenido	Evidencia a adjuntar
PR-33 conforme (alerta en ≤ 2 min); los 8 monitores activos; registros de las 5 fuentes visibles en Wazuh	Pendiente de ejecución	Capturas de la página de estado, del panel de Wazuh y de Netdata

8. Plan y resultados de pruebas técnicas

ID	Caso	Objetivo	Procedimiento o comando	Resultado esperado	Resultado obtenido	Estado	Evidencia
PR-01	Política por defecto del firewall del VPS	Entrada denegada y solo puertos necesarios	sudo ufw status verbose	deny (incoming), allow (outgoing); 22, 80 y 443/tcp ALLOW	Conforme según el manual del propietario (2026-10-17)	Conforme	Manual del VPS; captura de ufw status verbose a adjuntar
PR-02	Base de datos de la nube no expuesta	PostgreSQL solo en loopback	sudo ss -tlnp | grep 5432	Solo 127.0.0.1:5432 (y ::1)	Conforme según el manual (2026-10-17)	Conforme	Captura a adjuntar; verificación externa en PR-36
PR-03	Redirección HTTP → HTTPS del dominio	Forzar cifrado	curl -sI http://cermatschool.edu.pe	301 hacia https://	301 Moved Permanently → https://cermatschool.edu.pe/ (2026-10-24)	Conforme	Anexo B de S2-E2
PR-04	Redirección HTTP → HTTPS de www y api	Forzar cifrado	curl -sI http://www.cermatschool.edu.pe/ y http://api.cermatschool.edu.pe/up	301 hacia https://	301 en ambos (2026-10-24)	Conforme	Anexo B de S2-E2
PR-05	Disponibilidad web y API del colegio	Servicio en línea	curl -sI https://cermatschool.edu.pe/, https://www…/ y https://api…/up	200	200 en los tres (2026-10-24)	Conforme	Anexo B de S2-E2

ID	Caso	Objetivo	Procedimiento o comando	Resultado esperado	Resultado obtenido	Estado	Evidencia
PR-06	Protocolos TLS aceptados por el VPS	Rechazar TLS 1.0 y 1.1	openssl s_client -connect :443 -tls1 | -tls1_1 | -tls1_2 | -tls1_3	1.0 y 1.1 rechazados; 1.2 y 1.3 con cifrados AEAD	1.0 y 1.1: alerta 70 (protocol_version) del servidor; 1.2: ECDHE-ECDSA-AES256-GCM-SHA384; 1.3: TLS_AES_256_GCM_SHA384 (dominio y api, 2026-10-24)	Conforme	Anexo B de S2-E2
PR-07	Certificados vigentes	Emisor, SAN y vigencia correctos	openssl s_client … | openssl x509 -noout -issuer -enddate -ext subjectAltName	Emisor de confianza, SAN correcto y vigente	Let's Encrypt (YE1 y YE2); SAN: dominio y www, y api; vencen el 2027-01-15	Conforme	Anexo B de S2-E2
PR-08	Renovación automática de certificados	Evitar vencimientos	sudo certbot renew --dry-run	Simulación exitosa	Exitosa según el manual (2026-10-17)	Conforme	Captura a adjuntar
PR-09	Bloqueo de archivos ocultos	Evitar fuga de configuración	curl -s -o /dev/null -w "%{http_code}" https:///.env	403 o 404	403 en dominio y api (2026-10-24)	Conforme	Anexo B de S2-E2

ID	Caso	Objetivo	Procedimiento o comando	Resultado esperado	Resultado obtenido	Estado	Evidencia
PR-10	Cabeceras de seguridad HTTP	HSTS y cabeceras recomendadas por OWASP	curl -sI https://cermatschool.edu.pe/ y https://academia-school-platform.vercel.app/	HSTS, X-Content-Type-Options, protección contra framing, Referrer-Policy y Server sin versión	Colegio: ninguna cabecera de seguridad y Server: nginx/ (Ubuntu). Academia: solo HSTS en la primera medición; tras publicar `vercel.json` (2026-10-24): X-Content-Type-Options, Referrer-Policy, CSP frame-ancestors, Permissions-Policy y HSTS	No conforme (academia conforme; colegio pendiente)	Anexo B de S2-E2; acción en R-13
PR-11	Registros DNS	Delegación y registros esperados	nslookup -type=NS | MX | CNAME	NS de RCP; MX de Google; www → dominio	NS.RCP.NET.pe y NS2.RCP.NET.pe; 5 registros MX de Google; www CNAME al dominio (2026-10-24)	Conforme	Anexo B de S2-E2
PR-12	Protección del dominio	CAA, SPF, DMARC y DNSSEC	Consultas DNS sobre HTTPS (tipos CAA, TXT, DS)	Registros presentes	Sin CAA, sin SPF, sin DMARC y sin DNSSEC (2026-10-24)	No conforme	Anexo B de S2-E2; acciones en R-11 y R-14

ID	Caso	Objetivo	Procedimiento o comando	Resultado esperado	Resultado obtenido	Estado	Evidencia
PR-13	HTTPS de la plataforma de la academia (PaaS)	Redirección, HSTS y TLS	curl -sI http://… y https://…; openssl s_client	Redirección a HTTPS, HSTS y TLS ≥ 1.2	308 a HTTPS; HSTS max-age=63072000; includeSubDomains; preload; 1.0 y 1.1 sin negociación; 1.2 y 1.3 aceptados; certificado *.vercel.app vigente hasta 2026-11-27 (renovación gestionada por Vercel)	Conforme	Anexo B de S2-E2
PR-14	Internet → DMZ (PC-01)	Validar FW-60, FW-61	ssh; nmap -Pn -p 22 — origen: Equipo externo (datos móviles); destino: IP de WAN, 22/tcp (honeypot)	Sesión simulada de Cowrie y alerta en Wazuh; ningún otro puerto abierto	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-15	Internet → LAN (PC-02)	Validar FW-61	nmap -Pn -sS --top-ports 1000 — origen: Equipo externo; destino: IP de WAN, 1000 puertos más comunes	Solo responde 22/tcp (honeypot); el resto filtrado	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-16	DMZ → DB (PC-03)	Validar FW-41	nc -vz -w 3 — origen: VM-HPOT01 (10.10.50.10); destino: 10.10.40.10:3306	Bloqueado y registrado por el firewall	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha

ID	Caso	Objetivo	Procedimiento o comando	Resultado esperado	Resultado obtenido	Estado	Evidencia
PR-17	Usuarios → MGMT (PC-04)	Validar FW-12, FW-23	curl -k -m 5; nc -vz — origen: Equipo ADMIN (10.10.10.150) y equipo ACAD (10.10.20.120); destino: 10.10.99.10:8006 y 10.10.99.2:443	Bloqueado y registrado	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-18	ADMIN → MGMT (PC-05)	Validar FW-20	Navegador; curl -k — origen: ADMIN_TI (10.10.10.10); destino: 10.10.99.10:8006	Permitido (interfaz de Proxmox)	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-19	Invitados → redes internas (PC-06)	Validar FW-02	ping; nmap -sn — origen: Cliente GUEST; destino: 10.10.10.0/24, 10.10.40.0/24 y 10.10.99.0/27	Sin respuesta; bloqueos registrados	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-20	Invitados → Internet (PC-07)	Validar FW-01, FW-03	Navegador; curl -I — origen: Cliente GUEST; destino: https://academia-school-platform.vercel.app	Permitido; DNS resuelto por el firewall	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-21	Aislamiento de clientes Wi-Fi (PC-08)	Validar Configuración del AP	ping — origen: Cliente GUEST A; destino: Cliente GUEST B	Sin respuesta (aislamiento en el AP)	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha

ID	Caso	Objetivo	Procedimiento o comando	Resultado esperado	Resultado obtenido	Estado	Evidencia
PR-22	ACAD → impresora y ADMIN (PC-09)	Validar FW-11, FW-12	nc -vz — origen: Equipo ACAD; destino: 10.10.10.20:9100 y 10.10.10.150	Impresora permitida; equipo ADMIN bloqueado	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-23	SRV → Internet (PC-10)	Validar FW-30, FW-34	curl -I; nc -vz — origen: VM-APP01; destino: APIs de Google 443/tcp; servidor SMTP 25/tcp	443 permitido; 25 bloqueado	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-24	Establecimiento del túnel (PC-11)	Validar Diseño VPN	swanctl --list-sas; estado IPsec en OPNsense — origen: OPNsense ↔ VPS; destino: IKEv2	IKE_SA ESTABLISHED y CHILD_SA INSTALLED con AES_GCM_16_256 y ECP_384	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-25	VPN bidireccional (PC-12)	Validar FW-54, FW-70	ssh; curl — origen: Bastión ↔ VPS; destino: 10.20.0.1:22; desde el VPS, 10.10.40.10:3001/health	Ambos sentidos responden dentro del túnel	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-26	Selectores de tráfico (PC-13)	Validar Diseño VPN	ping; nc -vz — origen: VPS 10.20.0.1; destino: 10.10.10.0/24 y 10.10.20.0/24	Sin ruta por el túnel (redes no anunciadas)	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-27	Publicación de la API por el VPS (PC-14)	Validar Nginx (proxy)	curl -I — origen: Internet; destino: https://api-academia…/health y otra ruta	/health responde 200 a través del túnel; otras rutas 404	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha

ID	Caso	Objetivo	Procedimiento o comando	Resultado esperado	Resultado obtenido	Estado	Evidencia
PR-28	SSH del VPS tras el endurecimiento (PC-15)	Validar UFW-08, UFW-09	nc -vz; ssh — origen: Internet y bastión; destino: IP pública del VPS:22 y 10.20.0.1:22	Bloqueado desde Internet; permitido desde el bastión	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-29	Conmutación de enlaces (PC-16)	Validar Grupo de gateways	ping continuo; desconectar WAN1 — origen: Equipo ADMIN; destino: Internet	Recuperación en ≤ 60 s por WAN2; el túnel se restablece	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-30	Detección IDS con firma de prueba (PC-17)	Validar Suricata	curl — origen: Equipo ACAD; destino: http://testmynids.org/uid/index.html	Alerta de Suricata SID 2100498 visible en Wazuh	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-31	Detección de escaneo (PC-18)	Validar Suricata	nmap -sS -T4 — origen: Cliente GUEST; destino: 10.10.30.1 (firewall)	Alertas ET SCAN en Suricata y en Wazuh	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-32	Inicio de sesión en el honeypot (PC-19)	Validar Cowrie y Wazuh	ssh root@ — origen: Equipo externo; destino: Honeypot Cowrie	Evento cowrie.login en Wazuh con regla local de nivel ≥ 10	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-33	Caída de la API (PC-20)	Validar Uptime Kuma	pm2 stop cermat-api — origen: VM-APP01; destino: Uptime Kuma	Alerta en ≤ 2 min y recuperación registrada	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha

ID	Caso	Objetivo	Procedimiento o comando	Resultado esperado	Resultado obtenido	Estado	Evidencia
PR-34	DNS forzado en invitados (PC-21)	Validar FW-01, FW-04	nslookup — origen: Cliente GUEST; destino: 8.8.8.8:53	Bloqueado; solo resuelve el firewall	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-35	MTU por el túnel (PC-22)	Validar Diseño VPN	sftp; ping -M do -s 1332 — origen: VM-BKP01 → VPS; destino: Transferencia SFTP de 100 MB	Sin fragmentación ni cortes (MSS 1360)	Pendiente de ejecución	Pendiente	A adjuntar: salida del comando, registro del firewall o alerta del SIEM con fecha
PR-36	Base de datos de la nube no alcanzable desde Internet	Confirmar desde afuera lo verificado en PR-02	nc -vz -w 3 5432 (desde la sede o datos móviles)	Tiempo agotado o rechazo	Pendiente de ejecución	Pendiente	A adjuntar: salida de nc con fecha
PR-37	Fuerza bruta SSH detectada en el VPS	Detección de ataques reales sobre el servicio expuesto	Agente Wazuh en el VPS; revisar alertas de sshd (reglas 5710, 5712, 5716 y 5720)	Alertas con IP de origen y conteo	Pendiente de ejecución	Pendiente	A adjuntar: captura del panel de Wazuh

Resumen: 37 casos. 11 conformes y 2 no conformes con resultado real (PR-01 a PR-13); 24 pendientes de ejecución (PR-14 a PR-37). Incluye pruebas positivas (permitido), negativas (denegado) y de detección.

9. Incidencias detectadas

ID	Detección	Descripción	Clasificación	Severidad	Contención	Causa raíz	Lección aprendida	Estado	Vínculo SGSI
INC-01	2026-10-24	Reglas de Firestore publicadas el 22-jun-2026 con 3 fallas: listado público de matrículas pagadas, auto-asignación de rol y matrícula pública bloqueada	Incidente de seguridad: exposición potencial de datos personales y escalamiento de privilegios	S1 (alta)	Corrección con 19 pruebas; frontend y reglas publicados el 2026-10-24 y verificados como visitante sin sesión (listar matrículas pagadas → 403)	Una línea inválida impedía compilar y nadie verificaba el despliegue	Publicar solo por CI y verificar el ruleset publicado	Cerrado (2026-10-24)	R-01 a R-04; NC-01 y NC-02
INC-02	2026-10-24	Clave de cuenta de servicio y archivos de entorno en el repositorio privado (copias ZIP y archivos versionados)	Incidente de seguridad: credencial expuesta	S1 (alta)	Clave de enero (`283b43c3…`) eliminada y reemplazada por `ddf50bfe…`; contraseñas de las cuentas de `teachers.json` restablecidas; los `.env` (sin contraseñas) siguen versionados por decisión del equipo	Copias del proyecto subidas con secretos; control preventivo ausente	Escaneo de secretos en el CI y lista de revisión de cambios	Cerrado con riesgo residual aceptado (2026-10-24)	R-05 y R-06; NC-03

ID	Detección	Descripción	Clasificación	Severidad	Contención	Causa raíz	Lección aprendida	Estado	Vínculo SGSI
INC-03	2026-10-24	El antivirus puso en cuarentena scripts SQL al ejecutarlos desde PowerShell con cmd (IDP.Generic)	Evento de seguridad: falso positivo	S4 (baja)	Restaurar desde cuarentena, ejecutar desde Git Bash y exclusión acotada	Heurística del antivirus ante la cadena PowerShell → cmd	Procedimiento documentado en server/src/db/README.md	Cerrado	R-22
INC-04	2026-10-24	Sitio del colegio sin cabeceras de seguridad y con la versión de Nginx expuesta; SPA de la academia solo con HSTS	Observación de seguridad (no es incidente)	S4 (baja)	No requiere	Configuración por defecto	Academia: cabeceras publicadas con `vercel.json` y verificadas el 2026-10-24. Colegio: plantilla de Nginx de la sección 4.3	Cerrado para la academia; abierto para el colegio	R-13
INC-05	2026-10-24	Dominio sin SPF, DMARC, CAA ni DNSSEC	Observación de seguridad (no es incidente)	S3 (media)	No requiere	Configuración DNS inicial sin controles de correo	Lista de verificación de dominio	Abierto	R-11 y R-14

- **Clasificación:** según las severidades S1 a S4 del procedimiento de gestión de incidentes PRO-01 del SGSI.
- **Contención:** INC-01 se cerró el 2026-10-24 al publicar el frontend y las reglas, con verificación en producción. INC-02 se cerró el mismo día con la clave rotada y las contraseñas restablecidas, con riesgo residual aceptado por los `.env` versionados (no contienen contraseñas). INC-03 se cerró con un procedimiento.
- **Lecciones aprendidas:**
  - Probar contra lo publicado, no solo contra el código.
  - Verificar cada despliegue.
  - Escanear secretos antes de versionar.
  - Ejecutar los scripts desde Git Bash.
  - Incluir cabeceras y registros DNS de seguridad en la lista de verificación de cada despliegue.

10. Evidencias técnicas

10.1 Índice de evidencias

ID	Evidencia	Propósito	Estado	Ubicación
EV-01	Manual del propietario del VPS (2026-10-17)	Fuente de PR-01, PR-02 y PR-08	Real; no se publica porque contiene datos de infraestructura del colegio	Resumen en la sección 4.1
EV-02	Salidas de las verificaciones externas del 2026-10-24	Resultados de PR-03 a PR-07 y PR-09 a PR-13	Real	Anexo B
EV-03	Captura de `ufw status verbose`	Respaldo visual de PR-01	A adjuntar	—
EV-04	Captura de `ss -tlnp`	Respaldo visual de PR-02	A adjuntar	—
EV-05	Captura de `certbot renew --dry-run`	Respaldo visual de PR-08	A adjuntar	—
EV-06	Configuración sanitizada de Nginx	Revisar los bloqueos y el TLS	A adjuntar	`infra/red/vps/`
EV-07	`swanctl.conf` aplicado	Reconstruir la VPN	Plantilla en la sección 3; pendiente de aplicar	`infra/red/vps/`
EV-08	`config.xml` de OPNsense sanitizado y reglas exportadas	Reconstruir el perímetro	Pendiente	`infra/red/opnsense/`
EV-09	Alertas de Suricata, Cowrie y Wazuh	Demostrar la detección	Pendiente	`infra/logs/`
EV-10	Página de estado de Uptime Kuma	Demostrar el monitoreo	Pendiente	`infra/logs/`

10.2 Repositorio técnico de red

Estructura propuesta, solo con configuraciones sanitizadas (sin hashes, llaves, contraseñas ni IP públicas):

```
infra/
├── README.md        # orden de despliegue, cómo reconstruir y qué no se versiona
├── diagramas/       # copia de los .drawio de docs/assets/infraestructura/diagramas
├── red/
│   ├── opnsense/    # config.xml sanitizado y reglas exportadas
│   ├── switch/      # configuración exportada (VLAN, LAG, puertos)
│   └── vps/         # sede.conf (swanctl), reglas UFW y bloques de Nginx
├── cd/              # ver S2-E3
├── scripts/         # verificación (curl, openssl, nc) y respaldos
└── logs/            # salidas de pruebas con fecha, sin datos personales
```

Estado actual: ya están versionados `firestore.rules` con sus pruebas, `.github/workflows/ci.yml`, los scripts de base de datos (`server/src/db/*.sql`) y de respaldo (`server/scripts/*.js`); y, en el repositorio de esta documentación, los diagramas, las matrices y el script que las genera. **Pendiente:** crear `infra/` con las configuraciones a medida que se implementen. Topics del repositorio según el estándar de la escuela: `campus-juliaca`, `semestre-2026-2`, `linea-infraestructura`, `tipo-epe`, `seccion-g1` y `grupo-<n>-<nombre>`.

---

11. Conclusiones, limitaciones, mejoras futuras y referencias

11.1 Conclusiones

1. El perímetro implementado en la nube cumple el diseño: entrada denegada por defecto, base de datos no expuesta, TLS 1.2/1.3 con AEAD y redirección a HTTPS en todos los sitios, verificados con evidencia reproducible.
2. Las pruebas encontraron dos brechas reales (cabeceras HTTP y registros DNS de seguridad), con acción definida y criterio de cierre.
3. La VPN, el perímetro de la sede y la detección tienen procedimiento, configuración sin secretos y criterio de aceptación, listos para ejecutarse en cuanto exista la plataforma on-premise.

11.2 Limitaciones

- La sede no tiene todavía el hardware del diseño, así que las pruebas PR-14 a PR-35 no tienen resultado.
- La verificación externa se limitó a consultas no intrusivas: no se escanearon puertos del VPS sin una autorización escrita.
- PR-01, PR-02 y PR-08 se basan en el manual del propietario; falta adjuntar las capturas.

11.3 Mejoras futuras

- Laboratorio de validación (fase 1b) para obtener evidencia de PR-14 a PR-35 antes de comprar el hardware.
- WPA3-Enterprise con RADIUS, firewall redundante con CARP y acceso remoto de administradores por VPN con TOTP.

11.4 Referencias

[1] C. Kaufman, P. Hoffman, Y. Nir, P. Eronen y T. Kivinen, "Internet Key Exchange Protocol Version 2 (IKEv2)," RFC 7296, IETF, oct. 2014.

[2] E. Barker, Q. Dang, S. Frankel, K. Scarfone y P. Wouters, "Guide to IPsec VPNs," NIST SP 800-77 Rev. 1, jun. 2020.

[3] K. Scarfone y P. Hoffman, "Guidelines on Firewalls and Firewall Policy," NIST SP 800-41 Rev. 1, sep. 2009.

[4] K. Scarfone y P. Mell, "Guide to Intrusion Detection and Prevention Systems (IDPS)," NIST SP 800-94, feb. 2007.

[5] E. Rescorla, "The Transport Layer Security (TLS) Protocol Version 1.3," RFC 8446, IETF, ago. 2018.

[6] K. Moriarty y S. Farrell, "Deprecating TLS 1.0 and TLS 1.1," RFC 8996, IETF, mar. 2021.

[7] J. Hodges, C. Jackson y A. Barth, "HTTP Strict Transport Security (HSTS)," RFC 6797, IETF, nov. 2012.

[8] P. Hallam-Baker, R. Stradling y J. Hoffman-Andrews, "DNS Certification Authority Authorization (CAA) Resource Record," RFC 8659, IETF, nov. 2019.

[9] M. Kucherawy y E. Zwicky, "Domain-based Message Authentication, Reporting, and Conformance (DMARC)," RFC 7489, IETF, mar. 2015.

[10] OWASP Foundation, "OWASP Secure Headers Project." [En línea]. Disponible en: https://owasp.org/www-project-secure-headers/

[11] strongSwan Project, "swanctl.conf Reference." [En línea]. Disponible en: https://docs.strongswan.org/

[12] Deciso B.V., "OPNsense Documentation: Intrusion Prevention System." [En línea]. Disponible en: https://docs.opnsense.org/

[13] Wazuh Inc., "Wazuh Documentation." [En línea]. Disponible en: https://documentation.wazuh.com/

[14] Cowrie Project, "Cowrie SSH/Telnet Honeypot." [En línea]. Disponible en: https://github.com/cowrie/cowrie

Anexos

Anexo A. Comandos de las pruebas de segmentación y detección

Prueba	Desde	Comando	Resultado esperado
PR-14	Equipo externo (datos móviles)	`nmap -Pn -p 22,80,443,3389 <IP de WAN>` y `ssh root@<IP de WAN>`	Solo 22/tcp abierto; sesión simulada de Cowrie
PR-15	Equipo externo	`nmap -Pn -sS --top-ports 1000 <IP de WAN>`	Solo 22/tcp; el resto filtrado
PR-16	VM-HPOT01	`nc -vz -w 3 10.10.40.10 3306`	Tiempo agotado; bloqueo de FW-41 en el registro
PR-17	10.10.10.150 y 10.10.20.120	`curl -k -m 5 https://10.10.99.10:8006`	Tiempo agotado; bloqueo de FW-23 o FW-12 en el registro

Prueba	Desde	Comando	Resultado esperado
PR-18	ADMIN_TI (10.10.10.10)	`curl -k -m 5 -o /dev/null -w "%{http_code}" https://10.10.99.10:8006`	200
PR-30	Equipo ACAD	`curl http://testmynids.org/uid/index.html`	Alerta SID 2100498 en Wazuh
PR-31	Cliente GUEST	`nmap -sS -T4 10.10.30.1`	Alertas ET SCAN
PR-32	Equipo externo	`ssh root@<IP de WAN>` con una contraseña inventada	Regla 100101 en Wazuh
PR-36	Sede o datos móviles	`nc -vz -w 3 <IP pública del VPS> 5432`	Tiempo agotado o rechazo

Las pruebas que generan tráfico de ataque simulado (PR-14, PR-15, PR-31 y PR-32) se ejecutan solo con la autorización escrita descrita en S2-E1 §12.3.

Anexo B. Salidas de las verificaciones externas (2026-10-24)

Ejecutadas desde la estación del equipo (Windows 10, Git Bash con `curl` y OpenSSL 3.2.3). Son consultas HTTP, TLS y DNS no intrusivas sobre dominios propios. Se omiten las direcciones IP y la versión exacta del servidor web.

```
$ curl -sS -o /dev/null -D - http://cermatschool.edu.pe
HTTP/1.1 301 Moved Permanently
Server: nginx/<versión omitida> (Ubuntu)
Location: https://cermatschool.edu.pe/

$ curl -sS -o /dev/null -D - https://cermatschool.edu.pe/
HTTP/1.1 200 OK
Server: nginx/<versión omitida> (Ubuntu)
(cabeceras recibidas: Server, Date, Content-Type, Content-Length, Last-Modified,
 Connection, ETag, Cache-Control, Accept-Ranges; sin cabeceras de seguridad)

$ curl -sS -o /dev/null -w "%{http_code} %{redirect_url}\n" http://www.cermatschool.edu.pe/
301 https://www.cermatschool.edu.pe/
$ curl -sS -o /dev/null -w "%{http_code} %{redirect_url}\n" http://api.cermatschool.edu.pe/up
301 https://api.cermatschool.edu.pe/up
$ curl -sI https://www.cermatschool.edu.pe   -> HTTP/1.1 200 OK
$ curl -sI https://api.cermatschool.edu.pe/up -> HTTP/1.1 200 OK

$ curl -s -o /dev/null -w "%{http_code}\n" https://cermatschool.edu.pe/.env
403
$ curl -s -o /dev/null -w "%{http_code}\n" https://api.cermatschool.edu.pe/.env
403

$ openssl s_client -connect cermatschool.edu.pe:443 -servername cermatschool.edu.pe \
    | openssl x509 -noout -issuer -enddate -ext subjectAltName
issuer=C=US, O=Let's Encrypt, CN=YE1
notAfter=Jan 15 22:22:21 2027 GMT
X509v3 Subject Alternative Name: cermatschool.edu.pe, www.cermatschool.edu.pe
(api.cermatschool.edu.pe: issuer CN=YE2; notAfter=Jan 15 22:10:57 2027 GMT; SAN
api.cermatschool.edu.pe)

$ openssl s_client -connect cermatschool.edu.pe:443 -tls1 -cipher 'DEFAULT@SECLEVEL=0'
... tlsv1 alert protocol version ... SSL alert number 70     (igual con -tls1_1 y en api)
$ openssl s_client -connect cermatschool.edu.pe:443 -tls1_2   -> TLSv1.2, Cipher is ECDHE-ECDSA-
AES256-GCM-SHA384
$ openssl s_client -connect cermatschool.edu.pe:443 -tls1_3   -> TLSv1.3, Cipher is
TLS_AES_256_GCM_SHA384

$ nslookup -type=NS cermatschool.edu.pe
cermatschool.edu.pe  nameserver = NS.RCP.NET.pe
cermatschool.edu.pe  nameserver = NS2.RCP.NET.pe
$ nslookup -type=MX cermatschool.edu.pe
MX preference = 1  ASPMX.L.GOOGLE.COM · 5 ALT1/ALT2.ASPMX.L.GOOGLE.COM · 10
ALT3/ALT4.ASPMX.L.GOOGLE.COM
$ nslookup -type=CNAME www.cermatschool.edu.pe
www.cermatschool.edu.pe  canonical name = cermatschool.edu.pe

DNS sobre HTTPS (dns.google): CAA sin respuesta · DS sin respuesta (AD=false) ·
TXT: 2 registros, ninguno es SPF · _dmarc: sin registro DMARC

$ curl -sI http://academia-school-platform.vercel.app
HTTP/1.0 308 Permanent Redirect
Location: https://academia-school-platform.vercel.app/
$ curl -sI https://academia-school-platform.vercel.app
HTTP/1.1 200 OK
Strict-Transport-Security: max-age=63072000; includeSubDomains; preload
(sin X-Content-Type-Options, protección contra framing ni Referrer-Policy)
$ openssl ... academia-school-platform.vercel.app
issuer=C=US, O=Google Trust Services, CN=WR1 · notAfter=Nov 27 19:48:08 2026 GMT · SAN *.vercel.app
TLS 1.2: ECDHE-RSA-AES128-GCM-SHA256 · TLS 1.3: TLS_AES_128_GCM_SHA256 · TLS 1.0/1.1: sin negociación
```

Rúbrica de evaluación

N°	Criterio de evaluación	Peso
1	Trazabilidad con el diseño de red (Semestre 1)	6%
2	Conectividad híbrida implementada: VPN y enrutamiento	15%
3	Seguridad perimetral implementada: firewall, DMZ y segmentación	22%
4	IDS/IPS, honeypot y detección implementados	18%
5	Monitoreo, registros y visibilidad de red	15%
6	Plan y resultados de pruebas técnicas	12%
7	Calidad documental, evidencias y repositorio	6%
8	Sustentación técnica	6%
	Total	**100%**

Escala: Excelente 4, Logrado 3, En proceso 2, Insuficiente 1 y No evidenciado 0. Puntaje = peso × (nivel / 4).

Dónde se evidencia cada criterio

Criterio	Secciones
1	2
2	3
3	4 y 5
4	6
5	7
6	8 y Anexo A
7	9, 10 y Anexo B
8	Exposición ante el jurado (pendiente)

S2-E3 · Implementación, Gestión y Control de Centro de Datos (CE0332–CE0333)

CE0332 y CE0333 — Implementación, control y operación del centro de datos

Despliegue y operación del centro de datos híbrido diseñado en el Semestre 1: entorno on-premise (Proxmox VE, equivalente a ESXi), nube (VPS equivalente a EC2 y servicios PaaS), identidades, inventario final, respaldo y recuperación, RTO/RPO, monitoreo y control de cambios. Lo **implementado** (VPS, PaaS y respaldo y restauración de MySQL) se distingue de lo **pendiente de ejecución** (host, VM, VPN y respaldos del VPS y de Firestore).

Portada

Campo	Detalle
Título	Implementación, gestión y control del centro de datos híbrido de CERMAT
Entregable	Semestre 2 · Entregable 3 · CE0332 y CE0333
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo), UPeU campus Juliaca, sección g1
Fecha	2026-10-24
Versión	2.0

Control de versiones

Versión	Fecha	Cambio
1.0	2026-07-06	Servicios del servidor local, RAID, SLA y procedimientos (estructura anterior de la guía)
2.0	2026-10-24	Reescrito según la guía vigente: VPS como EC2 equivalente, procedimientos de Proxmox, identidades, inventario final con evidencia, registro de recuperación real, RTO/RPO medido y control de cambios

Productos obligatorios

Producto	Formato entregado	Ubicación	Criterio de aceptación (guía)	Estado
Informe de implementación, gestión y control de centro de datos	Página versionada; PDF desde la vista de impresión	Este documento	Completo, versionado y coherente con el diseño de S1	Entregado
Evidencias técnicas de configuración	Configuraciones sanitizadas y salidas de comandos	Secciones 3, 4, 5 y 7	Incluye nube (VPC/EC2/SG/NACL/IAM equivalentes) e hipervisor (vSwitch/VLAN/VM equivalentes)	Parcial: nube con evidencia; hipervisor con procedimiento pendiente
Registro de prueba de recuperación	XLSX y sección 7.7	s2-e3-registro-prueba-recuperacion.xlsx	Al menos un ejercicio de recuperación completo, documentado	**Cumplido**: 4 ejercicios ejecutados (REC-01 a REC-04); 8 pendientes
Repositorio técnico de centro de datos	Git	Sección 10	Scripts, configuraciones sanitizadas, README y control de versiones sin secretos	Parcial: scripts versionados; carpeta `infra/` por crear; secretos del historial revocados el 2026-10-24 (NC-03 cerrada)

1. Resumen ejecutivo de la implementación del centro de datos

Componente del diseño	Estado	Evidencia
Nube IaaS: VPS (equivalente a EC2) con UFW (equivalente a Security Group), Nginx, TLS y PostgreSQL local	**Implementado**	Manual del propietario (2026-10-17); verificaciones PR-01 a PR-09
Nube PaaS: Vercel y Firebase	**Implementado**	PR-13; 22 colecciones con reglas; último despliegue del frontend el 2026-10-15
Respaldo y restauración de MySQL con SHA-256 y RTO medido	**Implementado y probado**	REC-01 a REC-04 en una base de prueba (RTO de 0,27–0,38 s) y REC-05 en la base real (RTO de 0,23 s); falta programar el respaldo diario
Identidades de mínimo privilegio en las bases	**Implementado**	4 roles MySQL (error 1142 ante DML directo); usuario PostgreSQL sin superusuario
Host Proxmox, bridges con VLAN, bond y VM	Pendiente de ejecución	Procedimiento en la sección 3
Red interna del VPS, strongSwan y NACL	Pendiente de ejecución	Sección 4.4 y S2-E2 §3
Respaldo del VPS y de Firestore	Pendiente de ejecución	Sección 7 (no conformidades NC-04 y NC-06)

Componente del diseño	Estado	Evidencia
Monitoreo de capacidad y alertas	Parcial	`/health` y rutinas del manual; Netdata y Uptime Kuma pendientes

La capa local de la academia sigue en una PC con PM2 (CD-36) hasta que exista VM-APP01. El cumplimiento del diseño es completo en la nube y queda pendiente en la sede, por falta del hardware.

2. Trazabilidad con el diseño del centro de datos

Elementos de S1-E2	Implementación	Cambio o justificación
CD-01 a CD-22 (rack, UPS, host, Proxmox, bridges, VM, almacenamiento y enlaces)	Pendiente	Sujeto a la adquisición del hardware; se propone un laboratorio (fase 1b) para ensayar el procedimiento
CD-23 a CD-27 (VPS, Ubuntu con UFW, Nginx con Certbot, sistema del colegio y PostgreSQL)	Implementado	Sin cambios
CD-28 (strongSwan y `dum0`)	Pendiente	Requiere OPNsense en la sede
CD-29 a CD-32 (Vercel y Firebase)	Implementado	Reglas de Firestore corregidas publicadas y frontend con cabeceras de seguridad, verificados el 2026-10-24 (NC-01 cerrada)
CD-33 (GitHub y CI)	Implementado en código	La primera ejecución en GitHub está pendiente
CD-34 (DNS)	Implementado	Se agregan CAA, SPF y DMARC (PR-12)
CD-35 (túnel)	Pendiente	Requiere OPNsense
CD-36 (PC local)	Operativa, transitoria	Se mantiene hasta migrar a VM-APP01
VMware ESXi	Proxmox VE	Equivalencia técnica; sin costo de licencia
AWS (VPC, EC2, SG, NACL, IAM)	VPS, PaaS y controles equivalentes	Infraestructura ya contratada; sin cuenta de AWS

3. Implementación del entorno on-premise

3.1 Estado actual (operativo, transitorio)

La API Node.js (`cermat-api`, puerto 3001, gestionada con `npm run pm2:start`), el servicio de analítica FastAPI (puerto 8000) y MySQL 8 corren en una PC local. El respaldo usa `server/scripts/backup.js` y la restauración `server/scripts/restore.js` (sección 7). No hay hipervisor, firewall perimetral ni segmentación.

3.2 Procedimiento de despliegue en Proxmox VE

Estado: pendiente de ejecución.

Paso 1. Instalación. Instalar Proxmox VE desde la ISO oficial en PVE01, con ZFS RAID1 sobre los dos SSD. Configurar el repositorio sin suscripción y actualizar (`apt update && apt full-upgrade`).

Paso 2. Red (equivalente a vSwitch, port groups y NIC teaming). Archivo `/etc/network/interfaces`; los nombres `nic1` a `nic4` se sustituyen por los reales (`ip link`):

```
auto lo
iface lo inet loopback

iface nic1 inet manual
iface nic2 inet manual

auto bond0
iface bond0 inet manual
    bond-slaves nic1 nic2
    bond-mode 802.3ad
    bond-miimon 100
    bond-xmit-hash-policy layer2+3

auto vmbr0
iface vmbr0 inet manual
    bridge-ports bond0
    bridge-stp off
    bridge-fd 0
    bridge-vlan-aware yes
    bridge-vids 10 20 30 40 50 99

auto vmbr0.99
iface vmbr0.99 inet static
    address 10.10.99.10/27
    gateway 10.10.99.1

auto vmbr1
iface vmbr1 inet manual
    bridge-ports nic3
    bridge-stp off
    bridge-fd 0
#   WAN1: sin IP del host

auto vmbr2
iface vmbr2 inet manual
    bridge-ports nic4
    bridge-stp off
    bridge-fd 0
#   WAN2: sin IP del host
```

```
ifreload -a && ip -br link show master vmbr0 && cat /proc/net/bonding/bond0
```

Paso 3. Almacenamiento. Compresión y límite del ARC de ZFS; HDD de 4 TB en paso directo a VM-BKP01:

```
zfs set compression=lz4 rpool
echo "options zfs zfs_arc_max=4294967296" > /etc/modprobe.d/zfs.conf && update-initramfs -u
qm set 150 -scsi1 /dev/disk/by-id/<id-del-hdd>
```

Paso 4. Máquinas virtuales. Se adjunta la ISO de cada sistema con `--ide2 local:iso/<archivo>,media=cdrom`:

```
qm create 101 --name vm-fw01 --ostype other --cores 2 --memory 4096 --scsihw virtio-scsi-single \
  --scsi0 local-zfs:40 --net0 virtio,bridge=vmbr1 --net1 virtio,bridge=vmbr2 \
  --net2 "virtio,bridge=vmbr0,trunks=10;20;30;40;50;99" --onboot 1 --startup order=1
qm create 120 --name vm-bas01  --ostype l26 --cores 1 --memory 1024 --scsi0 local-zfs:16  --net0
virtio,bridge=vmbr0,tag=99 --onboot 1 --startup order=2
qm create 130 --name vm-siem01 --ostype l26 --cores 4 --memory 8192 --scsi0 local-zfs:150 --net0
virtio,bridge=vmbr0,tag=40 --onboot 1 --startup order=3
qm create 110 --name vm-app01  --ostype l26 --cores 2 --memory 4096 --scsi0 local-zfs:60  --net0
virtio,bridge=vmbr0,tag=40 --onboot 1 --startup order=4
qm create 150 --name vm-bkp01  --ostype l26 --cores 2 --memory 4096 --scsi0 local-zfs:32  --net0
virtio,bridge=vmbr0,tag=40 --onboot 1 --startup order=5
qm create 140 --name vm-mon01  --ostype l26 --cores 2 --memory 2048 --scsi0 local-zfs:30  --net0
virtio,bridge=vmbr0,tag=40 --onboot 1 --startup order=5
qm create 160 --name vm-hpot01 --ostype l26 --cores 1 --memory 1024 --scsi0 local-zfs:16  --net0
virtio,bridge=vmbr0,tag=50 --onboot 1 --startup order=6
qm list
```

Paso 5. Firewall virtual e IDS. Se instala OPNsense con Suricata en VM-FW01 según S2-E2 §4.2 y §6.1. Se activa el firewall de Proxmox en las VM de la VLAN 40 para microsegmentar: solo 1514/1515 hacia VM-SIEM01, 19999 hacia VM-MON01 y 8007 hacia VM-BKP01 desde PVE01.

Paso 6. Migrar la capa de la academia a VM-APP01.

```
# En VM-APP01 (Ubuntu 24.04): Node 22, MySQL 8, Python 3.11 y PM2 instalados
node scripts/restore.js --archivo <último respaldo>.sql --destino cermat_db --confirmar-produccion
node scripts/db-crear-usuarios.js            # lee las contraseñas de variables de entorno
npm run build && npm run pm2:start && pm2 startup systemd && pm2 save
pm2 start scripts/backup.js --name cermat-backup --cron "0 2 * * *" --no-autorestart
```

Luego se ajusta `CORS_ORIGINS` al dominio de Vercel y, desde el panel de administración, se cambia la URL de la API y de la analítica (`config/services`) a los subdominios publicados por el proxy del VPS (sección 4.4).

Paso 7. Respaldo de VM en PBS. Agregar el almacenamiento PBS en *Datacenter* → *Storage* con su huella digital. Programar un trabajo diario a las 03:00 para todas las VM, con retención de 7 diarias, 4 semanales y 3 mensuales, cifrado del cliente (la llave se guarda fuera de línea) y verificación semanal.

Criterio de aceptación	Resultado obtenido	Evidencia a adjuntar
`qm list` con las 7 VM y sus etiquetas; `bond0` con 2 enlaces activos; VM-APP01 responde `/health`; primer respaldo de PBS verificado	Pendiente de ejecución	Captura del resumen del host, `/etc/network/interfaces` sanitizado, salida de `qm list` y de `/proc/net/bonding/bond0` y registro del trabajo de PBS

4. Implementación del entorno de nube

4.1 VPS (equivalente a EC2): implementado

Elemento	Configuración	Fuente
Proveedor y plan	RackNerd, VPS KVM (US$ 35,99 al año)	Manual del propietario

Elemento	Configuración	Fuente
Recursos y región	2 vCPU, 2 GB de RAM, 35 GB SSD; New York, EE. UU.	Manual
Sistema operativo	Ubuntu 24.04 LTS de 64 bits	Manual
Administración	Usuario Linux no-root con sudo; SSH (22/tcp)	Manual
Frontend	Angular compilado, servido por Nginx en el dominio y en www	Manual; PR-05
Backend	Laravel con PHP 8.4-FPM en el subdominio `api`, con comprobación `/up`	Manual; PR-05
Base de datos	PostgreSQL 16.15 solo en loopback; base `cermat_produccion`; usuario de aplicación propietario de su base, sin superusuario	Manual; PR-02
Esquema	Importado en una transacción; 116 migraciones aplicadas	Manual
Permisos	Grupo `www-data`, sin 777; `.env` con permisos 640	Manual
Firewall de host	UFW: entrada denegada; 22, 80 y 443/tcp	Manual; PR-01
TLS	Let's Encrypt (Certbot) en el dominio, www y api; redirección de HTTP a HTTPS; renovación automática probada	Manual; PR-03 a PR-08
DNS	Punto.pe (servidores de RCP): A para el dominio y `api`, CNAME para `www`; MX de Google y TXT conservados	Manual; PR-11

4.2 Equivalencias AWS con su evidencia

Elemento AWS	Implementación	Evidencia	Estado
EC2	VPS KVM	Sección 4.1	Implementado
Security Group	UFW	PR-01	Implementado
NACL	nftables sin estado o filtro del proveedor	Sección 4.4	Pendiente
VPC: subred pública e Internet Gateway	Interfaz pública y enrutamiento del proveedor	Sitios accesibles (PR-05)	Implementado (provisto)
VPC: subred privada	`dum0` 10.20.0.0/24	S2-E2 §3, paso 1	Pendiente
Route tables	Tabla `main` y tabla 220 de strongSwan	`ip route show table 220`	Pendiente
NAT Gateway	No requerido	—	No aplica

Elemento AWS	Implementación	Evidencia	Estado
IAM	Usuarios Linux, roles de bases, claims de Firebase y cuentas de servicio	Sección 5	Parcial

4.3 Servicios PaaS: implementados

Servicio	Estado	Evidencia
Vercel (SPA)	En producción; último despliegue el 2026-10-15; redirección 308 a HTTPS y HSTS con preload	PR-13; panel de Vercel
Firebase Authentication	En producción; administradores por claim; invitaciones de un solo uso	`firestore.rules`; 8 perfiles
Cloud Firestore	22 colecciones con reglas por rol; versión corregida probada 19/19 y publicada el 2026-10-24	`tests/firestore-rules/reglas.test.ts`; verificación sin sesión en producción (E4 §2.7)
Firebase Storage	En producción	Consola de Firebase

4.4 Pendiente en la nube

Estado: pendiente de ejecución.

1. **Red interna y VPN:** procedimiento de S2-E2 §3.
2. **NACL** con nftables sin estado, sustituyendo `eth0` por la interfaz real y validando antes que no afecte al tráfico IPsec:

```
# /etc/nftables.d/nacl.nft
table netdev nacl {
  chain ingreso {
    type filter hook ingress device "eth0" priority -500; policy accept;
    ip saddr { 0.0.0.0/8, 127.0.0.0/8, 169.254.0.0/16, 192.0.2.0/24, 198.51.100.0/24,
203.0.113.0/24, 224.0.0.0/4, 240.0.0.0/4 } drop
    tcp flags & (fin|syn) == (fin|syn) drop
    tcp flags & (syn|rst) == (syn|rst) drop
  }
}
```

3. **Memoria:** medir la línea base (sección 9.3) y crear un archivo de intercambio de 2 GB si `swapon --show` no muestra ninguno.
4. **Proxy de la API de la academia.** Ejemplo para el subdominio propuesto; la analítica sigue el mismo patrón hacia el puerto 8000:

```
limit_req_zone $binary_remote_addr zone=api_academia:10m rate=10r/s;
server {
    listen 443 ssl;
    server_name api-academia.cermatschool.edu.pe;   # propuesto; certificado con Certbot
    server_tokens off;
    location = /health { proxy_pass http://10.10.40.10:3001/health; proxy_bind 10.20.0.1; }
    location /api/ {
        limit_req zone=api_academia burst=20 nodelay;
        proxy_pass http://10.10.40.10:3001;
        proxy_bind 10.20.0.1;
        proxy_set_header Host $host;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto https;
        proxy_connect_timeout 5s;
        proxy_read_timeout 15s;
        client_max_body_size 1m;
    }
    location / { return 404; }
}
```

En el código de la API debe configurarse `trust proxy` para registrar la IP real del cliente; es un cambio pendiente en el repositorio de la aplicación. 5. **Agentes:** Wazuh y Netdata hijo (S2-E2 §6.3 y §7.2).

Criterio de aceptación	Resultado obtenido	Evidencia a adjuntar
`nft list ruleset` con la tabla `nacl`; PR-27 conforme (`/health` responde 200 por el proxy y otras rutas 404); MemAvailable ≥ 25 % tras los agentes	Pendiente de ejecución	Salidas de `nft list ruleset`, `curl -I` y `free -m` antes y después

5. Gestión de identidades y accesos

Ámbito	Control	Estado	Evidencia
VPS	Usuario Linux no-root con sudo	Implementado	Manual
VPS	SSH solo con llaves y sin root	Por verificar	`sshd -T` (S2-E2 §4.3)
VPS	Secretos de Laravel en `.env` con permisos 640	Implementado	Manual
PostgreSQL	Usuario de aplicación propietario de su base, sin superusuario	Implementado	Manual (`\du`)
MySQL	4 roles de mínimo privilegio; `cermat_api` sin DML directo	Implementado en la base de prueba y en la base real (2026-10-24): cuentas `cermat_api`, `cermat_analitica` y `cermat_respaldo`, con contraseñas solo en `.env.local` no versionados	`server/src/db/04_seguridad.sql`; error 1142 verificado en la base real
MySQL	Contraseñas solo en variables de entorno, con un mínimo de 12 caracteres	Implementado en los scripts	`server/scripts/db-crear-usuarios.js`

Ámbito	Control	Estado	Evidencia
Firebase	Claim de administrador; roles solo con invitación vigente	Implementado y publicado (2026-10-24)	`firestore.rules` y 8 pruebas de roles
Google Cloud	Cuenta de servicio del CI con rol mínimo (*Firebase Rules Admin*), en el entorno protegido `produccion`	Definido en el CI; configuración del secreto por confirmar	`.github/workflows/ci.yml`
Google Cloud	Rotación de la clave expuesta en copias ZIP	Hecho (2026-10-24): clave `283b43c3…` eliminada y reemplazada por `ddf50bfe…`	NC-03
Proveedores	MFA en Google, GitHub, Vercel, RackNerd y Punto.pe	No verificado	NC-07
Proxmox, OPNsense y Wazuh	Usuarios nominativos con TOTP; root solo por consola	Planificado	Sección 3
VPN	Certificados X.509 propios; llaves privadas fuera de Git	Planificado	S2-E2 §3

Equivalencia con AWS IAM.

AWS IAM	Equivalente en este proyecto
Usuarios y grupos	Usuarios Linux nominativos y el grupo `sudo`
Roles y políticas	Roles de MySQL y PostgreSQL; claims de Firebase; roles IAM de las cuentas de servicio de Google Cloud
MFA	Segundo factor en las consolas y TOTP en Proxmox, OPNsense y Wazuh
Rotación de credenciales	Calendario de S2-E1 §10.4
Llaves de acceso	Llaves SSH ed25519 por persona; secretos de GitHub con rol mínimo

Accesos administrativos. Al hipervisor y al firewall solo se entra desde ADMIN_TI o el bastión, por la VLAN 99 (FW-20, FW-50). Al VPS, solo desde el bastión por la VPN, una vez cerrado 22/tcp a Internet (UFW-08 y UFW-09). La revisión trimestral de accesos sigue S2-E1 §10.5.

---

6. Inventario final de activos

ID	Activo	Propietario	Ubicación	Criticidad	Estado al 2026-10-24	Evidencia
ACT-01	Datos personales de alumnos y apoderados (users, enrollments, students; réplica alumnos)	Dirección de la academia	Firestore (Google) y réplica MySQL	Alta	Operativo	Reglas por rol en firestore.rules; 8 perfiles y 8 matrículas (conteo agregado al 2026-10-24)
ACT-02	Datos de pagos (payments; tabla pagos)	Dirección de la academia	Firestore y MySQL	Alta	Operativo	2 pagos confirmados (conteo agregado); triggers de auditoría en MySQL
ACT-03	Registros de asistencia (attendanceLogs, attendanceDayState, parentAttendance; tabla asistencia)	Dirección de la academia	Firestore y MySQL	Alta	Operativo	7 registros (conteo agregado); sp_registrar_asistencia idempotente
ACT-04	Contenido público (ciclos, sedes, posts, recursos y talleres)	Dirección de la academia	Firestore y Storage	Media	Operativo	Sitio público en Vercel (200 OK, 2026-10-24)
ACT-05	Configuración de servicios (config/services)	Líder técnico	Firestore	Alta	Operativo	src/lib/syncService.ts lee config/services
ACT-06	Reglas de seguridad de Firestore	Líder técnico	Repositorio Git y Firebase	Alta	Operativo (publicada 2026-10-24)	firestore.rules y 19 pruebas; versión corregida publicada el 2026-10-24 (reemplazó la del 22-jun-2026)
ACT-07	Código fuente, pruebas y pipeline CI	Líder técnico	GitHub (repositorio privado)	Alta	Operativo	.github/workflows/ci.yml (6 trabajos); 90 pruebas

ID	Activo	Propietario	Ubicación	Criticidad	Estado al 2026-10-24	Evidencia
ACT-08	Secretos y credenciales (cuenta de servicio, contraseñas de BD, llaves SSH, credenciales de VPN)	Líder técnico	Gestor de contraseñas y servidores	Alta	Operativo (clave rotada 2026-10-24)	db-crear-usuarios.js lee contraseñas del entorno; clave de servicio rotada (H-03 corregido)
ACT-09	Respaldos (MySQL, PostgreSQL, Firestore y VM)	Responsable de respaldos	PC local, VPS, PBS y disco externo	Crítica	Parcial (solo MySQL)	backup.js y restore.js; REC-01, REC-02 y REC-05 (base real)
ACT-10	Datos del sistema del colegio (PostgreSQL cermat_produccion)	Dirección del colegio	VPS (New York)	Crítica	Operativo	Manual del VPS (2026-10-17): 116 migraciones, base solo en loopback
ACT-11	Registros de eventos (API, Nginx, autenticación, firewall, IDS y SIEM)	Responsable de seguridad	VPS, PC local y VM-SIEM01	Alta	Parcial (sin centralizar)	morgan en server/src/index.ts; registros de Nginx en el VPS
ACT-12	Documentación técnica y del SGSI	Líder técnico	Repositorio público de documentación	Baja	Operativo	Este sitio de documentación
ACT-13	Plataforma web de la academia (SPA en Vercel)	Dirección de la academia	Vercel	Alta	Operativo	PR-13: HTTPS y HSTS con preload (2026-10-24)
ACT-14	Firebase Authentication (cuentas y claims)	Dirección de la academia	Google Cloud	Crítica	Operativo	Claim de administrador; invitaciones de un solo uso
ACT-15	Cloud Firestore y Storage	Dirección de la academia	Google Cloud	Crítica	Operativo	22 colecciones con reglas por rol
ACT-16	API de sincronización y servicio de analítica	Líder técnico	PC local (destino: VM-APP01)	Alta	Transitorio	helmet, CORS y morgan en server/src/index.ts; 18 pruebas

ID	Activo	Propietario	Ubicación	Criticidad	Estado al 2026-10-24	Evidencia
ACT-17	Base MySQL 8 (réplica relacional)	Líder técnico	PC local (destino: VM-APP01)	Alta	Transitorio	Roles de 04_seguridad.sql; 19 pruebas SQL
ACT-18	Sistema de gestión del colegio (Angular y Laravel)	Dirección del colegio	VPS	Alta	Operativo	PR-05: 200 en web y /up (2026-10-24)
ACT-19	VPS RackNerd (Ubuntu 24.04, UFW, Nginx y Certbot)	Dirección del colegio	New York (proveedor)	Crítica	Operativo	Manual del VPS; PR-01 a PR-09
ACT-20	PC local con PM2 (servicios transitorios)	Dirección de la academia	PC local (ubicación por confirmar)	Alta	Transitorio	npm run pm2:start en server/package.json
ACT-21	Host hipervisor PVE01 y sus VM	Dirección de la academia	Rack de la sede	Crítica	Planificado	Diseño S1-E2; pendiente de implementación
ACT-22	Firewall OPNsense con Suricata	Dirección de la academia	VM-FW01	Alta	Planificado	Diseño S1-E1 §13; pendiente
ACT-23	Red local: switch, AP y cableado	Dirección de la academia	Sede principal	Alta	Planificado	Diseño S1-E1 §8; pendiente
ACT-24	Túnel IPsec sede ↔ VPS	Líder técnico	OPNsense y VPS	Alta	Planificado	Diseño S1-E1 §10; pendiente
ACT-25	SIEM Wazuh	Responsable de seguridad	VM-SIEM01	Alta	Planificado	Diseño S1-E1 §14; pendiente
ACT-26	Monitoreo (Uptime Kuma y Netdata)	Encargado de TI	VM-MON01	Media	Planificado	Diseño S1-E2 §11; pendiente
ACT-27	Repositorio de respaldos (PBS) y disco externo	Responsable de respaldos	Sede y custodia externa	Crítica	Planificado	Diseño S1-E2 §11; pendiente
ACT-28	Honeypot Cowrie	Responsable de seguridad	VM-HPOT01 en la DMZ	Baja	Planificado	Diseño S1-E1 §14; pendiente
ACT-29	Dominio y DNS (cermatschool.edu.pe en Punto.pe)	Dirección del colegio	Punto.pe / RCP	Alta	Operativo	PR-11 y PR-12 (NS en RCP, MX de Google; sin CAA, SPF ni DMARC)

ID	Activo	Propietario	Ubicación	Criticidad	Estado al 2026-10-24	Evidencia
ACT-30	Cuentas administrativas de proveedores (Google/Firebase, GitHub, Vercel, RackNerd y Punto.pe)	Dirección	Proveedores en la nube	Alta	Operativo (MFA no verificado)	Revisión de MFA pendiente
ACT-31	Equipos de usuario (PC administrativas, laptops y dispositivos de auxiliares)	Dirección de la academia	Sede principal	Media	Operativo (por inventariar)	Antivirus activo en la PC local (cuarentena registrada en INC-03)
ACT-32	Personal clave (administrador del sistema, encargado de TI y equipo técnico)	Dirección	Sede y trabajo remoto	Alta	Operativo	Matriz RACI (S2-E1 §4.2)
ACT-33	Cuarto de equipos, rack y UPS	Dirección de la academia	Sede principal, Azángaro	Media	Planificado	Diseño de rack (S1-E2 §5)

Estado del inventario: 17 activos operativos sin observaciones, 3 transitorios (PC local, API y MySQL locales), 9 planificados (infraestructura de la sede) y 4 operativos con observaciones (respaldos y registros parciales, MFA no verificado y equipos por inventariar). Las reglas de Firestore (ACT-06) y los secretos (ACT-08) dejaron de tener observaciones el 2026-10-24.

7. Continuidad: respaldo, restauración y recuperación

7.1 Respaldo implementado (MySQL)

`server/scripts/backup.js` ejecuta `mysqldump --single-transaction --quick --routines --triggers --events --no-tablespaces` con la cuenta de solo lectura `cermat_respaldo`. La contraseña viaja en `MYSQL_PWD`, no como argumento. El script genera el `.sql` junto con su `.sha256` y conserva los 7 más recientes. Se programa con `pm2 start scripts/backup.js --name cermat-backup --cron "0 2 * * *" --no-autorestart`; esa programación en la PC productiva **está por verificar**.

7.2 Restauración probada (ejercicios reales)

`server/scripts/restore.js` verifica el `.sha256`, restaura en `cermat_db_verificacion`, mide el RTO, compara filas, rutinas, triggers y vistas con el origen y anota cada prueba en `registro-restauraciones.jsonl`. Se niega a restaurar sobre la base productiva sin `--confirmar-produccion`.

Registro real de las dos ejecuciones del 2026-10-24, en una instancia MySQL 8.0.30 aislada con datos de prueba. Contiene solo conteos, sin datos personales; las horas están en UTC (07:23 UTC equivale a 02:23 en Perú):


```
{"fecha":"2026-10-24T07:23:48.414Z","respaldo":"cermat_db_2026-10-24T07-23-
46.sql","integridad":"sha256
verificado","destino":"cermat_db_verificacion","rto_segundos":0.38,"filas":
{"alertas":0,"alumnos":1,"asistencia":3,"auditoria":1,"ciclos":1,"matriculas":3,"pagos":3,"schema_migr
aciones":3},"rutinas":10,"triggers":6,"vistas":3,"objetos_completos":true}
{"fecha":"2026-10-24T07:47:35.344Z","respaldo":"cermat_db_2026-10-24T07-47-
34.sql","integridad":"sha256
verificado","destino":"cermat_db_verificacion","rto_segundos":0.27,"filas":
{"alertas":0,"alumnos":1,"asistencia":2,"auditoria":1,"ciclos":1,"matriculas":3,"pagos":3,"schema_migr
aciones":3},"rutinas":9,"triggers":6,"vistas":3,"objetos_completos":true}
```


El origen cambió entre las dos ejecuciones porque se ajustaron las migraciones (de ahí la diferencia en rutinas y filas); en ambas, la base restaurada coincidió con su origen. También se verificó que la restauración rechaza un archivo alterado y que no escribe sobre la base productiva sin confirmación (REC-03 y REC-04). **Limitación:** son bases de prueba con pocas filas.

REC-05, base real (2026-10-24, 16:35 en Perú): después de aplicar las migraciones en `cermat_db`, `backup.js` generó el respaldo con la cuenta de solo lectura `cermat_respaldo` y `restore.js` lo restauró en `cermat_db_verificacion`. Registro de la ejecución (solo conteos):


```
{"fecha":"2026-10-24T21:35:08.790Z","respaldo":"cermat_db_2026-10-24T21-35-
08.sql","integridad":"sha256
verificado","destino":"cermat_db_verificacion","rto_segundos":0.23,"filas":
{"alertas":0,"alumnos":0,"asistencia":0,"auditoria":0,"ciclos":0,"matriculas":1,"pagos":1,"schema_migr
aciones":3},"rutinas":9,"triggers":6,"vistas":3,"objetos_completos":true}
```


La base real tiene hoy muy pocas filas porque la réplica solo recibe eventos cuando la capa local está encendida. Por eso el RTO de 0,23 s mide sobre todo la estructura y debe volver a medirse cuando la réplica tenga volumen.

7.3 Recuperación de una VM (REC-07)

Pendiente de ejecución.

1. Desde PBS, restaurar el último respaldo de VM-APP01 con un ID nuevo.
2. Iniciarla con la red desconectada: `qm set <id> --net0 virtio,bridge=vmbr0,tag=40,link_down=1`.
3. Verificar por consola los servicios (`pm2 status` y `curl localhost:3001/health`).
4. Medir el tiempo total y eliminar la VM de prueba.

Criterio de aceptación: ≤ 2 h. Evidencia a adjuntar: registro de la tarea de PBS y captura de `/health`.

7.4 Recuperación de un recurso de nube (REC-06 y REC-08)

Pendiente de ejecución. Primero se implantan los respaldos del VPS (NC-04):

```
#!/usr/bin/env bash
# /usr/local/sbin/respaldo-pg.sh — usuario postgres, desde cron a las 01:30
set -euo pipefail
DEST=/var/backups/pg
ARCHIVO="cermat_produccion_$(date +%F).dump"
pg_dump -Fc -d cermat_produccion -f "$DEST/$ARCHIVO"
pg_restore --list "$DEST/$ARCHIVO" > /dev/null        # comprueba que el archivo es legible
( cd "$DEST" && sha256sum "$ARCHIVO" >> SHA256SUMS )
find "$DEST" -name 'cermat_produccion_*.dump' -mtime +7 -delete
```

```
# /etc/cron.d/respaldo-pg
30 1 * * * postgres /usr/local/sbin/respaldo-pg.sh
```

Mientras no exista el túnel, se copia cada semana el último volcado a un medio cifrado fuera del VPS. Después, VM-BKP01 lo extrae cada día por el túnel (flujo F-10).

REC-06 — Restauración en una base de verificación:

```
sudo -u postgres createdb -O <usuario_app> cermat_verificacion
sudo -u postgres pg_restore -d cermat_verificacion --no-owner --role=<usuario_app>
/var/backups/pg/<archivo>.dump
sudo -u postgres psql -d cermat_verificacion -c "SELECT count(*) FROM migrations;"   # esperado: 116
sudo -u postgres dropdb cermat_verificacion
```

REC-08 — Reconstrucción completa del VPS: en una VM de prueba con Ubuntu 24.04, seguir el manual de despliegue, restaurar el último volcado y validar la web y la API apuntando un archivo `hosts` local a la VM. Se registra el tiempo de cada paso. Criterio: ≤ 8 h.

7.5 Recuperación de la VPN ante una interrupción simulada (REC-09)

Pendiente de ejecución. En el VPS, `sudo swanctl --terminate --ike sede-azangaro`, o bien desconectar WAN1 en la sede. OPNsense, con acción de inicio *start* y DPD *restart*, debe restablecer el túnel solo. Se mide el tiempo con `journalctl -u strongswan -f` y con la alerta y recuperación de Uptime Kuma. Criterio: ≤ 2 min. Evidencia: extracto del registro con las horas.

7.6 Firestore y frontend (REC-10 y REC-11)

Pendiente de ejecución.

- **Firestore:** si el plan es Blaze, `gcloud firestore export gs://<bucket>/<fecha>` programado a diario y `gcloud firestore import` en un proyecto de prueba. Si es Spark, un script con `firebase-admin` que exporte las colecciones a JSON cifrado y las cargue en el emulador. En ambos casos se comparan los conteos con los indicadores agregados (8 matrículas, 2 pagos, 7 registros de asistencia y 8 perfiles). Los usuarios se respaldan con `firebase auth:export` y el archivo, que incluye hashes de contraseñas, se cifra.
- **Vercel:** promover el despliegue anterior desde el panel y medir el tiempo (criterio: ≤ 15 min).

7.7 Registro de pruebas de recuperación

ID	Fecha y hora	Escenario	Componente	Procedimiento	RTO objetivo	RPO objetivo	RTO medido	Verificación	Resultado	Estado	Evidencia
REC-01	2026-10-24 02:23 (UTC−5)	Pérdida de la base relacional (restauración en base de verificación)	MySQL 8.0.30 de prueba (cermat_db con datos de prueba)	node scripts/backup.js y node scripts/restore.js	< 1 h	≤ 24 h	0,38 s	SHA-256 verificado. Filas: alumnos 1, ciclos 1, matrículas 3, pagos 3, asistencia 3, auditoría 1, alertas 0, schema_migraciones 3. 10 rutinas, 6 triggers y 3 vistas; objetos completos	Recuperación completa	Ejecutado	registro-restauraciones.jsonl (respaldo cermat_db_2026-10-24T07-23-46.sql)
REC-02	2026-10-24 02:47 (UTC−5)	Igual que REC-01, tras las migraciones finales	MySQL 8.0.30 de prueba	node scripts/backup.js y node scripts/restore.js	< 1 h	≤ 24 h	0,27 s	SHA-256 verificado. Asistencia 2 filas; 9 rutinas, 6 triggers y 3 vistas; objetos completos	Recuperación completa	Ejecutado	registro-restauraciones.jsonl (respaldo cermat_db_2026-10-24T07-47-34.sql)
REC-03	2026-10-24	Respaldo alterado (prueba negativa)	restore.js	Modificar el .sql y ejecutar restore.js	Rechazo	—	—	Mensaje: no coincide con su .sha256	Rechazado correctamente	Ejecutado	E2 §4.3

ID	Fecha y hora	Escenario	Componente	Procedimiento	RTO objetivo	RPO objetivo	RTO medido	Verificación	Resultado	Estado	Evidencia
REC-04	2026-10-24	Restauración accidental sobre producción (prueba negativa)	restore.js	--destino cermat_db sin --confirmar-produccion	Rechazo	—	—	Se niega a restaurar sobre la base productiva	Rechazado correctamente	Ejecutado	E2 §4.3
REC-05	2026-10-24 16:35 (UTC−5)	Restauración con la base real del equipo	MySQL 8.0.30 (PC local, `cermat_db`)	node scripts/backup.js (cuenta `cermat_respaldo`) y node scripts/restore.js hacia cermat_db_verificacion	< 1 h	≤ 24 h	0,23 s	SHA-256 verificado. Filas: matrículas 1, pagos 1, schema_migraciones 3, resto 0. 9 rutinas, 6 triggers y 3 vistas; objetos completos	Recuperación completa	Ejecutado	registro-restauraciones.jsonl (respaldo cermat_db_2026-10-24T21-35-08.sql); captura de consola por adjuntar
REC-06	Pendiente	Pérdida de la base del colegio	PostgreSQL 16 (VPS)	pg_dump -Fc y sha256sum; pg_restore --list; restaurar en base de verificación; comparar conteos (116 migraciones)	2 h	≤ 24 h	—	—	Pendiente de ejecución	Pendiente	A adjuntar: salida de pg_restore y conteos

ID	Fecha y hora	Escenario	Componente	Procedimiento	RTO objetivo	RPO objetivo	RTO medido	Verificación	Resultado	Estado	Evidencia
REC-07	Pendiente	Pérdida de una VM	VM-APP01 en Proxmox	Restaurar desde PBS con un ID nuevo y red aislada; verificar /health	2 h	≤ 24 h	—	—	Pendiente de ejecución	Pendiente	A adjuntar: registro de la tarea de PBS
REC-08	Pendiente	Pérdida total del VPS (recurso de nube)	VPS	Reconstruir en una VM de prueba con el manual y el último respaldo; validar web y API	8 h	≤ 24 h	—	—	Pendiente de ejecución	Pendiente	A adjuntar: bitácora con tiempos por paso
REC-09	Pendiente	Interrupción simulada del túnel	IPsec OPNsense ↔ VPS	swanctl --terminate --ike sede-azangaro en el VPS, o desconectar WAN1	≤ 2 min automático; 1 h manual	No aplica	—	—	Pendiente de ejecución	Pendiente	A adjuntar: registro de IPsec y alerta de Uptime Kuma
REC-10	Pendiente	Despliegue defectuoso del frontend	Vercel	Promover el despliegue anterior	15 min	0	—	—	Pendiente de ejecución	Pendiente	A adjuntar: historial de despliegues

ID	Fecha y hora	Escenario	Componente	Procedimiento	RTO objetivo	RPO objetivo	RTO medido	Verificación	Resultado	Estado	Evidencia
REC-11	Pendiente	Pérdida de datos operativos	Firestore	Exportar e importar en emulador o proyecto de prueba; comparar conteos agregados	4 h	≤ 24 h	—	—	Pendiente de ejecución	Pendiente	A adjuntar: conteos antes y después
REC-12	Pendiente	Pérdida del firewall virtual	VM-FW01	VM nueva y restaurar config.xml; repetir PR-16 y PR-17	2 h	Último config.xml	—	—	Pendiente de ejecución	Pendiente	A adjuntar: captura y resultado de las pruebas

8. RTO y RPO: objetivos frente a resultados

Servicio	RTO objetivo	RTO obtenido	RPO objetivo	RPO evidenciado	Conclusión
MySQL (base de prueba)	< 1 h	0,38 s (REC-01) y 0,27 s (REC-02)	≤ 24 h	Respaldo bajo demanda	Cumple en la base de prueba
MySQL (base real)	< 1 h	0,23 s (REC-05)	≤ 24 h	Respaldo bajo demanda; el respaldo diario falta programarlo, así que hoy el RPO no está acotado	RTO cumple; RPO pendiente de programar
PostgreSQL del colegio	2 h	Pendiente (REC-06)	≤ 24 h	Sin respaldos implantados: hoy el RPO no está acotado	**No cumple** (NC-04)
VM en PBS	2 h	Pendiente (REC-07)	≤ 24 h	Pendiente	—
VPS completo	8 h	Pendiente (REC-08)	≤ 24 h	Pendiente	—
VPN	≤ 2 min automático	Pendiente (REC-09)	No aplica	—	—
SPA (Vercel)	15 min	Pendiente (REC-10)	0	Código en Git	—

Servicio	RTO objetivo	RTO obtenido	RPO objetivo	RPO evidenciado	Conclusión
Firestore	4 h	Pendiente (REC-11)	≤ 24 h	Sin exportación programada	**No cumple** (NC-06)

9. Monitoreo y control operativo

9.1 Implementado

- `GET /health` de la API y de la analítica (estado de MySQL y tiempo en línea), visible en el panel admin "Infraestructura".
- Rutinas del manual del VPS:
  - **Diaria:** acceso, respaldos, disco y errores.
  - **Semanal:** actualizaciones, registros y certificados.
  - **Mensual:** restauración de prueba, capacidad y accesos.
- Tabla de diagnóstico por síntoma (502, 500, 503, 403, 413 y certificados) y lista de comandos prohibidos como reparación (`migrate:fresh`, reimportar el esquema, `key:generate`, `chmod 777`, abrir PostgreSQL).
- Panel de Vercel y consola de Firebase para el uso de los servicios PaaS.

9.2 Métricas y alertas planeadas (equivalente a CloudWatch)

Métrica	Fuente	Umbral de alerta	Acción
CPU del host PVE01	Netdata	> 85 % durante 10 min	Revisar las VM; redistribuir recursos
RAM del host	Netdata	> 80 %	Revisar el ARC de ZFS y las VM
Disco `local-zfs`	Netdata y `zpool list`	> 70 % advertencia; > 80 % crítico	Depurar o ampliar
Estado del espejo ZFS	`zpool status` (ZED)	DEGRADED	Reemplazar el disco en 72 h
Datastore de PBS	PBS	> 80 % o verificación fallida	Depuración, recolección de basura y revisión
RAM del VPS	Netdata y Wazuh	MemAvailable < 25 %	Riesgo R-08
Disco del VPS	Netdata	> 80 %	Rotar registros y respaldos
Certificados	Uptime Kuma	Vencen en menos de 14 días	Revisar Certbot
Disponibilidad web y de API	Uptime Kuma	2 fallas seguidas	PRO-01
Túnel IPsec	Uptime Kuma	3 minutos sin respuesta	REC-09
UPS	NUT	En batería más de 5 min o carga < 30 %	Apagado ordenado
Eventos de seguridad	Wazuh	Nivel ≥ 10	Notificación inmediata

Equivalencias: Netdata cubre las métricas de host (CPU, RAM, disco y red) que daría CloudWatch Metrics; Uptime Kuma, las comprobaciones sintéticas y alarmas; Wazuh, los registros y eventos (CloudWatch Logs).

9.3 Línea base de capacidad del VPS

Pendiente de ejecución. Comandos que se ejecutan en hora pico y en hora valle para validar el presupuesto de RAM de S1-E2 §10.5:

```
free -m; swapon --show; df -h /; uptime
ps -eo rss,comm --sort=-rss | head -n 12
```

Criterio de aceptación	Resultado obtenido	Evidencia a adjuntar
Valores registrados en dos horarios; MemAvailable ≥ 25 % antes de agregar agentes	Pendiente de ejecución	Salida de los comandos con fecha y hora

10. Control de cambios y gestión de configuración

10.1 Repositorio y estructura

Ya versionado en Git:

- `firestore.rules` con 19 pruebas.
- `.github/workflows/ci.yml` (6 trabajos).
- `server/src/db/` (migraciones numeradas, pruebas y su README).
- `server/scripts/backup.js`, `restore.js` y `db-crear-usuarios.js`.
- `.github/pull_request_template.md`.
- En el repositorio de documentación: diagramas, matrices y `scripts/generar-matrices-infra.mjs`.

Estructura propuesta para la configuración de infraestructura, con carpetas separadas para diagramas, hipervisor (ESXi en la guía), nube (AWS en la guía), scripts y registros:

```
infra/
├── README.md            # orden de despliegue, reconstrucción, qué no se versiona
├── diagramas/           # .drawio
├── cd/
│   ├── proxmox/         # interfaces sanitizado, comandos qm, trabajos de PBS (≡ ESXi)
│   └── nube/            # inventario del VPS, UFW, nftables, Nginx, respaldo-pg.sh (≡ AWS)
├── red/                 # ver S2-E2
├── scripts/             # verificación y respaldo
└── logs/                # salidas de pruebas y de restauración, con fecha
```

El README debe indicar el propósito de cada carpeta, el orden de despliegue (host → OPNsense → bastión → SIEM → aplicaciones → túnel), cómo reconstruir cada componente, qué secretos existen y dónde se guardan (nunca en Git), y cómo ejecutar las pruebas PR y REC.

10.2 Historial de cambios relevantes

Fecha	Cambio	Componente	Evidencia
2026-06-22	Publicación de las reglas de Firestore que estuvieron en producción hasta el 2026-10-24	Firestore	Ruleset identificado por id y fecha (E4 §1.6)
2026-06-22	Respaldo de MySQL `cermat_db_2026-06-22T16-29-01.sql`	MySQL (PC local)	Carpeta `backups/` del repositorio
2026-10-15	Frontend que estuvo en producción hasta el 2026-10-24 (fecha de su cabecera Last-Modified)	Vercel	Historial de despliegues
2026-10-17	Despliegue del sistema del colegio: Nginx, TLS, UFW y PostgreSQL	VPS	Manual del propietario
2026-10-24	Migraciones MySQL 02 a 04, scripts de respaldo y restauración, CI y corrección de reglas (publicada el mismo día, ver la fila siguiente)	Repositorio de la aplicación	Commit `05fbe9e`
2026-10-24	Frontend publicado (commit `c06f5a2`) con cabeceras de seguridad, tras dos despliegues bloqueados en Vercel; reglas de Firestore publicadas; clave de servicio rotada; `www.cermatschool.edu.pe` retirado del proyecto de Vercel	Vercel, Firebase y Google Cloud	E4 §2.7
2026-10-24	Reestructuración de la documentación de infraestructura, matrices y diagramas	Repositorio de documentación	Este conjunto de documentos

10.3 PRO-02 · Procedimiento de gestión de cambios

1. **Solicitud:** issue o PR con la plantilla (qué cambia, por qué y cómo revertirlo).
2. **Evaluación:** impacto en los riesgos y en la SoA; los cambios en reglas, firewall, VPN o bases son "de seguridad".
3. **Respaldo previo:** `backup.js`, `pg_dump`, `config.xml` o snapshot de la VM, según el componente.
4. **Prueba** en un entorno de prueba: emulador de Firestore, `cermat_prueba`, VM clonada o laboratorio.
5. **Aprobación:** un segundo integrante; la Dirección en los cambios mayores.
6. **Ejecución** en una ventana acordada; en el VPS se sigue el procedimiento de actualización sin pérdida del manual.

7. **Verificación:** se repiten las pruebas PR o REC afectadas y se compara lo publicado con lo versionado.
8. **Cierre:** registro en el historial y actualización de la documentación y del inventario.

10.4 Hallazgos del control de cambios

- Un solo autor en el historial y mensajes de commit genéricos ("mejoras").
- Sin revisiones registradas en la plantilla de PR.
- El CI aún no se ejecutó en GitHub.
- Secretos en el historial: revocados el 2026-10-24; los `.env`, sin contraseñas, siguen versionados por decisión del equipo.
- Dos despliegues bloqueados en Vercel que el push no mostraba; se resolvió el 2026-10-24 y desde entonces se verifica la versión en producción tras cada cambio.

Se trataron como NC-02 y NC-03 (cerradas el 2026-10-24) y NC-08 (abierta) del SGSI.

---

11. Resultados, conclusiones, limitaciones, mejoras futuras y referencias

11.1 Resultados

Indicador	Valor
Componentes del CD en el diseño	36 (los de nube, operativos; los de la sede, pendientes)
Activos en el inventario final con evidencia	33
Ejercicios de recuperación ejecutados / pendientes	5 / 7
RTO medido de MySQL	0,23 s en la base real (REC-05) y 0,27–0,38 s en la base de prueba (objetivo < 1 h)
Servicios con RPO actualmente no acotado	2 (PostgreSQL del colegio y Firestore)

11.2 Conclusiones

1. La nube del diseño está operativa y con evidencia: el VPS equivale a EC2 con Security Group, TLS y la base no expuesta, y la plataforma PaaS funciona con HTTPS y HSTS.
2. La recuperación está demostrada para la base relacional con verificación de integridad y RTO medido, primero en una base de prueba y después en la base real (REC-05). Es el ejercicio completo que exige la guía; falta programar el respaldo diario para acotar el RPO.
3. Las dos mayores brechas de continuidad son reales y prioritarias: el colegio y Firestore no tienen respaldo implantado, así que su RPO no está acotado.

4. El entorno on-premise tiene un procedimiento reproducible (red, VM, PBS y migración), listo para ejecutarse en cuanto exista el hardware.

11.3 Limitaciones

- Sin el hardware de la sede no hay evidencia de hipervisor, VM ni VPN.
- La base real tiene hoy muy pocas filas, así que su RTO (0,23 s) debe volver a medirse cuando la réplica tenga volumen.
- Parte de la evidencia del VPS proviene del manual del propietario y faltan las capturas.

11.4 Mejoras futuras

- Laboratorio de validación con Proxmox (fase 1b).
- Segundo host y clúster cuando la operación lo justifique.
- Respaldo inmutable fuera del sitio.
- Pruebas de restauración automatizadas, con su resultado publicado en Uptime Kuma.

11.5 Referencias

[1] Proxmox Server Solutions GmbH, "Proxmox VE Administration Guide." [En línea]. Disponible en: https://pve.proxmox.com/pve-docs/

[2] Proxmox Server Solutions GmbH, "Proxmox Backup Server Documentation." [En línea]. Disponible en: https://pbs.proxmox.com/docs/

[3] PostgreSQL Global Development Group, "pg_dump" y "pg_restore," *PostgreSQL 16 Documentation*. [En línea]. Disponible en: https://www.postgresql.org/docs/16/

[4] Oracle Corporation, "mysqldump — A Database Backup Program," *MySQL 8.0 Reference Manual*. [En línea]. Disponible en: https://dev.mysql.com/doc/refman/8.0/en/

[5] M. Swanson, P. Bowen, A. W. Phillips, D. Gallup y D. Lynes, "Contingency Planning Guide for Federal Information Systems," NIST SP 800-34 Rev. 1, may. 2010.

[6] Amazon Web Services, "Amazon VPC User Guide" y "Amazon EC2 User Guide." [En línea]. Disponible en: https://docs.aws.amazon.com/

[7] Netdata Inc., "Netdata Documentation." [En línea]. Disponible en: https://learn.netdata.cloud/

[8] Uptime Kuma, "Uptime Kuma." [En línea]. Disponible en: https://github.com/louislam/uptime-kuma

[9] Google, "Export and import data — Cloud Firestore." [En línea]. Disponible en: https://firebase.google.com/docs/firestore/manage-data/export-import

[10] ISO/IEC 27001:2022, *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. Ginebra, Suiza: ISO, 2022.

Anexos

Anexo	Contenido	Ubicación
A	Registro de pruebas de recuperación	s2-e3-registro-prueba-recuperacion.xlsx
B	Inventario final de activos con evidencia	s2-e3-inventario-final-activos.xlsx
C	Diagrama del centro de datos (rack, hipervisor y nube)	arquitectura-centro-datos-hibrido.drawio
D	Scripts de respaldo y restauración	`server/scripts/backup.js` y `server/scripts/restore.js` del repositorio de la aplicación
E	Base de datos: migraciones, roles y pruebas	`server/src/db/` y E2 de Ingeniería de Software

Rúbrica de evaluación

N°	Criterio de evaluación	Peso
1	Trazabilidad con el diseño de centro de datos (Semestre 1)	6%
2	Implementación on-premise: hipervisor ESXi y VMs	18%
3	Implementación AWS: VPC, EC2, Security Groups y NACL	18%
4	Gestión de identidades y accesos del centro de datos	14%
5	Inventario final de activos con evidencia	12%
6	Continuidad: backup, restore y recuperación probada	14%
7	Monitoreo y control operativo del centro de datos	10%
8	Calidad documental, control de versiones y sustentación	8%
	Total	**100%**

Escala: Excelente 4, Logrado 3, En proceso 2, Insuficiente 1 y No evidenciado 0. Puntaje = peso × (nivel / 4).

Dónde se evidencia cada criterio

Criterio	Secciones
1	2

Criterio	Secciones
2	3 (Proxmox VE como equivalente de ESXi)
3	4 (VPS y PaaS como equivalentes de AWS)
4	5
5	6
6	7 y 8
7	9
8	10, anexos y exposición ante el jurado (pendiente)

Producto Final S2 · Informe de Implementación Integral y Operativa

Informe integral del Semestre 2 y evaluación de cierre de la línea

Integra los tres entregables del semestre: el SGSI (S2-E1), la implementación y las pruebas de red (S2-E2) y la implementación y el control del centro de datos (S2-E3). Incluye la presentación ejecutiva, las evidencias unificadas, la trazabilidad con el diseño consolidado del Semestre 1 y la evaluación de cierre de la línea de Infraestructura.

Portada

Campo	Detalle
Título	Informe de implementación integral y operativa de la infraestructura híbrida de CERMAT
Entregable	Producto final del Semestre 2 (CE031, CE032 y CE033)
Estudiantes	David Robert Yucra Mamani (líder), Gladys Rosaura Yana Pari, Denilson Leeke Mamani Flores, Cárdenas Vilca Rennzo
Semestre	2026-2 (9° ciclo), UPeU campus Juliaca, sección g1
Fecha	2026-10-24
Versión	2.0

Productos

Producto	Formato sugerido por la guía	Entregado	Estado
Informe integral	PDF consolidado	Este documento y los tres entregables; el PDF completo del sitio se genera desde la vista de impresión	Entregado (versión del 2026-10-24; se regenera tras cada cambio)
Demo, video o recorrido técnico	Video o demostración en vivo	Guion en la sección 11	**Grabación pendiente**

Resumen ejecutivo

Qué se diseñó. Una arquitectura de seguridad híbrida con tres dominios:

- Sede principal segmentada y virtualizada: Proxmox VE equivalente a ESXi, OPNsense con Suricata, honeypot y Wazuh.

- Nube IaaS: el VPS de RackNerd como equivalente de EC2 en una VPC.
- Nube PaaS: Vercel y Firebase.

Los tres se integran por un túnel IPsec IKEv2 con AES-256-GCM y PFS.

Qué está implementado y verificado.

- La **nube**: VPS con firewall de host, TLS 1.2/1.3, redirección a HTTPS y base de datos solo en loopback, y la plataforma PaaS con HSTS y, desde el 2026-10-24, con cabeceras de seguridad y las reglas de Firestore corregidas publicadas. Verificado el 2026-10-24.
- La **capa de datos de la academia**: migraciones aplicadas en la base real, cuentas de mínimo privilegio, auditoría y respaldo con restauración probada (RTO de 0,23 s en la base real y 0,27–0,38 s en la base de prueba).
- Las **pruebas automáticas** de reglas, API y base de datos.
- El **SGSI completo**: 33 activos, 29 riesgos, una SoA de 93 controles, 6 políticas y procedimientos y una auditoría interna real con 11 hallazgos.

Qué está pendiente. Todo lo que requiere el hardware de la sede: hipervisor, VM, OPNsense, VLAN, VPN, Suricata, honeypot y Wazuh. Cada componente tiene procedimiento, configuración sin secretos, criterio de aceptación y evidencia por adjuntar.

Qué se cerró el 2026-10-24. La auditoría encontró fallas reales y activas, y las dos más graves se cerraron el mismo día:

- **Reglas de Firestore:** se publicaron el frontend y las reglas corregidas, y se verificó como visitante sin sesión que las matrículas pagadas ya no se pueden listar (403). La pre-matrícula pública volvió a funcionar.
- **Clave de servicio de los ZIP versionados:** fue revocada y reemplazada, y las contraseñas de las cuentas de `teachers.json` se restablecieron.

Qué sigue siendo urgente antes de la sustentación:

- Respaldos del VPS y de Firestore sin implantar.
- Dominio sin SPF ni DMARC y MFA no verificado.

1. Presentación ejecutiva

Pregunta	Respuesta
¿Qué problema resuelve?	Servicios críticos en la nube sin perímetro en la sede, sin canal privado entre la sede y el VPS, sin detección ni respaldo externo
¿Qué entrega hoy?	Perímetro y cifrado verificados en la nube; capa de datos con mínimo privilegio y restauración probada; SGSI con trazabilidad completa; diseño on-premise listo para ejecutar

Pregunta	Respuesta
¿Cuánto cuesta?	VPS de US$ 35,99 al año (ya contratado); software on-premise US$ 0; hardware por cotizar, sin presupuesto aprobado
¿Qué riesgos quedan?	4 críticos sin tratar todavía (R-04, R-07, R-11 y R-12); R-01 a R-03 se trataron el 2026-10-24. Con el plan, 11 residuales medios para aceptar
¿Qué se pide a la Dirección?	Aprobar las políticas; designar roles; autorizar las pruebas; aceptar los riesgos residuales medios (incluidos los `.env` versionados sin contraseñas); decidir la compra del hardware

2. Evidencias unificadas

Dominio	Evidencia	Tipo	Ubicación
Red (nube)	UFW con entrada denegada; PostgreSQL en loopback	Real (manual del 2026-10-17)	S2-E2 §4.1; PR-01 y PR-02
Red (nube)	Redirección 301/308, TLS 1.0/1.1 rechazados, TLS 1.2/1.3 con AEAD, certificados vigentes, `/.env` con 403	Real (verificación del 2026-10-24)	S2-E2, Anexo B; PR-03 a PR-09 y PR-13
Red (nube)	Brechas: cabeceras de seguridad ausentes en el colegio (la academia las publicó el 2026-10-24); dominio sin CAA, SPF, DMARC ni DNSSEC	Real (verificación del 2026-10-24)	PR-10 y PR-12
Red (sede)	Procedimientos de VPN, OPNsense, Suricata, Cowrie y Wazuh	Pendiente de ejecución	S2-E2 §3 a §7
Centro de datos (nube)	VPS equivalente a EC2 y su configuración	Real (manual)	S2-E3 §4.1
Centro de datos (sede)	Configuración de red de Proxmox, comandos `qm`, PBS y migración	Pendiente de ejecución	S2-E3 §3
Continuidad	REC-01 a REC-05: restauración con SHA-256 y RTO medido	Real (base de prueba y base real, REC-05)	S2-E3 §7.2; registro XLSX
Seguridad de aplicación	19 pruebas de reglas (10 fallaban con las reglas de junio; 0 fallas observadas en producción desde el 2026-10-24), 18 de API y 19 de base de datos	Real	E4 de Ingeniería de Software

Dominio	Evidencia	Tipo	Ubicación
SGSI	Inventario, riesgos, SoA, políticas, auditoría y no conformidades	Real (documental) y auditoría del 2026-10-24	S2-E1
Ética	Declaración de ética y autorización de pruebas	Pendiente de firma	S2-E1 §12

3. Análisis de riesgos

29 riesgos evaluados con ISO/IEC 27005: 7 críticos, 10 altos y 12 medios. 16 provienen de hallazgos reales. Tras el tratamiento quedarían 18 bajos y 11 medios.

Riesgo crítico	Nivel	Tratamiento	Plazo	Estado
R-01 Datos personales listables sin sesión	20	Publicar las reglas corregidas y verificar en producción	2026-10-31	Tratado (2026-10-24)
R-02 Auto-asignación de rol	16	Publicar las reglas y revisar los perfiles	2026-10-31	Tratado (2026-10-24); falta revisar los perfiles
R-04 Cambios de seguridad que no llegan a producción	16	Publicación solo por CI y comparación mensual	2026-11-07	En curso (falta el secreto del CI)
R-03 Matrícula pública bloqueada	15	Publicar las reglas y hacer una matrícula de prueba	2026-10-31	Tratado (2026-10-24)
R-07 Pérdida de datos del colegio	15	`pg_dump` diario, copia externa y restauración mensual	2026-11-07	Pendiente
R-11 Toma de cuentas por phishing	15	MFA, SPF, DKIM y DMARC	2026-10-31	Pendiente
R-12 Acceso SSH no autorizado al VPS	15	Verificar solo llaves, fail2ban y SSH por VPN	2026-11-07	Pendiente

Detalle completo en S2-E1 §6 y §7 y en s2-e1-matriz-riesgos.xlsx.

4. Declaración de Aplicabilidad

Tema	Controles	Implementado	Parcial	Planificado	No aplicable
5. Organizacionales	37	4	22	11	0
6. De personas	8	0	2	6	0
7. Físicos	14	0	0	14	0

Tema	Controles	Implementado	Parcial	Planificado	No aplicable
8. Tecnológicos	34	5	22	6	1
Total	93	9	46	37	1

Implementados con evidencia: 5.9, 5.12, 5.27, 5.37, 8.11, 8.26, 8.29, 8.33 y 8.34. Excluido: 8.30. Detalle en S2-E1 §8 y en s2-e1-declaracion-aplicabilidad.xlsx.

5. Declaración ética

La declaración de ética de seguridad (S2-E1 §12.7) y la declaración de responsabilidad ética del Semestre 1 (Producto final S1 §11) están **pendientes de firma** por los 4 integrantes. El comportamiento observado es coherente con ellas:

- Pruebas en el emulador y en bases de prueba.
- Auditoría de producción en modo solo lectura.
- Indicadores con conteos agregados.
- Verificación externa no intrusiva.
- Secretos reportados sin rutas exactas.

6. Pruebas

Tipo	Total	Con resultado real	Pendientes
Pruebas de red y perímetro (PR)	37	11 conformes y 2 no conformes	24
Pruebas de recuperación (REC)	12	5	7
Pruebas automáticas de software (E4)	90	90 en verde con las reglas corregidas	Primera ejecución del CI en GitHub

Incluyen pruebas positivas (permitido), negativas (denegado, rechazo de un respaldo alterado, negativa a restaurar sobre producción) y de detección (pendientes).

7. Monitoreo

Aspecto	Estado
Disponibilidad de la API y de MySQL (`/health` y panel de infraestructura)	Implementado
Rutinas de operación del VPS (diaria, semanal y mensual)	Documentado en el manual

Aspecto	Estado
Registros locales (morgan, Nginx y autenticación)	Implementado, sin centralizar
Uptime Kuma con latido externo	Pendiente (puede desplegarse de forma transitoria en la PC local)
Netdata y Wazuh	Pendientes (requieren el host)

8. Respaldo y recuperación

Sistema	Respaldo	Restauración probada	RTO objetivo / medido
MySQL de la academia	`backup.js` con SHA-256 (falta programarlo a diario)	Sí: REC-01 a REC-04 en base de prueba y REC-05 en la base real	< 1 h / 0,23 s (base real)
PostgreSQL del colegio	Diseñado, no implantado	No	2 h / pendiente
Firestore	No programado	No	4 h / pendiente
VM de la sede	PBS (diseñado)	No	2 h / pendiente
SPA en Vercel	Código en Git y despliegues anteriores	No ensayada	15 min / pendiente

9. Recomendaciones finales

N°	Recomendación	Riesgo o NC	Plazo
1	Publicar las reglas de Firestore corregidas por el CI **antes de difundir el sitio de documentación actualizado** y verificar una matrícula sin sesión	R-01 a R-04, NC-01 y NC-02	Hecho (2026-10-24), desde la consola; la publicación por CI sigue en R-04
2	Revocar y rotar la clave de la cuenta de servicio; retirar todas las copias ZIP y depurar el historial; agregar escaneo de secretos al CI	R-05, R-06 y NC-03	Rotación hecha (2026-10-24); copias ZIP a cargo del equipo; escaneo en el CI 2026-11-07
3	Activar MFA en Google, GitHub, Vercel, RackNerd y Punto.pe; publicar SPF, DKIM y DMARC	R-11 y NC-07	2026-10-31
4	Implantar `pg_dump` diario en el VPS con copia externa y ejecutar REC-06	R-07 y NC-04	2026-11-07

N°	Recomendación	Riesgo o NC	Plazo
5	Agregar cabeceras de seguridad y `server_tokens off` ; verificar SSH e instalar fail2ban; publicar CAA	R-12 a R-14	Academia: cabeceras publicadas (2026-10-24). Colegio: 2026-11-07 a 2026-11-14
6	Desplegar Uptime Kuma (de forma transitoria) con latido externo y medir la disponibilidad	R-09 y NC-05	2026-11-14
7	Programar la exportación de Firestore y ejecutar REC-11	R-10 y NC-06	2026-11-21
8	Montar un laboratorio con Proxmox para ejecutar PR-14 a PR-35, REC-07, REC-09 y REC-12, rotulando la evidencia como de laboratorio	R-15, R-16 y R-20	2026-11-21
9	Realizar la revisión por la dirección: aprobar las políticas, designar roles, aceptar los riesgos residuales y decidir el presupuesto	Cláusula 9.3	Semana del 2026-11-23
10	Adquirir el hardware y ejecutar la fase 2 en la sede	R-15 a R-19, R-26 y R-28	2027-I

10. Trazabilidad con el diseño técnico consolidado del Semestre 1

Elemento del diseño (S1)	Implementación o evidencia (S2)	Estado
Zonas y VLAN (S1-E1 §8)	Procedimiento de OPNsense, switch y Wi-Fi (S2-E2 §4.2); pruebas PR-14 a PR-23	Pendiente
Perímetro de la nube (UFW-01 a UFW-05)	PR-01 y PR-02	Implementado
Cifrado en tránsito	PR-03 a PR-07 y PR-13	Implementado y verificado
VPN IPsec (S1-E1 §10)	Procedimiento y configuración sin secretos (S2-E2 §3)	Pendiente
Detección (S1-E1 §14)	Procedimientos de Suricata, Cowrie y Wazuh (S2-E2 §6)	Pendiente
Host y VM (S1-E2 §5 y §6)	Procedimiento de Proxmox (S2-E3 §3)	Pendiente
Nube equivalente a AWS (S1-E2 §7)	VPS, UFW y PaaS (S2-E3 §4)	Implementado (NACL y `dum0` pendientes)
Integración híbrida (S1-E2 §8)	Proxy de la API y túnel (S2-E3 §4.4)	Pendiente
Continuidad 3-2-1 y RTO/RPO (S1-E2 §11)	REC-01 a REC-05 ejecutados; REC-06 a REC-12 pendientes (S2-E3 §7 y §8)	Parcial

Elemento del diseño (S1)	Implementación o evidencia (S2)	Estado
Requisitos RQ-01 a RQ-15 (Producto final S1 §6)	Verificaciones asignadas por requisito	Parcial
Riesgos y controles	SoA y matriz maestra (S2-E1 §8 y §14.2)	Establecido

11. Guion del recorrido técnico (demo)

Estado: grabación pendiente. Duración objetivo: 12 minutos.

Minuto	Contenido	Evidencia mostrada
0–2	Problema y arquitectura híbrida	Diagramas draw.io de topología general y zonas
2–4	Perímetro de la nube en vivo	`curl -I` (redirección, cabeceras) y `openssl s_client` (TLS) contra los dominios propios; captura de `ufw status verbose`
4–6	Seguridad de aplicación	Suite de 19 pruebas en el emulador: 19/19 con las reglas corregidas y 10 fallas con las de junio; consulta sin sesión que hoy devuelve 403 en producción
6–8	Recuperación en vivo	`node scripts/backup.js` y `node scripts/restore.js` en la base de prueba, con el RTO medido y la línea del registro
8–10	SGSI	Del riesgo R-01 al control 5.15 de la SoA y a su evidencia, con la no conformidad NC-01, su acción y su cierre del 2026-10-24
10–12	Pendientes y plan	Hoja de ruta, laboratorio y decisiones que se piden a la Dirección

12. Evaluación de cierre de la línea

La guía exige demostrar coherencia entre requerimientos, diseño, implementación, seguridad, operación, monitoreo, documentación, repositorio técnico y sustentación. La tabla resume la evidencia disponible y la brecha de cada aspecto. No es una autoevaluación: el nivel lo asigna el jurado.

Aspecto	Evidencia disponible	Brecha pendiente
Requerimientos	15 requisitos trazados a diseño y prueba (Producto final S1 §6)	Validar los supuestos con mediciones (ISP, energía y carga)
Diseño	Red, centro de datos, equivalencias, matrices y diagramas editables (S1)	—

Aspecto	Evidencia disponible	Brecha pendiente
Implementación	Nube y capa de datos operativas	Sede on-premise, VPN y detección
Seguridad	SGSI con riesgos, SoA, políticas y auditoría real; mínimo privilegio en las bases	Cerrar NC-04 a NC-08 (NC-01 a NC-03 se cerraron el 2026-10-24)
Operación	Procedimientos del VPS; respaldo y restauración de MySQL	Respaldos del VPS y de Firestore; laboratorio
Monitoreo	`/health` y registros locales	Uptime Kuma, Netdata y Wazuh
Documentación	8 documentos versionados con evidencia y pendientes declarados; PDF consolidado	Adjuntar capturas del laboratorio
Repositorio técnico	Scripts, CI, pruebas, matrices reproducibles y diagramas	Carpeta `infra/` con configuraciones sanitizadas; limpiar secretos del historial
Sustentación	Guion del recorrido técnico	Grabación y defensa individual

Pregunta central de la guía: *¿el estudiante puede diseñar, implementar, validar, operar y defender una solución de infraestructura tecnológica híbrida con criterio profesional, responsabilidad ética y evidencia técnica verificable?*

Respuesta basada en la evidencia:

- **Diseñar:** demostrado con un diseño completo, trazable y con equivalencias justificadas.
- **Implementar, validar y operar:** demostrado en la nube y en la capa de datos, con verificaciones reproducibles y una restauración medida. En la sede queda pendiente de hardware, con procedimientos listos.
- **Responsabilidad ética:** practicada (pruebas acotadas, sin datos ni secretos expuestos y hallazgos propios reportados), con las firmas pendientes.
- **Defender:** se completará en la sustentación.

Rúbricas aplicables

La guía no define una rúbrica propia para el producto final del Semestre 2; se evalúa con las rúbricas de los entregables que integra y con la evaluación de cierre de la sección 12.

S2-E1 · CE0321–CE0324 — Planificación e Implementación del SGSI

N°	Criterio de evaluación	Peso
1	Contexto, alcance y liderazgo del SGSI	10%
2	Inventario de activos y clasificación de información	10%
3	Evaluación y tratamiento de riesgos (ISO/IEC 27005)	18%

N°	Criterio de evaluación	Peso
4	Declaración de Aplicabilidad (SoA) y selección de controles	12%
5	Políticas y procedimientos del SGSI	10%
6	Gestión de identidades, accesos y protección de datos (gobernanza)	8%
7	Gestión de incidentes, continuidad y recuperación (planificación)	8%
8	Ética de la seguridad de la información	8%
9	Monitoreo, medición y auditoría interna del SGSI	9%
10	Calidad documental y sustentación	7%
	Total	**100%**

S2-E2 · CE0312–CE0313 — Implementación, Testing y Monitoreo de Red

N°	Criterio de evaluación	Peso
1	Trazabilidad con el diseño de red (Semestre 1)	6%
2	Conectividad híbrida implementada: VPN y enrutamiento	15%
3	Seguridad perimetral implementada: firewall, DMZ y segmentación	22%
4	IDS/IPS, honeypot y detección implementados	18%
5	Monitoreo, registros y visibilidad de red	15%
6	Plan y resultados de pruebas técnicas	12%
7	Calidad documental, evidencias y repositorio	6%
8	Sustentación técnica	6%
	Total	**100%**

S2-E3 · CE0332–CE0333 — Implementación, Gestión y Control de Centro de Datos

N°	Criterio de evaluación	Peso
1	Trazabilidad con el diseño de centro de datos (Semestre 1)	6%
2	Implementación on-premise: hipervisor ESXi y VMs	18%

N°	Criterio de evaluación	Peso
3	Implementación AWS: VPC, EC2, Security Groups y NACL	18%
4	Gestión de identidades y accesos del centro de datos	14%
5	Inventario final de activos con evidencia	12%
6	Continuidad: backup, restore y recuperación probada	14%
7	Monitoreo y control operativo del centro de datos	10%
8	Calidad documental, control de versiones y sustentación	8%
	Total	**100%**

Escala: Excelente 4, Logrado 3, En proceso 2, Insuficiente 1 y No evidenciado 0. Puntaje = peso × (nivel / 4).

Sustentación

Guía de sustentación y defensa técnica

> **Por qué existe esta página**
>
> En la versión vigente de la guía oficial (septiembre de 2026), la sustentación ya no es un entregable aparte (el antiguo E5, CE0217). Se evalúa en **cada** entregable: criterio "Sustentación y defensa técnica" y anexo "Evidencia de sustentación". En Infraestructura pesa entre 6 % y 8 %, y la sustentación individual puede complementar la nota del equipo para verificar autoría y dominio técnico. Esta guía organiza esa defensa.

1. Reparto por integrante

Cada integrante debe dominar el sistema completo y defender en profundidad al menos un área. El historial de git muestra un solo autor, así que el jurado puede preguntar a cualquiera.

Área / entregable	Responsable principal	Suplente
Gestión TI (E1–E5)	(a definir por el equipo)	(a definir)
Software E1–E2: requerimientos y datos	(a definir)	(a definir)
Software E3–E4: sistema, pruebas y CI	(a definir)	(a definir)
Infraestructura (S1 y S2)	(a definir)	(a definir)

2. Guion de demostración (10 minutos)

Min.	Qué se muestra	Dónde	Mensaje
0–1	Problema y solución	Inicio del sitio	Procesos dispersos → plataforma única con portales por rol
1–3	Pre-matrícula pública	`/matricula`	Validación de ciclo, grupo y cupo; un teléfono no se duplica en el grupo
3–4	Aprobación y pago	`/admin/matriculas` , `/admin/pagos`	Máquina de estados; un pago no se borra, se anula con autor
4–5	Asistencia por QR	Portal auxiliar	QR firmado; entrada y salida alternan por día
5–6	Consulta de padres	`/consulta-asistencia`	Código sin caracteres ambiguos, solo lectura

Min.	Qué se muestra	Dónde	Mensaje
6–8	Calidad	Pestaña *Actions* o terminal	90 pruebas; las reglas de junio fallaban 10 de 19, las corregidas pasan todas y están publicadas desde el 2026-10-24
8–9	Datos	Salida de `92_pruebas_bd.sql` y de `restore.js`	Integridad en la base, auditoría y RTO medido
9–10	Cierre	Plan de mejora del E4	Qué falta, por qué y con qué métrica se medirá

Plan B sin Internet: ejecutar en local `npm run test:rules` (emulador) y las pruebas de la base en MySQL local, y mostrar las capturas del E1.

3. Mensajes clave por entregable

Entregable	Qué defender	Evidencia que mostrar
Gestión TI E1–E5	Diagnóstico, business case con supuestos explícitos, plan, procesos AS-IS/TO-BE y ecosistema colegio + academia	Documentos de Gestión TI y modelo financiero en Excel
Software E1	Requisitos, reglas de negocio aplicadas en código, C4, ADR, estados y trazabilidad hasta las pruebas	E1
Software E2	Integridad en la base: FK, CHECK, procedimientos, triggers, roles y restauración probada	E2, `92_pruebas_bd.sql`
Software E3	Integración Firebase + API + analítica; patrones; manejo de errores; despliegue	E3, URL de Vercel
Software E4	Pruebas en 4 niveles, CI, incidente de las reglas, gestión ágil y CMMI	E4
Infraestructura	Diseño híbrido (sede + VPS + PaaS), SGSI, y qué está implementado y qué falta ejecutar	Infraestructura

4. Preguntas probables y respuestas preparadas

Pregunta	Respuesta
¿Por qué Firestore y además MySQL?	Firestore da tiempo real y reglas por rol sin servidor propio. MySQL resuelve reportes, conciliación y auditoría, que Firestore no hace bien. La réplica nunca bloquea la operación.

Pregunta	Respuesta
¿Qué pasa si se cae la API o MySQL?	La matrícula, los pagos y la asistencia siguen funcionando: la sincronización no bloquea y es idempotente. Los eventos perdidos aparecen en `v_conciliacion_pagos`.
¿Cómo saben que las reglas de seguridad funcionan?	Con 19 pruebas en el emulador que corren en el CI. Contra las reglas que estaban publicadas fallaban 10: así encontramos 3 fallas reales en producción. Publicamos la versión corregida el 2026-10-24 y lo verificamos como visitante sin sesión: listar matrículas pagadas ahora devuelve 403.
¿Por qué las reglas de producción estaban desactualizadas?	La línea 1 del archivo tenía un `#`, que no es sintaxis válida, y el despliegue fallaba sin que nadie lo viera. La versión corregida se publicó el 2026-10-24 desde la consola, después de pasar las 19 pruebas; cuando se configure el secreto del CI, la publicación será automática y solo tras las pruebas.
¿Cómo evitan que se falsifique un QR?	El QR lleva una firma opaca que la regla compara con `studentQrSignatures`. La marca corre en una transacción que impide dobles registros.
¿Quién puede escribir en MySQL?	Solo los procedimientos almacenados. La cuenta de la API recibe "permiso denegado" si intenta un INSERT directo; lo comprobamos.
¿El sistema se usa de verdad?	Está desplegado y en piloto con volumen bajo: 8 matrículas, 2 pagos, 7 marcas y 8 usuarios. No lo presentamos como adopción masiva; las metas de uso están en Gestión TI E5.
¿Por qué nivel 1 de CMMI si hay tantas pruebas?	Las prácticas técnicas están maduras, pero faltan estimación, revisiones registradas y gestión de configuración sin secretos. El plan de mejora lleva esas áreas al nivel 2.
¿Qué datos personales usaron para el informe?	Ninguno. Los indicadores son conteos agregados, y las pruebas usan el emulador y datos ficticios.
¿Por qué Vercel y no el VPS del colegio?	Son sistemas distintos: el colegio corre en su VPS y la academia en su propio dominio de Vercel. Llevar la capa relacional de la academia al VPS es viable, con el límite de 2 GB de RAM compartida.

5. Evidencias a tener abiertas antes de empezar

- [ ] Sitio desplegado: academia-school-platform.vercel.app
- [ ] Repositorio y pestaña *Actions* con el último pipeline en verde
- [ ] Terminal con `npm test` y `npm run test:rules` listos para ejecutar
- [ ] Salidas de `92_pruebas_bd.sql` (19/19) y de `scripts/restore.js`
- [ ] Sitio de esta documentación y PDF consolidado
- [ ] Actas firmadas (validación con la academia y declaración de ética) cuando existan

6. Registro de sustentación por entregable

Entregable	Fecha	Docente	Integrante(s)	Observaciones	Acciones acordadas
(completar tras cada exposición)					